

Governance- und Managementziele

Über ISACA

ISACA® (isaca.org) ist ein seit nahezu 50 Jahren bestehender globaler Verband, der Einzelpersonen und Unternehmen dabei unterstützt, Technologiepotenziale auszuschöpfen. Technologie treibt die Welt von heute an, und ISACA stattet Experten mit Know-how und Qualifikationen aus, führt Fortbildungen durch und erweitert konsequent das Kontaktnetzwerk, um die Karriere dieser Experten voranzubringen und ihre Organisationen bei der Transformation zu unterstützen. ISACA nutzt die Expertise von einer halben Million engagierter Fachleute in den Bereichen Informations- und Cybersicherheit, Governance, Assurance, Risiko und Innovation sowie die Erfahrung ihrer Tochtergesellschaft CMMI® Institute, um Innovation mittels Technologie voranzutreiben. ISACA ist in mehr als 188 Ländern vertreten, darunter mehr als 217 Chapter und Büros in den Vereinigten Staaten und China.

Haftungsausschluss

ISACA hat das *COBIT® 2019-Rahmenwerk: Governance- und Managementziele* (das „Werk“) in erster Linie als Weiterbildungsressource für EGIT- (Enterprise Governance of Information and Technology), Prüfungs-, Risiko- und Sicherheitsexperten konzipiert und erstellt. ISACA übernimmt keinerlei Gewähr, dass die Verwendung des Werks zu den gewünschten Ergebnissen führen wird. Das Werk sollte weder dahingehend ausgelegt werden, dass alle erforderlichen Informationen, Verfahren und Tests darin enthalten sind, noch dahingehend, dass alle nicht enthaltenen Informationen, Verfahren und Tests, mit denen dieselben Ergebnisse erzielt werden können, ausgeschlossen sind. Bei der Überlegung, wie angemessen bestimmte Informationen, Verfahren oder Tests sind, sollte sich der Anwender auf sein fachliches Urteilsvermögen stützen und die spezifischen Umstände berücksichtigen, die sich aus dem jeweiligen System oder der IT-Umgebung ergeben.

Disclaimer

ISACA has designed and created *COBIT® 2019 Framework: Governance and Management Objectives* (the „Work“) primarily as an educational resource for enterprise governance of information and technology (EGIT), assurance, risk and security professionals. ISACA makes no claim that use of any of the Work will assure a successful outcome. The Work should not be considered inclusive of all proper information, procedures and tests or exclusive of other information, procedures and tests that are reasonably directed to obtaining the same results. In determining the propriety of any specific information, procedure or test, enterprise governance of information and technology (EGIT), assurance, risk and security professionals should apply their own professional judgment to the specific circumstances presented by the particular systems or information technology environment.

Quality Statement

This Work is translated into *German* from the English language version of *COBIT® 2019 Framework: Governance and Management Objectives* by the ISACA Germany Chapter with the permission of ISACA®. The ISACA Germany Chapter assumes sole responsibility for the accuracy and faithfulness of the translation.

Verantwortlichkeit für die Übersetzung

Das vorliegende Werk ist die *deutsche* Übersetzung der englischen Version *COBIT® 2019 Framework: Governance and Management Objectives*. ISACA Germany Chapter hat die Übersetzung mit der Genehmigung der ISACA® ausgeführt. ISACA Germany Chapter übernimmt die alleinige Verantwortung für die Richtigkeit und Originaltreue der Übersetzung.

Copyright

© 2020 ISACA. Alle Rechte vorbehalten. Handbücher zur Verwendung sind unter www.isaca.org/COBITuse verfügbar.

© 2020 ISACA. All rights reserved. For usage guidelines, see www.isaca.org/COBITuse.

COBIT® 2019-Rahmenwerk: Governance- und Managementziele

ISBN 978-1-60420-858-0

ISACA

1700 E. Golf Road, Suite 400

Schaumburg, IL 60173, USA

Telefon: +1.847.660.5505

Fax: +1.847.253.1755

Kontaktieren Sie uns unter: <https://support.isaca.org>

Website: www.isaca.org

Besuchen Sie die ISACA Online-Foren: <https://engage.isaca.org/onlineforums>

Twitter: <http://twitter.com/ISACANews>

LinkedIn: <http://linkd.in/ISACAOOfficial>

Facebook: www.facebook.com/ISACAHQ

Instagram: www.instagram.com/isacanews/

In memoriam: John Lainhart (1946–2018)

Gewidmet John Lainhart, dem ISACA-Vorstandsvorsitzenden von 1984–1985. John war maßgeblich an der Erstellung des COBIT®-Rahmenwerks beteiligt und hatte zuletzt den Vorsitz der COBIT® 2019-Arbeitsgruppe inne, die mit diesem Werk ein erfolgreiches Ergebnis präsentiert. Während seiner vier Jahrzehnte bei ISACA nahm John zahlreiche Aufgaben innerhalb des Verbandes wahr. Er verfügte über die ISACA-Zertifizierungen CISA, CRISC, CISM und CGEIT. John hinterlässt ein bemerkenswertes persönliches und fachliches Vermächtnis. Sein Einsatz hatte wesentlichen Einfluss auf die Entwicklung von ISACA.

Danksagungen

Die ISACA dankt den folgenden Unterstützern:

COBIT-Arbeitsgruppe (2017–2018)

John Lainhart, Vorsitzender, CISA, CRISC, CISM, CGEIT, CIPP/G, CIPP/US, Grant Thornton, USA

Matt Conboy, Cigna, USA

Ron Saull, CGEIT, CSP, Great-West Lifeco & IGM Financial (im Ruhestand), Kanada

Entwicklungsteam

Steven De Haes, Ph.D., Management School der Universität Antwerpen, Belgien

Matthias Goorden, PwC, Belgien

Stefanie Grijp, PwC, Belgien

Bart Peeters, PwC, Belgien

Geert Poels, Ph.D., Universität Gent, Belgien

Dirk Steuperaert, CISA, CRISC, CGEIT, IT In Balance, Belgien

Review-Experten

Sarah Ahmad Abedin, CISA, CRISC, CGEIT, Grant Thornton LLP, USA

Floris Ampe, CISA, CRISC, CGEIT, CIA, ISO27000, PRINCE2, TOGAF, PwC, Belgien

Elisabeth Antonssen, Nordea Bank, Schweden

Krzysztof Baczkiwicz, CHAMP, CITAM, CSAM, Transpectit, Polen

Christopher M. Ballister, CRISC, CISM, CGEIT, Grant Thornton, USA

Gary Bannister, CGEIT, CGMA, FCMA, Österreich

Graciela Braga, CGEIT, Prüferin und Beraterin, Argentinien

Ricardo Bria, CISA, CRISC, CGEIT, COTO CICSA, Argentinien

Sushil Chatterji, CGEIT, Edutech Enterprises, Singapur

Peter T. Davis, CISA, CISM, CGEIT, COBIT 5 Assessor, CISSP, CMA, CPA, PMI-RMP, PMP, Peter Davis+Associates, Kanada

James Doss, CISM, CGEIT, EMCCA, ITIL-Experte, PMP, SSGB, TOGAF 9, ITvalueQuickStart.com, USA

Yalcin Gerek, CISA, CRISC, CGEIT, ITIL-Experte, Prince2, ISO 20000LI, ISO27001LA, TAC AS., Türkei

James L. Golden, Golden Consulting Associates, USA

J. Winston Hayden, CISA, CISM, CRISC, CGEIT, Südafrika

Jimmy Heschl, CISA, CISM, CGEIT, Red Bull, Österreich

Jorge Hidalgo, CISA, CISM, CGEIT, Chile

John Jasinski, CISA, CRISC, CISM, CGEIT, COBIT 5-Assessor, CSM, CSPO, IT4IT-F, ITIL-Experte, Lean IT-F, MOF, SSBB, TOGAF-F, USA

Joanna Karczewska, CISA, Polen

Glenn Keaveny, CEH, CISSP, Grant Thornton, USA

Eddy Khoo S. K., CGEIT, Kuala Lumpur, Malaysia

Joao Souza Neto, CRISC, CGEIT, Universidade Católica de Brasília, Brasilien

Tracey O'Brien, CISA, CISM, CGEIT, IBM Corp (im Ruhestand), USA

Zachy Olorunojowon, CISA, CGEIT, PMP, BC Ministry of Health, Victoria, BC, Kanada

Opeyemi Onifade, CISA, CISM, CGEIT, BRMP, CISSP, ISO 27001LA, M.IoD, Afenoid Enterprise Limited, Nigeria

Andre Pitkowski, CRISC, CGEIT, CRMA-IIA, OCTAVE, SM, APIT Consultoria de Informatica Ltd., Brasilien

Abdul Rafeq, CISA, CGEIT, FCA, Geschäftsführer, Wincer Infotech Limited, Indien

Dirk Reimers, Entco Deutschland GmbH, A Micro Focus Company

Steve Reznik, CISA, CRISC, ADP, LLC., USA

Bruno Horta Soares, CISA, CRISC, CGEIT, PMP, GOVaaS – Governance Advisors, as-a-Service, Portugal

Dr. Katalin Szenes, Ph.D., CISA, CISM, CGEIT, CISSP, John von Neumann Fakultät für Informatik, Óbuda-Universität, Ungarn

Peter Tessin, CISA, CRISC, CISM, CGEIT, Discover, USA

Mark Thomas, CRISC, CGEIT, Escoute, USA

Danksagungen (Forts.)

Review-Experten (Forts.)

John Thorp, CMC, ISP, ITCP, The Thorp Network, Kanada
Greet Volders, CGEIT, COBIT-Beurteilender, Voqualis N.V., Belgien
Markus Walter, CISA, CISM, CISSP, ITIL, PMP, TOGAF, PwC Singapur/Schweiz
David M. Williams, CISA, CAMS, Westpac, Neuseeland
Greg Witte, CISM, G2 Inc., USA

Vorstand der ISACA

Rob Clyde, CISM, Clyde Consulting LLC, USA, Vorsitzender
Brennan Baybeck, CISA, CRISC, CISM, CISSP, Oracle Corporation, USA, stellv. Vorsitzender
Tracey Dedrick, ehemaliger Chief Risk Officer bei Hudson City Bancorp, USA
Leonard Ong, CISA, CRISC, CISM, CGEIT, COBIT 5 Implementierer und Assessor, CFE, CIPM, CIPT, CISSP, CITBCM, CPP, CSSLP, GCFA, GCIA, GCIH, GSNA, ISSMP-ISSAP, PMP, Merck & Co., Inc., Singapur
R.V. Raghu, CISA, CRISC, Versatilist Consulting India Pvt. Ltd, Indien
Gabriela Reynaga, CISA, CRISC, COBIT 5 Foundation, GRCP, Holistics GRC, Mexiko
Gregory Touhill, CISM, CISSP, Cyxtera Federal Group, USA
Ted Wolff, CISA, Vanguard, Inc., USA
Tichaona Zororo, CISA, CRISC, CISM, CGEIT, COBIT 5-Assessor, CIA, CRMA, EGIT, Governance of IT, Südafrika
Theresa Grafenstine, CISA, CRISC, CGEIT, CGAP, CGMA, CIA, CISSP, CPA, Deloitte & Touche LLP, USA, ISACA-Vorstandsvorsitzende von 2017–2018
Chris K. Dimitriadis, Ph.D., CISA, CRISC, CISM, INTRALOT, Griechenland, ISACA-Vorstandsvorsitzender von 2015–2017
Matt Loeb, CGEIT, CAE, FASAE, Chief Executive Officer, ISACA, USA
Robert E. Stroud (1965–2018), CRISC, CGEIT, XebiaLabs, Inc., USA, ISACA-Vorstandsvorsitzender, von 2014–2015
ISACA ist zutiefst betrübt über das Ableben von Robert E. Stroud im September 2018.

Übersetzungsteam

Frank Schütz, Sprachenreich GmbH, Deutschland

Review durch:

Markus Gaulke, CISA, CISM, CGEIT, CRISC, KPMG AG Wirtschaftsprüfungsgesellschaft, Vorstand ISACA Germany Chapter e.V., Fachbuchautor Praxiswissen COBIT, Deutschland

INHALTSVERZEICHNIS

Abbildungsverzeichnis	8
Kapitel 1 Einführung in COBIT® 2019	9
1.1 COBIT als Rahmenwerk für die Governance von Informationen und Technologie	9
1.1.1 Was ist COBIT und was nicht?	9
1.2 Überblick über COBIT® 2019	10
1.3 Terminologie und wesentliche Konzepte des COBIT-Rahmenwerks	11
1.3.1 Governance- und Managementziele	11
1.3.2 Komponenten des Governance-Systems	12
1.3.3 Schwerpunktbereiche	14
Kapitel 2 Aufbau dieser Publikation und Zielgruppen	15
2.1 Aufbau dieser Publikation	15
2.2 Zielgruppen	15
Kapitel 3 Struktur der COBIT Governance- und Managementziele	17
3.1 Einführung	17
3.2 Governance- und Managementziele	17
3.3 Zielkaskade	18
3.4 Komponente: Prozess	19
3.5 Komponente: Organisationsstrukturen	20
3.6 Komponente: Informationsflüsse und -elemente	22
3.7 Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen	24
3.8 Komponente: Richtlinien und Verfahren	25
3.9 Komponente: Kultur, Ethik und Verhalten	25
3.10 Komponente: Services, Infrastruktur und Anwendungen	25
Kapitel 4 COBIT Governance- und Managementziele – detaillierte Anleitungen	27
COBIT-Kernmodell	27
4.1 Evaluieren, Vorgeben und Überwachen	27
4.2 Anpassen, Planen und Organisieren	55
4.3 Aufbauen, Beschaffen und Implementieren	159
4.4 Bereitstellen, Betreiben und Unterstützen	247
4.5 Überwachen, Evaluieren und Beurteilen	291
Anhänge	321
A.1 Anhang A: Zielkaskade – Zuordnungstabellen	321
A.2 Anhang B: Organisationsstrukturen – Übersicht und Beschreibungen	323
A.3 Anhang C: Detaillierte Liste der Referenzen	325

ABBILDUNGSVERZEICHNIS

Kapitel 1 Einführung in COBIT® 2019

Abbildung 1.1: COBIT-Übersicht	10
Abbildung 1.2: COBIT-Kernmodell	12
Abbildung 1.3: COBIT-Komponenten eines Governance-Systems	13

Kapitel 3 Struktur der COBIT Governance- und Managementziele

Abbildung 3.1: Darstellung der Governance- und Managementziele	18
Abbildung 3.2: Darstellung der zugehörigen Unternehmens- und IT-bezogenen Ziele	18
Abbildung 3.3: Darstellung der zugehörigen Ziele und Beispielmetriken	19
Abbildung 3.4: Darstellung der Prozesskomponente.....	19
Abbildung 3.5: Prozessfähigkeitsstufen.....	20
Abbildung 3.6: Darstellung der Komponente Organisationsstrukturen.....	21
Abbildung 3.7: Darstellung der Komponente Informationsflüsse und -elemente	23
Abbildung 3.8: Outputs an verschiedene Prozesse	23
Abbildung 3.9: Darstellung der Komponente Mitarbeiter, Fähigkeiten und Kompetenzen	24
Abbildung 3.10: Darstellung der Komponente Richtlinien und Verfahren	25
Abbildung 3.11: Darstellung der Komponente Kultur, Ethik und Verhalten.....	25
Abbildung 3.12: Darstellung der Komponente Services, Infrastruktur und Anwendungen	25

Anhänge

Abbildung A.1: Zuordnung von Unternehmenszielen zu IT-bezogenen Zielen	321
Abbildung A.2: Zuordnung von Governance- und Managementzielen zu IT-bezogenen Zielen.....	322
Abbildung A.3: COBIT Rollen und Organisationsstrukturen.....	323

Kapitel 1

Einführung in COBIT® 2019

1.1 COBIT als Rahmenwerk für die Governance von Informationen und Technologie

Im Laufe der Jahre wurden Rahmenwerke auf der Basis von bewährten Praktiken mit dem Ziel entwickelt und vorangetrieben, den Prozess des Verstehens, Konzipierens und Implementierens der Governance der unternehmensweiten I&T (EGIT) zu unterstützen. COBIT® 2019 baut auf mehr als 25 Jahren Entwicklungsarbeit in diesem Bereich auf, wobei nicht nur neue Erkenntnisse aus der Wissenschaft einfließen, sondern diese Erkenntnisse auch Anwendung in der Praxis finden.

Seit seiner Gründung hat sich COBIT® zu einem immer weiteren und umfassenderen Governance- und Management-Rahmenwerk für Informationen und Technologie (I&T) entwickelt und etabliert sich zunehmend als allgemein anerkanntes Rahmenwerk für die I&T-Governance.

1.1.1 Was ist COBIT und was nicht?

Bevor nachfolgend das aktualisierte COBIT-Rahmenwerk beschrieben wird, ist es wichtig darzulegen, was COBIT ist und was nicht:

COBIT ist ein Rahmenwerk für Governance und Management der unternehmensweiten Informationen und Technologie. Unter unternehmensweiter I&T versteht man die gesamte Informationsverarbeitung und Technologie, die das Unternehmen einsetzt, um seine Ziele zu erreichen, unabhängig davon, wo im Unternehmen dies stattfindet. Mit anderen Worten: unternehmensweite I&T ist nicht auf die IT-Abteilung einer Organisation beschränkt schließt diese aber ein.

Das COBIT-Rahmenwerk unterscheidet klar zwischen Governance und Management. Diese beiden Disziplinen umfassen unterschiedliche Aktivitäten, erfordern unterschiedliche Organisationsstrukturen und dienen unterschiedlichen Zwecken.

• **Governance** gewährleistet, dass:

- die Bedürfnisse, Voraussetzungen und Optionen der Anspruchsgruppen evaluiert werden, um ausgewogene, vereinbarte Unternehmensziele festzulegen.
- eine Ausrichtung durch Priorisierung und Entscheidungsfindung vorgegeben wird.
- die Leistung und Compliance anhand der vereinbarten Ausrichtung und den Zielen beurteilt werden.

In den meisten Unternehmen liegt die Gesamtverantwortung für die Governance in den Händen der Geschäftsleitung unter der Führung des Vorsitzenden. Einzelne Verantwortlichkeiten hinsichtlich Governance können auch an andere geeignete Ebenen in der Organisationsstruktur delegiert werden, insbesondere in größeren, komplexen Unternehmen.

• **Management** umfasst die Planung, Begründung und Überwachung von Aktivitäten in Übereinstimmung mit der vom Governance-Organ vorgegebenen Richtung, um die Unternehmensziele zu erreichen.

In den meisten Unternehmen obliegt das Management den obersten Führungskräften unter der Leitung des Chief Executive Officer (CEO).

COBIT definiert die Komponenten zum Aufbau und zur Aufrechterhaltung eines Governance-Systems: Prozesse, Organisationsstrukturen, Richtlinien und Verfahren, Informationsflüsse, Kultur und Verhalten, Fähigkeiten und Infrastruktur.¹

COBIT definiert ebenfalls Designfaktoren, die vom Unternehmen berücksichtigt werden sollten, um das am besten geeignete Governance-System aufzubauen.

COBIT setzt bei Governance-Fragestellungen an, indem relevante Governance-Komponenten zu Governance- und Managementzielen gruppiert werden, die im Hinblick auf die erforderlichen Fähigkeitsstufen gemanagt werden können.

¹ Diese Komponenten wurden in COBIT® 5 als Enabler bezeichnet.

Mehrere Missverständnisse zu COBIT sollen aber auch ausgeräumt werden:

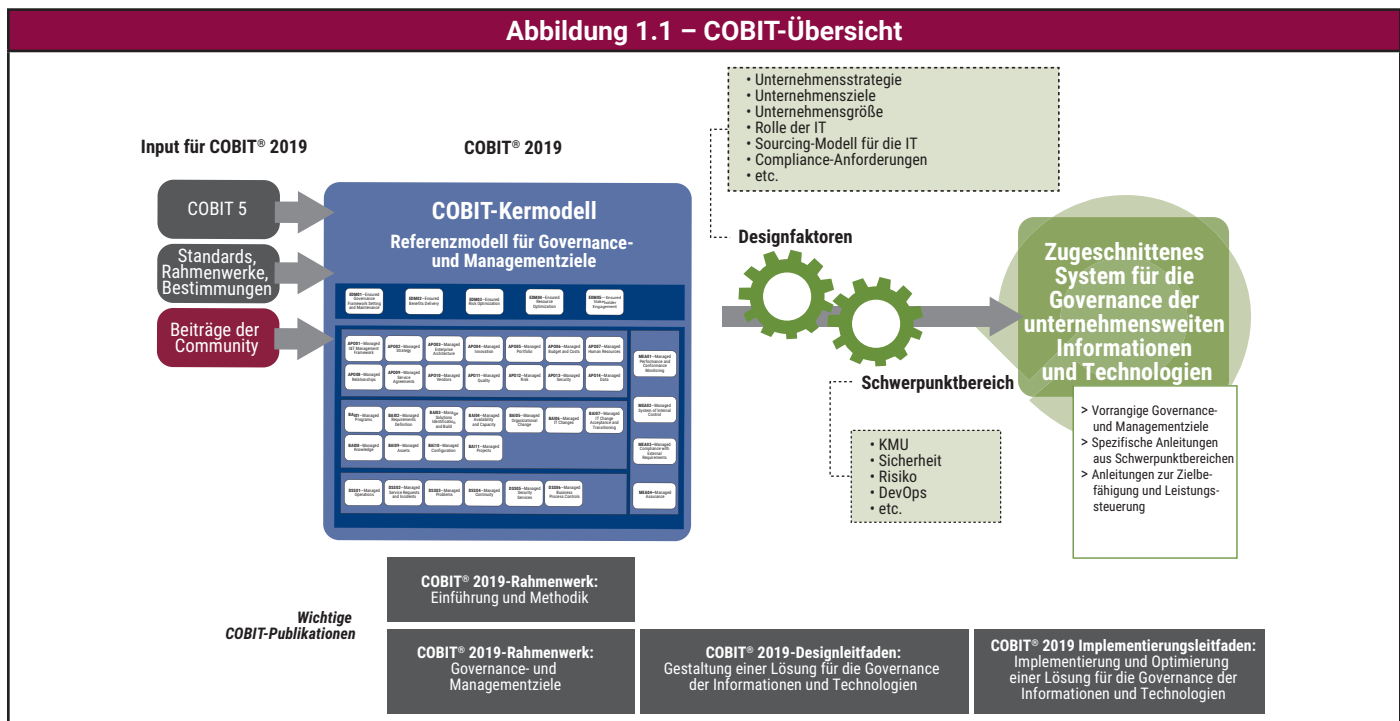
- COBIT ist keine vollständige Beschreibung der gesamten IT-Umgebung eines Unternehmens.
- COBIT ist kein Rahmenwerk zur Organisation von Geschäftsprozessen.
- COBIT ist kein (IT-)technisches Rahmenwerk zum Management der gesamten Technologie.
- COBIT trifft keine oder gibt keine IT-bezogenen Entscheidungen vor. COBIT liefert keine Entscheidung dahingehend, welche die beste IT-Strategie oder Architektur ist oder welche Kosten IT verursachen könnte oder sollte. Vielmehr definiert COBIT alle Komponenten, die beschreiben, welche Entscheidungen wie und von wem getroffen werden sollten.

1.2 Überblick über COBIT® 2019

Die COBIT® 2019-Reihe ist so ausgelegt, dass sie jederzeit erweitert und angepasst werden kann. Die folgenden Publikationen sind derzeit verfügbar.²

- **COBIT® 2019-Rahmenwerk: Einführung und Methodik** stellt die wesentlichen Konzepte von COBIT® 2019 vor.
- **COBIT® 2019-Rahmenwerk: Governance- und Managementziele** beschreibt umfassend die 40 wesentlichen Governance- und Managementziele, die entsprechenden Prozesse und andere verwandte Komponenten. In dieser Publikation wird auch auf andere Standards und Rahmenwerke Bezug genommen.
- **COBIT® 2019-Designleitfaden: Gestaltung einer Lösung für die Governance der Informationen und Technologie** beschäftigt sich mit Designfaktoren, die die Governance beeinflussen können, und stellt einen Arbeitsablauf zur Planung eines auf das Unternehmen zugeschnittenen Governance-Systems vor.
- **COBIT® 2019-Implementierungsleitfaden: Implementierung und Optimierung einer Lösung für die Governance der Informationen und Technologie** ist eine Weiterentwicklung des *COBIT® 5-Implementierungsleitfadens* und enthält eine Roadmap für die kontinuierliche Verbesserung der Governance. Die Publikation kann in Verbindung mit dem *COBIT® 2019-Designleitfaden* verwendet werden.

Abbildung 1.1 zeigt einen Überblick über COBIT® 2019 und veranschaulicht, welche Aspekte die verschiedenen Publikationen der Reihe abdecken.



² Zum Zeitpunkt der Veröffentlichung des *COBIT® 2019-Rahmenwerk: Governance- und Managementziele*, sind weitere Titel der COBIT® 2019-Reihe bereits geplant, aber noch nicht veröffentlicht.

Die in **Abbildung 1.1** als Schwerpunktbereiche ausgewiesenen Inhalte enthalten vertiefende Informationen zu einzelnen Themen.³

Zukünftig wird COBIT seinen Anwendern anbieten, inhaltliche Aktualisierungen vorzuschlagen, die nach einer Prüfung kontinuierlich eingebunden werden, um COBIT auf dem neuesten Stand der Erkenntnisse und Entwicklung zu halten.

Die folgenden Abschnitte erklären die COBIT® 2019 zugrundeliegenden wesentlichen Konzepte und Begriffe.

1.3 Terminologie und wesentliche Konzepte des COBIT-Rahmenwerks

1.3.1 Governance- und Managementziele

Damit I&T zur Erreichung der Unternehmensziele beitragen können, müssen eine Reihe von Governance- und Managementzielen erreicht werden. Grundlegende Prinzipien in Bezug auf Governance- und Managementziele sind:

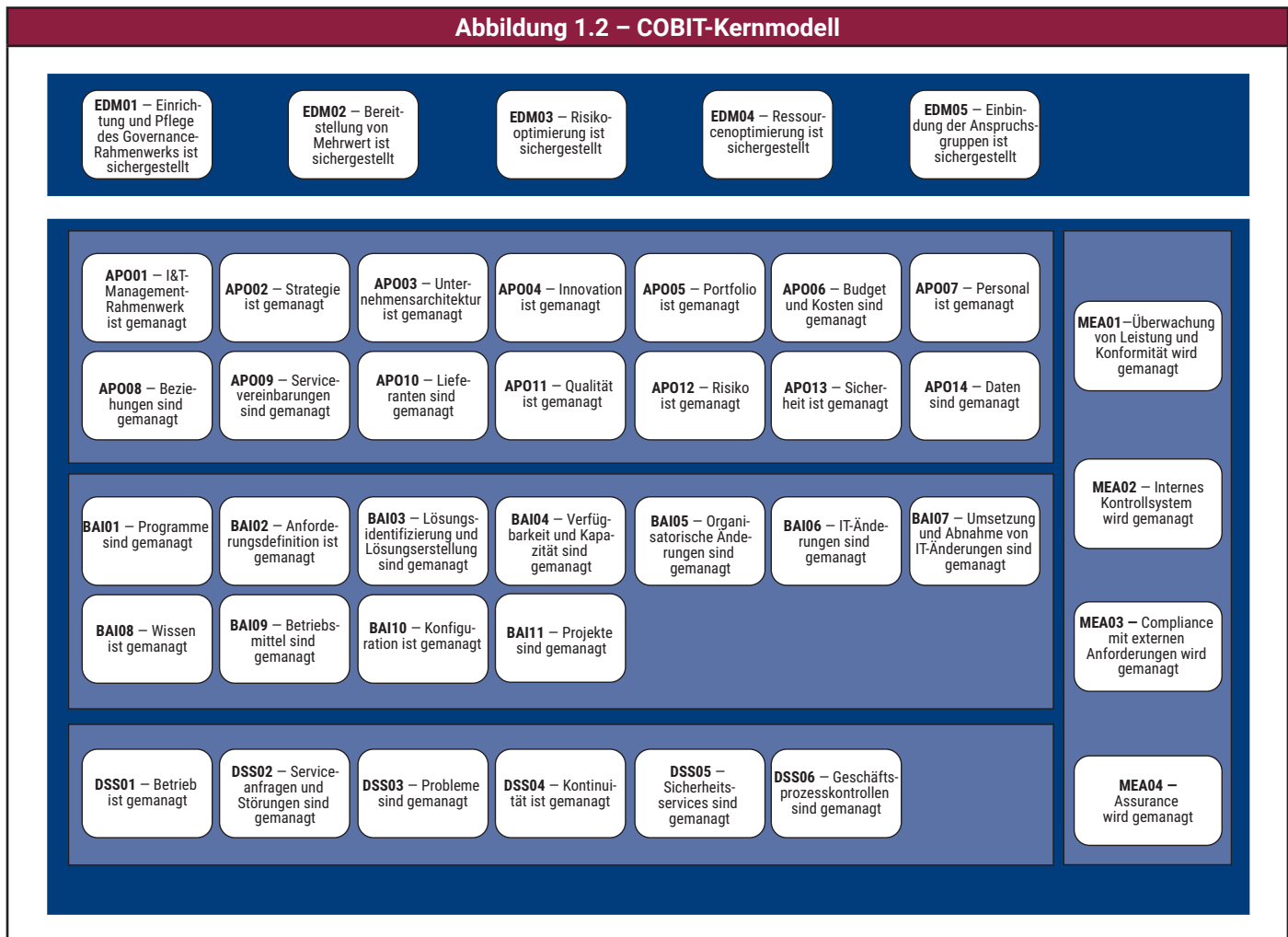
- Ein Governance- oder Managementziel **bezieht sich immer auf einen Prozess** (mit identischem oder ähnlichem Namen) und eine Reihe von Komponenten anderer Art, die zur Erreichung des Ziels beitragen.
- Ein Governance-Ziel bezieht sich auf einen Governance-Prozess (in **Abbildung 1.2** mit dunkelblauem Hintergrund dargestellt), während sich ein Managementziel auf einen Managementprozess bezieht (in **Abbildung 1.2** auf hellblauem Hintergrund dargestellt). In der Regel ist die Geschäftsleitung für Governance-Prozesse verantwortlich, während Managementprozesse in den Verantwortungsbereich des oberen und mittleren Managements fallen.

Innerhalb von COBIT sind die Governance- und Managementziele in fünf Domänen gruppiert. Die Domänen sind mit Verben bezeichnet, die den Hauptzweck und die Aktivitätsbereiche des Ziels ausdrücken:

- Governance-Ziele werden in die Domäne **Evaluieren, Vorgeben und Überwachen** eingeordnet. In dieser Domäne evaluiert das Governance-Organ strategische Optionen, steuert das obere Management hinsichtlich der gewählten strategischen Optionen und überwacht die Umsetzung der Strategie.
- Die Managementziele sind in vier Domänen gruppiert.
 - **Ausrichten, Planen und Organisieren** befasst sich mit der Organisation im Ganzen, der Strategie und den unterstützenden Aktivitäten für I&T.
 - **Aufbauen, Beschaffen und Implementieren** befasst sich mit der Definition, dem Erwerb und der Implementierung von I&T-Lösungen und deren Integration in Geschäftsprozesse.
 - **Bereitstellen, Betreiben und Unterstützen** befasst sich mit der operativen Bereitstellung und Unterstützung von I&T-Diensten einschließlich Sicherheit.
 - **Überwachen, Evaluieren und Beurteilen** befasst sich mit der Leistungsüberwachung und der Erfüllung interner Leistungsziele, interner Kontrollziele und externer Anforderungen durch I&T.

³ Publikationen zu Schwerpunktbereichen sind bereits in Vorbereitung, weitere in Planung. Die Reihe der Publikationen zu den Schwerpunktbereichen wird laufend erweitert. Die neuesten Informationen über aktuell verfügbare und geplante Publikationen sowie weitere Inhalte finden Sie unter www.isaca.org/cobit.

Abbildung 1.2 – COBIT-Kernmodell



1.3.2 Komponenten des Governance-Systems

Um Governance- und Managementziele zu erreichen, muss jedes Unternehmen ein aus einer Reihe verschiedener Komponenten aufgebautes Governance-System einrichten, anpassen und aufrechterhalten.

- Komponenten sind Faktoren, die einzeln oder in ihrer Gesamtheit zum reibungslosen Funktionieren des Governance-Systems des Unternehmens im Bereich I&T beitragen.
- Die Komponenten interagieren miteinander, was zu einem ganzheitlichen I&T-Governance-System führt.
- Komponenten können unterschiedlicher Art sein. Am gängigsten sind die Prozesse. Zu den Komponenten eines Governance-Systems gehören jedoch auch Organisationsstrukturen, Richtlinien und Verfahren, Informationen, Kultur und Verhalten, Fähigkeiten und Kompetenzen sowie Dienstleistungen, Infrastruktur und Anwendungen (**Abbildung 1.3**).
 - **Prozesse** beschreiben eine strukturierte Abfolge von Praktiken und Aktivitäten zur Erreichung bestimmter Ziele und erzeugen eine Reihe von Ergebnissen, die das Erreichen der allgemeinen IT-bezogenen Ziele unterstützen.
 - **Organisationsstrukturen** sind die wichtigsten entscheidungsrelevanten Einheiten in einem Unternehmen.
 - **Grundsätze, Richtlinien und Rahmenwerke** setzen gewünschtes Verhalten in konkrete Anleitungen für den unternehmerischen Alltag um.
 - **Informationen** sind in jeder Organisation allgegenwärtig und umfassen alle vom Unternehmen produzierten und genutzten Informationen. COBIT konzentriert sich auf Informationen, die für eine effektive Arbeitsweise des Governance-Systems des Unternehmens erforderlich sind.

- **Kultur, Ethik und Verhalten** des Einzelnen und des Unternehmens werden als Faktoren für den Erfolg von Governance- und Managementaktivitäten oft unterschätzt.
- **Mitarbeiter, Fähigkeiten und Kompetenzen** sind für eine gute Entscheidungsfindung, die Durchführung von korrekativen Maßnahmen und den erfolgreichen Abschluss aller Aktivitäten erforderlich.
- **Services, Infrastruktur und Anwendungen** umfassen die Infrastruktur, Technologie und Anwendungen, die dem Unternehmen das Governance-System zur Anwendung bereitstellen.

Abbildung 1.3 – COBIT-Komponenten eines Governance-Systems



Die verschiedenen Komponenten können generisch oder Varianten von generischen Komponenten sein:

- **Generische** Komponenten werden im COBIT-Kernmodell (siehe **Abbildung 1.2**) beschrieben und gelten im Prinzip in jeder Situation. Sie sind jedoch generischer Natur und müssen in der Regel angepasst werden, bevor sie praktisch umgesetzt werden können.
- **Varianten** basieren auf generischen Komponenten, sind aber auf einen bestimmten Zweck oder Kontext innerhalb eines Schwerpunktbereichs zugeschnitten (z. B. Informationssicherheit, DevOps, eine bestimmte Vorschrift).

1.3.3 Schwerpunktbereiche

Ein **Schwerpunktbereich** beschreibt einen bestimmten Sachverhalt, eine Domäne oder eine Fragestellung im Rahmen der Governance, die bzw. der durch eine Reihe von Governance- und Managementzielen und deren Komponenten adressiert werden kann. Beispiele für Schwerpunktbereiche sind: kleine und mittlere Unternehmen (KMU), Cybersicherheit, digitale Transformation, Cloud Computing, Datenschutz und DevOps.⁴

Das COBIT-Kernmodell, das die generischen Governance-Komponenten bereitstellt, ist Gegenstand dieser Publikation. Schwerpunktbereiche können eine Kombination aus generischen Governance-Komponenten und Varianten bestimmter Komponenten umfassen, die auf den jeweilige Schwerpunktbereich zugeschnitten sind.

Die Anzahl der Schwerpunktbereiche ist praktisch unbegrenzt. Diese Eigenschaft macht COBIT erweiterbar. Neue Schwerpunktbereiche können bei Bedarf hinzugefügt werden oder wenn Fachexperten und Anwender Beiträge zu COBIT liefern.

Weitere Publikationen zu Schwerpunktbereichen sind bereits in Vorbereitung, und die Reihe wird fortlaufend erweitert. Informationen über aktuell verfügbare und geplante Publikationen sowie weitere Inhalte finden Sie unter www.isaca.org/cobit.

⁴ Der DevOps-Ansatz repräsentiert sowohl eine Komponentenvariante als auch einen Schwerpunktbereich. Warum? DevOps ist ein aktuelles Thema auf dem Markt und bedarf zwingend einer spezifischen Anleitung, was es zu einem Schwerpunktbereich macht. DevOps umfasst eine Reihe von allgemeinen Governance- und Managementzielen des COBIT-Kernmodells sowie eine Reihe von Varianten von entwicklungs-, betriebs- und überwachungsbezogenen Prozessen und Organisationsstrukturen.

Kapitel 2

Aufbau dieser Publikation und Zielgruppen

2.1 Aufbau dieser Publikation

Diese Publikation enthält eine umfassende Beschreibung der 40 im COBIT-Kernmodell (**Abbildung 1.2**) definierten Governance- und Managementziele, der enthaltenen Prozesse, zugehörigen Komponenten sowie Verweise auf relevante Informationen wie z. B. weitere Standards und Rahmenwerke. Eine detaillierte Auflistung der Quellen der entsprechenden Verweise findet sich in Anhang C.

Der nachfolgende Teil dieses Dokuments umfasst die folgenden Kapitel und Anhänge:

- In Kapitel 3 wird die Struktur erläutert, anhand der die Anleitungen zu den 40 Governance- und Managementzielen für alle Komponenten detailliert beschrieben werden.
- Kapitel 4 enthält eine umfassende Beschreibung der 40 im COBIT-Kernmodell (**Abbildung 1.2**) definierten Governance- und Managementziele, der enthaltenen Prozesse, zugehörigen Komponenten sowie Verweise auf relevante Informationen wie z. B. weitere Standards und Rahmenwerke.
- Im Anhang finden sich folgende Informationen:
 - Zuordnungstabellen der Zielkaskade
 - Beschreibungen von Organisationsstrukturen
 - Liste mit Referenzen

2.2 Zielgruppen

Dieser Leitfaden richtet sich an Experten im gesamten Unternehmen, insbesondere aus den Bereichen Audit, Sicherheit, Risikomanagement und IT, aber auch an alle sonstigen Anwender, die von einer detaillierten Anleitung zu den 40 Governance- und Managementzielen des COBIT-Kernmodells profitieren können. Um COBIT so anzupassen, dass auf das Unternehmen zugeschnittene und zielgerichtete Governance-Praktiken vorliegen, ist ein gewisses Maß an Erfahrung und Verständnis des Unternehmens erforderlich.

Diese Seite wurde absichtlich freigelassen.

Kapitel 3

Struktur der COBIT Governance- und Managementziele

3.1 Einführung

Dieses Kapitel beschreibt die Struktur, die der detaillierten Beschreibung der einzelnen Governance- und Managementziele zugrunde liegt. Für jedes Governance- und Managementziel enthält Kapitel 4 Informationen zu den **Governance-Komponenten**, die diesem Governance- oder Managementziel zugeordnet sind:

- Prozesse
- Organisationsstrukturen
- Informationsflüsse und -elemente
- Mitarbeiter, Fähigkeiten und Kompetenzen
- Richtlinien und Verfahren
- Kultur, Ethik und Verhalten
- Services, Infrastruktur und Anwendungen

Der Aufbau dieser Informationen wird in den folgenden Abschnitten detailliert beschrieben.

3.2 Governance- und Managementziele

Wie bereits erläutert, umfasst COBIT® 2019 40 Governance- und Managementziele, die in fünf Domänen gegliedert sind (siehe **Abbildung 1.2**).

- **Governance**-Domäne
 - Evaluieren, Vorgeben und Überwachen
- **Management**-Domänen
 - Anpassen, Planen und Organisieren
 - Aufbauen, Beschaffen und Implementieren
 - Bereitstellen, Betreiben und Unterstützen
 - Überwachen, Evaluieren und Beurteilen

Die wesentlichen Informationen für jedes Ziel (siehe **Abbildung 3.1**) umfassen:

- Bezeichnung der Domäne
- Schwerpunktbereich (in der vorliegenden Publikation das COBIT-Kernmodell)
- Bezeichnung des Governance- oder Managementziels
- Beschreibung
- Zweck

Abbildung 3.1 – Darstellung der Governance- und Managementziele

Domäne: <NAME> Governance-/Managementziel: <NAME>	Schwerpunktbereich: <NAME>
Beschreibung	
<TEXT>	
Zweck	
<TEXT>	

3.3 Zielkaskade

Jedes Governance- oder Managementziel unterstützt die Erreichung von IT-bezogenen Zielen, die mit übergeordneten Unternehmenszielen in Zusammenhang stehen (weitere Informationen finden Sie in Kapitel 4.6 in *COBIT® 2019-Rahmenwerk: Einführung und Methodik* und Beispiele in den Zuordnungstabellen der Zielkaskade in Anhang A).

IT-bezogene Ziele (engl.: Alignment Goals), die einen direkten Bezug zu dem jeweiligen Governance- oder Managementziel haben, sind auf der rechten Seite zu den Zielen im Abschnitt zu den ausführlichen Leitlinien aufgeführt (**Abbildung 3.2**).

Abbildung 3.2 – Darstellung der zugehörigen Unternehmens- und IT-bezogenen Ziele

Das Governance-/Managementziel unterstützt die Erreichung einer Reihe von primären Unternehmens- und IT-bezogenen Zielen:		
Unternehmensziele		IT-bezogene Ziele
• <EG REF> <GOAL DESCRIPTION>		• <AG REF> <GOAL DESCRIPTION>

Zu den IT-bezogenen Zielen gehören:

- AG01: I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen
- AG02: Gesteuertes I&T-Risiko
- AG03: Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio
- AG04: Qualität der durch IT erzeugten Finanzinformationen
- AG05: Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
- AG06: Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen
- AG07: Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
- AG08: Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie
- AG09: Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
- AG10: Qualität der I&T-Managementinformationen
- AG11: I&T-Compliance mit internen Richtlinien
- AG12: Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft
- AG13: Wissen, Know-how und Initiativen für geschäftliche Innovationen

Unternehmensziele, die einen direkten Bezug zu den aufgeführten IT-bezogenen Zielen haben, sind auf der linken Seite im Abschnitt zu den ausführlichen Leitlinien in Kapitel 4 zu den Zielen aufgeführt. Zu den Unternehmenszielen gehören:

- EG01: Portfolio wettbewerbsfähiger Produkte und Dienstleistungen
- EG02: Gesteuertes Geschäftsrisiko

- EG03: Compliance mit externen Gesetzen und Bestimmungen
- EG04: Qualität von Finanzinformationen
- EG05: Kundenorientierte Servicekultur
- EG06: Kontinuität und Verfügbarkeit der geschäftlichen Services
- EG07: Qualität der Managementinformationen
- EG08: Optimierung der internen Geschäftsprozessfunktionalität
- EG09: Optimierung der Geschäftsprozesskosten
- EG10: Fähigkeiten, Motivation und Produktivität des Personals
- EG11: Compliance mit internen Richtlinien
- EG12: Gesteuerte Programme zur digitalen Transformation
- EG13: Produkt- und Geschäftsinnovation

Beispielmetriken zu Unternehmens- und IT-bezogenen Zielen sind ebenfalls in den Tabellen enthalten (**Abbildung 3.3**).

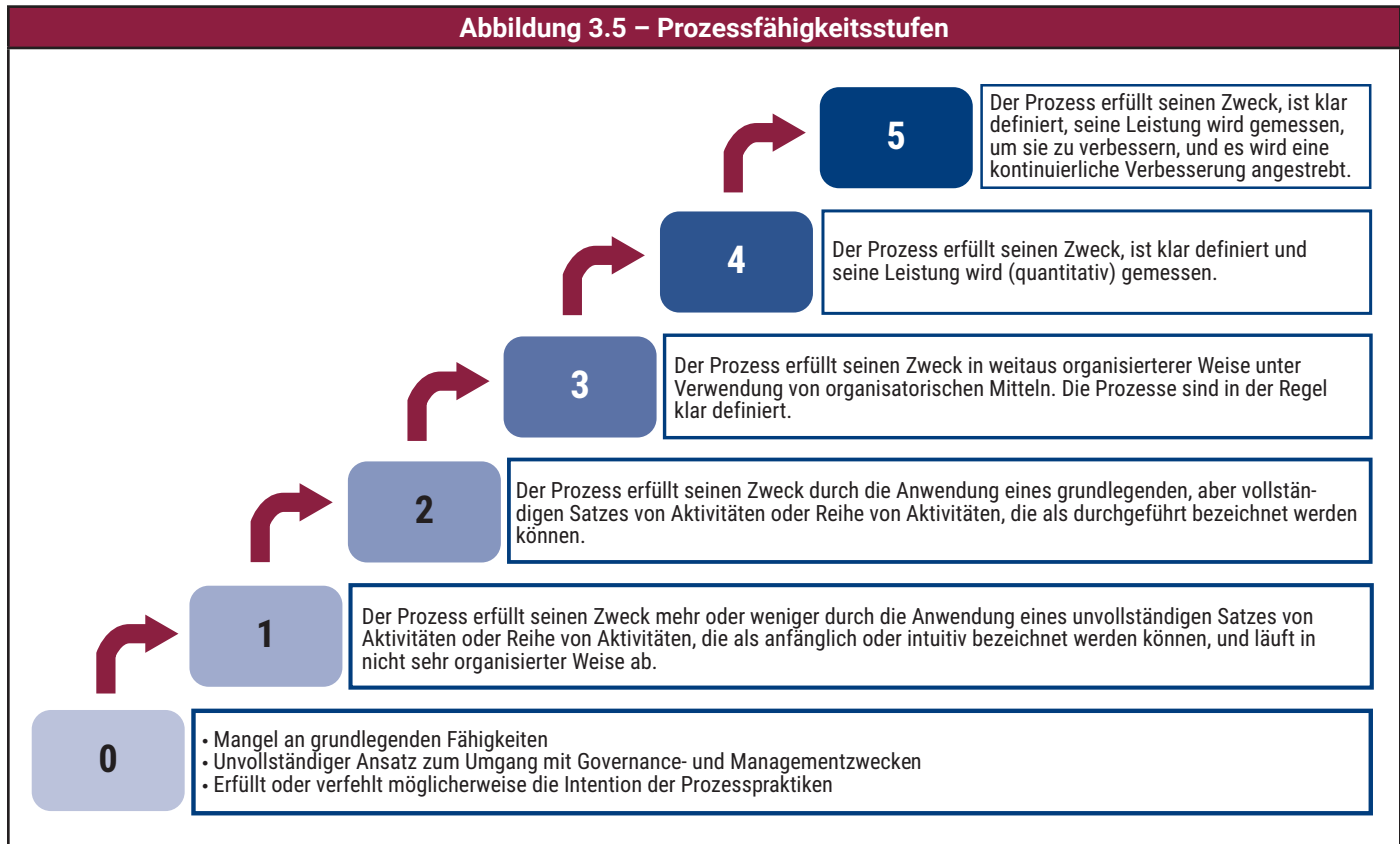
Abbildung 3.3 – Darstellung der zugehörigen Ziele und Beispielmetriken	
Das Governance-/Managementziel unterstützt die Erreichung einer Reihe von primären Unternehmens- und IT-bezogenen Zielen:	
Unternehmensziele	IT-bezogene Ziele
• <UZIELREF> <ZIELBESCHREIBUNG>	• <ITZIELREF> <ZIELBESCHREIBUNG>
Beispielmetriken für Unternehmensziele	Beispielmetriken für IT-bezogene Ziele
<UZIELREF> • <METRIK>	<ITZIELREF> • <METRIK>
<UZIELREF> • <METRIK>	<ITZIELREF> • <METRIK>

3.4 Komponente: Prozess

Jedes Governance- und Managementziel umfasst mehrere Prozesspraktiken. Jeder Prozess umfasst eine oder mehrere Aktivitäten. Zu jeder Prozesspraktik finden sich Beispielmetriken, um die Umsetzung der Praktik und ihren Beitrag zur Erreichung des Gesamtziels zu messen (**Abbildung 3.4**).

Abbildung 3.4 – Darstellung der Prozesskomponente		
A. Komponente: Prozess		
Governance-/Managementpraktik	Beispielmetrik	
<REF> <NAME> <BESCHREIBUNG>	<METRIK>	
Aktivitäten	Fähigkeitsstufe	
1. <TEXT>	<NR>	
2. <TEXT>	<NR>	
n. <TEXT>	<NR>	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
<NAME DES STANDARDS>	<TEXT>	
<NAME DES STANDARDS>	<TEXT>	

Allen Prozessaktivitäten wird eine Fähigkeitsstufe zugewiesen, die eine klare Definition von Prozessen mit verschiedenen Fähigkeitsstufen ermöglicht. Ein Prozess erreicht eine bestimmte Fähigkeitsstufe, sobald alle Aktivitäten dieser Stufe erfolgreich durchgeführt werden. COBIT® 2019 unterstützt ein auf Capability Maturity Model Integration® (CMMI) basierendes Prozessfähigkeitsschema, das von 0 bis 5 reicht. Die Fähigkeitsstufe ist ein Maß dafür, wie gut ein Prozess umgesetzt wurde und wie leistungsfähig er ist. **Abbildung 3.5** zeigt das Modell, die verschiedenen Fähigkeitsstufen und deren allgemeine Merkmale.



Kapitel 6 im *COBIT® 2019-Rahmenwerk: Einführung und Methodik* enthält weitere Informationen zur Leistungssteuerung und zur Ermittlung der Fähigkeitsstufe.

In diesem Bereich finden sich ggf. auch Verweise auf andere Standards und Leitlinien (siehe **Abbildung 3.4**). Die entsprechende Information bezieht sich auf alle Standards, Rahmenwerke, Compliance-Anforderungen und andere Materialien, die für den jeweiligen Prozess relevant sind. Der Bereich mit detaillierten Informationen zu Referenzen nennt spezifische Kapitel oder Abschnitte aus relevanten Leitlinien. Eine vollständige Übersicht über die Quellen der entsprechenden Leitlinien ist in Anhang C enthalten.

Wenn für eine bestimmte Komponente keine Leitlinie aufgeführt ist, sind aus den zugeordneten Quellen keine entsprechenden Referenzen bekannt. Die Anwendergemeinschaft ist in diesem Fall angehalten, entsprechende Quellen vorzuschlagen.

3.5 Komponente: Organisationsstrukturen

Die Governance-Komponente Organisationsstrukturen schlägt Verantwortlichkeiten und Zuständigkeiten für Prozesspraktiken vor (**Abbildung 3.6**). Die Tabellen enthalten sowohl individuelle Rollen als auch Organisationsstrukturen, sowohl aus dem geschäftlichen Bereich als auch aus der IT.

Abbildung 3.6 – Darstellung der Komponente Organisationsstrukturen

B. Komponente: Organisationsstrukturen								
Governance-/Managementpraktik	Organisationsstruktur 1	Organisationsstruktur 2	Organisationsstruktur 3	Organisationsstruktur 4	Organisationsstruktur 5	Organisationsstruktur 6	Organisationsstruktur 7	Organisationsstruktur 8 etc.
<REF> <NAME>								

Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
<NAME DES STANDARDS>	<TEXT>
<NAME DES STANDARDS>	<TEXT>

Die folgenden Rollen und Organisationsstrukturen wurden im Zusammenhang mit COBIT® 2019 definiert:

- Geschäftsleitung
- Exekutivkomitee
- Chief Executive Officer
- Chief Financial Officer
- Chief Operating Officer
- Chief Risk Officer
- Chief Information Officer
- Chief Technology Officer
- Chief Digital Officer
- I&T Governance Board
- Architekturausschuss
- Risikoausschuss des Unternehmens
- Chief Information Security Officer
- Geschäftsprozessverantwortlicher
- Portfoliomanager
- Lenkungsausschuss für Projekte und Programme
- Programm-Manager
- Projektmanager
- Project Management Office
- Datenmanagement
- Leiter Personal
- Relationship Manager
- Chefarchitekt

- Leiter Entwicklung
- Leiter IT-Betrieb
- Leiter IT-Administration
- Service Manager
- Information Security Manager
- Business Continuity Manager
- Datenschutzbeauftragter
- Rechtsbeistand
- Compliance
- Audit

Eine detaillierte Beschreibung jeder dieser Rollen und Organisationsstrukturen ist in Anhang B enthalten. Die verschiedenen Ebenen der Einbeziehung, die für diese Strukturen vorgesehen sind, lassen sich in die Ebenen *verantwortlich* und *zuständig* unterteilen.

- **R(esponsible, zuständig):** Rollen, deren wesentliche Aufgabe darin besteht, die Praktik umzusetzen und das beabsichtigte Ergebnis operativ herbeizuführen. Wer erledigt die Aufgabe? Wer treibt die Aufgabe voran?
- **A(countable, verantwortlich):** Rollen, denen die Gesamtverantwortung zugewiesen wurde. Prinzipiell kann Verantwortung nicht gemeinschaftlich wahrgenommen werden. Wer ist für den Erfolg und die Erfüllung der Aufgabe verantwortlich?

In jedem Bereich sind die Organisationsstrukturen beschrieben, die jeweils zuständig und/oder verantwortlich sind. Zu jeder Rolle und Organisationsstruktur gibt es eine detaillierte Beschreibung. Organisationsstrukturen ohne Verantwortung oder Zuständigkeiten wurden weggelassen, um die Lesbarkeit zu verbessern.

Anwender können die Tabellen vervollständigen, indem sie zwei Ebenen der Einbeziehung für Rollen und Organisationsstrukturen hinzufügen. Da die Zuordnung der Rollen C(onsulted, konsultiert) und I(nformed, informiert) vom organisatorischen Kontext und den Prioritäten abhängt, werden sie in dieser Übersicht nicht berücksichtigt.

- **C(onsulted, konsultiert):** Rollen, die Input für die Praktik bereitstellen. Wer stellt Input bereit?
- **I(nformed, informiert):** Rollen, die über die Ergebnisse und/oder Leistungen der Praktik informiert werden. Wer erhält Informationen?

Unternehmen sollten die Ebenen *Verantwortlich*, *Zuständig*, *Konsultiert* und *Informiert* überprüfen und die Rollen und Organisationsstrukturen im Diagramm entsprechend dem Unternehmenskontext, den Prioritäten und der bevorzugten Terminologie aktualisieren.

Wo relevant, sind im Abschnitt Komponenten der Organisationsstruktur Verweise zu anderen Standards und zusätzlichen Quellen aufgeführt. Die entsprechende Information bezieht sich auf alle Standards, Rahmenwerke, Compliance-Anforderungen und andere Materialien, die für die vorliegenden Organisationsstrukturen und ihre Ebenen der Einbeziehung in den Prozess relevant sind. Der Bereich mit detaillierten Informationen zu Referenzen nennt spezifische Kapitel oder Abschnitte aus relevanten Leitlinien. Eine vollständige Übersicht über die Quellen ist in Anhang C enthalten.

3.6 Komponente: Informationsflüsse und -elemente

Die dritte Governance-Komponente bietet Anleitungen zu Informationsflüssen und den mit den Prozesspraktiken verbundenen Elementen. Jede Praktik umfasst Inputs und Outputs mit Angaben zu Herkunft und Weiterleitungsziel.

Im Allgemeinen wird jeder Output an ein oder mehrere Ziele (Bestimmungsorte) gesendet, bei denen es sich in der Regel um andere COBIT-Prozesspraktiken handelt. Am Bestimmungsort wiederum fungiert der Output als Input (**Abbildung 3.7**).

Abbildung 3.7 – Darstellung der Komponente Informationsflüsse und -elemente

C. Komponente: Informationsflüsse und -elemente				
Governance-/Managementpraktik	Inputs		Outputs	
<REF> <NAME>	Von	Beschreibung	Beschreibung	Für
	<REF>	<TEXT>	<TEXT>	<REF>

Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
<NAME DES STANDARDS>	<TEXT>
<NAME DES STANDARDS>	<TEXT>

Es gibt jedoch eine Reihe von Outputs, die sehr zahlreiche Ziele (Bestimmungsorte) haben (z. B. alle COBIT-Prozesse oder alle Prozesse innerhalb einer Domäne). Um die Lesbarkeit nicht zu beeinträchtigen, werden diese Outputs nicht als Inputs der Zielprozesse aufgeführt. Eine vollständige Liste mit derartigen Outputs ist in **Abbildung 3.8** enthalten.

Bei einigen Inputs bzw. Outputs ist als Ziel „Intern“ angegeben, wenn sich die Inputs bzw. Outputs auf Aktivitäten innerhalb desselben Prozesses beziehen.

Abbildung 3.8 – Outputs an verschiedene Prozesse

Outputs an alle Prozesse		
Ursprüngliche wichtige Praktik	Output-Beschreibung	Ziel
APO13.02	Plan zur Behandlung von Informationssicherheitsrisiken	Alle EDM, APO, BAI, DSS, MEA
Ursprüngliche Governance-Praktik	Output-Beschreibung	Ziel
EDM01.01	Leitprinzipien der unternehmensweiten Governance	Alle EDM-Prozesse
EDM01.01	Modell zur Entscheidungsfindung	Alle EDM-Prozesse
EDM01.02	Unternehmensweite Governance-Kommunikation	Alle EDM-Prozesse
EDM01.01	Kompetenzstufen	Alle EDM-Prozesse
EDM01.03	Rückmeldung zur Effektivität und Leistung der Governance	Alle EDM-Prozesse
Outputs an alle Managementprozesse		
Ursprüngliche Managementpraktik	Output-Beschreibung	Ziel
APO01.01	Design des Managementsystems	Alle APO, BAI, DSS, MEA
APO01.01	Vorrangige Governance- und Managementziele	Alle APO, BAI, DSS, MEA
APO01.02	Kommunizieren der I&T-Ziele	Alle APO, BAI, DSS, MEA
APO01.02	Kommunikationsgrundregeln	Alle APO, BAI, DSS, MEA
APO01.03	Zielmodell-GAP-Analyse	Alle APO, BAI, DSS, MEA
APO01.11	Möglichkeiten zur Prozessverbesserung	Alle APO, BAI, DSS, MEA
APO02.05	I&T-Strategie und -Zielvorgaben	Alle APO, BAI, DSS, MEA
APO02.06	Kommunikationspaket	Alle APO, BAI, DSS, MEA
APO11.03	Qualitätsmanagementstandards	Alle APO, BAI, DSS, MEA
APO11.04	Prozessqualität von Servicezielen und Metriken	Alle APO, BAI, DSS, MEA
APO11.05	Kommunikation zu kontinuierlicher Verbesserung und bewährten Verfahren	Alle APO, BAI, DSS, MEA
APO11.05	Beispiele für bewährte Verfahren, die geteilt werden sollten	Alle APO, BAI, DSS, MEA
APO11.05	Benchmark-Ergebnisse für Qualitätsprüfung	Alle APO, BAI, DSS, MEA

Abbildung 3.8 – Outputs an verschiedene Prozesse (Forts.)

Outputs an alle Managementprozesse		
Ursprüngliche Managementpraktik	Output-Beschreibung	Ziel
MEA01.02	Überwachungsziele	Alle APO, BAI, DSS, MEA
MEA01.04	Leistungsberichte	Alle APO, BAI, DSS, MEA
MEA01.05	Korrektive Maßnahmen und Zuweisungen	Alle APO, BAI, DSS, MEA
MEA02.01	Ergebnisse aus der Überwachung und Überprüfung interner Kontrollen	Alle APO, BAI, DSS, MEA
MEA02.01	Ergebnisse aus Benchmarks und anderen Bewertungen	Alle APO, BAI, DSS, MEA
MEA02.03	Ergebnisse aus der Überprüfung von Selbsteinschätzungen	Alle APO, BAI, DSS, MEA
MEA02.03	Pläne und Kriterien für Selbsteinschätzung	Alle APO, BAI, DSS, MEA
MEA02.04	Kontrollschwächen	Alle APO, BAI, DSS, MEA
MEA02.04	Abhilfemaßnahmen	Alle APO, BAI, DSS, MEA
MEA03.02	Kommunikation zu geänderten Compliance-Anforderungen	Alle APO, BAI, DSS, MEA
MEA04.02	Prüfungspläne	Alle APO, BAI, DSS, MEA
MEA04.08	Bericht über Prüfungen	Alle APO, BAI, DSS, MEA
MEA04.08	Ergebnisse der Prüfungen	Alle APO, BAI, DSS, MEA
MEA04.09	Abhilfemaßnahmen	Alle APO, BAI, DSS, MEA

Wo relevant, sind im Abschnitt zu der Komponente Informationsflüsse und -elemente Verweise zu anderen Standards und zusätzlichen Quellen aufgeführt. Die entsprechende Information bezieht sich auf alle Standards, Rahmenwerke, Compliance-Anforderungen und andere Materialien, die für das jeweilige Informationselement relevant sind. Der Bereich mit detaillierten Informationen zu Referenzen nennt spezifische Kapitel oder Abschnitte aus relevanten Leitlinien. Eine vollständige Übersicht über die Quellen ist in Anhang C enthalten.

3.7 Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Die Governance-Komponente Mitarbeiter, Fähigkeiten und Kompetenzen führt Ressourcen und Fähigkeiten auf, die zur Erreichung des Governance- oder Managementziels erforderlich sind. COBIT® 2019 greift diesbezüglich auf das Skills Framework for the Information Age (SFIA®) V6 (Version 6) zurück.⁵ Alle aufgeführten Fähigkeiten werden im SFIA-Rahmenwerk ausführlich beschrieben. Der detaillierte Verweis enthält einen eindeutigen Kürzel, das auf die jeweilige Fähigkeit im SFIA-Rahmenwerk verweist (**Abbildung 3.9**). Darüber hinaus sind für einige Governance- und Managementziele Verweise auf das *e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework*⁶ und die *Core Principles for the Professional Practice of Internal Auditing*⁷ des Institute of Internal Auditors enthalten.

Abbildung 3.9 – Darstellung der Komponente Mitarbeiter, Fähigkeiten und Kompetenzen

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
<NAME>	Skills Framework for the Information Age, V6 (SFIA 6), 2015	<SFIA Kürzel>
<NAME>	Skills Framework for the Information Age, V6 (SFIA 6), 2015	<SFIA Kürzel>

⁵ SFIA Foundation, SFIA V6, the sixth major version of the Skills Framework for the Information Age., <https://www.sfia-online.org/en/framework/sfia-6>

⁶ European Committee for Standardization (CEN), e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, EN 16234-1:2016, https://standards.cen.eu/dyn/www/f?p=204:110:0:::FSP_PROJECT:41798&cs=13E00999DD92E702F0E171397CF76EC87

⁷ The Institute of Internal Auditors® (IIA®), Core Principles for the Professional Practice of Internal Auditing, <https://na.theiia.org/standards-guidance/mandatory-guidance/Pages/Core-Principles-for-the-Professional-Practice-of-Internal-Auditing.aspx>

3.8 Komponente: Richtlinien und Verfahren

Diese Komponente bietet detaillierte Informationen zu Richtlinien und Verfahren, die für das Governance- und Managementziel relevant sind. Der Name der relevanten Richtlinien und Verfahren wird zusammen mit einer Beschreibung des Zwecks und Inhalts der Richtlinie angegeben (**Abbildung 3.10**).

Wo relevant, sind Verweise zu anderen Standards und zusätzlichen Quellen aufgeführt. Dabei werden spezifische Kapitel oder Abschnitte der zugehörigen Quelle genannt, in der weitere Informationen enthalten sind. Eine vollständige Übersicht über die Quellen ist in Anhang C enthalten.

Abbildung 3.10 – Darstellung der Komponente Richtlinien und Verfahren			
E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
<NAME>	<BESCHREIBUNG>	<NAME DES STANDARDS>	<TEXT>

3.9 Komponente: Kultur, Ethik und Verhalten

Die Governance-Komponente Kultur, Ethik und Verhalten bietet detaillierte Informationen zu gewünschten kulturbezogenen Elementen innerhalb der Organisation, die die Erreichung eines Governance- oder Managementziels unterstützen (**Abbildung 3.11**). Wo relevant, sind Verweise zu anderen Standards und zusätzlichen Quellen aufgeführt. Dabei werden spezifische Kapitel oder Abschnitte der zugehörigen Quelle genannt, in der weitere Informationen enthalten sind. Eine vollständige Übersicht über die Quellen ist in Anhang C enthalten.

Abbildung 3.11 – Darstellung der Komponente Kultur, Ethik und Verhalten		
F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
<NAME>	<NAME DES STANDARDS>	<TEXT>

3.10 Komponente: Services, Infrastruktur und Anwendungen

Die Governance-Komponente Services, Infrastruktur und Anwendungen bietet detaillierte Informationen zu Services von Drittanbietern, Arten von Infrastrukturen und Kategorien von Anwendungen, die zur Unterstützung der Erreichung eines Governance- oder Managementziels eingesetzt werden können. Die Informationen sind allgemein gehalten (um die Nennung spezifischer Anbieter oder Produkte zu vermeiden), die Einträge geben den Unternehmen jedoch eine Richtung zum Aufbau ihres Governance-Systems für I&T vor (**Abbildung 3.12**).

Abbildung 3.12 – Darstellung der Komponente Services, Infrastruktur und Anwendungen
G. Komponente: Services, Infrastruktur und Anwendungen
<KATEGORIE VON DIENSTLEISTUNGEN, INFRASTRUKTUR ODER ANWENDUNGEN>

Diese Seite wurde absichtlich freigelassen.

Kapitel 4**COBIT Governance- und Managementziele – detaillierte Anleitungen****COBIT-Kernmodell**

4.1 EVALUIEREN, VORGEBEN UND ÜBERWACHEN

- 01** Einrichtung und Pflege des Governance-Rahmenwerks ist sichergestellt
- 02** Bereitstellung von Mehrwert ist sichergestellt
- 03** Risiko-Optimierung ist sichergestellt
- 04** Ressourcen-Optimierung ist sichergestellt
- 05** Einbindung der Anspruchsgruppen ist sichergestellt

Diese Seite wurde absichtlich freigelassen.

Domäne: Evaluieren, Vorgeben und Überwachen		Schwerpunktbereich: COBIT-Kernmodell
Governance-Ziel: EDM01 – Einrichtung und Pflege des Governance-Rahmenwerks ist sichergestellt		
Beschreibung		
Analyse und Formulierung der Anforderungen an die Governance der unternehmensweiten I&T. Einrichtung und Pflege von Governance-Komponenten mit klarer Angabe der Zuständigkeiten und Befugnisse, um die Mission, Ziele und Zielvorgaben des Unternehmens zu erreichen.		
Zweck		
Bereitstellung eines konsistenten Ansatzes, der in den Governance-Ansatz des Unternehmens integriert und an diesem ausgerichtet ist. I&T-bezogene Entscheidungen müssen im Einklang mit den Strategien und Zielvorgaben des Unternehmens getroffen und der gewünschte Wert realisiert werden. Zu diesem Zweck muss sichergestellt werden, dass I&T-bezogene Prozesse effektiv und transparent überwacht werden, die Compliance mit gesetzlichen, vertraglichen und behördlichen Anforderungen gegeben ist und die Governance-Anforderungen für Mitglieder der Geschäftsleitung erfüllt sind.		
Das Governance-Ziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG03 Compliance mit externen Gesetzen und Bestimmungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG01 I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen • AG03 Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG03 a. Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern b. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursacht haben c. Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Nichteinhaltung der Vorschriften d. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern		AG01 a. Kosten der Nichteinhaltung von IT-Vorschriften, einschließlich Vergleichen und Bußgeldern, sowie die Auswirkungen von Reputationsverlusten b. Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von IT-Vorschriften, die der Geschäftsleitung gemeldet wurden oder zu öffentlichen Kommentaren oder Unannehmlichkeiten führten c. Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit IT-Dienstleistern
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess	
Governance-Praktik	Beispielmetrik
EDM01.01 Evaluieren des Governance-Systems Identifizieren Sie kontinuierlich die Anspruchsgruppen des Unternehmens und binden Sie sie ein. Dokumentieren Sie die Anforderungen und beurteilen Sie das aktuelle und künftige Design der Governance der unternehmensweiten I&T.	a. Anzahl der für I&T-Governance und Entscheidungsfindung definierten Leitprinzipien b. Anzahl der Führungskräfte, die an der Festlegung der Governance-Ausrichtung der I&T beteiligt sind

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Analysieren und identifizieren Sie die internen und externen Rahmenbedingungen (rechtliche, behördliche und vertragliche Verpflichtungen) sowie die Entwicklungen im Geschäftsumfeld, die sich auf die Ausgestaltung der Governance auswirken könnten.	2
2. Bestimmen Sie die Bedeutung der I&T und die Rolle, die sie in Bezug auf das Geschäft einnimmt.	
3. Ziehen Sie externe Bestimmungen, Gesetze und vertragliche Verpflichtungen heran und bestimmen Sie, wie diese im Rahmen der Governance der unternehmensweiten I&T angewendet werden sollten.	
4. Bestimmen Sie, welche Auswirkungen die allgemeine Kontrollumgebung des Unternehmens auf die I&T hat.	
5. Passen Sie die Verarbeitung von Informationen und deren Nutzung unter ethischen Gesichtspunkten sowie die Auswirkungen auf Gesellschaft, Umwelt und die Interessen interner und externer Anspruchsgruppen an die Ausrichtung, Ziele und Zielvorgaben des Unternehmens an.	3
6. Formulieren Sie Prinzipien, auf deren Grundlage Sie die Ausgestaltung der Governance und die Entscheidungsfindung im Bereich I&T vornehmen.	
7. Bestimmen Sie das optimale Entscheidungsfindungsmodell für I&T.	
8. Bestimmen Sie geeignete Stufen für die Delegierung von Befugnissen bei I&T-Entscheidungen, und legen Schwellenwertregeln fest.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	GE.AG Apply Governance System; GE.MG Monitor Governance System
ISO/IEC 38500:2015(E)	5.2 Principle 1: Responsibility (Evaluate)
ITIL V3, 2011	Service Strategy, 2.3 Governance and management systems
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.1 Preparation (Tasks 2, 3, 4, 5)
Governance-Praktik	Beispielmetrik
EDM01.02 Steuern des Governance-Systems Informieren Sie Führungskräfte über die Prinzipien der I&T-Governance und versuchen Sie, deren Unterstützung, Mitwirkung und Engagement zu erlangen. Lenken Sie die Strukturen, Prozesse und Praktiken für die Governance der I&T in Übereinstimmung mit den vereinbarten Governance-Prinzipien, Entscheidungsfindungsmodellen und Kompetenzstufen. Definieren Sie die für eine fundierte Entscheidungsfindung erforderlichen Informationen.	a. Ausmaß, in dem vereinbarte I&T-Governance-Prinzipien in Prozessen oder Praktiken nachweisbar sind (Anteil der Prozesse und Praktiken, denen klar Prinzipien zugeordnet werden können) b. Häufigkeit der Berichterstattung über die I&T-Governance an das Exekutivkomitee und die Geschäftsleitung c. Anzahl der Rollen, Zuständigkeiten und Befugnisse für die I&T-Governance, die von den entsprechenden Geschäfts- und I&T-Managern definiert, zugewiesen und akzeptiert wurden
Aktivitäten	Fähigkeitsstufe
1. Kommunizieren Sie die Prinzipien der I&T-Governance und stimmen Sie mit den obersten Führungskräften ab, wie eine informierte und engagierte Führung etabliert werden kann.	2
2. Richten Sie Governance-Strukturen, -Prozesse und -Praktiken ein, die den vereinbarten Gestaltungsprinzipien entsprechen, bzw. delegieren Sie deren Einrichtung.	
3. Richten Sie ein I&T Governance Board (oder ein vergleichbares Gremium) auf Geschäftsleitungsebene ein. Dieses Board sollte sicherstellen, dass die I&T-Governance als Teil der unternehmensweiten Governance angemessen berücksichtigt wird. Es sollte bei der strategischen Ausrichtung beraten und die Prioritäten für durch I&T ermöglichte Investitionsprogramme in Übereinstimmung mit der Geschäftsstrategie und den Prioritäten des Unternehmens festlegen.	
4. Ordnen Sie auf der Grundlage der für die Governance vereinbarten Gestaltungsprinzipien, Entscheidungsfindungsmodelle und Delegierungsregeln die Zuständigkeit, Befugnisse und Verantwortlichkeit für I&T-bezogene Entscheidungen zu.	3
5. Stellen Sie sicher, dass Beteiligte, die für die Überwachung und Entscheidungsfindung zuständig sind, anhand von Kommunikations- und Berichtsmechanismen mit geeigneten Informationen versorgt werden.	
6. Fordern Sie von den Mitarbeitern die Einhaltung der einschlägigen Richtlinien für ethisches und professionelles Verhalten ein, und stellen Sie sicher, dass die Konsequenzen der Nichteinhaltung bekannt sind und gezogen werden.	
7. Steuern Sie die Einrichtung eines Belohnungssystems, das den gewünschten kulturellen Wandel fördert.	

A. Komponente: Prozess (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	GE.DG Direct Governance System
ISF, The Standard of Good Practice for Information Security 2016	SG1.1 Security Governance Framework
ISO/IEC 38500:2015(E)	5.2 Principle 1: Responsibility (Direct)
ISO/IEC 38502:2017(E)	Governance of IT – Framework and model (alle Kapitel)
King IV Report on Corporate Governance for South Africa, 2016	Part 5.4: Governance functional areas – Principle 12
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.14 Planning (PL-2, PL-10)
Governance-Praktik	Beispielmetrik
EDM01.03 Überwachen des Governance-Systems Überwachen Sie die Effektivität und die Leistung der Governance der unternehmensweiten I&T. Beurteilen Sie, ob das Governance-System und die implementierten Mechanismen (einschließlich der Strukturen, Prinzipien und Prozesse) effektiv funktionieren und für eine ausreichende Überwachung der I&T sorgen, um Wertschöpfung zu ermöglichen.	a. Tatsächliche vs. Soll-Bearbeitungszeit für wichtige Entscheidungen b. Häufigkeit unabhängiger Überprüfungen der I&T-Governance c. Grad der Zufriedenheit der Anspruchsgruppen (gemessen durch Umfragen) d. Anzahl der gemeldeten I&T-Governance-Probleme
Aktivitäten	Fähigkeitsstufe
1. Beurteilen Sie die Effektivität und Leistung derjenigen Anspruchsgruppen, denen die Zuständigkeit und die Befugnisse für die Governance der unternehmensweiten I&T übertragen wurden.	3
2. Beurteilen Sie regelmäßig, ob die vereinbarten Mechanismen der Governance der I&T (Strukturen, Prinzipien, Prozesse usw.) eingerichtet wurden und wirksam sind.	4
3. Beurteilen Sie die Effektivität des Governance-Designs und identifizieren Sie Maßnahmen, um möglicherweise festgestellte Abweichungen zu beheben.	
4. Überwachen Sie, inwieweit die I&T (behördlichen, gesetzlichen, gewohnheitsrechtlichen und vertraglichen) Verpflichtungen, internen Richtlinien, Standards und fachlichen Leitlinien gerecht wird.	
5. Überwachen Sie die Effektivität und die Einhaltung des Kontrollsystems des Unternehmens.	
6. Überwachen Sie reguläre und routinemäßige Mechanismen, mit denen sichergestellt wird, dass die Nutzung der I&T mit den einschlägigen (behördlichen, gesetzlichen, gewohnheitsrechtlichen und vertraglichen) Verpflichtungen, Standards und Leitlinien vereinbar ist.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 38500:2015(E)	5.2 Principle 1: Responsibility (Monitor)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.14 Planning (PL-11)

B. Komponente: Organisationsstrukturen					
Wichtige Governance-Praktik	Geschäftsleitung	Exekutivkomitee	Chief Executive Officer	Chief Information Officer	I&T Governance Board
EDM01.01 Evaluieren des Governance-Systems	A	R	R	R	R
EDM01.02 Steuern des Governance-Systems	A	R			R
EDM01.03 Überwachen des Governance-Systems	A	R	R	R	R

B. Komponente: Organisationsstrukturen (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017	6. Governance and Culture – Principle 2
ISO/IEC 38502:2017(E)	5.1 Responsibilities of the governing body
King IV Report on Corporate Governance for South Africa, 2016	Part 2: Fundamental concepts – Definition of corporate governance; Teil 5.3: Governing structures and delegation – Principle 6 & 7

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Governance-Praktik	Inputs		Outputs	
EDM01.01 Evaluieren des Governance-Systems	Von	Beschreibung	Beschreibung	Für
	MEA03.02	Kommunikation zu geänderten Compliance-Anforderungen	Unternehmensweite Governance-Leitprinzipien	Alle EDM, APO01.01, APO01.03, APO01.04
	Außerhalb von COBIT	- Struktur/Satzung/Statuten der Organisation - Governance/Entscheidungsfindungsmodell - Gesetze/Vorschriften - Trends im Geschäftsumfeld	Entscheidungsfindungsmodell	Alle EDM, APO01.01, APO01.04
			Kompetenzstufen	Alle EDM-Prozesse, APO01.05
EDM01.02 Steuern des Governance-Systems			Unternehmensweite Governance-Kommunikation	Alle EDM-Prozesse, APO01.02
			Belohnungssystem	APO07.03, APO07.04
EDM01.03 Überwachen des Governance-Systems	MEA01.04	Leistungsberichte	Feedback zu Effektivität und Leistung der Governance	Alle EDM-Prozesse, APO01.11
	MEA01.05	Status und Ergebnisse von Aktivitäten		
	MEA02.01	- Ergebnisse aus der internen Überwachung und Überprüfung - Ergebnisse aus Benchmarks und anderen Bewertungen		
	MEA02.03	Ergebnisse aus der Überprüfung von Selbsteinschätzungen		
	MEA03.03	Compliance-Bestätigungen		
	MEA03.04	- Berichte zur Compliance-Prüfung - Berichte über Verstöße und Ursachen der Nichteinhaltung von Vorschriften		
	MEA04.02	Prüfungspläne		
	Außerhalb von COBIT	- Prüfberichte - Verpflichtungen		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017	3.1 Preparation (Task 2, 3, 4, 5): Inputs und Outputs

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
IS-Governance	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.9. IS-Governance
IT-Governance	Skills Framework for the Information Age V6, 2015	GOVN

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Delegierung von Befugnissen	Legt die Befugnisse fest, die ausschließlich der Geschäftsleitung vorbehalten sind. Beschreibt allgemeine Prinzipien der Delegierung von Befugnissen und deren zeitliche Planung (einschließlich klarer Grenzen). Definiert Organisationsstrukturen, an die die Geschäftsleitung Befugnisse delegiert.	(1) ISO/IEC 38500:2015(E); (2) ISO/IEC 38502:2017(E); (3) King IV Report on Corporate Governance for South Africa, 2016	(1) 5.2 Principle 1: Responsibility; (2) 5.3 Delegation; (3) Part 5.3: Governing structures and delegation Principle – 8 and 10
Governance-Richtlinie	Stellt Leitprinzipien der Governance bereit (z. B. I&T-Governance ist entscheidend für den Unternehmenserfolg, strategische Ausrichtung von I&T und Geschäftsaktivitäten, Geschäftsanforderungen und -vorteile bestimmen die Prioritäten, die Durchsetzung muss angemessen, zeitnah und konsistent sein, bewährte Praktiken, Rahmenwerke und Standards der Branche müssen beurteilt und gegebenenfalls umgesetzt werden). Umfasst auch notwendige Governance-Aspekte wie den Aufbau von Vertrauen und Partnerschaften, um erfolgreich zu sein. Betont, dass die I&T-Governance einen Prozess der kontinuierlichen Verbesserung darstellt und angepasst, weiterentwickelt und aktualisiert werden muss, um wirksam zu bleiben.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.14 Planning (PL-1)

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Identifizieren und kommunizieren Sie die Entscheidungsfindungskultur, die ethische Haltung der Organisation und individuelle Verhaltensweisen, die die Unternehmenswerte vermitteln. Demonstrieren Sie einen ethischen Führungsstil und leben Sie die Unternehmenskultur vor.	(1) National Institute of Standards and Technology Special Publication 800-53, Revision 5, August 2017; (2) ISO/IEC 38500:2015(E); (3) King IV Report on Corporate Governance for South Africa, 2016	(1) 3.14 Planning (PL-4); (2) 4.1 Principles; (3) Part 5.1: Leadership, ethics and corporate citizenship – Principle 2
G. Komponente: Services, Infrastruktur und Anwendungen		
• COBIT und zugehörige Produkte/Werkzeuge • Ähnliche Rahmenwerke und Standards		

Domäne: Evaluieren, Vorgeben und Überwachen Governance-Ziel: EDM02 – Bereitstellung von Mehrwert ist sichergestellt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Optimierung des Wertbeitrags durch Investitionen in Geschäftsprozesse, I&T-Services und I&T-Betriebsmittel.		
Zweck		
Sicherstellung eines optimalen Wertbeitrages aus Services, Betriebsmitteln und Initiativen, die durch I&T ermöglicht wurden, kosteneffiziente Bereitstellung von Lösungen und Services sowie ein zuverlässiger und genauer Überblick über die Kosten und den möglichen Mehrwert, damit die Geschäftsanforderungen effektiv und effizient unterstützt werden können.		
Das Governance-Ziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Governance-Praktik	Beispielmetrik	
EDM02.01 Einrichten des angestrebten Investitionsmix Überprüfen Sie die Klarheit der Unternehmens- und I&T-Strategien und derzeitigen Services und stellen Sie diese sicher. Definieren Sie einen geeigneten Investitionsmix auf Basis der Kosten, der Vereinbarkeit mit der Strategie, der Art des Mehrwerts für die Programme im Portfolio, des Risikograds und von Finanzkennzahlen wie Kosten und erwartete Rendite (ROI) über den gesamten wirtschaftlichen Lebenszyklus. Passen Sie die Unternehmens- und I&T-Strategien ggf. an.	a. Anteil der I&T-Investitionen, die sich auf die Unternehmensstrategie zurückführen lassen b. Anteil der I&T-Investitionen, die auf Basis der Kosten, der Vereinbarkeit mit der Strategie, der Finanzkennzahlen (z. B. Kosten und ROI über den gesamten wirtschaftlichen Lebenszyklus), des Risikograds und der Art des Mehrwerts für die Programme im Portfolio definiert wurden	
Aktivitäten	Fähigkeitsstufe	
1. Erstellen und pflegen Sie Portfolios mit durch I&T ermöglichten Investitionsprogrammen, IT-Services und IT-Betriebsmitteln, um die Grundlage für das aktuelle IT-Budget zu schaffen und die taktischen und strategischen I&T-Pläne zu unterstützen.	2	
2. Sorgen Sie dafür, dass die IT und die Geschäftsbereiche ein gemeinsames Verständnis der potenziellen Chancen haben, die der IT zur Verfügung stehen, um die Umsetzung der Unternehmensstrategie zu ermöglichen und zu ihr beizutragen.		
3. Identifizieren Sie die allgemeinen Kategorien von Informationssystemen, Anwendungen, Daten, IT-Services, Infrastrukturen, I&T-Betriebsmittel, Ressourcen, Fähigkeiten, Praktiken, Kontrollen und Beziehungen, die zur Unterstützung der Unternehmensstrategie erforderlich sind.		
4. Verständigen Sie sich auf I&T-Ziele und berücksichtigen Sie dabei die Beziehungen, die zwischen der Unternehmensstrategie und den I&T-Services, Betriebsmitteln und sonstigen Ressourcen bestehen. Identifizieren Sie mögliche Synergien und nutzen Sie diese.		
5. Definieren Sie einen Investitionsmix, der das erforderliche Gleichgewicht zwischen verschiedenen Dimensionen herstellt, einschließlich eines angemessenen Verhältnisses zwischen kurz- und langfristigen Erträgen, finanziellen und nicht-finanziellen Vorteilen sowie risikoreichen und risikoarmen Investitionen.	3	

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
King IV Report on Corporate Governance for South Africa, 2016		Part 5.5: Stakeholder relationships – Principle 17
The Open Group IT4IT Reference Architecture, Version 2.0		3.2 IT Value Chain and IT4IT Reference Architecture
Governance-Praktik		Beispielmetrik
EDM02.02 Evaluieren der Wertoptimierung Bewerten Sie kontinuierlich das Portfolio der durch I&T ermöglichten Investitionen, Services und Betriebsmittel, um die Wahrscheinlichkeit für die Erreichung der Unternehmenszielvorgaben und die Bereitstellung eines Wertbeitrages bestimmen zu können. Identifizieren und beurteilen Sie Richtungswechsel, die dem Management mitgeteilt werden müssen, um die Wertschöpfung zu optimieren.		a. Abweichung zwischen Soll- und Ist-Investitionsmix b. Anteil des Portfolios aus durch I&T ermöglichten Investitionen mit einer gewissen Wahrscheinlichkeit, die Unternehmenszielvorgaben zu erreichen und Wert zu angemessenen Kosten zu liefern
Aktivitäten		Fähigkeitsstufe
1. Ermitteln Sie die Anforderungen der Anspruchsgruppen, strategische I&T-Probleme (wie z. B. I&T-Zuverlässigkeit) sowie die technologischen Erkenntnisse und Befähigungen in Bezug auf die tatsächliche und potenzielle Bedeutung der I&T für die Unternehmensstrategie.		2
2. Ermitteln Sie die wichtigsten Governance-Elemente, die für die zuverlässige, sichere und kosteneffektive Bereitstellung eines optimalen Wertes aus der Nutzung vorhandener und neuer I&T-Services, Betriebsmittel und Ressourcen erforderlich sind.		3
3. Ermitteln und erörtern Sie regelmäßig die Chancen, die sich für das Unternehmen aus Änderungen, die durch aktuelle, neue oder aufkommende Technologien möglich sind, ergeben könnten und optimieren Sie den Wert, der sich aus diesen Chancen ableiten lässt.		
4. Ermitteln Sie, was für das Unternehmen als Wert gilt, und überlegen Sie, wie gut dies kommuniziert, verstanden und in den Unternehmensprozessen abgebildet wird.		
5. Bewerten Sie, wie effektiv die Unternehmens- und I&T-Strategien im Hinblick auf die Bereitstellung eines Wertbeitrages in das Unternehmen integriert und aufeinander bzw. auf die Unternehmensziele abgestimmt sind.		4
6. Ermitteln und erwägen Sie, wie effektiv die derzeitigen Rollen, Zuständigkeiten, Verantwortlichkeiten und Entscheidungsträger in Bezug auf die Sicherstellung der Wertschöpfung aus durch I&T ermöglichten Investitionen, Services und Betriebsmitteln sind.		
7. Prüfen Sie, wie gut das Management der durch I&T ermöglichten Investitionen, Services und Betriebsmittel auf das Wertmanagement des Unternehmens und auf Finanzmanagement-Praktiken abgestimmt ist		
8. Bewerten Sie das Portfolio der Investitionen, Services und Betriebsmittel in Bezug auf die Ausrichtung an den strategischen Zielvorgaben des Unternehmens sowie den finanziellen und nicht-finanziellen Unternehmenswert, die Risiken in Bezug auf die Bereitstellung und Vorteile, die Ausrichtung an Geschäftsprozessen, die Effektivität in Bezug auf Nutzbarkeit, Verfügbarkeit und Reaktionsfähigkeit sowie die Effizienz in Bezug auf Kosten, Redundanz und den technischen Zustand.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		7. Strategy and Objective-Setting – Principle 8
ISF, The Standard of Good Practice for Information Security 2016		SG2.2 Stakeholder Value Delivery
ISO/IEC 38500:2015(E)		5.3 Principle 2: Strategy (Evaluate)
King IV Report on Corporate Governance for South Africa, 2016		Part 5.2: Strategy, performance and reporting – Principle 4
The Open Group IT4IT Reference Architecture, Version 2.0		5. Strategy to Portfolio (S2P) Value Stream
Governance-Praktik		Beispielmetrik
EDM02.03 Steuern der Wertoptimierung Wenden Sie Prinzipien und Praktiken des Wertmanagements an, um während des gesamten Wirtschaftslebenszyklus von durch I&T ermöglichten Investitionen eine optimale Wertrealisierung zu ermöglichen.		a. Anteil der I&T-Initiativen im Gesamtportfolio, deren Wert über den gesamten Lebenszyklus hinweg gemanagt wird b. Anteil der I&T-Initiativen, die die Prinzipien und Praktiken des Wertmanagements anwenden
Aktivitäten		Fähigkeitsstufe
1. Definieren und kommunizieren Sie Portfolio- und Investitionsarten, Kategorien, Kriterien und relative Gewichtungen für die einzelnen Kriterien, um allgemeine, relative Wertpunktzahlen zu erhalten.		2

A. Komponente: Prozess (Forts.)	
2. Definieren Sie Anforderungen für Stage-Gate- und andere Überprüfungen, um die Bedeutung der Investition für das Unternehmen und das damit verbundene Risiko, für Programmzeitpläne, Finanzierungspläne und die Bereitstellung von wichtigen Befähigungen und Vorteilen sowie für den kontinuierlichen Wertbeitrag zu ermitteln.	3
3. Motivieren Sie das Management dazu, potenzielle innovative I&T-Nutzungsmöglichkeiten in Erwägung zu ziehen, um dem Unternehmen zu ermöglichen, auf neue Chancen und Herausforderungen zu reagieren, neue Geschäftsmöglichkeiten anzugehen, seine Wettbewerbsfähigkeit zu stärken oder Prozesse zu verbessern.	
4. Steuern Sie etwaige Änderungen bezüglich der Zuweisung von Verantwortlichkeiten und Zuständigkeiten, die für die Umsetzung des Investitionsportfolios und die Bereitstellung eines Wertbeitrages aus Geschäftsprozessen und Services erforderlich sind.	
5. Steuern Sie etwaige Änderungen in Bezug auf das Investitions- und Serviceportfolio, die erforderlich sind, um eine neuerliche Ausrichtung an aktuelle und erwartete Unternehmenszielvorgaben und/oder Einschränkungen vorzunehmen.	
6. Empfehlen Sie die Berücksichtigung potenzieller Innovationen, organisatorischer Veränderungen oder operativer Verbesserungen, die dem Unternehmen einen erhöhten Wert aus durch I&T ermöglichten Investitionen verschaffen könnten.	
7. Definieren und kommunizieren Sie Ziele für die Bereitstellung eines Wertbeitrages auf Unternehmensebene und Ergebniskennzahlen, um eine effektive Überwachung zu ermöglichen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 38500:2015(E)	5.3 Principle 2: Strategy (Direct)
Governance-Praktik	Beispielmetrik
EDM02.04 Überwachen der Wertoptimierung Überwachen Sie die wichtigsten Ziele und Metriken, um festzustellen, ob das Unternehmen den erwarteten Wert und Nutzen aus den durch I&T ermöglichten Investitionen und Services realisiert. Identifizieren Sie gravierende Störungen, und ziehen Sie geeignete korrektive Maßnahmen in Betracht.	a. Anzahl der neuen Geschäftschancen, die als direkte Folge der I&T-Entwicklungen realisiert wurden b. Anteil der strategischen Unternehmenszielvorgaben, die als Ergebnis strategischer I&T-Initiativen erreicht wurden c. Grad der Zufriedenheit der oberen Führungskräfte mit der Bereitstellung eines Wertbeitrages und den Kosten seitens I&T d. Grad der Zufriedenheit der Anspruchsgruppen mit den Fortschritten bei der Erreichung der identifizierten Ziele (Wertbeitrag auf der Grundlage von Umfragen) e. Grad der Zufriedenheit der Anspruchsgruppen mit der Fähigkeit des Unternehmens, Wert aus durch I&T ermöglichten Initiativen zu generieren f. Anzahl der Störungen, die aufgrund tatsächlicher oder versuchter Umgehung der etablierten Wertmanagement-Prinzipien und -Praktiken aufgetreten sind g. Anteil erwarteter Wertbeiträge, die tatsächlich realisiert wurden
Aktivitäten	Fähigkeitsstufe
1. Definieren Sie einen ausgewogenen Umfang von Leistungszielvorgaben, Metriken, Zielen und Benchmarks. Die Metriken sollten Kennzahlen für Aktivitäten und Ergebnisse mit vor- und nachgelagerten Indikatoren für Ergebnisse sowie ein angemessenes Gleichgewicht zwischen finanziellen und nicht-finanziellen Kennzahlen aufweisen. Prüfen und vereinbaren Sie diese mit der IT-Abteilung und anderen Geschäftsbereichen sowie relevanten Anspruchsgruppen.	4
2. Erfassen Sie relevante, zeitgerechte, vollständige, zuverlässige und genaue Daten, um über den Fortschritt der Bereitstellung eines Wertbeitrages hinsichtlich der Ziele zu berichten. Verschaffen Sie sich einen vollständigen Überblick über die Leistung des Portfolios, der Programme und der I&T (technisch und operativ), der die Entscheidungsfindung unterstützt. Stellen Sie sicher, dass die erwarteten Ergebnisse erzielt werden.	
3. Verschaffen Sie sich regelmäßig relevante Portfolio-, Programm- und I&T-Leistungsberichte (technologisch und funktionsbezogen). Überprüfen Sie den Fortschritt des Unternehmens im Hinblick auf die identifizierten Ziele und das Ausmaß, in dem die geplanten Zielvorgaben erreicht, die Ergebnisse erbracht, die Leistungsziele erfüllt und die Risiken gemindert wurden.	
4. Stellen Sie im Rahmen der Überprüfung von Berichten sicher, dass geeignete korrektive Maßnahmen initiiert und kontrolliert werden.	5
5. Nehmen Sie im Rahmen der Überprüfung von Berichten ggf. geeignete Maßnahmen vor, um die Wertoptimierung sicherzustellen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 38500:2015(E)	5.3 Principle 2: Strategy (Monitor)

B. Komponente: Organisationsstrukturen									
Wichtige Governance-Praktik							Geschäftsleitung	Exekutivkomitee	Chief Executive Officer
EDM02.01 Einrichten des angestrebten Investitionsmix							A	R	R
EDM02.02 Evaluieren der Wertoptimierung							A	R	R
EDM02.03 Steuern der Wertoptimierung							A	R	R
EDM02.04 Überwachen der Wertoptimierung							A	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)					Detaillierte Referenzen				
King IV Report on Corporate Governance for South Africa, 2016					Part 2: Fundamental concepts – Definition of corporate governance				

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Governance-Praktik	Inputs		Outputs	
EDM02.01 Einrichten des angestrebten Investitionsmix	Von	Beschreibung	Beschreibung	Für
EDM02.01 Einrichten des angestrebten Investitionsmix	AP002.05	- Definition von strategischen Initiativen - Initiativen zur Risikobewertung - Strategische Roadmap	Feedback zu Strategie und Zielen	AP002.05
	AP009.01	Definitionen von Standardsservices	Identifizierte Ressourcen und Fähigkeiten, die erforderlich sind, um die Strategie zu unterstützen	Intern
	BAI03.11	Servicedefinitionen	Definierter Investitionsmix	Intern EDM02.03
	EDM02.03	Investitionsarten und -kriterien		
EDM02.02 Evaluieren der Wertoptimierung	AP002.05	Strategische Roadmap	Bewertung der strategischen Ausrichtung	AP002.04, AP005.02
	AP005.01	Erwartungen an den Kapitalertrag	Bewertung von Investitionen und Serviceportfolios	AP005.02, AP005.03, AP006.02
	AP005.02	Ausgewählte Programme mit ROI-Meilensteinen		
	AP005.05	Nutzerergebnisse und zugehörige Mitteilungen		
	BAI01.06	Stage-Gate-Review-Ergebnisse		
EDM02.03 Steuern der Wertoptimierung	AP005.03	Investitionsportfolio-Leistungsberichte	Anforderungen an Stage-Gate-Reviews	BAI01.01, BAI11.01
	EDM02.01	Definierter Investitionsmix	Investitionsarten und -kriterien	EDM02.01, AP005.02

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
EDM02.04 Überwachen der Wertoptimierung	APO05.03	Investitionsportfolio-Leistungsberichte	Maßnahmen zur Verbesserung der Wertschöpfung	APO05.03, APO06.02, BAI01.01, BAI11.01, EDM05.01
			Feedback zu Portfolio- und Programmleistung	APO05.03, APO06.05, BAI01.06
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Nutzenmanagement	Skills Framework for the Information Age V6, 2015	BENM

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Budgetierung und Umsetzung von Investitionen	Legt Richtlinien fest, um den Bedarf und die Anforderungen für Investitionen zu ermitteln, deren Umsetzung zu überwachen und einen maximalen Nutzen zu gewährleisten. Befasst sich mit der Formulierung von Budgetanforderungen und der Überwachung des Budgets und der planmäßigen Ausführung der technischen Leistung. Empfiehlt eine Neuzuweisung oder Neuprogrammierung, wenn angebracht. Befasst sich mit der Überwachung der Leistung anhand von Service Level Agreements und anderen leistungsbezogenen Metriken.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Der Wert, den I&T generiert, hängt davon ab, inwieweit I&T auf das Unternehmen abgestimmt sind und die Erwartungen erfüllt. Optimieren Sie den Wert von I&T durch die Schaffung einer Kultur, in der I&T-Services pünktlich, im Rahmen des Budgets und in angemessener Qualität erbracht werden.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Kostenrechnungssystem • Programm-Management-Werkzeuge

Diese Seite wurde absichtlich freigelassen.

Domäne: Evaluieren, Vorgeben und Überwachen Governance-Ziel: EDM03 – Risiko-Optimierung ist sichergestellt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Sicherstellung, dass die Risikobereitschaft und -toleranz des Unternehmens verstanden, artikuliert und kommuniziert werden und dass die mit der Nutzung von I&T verbundenen Risiken für den Unternehmenswert identifiziert und gemanagt werden.		
Zweck		
Sicherstellung, dass das I&T-bezogene Unternehmensrisiko die Risikobereitschaft und Risikotoleranz des Unternehmens nicht übersteigt, dass die Auswirkungen des I&T-Risikos auf den Unternehmenswert identifiziert und gemanagt werden und dass die Gefahr für Compliance-Verfehlungen minimiert wird.		
Das Governance-Ziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
- EG02 Gesteuertes Geschäftsrisiko - EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services		- AG02 Gesteuertes I&T-Risiko - AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobeurteilung abgedeckt werden b. Anteil der gravierenden Störungen, die in den Risikobeurteilungen nicht identifiziert wurden, an den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG02 a. Aktualisierungshäufigkeit des Risikoprofils b. Anteil der unternehmensweiten Risikobeurteilungen einschließlich I&T-bezogener Risiken c. Anzahl gravierender I&T-bezogener Störungen, die nicht im Rahmen einer Risikobewertung identifiziert wurden
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursacht haben b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Verfügbarkeitszielen der Services		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben

A. Komponente: Prozess		
Governance-Praktik		Beispielmetrik
EDM03.01 Evaluieren des Risikomanagements Analysieren und beurteilen Sie kontinuierlich die Wirkung von Risiken auf die derzeitige und künftige I&T-Nutzung im Unternehmen. Bestimmen Sie, inwieweit die Risikobereitschaft des Unternehmens angemessen ist, und überprüfen Sie, ob das Risiko für den Unternehmenswert in Verbindung mit der I&T-Nutzung identifiziert wurde und gemanagt wird.		a. Ausmaß unerwarteter Auswirkungen auf das Unternehmen b. Anteil des I&T-Risikos, das die Risikotoleranz des Unternehmens übersteigt c. Aktualisierungsrate der Risikofaktorbewertung
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie ein Verständnis für die Organisation und ihr Umfeld in Bezug auf das I&T-Risiko.		2
2. Bestimmen Sie die Risikobereitschaft der Organisation, d. h. das Niveau des I&T-bezogenen Risikos, das das Unternehmen einzugehen bereit ist, um seine Zielvorgaben zu erreichen.		
3. Bestimmen Sie die Toleranzniveaus bezogen auf die Risikobereitschaft, d. h. vorübergehend akzeptable Abweichungen von der definierten Risikobereitschaft.		
4. Bestimmen Sie, inwieweit die I&T-Risikostrategie an der Risikostrategie des Unternehmens ausgerichtet ist, und stellen Sie sicher, dass die Risikobereitschaft die Risikofähigkeit des Unternehmens nicht übersteigt.		
5. Bewerten Sie I&T-Risikofaktoren proaktiv im Vorfeld ausstehender strategischer Unternehmensentscheidungen und stellen Sie sicher, dass Risikoüberlegungen Teil des strategischen Entscheidungsprozesses des Unternehmens sind.		3
6. Bewerten Sie die Risikomanagementaktivitäten, um deren Ausrichtung an der Fähigkeit des Unternehmens, I&T-bezogene Verluste zu verkraften, sowie deren Toleranz seitens der Führungskräfte sicherzustellen		
7. Gewinnen Sie die erforderlichen Fähigkeiten und Mitarbeiter für das I&T-Risikomanagement und behalten Sie sie bei.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		Strategy and Objective-Setting – Principle 6 7; 9. Review and Revision – Principle 16
Governance-Praktik		Beispielmetrik
EDM03.02 Steuern des Risikomanagements Steuern Sie die Einrichtung von Risikomanagementpraktiken, um eine hinreichende Absicherung dahingehend zu bieten, dass die I&T-Risikomanagement-Praktiken geeignet sind und dass das tatsächliche I&T-Risiko nicht die Risikobereitschaft der Geschäftsleitung übersteigt.		a. Grad der Ausrichtung von I&T- und Unternehmensrisiko b. Anteil der Projekte im Unternehmen, bei denen das I&T-Risiko berücksichtigt wurde
Aktivitäten		Fähigkeitsstufe
1. Steuern Sie die Umsetzung und Integration der I&T-Risikostrategie in die Risikomanagementpraxis und die betrieblichen Aktivitäten.		2
2. Steuern Sie die Entwicklung von Risikokommunikationsplänen (die sämtliche Unternehmensebenen umfassen).		
3. Steuern Sie die Implementierung geeigneter Mechanismen, um schnell auf veränderte Risiken reagieren zu können, und erstatten Sie, basierend auf vereinbarten Eskalationsprinzipien (was wird gemeldet, wann, wo und wie) unverzüglich Bericht an die jeweiligen Managementebenen.		
4. Stellen Sie sicher, dass Risiken, Chancen, Probleme und Bedenken jederzeit von jedermann identifiziert und der entsprechenden Stelle gemeldet werden können. Risiken sollten in Einklang mit veröffentlichten Richtlinien und Verfahren gemanagt und an die relevanten Entscheidungsträger eskaliert werden.		
5. Identifizieren Sie wichtige Ziele und Metriken der Risiko-Governance- und Managementprozesse, die es zu überwachen gilt, und genehmigen Sie die Ansätze, Methoden, Techniken und Prozesse zur Erfassung und Meldung der Kennzahlen.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		RS.AS Apply Risk Management Strategy; BC.RO Determine Strategic Risk Objectives
ISF, The Standard of Good Practice for Information Security 2016		IR1.1 Information Risk Assessment–Management Approach
King IV Report on Corporate Governance for South Africa, 2016		Part 5.4: Governance functional areas – Principle 11
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.5 Assessment (Task 2)
Governance-Praktik		Beispielmetrik
EDM03.03 Überwachen des Risikomanagements Überwachen Sie wichtige Ziele und Metriken der Risikomanagementprozesse. Legen Sie fest, wie Abweichungen oder Probleme identifiziert, nachverfolgt und gemeldet werden sollen, um deren Behebung zu ermöglichen.		a. Anzahl der identifizierten und gemanagten potenziellen I&T-Risikobereiche b. Anteil der kritischen Risiken, die effektiv gemindert wurden c. Anteil der zeitgerecht ausgeführten I&T-Risiko-Maßnahmenpläne
Aktivitäten		Fähigkeitsstufe
1. Melden Sie Probleme im Rahmen des Risikomanagements der Geschäftsleitung oder dem Exekutivkomitee.		2
2. Überwachen Sie, inwieweit das Risikoprofil innerhalb der Schwellenwerte der Risikobereitschaft gemanagt wird.		3
3. Überwachen Sie wichtige Ziele und Metriken der Risiko-Governance- und Managementprozesse unter Berücksichtigung der jeweiligen Sollwerte. Analysieren Sie die zugrunde liegenden Ursachen etwaiger Abweichungen und leiten Sie korrektive Maßnahmen zu deren Behebung ein.		4
4. Ermöglichen Sie wichtigen Anspruchsgruppen, den Fortschritt des Unternehmens hinsichtlich der identifizierten Ziele zu überprüfen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		9. Review and Revision – Principle 17
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.1 Preparation (Task 7); 3.5 Assessment (Task 1); 3.6 Authorization (Task 1)
The Open Group IT4IT Reference Architecture, Version 2.0		6. Requirement to Deploy (R2D) Value Stream; 7. Request to Fulfill (R2F) Value Stream

B. Komponente: Organisationsstrukturen								
Wichtige Governance-Praktik		Geschäftsleitung	Exekutivkomitee	Chief Executive Officer	Chief Risk Officer	Chief Information Officer	I&T Governance Board	Risikoausschuss des Unternehmens
EDM03.01 Evaluieren des Risikomanagements		A	R	R	R	R	R	R
EDM03.02 Steuern des Risikomanagements		A	R	R	R	R	R	R
EDM03.03 Überwachen des Risikomanagements		A	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen						
COSO Enterprise Risk Management, Juni 2017		6. Governance and Culture – Principle						
King IV Report on Corporate Governance for South Africa, 2016		Part 2: Fundamental concepts – Definition of corporate governance						

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Governance-Praktik	Inputs		Outputs	
EDM03.01 Evaluieren des Risikomanagements	Von	Beschreibung	Beschreibung	Für
	AP012.01	Aufkommende Risiko- themen und -faktoren	Anleitung zur Risikobereit- schaft	AP004.01, AP012.03
	Außerhalb von COBIT	Unternehmensweite Risikomanagementprin- zipien	Bewertung der Risiko- management-Aktivitäten	AP012.01
			Genehmigte Risikotole- ranzniveaus	AP012.03
EDM03.02 Steuern des Risikomanagements	AP012.03	Aggregiertes Risiko- profil, einschließlich Status der Risiko- management-Aktivitäten	Genehmigtes Verfahren zur Beurteilung des Risi- komanagements	AP012.01
	Außerhalb von COBIT	Unternehmensweite Risi- komanagementprofile und Pläne zur Risikomin- derung	Zu überwachende wichtige Ziele für das Risikomanagement	AP012.01
			Richtlinien zum Risiko- management	AP012.01
EDM03.03 Überwachen des Risikomanagements	AP012.02	Ergebnisse der Risiko- analyse	Abhilfemaßnahmen bei Abweichungen im Risiko- management	AP012.06
	AP012.04	- Risikoanalyse- und Risikoprofilberichte für Anspruchsgruppen - Ergebnisse von Risikobewertungen Dritter - Chancen für die Akzeptanz eines größeren Risikos	An die Geschäftsleitung gerichtete Fragestellungen zum Risikomanagement	EDM05.01
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.1 Preparation (Task 7): Inputs and Outputs; 3.5 Assessment (Tasks 1, 2): Inputs 2, and Outputs; 3.6 Authorization (Task 1): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Management von Geschäftsrisiken	Skills Framework for the Information Age V6, 2015	BURM
Risikomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.3. Risk Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Unternehmensrisiko	Definiert die Steuerung und das Management von Unternehmensrisiken auf strategischer, taktischer und operativer Ebene gemäß den Geschäftszielen. Überträgt die unternehmensweite Governance in Prinzipien und Richtlinien der Risikosteuerung und erläutert Maßnahmen zum Risikomanagement.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.17 Risk assessment (RA-1)

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Fördern Sie eine risikobewusste I&T-Kultur auf allen Unternehmensebenen und befähigen Sie das Unternehmen, I&T-Risiken, Chancen und potenzielle Auswirkungen auf das Geschäft proaktiv zu identifizieren, zu melden und zu eskalieren. Die oberste Führungsebene sollte dabei die Richtung vorgeben und offenkundige und nachhaltige Unterstützung für Risikopraktiken zeigen. Zudem muss die Führungsebene die Risikobereitschaft klar definieren und ein angemessenes Maß an Diskussion im Rahmen des Geschäftsalltags sicherstellen. Zu den wünschenswerten Verhaltensweisen gehört es, die Mitarbeiter zu ermutigen, Probleme oder negative Ergebnisse anzusprechen und I&T-Risiken transparent zu machen. Geschäftsverantwortliche sollten gegebenenfalls die Übernahme von Verantwortung für I&T-Risiken annehmen und durch die Bereitstellung angemessener Ressourcen ein echtes Engagement für das I&T-Risikomanagement an den Tag legen.	COSO Enterprise Risk Management, Juni 2017	6. Governance and Culture – Principles 3 and 4

G. Komponente: Services, Infrastruktur und Anwendungen
Risikomanagementsystem

Domäne: Evaluieren, Vorgeben und Überwachen Governance-Ziel: EDM04 – Risiko-Optimierung ist sichergestellt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Sicherstellung, dass adäquate und ausreichende geschäfts- und I&T-bezogene Ressourcen (Mitarbeiter, Prozesse und Technologie) zur Verfügung stehen, um die Unternehmenszielvorgaben effektiv und zu optimalen Kosten zu unterstützen.		
Zweck		
Sicherstellung, dass der Ressourcenbedarf des Unternehmens optimal gedeckt und dass die I&T-Kosten optimiert werden sowie die Wahrscheinlichkeit der Nutzenrealisierung und die Bereitschaft für künftige Veränderungen erhöht wird.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		
A. Komponente: Prozess		
Governance-Praktik	Beispielmetrik	
EDM04.01 Evaluieren des Ressourcenmanagements Analysieren und beurteilen Sie kontinuierlich den aktuellen und künftigen Bedarf an unternehmens- und I&T-bezogenen Ressourcen (finanziell und personell), die Sourcing-Optionen (einschließlich Sourcing-Strategien) sowie die Zuordnungs- und Managementprinzipien, die erforderlich sind, um die Anforderungen des Unternehmens optimal zu erfüllen.	a. Anzahl der Abweichungen vom Ressourcenplan b. Anteil der Ressourcenplan- und Unternehmensarchitektur-Strategien, die mit den zugewiesenen Ressourcen Wert generieren und Risiken mindern	

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Prüfen Sie, ausgehend von den derzeitigen und künftigen Strategien, die Optionen für die Bereitstellung von I&T-Ressourcen (Technologie, finanzielle und personelle Ressourcen) sowie die Entwicklungsfähigkeiten mit Blick auf die Erfüllung aktueller und künftiger Anforderungen (einschließlich Sourcing-Optionen).		2
2. Definieren Sie Prinzipien für die Zuteilung und das Management von Ressourcen und Befähigungen, sodass die I&T in der Lage sind, die Anforderungen des Unternehmens, entsprechend den vereinbarten Prioritäten und unter Berücksichtigung der Budgeteinschränkungen, zu erfüllen. Definieren Sie z. B. bevorzugte Sourcing-Optionen für bestimmte Dienstleistungen und finanzielle Grenzen pro Sourcing-Option.		
3. Überprüfen und genehmigen Sie den Ressourcenplan und Unternehmensarchitekturstrategien, um mithilfe der zugeteilten Ressourcen für die Bereitstellung eines Wertbeitrages und Risikominderung zu sorgen.		
4. Ermitteln Sie die Anforderungen, um das I&T-Ressourcenmanagement an der Finanz- und Personalplanung des Unternehmens ausrichten zu können.		
5. Definieren Sie Prinzipien für das Management und die Kontrolle der Unternehmensarchitektur.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		GR.DR Direct Resource Management Needs
ISO/IEC 38500:2015(E)		5.4 Principle 3: Acquisition (Evaluate)
Governance-Praktik		Beispielmetrik
EDM04.02 Steuern des Ressourcenmanagements Stellen Sie sicher, dass Ressourcenmanagementprinzipien angewendet werden, um eine optimale Nutzung von Unternehmens- und I&T-Ressourcen während ihres gesamten Wirtschaftslebenszyklus zu ermöglichen.		a. Anzahl der Abweichungen und Ausnahmen von den Prinzipien des Ressourcenmanagements b. Anteil der wiederverwendeten Architekturkomponenten
Aktivitäten		Fähigkeitsstufe
1. Weisen Sie Zuständigkeiten für die Umsetzung des Ressourcenmanagements zu.		2
2. Richten Sie Prinzipien zum Sichern von Ressourcen ein.		
3. Kommunizieren Sie die Ressourcenmanagementstrategien, Prinzipien und vereinbarten Ressourcenplan- und Unternehmensarchitekturstrategien, und treiben Sie deren Anwendung voran.		3
4. Richten Sie das Ressourcenmanagement an der Finanz- und Personalplanung des Unternehmens aus.		
5. Definieren Sie wichtige Ziele, Kennzahlen und Metriken für das Ressourcenmanagement.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		GR.ER Evaluate Resource Management Needs
COSO Enterprise Risk Management, Juni 2017		6. Governance and Culture – Principle 5
ISO/IEC 38500:2015(E)		5.4 Principle 3: Acquisition (Direct)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.14 Planning (PL-4)
Governance-Praktik		Beispielmetrik
EDM04.03 Überwachen des Ressourcenmanagements Überwachen Sie wichtige Ziele und Metriken der Ressourcenmanagementprozesse. Legen Sie fest, wie Abweichungen oder Probleme identifiziert, nachverfolgt und gemeldet werden sollen, um deren Behebung zu ermöglichen.		a. Umfang der Rückmeldungen von Anspruchsgruppen zur Ressourcenoptimierung b. Anzahl der Vorteile (z. B. Kosteneinsparungen), die durch eine optimale Nutzung der Ressourcen erreicht werden konnten c. Anzahl der realisierten Leistungsziele für das Ressourcenmanagement d. Anteil der Projekte und Programme mit mittlerem oder hohem Risiko aufgrund von Problemen beim Ressourcenmanagement e. Anteil der Projekte mit angemessener Ressourcenzuteilung

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Überwachen Sie die Zuteilung und Optimierung von Ressourcen entsprechend den Zielvorgaben und Prioritäten des Unternehmens und berücksichtigen Sie dabei die vereinbarten Ziele und Metriken.	4
2. Überwachen Sie die I&T-bezogenen Sourcing-Strategien, Unternehmensarchitekturstrategien und die geschäfts- und IT-bezogenen Befähigungen und Ressourcen, um sicherzustellen, dass derzeitige und künftige Anforderungen und Zielvorgaben des Unternehmens erfüllt werden können.	
3. Überwachen Sie die Ressourcenleistung unter Berücksichtigung der jeweiligen Sollwerte. Analysieren Sie die Ursachen etwaiger Abweichungen, und leiten Sie korrektive Maßnahmen zu deren Behebung ein.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	GR.MR Monitor Resource Management Needs
ISO/IEC 38500:2015(E)	5.4 Principle 3: Acquisition (Evaluate)

B. Komponente: Organisationsstrukturen							
Wichtige Governance-Praktik						Geschäftsleitung	Exekutivkomitee
						Chief Executive Officer	Chief Operating Officer
						Chief Information Officer	I&T Governance Board
EDM04.01 Evaluieren des Ressourcenmanagements						A	R
EDM04.02 Steuern des Ressourcenmanagements						A	R
EDM04.03 Überwachen des Ressourcenmanagements						A	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen						
King IV Report on Corporate Governance for South Africa, 2016	Part 2: Fundamental concepts – Definition of corporate governance						

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Governance-Praktik	Inputs		Outputs	
EDM04.01 Evaluieren des Ressourcenmanagements	Von	Beschreibung	Beschreibung	Für
	APO02.04	Lücken und erforderliche Änderungen zur Erreichung der Zielbefähigung	Leitprinzipien für die Zuweisung von Ressourcen und Befähigungen	APO02.01, APO07.01, BAI03.11
	APO07.03	Pläne zur Entwicklung von Fähigkeiten	Genehmigter Ressourcenplan	APO02.05, APO07.01, APO09.02
	APO10.02	Ergebnisse von Lieferantenbewertungen	Leitprinzipien für die Unternehmensarchitektur	APO03.01

EDM04.02 Steuern des Ressourcenmanagements			Grundsätze für die Sicherung von Ressourcen	AP001.02
			Zugewiesene Zuständigkeiten für das Ressourcenmanagement	AP001.05, DSS06.03
			Kommunikation von Sourcingstrategien	AP002.06, AP007.05, AP009.02
C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
EDM04.03 Überwachen des Ressourcenmanagements			Abhilfemaßnahmen zur Behebung von Abweichungen im Ressourcenmanagement	AP002.05, AP007.01, AP007.03, AP009.04
			Rückmeldung zur Zuteilung und Effektivität von Ressourcen und Fähigkeiten	EDM05.01, AP002.02, AP007.05, AP009.05
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Portfoliomanagement	Skills Framework for the Information Age V6, 2015	POMG
Beschaffung	Skills Framework for the Information Age V6, 2015	RESC

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Leistungsmessung	Identifiziert den Bedarf für ein System zur Leistungsmessung, das über das konventionelle Rechnungswesen hinausgeht. Dieses System umfasst die Feststellung von Beziehungen und wissensbasierten Vermögenswerten, die notwendig sind, um im Informationszeitalter wettbewerbsfähig zu sein, einschließlich Kundenorientierung, Prozesseffizienz und die Fähigkeit zu lernen und zu wachsen (Balanced Scorecard). Die Balanced Scorecard setzt die Strategie in Maßnahmen zur Erreichung der Unternehmensziele um, wobei immaterielle Faktoren wie Kundenzufriedenheit, Rationalisierung interner Funktionen, Schaffung von operativer Effizienz und Befähigung von Mitarbeitern berücksichtigt werden. Diese ganzheitliche Sicht der betrieblichen Tätigkeiten trägt dazu bei, langfristige strategische Zielvorgaben und kurzfristige Maßnahmen miteinander zu verknüpfen.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur, in der Ressourcen wertgeschätzt werden und in der die Investition, Nutzung und Zuteilung von Ressourcen (ob Mitarbeiter, Informationen, Anwendungen, Technologie oder Einrichtungen) auf die Bedürfnisse der Organisation abgestimmt sind. Veranschaulichen Sie diese Werte, indem Sie sicherstellen, dass geeignete Methoden und angemessene Fähigkeiten in der Organisation vorhanden sind. Stellen Sie beispielsweise sicher, dass die Vorteile aus der Beschaffung von Dienstleistungen realistisch und umsetzbar sind und implementieren Sie zuverlässige Systeme zur Leistungsmessung (z. B. Balanced Scorecard).		
G. Komponente: Services, Infrastruktur und Anwendungen		
Systeme zur Leistungsmessung (z. B. Balanced Scorecard, Werkzeuge zum Management von Fähigkeiten)		

Diese Seite wurde absichtlich freigelassen.

Domäne: Evaluieren, Vorgeben und Überwachen Governance-Ziel: EDM05 – Einbindung der Anspruchsgruppen ist sichergestellt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Sicherstellung, dass die Anspruchsgruppen identifiziert und in das I&T-Governance-System eingebunden werden und dass die Messung und Meldung der I&T-Leistung und -Konformität des Unternehmens transparent sind, wobei die Anspruchsgruppen die Ziele und Metriken sowie die erforderlichen Abhilfemaßnahmen genehmigen.		
Zweck		
Sicherstellung, dass die Anspruchsgruppen die I&T-Strategie und die Roadmap unterstützen und dass die Kommunikation mit den Anspruchsgruppen effektiv und rechtzeitig erfolgt und dass die Grundlage für die Berichterstattung mit dem Ziel geschaffen wird, die Leistung zu steigern. Identifizierung von Bereichen, in denen Verbesserungen möglich sind und Sicherstellung, dass die I&T-bezogenen Zielvorgaben und Strategien mit der Unternehmensstrategie vereinbar sind.		
Das Governance-Ziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen		AG10 Qualität der I&T-Managementinformationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG10 a. Grad der Zufriedenheit der Nutzer mit der Qualität, Pünktlichkeit und Verfügbarkeit von I&T-bezogenen Managementinformationen unter Berücksichtigung der verfügbaren Ressourcen b. Verhältnis und Ausmaß von falschen Geschäftsentscheidungen, bei denen fehlerhafte oder nicht verfügbare I&T-bezogene Informationen ein Schlüsselfaktor waren c. Anteil der Informationen, die die Qualitätskriterien erfüllt haben
EG07 a. Grad der Zufriedenheit der Geschäftsleitung mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		

A. Komponente: Prozess		
Governance-Praktik	Beispielmetrik	
EDM05.01 Evaluieren der Einbeziehung der Anspruchsgruppen und der Berichtsanforderungen Analysieren und beurteilen Sie kontinuierlich die derzeitigen und künftigen Anforderungen an die Einbeziehung Anspruchsgruppen und die Berichterstattung (einschließlich der durch gesetzliche Bestimmungen vorgeschriebenen Berichterstattung) sowie die Kommunikation mit weiteren Anspruchsgruppen. Legen Sie Grundsätze für die Einbeziehung und die Kommunikation mit Anspruchsgruppen fest.	a. Datum der letzten Überarbeitung der Berichtsanforderungen b. Anteil der in den Berichtsanforderungen abgedeckten Anspruchsgruppen	
Aktivitäten	Fähigkeitsstufe	
1. Identifizieren Sie alle relevanten I&T-Anspruchsgruppen innerhalb und außerhalb des Unternehmens. Gruppieren Sie Anspruchsgruppen in Kategorien mit ähnlichen Anforderungen.	2	
2. Analysieren und beurteilen Sie die derzeitigen und künftigen vorgeschriebenen Berichtsanforderungen in Bezug auf die I&T-Nutzung im Unternehmen (Bestimmungen, Gesetzgebung, Gewohnheitsrecht, Verträge) sowie deren Umfang und Häufigkeit.		
3. Analysieren und beurteilen Sie die derzeitigen und künftigen Kommunikations- und Berichterstattungsanforderungen für weitere Anspruchsgruppen in Bezug auf die I&T-Nutzung im Unternehmen, einschließlich des erforderlichen Grades der Einbeziehung und Rücksprache sowie des Umfangs der Kommunikation, des Detaillierungsgrades und der Bedingungen.		

4. Stellen Sie Prinzipien für die Kommunikation mit externen und internen Anspruchsgruppen auf (einschließlich der Kommunikationsformate und -kanäle) sowie Prinzipien für die Abnahme und Freigabe der Berichterstattung seitens der Anspruchsgruppen.		3
A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		SR.DR Direct Stakeholder Communication and Reporting
Governance-Praktik		Beispielmetrik
EDM05.02 Steuern der Einbeziehung der Anspruchsgruppen, Kommunikation und Berichterstattung Sorgen Sie für eine effektive Einbeziehung der Anspruchsgruppen, Kommunikation und Berichterstattung. Dazu gehören Mechanismen zur Sicherstellung der Qualität und Vollständigkeit von Informationen, Überwachung der Pflichtberichterstattung sowie die Erstellung einer Kommunikationsstrategie für Anspruchsgruppen.		a. Anzahl der Verstöße gegen die Pflichtberichterstattung b. Grad der Zufriedenheit der Anspruchsgruppen mit Kommunikation und Berichterstattung
Aktivitäten		Fähigkeitsstufe
1. Steuern Sie die Einrichtung einer Strategie zur Kommunikation und Rücksprache für externe und interne Anspruchsgruppen.		2
2. Steuern Sie die Implementierung von Mechanismen, die sicherstellen, dass die Informationen den Kriterien für die I&T-Pflichtberichterstattung entsprechen, die für das Unternehmen gelten.		
3. Richten Sie Mechanismen zur Validierung und Genehmigung von Pflichtberichten ein.		
4. Richten Sie Eskalationsmechanismen für die Berichterstattung ein.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		SR.AR Apply Stakeholder Reporting Requirements
King IV Report on Corporate Governance for South Africa, 2016		Part 5.5: Stakeholder relationships – Principle 16
King IV Report on Corporate Governance for South Africa, 2016		Part 5.2: Strategy, performance and reporting – Principle 5
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity V1.1, April 2018		3.3 Communicating Cybersecurity Requirements with Stakeholders
Governance-Praktik		Beispielmetrik
EDM05.03 Überwachen der Einbeziehung der Anspruchsgruppen Überwachen Sie den Grad der Einbeziehung der Anspruchsgruppen und die Effektivität der Kommunikation mit ihnen. Beurteilen Sie Mechanismen zur Sicherstellung der Genauigkeit, Zuverlässigkeit und Effektivität und überprüfen Sie, inwieweit die Anforderungen unterschiedlicher Anspruchsgruppen bezüglich der Berichterstattung und Kommunikation erfüllt werden.		a. Grad der Einbeziehung der Anspruchsgruppen in die Abläufe der unternehmensweiten I&T b. Anteil der Berichte mit Ungenauigkeiten c. Anteil der Berichte, die pünktlich geliefert wurden
Aktivitäten		Fähigkeitsstufe
1. Beurteilen Sie regelmäßig die Effektivität der Mechanismen, mit denen die Genauigkeit und Zuverlässigkeit von Pflichtberichten sichergestellt werden soll.		4
2. Beurteilen Sie regelmäßig die Effektivität der Mechanismen für die Einbeziehung von und die Kommunikation mit externen und internen Anspruchsgruppen sowie die Ergebnisse der Kommunikation.		
3. Bestimmen Sie, inwieweit die Anforderungen unterschiedlicher Anspruchsgruppen erfüllt werden und den Grad der Einbeziehung der Anspruchsgruppen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		SR.MC Monitor Stakeholder Communication

B. Komponente: Organisationsstrukturen					
Wichtige Governance-Praktik					Geschäftsleitung Exekutivkomitee Chief Executive Officer Chief Risk Officer Chief Information Officer
EDM05.01 Evaluieren der Einbeziehung der Anspruchsgruppen und der Berichtsanforderungen					A R R R R
EDM05.02 Steuern der Einbeziehung der Anspruchsgruppen, Kommunikation und Berichterstattung					A R R R R
EDM05.03 Überwachen der Einbeziehung der Anspruchsgruppen					A R R R R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)			Detaillierte Referenzen		
King IV Report on Corporate Governance for South Africa, 2016			Part 2: Fundamental concepts – Definition of corporate governance		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Governance-Praktik	Inputs		Outputs	
EDM05.01 Evaluieren der Einbeziehung der Anspruchsgruppen und der Berichtsanforderungen	Von	Beschreibung	Beschreibung	Für
	EDM02.04	Maßnahmen zur Verbesserung der Wertbereitstellung	Grundsätze der Berichterstattung und Kommunikation	MEA01.01
	EDM03.03	An die Geschäftsleitung gerichtete Fragestellungen zum Risikomanagement	Bewertung der Anforderungen an die Unternehmensberichterstattung	MEA01.01
	EDM04.03	Rückmeldung zur Zuteilung und Effektivität von Ressourcen und Fähigkeiten		
EDM05.02 Steuern der Einbeziehung der Anspruchsgruppen, Kommunikation und Berichterstattung	APO12.04	Risikoanalyse- und Risikoprofilberichte für Anspruchsgruppen	Regeln für die Validierung und Genehmigung von Pflichtberichten	MEA01.01, MEA03.04
			Richtlinien zur Eskalation	MEA01.05
EDM05.03 Überwachen der Einbeziehung der Anspruchsgruppen	MEA04.08	• Ergebnisse der Prüfungen • Bericht der Prüfungen	Bewertung der Effektivität der Berichterstattung	MEA01.01, MEA03.04
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Beziehungsmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.4. Relationship Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Transparenzrichtlinie	Erläutert die Wichtigkeit einer häufigen, offenen Kommunikation mit allen Anspruchsgruppen, um sicherzustellen, dass sie die strategische Bedeutung der I&T für den Unternehmenserfolg verstehen. Hilft dabei, eine angemessene Risikominderung zu gewährleisten, indem Transparenz und effektives Risikomanagement mit dem I&T-Wert und dem Unternehmenswachstum verknüpft werden.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur, in der eine offene und strukturierte Kommunikation mit den wichtigsten Anspruchsgruppen entsprechend ihren Anforderungen stattfindet.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Kommunikationsmittel und -kanäle • Dashboard zur Steuerung der IT • Werkzeuge zur Befragung der Anspruchsgruppen

4.2 ANPASSEN, PLANEN UND ORGANISIEREN

- 01 I&T-Management-Rahmenwerk ist gemanagt
- 02 Strategie ist gemanagt
- 03 Unternehmensarchitektur ist gemanagt
- 04 Innovation ist gemanagt
- 05 Portfolio ist gemanagt
- 06 Budget und Kosten sind gemanagt
- 07 Personal ist gemanagt
- 08 Beziehungen sind gemanagt
- 09 Servicevereinbarungen sind gemanagt
- 10 Lieferanten sind gemanagt
- 11 Qualität ist gemanagt
- 12 Risiko ist gemanagt
- 13 Sicherheit ist gemanagt
- 14 Daten sind gemanagt

Diese Seite wurde absichtlich freigelassen.

Domäne: Anpassen, Planen und Organisieren Managementziel: APO01 – I&T-Management-Rahmenwerk ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Konzeption des Managementsystems für die unternehmensweite I&T auf der Grundlage der Unternehmensziele und anderer Designfaktoren. Implementierung aller erforderlichen Komponenten des Managementsystems auf der Grundlage dieses Konzepts.		
Zweck		
Bereitstellung eines konsistenten Managementansatzes, mit dessen Hilfe die Governance-Anforderungen des Unternehmens erfüllt werden können, der die folgenden Komponenten umfasst: Managementprozesse, Organisationsstrukturen, Rollen und Zuständigkeiten, zuverlässige und wiederholbare Aktivitäten, Informationselemente, Richtlinien und Verfahren, Fähigkeiten und Kompetenzen, Kultur und Verhalten sowie Services, Infrastruktur und Anwendungen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG03 Compliance mit externen Gesetzen und Bestimmungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG11 Compliance mit internen Richtlinien • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die IT ermöglichten Anlage- und Dienstleistungsportfolio • AG11 I&T-Compliance mit internen Richtlinien
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG03 a. Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern b. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursachten c. Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Nichteinhaltung der Vorschriften d. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von I&T-bezogenen Richtlinien b. Anzahl der Ausnahmen hinsichtlich interner Richtlinien c. Häufigkeit der Überprüfung und Aktualisierung der Richtlinien
EG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von Richtlinien b. Anteil der Anspruchsgruppen, die die Richtlinien verstehen c. Anteil der Richtlinien, die durch effektive Standards und Arbeitspraktiken unterstützt werden		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmessung
APO01.01 Design des Managementsystems für die Unternehmens-I&T Gestalten Sie ein Managementsystem, das auf die Anforderungen des Unternehmens zugeschnitten ist. Der Managementbedarf des Unternehmens wird dabei durch die Anwendung der Zielkaskade und Designfaktoren definiert. Stellen Sie sicher, dass die Governance-Komponenten in die unternehmensweite Governance- und Managementphilosophie und die Arbeitsweise integriert und darauf abgestimmt sind.		a. Anzahl der formellen Freigaben der vorrangigen Zielvorgaben für das I&T-Managementsystem durch die zuständigen Governance-Strukturen b. Anteil der Governance-Komponenten, die in die unternehmensweite Governance- und Managementphilosophie und die Arbeitsweise integriert und darauf abgestimmt sind
Aktivitäten		Fähigkeitsstufe
1. Verschaffen Sie sich ein Bild der Vision, Ausrichtung und Strategie des Unternehmens sowie des aktuellen Unternehmensumfeldes und der Herausforderungen.		2
2. Machen Sie sich mit dem internen Unternehmensumfeld vertraut. Dazu gehören Aspekte wie Managementkultur und -philosophie, Risikotoleranz, Sicherheit und Datenschutz, ethische Werte, Verhaltenskodex, Verantwortlichkeiten und Anforderungen an die Integrität des Managements.		
3. Wenden Sie die COBIT-Zielkaskade und -Designfaktoren auf die Unternehmensstrategie und den Kontext an, um über die Prioritäten für das Managementsystem und die Umsetzung der Prioritäten der Managementziele zu entscheiden.		
4. Validieren Sie ausgewählte Prioritäten für die Umsetzung der Managementziele anhand von branchenspezifischen bewährten Praktiken oder Anforderungen (z. B. branchenspezifische Vorschriften) sowie mit geeigneten Governance-Strukturen.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		7. Strategy and Objective-Setting – Principle 9
ISO/IEC 27001:2013/Cor.2:2015(E)		International standard for establishing, implementing and maintaining a management system (all chapters)
ITIL V3, 2011		Service Strategy, 2.3 Governance and management systems
Managementpraktik		Beispielmessung
APO01.02 Kommunizieren der Ziele und Richtungsvorgaben sowie der Entscheidungen des Managements Vermitteln Sie entsprechendes Bewusstsein und fördern Sie das Verständnis für die Ausrichtung und die I&T-Ziele bei den Anspruchsgruppen im gesamten Unternehmen. Kommunizieren Sie in regelmäßigen Abständen wichtige I&T-bezogene Entscheidungen und deren Auswirkungen auf das Unternehmen.		a. Häufigkeit der Kommunikation über die Managementziele und die Ausrichtung der I&T b. Zugewiesene Verantwortung für die Übermittlung regelmäßiger Mitteilungen
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie ausreichende und qualifizierte Ressourcen zur Unterstützung des Kommunikationsprozesses bereit.		2
2. Definieren Sie Grundregeln für die Kommunikation, indem Sie die Anforderungen an die Kommunikation identifizieren und darauf aufbauend Pläne umsetzen. Berücksichtigen Sie dabei die Kommunikation von oben nach unten, von unten nach oben sowie die horizontale Kommunikation.		3
3. Kommunizieren Sie kontinuierlich die I&T-Ziele und -Ausrichtung. Stellen Sie sicher, dass die Kommunikation durch Worte und Taten und unter Verwendung aller verfügbaren Kanäle von den obersten Führungskräften unterstützt wird.		
4. Stellen Sie sicher, dass die kommunizierten Informationen klare Formulierungen enthalten, was Mission, Servicezielvorgaben, interne Kontrollen, Qualität, Ethikkodex/Verhaltenskodex, Richtlinien und Verfahren, Rollen und Zuständigkeiten usw. anbelangt. Kommunizieren Sie die Informationen mit dem für die jeweilige Zielgruppe im Unternehmen angemessenen Grad an Ausführlichkeit.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine entsprechenden weiteren Quellen für diese Komponente		

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
APO01.03 Implementieren von Managementprozessen (zur Unterstützung der Erreichung von Governance- und Managementzielen) Definieren Sie Zielprozess-Fähigkeitsstufen und Implementierungsprioritäten auf der Grundlage des Designs des Managementsystems.		a. Anzahl der prioritären Prozesse, die implementiert oder verbessert werden müssen, um die angestrebte Fähigkeitsstufe zu erreichen b. Anzahl der für die Nachverfolgung der erfolgreichen Prozessimplementierung definierten Metriken
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie ein organisationsspezifisches I&T-Governance-Zielprozessmodell auf der Grundlage der Auswahl der vorrangigen Managementziele (Ausgabe der Zielkaskade und Anwendung der Designfaktoren).		2
2. Analysieren Sie die Lücke zwischen dem Zielprozessmodell für die Organisation und den aktuellen Praktiken und Aktivitäten.		3
3. Entwerfen Sie eine Roadmap für die Implementierung fehlender Prozesspraktiken und -aktivitäten. Verwenden Sie bewährte Metriken zur Nachverfolgung des Implementierungserfolges.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
APO01.04 Definieren und Implementieren der Organisationsstrukturen Richten Sie die erforderlichen internen und erweiterten Organisationsstrukturen (z. B. Ausschüsse) gemäß dem Entwurf des Managementsystems ein, um eine effektive und effiziente Entscheidungsfindung zu ermöglichen. Stellen Sie sicher, dass das erforderliche I&T-Wissen bei der Entwicklung der Managementstrukturen genutzt wird.		a. Grad der Zufriedenheit der obersten Führungskräfte mit der Entscheidungsfindung des Managements b. Anzahl der Entscheidungen, die nicht innerhalb der Management-Strukturen getroffen werden konnten und in die Governance-Strukturen eskaliert wurden
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie die Entscheidungen, die für die Erreichung der Unternehmensergebnisse und die I&T-Strategie sowie für das Management und die Ausführung der I&T-Services erforderlich sind.		2
2. Beziehen Sie Anspruchsgruppen ein, die für eine Entscheidungsfindung maßgeblich sind (verantwortlich, zuständig, konsultiert oder informiert (RACI)).		
3. Definieren Sie den Umfang, die Schwerpunkte, den Auftrag und die Verantwortlichkeiten jeder Funktion innerhalb der I&T-bezogenen Organisation in Übereinstimmung mit der Governance-Ausrichtung.		
4. Definieren Sie den Umfang der internen und externen Funktionen und Rollen sowie die erforderlichen Fähigkeiten und Entscheidungsbefugnisse, die erforderlich sind, um alle Praktiken, einschließlich der von Dritten ausgeführten, abzudecken.		3
5. Richten Sie die I&T-bezogene Organisation an den Organisationsmodellen der Unternehmensarchitektur aus.		
6. Richten Sie einen I&T-Lenkungsausschusses (oder ein gleichwertiges Gremium) ein, der sich aus Führungskräften, Geschäfts- und I&T-Managern zusammensetzt, um den Status von Projekten zu verfolgen, Ressourcenkonflikte zu lösen und die Servicequalität und Serviceverbesserungen zu überwachen.		
7. Stellen Sie Richtlinien für die einzelnen Managementstrukturen bereit (einschließlich Mandat, Zielvorgaben, Besprechungsteilnehmer, Zeitplan, Nachverfolgung, Beaufsichtigung und Überwachung) sowie erforderliche Inputs für und erwartete Ergebnisse aus Besprechungen.		4
8. Überprüfen Sie regelmäßig die Angemessenheit und Effektivität der Organisationsstrukturen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)			
Managementpraktik		Beispielmetrik	
AP001.05 Einrichten der Rollen und Zuständigkeiten Definieren und Kommunizieren Sie die Rollen und Zuständigkeiten für die unternehmensweite I&T, einschließlich der Kompetenzstufen, Zuständigkeiten und Verantwortlichkeiten.		a. Anzahl der I&T-bezogenen Rollen, die Personen zugewiesen wurden b. Anzahl der fertiggestellten Rollenbeschreibungen	
Aktivitäten			Fähigkeitsstufe
1. Erstellen, vereinbaren und kommunizieren Sie die I&T-bezogenen Rollen und Zuständigkeiten für das gesamte Personal im Unternehmen unter Berücksichtigung der Geschäftsanforderungen und Zielvorgaben. Grenzen Sie dabei klar zwischen Zuständigkeit und Verantwortlichkeit ab, insbesondere wenn es um Entscheidungsfindung und Genehmigungen geht.			2
2. Berücksichtigen Sie bei der Festlegung der Rollen die Anforderungen an die Unternehmens- und I&T-Servicekontinuität, einschließlich Anforderungen hinsichtlich Reservepersonal und fachbereichsübergreifender Schulungen.			
3. Stellen Sie Input für den I&T-Servicekontinuitätsprozess bereit, indem Sie Kontaktinformationen und Rollenbeschreibungen im Unternehmen aktuell halten.			
4. Nehmen Sie in die Rollen- und Zuständigkeitsbeschreibungen die Einhaltung von Managementrichtlinien und -verfahren, des Verhaltenskodex und von Berufspraktiken auf.			
5. Stellen Sie sicher, dass die Verantwortlichkeit durch Rollen und Zuständigkeiten festgelegt ist.			
6. Strukturieren Sie die Rollen und Zuständigkeiten so, dass die Wahrscheinlichkeit, dass ein kritischer Prozess von einer einzigen Rolle wahrgenommen wird, möglichst gering ist.			
7. Implementieren Sie geeignete Aufsichtspraktiken, um sicherzustellen, dass die Rollen und Zuständigkeiten angemessen ausgeübt werden, um beurteilen zu können, ob alle Mitarbeiter über ausreichende Befugnisse und Ressourcen verfügen, um ihren Rollen und Zuständigkeiten gerecht zu werden und um die Leistung allgemein überprüfen zu können. Das Maß an Aufsicht sollte der Position und dem Umfang der zugewiesenen Zuständigkeiten angepasst sein.			3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
Keine zugehörigen Leitfäden für diese Managementpraktik			
Managementpraktik		Beispielmetrik	
AP001.06 Optimieren der Eingliederung der IT-Funktion Positionieren Sie IT-Befähigungen in der gesamten Organisationsstruktur, um die strategische Bedeutung und die operative Abhängigkeit innerhalb des Unternehmens widerzuspiegeln. Die Berichtslinie des CIO und die Vertretung der IT innerhalb der oberen Führungsebene sollten der Bedeutung der I&T innerhalb des Unternehmens angemessen sein.		a. Anzahl der wichtigen Anspruchsgruppen, die die Eingliederung der IT-Funktion genehmigt haben b. Anteil der Anspruchsgruppen mit einer positiven Meinung zur Eingliederung der IT-Funktion	
Aktivitäten			Fähigkeitsstufe
1. Bestimmen Sie den Kontext für die Eingliederung der IT-Funktion einschließlich der Beurteilung der Unternehmensstrategie und des Betriebsmodells (zentralisiert, autonom, dezentralisiert, hybrid), der Bedeutung der I&T sowie der Beschaffungssituation und -optionen.			3
2. Identifizieren, bewerten und priorisieren Sie Optionen für die organisatorische Eingliederung, sowie das Sourcing- und das Betriebsmodell.			
3. Legen Sie die Eingliederung der IT-Funktion fest und sorgen Sie für die entsprechende Zustimmung.			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
ISO/IEC 27002:2013/Cor.2:2015(E)		8.2 Information classification	
Managementpraktik		Beispielmetrik	
AP001.07 Definieren der Verantwortung für Informationen (Daten) und Systeme Definieren und pflegen Sie Zuständigkeiten für die Verantwortung für Informationen (Daten) und Informationssysteme. Stellen Sie sicher, dass die Verantwortlichen Entscheidungen zur Klassifizierung von Informationen und Systemen und deren Schutz entsprechend der Klassifizierung treffen.		a. Anteil der Informationsbestände mit klar definierten Verantwortlichen b. Anteil der Informationssysteme mit klar definierten Verantwortlichen c. Anteil der Informationselemente, die gemäß den vereinbarten Stufen klassifiziert sind	

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie Richtlinien bereit, mit deren Hilfe eine angemessene und konsistente, unternehmensweite Klassifizierung von Informationselementen sichergestellt werden kann.	3
2. Erstellen Sie eine Informationsbestandsliste (Systeme und Daten), die eine Auflistung der Verantwortlichen, Verwahrer und Klassifizierungen umfasst und halten Sie sie aktuell. Beziehen Sie ausgelagerte Systeme ebenso ein wie Systeme, deren Verantwortung im Unternehmen verbleiben sollte.	
3. Bewerten und unterscheiden Sie zwischen kritischen (hochwertigen) und unkritischen Daten, Informationen und Systemen. Stellen Sie einen für die jeweilige Kategorie angemessenen Schutz sicher.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
APO01.08 Definieren von Zielfähigkeiten und Kompetenzen Definieren Sie die erforderlichen Fähigkeiten und Kompetenzen, um die relevanten Managementziele zu erreichen.	a. Anzahl der Mitarbeiter, die an Schulungen oder Sensibilisierungsveranstaltungen zu ausgewählten Fertigkeiten, Kompetenzen und erwünschten Verhaltensweisen teilgenommen haben b. Anteil der Mitarbeiter mit den erforderlichen, auf ausgewählte Managementziele ausgerichteten Fähigkeiten und Kompetenzen
Aktivitäten	Fähigkeitsstufe
1. Ermitteln Sie die zur Erreichung ausgewählter Managementziele erforderlichen Fähigkeiten und Kompetenzen.	2
2. Analysieren Sie die Lücke zwischen den für das Unternehmen angestrebten Fähigkeiten und Kompetenzen und den derzeitigen Fähigkeiten der Mitarbeiter. Siehe APO07 – Personal ist hinsichtlich Kompetenzentwicklung und Managementpraktiken gemanagt.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
APO01.09 Definieren und Kommunizieren von Richtlinien und Verfahren Richten Sie Verfahren zur Aufrechterhaltung der Compliance und Leistungsmessung hinsichtlich Richtlinien und anderen Komponenten des Kontrollrahmenwerks ein. Setzen Sie die Konsequenzen im Falle der Nichteinhaltung oder einer unzureichenden Leistung durch. Verfolgen Sie Trends und Leistung, und berücksichtigen Sie diese bei der künftigen Gestaltung und Verbesserung des Kontrollrahmenwerks.	a. Anteil der aktiven Richtlinien und Verfahren, die dokumentiert und auf dem neuesten Stand sind b. Anzahl der Mitarbeiter, die sich der Richtlinien und Verfahren bewusst sind und eine entsprechende Kompetenz nachweisen können
Aktivitäten	Fähigkeitsstufe
1. Erstellen Sie Richtlinien, die den IT-Kontrollerwartungen in Bezug auf relevante Schlüsselthemen wie z. B. Qualität, Sicherheit, Vertraulichkeit, interne Kontrollen, Nutzung von I&T-Betriebsmitteln, Ethik und geistige Eigentumsrechte gerecht werden.	3
2. Sorgen Sie für die Implementierung und einheitliche Durchsetzung der I&T-Richtlinien bei den betreffenden Mitarbeitern, sodass die Richtlinien zu einem festen Bestandteil der Unternehmensabläufe werden.	
3. Bewerten und aktualisieren Sie die Richtlinien mindestens einmal pro Jahr, um eventuellen Veränderungen in der Betriebs- oder Geschäftsumgebung Rechnung zu tragen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

A. Komponente: Prozess (Forts.)

Managementpraktik	Beispielmetrik
APO01.10 Definieren und Implementieren von Infrastrukturen, Diensten und Anwendungen zur Unterstützung des Governance- und Managementsystems Definieren und implementieren Sie Infrastruktur, Dienste und Anwendungen zur Unterstützung des Governance- und Managementsystems (z. B. Architektur-Repositories, Risikomanagementsystem, Projektmanagement-Tools, Werkzeuge zur Kostenverfolgung und zur Überwachung von Störungen).	a. Anzahl der ausgewählten Werkzeuge zur Unterstützung prioritärer Prozesse b. Angemessenheit/Abdeckung der wichtigsten I&T-Prozesse durch die Werkzeuge c. Zufriedenheit der Empfänger mit der Genauigkeit, Vollständigkeit und Aktualität der Informationen d. Grad der Zufriedenheit der Anspruchsgruppen mit den Werkzeugen, die zur Unterstützung ihrer Anforderungen ausgewählt wurden
Aktivitäten	Fähigkeitsstufe
1. Ermitteln Sie die vorrangigen Managementziele, die durch die Automatisierung von Diensten, Anwendungen oder Infrastruktur erreicht werden können.	2
2. Wählen und Implementieren Sie die am besten geeigneten Werkzeuge aus und kommunizieren Sie diese an die Anspruchsgruppen.	
3. Bieten Sie bei Bedarf Schulungen zu ausgewählten Werkzeugen an.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
APO01.11 Managen der kontinuierlichen Verbesserung des I&T-Managementsystems Verbessern Sie kontinuierlich Prozesse und andere Komponenten des Managementsystems, um sicherzustellen, dass diese die Governance- und Managementziele erfüllen können. Berücksichtigen Sie dabei COBIT-Implementierungsanleitungen, neu entstehende Standards, Compliance-Anforderungen, Automatisierungsmöglichkeiten und Rückmeldungen der Anspruchsgruppen.	a. Datum der letzten Aktualisierung des Rahmenwerks und der Komponenten b. Anzahl der I&T-bezogenen Verluste aufgrund von Unzulänglichkeiten bei der Gestaltung der Kontrollumgebung
Aktivitäten	Fähigkeitsstufe
1. Beurteilen Sie regelmäßig die Leistung der Rahmenwerk-Komponenten, und ergreifen Sie ggf. geeignete Maßnahmen.	4
2. Identifizieren Sie geschäftskritische Prozesse auf der Grundlage von Leistungs- und Konformitätstreibern und den damit verbundenen Risiken. Bewerten Sie die Fähigkeiten und ermitteln Sie Verbesserungsziele. Analysieren Sie Lücken bei Fähigkeiten und Kontrolle. Identifizieren Sie Optionen zur Verbesserung oder Neugestaltung des entsprechenden Prozesses.	
3. Setzen Sie Prioritäten für Verbesserungsinitiativen auf der Grundlage potenzieller Vorteile und der Kosten. Setzen Sie vereinbarte Verbesserungen in den Arbeitsalltag um und setzen Sie Leistungsziele und -metriken fest, um die Überwachung von Verbesserungen zu ermöglichen.	5
4. Erwägen Sie Möglichkeiten zur Verbesserung der Effizienz und Effektivität (z. B. durch Schulung, Dokumentation, Standardisierung und/oder Prozessautomatisierung).	
5. Aktualisieren Sie den Prozess durch Anwendung von Qualitätsmanagementpraktiken.	
6. Setzen Sie veraltete Governance-Komponenten inaktiv (Prozesse, Informationselemente, Richtlinien usw.).	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ITIL V3, 2011	Continual Service Improvement, 4.1 The 7-Step Improvement Process

B. Komponente: Organisationsstrukturen																					
	Exekutivkomitee	Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Architekturausschuss	Risikoausschuss des Unternehmens	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Datenmanagement	Leiter Personal	Relationship Manager	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter
Wichtige Managementpraktik:																					
APO01.01 Design des Managementsystems für die Unternehmens-I&T	A		R	R	R	R															
APO01.02 Kommunizieren der Ziele und Richtungsvorgaben sowie der Entscheidungen des Managements	A	R	R	R	R	R			R				R								
APO01.03 Implementieren von Managementprozessen (zur Unterstützung der Erreichung von Governance- und Managementzielen)	A	R	R	R	R	R			R												
APO01.04 Definieren und Implementieren der Organisationsstrukturen	A		R	R	R	R						R									
APO01.05 Einrichten der Rollen und Zuständigkeiten	A		R	R	R	R															
APO01.06 Optimieren der Eingliederung der IT-Funktion	A		R	R	R	R		R													
APO01.07 Definieren der Verantwortung für Informationen (Daten) und Systeme	A		R	R	R	R		R		R	R			R							
APO01.08 Definieren von Zielfähigkeiten und Kompetenzen	A		R	R	R	R								R	R	R	R				
APO01.09 Definieren und Kommunizieren von Richtlinien und Verfahren	A		R	R	R	R	R	R		R	R	R		R	R	R	R	R	R	R	R
APO01.10 Definieren und Implementieren von Infrastrukturen, Diensten und Anwendungen zur Unterstützung des Governance- und Managementsystems	A		R	R	R	R					R			R	R	R	R	R	R	R	R
APO01.11 Managen der kontinuierlichen Verbesserung des I&T-Managementsystems	A		R	R	R	R				R	R			R	R	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen																				
COSO Enterprise Risk Management, Juni 2017	6. Governance and Culture – Principle 2																				
ISO/IEC 27001:2013/Cor.2:2015(E)	5.3 Organisatorische Rollen, Verantwortlichkeiten und Befugnisse																				

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO01.01 Design des Managementsystems für die Unternehmens-I&T	Von	Beschreibung	Beschreibung	Für
	APO02.05	Strategische Roadmap	Vorrangige Governance- und Managementziele	Alle APO, BAI, DSS, MEA
	APO12.01	Aufkommende Risikothemen und -faktoren	Managementsystem-design	Alle APO, BAI, DSS, MEA
	APO12.02	Ergebnisse der Risikoanalyse		
	EDM01.01	- Leitprinzipien der unternehmensweiten Governance - Modell zur Entscheidungsfindung		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
APO01.02 Kommunizieren der Ziele und Richtungsvorgaben sowie der Entscheidungen des Managements	APO12.06	Kommunikation der Risikoauswirkungen	Kommunikationsgrundregeln	Alle APO, BAI, DSS, MEA
	DSS04.01	Richtlinien und Zielvorgaben für die Geschäftskontinuität	Kommunikation der I&T-Ziele	Alle APO, BAI, DSS, MEA
	DSS05.01	Richtlinie zur Verhinderung bösartiger Software		
	DSS05.02	Sicherheitsrichtlinie für Konnektivität		
	DSS05.03	Sicherheitsrichtlinien für Endpunktgeräte		
	EDM01.02	Unternehmensweite Governance-Kommunikation		
	EDM04.02	Grundsätze für die Sicherung von Ressourcen		
APO01.03 Implementieren von Managementprozessen (zur Unterstützung der Erreichung von Governance- und Managementzielen)	APO02.04	Lücken und erforderliche Änderungen zur Erreichung der Zielbefähigung	Zielmodell-GAP-Analyse	Alle APO, BAI, DSS, MEA
	EDM01.01	Unternehmensweite Governance-Leitprinzipien	Prozess-Fähigkeitsstufen	APO01.11
APO01.04 Definieren und Implementieren der Organisationsstrukturen	APO03.02	Prozessarchitekturmodell	Betriebsrichtlinien für Unternehmen	APO03.02
	EDM01.01	Unternehmensweite Governance-Leitprinzipien	Definition von Organisationsstruktur und Funktionen	APO03.02
APO01.05 Einrichten der Rollen und Zuständigkeiten	Von	Beschreibung	Beschreibung	Für
	APO07.03	• Matrix der Fähigkeiten und Kompetenzen • Pläne zur Entwicklung von Fähigkeiten	Definition von Aufsichtspraktiken	APO07.01
	APO11.01	Rollen, Verantwortlichkeiten und Entscheidungsbefugnisse im Qualitätsmanagementsystem (QMS)	Definition von I&T-bezogenen Rollen und Zuständigkeiten	DSS05.04
	APO13.01	Information zum Umfang des Managementsystems für Informationssicherheit (ISMS)		
	DSS06.03	• Zugewiesene Rollen und Verantwortlichkeiten • Zugewiesene Kompetenzstufen		
	EDM01.01	Kompetenzstufen		
	EDM04.02	Zugewiesene Zuständigkeiten für das Ressourcenmanagement		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
APO01.06 Optimieren der Eingliederung der IT-Funktion	Außerhalb von COBIT	• Unternehmensstrategie • Betriebsmodell des Unternehmens	Definierte operative Eingliederung der IT-Funktion	APO03.02
			Bewertung von Optionen für die IT-Organisation	APO03.02
APO01.07 Definieren der Verantwortung für Informationen (Daten) und Systeme			Richtlinien zur Datenklassifizierung	APO03.02, APO14.01, BAI02.01, DSS05.02, DSS06.01
			Richtlinien zur Datensicherheit und -kontrolle	APO14.04, APO14.10, BAI02.01
			Verfahren zur Datenintegrität	APO14.04, BAI02.01, DSS06.01
APO01.08 Definieren von Zielfähigkeiten und Kompetenzen			Matrix der Zielfähigkeiten und -kompetenzen	APO07.03
APO01.09 Definieren und Kommunizieren von Richtlinien und Verfahren	DSS01.04	Umweltpolitik	Abhilfemaßnahmen bei Nichteinhaltung (Non-Compliance)	MEA01.05
	MEA03.02	Aktualisierte Richtlinien, Grundsätze, Verfahren und Standards		
APO01.10 Definieren und Implementieren von Infrastrukturen, Diensten und Anwendungen zur Unterstützung des Governance- und Managementsystems	APO09.01	Identifizierte Lücken bei den geschäftsbezogenen I&T-Services	Plan der passenden I&T-Landschaft einschließlich fehlender I&T-Fähigkeiten, Dienste und Anwendungen	APO02.02, APO02.03
	Außerhalb von COBIT	Bewertung der I&T-Landschaft einschließlich Diensten, Anwendungen und Infrastruktur		
APO01.11 Managen der kontinuierlichen Verbesserung des I&T-Managementsystems	Von	Beschreibung	Beschreibung	Für
	APO01.03	Prozess-Fähigkeitsstufen	Möglichkeiten zur Prozessverbesserung	Alle APO, BAI, DSS, MEA
	EDM01.03	Rückmeldung zur Effektivität und Leistung der Governance	Leistungsziele und Metriken zur Nachverfolgung von Prozessverbesserungen	MEA01.02
	MEA03.02	Aktualisierte Richtlinien, Grundsätze, Verfahren und Standards	Bewertungen der Prozessfähigkeit	MEA01.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
IT-Governance	Skills Framework for the Information Age V6, 2015	GOVN
IT-Management	Skills Framework for the Information Age V6, 2015	ITMG

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
I&T-Management-Rahmenwerk	Einrichtung eines Managementsystems für die unternehmensweite I&T auf der Grundlage der Unternehmensziele und anderer Designfaktoren. Betrachtet detaillierte Richtlinien und Grundsätze für das I&T-Management über alle Komponenten hinweg.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine interne Kultur der Zusammenarbeit zwischen Geschäft und IT, wobei die notwendigen Managementziele, Strukturen, Prozesse sowie Rollen und Verantwortlichkeiten derart festgelegt werden, dass sie eine Entscheidungsfindung und Wertschöpfung auf die effektivste und effizienteste Weise ermöglichen.		

G. Komponente: Services, Infrastruktur und Anwendungen	
• COBIT und zugehörige Produkte/Werkzeuge • Ähnliche Rahmenwerke und Standards	

Domäne: Anpassen, Planen und Organisieren Managementziel: APO02 – Strategie ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Bereitstellung einer ganzheitlichen Übersicht der aktuellen Geschäfts- und I&T-Umgebung, der künftigen Ausrichtung und der Initiativen, die für die Migration in die gewünschte künftige Umgebung erforderlich sind. Sicherstellung, dass der gewünschte Grad der Digitalisierung integraler Bestandteil der künftigen Ausrichtung und der I&T-Strategie ist. Bewertung des aktuellen digitalen Reifegrads der Organisation und Entwickeln einer Roadmap, um die Lücken zu schließen. Überdenken der internen Abläufe und der kundenbezogenen Aktivitäten im geschäftlichen Bereich. Sicherstellen, dass der Schwerpunkt auf der Transformation der gesamten Organisation liegt. Heranziehung der Bausteine der Unternehmensarchitektur, Governance-Komponenten und des Ökosystems der Organisation, einschließlich der extern bereitgestellten Services und zugehöriger Befähigungen, um eine zuverlässige, aber auch agile und effiziente Abarbeitung der strategischen Zielvorgaben zu ermöglichen.		
Zweck		
Unterstützung der digitalen Transformationsstrategie der Organisation und Bereitstellung des gewünschten Wertes anhand einer Roadmap mit stufenweisen Änderungen. Verwendung eines ganzheitlichen I&T-Ansatzes, der sicherstellt, dass jede Initiative eindeutig mit einer übergreifenden Strategie verbunden ist. Ermöglichung von Veränderungen verschiedener Aspekte der Organisation – von Kanälen und Prozessen bis hin zu Daten, Kultur, Fähigkeiten, Betriebsmodell und Anreizsystemen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG05 Kundenorientierte Servicekultur • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG08 Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Services		AG08 a. Dauer der Ausführung von Geschäftsprozessen oder -prozessen b. Anzahl der durch I&T ermöglichten Geschäftsprogramme, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder zusätzliche Kosten verursacht haben c. Anzahl der Geschäftsprozessänderungen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder überarbeitet werden mussten d. Anzahl von Anwendungen oder kritischen Infrastrukturen, die isoliert arbeiten und nicht integriert sind
EG05 a. Anzahl der Unterbrechungen bei den Kundenservices b. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die Kundenservices den vereinbarten Standards entsprechen c. Anzahl von Kundenbeschwerden d. Trend der Umfrageergebnisse zur Kundenzufriedenheit		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
AP002.01 Verstehen von Unternehmenskontext und -ausrichtung Betrachten Sie den Unternehmensukontext (Branchentreiber, einschlägige Bestimmungen, Wettbewerbsgrundlage), die derzeitige Arbeitsweise und das Anspruchsniveau in Bezug auf die Digitalisierung.		a. Wissensstand innerhalb des I&T-Managements bezüglich der aktuellen Unternehmensorganisation und des Kontextes b. Wissensstand innerhalb des I&T-Managements bezüglich der Unternehmensziele und -ausrichtung c. Grad des Verständnisses der wichtigsten I&T-Anspruchsgruppen und ihrer detaillierten Anforderungen
Aktivitäten		Fähigkeitsstufe
1. Entwickeln und gewährleisten Sie ein Verständnis des externen Unternehmensumfeldes.		2
2. Entwickeln und gewährleisten Sie ein Verständnis der aktuellen Arbeitsweise, einschließlich des operativen Umfelds, der Unternehmensarchitektur (Geschäfts-, Informations-, Daten-, Anwendungs- und Technologiebereiche), der Unternehmenskultur und der aktuellen Herausforderungen.		
3. Entwickeln und gewährleisten Sie ein Verständnis der zukünftigen Unternehmensausrichtung, einschließlich Unternehmensstrategie, -ziele und -zielvorgaben. Erfassen Sie das Anspruchsniveau des Unternehmens in Bezug auf die Digitalisierung, die eine Reihe von zunehmend ehrgeizigeren Zielen umfassen kann, von der Kostensenkung, dem Ausbau der Kundenorientierung oder der schnelleren Markteinführung durch die Digitalisierung interner Abläufe bis hin zur Schaffung völlig neuer Einnahmequellen durch neue Geschäftsmodelle (z. B. Plattformgeschäft).		
4. Identifizieren Sie wichtige Anspruchsgruppen und verschaffen Sie sich Einblick in deren Anforderungen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		7. Strategy and Objective-Setting – Principle 6
Managementpraktik		Beispielmetrik
AP002.02 Beurteilen der aktuellen Befähigungen, der Leistung und der digitalen Reife des Unternehmens Beurteilen Sie die Leistung der derzeitigen I&T-Services und entwickeln Sie ein Verständnis für das aktuelle Geschäft und die I&T-Befähigungen (sowohl intern als auch extern). Bewerten Sie den aktuellen digitalen Reifegrad des Unternehmens und seine Bereitschaft für Veränderungen.		a. Anteil der Mitarbeiter, die mit ihren derzeitigen Befähigungen zufrieden sind b. Grad der Zufriedenheit der Geschäftsverantwortlichen mit den Investitionen in und der Nutzung der internen und externen Betriebsmittel zur Erfüllung der kritischen Erfolgsfaktoren
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie eine Ausgangsbasis bezüglich der aktuellen Geschäfts- und I&T-Befähigungen und -Services. Dies beinhaltet die Bewertung von extern erbrachten Services, die Governance der I&T und unternehmensweite I&T-bezogene Fähigkeiten und Kompetenzen.		2
2. Bewerten Sie den digitalen Reifegrad anhand verschiedener Dimensionen (z. B. Fähigkeit der Führungsebene zur Nutzung von Technologie, Grad des akzeptierten Technologierisikos, Innovationsansatz, Kultur und Wissensstand der Nutzer). Beurteilen Sie die Bereitschaft zur Veränderung.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		7. Strategy and Objective-Setting – Principle 6; 9. Review and Revision – Principle 15
Managementpraktik		Beispielmetrik
AP002.03 Festlegen der angestrebten digitalen Befähigungen Definieren Sie die angestrebten I&T-Produkte und Services sowie die erforderlichen Befähigungen auf der Grundlage des Verständnisses des Unternehmensumfeldes und dessen Ausrichtung. Berücksichtigen Sie Referenzstandards, bewährte Verfahren und validierte aufkommende Technologien.		a. Anteil der Unternehmenszielvorgaben, die von den I&T-Zielen/Zielvorgaben erfasst sind b. Anteil der I&T-Zielvorgaben, die die Unternehmensstrategie unterstützen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Fassen Sie das Umfeld und die Ausrichtung des Unternehmens zusammen und identifizieren Sie spezifische I&T-Aspekte der Unternehmensstrategie (z. B. Digitalisierung von Prozessen, Implementierung neuer Technologien, Unterstützung der Legacy-Architektur, Anwendung neuer digitaler Geschäftsmodelle, Entwicklung eines digitalen Produktportfolios usw.).	2
2. Definieren Sie übergeordnete I&T-Zielvorgaben/-Ziele und bestimmen Sie, inwieweit diese zu den Unternehmenszielvorgaben beitragen.	
3. Machen Sie detaillierte Angaben zu den I&T-Services und -Produkten, die erforderlich sind, um die Unternehmenszielvorgaben zu erreichen. Berücksichtigen Sie validierte, aufkommende Technologie- oder Innovationsideen, Referenzstandards, Geschäftsideen und I&T-Fähigkeiten von Konkurrenten, vergleichende Benchmarks bewährter Verfahren und die Bereitstellung aufkommender I&T-Services.	3
4. Bestimmen Sie I&T-Befähigungen, Methoden und organisatorische Ansätze, die zur Realisierung des definierten I&T-Produkt- und Serviceportfolios erforderlich sind. Erwägen Sie je nach Geschäftsanforderungen unterschiedliche Entwicklungsmethoden (Agile, Scrum, Wasserfall, bimodale IT). Überlegen Sie, wie jede Methode zur Verwirklichung der I&T-Zielvorgaben beitragen könnte.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP002.04 Durchführen einer GAP-Analyse Identifizieren Sie Lücken zwischen der derzeitigen und der angestrebten Umgebung und beschreiben Sie die wesentlichen Änderungen der Unternehmensarchitektur.	a. Anzahl der erforderlichen Änderungen mit bedeutenden Auswirkungen in den verschiedenen Bereichen der Unternehmensarchitektur b. Anzahl der signifikanten Lücken zwischen der derzeitigen Umgebung und bewährten Praktiken
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie alle Lücken und Änderungen, die erforderlich sind, um die angestrebte Umgebung zu realisieren.	3
2. Beschreiben Sie wesentlichen Änderungen der Unternehmensarchitektur (Geschäfts-, Informations-, Daten-, Anwendungs- und Technologiebereiche).	
3. Bestimmen Sie die wesentlichen Auswirkungen aller Lücken. Bewerten Sie die Auswirkungen potenzieller Änderungen auf die Geschäfts- und I&T-Betriebsmodelle, I&T-Forschungs- und Entwicklungsfähigkeiten und I&T Investitionsprogramme.	
4. Bestimmen Sie den Wert potenzieller Änderungen hinsichtlich der Geschäfts- und I&T-Befähigungen, der I&T-Services und der Unternehmensarchitektur, und überlegen Sie, welche Auswirkungen sich ergäben, wenn keine Änderungen vorgenommen werden würden.	4
5. Verfeinern Sie Ihre Definition der angestrebten Umgebung und erstellen Sie eine Wertaussage, aus der die Vorteile der angestrebten Umgebung hervorgehen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP002.05 Definieren des Strategieplans und der Roadmap Entwickeln Sie eine ganzheitliche digitale Strategie in Zusammenarbeit mit den relevanten Anspruchsgruppen und erarbeiten Sie eine Roadmap, die die zur Erreichung der Ziele und Zielvorgaben erforderlichen Schritte definiert. Stellen Sie sicher, dass der Schwerpunkt auf der Durchführung der Transformation liegt, indem ein Mitarbeiter benannt wird, der die digitale Transformation leitet und die Abstimmung zwischen Geschäft und I&T vorantreibt.	a. Grad der Unterstützung seitens der Anspruchsgruppen für den digitalen Transformationsplan b. Anteil der I&T-Strategieinitiativen, die sich selbst finanzieren (finanzieller Nutzen übersteigt die Kosten) c. Grad der Übereinstimmung zwischen Unternehmensstrategie und I&T-Strategie und -Zielvorgaben

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Initiativen, die für das Schließen der Lücken zwischen der derzeitigen und der angestrebten Umgebung erforderlich sind. Integrieren Sie die Initiativen in eine kohärente I&T-Strategie, die I&T mit allen Aspekten des Geschäfts in Einklang bringt.		3
2. Erstellen Sie eine detaillierte Roadmap, die die einzelnen Schritte definiert, die erforderlich sind, um die Ziele und Zielvorgaben der I&T-Strategie zu erreichen. Stellen Sie sicher, dass Maßnahmen zur Ausbildung von Mitarbeitern mit neuen Fähigkeiten, zur Unterstützung der Übernahme neuer Technologien, zur Förderung von Veränderungen in der gesamten Organisation usw. vorgesehen sind.		
3. Berücksichtigen Sie das externe Ökosystem (Partnerunternehmen, Lieferanten, Start-ups usw.) als Unterstützungsmöglichkeit bei der Umsetzung der Roadmap.		
4. Gruppieren Sie die Aktivitäten in Form von Programmen und/oder Projekten mit einem klaren Ziel oder Ergebnis. Legen Sie für jedes Projekt den grundsätzlichen Ressourcenbedarf, den Zeitplan, das Investitions-/operative Budget, das Risiko, die Auswirkungen von Änderungen usw. fest.		
5. Bestimmen Sie Abhängigkeiten, Überschneidungen, Synergien und Auswirkungen zwischen den Projekten und setzen Sie Prioritäten.		
6. Finalisieren Sie die Roadmap und geben Sie die Zeitplanung und die Abhängigkeiten zwischen den Projekten an.		
7. Stellen Sie sicher, dass der Schwerpunkt auf der Umsetzung der Transformation liegt. Bestimmen Sie einen Champion für die digitale Transformation und die Abstimmung zwischen Geschäft und I&T (Chief Digital Officer (CDO) oder eine andere übliche C-Suite-Rolle).		
8. Sichern Sie sich die Unterstützung der Anspruchsgruppen und lassen Sie den Plan formell genehmigen.		
9. Setzen Sie die Zielvorgaben in messbare Ergebnisse um, die mittels Metriken (was) und Zielen (wie viel) dargestellt werden. Stellen Sie sicher, dass die Ergebnisse und Kennzahlen den Unternehmensvorteilen zugeordnet werden können.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SG2.1 Information Security Strategy
ITIL V3, 2011		Service Strategy, 4.1 Strategy management for IT services
Managementpraktik		Beispielmetrik
APO02.06 Kommunizieren der I&T-Strategie und -Ausrichtung. Sorgen Sie dafür, dass die Geschäfts- und I&T-Zielvorgaben und die jeweilige Ausrichtung, so wie sie in der I&T-Strategie erfasst sind, bekannt sind und verstanden werden, indem Sie diese gegenüber den jeweiligen Anspruchsgruppen und Anwendern im Unternehmen kommunizieren.		a. Häufigkeit, in der Aktualisierungen am Kommunikationsplan der I&T-Strategie vorgenommen wurden b. Anteil der Anspruchsgruppen, die sich der I&T-Strategie und -ausrichtung bewusst sind
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie einen Kommunikationsplan, aus dem die erforderlichen Inhalte, die Zielgruppen, die Kommunikationsmechanismen und -kanäle sowie die Zeitpläne hervorgehen.		3
2. Erarbeiten Sie ein Kommunikationspaket, das den Plan effektiv abbildet und nutzen Sie dabei die verfügbaren Medien und Technologien.		
3. Entwickeln und pflegen Sie ein Netzwerk für die Befürwortung, Unterstützung und das Vorantreiben der I&T-Strategie.		
4. Holen Sie Rückmeldungen ein und aktualisieren Sie ggf. den Kommunikationsplan und dessen Bereitstellung.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

B. Komponente: Organisationsstrukturen													
Wichtige Managementpraktik:													
AP002.01 Verstehen von Unternehmenskontext und -ausrichtung		A	R	R					R	R	R	R	R
AP002.02 Beurteilen der aktuellen Befähigungen, der Leistung und der digitalen Reife des Unternehmens		A	R	R					R		R	R	R
AP002.03 Festlegen der angestrebten digitalen Befähigungen			R	R	A		R		R	R	R	R	R
AP002.04 Durchführen einer GAP-Analyse			R	R	R	A	R		R		R	R	R
AP002.05 Definieren des Strategieplans und der Roadmap			R	R	R	A	R		R		R	R	R
AP002.06 Kommunizieren der I&T-Strategie und -Ausrichtung	R	R	R	R	A								
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)													
Detaillierte Referenzen													
ISO/IEC 38502:2017(E)													
5.4 Responsibilities of managers													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
AP002.01 Verstehen von Unternehmenskontext und -ausrichtung	AP004.02	Innovationschancen in Verbindung mit Geschäftstreibern	Quellen und Prioritäten für Veränderungen	Intern
	EDM04.01	Leitprinzipien für die Zuweisung von Ressourcen und Fähigkeiten		
	Außerhalb von COBIT	Unternehmensstrategie und Analyse der Stärken, Schwächen, Chancen und Risiken (SWOT)		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
APO02.02 Beurteilen der aktuellen Befähigungen, der Leistung und der digitalen Reife des Unternehmens	APO06.05	Möglichkeiten zur Kostenoptimierung	Lücken und Risiken im Zusammenhang mit den derzeitigen Fähigkeiten	APO12.01
	APO08.05	Definition potenzieller Verbesserungsprojekte	SWOT-Analyse der Fähigkeiten	Intern
	APO09.01	Identifizierte Lücken bei den IT-Services für das Unternehmen	Ausgangsbasis derzeitiger Fähigkeiten	Intern
	APO09.04	Verbesserungspläne und Abhilfemaßnahmen		
	APO12.01	Aufkommende Risiko- themen und -faktoren		
	APO12.02	Ergebnisse der Risiko- analyse		
	APO12.03	Aggregiertes Risiko- profil, einschließlich Status der Risiko- managementaktivitäten		
	APO12.05	Projektvorschläge zur Risikominderung		
	BAI04.03	• Priorisierte Verbesse- rungen • Leistungs- und Kapazi- tätspläne		
	BAI04.05	Abhilfemaßnahmen		
	BAI09.01	Ergebnisse der Zweck- mäßigkeitsüberprü- fungen		
	BAI09.04	• Ergebnisse der Prüfungen zur Kostenoptimierung • Möglichkeiten zur Senkung der Betriebs- mittelkosten oder zur Wertsteigerung		
	EDM04.03	Rückmeldung zur Zutei- lung und Effektivität von Ressourcen und Fähigkeiten		
APO02.03 Festlegen der angestrebten digitalen Befähigungen	APO04.05	• Ergebnisse und Empfehlungen von Proof-of-Concept- Initiativen • Analyse der abge- lehnten Initiativen	Vorgeschlagene Ände- rungen der Unterneh- mensarchitektur	APO03.03
			Erforderliche Geschäfts- und IT-Befähigungen	Intern
			Übergeordnete I&T-bezo- gene Ziele	Intern

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
APO02.04 Durchführen einer GAP-Analyse	APO04.06	Bewertung innovativer Ansätze	Lücken und erforderliche Änderungen zur Erreichung der Zielbefähigung	APO01.03, APO13.02, BAI03.11, EDM04.01
	APO05.01	Erwartungen an die Investitionsrendite	Wert-Nutzen-Feststellung für die angestrebte Umgebung	BAI03.11
	BAI01.05	Ergebnisse der Überwachung der Programmzielerreichung		
	BAI01.06	Stage-Gate-Review-Ergebnisse		
	BAI11.09	Überprüfungsergebnisse nach der Implementierung		
	EDM02.02	Bewertung der strategischen Ausrichtung		
APO02.05 Definieren des Strategieplans und der Roadmap	Von	Beschreibung	Beschreibung	Für
	APO03.01	• Definierter Umfang der Architektur • Business Case und Mehrwert des Architekturkonzepts	I&T-Strategie und -Zielvorgaben	Alle APO, BAI, DSS, MEA
	APO03.02	Informationsarchitekturmodell	Strategische Roadmap	APO01.01, APO03.01, APO08.01, EDM02.01, EDM02.02
	APO03.03	Übergangsarchitekturen	Definition von strategischen Initiativen	EDM02.01
	APO05.01	Finanzierungsoptionen	Initiativen zur Risikobewertung	EDM02.01, APO12.01
	APO06.02	Budgetzuweisungen		
	APO06.03	I&T-Budget		
	BAI09.05	Maßnahmenplan zur Anpassung der Lizenzanzahl und -zuteilung		
	DSS04.02	Genehmigte strategische Optionen		
	EDM02.01	Feedback zu Strategie und Zielen		
	EDM04.01	Genehmigter Ressourcenplan		
	EDM04.03	Abhilfemaßnahmen zur Behebung von Abweichungen im Ressourcenmanagement		
	APO02.06 Kommunizieren der I&T-Strategie und -Ausrichtung.	EDM04.02	Kommunikation von Beschaffungsstrategien	Kommunikationspaket
			Kommunikationsplan	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
ITIL V3, 2011		Service strategy, 3.9 Service strategy inputs and outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Entwicklung von Businessplänen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.3. Business Plan Development
Überwachung von aufkommenden Technologien	Skills Framework for the Information Age V6, 2015	EMRG
I&T-Strategie und -Planung	Skills Framework for the Information Age V6, 2015	ITSP
Ausrichtung der Strategie	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.1. IS and Business Strategy Alignment

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Prinzipien der IT-Service-Strategie	Einzelheiten finden Sie in den zugehörigen Leitfäden.	ITIL V3, 2011	Service Strategy, 3. Service strategy principles
Richtlinie zu I&T-Strategie und -Prinzipien	Bietet einen ganzheitlichen Überblick über das aktuelle geschäftliche und I&T-Umfeld, die strategische Ausrichtung und die Initiativen, die für den Übergang in das angestrebte künftige Umfeld erforderlich sind. Stellt sicher, dass die Geschäfts- und I&T-Strategie den angestrebten Grad der Digitalisierung widerspiegeln.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur und zugrunde liegende Werte, die zur Geschäftsstrategie passen (d. h. kundenorientiert, innovationsgetrieben, produktbasiert). Finden Sie Wege, um Prozesse zu beschleunigen und eine unterstützende Kultur sowie Verhaltensweisen einzuführen, die ein schnelleres Tempo ermöglichen. Dies könnte damit beginnen, grundlegende Gewohnheiten zu ändern, z. B. häufigere Strategieführungssitzungen abzuhalten oder bestimmte Aktivitäten zu automatisieren. Im aktuellen Kontext von digitalen Geschäftsmodellen, Ökosystemen und Disruption ist es für viele Organisationen von entscheidender Bedeutung, der digitalen Transformation Priorität in der Strategie einzuräumen. Bauen Sie eine Kultur auf, die den Status quo in Frage stellt und neue Arbeitsweisen erprobt (z. B. Investitionen in Automatisierung, um schnell auf Kundenwünsche reagieren zu können, Entwicklung umfassender Berichts- und Analysefunktionen zur Interpretation von Kundenbedürfnissen, Aufbau innovativer Schnittstellen zur Erfassung von Kundendaten, Schaffung von Mechanismen zur Bereitstellung von Inhalten und Angeboten über alle relevanten Kanäle).	The Scaled Agile Framework for Lean Enterprises	Konfigurierbares Rahmenwerk, das Organisationen hilft, neue Produkte und Lösungen mit kürzester Vorlaufzeit zu liefern (alle Kapitel)

G. Komponente: Services, Infrastruktur und Anwendungen
• Kundenanalyse • Branchenbenchmarks • System zur Leistungsmessung (z. B. Balanced Scorecard, Werkzeuge zum Management der Fähigkeiten) • Werkzeuge und Services zur Beobachtung der Technologieentwicklung

Domäne: Anpassen, Planen und Organisieren Managementziel: APO03 – Unternehmensarchitektur ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Einrichtung einer allgemeinen Architektur, die aus den Schichten Geschäftsprozesse, Informationen, Daten, Anwendungen und Technologie besteht. Erstellung von wichtigen Modellen und Praktiken in Übereinstimmung mit der Unternehmens- und I&T-Strategie, die die Ausgangs- und Zielarchitektur beschreiben. Definition der Anforderungen für Taxonomie, Standards, Richtlinien, Verfahren, Vorlagen und Werkzeuge und Herstellen einer Verknüpfung zwischen diesen Komponenten. Optimierung der Ausrichtung, Steigerung der Agilität, Verbesserung der Informationsqualität und Generierung potenzieller Kosteneinsparungen durch Initiativen wie die Wiederverwendung von Bausteinkomponenten.		
Zweck		
Darstellung der unterschiedlichen Bausteine, aus denen das Unternehmen besteht, der Beziehungen der Bausteine untereinander, sowie der Prinzipien, auf denen ihr Design und ihre Weiterentwicklung im Laufe der Zeit basiert und die eine standardisierte, flexible und effiziente Erfüllung operativer und strategischer Zielvorgaben ermöglicht.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG05 Kundenorientierte Servicekultur • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG08 Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Dienstleistungen und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG05 a. Anzahl der Unterbrechungen bei Kundenservices b. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die Kundenservices den vereinbarten Standards entsprechen c. Anzahl von Kundenbeschwerden d. Trend der Umfrageergebnisse zur Kundenzufriedenheit		AG08 a. Dauer der Ausführung von Geschäftsservices oder -prozessen b. Anzahl der durch I&T ermöglichten Geschäftsprogramme, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder zusätzliche Kosten verursacht haben c. Anzahl der Geschäftsprozessänderungen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder überarbeitet werden mussten d. Anzahl von Anwendungen oder kritischen Infrastrukturen, die isoliert arbeiten und nicht integriert sind
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
AP003.01 Entwickeln einer Vision der Unternehmensarchitektur Die Architekturvision bietet einen ersten Überblick der Ausgangs- und Zielarchitektur und umfasst die Domänen Geschäft, Informationen, Daten, Anwendungen und Technologie. Die Architekturvision gibt dem Sponsor ein wichtiges Instrument an die Hand, um den Anspruchsgruppen innerhalb des Unternehmens die Vorteile der vorgeschlagenen Befähigungen nahe zu bringen. Die Architekturvision beschreibt, wie es mit neuen Befähigungen (im Einklang mit der I&T-Strategie und den Zielvorgaben) gelingt, die Ziele und strategischen Zielvorgaben des Unternehmens zu erfüllen und bei der Implementierung die Bedenken der Anspruchsgruppen zu berücksichtigen.	a. Umfang der Kundenrückmeldungen zur Architektur b. Grad, in dem die Ausgangs- und Zielarchitektur die Domänen Geschäft, Informationen, Daten, Anwendungen und Technologie abdecken sowie Häufigkeit der Aktualisierung	
Aktivitäten	Fähigkeitsstufe	
1. Identifizieren Sie die wichtigsten Anspruchsgruppen und ihre Anliegen/Zielvorgaben. Definieren Sie die wichtigsten Unternehmensanforderungen, die es zu erfüllen gilt, sowie die Architekturansichten, die entwickelt werden müssen, um den Anforderungen der Anspruchsgruppen gerecht zu werden.	2	
2. Identifizieren Sie Unternehmensziele und strategische Treiber. Definieren Sie die Einschränkungen, die berücksichtigt werden müssen, einschließlich unternehmensweiter und projektspezifischer Einschränkungen (z. B. Zeitbedarf, Zeitplan, Ressourcen usw.).		
3. Richten Sie die Architekturzielvorgaben an den strategischen Programmprioritäten aus.		
4. Ermitteln Sie Unternehmensbefähigungen und -ziele, und identifizieren Sie Möglichkeiten zur Realisierung dieser Ziele.		
5. Beurteilen Sie die Änderungsbereitschaft des Unternehmens.		
6. Definieren Sie den Umfang der Ausgangs- und Zielarchitektur. Nennen Sie sowohl Elemente, die im Umfang enthalten sind, als auch solche, die nicht enthalten sind. (Ausgangs- und Zielarchitektur müssen dabei nicht im gleichen Detailgrad beschrieben werden)		
7. Bestimmen Sie die aktuellen strategischen Ziele und Zielvorgaben des Unternehmens. Stellen Sie anhand des strategischen Planungsprozesses sicher, dass bei der Entwicklung des Strategieplans I&T-bezogene Chancen der Unternehmensarchitektur genutzt werden.		
8. Erstellen Sie, basierend auf den Anmerkungen der Anspruchsgruppen, den Anforderungen an die Unternehmensbefähigungen, dem Umfang sowie den Einschränkungen und den Prinzipien die Architekturvision (d. h. einen allgemeinen Überblick über die Ausgangs- und Zielarchitektur).	3	
9. Erarbeiten Sie Architektur- und Unternehmensprinzipien und überprüfen Sie diese. Stellen Sie sicher, dass alle bestehenden Definitionen aktuell sind. Beseitigen Sie eventuelle Unklarheiten.		
10. Identifizieren Sie das Änderungsrisiko für das Unternehmen, das mit der Architekturvision verbunden ist. Beurteilen Sie das anfängliche Risikoniveau (z. B. kritisch, marginal oder vernachlässigbar). Entwickeln Sie für jedes erhebliche Risiko eine Minderungsstrategie.		
11. Entwickeln Sie einen Business Case für das Unternehmensarchitekturkonzept, skizzieren Sie Pläne und eine Architekturleistungsbeschreibung. Sichern Sie sich die Genehmigung für die Initiierung eines an der Unternehmensstrategie ausgerichteten und darin integrierten Projekts.	4	
12. Definieren Sie das Wertversprechen, die Ziele und die Metriken für die Zielarchitektur.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.15 Program management (PM-7)	
The Open Group Standard TOGAF version 9.2, 2018	6. Phase A: Architecture Vision	
Managementpraktik	Beispielmetrik	
AP003.02 Definieren der Referenzarchitektur Die Referenzarchitektur beschreibt die derzeitige und die angestrebte Architektur für die Domänen Geschäft, Informationen, Daten, Anwendungen und Technologie.	a. Datum der letzten Aktualisierung der Domänen oder Architekturen b. Anzahl der beantragten und bewilligten Ausnahmen von Architekturstandards und Referenzen	

A. Komponente: Prozess (Forts.)		
Aktivitäten	Fähigkeitsstufe	
1. Pflegen Sie ein Architektur-Repository, in dem Standards, wiederverwendbare Komponenten, Modellierungsartefakte, Beziehungen, Abhängigkeiten und Ansichten enthalten sind, um eine einheitliche Struktur und Wartung zu ermöglichen.	3	
2. Wählen Sie Referenzstandpunkte aus dem Architektur-Repository aus, die es dem Architekten ermöglichen, darzustellen, inwiefern den Interessen der Anspruchsgruppen in der Architektur entsprochen wird.		
3. Wählen Sie für jeden Standpunkt die Modelle aus, die zur Unterstützung der jeweils erforderlichen Ansicht benötigt werden. Verwenden Sie dazu ausgewählte Werkzeuge oder Methoden und wählen Sie den geeigneten Detailgrad.		
4. Entwickeln Sie Domänenbeschreibungen für die Ausgangsarchitektur, und wählen Sie Umfang und Detailgrad so aus, dass die Zielarchitektur ausreichend erläutert wird. Identifizieren Sie, soweit möglich, relevante Architekturbausteine aus dem Architektur-Repository.		
5. Halten Sie ein Prozessarchitekturmodell vor, das Bestandteil der Domänenbeschreibungen der Ausgangs- und der Zielarchitektur ist. Standardisieren Sie die Beschreibung und Dokumentation von Prozessen. Definieren Sie die Rollen und Zuständigkeiten der Prozessentscheidungsträger, des Prozessverantwortlichen, der Prozessanwender, des Prozessteams und sonstiger einzubeziehender Prozessanspruchsgruppen.		
6. Halten Sie ein Informationsarchitekturmodell vor, das Bestandteil der Domänenbeschreibungen der Ausgangs- und der Zielarchitektur ist. Dieses sollte mit der Unternehmensstrategie vereinbar sein, um eine optimale Erfassung, Speicherung und Nutzung von Daten zur Unterstützung der Entscheidungsfindung zu ermöglichen.		
7. Überprüfen Sie die Architekturmodelle auf interne Konsistenz und Genauigkeit. Führen Sie eine GAP-Analyse der Ausgangs- und der Zielarchitektur durch. Priorisieren Sie eventuelle Lücken und definieren Sie neue oder modifizierte Komponenten, die für die Zielarchitektur entwickelt werden müssen. Beseitigen Sie Inkompatibilitäten, Inkonsistenzen oder Konflikte innerhalb der Zielarchitektur.		
8. Führen Sie eine formelle Anspruchsgruppenüberprüfung durch, indem Sie die vorgeschlagene Architektur mit der ursprünglichen Motivation für die Initiierung des Architekturprojekts und der Leistungsbeschreibung für die Architektur vergleichen.		
9. Bringen Sie die Architekturdomänen Geschäft, Informationen, Daten, Anwendungen und Technologie zum Abschluss. Erstellen Sie ein Dokument, in dem die Architektur definiert wird.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
CMMI Data Management Maturity Model, 2014	Platform and Architecture – Architectural Approach; Platform and Architecture – Data Integration	
ITIL V3, 2011	Service Strategy, 5.4 IT service strategy and enterprise architecture	
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.1 Preparation (Task 9):	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.5 Configuration management (CM-8)	
The Open Group Standard TOGAF version 9.2, 2018	7. Phase B: Business Architecture; 8. Phase C: Information Systems Architectures; 9. Phase C: Information Systems Architectures Data Architecture; 10. Phase C: Information Systems Architectures Application Architecture; 11. Phase D: Technology Architecture	
Managementpraktik	Beispielmetrik	
AP003.03 Auswählen von Handlungsalternativen und Lösungen Analysieren Sie kritisch die Lücken zwischen der Ausgangs- und Zielarchitektur aus geschäftlicher und technischer Perspektive und gruppieren Sie diese logisch zu Projektarbeitspaketen. Betten Sie das Projekt in zugehörige, durch I&T ermöglichte Investitionsprogramme ein, um sicherzustellen, dass die architekturbezogenen Initiativen mit diesen abgestimmt sind und diese Initiativen als Teil der übergreifenden Änderungen des Unternehmens ermöglicht werden. Beziehen Sie dabei wichtige geschäftliche und IT-Anspruchsgruppen ein, um die Transformationsbereitschaft des Unternehmens zu beurteilen und identifizieren Sie Chancen, Lösungen sowie sämtliche Implementierungshemmnisse.	a. Anzahl der identifizierten Lücken in den Modellen in den Architekturdomänen Geschäft, Informationen, Daten, Anwendungen und Technologie b. Anteil der wichtigsten Anspruchsgruppen des Unternehmens aus dem geschäftlichen und IT-Bereich zur Bewertung der Transformationsbereitschaft des Unternehmens und zur Ermittlung von Möglichkeiten und Lösungen sowie allen Implementierungsbeschränkungen	

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Bestimmen und überprüfen Sie wichtige Attribute für die Veränderung des Unternehmens. Berücksichtigen Sie die Unternehmenskultur und deren Auswirkungen auf die Implementierung der Architektur und die Befähigungen des Unternehmens in Bezug auf den Übergang.		3
2. Identifizieren Sie etwaige Treiber im Unternehmen, die die Abfolge der Implementierung einschränken würden. Überprüfen Sie ebenfalls die Strategie- und Geschäftspläne des Unternehmens und der Geschäftszweige. Bestimmen Sie den derzeitigen Reifegrad der Unternehmensarchitektur.		
3. Überprüfen und konsolidieren Sie die Ergebnisse der GAP-Analyse zwischen Ausgangs- und Zielarchitektur. Beurteilen Sie die Auswirkungen im Hinblick auf potenzielle Lösungen, Chancen, Interdependenzen und Ausrichtung an aktuellen, durch I&T ermöglichten Programmen.		
4. Beurteilen Sie Anforderungen, Lücken, Lösungen und weitere Faktoren, um einen Mindestumfang funktionaler Anforderungen zu identifizieren, deren Einbindung in Arbeitspakete eine effizientere und effektivere Implementierung der Zielarchitektur bewirken würde.		
5. Gleichen Sie die konsolidierten Anforderungen mit potenziellen Lösungen ab.		
6. Detaillieren Sie die anfänglichen Abhängigkeiten und identifizieren Sie Einschränkungen für den Implementierungs- und den Migrationsplan. Erstellen Sie einen Abhängigkeitsanalysebericht.		
7. Überprüfen Sie die Bereitschaft des Unternehmens für die Unternehmenstransformation und das damit verbundene Risiko.		
8. Formulieren Sie eine globale Implementierungs- und Migrationsstrategie. Implementieren Sie die Zielarchitektur (und eventuelle Übergangsarchitekturen) entsprechend der Unternehmensstrategie, den Zielvorgaben und der Zeitplanung.		
9. Identifizieren und gruppieren Sie wichtige Arbeitspakete in Form einer schlüssigen Kombination aus Programmen und Projekten und unter Berücksichtigung der Ausrichtung und des Ansatzes für die Umsetzung der Unternehmensstrategie.		
10. Entwickeln Sie ggf. Übergangsarchitekturen für Situationen, bei denen der Umfang aufgrund der durch die Zielarchitektur erforderlichen Änderungen einen mehrstufigen Ansatz erfordert.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Platform and Architecture – Architectural Approach; Platform and Architecture – Data Integration
The Open Group Standard TOGAF version 9.2, 2018		12. Phase E: Opportunities and Solutions
Managementpraktik		Beispielmetrik
APO03.04 Festlegen der Architekturimplementierung Erstellen Sie einen gangbaren Implementierungs- und Migrationsplan, der an den Programm- und Projektportfolios ausgerichtet ist. Stellen Sie sicher, dass der Plan sorgfältig koordiniert und geeignet ist, die Bereitstellung eines Wertbeitrages sicherzustellen und zu gewährleisten, dass die erforderlichen Ressourcen für die Ausführung der damit verbundenen Tätigkeiten verfügbar sind		a. Klare Definition der Anforderungen an die Governance der Architekturimplementierung b. Anteil der Anspruchsgruppen, die mit der Architekturimplementierung und -migration vertraut sind
Aktivitäten		Fähigkeitsstufe
1. Erarbeiten Sie im Rahmen der Programm- und Projektplanung, was im Implementierungs- und Migrationsplan enthalten sein sollte. Stellen Sie sicher, dass der Plan die Anforderungen der jeweiligen Entscheidungsträger berücksichtigt.		3
2. Prüfen Sie die Stufen und Phasen der Übergangsarchitektur. Aktualisieren Sie das Architekturdefinitionsdokument.		
3. Definieren und Vervollständigen Sie den Implementierungs- und Migrationsplan für die Architektur und berücksichtigen Sie dabei einschlägige Governance-Anforderungen. Betten Sie den Plan, die Aktivitäten und Abhängigkeiten in die Programm- und Projektplanung ein.		
4. Kommunizieren Sie die definierte Roadmap für die Architektur an die relevanten Anspruchsgruppen. Informieren Sie die Anspruchsgruppen über die Definition der Zielarchitektur, die Architekturrichtlinien und -prinzipien, das Dienstleistungsportfolio usw.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Platform and Architecture – Architectural Approach; Platform and Architecture – Data Integration
The Open Group Standard TOGAF version 9.2, 2018		13. Phase F: Migration Planning

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmetrik
AP003.05 Bereitstellen von Unternehmensarchitekturservices Stellen Sie Unternehmensarchitekturservices innerhalb des Unternehmens bereit, die die Steuerung und Überwachung von Implementierungsprojekten, die Formalisierung von Methoden zum Umgang mit Architekturverträgen, die Messung und Kommunikation des Architekturmehrwerts und die Überwachung der Compliance umfassen.	a. Umfang der Kundenrückmeldungen zu den Architekturservices b. Anteil der Projekte, die das Rahmenwerk und die Methodik zur Wiederverwendung von definierten Komponenten nutzen c. Anteil der Projekte, die Unternehmensarchitekturservices nutzen d. Realisierte Projektvorteile, die auf die Architektur zurückgeführt werden können (z. B. Kostenreduzierung durch Wiederverwendung)
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie Umfang und Prioritäten und begleiten Sie die Entwicklung und Bereitstellung von Lösungen (z. B. durch die Nutzung einer serviceorientierten Architektur).	3
2. Managen Sie die Anforderungen an die Unternehmensarchitektur und unterstützen Sie die Geschäftsbereiche und IT mit Beratung und Fachwissen zu Architekturprinzipien, -modellen und -bausteinen. Gewährleisten Sie, dass neue Implementierungen (wie auch Änderungen an der aktuellen Architektur) mit den Prinzipien und Anforderungen der Unternehmensarchitektur übereinstimmen.	
3. Managen Sie das Portfolio der Unternehmensarchitekturservices, um die Vereinbarkeit mit den strategischen Zielvorgaben und der Lösungsentwicklung sicherzustellen.	
4. Identifizieren Sie die Prioritäten der Unternehmensarchitektur. Richten Sie die Prioritäten an den Werttreibern aus. Definieren und erfassen Sie Wertmetriken und ermitteln und kommunizieren Sie den Wert der Unternehmensarchitektur.	4
5. Richten Sie ein Technologieforum ein, um Leitlinien für die Architektur und nützliche Hinweise für Projekte bereitzustellen und die Auswahl von Technologien zu unterstützen. Überprüfen Sie die Compliance mit Standards und Leitlinien sowie die Compliance mit externen Anforderungen und deren geschäftliche Relevanz.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Platform and Architecture – Architectural Standards
ITIL V3, 2011	Service Design, 3.9 Service Oriented Architecture
The Open Group Standard TOGAF Version 9.2, 2018	14. Phase G: Implementation Governance; 15. Phase H: Architecture Change Management

B. Komponente: Organisationsstrukturen									
Wichtige Managementpraktik:	Chief Operating Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Architekturausschuss	Datenmanagement	Chefarchitekt	
AP003.01 Entwickeln einer Vision der Unternehmensarchitektur		R	R	R	R	A	R	R	
AP003.02 Definieren der Referenzarchitektur		R	R	R	R	A	R	R	
AP003.03 Auswählen von Handlungsalternativen und Lösungen		R	R	R	R	A	R	R	
AP003.04 Festlegen der Architekturimplementierung	R	R	R	R	R	A	R	R	
AP003.05 Bereitstellen von Unternehmensarchitekturservices	R	R	R	R	R	A			R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen								
The Open Group Standard TOGAF Version 9.2, 2018	41. Architecture Board								

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO03.01 Entwickeln einer Vision der Unternehmensarchitektur	Von	Beschreibung	Beschreibung	Für
	APO02.05	Strategische Roadmap	Definierter Umfang der Architektur	APO02.05
	EDM04.01	Leitprinzipien für die Unternehmensarchitektur	Architekturkonzept Business Case und Wertversprechen	APO02.05, APO05.02
	Außerhalb von COBIT	Unternehmensstrategie	Architekturprinzipien	BAI02.01, BAI03.01, BAI03.02
APO03.02 Definieren der Referenzarchitektur	APO01.04	- Definition von Organisationsstruktur und Funktionen - Betriebsrichtlinien für Unternehmen	Prozessarchitekturmodell	APO01.04
	APO01.06	- Bewertung von Optionen für die IT-Organisation - Definierte operative Eingliederung der IT-Funktion	Informationsarchitekturmodell	APO02.05, APO14.03, BAI02.01, BAI03.02, DSS05.03, DSS05.04, DSS05.06
Managementpraktik	Inputs		Outputs	
APO03.02 Definieren der Referenzarchitektur (Forts.)	Von	Beschreibung	Beschreibung	Für
	APO01.07	Richtlinien zur Datenklassifizierung	Ausgangs-Domänenbeschreibungen und Architekturdefinition	APO13.02, BAI02.01, BAI03.01, BAI03.02, BAI03.12
	APO14.01	Strategie zum Datenmanagement		
	APO14.03	Metadaten-Dokumentation		
	Außerhalb von COBIT	Unternehmensstrategie		
APO03.03 Auswählen von Handlungsalternativen und Lösungen	APO02.03	Vorgeschlagene Änderungen der Unternehmensarchitektur	Übergangsarchitekturen	APO02.05
	Außerhalb von COBIT	- Treiber im Unternehmen - Unternehmensstrategien		
APO03.04 Festlegen der Architekturimplementierung			Beschreibung der Implementierungsphase	BAI01.01, BAI01.02, BAI11.01
			Architektur-Governance-Anforderungen	BAI01.01, BAI11.01
			Ressourcenanforderungen	BAI01.02
APO03.05 Bereitstellen von Unternehmensarchitectur-services			Anleitung zur Lösungsentwicklung	BAI02.01, BAI02.02, BAI03.02, BAI03.12

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017	3.1 Preparation (Task 9): Inputs und Outputs
The Open Group Standard TOGAF Version 9.2, 2018	6. Phase A: Architecture Vision Inputs and Outputs; 7. Phase B: Business Architecture: Inputs and Outputs; 9. Phase C: Information Systems Architectures Data Architecture: Inputs and Outputs; 10. Information Systems Architectures Application Architecture: Inputs and Outputs; 11. Phase D: Technology Architecture Inputs and Outputs; 12. Phase E: Opportunities and Solutions: Inputs and Outputs; 13. Phase F: Migration Planning Inputs and Outputs; 14. Phase G: Implementation Governance: Inputs and Outputs; 15. Phase H: Architecture Change Management Inputs und Outputs

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Architekturkonzept	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.5. Architecture Design
Datenanalyse	Skills Framework for the Information Age V6, 2015	DTAN
Unternehmens- und Geschäftsarchitektur	Skills Framework for the Information Age V6, 2015	STPL
Produkt-/Serviceplanung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.4. Product/Service Planning
Lösungsarchitektur	Skills Framework for the Information Age V6, 2015	ARCH

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Architekturprinzipien	Definiert allgemeine Prinzipien zur Erstellung von Regeln und Leitlinien bezüglich des 20. Architekturprinzips für Architekturprozesse, -verfahren, -schichten und die allgemeine Nutzung und Verknüpfung von I&T-Ressourcen und -Betriebsmitteln. Benennt Architekturprinzipien zur Verbesserung der Entscheidungsfindung. Gewährleistet die Anpassung der derzeitigen und der Zielarchitektur an die Unternehmensziele und -strategie.	The Open Group Standard TOGAF Version 9.2, 2018	20. Architecture Principles

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Stellen Sie eine Umgebung her, in der sich das Management der Architektur Anforderungen in Bezug auf die Geschäftsziele und -vorgaben bewusst ist. Fördern Sie eine effektive praktische Anwendung der Unternehmensarchitektur in der gesamten Organisation (nicht nur von Unternehmensarchitekten). Stellen Sie einen ganzheitlichen Ansatz sicher, der die Komponenten nahtloser miteinander verbindet (z. B. durch Abkehr von dedizierten Teams von Anwendungsspezialisten).		

G. Komponente: Services, Infrastruktur und Anwendungen

Architektur-Repository

Domäne: Anpassen, Planen und Organisieren Managementziel: APO04 – Innovation ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Verankerung von I&T und den zugehörigen Servicetrends im Bewusstsein und Beobachtung aufkommender Technologietrends. Proaktives identifizieren von Innovationsmöglichkeiten und Planung, wie man von Innovationen in Bezug auf die Geschäftsanforderungen und die definierte I&T-Strategie profitieren kann. Analyse der Möglichkeiten für Innovationen oder Verbesserungen des Geschäfts durch aufkommende Technologien, Services oder I&T, sowie durch bestehende, etablierte Technologien oder Innovationen im Bereich der Geschäfts- und IT-Prozesse. Einflussnahme auf die strategische Planung und Entscheidungen in Verbindung mit der Unternehmensarchitektur.		
Zweck		
Realisierung von Wettbewerbsvorteilen, Geschäftsinnovation, verbessertem Kundenerlebnis und verbesserter operativer Effektivität und Effizienz durch die Nutzung von I&T-Entwicklungen und aufkommenden Technologien.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG13 Produkt- und Geschäftsinnovation		• AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG13 Wissen, Know-how und Initiativen für geschäftliche Innovationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Dienstleistungen und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG13 a. Grad des Bewusstseins und Verständnisses für geschäftliche Innovationsmöglichkeiten b. Zufriedenheit der Anspruchsgruppen mit dem Grad der Produkt- und Innovationskompetenz und der Entwicklung von neuen Ideen c. Anzahl der genehmigten Produkt- und Serviceinitiativen, die aus innovativen Ideen resultieren		AG13 a. Grad des Bewusstseins von Führungskräften und des Verständnisses für Innovationsmöglichkeiten im Bereich I&T b. Anzahl der genehmigten Initiativen, die aus innovativen I&T-Ideen resultieren c. Anzahl der anerkannten/ausgezeichneten Innovations-Champions

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
APO04.01 Schaffen einer innovationsfördernden Umgebung Schaffen Sie eine innovationsfördernde Umgebung, und berücksichtigen Sie dabei Aspekte wie Kultur, Belohnung, Zusammenarbeit, Technologieforen sowie Mechanismen, die geeignet sind, Ideen von Mitarbeitern zu fördern und zu sammeln.		a. Wahrnehmung und Rückmeldungen der Anspruchsgruppen im Unternehmen zu I&T-Innovationen b. Einbeziehung von Zielen die sich auf Innovationen oder aufkommende Technologien beziehen in die Leistungsziele der entsprechenden Mitarbeiter
Aktivitäten		Fähigkeitsstufe
1. Erstellen Sie einen Innovationsplan, der Aufschluss über die Risikobereitschaft, das geplante Budget für Innovationsinitiativen und über Innovationszielvorgaben gibt.		2
2. Stellen Sie eine Infrastruktur bereit, die eine Governance-Komponente für Innovation sein kann (z. B. Kollaborationswerkzeuge zur Verbesserung der Zusammenarbeit zwischen unterschiedlichen Standorten und/oder Bereichen).		
3. Richten Sie ein Programm ein, das es Mitarbeitern ermöglicht, innovative Ideen einzubringen, sowie eine passende Entscheidungsstruktur zur Beurteilung und Weiterentwicklung dieser Ideen.		3
4. Fördern Sie innovative Ideen von Kunden, Lieferanten und Geschäftspartnern.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
AP004.02 Sicherstellen der Kenntnis des Unternehmensumfeldes Ermitteln Sie bei den jeweiligen Anspruchsgruppen, welchen Herausforderungen sie gegenüberstehen. Sorgen Sie dafür, dass jederzeit adäquate Kenntnisse zur Unternehmensstrategie, zum Wettbewerbsumfeld und eventuellen Einschränkungen vorhanden sind, damit Chancen, die durch neue Technologien möglich sind, identifiziert werden können.		a. Anteil der umgesetzten Initiativen mit einer klaren Verbindung zu einem Unternehmensziel b. Anteil der Chancen, die sich aus den identifizierten neuen Technologien ergeben
Aktivitäten		Fähigkeitsstufe
1. Sorgen Sie dafür, dass Branchen- und Geschäftstreiber, Unternehmens- und I&T-Strategie sowie die Unternehmensabläufe und aktuellen Herausforderungen jederzeit verstanden werden. Nutzen Sie dieses Verständnis, um potenzielle wertschöpfende Technologien zu identifizieren und innovative I&T zu entwickeln.		2
2. Führen Sie regelmäßige Besprechungen mit Geschäftseinheiten, Bereichen und/oder sonstigen Anspruchsgruppen durch, um aktuelle Geschäftsprobleme, Prozessengpässe oder Einschränkungen zu ermitteln, bei denen Chancen durch aufkommende Technologien oder I&T-Innovationen bestehen.		3
3. Machen Sie sich mit den Investitionsparametern des Unternehmens für Innovationen und neue Technologien vertraut, damit passende Strategien entwickelt werden können.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP004.03 Überwachen und Beobachten der technologischen Entwicklung Richten Sie einen Technologieüberwachungsprozess ein und stellen Sie eine systematische Überwachung und Beobachtung des externen Unternehmensumfeldes sicher, um aufkommende Technologien zu identifizieren, die das Potenzial zur Schaffung von Mehrwert haben (z. B. indem Sie die Unternehmensstrategie unterstützen, Kosten minimieren, Überalterung verhindern oder Unternehmens- und I&T-Prozesse besser unterstützen). Überwachen Sie den Markt, die Wettbewerbslandschaft, Industriesektoren sowie gesetzliche und regulatorische Entwicklungen, damit aufkommende Technologien und innovative Ideen im Unternehmenskontext analysiert werden können.		a. Häufigkeit der Untersuchung und Beobachtung der Umgebung zur Identifizierung innovativer Ideen und Trends b. Anteil der Anspruchsgruppen, die mit den Bemühungen zufrieden sind, den Markt, die Wettbewerbslandschaft, die Industriesektoren und die rechtlichen und regulatorischen Entwicklungen zu beobachten, um aufkommende Technologien oder innovative Ideen im Unternehmenskontext zu analysieren
Aktivitäten		Fähigkeitsstufe
1. Bestimmen Sie Bereitschaft und das Potenzial des Unternehmens in Bezug auf die Übernahme technologischer Innovationen. Fokussieren Sie die Bemühungen auf die am besten geeigneten technologischen Innovationen.		2
2. Richten Sie einen Technologieüberwachungsprozess ein und erforschen und überprüfen Sie das externe Umfeld, einschließlich entsprechender Websites, Zeitschriften und Konferenzen, um aufkommende Technologien und ihren potenziellen Wert für das Unternehmen zu ermitteln.		
3. Beraten Sie sich ggf. mit externen Experten, um Forschungsergebnisse zu sichten, oder Informationen zu aufkommenden Technologien einzuholen.		
4. Sammeln Sie Ideen der Mitarbeiter zu I&T-Innovationen und prüfen Sie diese auf ihre mögliche Umsetzung.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP004.04 Beurteilen des Potenzials aufkommender Technologien und innovativer Ideen Analysieren Sie identifizierte aufkommende Technologien und/oder sonstige Vorschläge für I&T-Innovationen, um deren Geschäftspotenzial zu ermitteln. Validieren Sie gemeinsam mit Anspruchsgruppen die Ansichten zum Potenzial neuer Technologien und Innovationen.		a. Anteil der umgesetzten Initiativen, mit deren Hilfe der geplante Nutzen realisiert wurde b. Anteil der Initiativen zur Erprobung aufkommender Technologien oder anderer innovativer Ideen, deren Umsetzbarkeit bestätigt wurde

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Bewerten Sie die identifizierten Technologien und berücksichtigen Sie dabei Aspekte, wie z. B. die erforderliche Zeit bis zur Erreichung der Reife, das inhärente Risiko (einschließlich potenzieller rechtlicher Auswirkungen), die Eignung für die Unternehmensarchitektur und das Potenzial zur Schaffung von Mehrwert im Einklang mit der Unternehmens- und I&T-Strategie.	2
2. Identifizieren Sie Probleme, die möglicherweise gelöst oder im Rahmen einer Proof-of-Concept-Initiative validiert werden müssen.	3
3. Legen Sie den Rahmen für die Proof-of-Concept-Initiative fest und berücksichtigen Sie dabei gewünschte Ergebnisse, das erforderliche Budget, Zeitrahmen und Zuständigkeiten.	
4. Holen Sie die Genehmigung für die Proof-of-Concept-Initiative ein.	
5. Führen Sie Proof-of-Concept-Initiativen zur Erprobung aufkommender Technologien oder anderer innovativer Ideen durch. Identifizieren Sie etwaige Probleme, und bestimmen Sie unter Berücksichtigung der Machbarkeit und des potenziellen ROI, ob weitere Implementierungs- oder Rollout-Maßnahmen in Betracht gezogen werden sollten	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP004.05 Empfehlen geeigneter weiterführender Initiativen Bewerten und überwachen Sie die Ergebnisse der Proof-of-Concept-Initiativen und generieren Sie im positiven Fall Empfehlungen für weiterführende Initiativen. Sichern Sie sich die Unterstützung der Anspruchsgruppen.	a. Anzahl der Proof-of-Concept-Initiativen, die bewertet und zum Rollout freigegeben wurden b. Anzahl der Proof-of-Concept-Initiativen, die in tatsächliche Investitionen umgesetzt wurden
Aktivitäten	Fähigkeitsstufe
1. Dokumentieren Sie die Proof-of-Concept-Ergebnisse sowie Anleitungen und Empfehlungen für Trends und Innovationsprogramme.	3
2. Kommunizieren Sie gangbare Innovationschancen und lassen Sie diese in die Prozesse der I&T-Strategie und der Unternehmensarchitektur einfließen.	
3. Analysieren und kommunizieren Sie die Gründe für die Ablehnung von Proof-of-Concept-Initiativen.	
4. Verfolgen Sie die Proof-of-Concept-Initiativen nach und ermitteln Sie, in welchem Ausmaß diese bei tatsächlichen Investitionen genutzt wurden.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP004.06 Überwachen der Implementierung und Nutzung von Innovation Überwachen Sie die Implementierung und Nutzung aufkommender Technologien und Innovationen während der Integration, der Übernahme und des gesamten wirtschaftlichen Lebenszyklus, um sicherzustellen, dass die in Aussicht gestellten Vorteile realisiert werden, und um gewonnene Erkenntnisse zu erfassen	a. Erhöhung des Marktanteils oder der Wettbewerbsfähigkeit durch Innovationen b. Umfang der gewonnenen Erkenntnisse und Verbesserungsmöglichkeiten, die für eine zukünftige Nutzung erfasst wurden
Aktivitäten	Fähigkeitsstufe
1. Ermitteln Sie neue Erkenntnisse und Verbesserungsmöglichkeiten.	3
2. Stellen Sie sicher, dass Innovationsinitiativen mit der Unternehmens- und I&T-Strategie übereinstimmen. Überwachen Sie kontinuierlich die Ausrichtung. Passen Sie den Innovationsplan ggf. an.	
3. Beurteilen Sie neue Technologien bzw. I&T-Innovationen, die im Rahmen der Entwicklung der I&T-Strategie- und Unternehmensarchitektur implementiert wurden. Bewerten Sie den Grad ihrer Umsetzung im Rahmen des Programm-Managements von Initiativen.	4
4. Identifizieren und bewerten Sie den potenziellen Wert von Innovationen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen												
Wichtige Managementpraktik:												
APO04.01 Schaffen einer innovationsfördernden Umgebung	A	R	R	R	R	R	R	R	R	R	R	R
APO04.02 Sicherstellen der Kenntnis des Unternehmensumfeldes	A	R	R	R	R	R	R	R	R	R	R	R
APO04.03 Überwachen und Beobachten der technologischen Entwicklung	A	R	R	R	R	R	R	R	R	R	R	R
APO04.04 Beurteilen des Potenzials aufkommender Technologien und innovativer Ideen	A	R	R	R	R	R	R	R	R	R	R	R
APO04.05 Empfehlen geeigneter weiterführender Initiativen	A	R	R	R	R	R	R	R	R	R	R	R
APO04.06 Überwachen der Implementierung und Nutzung von Innovation	A	R	R	R	R	R	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen) Detaillierte Referenzen												
Keine entsprechenden weiteren Quellen für diese Komponente												

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
APO04.01 Schaffen einer innovationsfördernden Umgebung	EDM03.01	Anleitung zur Risikobereitschaft	Anerkennungs- und Belohnungsprogramm	APO07.04
			Innovationsplan	Intern
APO04.02 Sicherstellen der Kenntnis des Unternehmensumfeldes	Außerhalb von COBIT	Unternehmensstrategie und Analyse der Stärken, Schwächen, Chancen und Risiken (SWOT)	Innovationschancen in Verbindung mit Geschäftstreibern	APO02.01
APO04.03 Überwachen und Beobachten der technologischen Entwicklung	Außerhalb von COBIT	Aufkommende Technologien	Erforschung und Analyse von Innovationsmöglichkeiten	BAI03.01
APO04.04 Beurteilen des Potenzials aufkommender Technologien und innovativer Ideen			Proof-of-Concept-Umfang und Entwurf eines Business Case	APO05.02, APO06.02
			Auswertungen von Innovationsideen	BAI03.01
			Ergebnisse von Proof-of-Concept-Initiativen	Intern
APO04.05 Empfehlen geeigneter weiterführender Initiativen			Analyse der abgelehnten Initiativen	APO02.03, BAI03.08
			Ergebnisse und Empfehlungen von Proof-of-Concept-Initiativen	APO02.03, BAI03.09

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO04.06 Überwachen der Implementierung und Nutzung von Innovation			Bewertung innovativer Ansätze	AP002.04, BAI03.02
			Bewertung des Nutzens von Innovationen	AP005.03
			Angepasste Innovationspläne	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Entwicklung von Business Plänen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.3. Business Plan Development
Überwachung von aufkommenden Technologien	Skills Framework for the Information Age V6, 2015	EMRG
Innovation	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.9. Innovativ
Innovation	Skills Framework for the Information Age V6, 2015	INOV
Forschung	Skills Framework for the Information Age V6, 2015	RSCH
Überwachung von Technologietrends	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.7. Technology Trend Monitoring

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Innovationsprinzipien	Definiert allgemeine Prinzipien, die sicherstellen, dass neue/innovative Ideen bei der Definition neuer strategischer Ziele und Entscheidungen umfassend bewertet werden.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie ein innovationsförderndes Umfeld durch entsprechende HR-Initiativen, wie z. B. Programme zur Anerkennung und Belohnung von Innovationen, angemessene Wechsel des Arbeitsbereichs und einen Ermessensspielraum zur Erprobung. Stellen Sie eine enge Zusammenarbeit und Koordination von Initiativen in der gesamten Organisation sicher.		

G. Komponente: Services, Infrastruktur und Anwendungen	
• Plattformen zur Zusammenarbeit • Branchenbenchmarks • Werkzeuge und Services zur Beobachtung der Technologieentwicklung	

Diese Seite wurde absichtlich freigelassen.

Domäne: Anpassen, Planen und Organisieren Managementziel: APO05 – Portfolio ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Umsetzung der für Investitionen festgelegten strategischen Vorgaben in Einklang mit der Unternehmensarchitekturvision und der I&T-Roadmap. Betrachtung der unterschiedlichen Investitionskategorien sowie der Ressourcen- und Finanzierungseinschränkungen. Bewertung, Priorisierung und Justierung von Programmen und Dienstleistungen durch Managen des Bedarfs innerhalb der Ressourcen- und Finanzierungseinschränkungen und unter Berücksichtigung ihrer Ausrichtung an strategischen Zielvorgaben, des Unternehmenswerts und des Risikos. Verschiebung ausgewählter Programme zur Ausführung in das aktive Produkt- oder Dienstleistungsportfolio. Überwachung der Leistung des gesamten Portfolios an Produkten, Dienstleistungen und Programmen sowie Empfehlung etwaiger Anpassungen, die aufgrund der Leistung der Programme und Dienstleistungen oder infolge veränderter Unternehmensprioritäten sinnvoll erscheinen.		
Zweck		
Optimierung der Leistung des gesamten Programmportfolios, um der Leistung der individuellen Programme, Produkte und Dienstleistungen sowie veränderten Unternehmensprioritäten und -anforderungen Rechnung zu tragen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die IT ermöglichten Anlage- und Dienstleistungsportfolio • AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
APO05.01 Bestimmen der Verfügbarkeit und der Quellen von Finanzinstrumenten oder finanziellen Mitteln Machen Sie potenzielle Finanzierungsquellen und unterschiedliche Finanzierungsoptionen ausfindig und bestimmen Sie, welche Auswirkungen die Wahl der Finanzierungsquelle auf die Renditeerwartungen hat.	a. Verhältnis von zugeteilten zu verbrauchten Mitteln b. Verhältnis von einbehaltenen Gewinnen zu zugeteilten Mitteln

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Bestimmen Sie die derzeitige Verfügbarkeit und Bindung von Finanzmitteln, die aktuell genehmigten Ausgaben und die tatsächlichen bisherigen Ausgaben.		2
2. Identifizieren Sie Optionen für die Beschaffung zusätzlicher Finanzmittel für durch I&T ermöglichte Investitionen über interne und externe Quellen.		
3. Bestimmen Sie, welche Auswirkungen die Finanzierungsquelle auf die Renditeerwartungen hat.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP005.02 Evaluieren und Auswählen der zu finanzierenden Programme Bewerten und priorisieren Sie auf der Grundlage der Anforderungen an den gesamten Investitionsportfoliomix, den I&T-Strategieplan sowie die Roadmap die für die Programme erstellten Business Cases und entscheiden Sie über Investitionsvorschläge. Teilen Sie die Finanzmittel zu und leiten Sie die Programme ein.		a. Anteil der Projekte im I&T-Projektportfolio, die sich unmittelbar auf die I&T-Strategie zurückführen lassen b. Anteil der Geschäftseinheiten, die in den Bewertungs- und Priorisierungsprozess einbezogen sind
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie Investitionschancen, und ordnen Sie diese den Kategorien des Investitionsportfolios zu. Spezifizieren Sie die erwarteten Unternehmensergebnisse, die für deren Erreichung erforderlichen Initiativen, die Kosten, Abhängigkeiten und Risiken. Spezifizieren Sie eine Methodik zur Messung der Ergebnisse, Kosten und Risiken.		2
2. Führen Sie eine detaillierte Bewertung aller Business Cases zu Programmen durch. Bewerten Sie die strategische Ausrichtung, den Unternehmensnutzen, das Risiko und die Verfügbarkeit von Ressourcen.		3
3. Beurteilen Sie die Auswirkungen auf das allgemeine Investitionsportfolio, die sich aus der Hinzufügung von Anwärterprogrammen ergeben, einschließlich aller Änderungen, die möglicherweise an anderen Programmen vorzunehmen wären.		
4. Entscheiden Sie, welche Anwärterprogramme in das aktive Investitionsportfolio aufgenommen sollen. Entscheiden Sie, ob abgelehnte Programme für künftige Überlegungen beibehalten oder mit einer Anschubfinanzierung versehen werden sollten, um festzustellen, ob der Business Case verbessert werden kann oder verworfen werden sollte.		
5. Bestimmen Sie die Meilensteine, die für den vollständigen wirtschaftlichen Lebenszyklus der ausgewählten Programme erforderlich sind. Teilen Sie die Gesamtfinanzierungsmittel für das Programm den einzelnen Meilensteinen zu, und reservieren Sie die Mittel. Verschieben Sie das Programm in das aktive Investitionsportfolio.		
6. Richten Sie Verfahren zur Kommunikation der kosten-, nutzen- und risikobezogenen Aspekte der Portfolios an die Prozesse für Budgetpriorisierung, Kostenmanagement und Nutzenmanagement ein, damit sie dort berücksichtigt werden können.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 1.2.3 Relationship of project, program, portfolio and operations management
Managementpraktik		Beispielmetrik
AP005.03 Überwachen, Optimieren und Berichten der Leistung des Investitionsportfolios Überwachen und optimieren Sie regelmäßig die Leistung des Investitionsportfolios und der einzelnen Programme über den gesamten Investitionslebenszyklus hinweg. Gewährleisten Sie eine kontinuierliche Überwachung der Ausrichtung des Portfolios an der I&T-Strategie.		a. Trends des ROI von Initiativen, die in der I&T-Strategie enthalten sind b. Grad der Zufriedenheit mit Portfolioüberwachungsberichten c. Anteil der Programme, die auf die Geschäftsanforderungen des Unternehmens abgestimmt sind

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie das Portfolio regelmäßig, um Synergien zu identifizieren und zu nutzen, Redundanzen zwischen den Programmen zu beseitigen und Risiken zu identifizieren und zu mindern.	3
2. Führen Sie im Falle von Änderungen eine Neubewertung des Portfolios durch und setzen Sie die Prioritäten neu, um sicherzustellen, dass das Portfolio jederzeit an der Geschäfts- und I&T-Strategie ausgerichtet ist. Stellen Sie die Investitionen so zusammen, dass das Portfolio den optimalen Gesamtwert liefert. Dies erfordert möglicherweise die Änderung, Zurückstellung oder Beendigung von Programmen oder die Initiierung neuer Programme, um das Portfolio neu auszubalancieren und zu optimieren.	
3. Passen Sie die Zielwerte, Prognosen und Budgets des Unternehmens sowie ggf. den Umfang der Überwachung an, um die entstehenden Ausgaben und die erwarteten Unternehmensvorteile der im aktiven Investitionsportfolio befindlichen Programme abzubilden. Programmausgaben sollten rückverrechnet werden. Etablieren Sie flexible Budgetierungsprozesse, damit vielversprechende Projekte schnell Ressourcen erhalten, um schnell skalieren zu können.	
4. Entwickeln Sie Metriken zur Messung des I&T-Beitrags zum Unternehmen. Legen Sie angemessene Leistungsziele fest, die die erforderlichen I&T- und Unternehmensbefähigungsziele widerspiegeln. Greifen Sie zur Entwicklung von Metriken auf die Unterstützung externer Experten und Benchmark-Daten zurück.	4
5. Sorgen Sie dafür, dass allen Anspruchsgruppen eine genaue Darstellung der Leistung des Investitionsportfolios zur Verfügung steht.	
6. Stellen Sie der Führungsebene Berichte zur Überprüfung der Fortschritte des Unternehmens in Bezug auf die festgelegten Ziele zur Verfügung und machen Sie Angaben darüber, was in einem bestimmten Zeitrahmen noch ausgegeben und erreicht werden muss.	
7. Nehmen Sie in die regelmäßige Leistungsüberwachung Informationen zum Grad auf, in dem geplante Zielvorgaben erreicht, Risiken gemindert, Befähigungen geschaffen, Ergebnisse erbracht und Leistungsziele erreicht wurden.	
8. Identifizieren Sie Abweichungen zwischen budgetierten und tatsächlichen Ausgaben und dem erwarteten ROI der Investitionen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP005.04 Pflegen von Portfolios Pflegen Sie die Portfolios für Investitionsprogramme und -projekte, I&T-Produkte und -Services und I&T-Betriebsmittel.	a. Anzahl der abgeschlossenen Programme und Projekte b. Zeit seit der letzten Aktualisierung des Serviceportfolios
Aktivitäten	Fähigkeitsstufe
1. Erstellen und pflegen Sie Portfolios für durch I&T ermöglichte Investitionsprogramme, I&T-Services und -Betriebsmittel, die die Grundlage des aktuellen I&T-Budget bilden und die taktischen und strategischen I&T-Pläne unterstützen.	3
2. Pflegen Sie Serviceportfolios gemeinsam mit Service Delivery Managern. Pflegen Sie Betriebsmittelpportfolios in Zusammenarbeit mit Betriebsleitern und Architekten. Legen Sie Prioritäten für Portfolios fest, um Investitionsentscheidungen zu unterstützen.	
3. Entfernen Sie ein Programm aus dem aktiven Investitionsportfolio, sobald die gewünschten Unternehmensvorteile erreicht wurden oder feststeht, dass die Vorteile nicht im Rahmen der für das Programm festgelegten Wertkriterien erreicht werden können.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ITIL V3, 2011	Service Strategy, 4.2 Service portfolio management
Managementpraktik	Beispielmetrik
AP005.05 Managen der Nutzenerreichung Überwachen Sie den Nutzen der Bereitstellung und Beibehaltung geeigneter I&T-Produkte, -Services und -Fähigkeiten auf der Grundlage des vereinbarten und aktuellen Business Case.	a. Anteil der Änderungen an Investitionsprogrammen, die in den relevanten I&T-Portfolios abgebildet werden b. Anteil der Anspruchsgruppen, die mit den Aktivitäten zufrieden sind, die Vorteile der Bereitstellung und Beibehaltung angemessener I&T-Services und -Fähigkeiten auf der Grundlage des verabschiedeten und aktuellen Business Case zu überwachen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Vollziehen Sie anhand der vereinbarten Metriken nach, inwieweit Vorteile erreicht werden, wie sie sich im Laufe des Lebenszyklus von Programmen und Projekten weiterentwickeln, wie sie durch I&T-Produkte- und Services realisiert werden und in welchem Verhältnis sie zu internen und Industrie-Benchmarks stehen. Kommunizieren Sie die Ergebnisse an die Anspruchsgruppen.	4
2. Implementieren Sie korrektive Maßnahmen, wenn die erreichten Vorteile erheblich von den erwarteten Vorteilen abweichen. Aktualisieren Sie den Business Case anhand von neuen Initiativen und implementieren Sie ggf. Verbesserungen für Geschäftsprozesse und Services.	5
3. Ziehen Sie die Unterstützung durch externe Experten und Branchenführer in Erwägung und nutzen Sie vergleichende Benchmark-Daten, um die Metriken und Ziele zu prüfen und zu verbessern.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen																		
Wichtige Managementpraktik:										Chief Financial Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Portfoliomanager	Programm-Manager	Project Management Office
										R	R			A		R		
										R	R	R	R	A		R	R	
											R	R	R	A		R	R	
											R	R	R	A		R	R	R
										R	R	R	R	A	R	R	R	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)										Detaillierte Referenzen								
Keine entsprechenden weiteren Quellen für diese Komponente																		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO05.01 Bestimmen der Verfügbarkeit und der Quellen von Finanzinstrumenten oder finanziellen Mitteln	Von	Beschreibung	Beschreibung	Für
			Erwartungen zur Rendite der Investition	APO02.04, APO06.02, BAI01.06, EDM02.02
			Finanzierungsoptionen	APO02.05

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
APO05.02 Evaluieren und Auswählen der zu finanzierenden Programme	Von	Beschreibung	Beschreibung	Für
	APO03.01	Business Case und Wertversprechen des Architekturkonzepts	Business Case des Programms	APO06.02, BAI01.02
	APO04.04	Umfang des Proof-of-Concept und Entwurf eines Business Case	Bewertung des Business Case	APO06.02, BAI01.06
	APO06.02	- Budgetzuweisungen - Priorisierung und Klassifizierung von I&T-Initiativen	Ausgewählte Programme mit ROI-Meilensteinen	BAI01.04, EDM02.02
	APO06.03	- IT-Budget - Kommunikation des Budgets		
	APO09.01	Identifizierte Lücken bei den IT-Services für das Unternehmen		
	APO09.03	Service-Level-Vereinbarungen (SLAs)		
	APO13.02	Informationssicherheit Business Cases		
	BAI01.02	- Plan zur Realisierung des Programmnutzens - Programmkonzept des Business Case - Programm-Mandat und Satzung		
	EDM02.02	- Bewertung der strategischen Ausrichtung - Bewertung der Investitions- und Serviceportfolios		
	EDM02.03	Investitionsarten und -kriterien		
APO05.03 Überwachen, Optimieren und Berichten der Leistung des Investitionsportfolios	APO04.06	Bewertung des Innovationsnutzens	Investitionsportfolio-Leistungsberichte	APO09.04, BAI01.06, EDM02.03, EDM02.04, MEA01.03
	BAI01.06	Stage-Gate-Review-Ergebnisse		
	EDM02.02	Bewertung von Investitionen und Serviceportfolios		
	EDM02.04	- Feedback zur Portfolio- und Projektleistung - Maßnahmen zur Verbesserung des Wertbeitrags		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO05.04 Pflegen von Portfolios	BAI01.09	Kommunikation über die Inaktivsetzung des Programms und laufende Verantwortlichkeiten	Aktualisierte Portfolios von Programmen, Services und Betriebsmitteln	APO09.02, BAI01.01
	BAI03.11	Aktualisiertes Serviceportfolio		
APO05.05 Managen der Nutzenerreichung	BAI01.04	Programmbudget und Nutzenregister	Korrekturmaßnahmen zur Verbesserung der Nutzenrealisierung	APO09.04, BAI01.06
	BAI01.05	Ergebnisse der Überwachung der Nutzenrealisierung	Nutzerergebnisse und zugehörige Mitteilungen	APO09.04, BAI01.06, EDM02.02
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Nutzenmanagement	Skills Framework for the Information Age V6, 2015	BENM
Portfoliomanagement	Skills Framework for the Information Age V6, 2015	POMG
Produkt-/Serviceplanung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.4. Product/Service Planning

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Portfolioprinzipien	Definition allgemeiner Prinzipien, die eine korrekte und vielfältige Auswahl von Programmen und Projekten zur Erreichung der I&T-Strategie gewährleisten und die die Ausrichtung an der Unternehmensstrategie, an einen geeigneten Investitionsmix etc. sicherstellen.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Fördern Sie das systematische Management von I&T-Investitionen sowie die objektive Messung und Bewertung von Investitionsszenarien.		
Zur Förderung von Schnelligkeit und Agilität, sollten die Führungskräfte das aktive Investitionsportfolio aussagekräftig bewerten. Wenn ein Prototyp nicht funktioniert, muss die Führungsebene das Projekt entschlossen beenden, die Lehren daraus ziehen und weitermachen. Ressourcen sollten für erfolgreiche Projekte schnell bereitgestellt werden, um eine angemessene Skalierung zu erreichen.		

G. Komponente: Services, Infrastruktur und Anwendungen
Portfolio/Investitionsmanagement-Tools

Domäne: Anpassen, Planen und Organisieren Managementziel: APO06 – Budget und Kosten sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Management der I&T-bezogenen Finanzangelegenheiten sowohl in den Geschäfts- als auch in den IT-Funktionen, wobei das Budget-, Kosten- und Nutzenmanagement und die Priorisierung der Ausgaben durch die Anwendung formeller Budgetierungspraktiken und eines fairen und gerechten Systems der Kostenzuweisung abgedeckt werden. Hinzuziehung der Anspruchsgruppen zur Ermittlung und Kontrolle der Gesamtkosten und -nutzen im Rahmen der strategischen und taktischen I&T-Planung. Einleitung von Korrekturmaßnahmen, wo erforderlich.		
Zweck		
Förderung einer Partnerschaft zwischen IT und Anspruchsgruppen im Unternehmen, um eine effektive und effiziente Nutzung I&T-bezogener Ressourcen zu ermöglichen und die Kosten und den Geschäftswert von Lösungen und Services transparent und nachvollziehbar zu gestalten. Befähigung des Unternehmens, fundierte Entscheidungen zur Nutzung von I&T-Lösungen und -Services zu treffen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG09 Optimierung der Geschäftsprozesskosten • EG12 Gesteuerte Programme zur digitalen Transformation		• AG04 Qualität der durch IT erzeugten Finanzinformationen • AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG04 a. Zufriedenheit der wichtigsten Anspruchsgruppen hinsichtlich des Grades an Transparenz, Verständnis und Genauigkeit der I&T-Finanzinformationen b. Anteil der I&T-Services mit definierten und genehmigten Betriebskosten und erwartetem Nutzen
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind
EG07 a. Grad der Zufriedenheit der Geschäftsleitung und obersten Führungskräfte mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		
EG09 a. Verhältnis von Kosten zu erreichten Service Levels b. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Kosten der Geschäftstätigkeit		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
APO06.01 Managen des Finanz- und Rechnungswesens für die IT Entwickeln und pflegen Sie eine Methode zur buchhalterischen Berücksichtigung aller I&T-bezogenen Kosten, Investitionen und Abschreibungen, die einen festen Bestandteil der Finanzsysteme und Konten des Unternehmens bildet. Erstellen Sie unter Verwendung der Messsysteme des Unternehmens für den Finanzbereich Bericht.		a. Anzahl der Abweichungen zwischen erwarteten und tatsächlichen Budgetkategorien b. Nützlichkeit von Finanzinformationen als Input für Business Cases für neue Investitionen in I&T-Betriebsmittel und -Services
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Prozesse, Inputs und Outputs und Zuständigkeiten für das Finanzmanagement und Rechnungswesen der I&T in Einklang mit den Budgetierungs- und Kostenberechnungsrichtlinien und -ansätzen des Unternehmens. Definieren Sie, wie die Analyse und Berichterstattung (an wen und wie) des I&T-Budget-Kontrollprozesses erfolgen soll.		2
2. Definieren Sie ein Klassifizierungsschema, um alle I&T-bezogenen Kostenarten zu identifizieren (Investitionsausgaben [Capex] vs. Betriebsausgaben [Opex], Hardware, Software, Personal usw.). Definieren Sie, wie sie erfasst werden.		
3. Nutzen Sie Finanzinformationen als Input für Business Cases, die für neue Investitionen in I&T-Betriebsmittel und I&T-Services erstellt werden.		3
4. Stellen Sie sicher, dass die Kosten in den Portfolios der I&T-Betriebsmittel und -Services gepflegt werden.		
5. Entwickeln und pflegen Sie Praktiken für die Finanzplanung und die Optimierung wiederkehrender operativer Kosten, um bei möglichst geringen Ausgaben einen maximalen Wertbeitrag für das Unternehmen zu generieren.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011		Service Strategy, 4.3 Financial management for IT services
Managementpraktik		Beispielmetrik
APO06.02 Priorisieren der Ressourcenzuteilung Implementieren Sie einen Entscheidungsfindungsprozess für die Festlegung von Prioritäten bei der Zuteilung von Ressourcen, sowie Regeln für die Vornahme von Investitionen, über die die einzelnen Geschäftsbereiche frei verfügen können. Ziehen Sie die Einbeziehung externer Serviceanbieter sowie Kauf-, Entwicklungs- und Mietoptionen in Erwägung.		a. Anzahl der eskalierten Probleme in Verbindung mit der Zuteilung von Ressourcen b. Anteil der Ausrichtung von I&T-Ressourcen auf Initiativen mit hoher Priorität
Aktivitäten		Fähigkeitsstufe
1. Klassifizieren Sie alle I&T-Initiativen und Budgetanfragen auf der Basis von Business Cases sowie strategischen und taktischen Prioritäten. Etablieren Sie Verfahren zur Festlegung der Budgetzuweisung und von Obergrenzen.		2
2. Weisen Sie Geschäfts- und IT-Ressourcen (einschließlich externer Dienstleister) im Rahmen der Budgetzuweisungen für I&T-gestützte Programme, Services und Betriebsmittel zu. Erwägen Sie die Optionen für den Kauf oder die Entwicklung von aktivierten Betriebsmitteln und Services im Vergleich zur Nutzung externer Betriebsmittel und Services auf einer Pay-for-Use-Basis.		
3. Führen Sie ein Verfahren zur Kommunikation von Budgetentscheidungen und zur Überprüfung dieser Entscheidungen durch den Budgetverantwortlichen der Geschäftseinheiten ein.		
4. Identifizieren, kommunizieren und beheben Sie schwerwiegende Auswirkungen von Budgetentscheidungen auf Business Cases, Portfolios und Strategiepläne. Dies kann z. B. der Fall sein, wenn Budgets aufgrund veränderter Unternehmensumstände einer Überarbeitung bedürfen oder sie nicht ausreichen, um strategische Zielvorgaben oder Ziele im Rahmen eines Business Case zu unterstützen.		
5. Bewirken Sie beim Exekutivkomitee eine Ratifizierung für diejenigen Änderungen des allgemeinen I&T-Budgets, die sich negativ auf die strategischen oder taktischen Pläne der Einheit auswirken. Unterbreiten Sie Vorschläge für Maßnahmen zur Behebung dieser Auswirkungen.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)		
Managementpraktik	Beispielmetrik	
AP006.03 Erstellen und Pflegen von Budgets Erstellen Sie auf der Basis des Portfolios für I&T-gestützte Programme und I&T-Services ein Budget, das die Investitionsprioritäten bei der Unterstützung strategischer Zielsetzungen widerspiegelt.	a. Anzahl von Budgetänderungen aufgrund von Versäumnissen und Fehlern b. Eignung des I&T-Budgets bei der Ermittlung aller erwarteten I&T-Kosten für I&T-gestützte Programme, Services und Betriebsmittel	
Aktivitäten	Fähigkeitsstufe	
1. Implementieren Sie ein I&T-Budget, in dem sämtliche erwarteten I&T-Kosten für I&T-gestützte Programme, Services und Betriebsmittel enthalten sind.	2	
2. Berücksichtigen Sie bei der Erstellung des Budgets folgende Aspekte: Ausrichtung am Geschäft, Ausrichtung an der Sourcing-Strategie, genehmigte Finanzierungsquellen; interne Ressourcenkosten, u. a. für Personal, Informationsbestände und Sonstiges, Kosten für externe Anbieter, u. a. für Outsourcing-Verträge, Berater und Serviceanbieter, Anlage- und Betriebskosten sowie arbeitslastabhängige Kostenarten.		
3. Dokumentieren Sie die Gründe zur Rechtfertigung von Unvorhergesehenem und überprüfen Sie diese regelmäßig.		
4. Fordern Sie Verantwortliche für Prozesse, Services und Programme sowie Projekt- und Asset-Manager auf, Budgets zu planen.		
5. Überprüfen Sie die Budgetpläne und treffen Sie Entscheidungen über die Budgetzuteilung. Erstellen Sie das Budget und passen Sie es unter Berücksichtigung sich ändernder Unternehmensanforderungen und finanzieller Überlegungen an.	3	
6. Erfassen, pflegen und kommunizieren Sie das aktuelle I&T-Budget, einschließlich der bestätigten und derzeitigen Aufwendungen und berücksichtigen Sie dabei I&T-Projekte, die in den durch I&T ermöglichten Investitionsportfolios erfasst sind, sowie den Einsatz und die Pflege von Betriebsmittel- und Serviceportfolios.		
7. Überwachen Sie die Effektivität der verschiedenen Aspekte der Budgetierung.	4	
8. Nutzen Sie die Ergebnisse der Überwachung, um Verbesserungen umzusetzen und sicherzustellen, dass künftige Budgets genauer, zuverlässiger und kosteneffektiver sind.	5	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISO/IEC 20000-1:2011(E)	6.4 Budgeting and accounting for services	
PMBOK Guide Sixth Edition, 2017	Part 1: 7. Project cost management	
Managementpraktik	Beispielmetrik	
AP006.04 Modellieren und Umlegen von Kosten Richten Sie ein I&T-Kostenberechnungsmodell ein, das beispielsweise auf der Servicedefinition basiert und wenden Sie dieses an. Dieser Ansatz stellt sicher, dass die Zuordnung von Kosten für Services identifizierbar, messbar und vorhersehbar ist und fördert den verantwortungsvollen Umgang mit Ressourcen, einschließlich derer, die von Serviceanbietern bereitgestellt werden. Überprüfen Sie regelmäßig das Kosten-/Kostenstellenmodell und führen Sie entsprechende Benchmarks durch, um dessen Relevanz und Eignung für die sich weiterentwickelnden Geschäfts- und IT-Aktivitäten zu gewährleisten.	a. Anteil der allgemeinen I&T-Kosten, die gemäß einem verabschiedeten Kostenstellenmodell umgelegt werden b. Anzahl der Überprüfungen und Benchmarks des Kosten-/Kostenstellenmodells und deren Angemessenheit für aufkommende Geschäfts- und I&T-Aktivitäten	

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Legen Sie ein Kostenzuordnungsmodell fest, das eine faire, transparente, reproduzierbare und vergleichbare Zuordnung der I&T-bezogenen Kosten zu den Nutzern ermöglicht. Ein grundlegendes Beispiel für ein Zuordnungsmodell ist die gleichmäßige Verteilung der I&T-bezogenen Kosten. Dabei handelt es sich um ein sehr einfaches Zuordnungsmodell, das leicht anzuwenden ist. Je nach Unternehmenskontext wird es jedoch oft als unfair angesehen und fördert nicht den verantwortungsvollen Umgang mit Ressourcen. Die Prozesskostenrechnung, bei der die Kosten den IT-Services zugeordnet und den Nutzern dieser Services in Rechnung gestellt werden, ermöglicht eine transparentere und vergleichbarere Kostenzuordnung. 2. Überprüfen Sie die Servicedefinitionskataloge und identifizieren Sie diejenigen Services, die dem Anwender belastet werden, und diejenigen, bei denen es sich um gemeinsam genutzte Services handelt. 3. Gestalten Sie das Kostenzuordnungsmodell so transparent, dass die Benutzer ihre tatsächliche Nutzung und Belastung anhand von Kategorien und Kostentreibern ermitteln können, die für den Benutzer sinnvoll sind (z. B. Kosten pro Helpdesk-Anruf, Kosten pro Softwarelizenz), und dass die I&T-Kosten besser vorhersehbar sind und die I&T-Ressourcen effizient und effektiv genutzt werden können. Analysieren Sie die Kostentreiber (Zeitaufwand pro Aktivität, Ausgaben, Anteil der fixen vs. variablen Kosten usw.). Wählen Sie einen angemessenen Detailgrad (z. B. verschiedene Kategorien von Nutzern mit unterschiedlichen Gewichtungen) und verwenden Sie Kostenschätzungen oder Durchschnittswerte, wenn die tatsächlichen Kosten stark schwanken. 4. Erklären Sie wichtigen Anspruchsgruppen die Grundsätze des Kostenzuordnungsmodells und die Ergebnisse. Holen Sie ihr Feedback ein, um die Feinabstimmung in Richtung eines transparenten und umfassenden Modells weiter voranzutreiben. 5. Holen Sie Zustimmung der wichtigsten Anspruchsgruppen ein und kommunizieren Sie das I&T-Kostenzuordnungsmodell an die Führungskräfte der Abteilungen. 6. Kommunizieren Sie wichtige Änderungen in den Grundsätzen des Kosten-/Kostenstellenmodells an wichtige Anspruchsgruppen und an die Führungskräfte der Abteilungen.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP006.05 Managen von Kosten Implementieren Sie einen Kostenmanagementprozess, der die tatsächlichen Kosten mit dem Budget abgleicht. Die Kosten sollten dabei überwacht und berichtet werden. Abweichungen vom Budget sollten zeitnah erkannt und ihre Auswirkungen auf Unternehmensprozesse und Services beurteilt werden.		a. Abweichung zwischen Budgets, Prognosen und tatsächlichen Kosten b. Aktualität der Überwachung und Berichterstattung bei Abweichungen und deren Auswirkungen auf die bewerteten Unternehmensprozesse und Services
Aktivitäten		Fähigkeitsstufe
1. Holen Sie die Zustimmung der wichtigsten Anspruchsgruppen ein und kommunizieren Sie das I&T-Kostenzuordnungsmodells an die Führungskräfte der Abteilungen. 2. Erstellen Sie Zeitvorgaben für den Kostenmanagementprozess, und berücksichtigen Sie dabei die Anforderungen für Budgetierung, Rechnungswesen und Zeitplan. 3. Legen Sie eine Methode zur Erfassung relevanter Daten fest, um Abweichungen zwischen Budget und tatsächlichen Kosten, der Kapitalrendite für Investitionen, den Trends bei den Servicekosten usw. zu ermitteln.		2
4. Definieren Sie die Vorgehensweise bei der Konsolidierung der Kosten für die jeweiligen Ebenen im Unternehmen (zentrale IT vs. IT-Budget innerhalb der Abteilungen) und deren Darstellung gegenüber den Anspruchsgruppen. Die Berichte liefern Informationen über die Kosten pro Kostenkategorie, Budget im Vergleich zum Ist-Zustand, die höchsten Ausgaben usw., um rechtzeitig erforderliche Korrekturmaßnahmen zu identifizieren. 5. Fordern Sie die Verantwortlichen für das Kostenmanagement auf, die Daten zu erfassen, zu sammeln und zu konsolidieren und diese den jeweiligen Budgetinhabern zu präsentieren und zu melden. Budgetanalysten und Budgetinhaber analysieren gemeinsam Abweichungen vom Budget und vergleichen die Performance mit internen Benchmarks und Industrie-Benchmarks. Dabei sollte die Gemeinkostenumlage angewendet werden. Anhand des Analyseergebnisses können gravierende Abweichungen erklärt und korrektive Maßnahmen vorgeschlagen werden 6. Stellen Sie sicher, dass die jeweiligen Managementebenen die Ergebnisse der Analyse überprüfen und die vorgeschlagenen korrektiven Maßnahmen genehmigen.		3
7. Stellen Sie sicher, dass Änderungen in Bezug auf die Kostenstruktur und Unternehmensanforderungen identifiziert und Budgets und Prognosen ggf. überarbeitet werden.		4

A. Komponente: Prozess (Forts.)	
8. Identifizieren Sie in regelmäßigen Abständen, und insbesondere bei Budgetkürzungen aufgrund von finanziellen Engpässen, Möglichkeiten zur Optimierung der Kosten und von Effizienzsteigerungen, ohne dabei die Services einzuschränken.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen											
Wichtige Managementpraktik:						Chief Financial Officer					
						Chief Information Officer					
						Chief Technology Officer					
						Chief Digital Officer					
						Portfoliomanager					
						Leiter IT-Administration					
APO06.01 Managen des Finanz- und Rechnungswesens für die IT						A				R	R
APO06.02 Priorisieren der Ressourcenzuteilung						R	A	R	R	R	R
APO06.03 Erstellen und Pflegen von Budgets						R	A	R	R		R
APO06.04 Modellieren und Umlegen von Kosten						R	A				R
APO06.05 Managen von Kosten						R	A	R	R		R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)					Detaillierte Referenzen						
Keine entsprechenden weiteren Quellen für diese Komponente											

C. Komponente: Managementabläufe und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
APO06.01 Managen des Finanz- und Rechnungswesens für die IT	BAI09.01	Betriebsmittelregister	Praktiken der Finanzplanung	Intern
			Klassifikationsschema für I&T-Kosten	Intern
			Prozesse des Rechnungswesens	Intern

C. Komponente: Managementabläufe und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO06.02 Priorisieren der Ressourcenzuteilung	APO04.04	Umfang des Proof-of-Concept und Entwurf eines Business Case	Budgetzuweisungen	APO02.05, APO05.02, APO07.05, BAI03.11
	APO05.01	Erwartungen an die Investitionsrendite	Priorisierung und Einstufung von I&T-Initiativen	APO05.02
	APO05.02	• Business Case des Programms • Bewertungen des Business Case		
	EDM02.02	Bewertung von Investitionen und Serviceportfolios		
	EDM02.04	Maßnahmen zur Verbesserung der Wertschöpfung		
APO06.03 Erstellen und Pflegen von Budgets			I&T-Budget	APO02.05, APO05.02, APO07.01, BAI03.11
			Kommunikation des Budgets	APO05.02, APO07.01, BAI03.11
APO06.04 Modellieren und Umlegen von Kosten			Operative Verfahren	Intern
			Kommunikation der Kostenzuordnung	Intern
			Kostenzuordnungsmo- dell	Intern
			Kategorisierte I&T-Kosten	Intern
APO06.05 Managen von Kosten	BAI01.02	Plan zur Realisierung des Nutzens des Programm-Managements	Möglichkeiten zur Kostenoptimierung	APO02.02
	BAI01.04	Programmbudget und Nutzenregister	Methode zur Kostenkonsolidierung	Intern
	BAI01.05	Ergebnisse der Überwachung der Nutzenrealisierung	Methode der Kostendatenerfassung	Intern
	EDM02.04	Feedback zu Portfolio- und Programmleistung		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 7. Project cost management Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Finanzmanagement	Skills Framework for the Information Age V6, 2015	FMIT

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Budgetierungsrichtlinie	Befasst sich mit der Vorbereitung und dem Zeitplan für die Erstellung des Jahresbudgets und der Prognose der jährlichen Finanzlage. Umreißt die erforderlichen Managementberichtsprozesse. Legt die Rechenschaftspflicht und Verantwortung für den Budgetplan und andere Finanzdokumente fest.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Ein effektives und effizientes Management der I&T wird durch eine Kultur der Transparenz hinsichtlich Budget, Kosten und Nutzen in der gesamten Organisation unterstützt. Das Management sollte eine Kultur der faktenbasierten Entscheidungsfindung ermöglichen. Beispielsweise zählen dazu: Vergleichbare Schätzungen von Geschäfts- und IT-Kosten sowie der Vorteile als Input für das Portfoliomanagement, faire Kostenzuordnung von IT-Betriebsmitteln und -Ressourcen und nachvollziehbare IT-Budgets.		

G. Komponente: Services, Infrastruktur und Anwendungen
Kostenrechnungssystem

Diese Seite wurde absichtlich freigelassen.

Domäne: Anpassen, Planen und Organisieren Managementziel: APO07 – Personal ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Bereitstellung eines strukturierten Ansatzes, um eine optimale Rekrutierung, Planung, Bewertung und Entwicklung von Mitarbeitern (sowohl intern als auch extern) zu gewährleisten.		
Zweck		
Optimierung der Befähigungen von Mitarbeitern, um die Unternehmenszielvorgaben zu erreichen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG10 Fähigkeiten, Motivation und Produktivität der Mitarbeiter • EG13 Produkt- und Geschäftsinnovation		• AG12 Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft • AG13 Wissen, Know-how und Initiativen für geschäftliche Innovationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG12 a. Anteil von I&T-erfahrenen Fachbereichsmitarbeitern (d. h. Personen, die über das erforderliche I&T-Wissen und -Verständnis verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten in ihrem Fachgebiet zu erkennen) b. Anteil der fachlich erfahrenen I&T-Mitarbeiter (d. h. Personen, die über das erforderliche Wissen und Verständnis der relevanten Geschäftsbereiche verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten für den Geschäftsbereich zu erkennen) c. Anzahl oder Anteil der Mitarbeiter mit Erfahrung im Technologiemanagement
EG10 a. Mitarbeiterproduktivität im Vergleich zu Benchmarks b. Grad der Zufriedenheit der Anspruchsgruppen mit den Fachkenntnissen und den Fähigkeiten der Mitarbeiter b. Anteil des Personals, dessen Fähigkeiten nicht ausreichen, um seine Rolle kompetent wahrzunehmen d. Anteil zufriedener Mitarbeiter		AG13 a. Grad des Bewusstseins von Führungskräften und des Verständnisses für Innovationsmöglichkeiten im Bereich I&T b. Anzahl der genehmigten Initiativen, die aus innovativen I&T-Ideen resultieren c. Anzahl der anerkannten/ausgezeichneten Innovations-Champions
EG13 a. Grad des Bewusstseins und Verständnisses für geschäftliche Innovationsmöglichkeiten b. Zufriedenheit der Anspruchsgruppen mit dem Grad der Produkt- und Innovationskompetenz und der Entwicklung von neuen Ideen c. Anzahl der genehmigten Produkt- und Serviceinitiativen, die aus innovativen Ideen resultieren		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
APO07.01 Aufbauen und Aufrechterhalten einer adäquaten und angemessenen Personalbesetzung Entwickeln und erweitern Sie eine Methode zum Managen und Berücksichtigen aller I&T-bezogenen Kosten, Investitionen und Abschreibungen, die einen festen Bestandteil der Finanzsysteme und Konten des Unternehmens bildet. Erstellen Sie unter Verwendung der Systeme zur Ermittlung der Finanzinformationen des Unternehmens Bericht.	a. Durchschnittliche Dauer von Vakanzen b. Anteil der vakanten IT-Stellen c. Anteilige Personalfluktuationsrate

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Bewerten Sie die Personalanforderungen regelmäßig oder bei Eintreten größerer Veränderungen. Stellen Sie sicher, dass sowohl das Unternehmen als auch die IT-Funktion über ausreichende Ressourcen verfügen, um die Ziele und Zielvorgaben des Unternehmens, die Geschäftsprozesse und Kontrollen sowie die I&T-gestützten Initiativen adäquat und angemessen zu unterstützen.		2
2. Sorgen Sie dafür, dass Rekrutierungs- und Mitarbeiterbindungsprozesse für Fachbereichs- und IT-Personal mit den allgemeinen Personalrichtlinien und -verfahren des Unternehmens vereinbar sind.		
3. Richten Sie flexible Ressourcenvereinbarungen ein, z. B. durch Versetzungen oder den Einsatz externer Vertragspartner bzw. Servicevereinbarungen mit Dritten, um veränderte Geschäftsanforderungen zu unterstützen.		
4. Nehmen Sie Hintergrundprüfungen in den IT-Rekrutierungsprozess für Mitarbeiter, Auftragnehmer und Anbieter auf. Umfang und Häufigkeit dieser Überprüfungen sollten an die Sensitivität und/oder Kritizität der Funktion gekoppelt sein.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		6. Governance and Culture – Principle 5
Skills Framework for the Information Age V6, 2015		SFIA and skills management – Acquire
Managementpraktik		Beispielmetrik
AP007.02 Identifizieren von wichtigem IT-Personal Identifizieren Sie wichtiges IT-Personal. Minimieren Sie hinsichtlich der Ausübung kritischer Funktionen die Abhängigkeit von Einzelpersonen durch Wissenserfassung (Dokumentation), die gemeinsame Nutzung von Wissen, Nachfolgeplanung und das Vorhalten von Reservepersonal		a. Anteil der kritischen Arbeitsplätze, bei denen das Unternehmen von einer Einzelperson abhängig ist b. Anzahl der umgesetzten Reservepersonalpläne
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie Richtlinien als Sicherheitsvorkehrung bereit, die festlegen, dass wichtige Funktionsinhaber eine bestimmte Mindestanzahl von Urlaubstagen zusammenhängend nehmen müssen.		2
2. Treffen Sie zweckdienliche Maßnahmen im Hinblick auf Stellenwechsel und insbesondere im Hinblick auf Kündigungen.		
3. Nutzen Sie Initiativen zur Wissenserfassung (Dokumentation), zum Wissensaustausch, zur Nachfolgeplanung, zum Vorhalten von Reservepersonal, zu fachbereichsübergreifenden Schulungen und Arbeitsplatzrotation, um die Abhängigkeit von einzelnen Personen, die kritische Funktionen ausüben zu minimieren.		
4. Testen Sie regelmäßig Reservepersonalpläne.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		RI.RR Identification of Roles and Responsibilities
Skills Framework for the Information Age V6, 2015		SFIA and skills management – Acquire
Managementpraktik		Beispielmetrik
AP007.03 Aufrechterhalten der Fähigkeiten und Kompetenzen der Mitarbeiter Definieren und managen Sie die erforderlichen Fähigkeiten und Kompetenzen der Mitarbeiter. Überprüfen Sie regelmäßig, ob die Mitarbeiter aufgrund ihrer Ausbildung, Schulung und/oder Erfahrung über die zur Ausübung ihrer Rolle erforderlichen Kompetenzen verfügen. Stellen Sie sicher, dass diese Kompetenzen aufrecht erhalten werden, gegebenenfalls durch Nutzung von Qualifikations- und Zertifizierungsprogrammen. Ermöglichen Sie den Mitarbeitern ein kontinuierliches Lernen und bieten Sie ihnen Optionen, ihr Wissen, ihre Fähigkeiten und ihre Kompetenzen auf einem Niveau zu halten, das zur Erreichung der Unternehmensziele erforderlich ist.		a. Identifizierte wichtige Fähigkeiten und Kompetenzen, die in der Ressourcenmatrix fehlen b. Anzahl der identifizierten Lücken zwischen erforderlichen und verfügbaren Fähigkeiten c. Anzahl der angebotenen Schulungsprogramme
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie die aktuell verfügbaren Fähigkeiten und Kompetenzen der internen und externen Ressourcen.		2
2. Identifizieren Sie Lücken zwischen den erforderlichen und den verfügbaren Fähigkeiten. Entwickeln Sie Maßnahmenpläne, um diese Lücken auf individueller und auf kollektiver Ebene zu schließen, z. B. durch Schulung (technische und verhaltensbezogene Fähigkeiten), Rekrutierung, Stellenumbesetzung und geänderte Sourcing-Strategien.		

A. Komponente: Prozess (Forts.)	
3. Überprüfen Sie regelmäßig die Schulungsmaterialien und -programme. Stellen Sie deren Eignung für veränderte Unternehmensanforderungen sicher und überprüfen Sie deren Eignung hinsichtlich der erforderlichen Kenntnisse, Fähigkeiten und Möglichkeiten.	3
4. Bieten Sie Zugang zu Wissensrepositorien, um die Weiterentwicklung von Fähigkeiten und Kompetenzen zu unterstützen.	
5. Entwickeln Sie Schulungsprogramme, basierend auf organisatorischen und Prozessanforderungen, einschließlich der Anforderungen bezüglich Unternehmenswissen, interner Kontrolle, ethischem Verhalten, Sicherheit und Datenschutz und stellen Sie diese bereit.	
6. Führen Sie regelmäßige Reviews durch, um die Weiterentwicklung der Fähigkeiten und Kompetenzen der internen und externen Ressourcen zu beurteilen. Überprüfen Sie die Nachfolgeregelung.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016	PM2.3 Security Education/Training
ISO/IEC 27001:2013/Cor.2:2015(E)	7.2 Competence
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity V1.1, April 2018	PR.AT Awareness and Training
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.2 Awareness and training (AT-3, AT-4)
Skills Framework for the Information Age V6, 2015	SFIA and skills management – Deploy
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 17: Security Skills Assessment and Appropriate Training to Fill Gaps
Managementpraktik	Beispielmetrik
AP007.04 Bewerten und Erkennen/Belohnen der Mitarbeiterleistung Führen Sie regelmäßig und zeitnah Leistungsbewertungen anhand der individuellen Zielvorgaben, die aus Unternehmenszielen, etablierten Standards, spezifischen Aufgabenzuständigkeiten und aus dem Rahmenwerk für Fähigkeiten und Kompetenzen abgeleitet wurden, durch. Führen Sie einen Vergütungs-/Anerkennungsprozess ein, der die Erreichung von Leistungszielen belohnt.	a. Anzahl der offiziellen Feedbackgespräche und durchgeführten 360-Grad-Bewertungen b. Anzahl und Wert der Belohnungen, die an Mitarbeiter vergeben werden
Aktivitäten	Fähigkeitsstufe
1. Legen Sie individuelle Ziele vor dem Hintergrund funktionaler Ziele bzw. der Unternehmensziele fest.	2
2. Setzen Sie individuelle Ziele, die auf die relevanten I&T- und Unternehmensziele abgestimmt sind. Legen Sie den Zielen spezifische, messbare, erreichbare, relevante und zeitgebundene (SMART) Zielvorgaben zugrunde, die die für die Rolle(n) erforderlichen Kernkompetenzen, Unternehmenswerte und Fähigkeiten widerspiegeln.	
3. Geben Sie zeitnah eine Rückmeldung zur Leistung des Mitarbeiters im Vergleich zu dessen Zielen.	
4. Stellen Sie spezifische Anweisungen für die Nutzung und Speicherung persönlicher Informationen im Rahmen des Bewertungsprozesses bereit und berücksichtigen Sie dabei die einschlägigen Gesetze zum Schutz von personenbezogenen Daten sowie die jeweiligen arbeitsrechtlichen Bestimmungen.	
5. Stellen Sie die Ergebnisse der 360-Grad-Bewertungen der Leistung zusammen.	3
6. Bieten Sie eine formelle Entwicklungsplanung zur Karriere und beruflichen Weiterentwicklung auf der Grundlage der Ergebnisse eines Evaluierungsprozesses, um die Entwicklung von Kompetenzen und Möglichkeiten für die persönliche Weiterentwicklung zu fördern und die Abhängigkeit von Schlüsselpersonen zu verringern. Bieten Sie den Mitarbeitern Coaching zu Leistung und Verhalten an, wann immer es angebracht ist.	
7. Implementieren Sie einen Vergütungs-/Anerkennungsprozess, der angemessenes Engagement, den Ausbau von Kompetenzen und die Erreichung von Leistungszielen belohnt. Stellen Sie sicher, dass der Prozess konsistent und im Einklang mit den Richtlinien der Organisation angewendet wird.	
8. Implementieren und kommunizieren Sie einen Disziplinarprozess.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Skills Framework for the Information Age V6, 2015	SFIA and skills management – Develop

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
AP007.05 Planen und Verfolgen des Personaleinsatzes (für IT und Geschäftsbetrieb) Ermitteln und verfolgen Sie den aktuellen und künftigen Bedarf an Personal für Geschäftsbetrieb und IT sowie die Zuständigkeiten für die unternehmensweite I&T. Identifizieren Sie Engpässe und stellen Sie Input für Sourcing-Pläne sowie Unternehmens- und IT-Rekrutierungsprozesse bereit.		a. Anzahl der identifizierten Deckungslücken und fehlenden Fähigkeiten bei der Personalplanung b. Zeit, die pro Vollzeitäquivalent für Aufträge und Projekte aufgewendet wird
Aktivitäten		Fähigkeitsstufe
1. Erstellen und pflegen Sie eine Bestandsliste des für den Geschäftsbetrieb und für IT eingesetzten Personals.		2
2. Ermitteln Sie den derzeitigen und den künftigen Bedarf an Personal, das erforderlich ist, um die Erreichung der I&T-Ziele zu unterstützen und Services und Lösungen bereitzustellen. Stützen Sie sich dabei auf das Portfolio der aktuellen I&T-bezogenen Initiativen, das künftige Investitionsportfolio sowie Anforderungen, die sich aus dem betrieblichen Alltag ergeben.		3
3. Identifizieren Sie Engpässe und stellen Sie Input für die Sourcing-Pläne sowie für Unternehmens- und IT-Rekrutierungsprozesse bereit. Erstellen und überprüfen Sie den Personalbesetzungsplan und verfolgen Sie den tatsächlichen Einsatz.		
4. Führen Sie adäquate Aufzeichnungen zum Zeitaufwand, der sich aus den unterschiedlichen Aufgaben, Aufträgen, Services und Projekten ergibt.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Skills Framework for the Information Age V6, 2015		SFIA and skills management – Assess; Reward
Managementpraktik		Beispielmetrik
AP007.06 Managen von Vertragspersonal Stellen Sie sicher, dass Berater und Vertragspersonal, die dem Unternehmen ihre I&T-Kompetenzen zur Verfügung stellen, die Richtlinien der Organisation kennen und diese befolgen und die vereinbarten vertraglichen Anforderungen erfüllen.		a. Anteil der Vertragspartner, die das Kontrollrahmenwerk des Unternehmens unterzeichnet haben b. Häufigkeit der regelmäßigen Überprüfungen, die durchgeführt werden, um die Korrektheit und die Einhaltung der Vorschriften durch das Personal des Auftragnehmers sicherzustellen
Aktivitäten		Fähigkeitsstufe
1. Implementieren Sie Richtlinien und Verfahren für Vertragspersonal.		2
2. Verpflichten Sie Vertragspartner vor Aufnahme ihrer Vertragstätigkeit formell zur Einhaltung des I&T-Kontrollrahmenwerks des Unternehmens. Dazu gehören beispielsweise die Richtlinien für Sicherheitsüberprüfungen, die physische und logische Zugangssteuerung, die Nutzung von Einrichtungen, die Wahrung der Vertraulichkeit von Informationen und Verschwiegenheitsverpflichtungen.		
3. Informieren Sie Vertragspartner darüber, dass sich das Management das Recht vorbehält, die Nutzung sämtlicher IT-Ressourcen zu überwachen und zu kontrollieren. Dies umfasst u. a. E-Mails, Sprachnachrichten sowie sämtliche Programme und Datendateien.		
4. Stellen Sie Vertragspartnern im Rahmen der Verträge eine klare Definition ihrer Rollen und Verantwortlichkeiten bereit. Dazu gehören auch explizite Anforderungen hinsichtlich der Dokumentation der erbrachten Arbeitsleistungen nach vereinbarten Standards und in vereinbarten Formaten.		
5. Überprüfen Sie die Arbeitsleistung der Vertragspartner, und machen Sie die Freigabe von Zahlungen vom Ergebnis dieser Überprüfung abhängig.		
6. Definieren Sie alle Arbeiten, die von externen Parteien durchgeführt werden, in formellen und eindeutig geregelten Verträgen.		3
7. Führen Sie periodische Überprüfungen durch, um sicherzustellen, dass Vertragsmitarbeiter alle erforderlichen Vereinbarungen unterzeichnet und diesen zugestimmt haben.		4
8. Führen Sie periodische Überprüfungen durch, um sicherzustellen, dass die Rollen und Zugriffsrechte von Vertragspartnern angemessen sind und den Vereinbarungen entsprechen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Skills Framework for the Information Age V6, 2015		SFIA and skills management – Deploy

B. Komponente: Organisationsstrukturen																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																							
Wichtige Managementpraktik:												Chief Financial Officer						Chief Operating Officer						Chief Information Officer						Chief Technology Officer						Chief Digital Officer						Project Management Office						Leiter Personal						Chefarchitekt						Leiter Entwicklung						Leiter IT-Betrieb						Leiter IT-Administration						Service Manager						Information Security Manager						Business Continuity Manager						Datenschutzbeauftragter						Rechtsbeistand																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																	
																								A						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R						R					

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
APO07.01 Aufbauen und Aufrechterhalten einer adäquaten und angemessenen Personalbesetzung	APO01.05	Definition von Aufsichtspraktiken	Stellenbeschreibungen und Personalbeschaffungspläne	Intern
	APO06.03	- IT-Budget - Kommunikation des Budgets	Bewertung des Personalbedarfs	Intern
	EDM04.01	- Leitprinzipien für die Zuweisung von Ressourcen und Fähigkeiten - Genehmigter Ressourcenplan	Kompetenz- und Karriereentwicklungspläne	Intern APO07.02
	EDM04.03	Abhilfemaßnahmen zur Behebung von Abweichungen im Ressourcenmanagement		
	Außerhalb von COBIT	- HR-Richtlinien und -Verfahren des Unternehmens - Unternehmensziele und Zielvorgaben		
APO07.02 Identifizieren von wichtigem IT-Personal	APO07.01	Kompetenz- und Karriereentwicklungspläne	Maßnahmenpläne zur Beendigung von Arbeitsverhältnissen	Intern
			Vorgaben zu Mindesturlaub	Intern
APO07.03 Aufrechterhalten der Fähigkeiten und Kompetenzen der Mitarbeiter	APO01.08	Matrix der Zielfähigkeiten und -kompetenzen	Matrix der Fähigkeiten und Kompetenzen	APO01.05, APO14.01, BAI01.02, BAI01.04, BAI03.12
	BAI08.02	Veröffentlichte Wissensrepositorien	Pläne zur Entwicklung von Fähigkeiten	APO01.05, EDM04.01
	BAI08.03	Weitergabe von Wissen und Schulungspläne	Überprüfungsberichte	Intern
	DSS04.06	- Schulungsanforderungen - Überwachung der Ergebnisse von Fähigkeiten und Kompetenzen		
	EDM01.02	Belohnungssystemansatz		
	EDM04.03	Abhilfemaßnahmen zur Behebung von Abweichungen im Ressourcenmanagement		
	Außerhalb von COBIT	Unternehmensziele und -zielvorgaben		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
APO07.04 Bewerten und Erkennen/Belohnen der Mitarbeiterleistung	APO04.01	Anerkennungs- und Belohnungsprogramm	Pläne zur Verbesserung	Intern
	BAI05.04	Ausgerichtete HR-Leistungszielvorgaben	Leistungsbewertungen	Intern
	BAI05.06	Ergebnisse von HR-Leistungsprüfungen	Mitarbeiterziele	Intern
	DSS06.03	Zugewiesene Zugriffsrechte		
	EDM01.02	Belohnungssystemansatz		
	Außerhalb von COBIT	Unternehmensziele und -zielvorgaben		
APO07.05 Planen und Verfolgen des Personaleinsatzes (für IT und Geschäftsbetrieb)	APO06.02	Budgetzuweisungen	Bestandsaufnahme des für den Geschäftsbetrieb und für IT eingesetzten Personals	BAI01.04
	BAI01.04	Ressourcenanforderungen und Rollen	Aufzeichnungen zur Ressourcennutzung	BAI01.06
	BAI11.08	Ressourcenanforderungen für Projekte	Analyse von Ressourcendefiziten	BAI01.06
	EDM04.02	Kommunikation von Beschaffungsstrategien		
	EDM04.03	Rückmeldung zur Zuteilung und Effektivität von Ressourcen und Fähigkeiten		
	Unternehmensorganisation	Aktuelle und künftige Portfolios		
	Außerhalb von COBIT	Organisationsstruktur des Unternehmens		
APO07.06 Managen von Vertragspersonal	BAI01.04	Ressourcenanforderungen und Rollen	Überprüfung von Vertragsvereinbarungen	Intern
	BAI01.09	Kommunikation in Bezug auf die Inaktivsetzung von Programmen und weiterhin geltende Verantwortlichkeiten	Vertragsvereinbarungen	Intern
	BAI11.08	Ressourcenanforderungen für Projekte	Richtlinien für Vertragsmitarbeiter	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 9. Project resource management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Bereitstellung von Schulungen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.3. Education and Training Provision
Schulungs- und Entwicklungsmanagement	Skills Framework for the Information Age V6, 2015	ETMG
Leistungsmanagement	Skills Framework for the Information Age V6, 2015	PEMT
Personalentwicklung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.9. Personnel Development
Berufliche Entwicklung	Skills Framework for the Information Age V6, 2015	PDSV
Beschaffung	Skills Framework for the Information Age V6, 2015	RESC

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie für Vertragspersonal	Nennt Kriterien für die Erweiterung des Personals durch externe Berater und/oder Vertragspartner in Übereinstimmung mit den unternehmensweiten IT-Beschaffungsrichtlinien und dem I&T-Kontrollrahmenwerk. Legt fest, wann und welche Art von Arbeiten an Dritte unter welchen Bedingungen vergeben werden können.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.16 Personnel security (PS-1)
Richtlinien zur Personalpolitik (HR)	Beschreibt die gegenseitigen Erwartungen des Unternehmens und seiner Mitarbeiter. Fasst akzeptable und inakzeptable Verhaltensweisen von Mitarbeitern in einem Verhaltenskodex zusammen, um das Management von Risiken im Zusammenhang mit menschlichem Verhalten zu vereinfachen.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Beschreiben Sie die Rollen und Verantwortlichkeiten der Nutzer in Bezug auf Informationen, Medien- und Netzwerknutzung, Sicherheit und Datenschutz. Vermitteln und Fördern Sie eine gemeinsame Kultur, die allen Personen im Unternehmen das erwartete Verhalten vorgibt und etablieren Sie eine Null-Toleranz-Politik für unethisches Verhalten.	National Institute of Standards and Technology Special Publication 800-53, Revision 5, August 2017	3.14 Planning (PL-4)

G. Komponente: Services, Infrastruktur und Anwendungen	
• Personalmanagementsystem • System zur Leistungsmessung (z. B. Balanced Scorecard, Werkzeuge zum Management der Fähigkeiten) • Werkzeuge zur Ressourcenplanung	

Domäne: Anpassen, Planen und Organisieren Managementziel: APO08 – Beziehungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Management der Beziehungen zu den geschäftsseitigen Anspruchsgruppen in einer formellen und transparenten Weise, die gegenseitiges Vertrauen bei gleichzeitiger Konzentration auf die Erreichung der strategischen Ziele unter Berücksichtigung budgetärer Beschränkungen und der Risikotoleranz gewährleistet. Aufbau von Beziehungen auf der Basis offener und transparenter Kommunikation, einer gemeinsamen Sprache und auf der Bereitschaft zur Übernahme von Eigenverantwortung und Verantwortung für wichtige Entscheidungen auf beiden Seiten. Zusammenarbeit von Geschäft und IT, um bessere Unternehmensergebnisse im Hinblick auf die Unterstützung der Unternehmensziele zu erzielen.		
Zweck		
Bereitstellung der geeigneten Kenntnisse, Fähigkeiten und Verhaltensweisen, um bessere Ergebnisse, größeres (gegenseitiges) Vertrauen und eine effektive Nutzung der Ressourcen zu erreichen, um eine produktive Beziehung zu den Anspruchsgruppen des Unternehmens aufzubauen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG10 Fähigkeiten, Motivation und Produktivität der Mitarbeiter • EG13 Produkt- und Geschäftsinnovation		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen • AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG12 Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft • AG13 Wissen, Know-how und Initiativen für geschäftliche Innovationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG10 a. Mitarbeiterproduktivität im Vergleich zu Benchmarks b. Grad der Zufriedenheit der Anspruchsgruppen mit den Fachkenntnissen und den Fähigkeiten der Mitarbeiter b. Anteil des Personals, dessen Fähigkeiten nicht ausreichen, um seine Rolle kompetent wahrzunehmen d. Anteil zufriedener Mitarbeiter		AG12 a. Anteil von I&T-erfahrenen Fachbereichsmitarbeitern (d. h. Personen, die über das erforderliche I&T-Wissen und -Verständnis verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten in ihrem Fachgebiet zu erkennen) b. Anteil der fachlich erfahrenen I&T-Mitarbeiter (d. h. Personen, die über das erforderliche Wissen und Verständnis der relevanten Geschäftsbereiche verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten für den Geschäftsbereich zu erkennen) c. Anzahl oder Anteil der Mitarbeiter mit Erfahrung im Technologiemanagement
EG13 a. Grad des Bewusstseins und Verständnisses für geschäftliche Innovationsmöglichkeiten b. Zufriedenheit der Anspruchsgruppen mit dem Grad der Produkt- und Innovationskompetenz und der Entwicklung von neuen Ideen c. Anzahl der genehmigten Produkt- und Serviceinitiativen, die aus innovativen Ideen resultieren		AG13 a. Grad des Bewusstseins von Führungskräften und des Verständnisses für Innovationsmöglichkeiten im Bereich I&T b. Anzahl der genehmigten Initiativen, die aus innovativen I&T-Ideen resultieren c. Anzahl der anerkannten/ausgezeichneten Innovations-Champions

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
AP008.01 Verstehen der geschäftlichen Erwartungen Ermitteln Sie aktuelle geschäftliche Probleme, Zielvorgaben und Erwartungen in Bezug auf I&T. Stellen Sie sicher, dass Anforderungen verstanden, gemanagt und kommuniziert werden und dass ihr Status abgestimmt und genehmigt wird.		a. Anzahl der identifizierten aktuellen geschäftlichen Probleme b. Anzahl der definierten Geschäftsanforderungen für I&T-gestützte Services
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie die geschäftlichen Anspruchsgruppen sowie ihre Interessen und Verantwortungsbereiche.		2
2. Überprüfen Sie die aktuelle Ausrichtung, die Probleme und die strategischen Zielvorgaben des Unternehmens und deren Ausrichtung an der Unternehmensarchitektur.		
3. Machen Sie sich mit dem derzeitigen geschäftlichen Umfeld, den Prozesseinschränkungen bzw. -problemen, Fragestellungen zur geographischen Erweiterung oder Verkleinerung und den industriellen/behördlichen Treibern vertraut.		
4. Behalten Sie einen Überblick über die Geschäftsprozesse und die damit verbundenen Aktivitäten. Machen Sie sich mit Bedarfsmustern in Bezug auf Servicevolumen und -nutzung vertraut.		
5. Managen Sie Erwartungen, indem Sie sicherstellen, dass die Geschäftsbereiche die Prioritäten, Abhängigkeiten, finanziellen Einschränkungen und die Notwendigkeit der Planung von Anforderungen verstehen.		3
6. Klären Sie geschäftliche Erwartungen an I&T-gestützte Services und Lösungen. Stellen Sie sicher, dass die Anforderungen anhand von entsprechenden geschäftlichen Abnahmekriterien und Metriken definiert werden.		4
7. Stellen Sie die Zustimmung der IT und der Fachabteilungen zu den Erwartungen und deren Messung sicher. Stellen Sie ebenfalls sicher, dass diese Vereinbarung von allen Anspruchsgruppen bestätigt wird.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP008.02 Ausrichten der I&T-Strategie an den Geschäftserwartungen und Identifizieren von Möglichkeiten für die IT, das Geschäft zu verbessern Richten Sie die I&T-Strategie an den aktuellen Geschäftszielen und Erwartungen aus, um die IT in die Lage zu versetzen, ein wertschöpfender Partner innerhalb des Unternehmens und eine Governance-Komponente zur Verbesserung der Unternehmensleistung zu sein.		a. Umfang der Berücksichtigung von Technologiemöglichkeiten in Investitionsvorschlägen b. Befragung von geschäftlichen Anspruchsgruppen hinsichtlich ihres technologischen Bewusstseins
Aktivitäten		Fähigkeitsstufe
1. Positionieren Sie die IT als Partner des Unternehmens. Nehmen Sie eine proaktive Rolle bei der Identifizierung von Chancen, Risiken und Einschränkungen sowie bei der diesbezüglichen Kommunikation mit wichtigen Anspruchsgruppen ein. Dazu gehören aktuelle und aufkommende Technologien, Services und Geschäftsprozessmodelle.		3
2. Arbeiten Sie bei wichtigen neuen Initiativen mit dem Portfolio-, Programm- und Projektmanagement zusammen. Stellen Sie sicher, dass die IT-Organisation bei Einleitung einer neuen Initiative durch Untertützung in Form von Beratung und Empfehlungen (z. B. Entwicklung von Business Cases, Definition von Anforderungen, Lösungskonzept) und durch die Übernahme von Verantwortung für die I&T-Arbeitsabläufe einbezogen wird.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011		Service Strategy, 4.4 Demand management
Managementpraktik		Beispielmetrik
AP008.03 Managen der Beziehung zum Geschäft (Business) Managen Sie die Beziehung zwischen der IT-Service-Organisation und den geschäftlichen Ansprechpartnern. Stellen Sie sicher, dass die Rollen und Zuständigkeiten im Rahmen von Beziehungen definiert und zugewiesen sind und die Kommunikation unterstützt wird.		a. Bewertungen aus Umfragen zur Benutzer- und IT-Mitarbeiterzufriedenheit b. Anteil der Rollen und Zuständigkeiten im Rahmen von Beziehungen, die definiert, zugewiesen und kommuniziert sind

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Bestimmen Sie für jeden wichtigen Geschäftsbereich einen Relationship Manager, der als zentraler Ansprechpartner fungiert. Stellen Sie sicher, dass in der Geschäftsorganisation ein Ansprechpartner identifiziert wird, der das erforderliche geschäftliche Verständnis und ausreichende Technologiekenntnisse mitbringt und über ein ausreichendes Maß an Autorität verfügt.	3
2. Managen Sie die Beziehung auf formelle und transparente Weise, sodass die Erreichung eines gemeinsamen Ziels in Form von erfolgreichen Unternehmensergebnissen, bei gleichzeitiger Unterstützung strategischer Ziele und Berücksichtigung budgetärer Einschränkungen und der Risikotoleranz, im Mittelpunkt steht.	
3. Definieren und kommunizieren Sie ein Beschwerde- und Eskalationsverfahren, um etwaige Probleme innerhalb der Beziehung zu lösen.	
4. Stellen Sie sicher, dass wichtige Entscheidungen abgestimmt und von den relevanten verantwortlichen Anspruchsgruppen genehmigt werden.	
5. Planen Sie spezifische Interaktionen und Zeitvorgaben auf der Basis gemeinsam vereinbarter Zielvorgaben und einer gemeinsamen Sprache (Review-Besprechungen zu Services und Leistung, Überprüfung neuer Strategien oder Pläne usw.).	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)	7.1 Business relationship management
ITIL V3, 2011	Service Strategy, 4.5 Business relationship management
Managementpraktik	Beispielmetrik
AP008.04 Koordinieren und Kommunizieren Arbeiten Sie mit allen relevanten Anspruchsgruppen zusammen und koordinieren Sie die durchgängige Bereitstellung von I&T-Services und -Lösungen für das Geschäft.	a. Zeit seit der letzten Aktualisierung des integrierten Kommunikationsplans für das Unternehmen b. Grad der Zufriedenheit der Geschäftsverantwortlichen mit der Koordination der durchgängigen Bereitstellung von I&T-Services und -Lösungen
Aktivitäten	Fähigkeitsstufe
1. Koordinieren und kommunizieren Sie Änderungen und Übergangsaktivitäten, wie z. B. Projekt- oder Änderungspläne, Zeitpläne, Release-Richtlinien, Veröffentlichung von bekannten Fehlern und Schulungsmaßnahmen.	2
2. Koordinieren und kommunizieren Sie betrieblliche Aktivitäten, Rollen und Zuständigkeiten, einschließlich der Definition von Anforderungstypen, der hierarchischen Eskalation, wichtiger (geplanter und ungeplanter) Ausfallzeiten sowie des Inhalts und der Häufigkeit von Serviceberichten.	
3. Übernehmen Sie bei wichtigen Ereignissen, die sich auf die Beziehung zum Kerngeschäft auswirken könnten, die Verantwortung für die Reaktion gegenüber diesem. Stellen Sie ggf. unmittelbare Unterstützung bereit.	
4. Pflegen Sie einen integrierten Kommunikationsplan, in dem der Inhalt, die Häufigkeit und die Empfänger von Servicebereitstellungsinformationen, einschließlich des Status des gelieferten Wertbeitrags und eventuell identifizierte Risiken, definiert sind.	3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
AP008.05 Bereitstellen von Input für die kontinuierliche Verbesserung von Services Sorgen Sie für eine kontinuierliche Verbesserung und Weiterentwicklung von I&T-gestützten Services und der Servicebereitstellung gegenüber dem Unternehmen, um eine Anpassung an sich ändernde Unternehmensziele und Technologien zu ermöglichen	a. Anteil der an die Geschäftsanforderungen des Unternehmens angepassten I&T-Services b. Anteil der identifizierten und beseitigten Ursachen von Problemen

A. Komponente: Prozess	
Aktivitäten	Fähigkeitsstufe
1. Führen Sie eine Analyse der Kunden- und Anbieterzufriedenheit durch. Stellen Sie sicher, dass Problemen aktiv nachgegangen wird und melden Sie Ergebnisse und Status.	4
2. Identifizieren, kommunizieren und implementieren Sie gemeinsam Verbesserungsinitiativen.	5
3. Arbeiten Sie mit den Servicemanagement- und Prozessverantwortlichen zusammen, um sicherzustellen, dass I&T-gestützte Services und Servicemanagementprozesse kontinuierlich verbessert und die Ursachen etwaiger Probleme identifiziert und beseitigt werden.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen																
Wichtige Managementpraktik:																
	Chief Executive Officer	Chief Financial Officer	Chief Operating Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Relationship Manager	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter
				A	R	R		R	R		R	R	R	R	R	R
				A	R	R	R	R	R	R	R	R	R			
	R	R	R	A	R	R		R	R		R	R	R			
	R	R	R	A	R	R		R	R		R	R	R			
				A	R	R		R	R		R	R	R			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen														
Keine entsprechenden weiteren Quellen für diese Komponente																

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO08.01 Verstehen der geschäftlichen Erwartungen	Von	Beschreibung	Beschreibung	Für
	APO02.05	Strategische Roadmap	Abgestimmte und vereinbarte geschäftliche Erwartungen	Intern
APO08.02 Ausrichten der IT-Strategie an den Geschäftserwartungen und Identifizieren von Möglichkeiten für die IT, das Geschäft zu verbessern	APO09.01	Identifizierte Lücken bei den IT-Services für das Unternehmen	Vereinbarte nächste Schritte und Aktionspläne	Intern
	APO09.04	- Service-Level-Leistungsberichte - Aktionspläne zur Verbesserung und Abhilfemaßnahmen		
	APO11.03	Grundursachen für Qualitätsmängel		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO08.03 Managen der Beziehung zum Geschäft (Business)	DSS02.02	Klassifizierte und priorisierte Störungen und Serviceanfragen	Beschwerde- und Eskalationsstatus	Intern
	DSS02.06	• Geschlossene Serviceanfragen und Störungen • Bestätigung der zufriedenstellenden Erfüllung oder Lösung seitens des Benutzers	Vereinbarte wichtige Entscheidungen	Intern
	DSS02.07	• Bericht über Störungstatus und Trends • Bericht über den Status der Erfüllung von Anforderungen und Trends		
Managementpraktik	Inputs		Outputs	
APO08.04 Koordinieren und Kommunizieren	Von	Beschreibung	Beschreibung	Für
	APO09.03	Service Level Vereinbarungen (SLAs)	Kundenrückmeldungen	Intern
	APO12.06	Kommunikation der Risikoauswirkungen	Kommunikationspakete	Intern
	BAI05.05	Betriebs- und Nutzungsplan	Kommunikationsplan	Intern
	BAI07.07	Plan für zusätzlichen Support		
	BAI09.02	Mitteilungen über geplante Wartungsausfallzeiten		
	DSS03.04	Kommunikation des erlernten Wissens		
APO08.05 Bereitstellen von Input für die kontinuierliche Verbesserung von Services	APO09.02	Servicekataloge	Definition potenzieller Verbesserungsprojekte	APO02.02, BAI03.11
	APO11.02	• Kundenanforderungen an das Qualitätsmanagement • Ergebnisse der Servicequalität, einschließlich Kundenfeedback	Zufriedenheitsanalysen	APO09.04
	APO11.03	Ergebnisse der Qualitätsüberwachung für die Lösungs- und Servicebereitstellung		
	APO11.04	Ergebnisse von Qualitätsprüfungen und Audits		
	BAI03.10	Wartungsplan		
	BAI05.05	Erfolgskennzahlen und Ergebnisse		
	BAI07.07	Plan für zusätzlichen Support		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Beziehungsmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.4. Beziehungsmanagement
Beziehungsmanagement	Skills Framework for the Information Age V6, 2015	RLMT

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Beziehungsmanagement zwischen Geschäft und IT	Stellt Richtlinien für den Aufbau und die Pflege von Beziehungen zwischen Geschäft und IT bereit. Fördert Transparenz, gegenseitiges Vertrauen und einen gemeinsamen Fokus auf das Erreichen strategischer Ziele unter Berücksichtigung von Budget und Risikotoleranz.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur, die auf gegenseitigem Vertrauen, transparenter Kommunikation, verständlichen Begriffen, einer offenen und gemeinsamen Sprache, Eigenverantwortung und Verantwortlichkeit beruht. Es ist wichtig, dass gute Beziehungen zwischen Geschäft und IT innerhalb des Unternehmens bestehen, um ein gemeinsames Ziel zu erreichen.		

G. Komponente: Services, Infrastruktur und Anwendungen

- Plattformen zur Zusammenarbeit
- Unterstützung bei internen Schulungen und der Schaffung von Bewusstsein

Domäne: Anpassen, Planen und Organisieren Managementziel: APO09 – Servicevereinbarungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Ausrichtung der I&T-gestützten Produkte und Services (inkl. Service Levels) auf die Bedürfnisse und Erwartungen des Unternehmens. Dies umfasst auch die Identifizierung, Spezifikation, Gestaltung, Veröffentlichung, Vereinbarung und Überwachung von I&T-Produkten und -Services, Service Levels und Leistungsindikatoren.		
Zweck		
Sicherstellung, dass I&T-Produkte, Services und Service Levels den aktuellen und zukünftigen Bedürfnissen des Unternehmens entsprechen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
APO09.01 Identifizieren von I&T-Services Analysieren Sie die geschäftlichen Anforderungen und den Grad der Unterstützung von Geschäftsprozessen durch I&T-gestützte Services und Service Levels. Erörtern und vereinbaren Sie mit den Geschäftsbe- reichen potenzielle Services und Service Levels. Vergleichen Sie poten- zielle Service Levels mit dem aktuellen Serviceportfolio und identifi- zieren Sie neue oder geänderte Services oder Service-Level-Optionen.		a. Anzahl der Geschäftsaktivitäten, die von keinem I&T-Service unter- stützt werden b. Anzahl der identifizierten veralteten Services
Aktivitäten		Fähigkeitsstufe
1. Beurteilen Sie aktuelle I&T-Services und Service Levels, um Lücken zwischen den bestehenden Services und den von ihnen unterstützten Geschäftsaktivitäten zu ermitteln. Identifizieren Sie verbesserungsfähige Bereiche innerhalb der bestehenden Services und Service-Level-Optionen.		2
2. Analysieren, untersuchen und schätzen Sie die künftige Nachfrage und überprüfen Sie die Kapazität der bestehenden I&T-ge- stützten Services.		3
3. Analysieren Sie Geschäftsprozessaktivitäten, um den Bedarf an neuen oder überarbeiteten I&T-Services zu ermitteln.		
4. Vergleichen Sie die identifizierten Anforderungen mit den bestehenden Servicekomponenten des Portfolios. Bündeln Sie, soweit möglich, bestehende Servicekomponenten (I&T-Services, Service-Level-Optionen und Servicepakete) zu neuen Servicepaketen, um identifizierte Geschäftsanforderungen zu erfüllen.		
5. Überprüfen Sie das Portfolio der I&T-Services gemeinsam mit dem Portfolio Management und dem Business Relationship Management regelmäßig auf veraltete Services. Verständigen Sie sich auf die Inaktivsetzung von Services und schlagen Sie Änderungen vor.		

A. Komponente: Prozess (Forts.)		
6. Gleichen Sie ggf. Nachfrage und Servicepakete ab und erstellen Sie standardisierte Services um die Effizienzen zu steigern.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ITIL V3, 2011	Service Strategy, 4.4 Demand management	
Managementpraktik	Beispielmetrik	
AP009.02 Katalogisieren I&T-gestützter Services Definieren und pflegen Sie einen oder mehrere Servicekataloge für die jeweiligen Zielgruppen. Veröffentlichen und pflegen Sie aktive I&T-gestützte Services in den Servicekatalogen.	a. Anteil der angebotenen aktiven I&T-gestützten Services und Servicepakete am Portfolio b. Zeit seit der letzten Aktualisierung des Serviceportfolios	
Aktivitäten		Fähigkeitsstufe
1. Veröffentlichen Sie in den Katalogen relevante, aktive I&T-gestützte Services, Servicepakete und Service-Level-Optionen aus dem Portfolio.		2
2. Stellen Sie kontinuierlich sicher, dass die Servicekomponenten im Portfolio und die zugehörigen Servicekataloge vollständig und auf dem neuesten Stand sind.		3
3. Informieren Sie das Business Relationship Management über Aktualisierungen in den Servicekatalogen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ITIL V3, 2011	Service Design, 4.2 Service Catalogue Management	
Managementpraktik	Beispielmetrik	
AP009.03 Definieren und Erstellen von Servicevereinbarungen Definieren und erstellen Sie Servicevereinbarungen, die auf den Optionen der Servicekataloge basieren. Beziehen Sie interne betriebliche Vereinbarungen mit ein.	a. Anzahl von Geschäftsprozessen mit nicht definierten Servicevereinbarungen b. Anteil der aktiven IT-Services, die durch Servicevereinbarungen abgedeckt sind	
Aktivitäten		Fähigkeitsstufe
1. Analysieren Sie Anforderungen für neue oder geänderte Servicevereinbarungen von Seiten des Business Relationship Managements, um sicherzustellen, dass die Anforderungen erfüllt werden können. Erwägen Sie Aspekte, wie z. B. Servicezeiten, Verfügbarkeit, Leistung, Kapazität, Sicherheit, Kontinuität, Compliance und regulatorische Aspekte, Nutzbarkeit, Nachfrageeinschränkungen und Datenqualität.		2
2. Entwerfen Sie Kundenservicevereinbarungen, die auf den Services, Servicepaketen und Service-Level-Optionen in den jeweiligen Servicekatalogen basieren.		
3. Stellen Sie die Kundenservicevereinbarungen gemeinsam mit dem Business Relationship Management fertig.		
4. Bestimmen, vereinbaren und dokumentieren Sie ggf. interne betriebliche Vereinbarungen, um die Kundenservicevereinbarungen zu untermauern.		3
5. Setzen Sie sich mit dem Lieferantenmanagement in Verbindung, um sicherzustellen, dass die Kundenservicevereinbarungen ggf. durch geeignete Verträge mit externen Serviceanbietern sichergestellt werden.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016	SY2.1 Service Level Agreements	
ISO/IEC 20000-1:2011(E)	4.5 Establish and improve the SMS; 6.1 Service level management	
ITIL V3, 2011	Service Design, 4.3 Service Level Management	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.18 System and services acquisition (SA-9)	
Managementpraktik	Beispielmetrik	
AP009.04 Überwachen und Berichten von Service Levels Überwachen Sie Service Levels, berichten Sie über deren Erreichung, und ermitteln Sie Trends. Stellen Sie geeignete Managementinformationen bereit, um die Leistungssteuerung zu unterstützen.	a. Anzahl und Schweregrad von Serviceverstößen b. Anteil der Kunden, die mit der Servicebereitstellung zufrieden sind, da diese den vereinbarten Service Levels entspricht c. Anteil der erreichten Serviceziele d. Anteil der Services, die mittels Service Level überwacht werden	

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Legen Sie Kennzahlen zur Überwachung und Erfassung von Service-Level-Informationen fest und halten Sie diese aktuell.	4
2. Bewerten Sie die Leistung und erstellen Sie regelmäßig einen formellen Bericht über die Leistung der Servicevereinbarung, und machen Sie auch Angaben zu Abweichungen von den vereinbarten Werten. Lassen Sie diesen Bericht dem Business Relationship Management zukommen.	
3. Führen Sie regelmäßige Überprüfungen durch, um Trends in Bezug auf die Service-Level-Leistung zu prognostizieren und zu identifizieren. Beziehen Sie Praktiken zum Qualitätsmanagement in die Serviceüberwachung mit ein.	
4. Stellen Sie geeignete Managementinformationen bereit, um die Leistungssteuerung zu unterstützen.	
5. Vereinbaren Sie für Leistungsprobleme oder negative Trends Aktionspläne und Abhilfemaßnahmen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
HITRUST CSF Version 9, September 2017	09.02 Control Third Party Service Delivery
ISO/IEC 20000-1:2011(E)	6.2 Service Reporting (Serviceberichte)
Managementpraktik	Beispielmetrik
AP009.05 Überprüfen von Servicevereinbarungen und -verträgen Überprüfen Sie die Servicevereinbarungen regelmäßig und überarbeiten Sie diese gegebenenfalls.	a. Anzahl der durchgeführten Überprüfungen der Servicevereinbarungen b. Anteil der erreichten Serviceziele c. Anteil der Anspruchsgruppen, die mit der Qualität der Servicevereinbarungen zufrieden sind d. Anzahl der überprüften Servicevereinbarungen, sofern erforderlich
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie Servicevereinbarungen regelmäßig anhand der vereinbarten Bedingungen, um sicherzustellen, dass sie effektiv und aktuell sind. Berücksichtigen Sie ggf. geänderte Anforderungen, I&T-gestützte Services, Servicepakete oder Service-Level-Optionen.	3
2. Überarbeiten Sie bei Bedarf die bestehenden Servicevereinbarungen mit dem Serviceanbieter. Vereinbaren und aktualisieren Sie die internen betrieblichen Vereinbarungen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen											
Wichtige Managementpraktik:											
AP009.01 Identifizieren von I&T-Services	R	R	A		R			R			
AP009.02 Katalogisieren I&T-gestützter Services		R	A	R				R			
AP009.03 Definieren und Erstellen von Servicevereinbarungen		R	A			R	R	R	R	R	R
AP009.04 Überwachen und Berichten von Service Levels		R	A		R			R			R
AP009.05 Überprüfen von Servicevereinbarungen und -verträgen	R	A	R			R	R	R			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen										
ISO/IEC 20000-1:2011(E)	4.1.1 Management commitment										

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO09.01 Identifizieren von I&T-Services	Von	Beschreibung	Beschreibung	Für
			Identifizierte Lücken bei den I&T-Services für das Unternehmen	APO01.10, APO02.02, APO05.02, APO08.02
			Definitionen von Standard-services	EDM02.01
APO09.02 Katalogisieren I&T-gestützter Services	APO05.04	Aktualisierte Portfolios von Programmen, Services und Betriebsmitteln	Servicekataloge	APO08.05
	EDM04.01	Genehmigter Ressourcenplan		
	EDM04.02	Kommunikation von Beschaffungsstrategien		
APO09.03 Definieren und Erstellen von Servicevereinbarungen	APO11.02	Kundenanforderungen an das Qualitätsmanagement	Service Level Vereinbarungen (SLAs)	APO05.02, APO08.04, DSS01.02, DSS02.01, DSS02.02, DSS04.01, DSS05.02, DSS05.03
	APO14.07	Anforderungen an die Datenqualität	Operational Level Vereinbarungen (OLAs)	DSS01.02, DSS02.07, DSS04.03, DSS05.03

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO09.04 Überwachen und Berichten von Service Levels	APO05.03	Investitionsportfolio-Leistungsberichte	Verbesserungspläne und Abhilfemaßnahmen	APO02.02, APO08.02
	APO05.05	• Resultierender Nutzen und zugehörige Kommunikation • Korrekturmaßnahmen zur Verbesserung der Nutzenrealisierung	Service-Level-Leistungsberichte	APO08.02, MEA01.03
	APO08.05	Zufriedenheitsanalysen		
	APO11.03	• Ergebnisse der Qualitätsüberwachung für die Lösungs- und Servicebereitstellung • Grundursachen für Qualitätsmängel bei der Bereitstellung		
	APO11.04	Ergebnisse von Qualitätsprüfungen und Audits		
	DSS02.02	Klassifizierte und priorisierte Störungen und Serviceanfragen		
	DSS02.06	Geschlossene Serviceanfragen und Störungen		
	DSS02.07	• Bericht über Störungstatus und Trends • Status der Antrags-erfüllung und Trendbericht		
	EDM04.03	Abhilfemaßnahmen zur Behebung von Abweichungen im Ressourcenmanagement		
Managementpraktik	Inputs		Outputs	
APO09.05 Überprüfen von Servicevereinbarungen und -verträgen	Von	Beschreibung	Beschreibung	Für
	APO11.02	Ergebnisse zur Servicequalität, einschließlich Kundenfeedback	Aktualisierte SLAs	Intern
	APO11.04	Ergebnisse von Qualitätsprüfungen und Audits		
	BAI04.01	Auswertungen gegen SLAs		
	EDM04.03	Rückmeldung zur Zuteilung und Effektivität von Ressourcen und Fähigkeiten		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 12. Project procurement management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Service-Level-Management	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.2. Service Level Management
Service-Level-Management	Skills Framework for the Information Age V6, 2015	SLMO

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Service-Level-Vereinbarung (SLA)	Beschreibt allgemeine Standards und Kriterien zur Information über spezifische Anforderungen und Bedingungen für die Erbringung von Services, sei es zwischen Einheiten innerhalb des Unternehmens oder zwischen dem Unternehmen und einer dritten Partei.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schließen Sie einen Vertrag zwischen einem Dienstleister (intern oder extern) und dem Endbenutzer, der das erwartete Serviceniveau definiert. Stellen Sie sicher, dass dieses Serviceniveau auf dem Output basiert, der unter Nutzung von SMART-Zielen (spezifisch, messbar, erreichbar, realistisch und terminiert) definiert wird. Etablieren Sie eine Kultur, in der das Serviceniveau eingehalten wird. Vermeiden Sie die Nichteinhaltung durch ein Sanktionssystem.		

G. Komponente: Services, Infrastruktur und Anwendungen

- Vertragsmanagementsystem
- Werkzeuge zur Überwachung der Service Level

Domäne: Anpassen, Planen und Organisieren Managementziel: APO10 – Lieferanten sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Management der von allen Arten von Lieferanten bereitgestellten I&T-bezogenen Produkte und Services, um den Unternehmensanforderungen gerecht zu werden. Dies umfasst die Suche und Auswahl von Lieferanten, das Management von Beziehungen und Verträgen sowie die Überprüfung und Überwachung der Lieferantenleistung und des Lieferantenökosystems (einschließlich der vorgelagerten Lieferkette) hinsichtlich Effektivität und Compliance.		
Zweck		
Optimierung der verfügbaren I&T-Befähigungen zur Unterstützung der I&T-Strategie und Roadmap, Minimierung des Risikos einer unzureichenden oder nichtkonformen Lieferantenleistung und Sicherstellung einer wettbewerbsfähigen Preisgestaltung.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
APO10.01 Identifizieren und Evaluieren der Lieferantenbeziehungen und -verträge Suchen und identifizieren Sie kontinuierlich Lieferanten und kategorisieren Sie sie nach Art, Wichtigkeit und Kritikalität. Legen Sie Kriterien zur Bewertung von Lieferanten und Verträgen fest. Bewerten Sie das Gesamtportfolio an bestehenden und alternativen Lieferanten und Verträgen.	a. Anteil der definierten Bewertungskriterien, die durch bestehende Lieferanten und Verträge erfüllt werden b. Anteil von alternativen Lieferanten, die gleichwertige Services wie die bestehenden Lieferanten anbieten	
Aktivitäten	Fähigkeitsstufe	
1. Suchen Sie im Unternehmensumfeld kontinuierlich nach neuen Partnern und Lieferanten, die ergänzende Leistungen anbieten und die Umsetzung der I&T-Strategie, der Roadmap und der Unternehmensziele unterstützen können.	3	
2. Definieren und pflegen Sie Kriterien, die sich auf Art, Wichtigkeit und Kritizität von Lieferanten und Lieferantenverträgen beziehen, um den Fokus auf bevorzugte und wichtige Lieferanten richten zu können.		
3. Identifizieren, erfassen und kategorisieren Sie bestehende Lieferanten und Verträge anhand von definierten Kriterien, um ein ausführliches Register der bevorzugten Lieferanten, die es sorgsam zu managen gilt, zu führen.		

A. Komponente: Prozess (Forts.)		
4. Legen Sie Kriterien für die Bewertung von Lieferanten und Verträgen fest, um eine allgemeine Überprüfung und einen konsistenten Vergleich der Lieferantenleistung zu ermöglichen.		4
5. Bewerten und vergleichen Sie regelmäßig die Leistung bestehender und alternativer Lieferanten, um neue Möglichkeiten oder zwingende Gründe für die Überprüfung der aktuellen Lieferantenverträge zu identifizieren.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP010.02 Auswählen von Lieferanten Wählen Sie Lieferanten nach einer fairen und formellen Praktik aus, um, basierend auf zuvor festgelegten Anforderungen, eine optimale und nutzbare Eignung sicherzustellen. Die Anforderungen sollten unter Berücksichtigung des Inputs potenzieller Lieferanten optimiert werden.		a. Anzahl der festgestellten Abweichungen zwischen dem Angebot des ausgewählten Lieferanten und den in der Angebotsaufforderung (RFP) angegebenen Anforderungen b. Anteil der Anspruchsgruppen, die mit den Lieferanten zufrieden sind
Aktivitäten		Fähigkeitsstufe
1. Überprüfen Sie alle Informationsanfragen (RFIs) und Angebotsaufforderungen (RFPs), um sicherzustellen, dass die Anforderungen klar definiert sind (z. B. Unternehmensanforderungen hinsichtlich Datenschutz, operative Anforderungen hinsichtlich Geschäftsbetrieb und I&T-Verarbeitung, Prioritäten für die Serviceerbringung) und ein Verfahren zur Klarstellung der Anforderungen umfassen. Die RFIs und RFPs sollten den Lieferanten genügend Zeit für die Vorbereitung ihrer Angebote einräumen und die Vergabekriterien und den Entscheidungsprozess klar definieren.		2
2. Bewerten Sie die RFIs und RFPs anhand des genehmigten Bewertungsprozesses bzw. der genehmigten Kriterien und führen Sie einen dokumentierten Nachweis über die Bewertungen. Überprüfen Sie die Referenzen von Lieferantenanwärtern.		
3. Wählen Sie den Lieferanten aus, der die Anforderungen im RFP am besten erfüllt. Dokumentieren und kommunizieren Sie die Entscheidung und unterzeichnen Sie den Vertrag.		
4. Nehmen Sie im besonderen Fall eines Softwareerwerbs, die Rechte und Pflichten aller Parteien in die Vertragsbedingungen auf und sorgen Sie für deren Wahrnehmung. Diese Rechte und Pflichten können sich beispielsweise auf Besitz und Lizenzierung von geistigem Eigentum, auf Wartung, Garantien, Schiedsverfahren, Aktualisierungsbedingungen, Zweckdienlichkeit sowie auf Sicherheit, Datenschutz, Treuhandbestimmungen und Zugriffsrechte beziehen.		3
5. Nehmen Sie im besonderen Fall eines Erwerbs von Entwicklungsressourcen, die Rechte und Pflichten aller Parteien in die Vertragsbedingungen auf und sorgen Sie für deren Wahrnehmung. Diese Rechte und Pflichten können sich beispielsweise auf Besitz und Lizenzierung von geistigem Eigentum, auf Zweckdienlichkeit, einschließlich Entwicklungsmethodologien, auf Tests, Qualitätsmanagement-Prozesse, einschließlich der erforderlichen Leistungskriterien, auf Leistungsüberprüfungen, Zahlungsgrundlagen, Garantien, Schiedsverfahren, HR-Management sowie auf die Compliance mit den Richtlinien des Unternehmens beziehen.		
6. Holen Sie sich rechtlichen Rat in Bezug auf Vereinbarungen ein, die sich auf die Akquisition von Entwicklungsressourcen und den Besitz und die Lizenzierung von geistigem Eigentum beziehen.		
7. Nehmen Sie im besonderen Fall eines Erwerbs von Infrastrukturen, Einrichtungen und zugehörigen Services, die Rechte und Pflichten aller Parteien in die Vertragsbedingungen auf und sorgen Sie für deren Wahrnehmung. Diese Rechte und Pflichten können sich beispielsweise auf Service Levels, Wartungsverfahren, Zugangskontrollen, Sicherheit, Datenschutz, Leistungsüberprüfungen, Zahlungsgrundlagen und Schiedsverfahren beziehen		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP010.03 Managen von Lieferantenbeziehungen und -verträgen Formalisieren und managen Sie die Beziehung mit jedem einzelnen Lieferanten. Managen, pflegen und überwachen Sie Verträge und Serviceerbringung. Stellen Sie sicher, dass neue oder geänderte Verträge den Unternehmensstandards sowie den gesetzlichen und behördlichen Anforderungen entsprechen. Legen Sie vertragliche Auseinandersetzungen bei.		a. Anteil der Drittlieferanten, deren Verträge Kontrollanforderungen enthalten b. Anzahl der formellen Streitfälle mit Lieferanten c. Anzahl der Sitzungen zur Lieferantenüberprüfung d. Anteil der Streitfälle, die innerhalb eines angemessenen Zeitrahmens einvernehmlich beigelegt wurden

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Bestimmen Sie für alle Lieferanten Beziehungsverantwortliche und übertragen Sie ihnen die Verantwortung für die Qualität der bereitgestellten Services.	3
2. Legen Sie einen formalen Kommunikations- und Überprüfungsprozess sowie Interaktionsmöglichkeiten und Termine mit Lieferanten fest.	
3. Vereinbaren, managen, pflegen und verlängern Sie Verträge mit Lieferanten. Stellen Sie sicher, dass die Verträge den Unternehmensstandards sowie den gesetzlichen und behördlichen Anforderungen entsprechen.	
4. Nehmen Sie in Verträge mit wichtigen Serviceanbietern Bestimmungen auf, die eine Überprüfung des Lieferantenunternehmens sowie der internen Praktiken und Kontrollen durch das Management oder unabhängige Dritte vorsehen. Vereinbaren Sie unabhängige Prüfungen und Kontrollen der betrieblichen Umgebungen von Outsourcing-Anbietern, um sicherzustellen, dass den vereinbarten Anforderungen adäquat entsprochen wird.	
5. Nutzen Sie etablierte Verfahren, um Vertragsstreitigkeiten zu regeln. Bauen Sie dabei, soweit möglich, immer zuerst auf eine effektive Beziehung und Kommunikation, um Probleme bei Services zu beseitigen.	
6. Definieren und formalisieren Sie Rollen und Zuständigkeiten für die einzelnen Serviceanbieter. Falls mehrere Lieferanten einen Service gemeinschaftlich anbieten, denken Sie darüber nach, einem der Lieferanten die Rolle des Hauptlieferanten zu übertragen, der für den Gesamtvertrag verantwortlich ist.	
7. Bewerten Sie die Effektivität der Beziehung und identifizieren Sie notwendige Verbesserungen.	4
8. Definieren, kommunizieren und vereinbaren Sie Methoden, um erforderliche Verbesserungen in der Beziehung zu bewirken.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)	7.2 Supplier management
ITIL V3, 2011	Service Design, 4.8 Supplier Management
Managementpraktik	Beispielmetrik
AP010.04 Managen des Lieferantenrisikos Identifizieren und managen Sie das Risiko in Verbindung mit der Fähigkeit von Lieferanten, kontinuierlich sichere, effiziente und effektive Services bereitzustellen. Das umfasst auch die Unterlieferanten oder Vorlieferanten, die für die Erbringung der Services des unmittelbaren Lieferanten zuständig sind.	a. Häufigkeit von Risikomanagement-Sitzungen mit dem Lieferanten b. Anzahl der risikobezogenen Ereignisse, die zu Servicestörungen führen c. Anteil der risikobezogenen Störungen, die akzeptabel gelöst wurden (Zeit und Kosten)
Aktivitäten	Fähigkeitsstufe
1. Berücksichtigen Sie bei der Vertragsgestaltung das potenzielle Servicerisiko, indem Sie die Serviceanforderungen klar definieren, einschließlich Software-Treuhandvereinbarungen, alternativen Lieferanten oder Standby-Vereinbarungen, um die Möglichkeit eines Lieferantenversagens zu reduzieren und indem Sie die Themen Sicherheit, Schutz des geistigen Eigentums, Datenschutz sowie rechtliche und behördliche Anforderungen eindeutig regeln.	3
2. Identifizieren, überwachen und managen Sie ggf. das Risiko in Verbindung mit der Fähigkeit des Lieferanten, Services effizient, effektiv, sicher, vertraulich, zuverlässig und kontinuierlich bereitzustellen. Verknüpfen Sie kritische interne IT-Managementprozesse mit den jeweiligen Prozessen der externen Dienstleister, z. B. Leistungs- und Kapazitätsplanung, Änderungsmanagement und Konfigurationsmanagement.	4
3. Bewerten Sie das weitere Umfeld des Lieferanten und identifizieren, überwachen und managen Sie ggf. Risiken im Zusammenhang mit Unterauftragnehmern und Vorlieferanten, die die Fähigkeit des Lieferanten beeinflussen, die Services effizient, effektiv, sicher, zuverlässig und kontinuierlich zu erbringen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	RM.MP Manage External Participation
ISF, The Standard of Good Practice for Information Security 2016	SC1.1 External Supplier Management Process
ISO/IEC 27002:2013/Cor.2:2015(E)	15. Supplier relationships
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	D.SC Supply Chain Risk Management

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmetrik
AP010.05 Überwachen der Lieferantenleistung und -Compliance Überprüfen Sie regelmäßig die Gesamtleistung der Lieferanten, die Compliance mit vertraglichen Anforderungen und das Preis-Leistungs-Verhältnis. Verfolgen Sie eventuell identifizierte Probleme.	a. Anzahl der von den Lieferanten verursachten I&T-bezogenen Serviceverstöße b. Anteil der Lieferanten, die die vereinbarten Anforderungen erfüllen
Aktivitäten	Fähigkeitsstufe
1. Fordern Sie ggf. eine unabhängige Überprüfung der internen Praktiken und Kontrollen des Lieferanten.	3
2. Definieren und dokumentieren Sie Kriterien zur Überwachung der Lieferantenleistung in Anlehnung an Service Level Agreements. Stellen Sie sicher, dass der Lieferant regelmäßig und transparent einen Bericht zu vereinbarten Kriterien erstellt.	4
3. Überwachen und überprüfen Sie die Servicebereitstellung, um sicherzustellen, dass der Lieferant eine akzeptable Servicequalität liefert, die Anforderungen erfüllt und die vertraglichen Bestimmungen einhält.	
4. Überprüfen Sie die Lieferantenleistung und das Preis-Leistungs-Verhältnis. Stellen Sie sicher, dass der Lieferant im Vergleich zu alternativen Lieferanten und gemessen an den Marktbedingungen zuverlässig und wettbewerbsfähig ist.	
5. Überwachen und bewerten Sie extern verfügbare Informationen über den Anbieter und dessen Lieferkette.	5
6. Erfassen und beurteilen Sie die Ergebnisse der Überprüfungen regelmäßig und besprechen Sie diese mit dem Lieferanten, um Erfordernisse und Verbesserungspotenziale zu identifizieren.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen													
Wichtige Managementpraktik:		Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Risikoausschuss des Unternehmens	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Datenschutzbeauftragter
	AP010.01 Identifizieren und Evaluieren der Lieferantenbeziehungen und -verträge		R	R	R	A				R			
	AP010.02 Auswählen von Lieferanten		R	R	R	A		R	R	R	R	R	
	AP010.03 Managen von Lieferantenbeziehungen und -verträgen		R	R	R	A		R	R	R	R		
	AP010.04 Managen des Lieferantenrisikos	R	R	R	R	A	R	R	R	R	R	R	
	AP010.05 Überwachen der Lieferantenleistung und -Compliance	R	R	R	R	A	R	R	R	R	R		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen											
Keine entsprechenden weiteren Quellen für diese Komponente													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO10.01 Identifizieren und Evaluieren der Lieferantenbeziehungen und -verträge	Von	Beschreibung	Beschreibung	Für
	Außerhalb von COBIT	Lieferantenverträge	Lieferantenkatalog	BAI02.02
			Eventuelle Überarbeitung von Lieferantenverträgen	Intern
			Bedeutung des Lieferanten und Bewertungskriterien	Intern
APO10.02 Auswählen von Lieferanten	BAI02.02	Akquisitions-/Entwicklungsplan	Lieferanten-RFIs und -RFPs	BAI02.01, BAI02.02
			RFI- und RFP-Auswertungen	BAI02.02
			Ergebnisse von Lieferantenbewertungen	BAI02.02, EDM04.01
APO10.03 Managen von Lieferantenbeziehungen und -verträgen	BAI03.04	Genehmigter Akquisitionsplan	Ergebnisse und Verbesserungsvorschläge	Intern
			Kommunikation und Überprüfungsprozess	Intern
			Rollen und Verantwortlichkeiten der Lieferanten	Intern
APO10.04 Managen des Lieferantenrisikos	APO12.04	• Risikoanalyse und Risikoprofilberichte für Anspruchsgruppen • Ergebnisse von Risikobewertungen Dritter	Identifiziertes Lieferanten-Liefererrisiko	AP012.01, AP012.03, BAI01.01, BAI11.01
			Identifizierte Vertragsanforderungen zur Risikominimierung	Intern
APO10.05 Überwachen der Lieferantenleistung und -Compliance			Kriterien für die Überwachung der Einhaltung durch die Lieferanten	Intern
			Überprüfungsergebnisse der Überwachung der Lieferanten-Compliance	MEA01.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Vertragsmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.8. Contract Management
Vertragsmanagement	Skills Framework for the Information Age V6, 2015	ITCM
Einkauf	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.4. Purchasing
Sourcing	Skills Framework for the Information Age V6, 2015	SORC

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
IT-Beschaffungsrichtlinie	Beschreibt Prinzipien und Verfahren für die Beschaffung von IT-Hardware, Software und Hosting-Lösungen. Detailliert Standards für Betriebssysteme, Computernetzwerke, Hardware-spezifikationen usw. Bietet Richtlinien für das Vertragsmanagement (z. B. Geschäftsbedingungen, Überwachung von Verträgen).		
Richtlinie für das Management der IT-Service-Bereitstellung durch Dritte	Stellt Leitlinien für das Management von Risiken im Zusammenhang mit Services Dritter auf. Legt einen Rahmen für die Erwartungen an das Verhalten fest und nennt Sicherheitsvorkehrungen, die von Drittanbietern beim Managen von Risiken im Zusammenhang mit bereitgestellten Services gefordert werden.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Aufbau und Managements eines Ökosystems von Anbietern, die das Unternehmen bei seiner digitalen Transformation und Innovation unterstützen können. Das umfasst auch das kontinuierliche Absuchen des Unternehmensumfelds nach neuen und effektiven Partnern.		
Das Management gibt den Ton an und veranschaulicht das richtige Verhalten bei der Kommunikation mit den Anbietern, um erforderliche Verbesserungen zu vereinbaren und umzusetzen. Stellen Sie sicher, dass die Verträge den Unternehmensstandards sowie den gesetzlichen und behördlichen Anforderungen entsprechen.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Vertragsmanagementsystem • Assurance-Dienstleistungen durch Dritte

Domäne: Anpassen, Planen und Organisieren Managementziel: APO11 – Qualität ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Definition und Kommunikation von Qualitätsanforderungen für alle Prozesse, Verfahren und die zugehörigen Unternehmensergebnisse. Ermöglichung von Kontrollen, laufender Überwachung und der Anwendung bewährter Praktiken und Standards zur kontinuierlichen Verbesserung und Effizienzsteigerung.		
Zweck		
Sicherstellung einer konsistenten Bereitstellung von Technologielösungen und Services, um die Qualitätsanforderungen des Unternehmens und die Bedürfnisse der Anspruchsgruppen zu erfüllen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen • AG10 Qualität der I&T-Managementinformationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG10 a. Grad der Zufriedenheit der Nutzer mit der Qualität, Pünktlichkeit und Verfügbarkeit von I&T-bezogenen Managementinformationen unter Berücksichtigung der verfügbaren Ressourcen b. Verhältnis und Ausmaß von falschen Geschäftsentscheidungen, bei denen fehlerhafte oder nicht verfügbare I&T-bezogene Informationen ein wesentlicher Faktor waren c. Anteil der Informationen, die die Qualitätskriterien erfüllt haben
EG07 a. Grad der Zufriedenheit der Geschäftsleitung und obersten Führungskräfte mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
AP011.01 Einrichten eines Qualitätsmanagement-Systems (QMS) Erstellen und pflegen Sie ein Qualitätsmanagement-System (QMS), das einen standardisierten, formalen und konsistenten Ansatz für das Qualitätsmanagement von Informationen bietet. Das QMS sollte Technologie- und Geschäftsprozesse ermöglichen, die an den Geschäftsanforderungen und dem Qualitätsmanagement des Unternehmens ausgerichtet sind.		a. Grad der Effektivität von Qualitätsmanagement-Reviews b. Grad der Zufriedenheit der wichtigsten Anspruchsgruppen mit dem Qualitätsmanagement-Review-Programm
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie sicher, dass das I&T-Kontrollrahmenwerk und die Geschäfts- und IT-Prozesse einen standardisierten, formalen und kontinuierlichen Qualitätsmanagementansatz umfassen, der an den Anforderungen des Unternehmens ausgerichtet ist. Identifizieren Sie innerhalb des I&T-Kontrollrahmens und der Geschäfts- und IT-Prozesse Qualitätsanforderungen und -kriterien (z. B. basierend auf gesetzlichen und Kundenanforderungen).		3
2. Definieren Sie in der Organisationsstruktur Rollen, Aufgaben, Entscheidungsbefugnisse und Zuständigkeiten für das Qualitätsmanagement.		
3. Bitten Sie bei der Festlegung der Qualitätsanforderungen und der Qualitätsmanagement-Kriterien das Management sowie externe und interne Anspruchsgruppen um Input.		
4. Überwachen und überprüfen Sie das QMS regelmäßig anhand vereinbarter Akzeptanzkriterien. Beziehen Sie Feedback von Kunden, Benutzern und Management ein.		4
5. Gehen Sie auf Abweichungen in den Überprüfungsergebnissen näher ein, um das QMS kontinuierlich zu verbessern.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 8.1 Plan quality management
Managementpraktik		Beispielmetrik
AP011.02 Ausrichten des Qualitätsmanagements am Kunden Fokussieren Sie das Qualitätsmanagement auf die Kunden, indem Sie deren Anforderungen bestimmen und die Ausrichtung an den Qualitätsmanagement-Praktiken sicherstellen.		a. Grad der Kundenzufriedenheit b. Anteil der Kundenanforderungen und -erwartungen, die in der gesamten Geschäfts- und IT-Organisation kommuniziert werden
Aktivitäten		Fähigkeitsstufe
1. Fokussieren Sie das Qualitätsmanagement auf die Kunden, indem Sie interne und externe Kundenanforderungen bestimmen und die Ausrichtung der I&T-Standards und Praktiken sicherstellen. Definieren und kommunizieren Sie Rollen und Zuständigkeiten bezüglich der Konfliktlösung zwischen dem Benutzer/Kunden und der IT-Organisation.		3
2. Managen Sie die geschäftlichen Anforderungen und Erwartungen an die einzelnen Geschäftsprozesse, operativen IT-Services und neuen Lösungen. Pflegen Sie die zugehörigen Qualitätsabnahmekriterien.		
3. Kommunizieren Sie die Anforderungen und Erwartungen der Kunden innerhalb der Geschäfts- und IT-Organisation.		
4. Holen Sie regelmäßig die Meinung der Kunden zu Geschäftsprozessen und zur Bereitstellung von IT-Services und -Lösungen ein. Bestimmen Sie die Auswirkungen auf I&T-Standards und -Praktiken und stellen Sie sicher, dass die Kundenerwartungen erfüllt und umgesetzt werden.		4
5. Erfassen Sie Qualitätsabnahmekriterien zur Einbindung in SLAs.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
AP011.03 Managen von Qualitätsstandards, -praktiken und -verfahren und integrieren von Qualitätsmanagement in Schlüsselprozesse und Lösungen Identifizieren und pflegen Sie Standards, Verfahren und Praktiken für wichtige Prozesse, um das Unternehmen bei der Erreichung der vereinbarten Qualitätsmanagementstandards zu leiten. Dies sollte in Anlehnung an die Anforderungen des I&T-Kontrollrahmenwerks erfolgen. Ziehen Sie eine Zertifizierung wichtiger Prozesse, Organisationseinheiten, Produkte oder Services in Betracht.		a. Anzahl der Prozesse mit definierten Qualitätsanforderungen b. Anzahl der Mängel, die im Vorfeld der Produktivsetzung entdeckt wurden c. Anzahl der Services mit einem formellen Plan zum Qualitätsmanagement d. Anzahl der SLAs, die Qualitätsakzeptanzkriterien enthalten
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie die Standards, Praktiken und Verfahren für das Qualitätsmanagement in Anlehnung an die Anforderungen des I&T-Kontrollrahmenwerks sowie die Kriterien und Richtlinien des Qualitätsmanagements des Unternehmens.		2
2. Integrieren Sie die erforderlichen Qualitätsmanagementpraktiken in die wichtigsten Prozesse und Lösungen in der gesamten Organisation.		3
3. Erwägen Sie die Vorteile und Kosten von Qualitätszertifizierungen.		
4. Kommunizieren Sie das Qualitätsmanagementkonzept nachhaltig (z. B. durch regelmäßige, formelle Qualitätsschulungsprogramme).		
5. Überwachen Sie Qualitätsdaten und zeichnen Sie diese auf. Greifen Sie auf bewährte Praktiken der Branche zurück, wenn Sie die Qualitätspraktiken des Unternehmens verbessern und anpassen.		4
6. Überprüfen Sie spezifische Qualitätsmanagementprozesse regelmäßig auf fortbestehende Relevanz, Effizienz und Effektivität. Überwachen Sie die Erreichung von Qualitätszielvorgaben.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 8.2 Manage quality
Managementpraktik		Beispielmetrik
AP011.04 Durchführen von Qualitätsüberwachung, Kontrollen und Überprüfungen Überwachen Sie kontinuierlich die Qualität von Prozessen und Services gemäß den Standards des Qualitätsmanagements. Definieren, planen und implementieren Sie Kennzahlen, um die Kundenzufriedenheit mit der Qualität und den durch das Qualitätsmanagementsystem (QMS) generierten Wertbeitrag zu überwachen. Die gesammelten Informationen sollten vom Prozessverantwortlichen zur Qualitätsverbesserung genutzt werden.		a. Anteil der zertifizierten Lösungen und Services b. Durchschnittliche Bewertung der Zufriedenheit der Anspruchsgruppen mit Lösungen und Services c. Anzahl der Prozesse, die über einen formellen Qualitätsmanagementbericht verfügen d. Anteil der überprüften Projekte, die die angestrebten Qualitätsziele erfüllen e. Anzahl, Robustheit und Aktualität der Risikoanalysen
Aktivitäten		Fähigkeitsstufe
1. Bereiten Sie Qualitätsprüfungen für wichtige Prozesse und Lösungen vor und führen Sie diese durch.		3
2. Überwachen Sie für diese wichtigen Prozesse und Lösungen zielorientierte Qualitätsmetriken, die an den allgemeinen Qualitätszielvorgaben ausgerichtet sind.		4
3. Stellen Sie sicher, dass Management- und Prozessverantwortliche regelmäßig die Leistung des Qualitätsmanagements anhand von definierten Qualitätsmetriken überprüfen.		
4. Analysieren Sie die Gesamtergebnisse der Leistung des Qualitätsmanagements.		
5. Melden Sie die Ergebnisse der Leistungsüberprüfung des Qualitätsmanagements und leiten Sie ggf. Verbesserungen ein.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 8.3 Control quality

Managementpraktik	Beispielmetrik
AP011.05 Sicherstellen von kontinuierlicher Verbesserung Führen und kommunizieren Sie regelmäßig einen allgemeinen Qualitätsplan, der die kontinuierliche Verbesserung fördert. Der Plan sollte die Notwendigkeit und den Nutzen einer kontinuierlichen Verbesserung definieren. Sammeln und analysieren Sie Daten zum Qualitätsmanagementsystem (QMS) und verbessern Sie dessen Effektivität. Beheben Sie nicht konforme Abweichungen, um deren Wiederholung zu vermeiden.	a. Anzahl der durchgeführten Ursachenanalysen b. Anteil der pünktlichen und vollständigen Services und Produkte
Aktivitäten	Fähigkeitsstufe
1. Richten Sie eine Plattform für den Austausch bewährter Verfahren und die Erfassung von Informationen zu Mängeln und Fehlern ein, um aus diesen lernen zu können.	2
2. Identifizieren Sie Beispiele für hervorragendes Qualitätsmanagement, die sich positiv auf andere Services und Projekte auswirken können. Teilen Sie diese mit den Teams für Service- und Projektbereitstellung, um Verbesserungen zu fördern.	3
3. Identifizieren Sie Beispiele für wiederkehrende Qualitätsmängel. Bestimmen Sie ihre Ursache, bewerten Sie die Auswirkungen und das Ergebnis und stimmen Sie mit den Teams, die für die Service- und/oder Projektbereitstellung zuständig sind, Verbesserungsmaßnahmen ab.	
4. Schulen Sie die Mitarbeiter in den Methoden und Tools für kontinuierliche Verbesserung.	
5. Führen Sie für die Ergebnisse der Qualitätsüberprüfungen Benchmarks durch, und vergleichen Sie sie mit internen historischen Daten, branchenüblichen Richtwerten, Standards und Daten vergleichbarer Unternehmen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	DE.DP Detection Processes

B. Komponente: Organisationsstrukturen

		Chief Operating Officer	Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Portfoliomanager	Programm-Manager	Projektmanager	Project Management Office	Datenmanagement	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager
Wichtige Managementpraktik:																				
AP011.01 Einrichten eines Qualitätsmanagement-Systems (QMS)		A		R		R											R	R		
AP011.02 Ausrichten des Qualitätsmanagements am Kunden				A		R		R										R		
AP011.03 Managen von Qualitätsstandards, -praktiken und -verfahren und integrieren von Qualitätsmanagement in Schlüsselprozesse und Lösungen				A	R	R		R	R	R	R	R	R	R	R	R	R	R	R	R
AP011.04 Durchführen von Qualitätsüberwachung, Kontrollen und Überprüfungen			R	A		R	R	R										R		
AP011.05 Sicherstellen von kontinuierlicher Verbesserung				A				R	R	R	R	R		R	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen																		
Keine entsprechenden weiteren Quellen für diese Komponente																				

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO11.01 Einrichten eines Qualitätsmanagement-Systems (QMS)	Von	Beschreibung	Beschreibung	Für
	Außerhalb von COBIT	Unternehmensweites Qualitätssystem	Rollen, Verantwortlichkeiten und Entscheidungsbefugnisse im Rahmen des Qualitätsmanagementsystems (QMS)	APO01.05, DSS06.03
			Qualitätsmanagementpläne	APO14.04, APO14.06, BAI01.07, BAI11.05
			Ergebnisse der QMS-Effektivitätsprüfungen	BAI03.06
APO11.02 Ausrichten des Qualitätsmanagements am Kunden	Außerhalb von COBIT	Qualitätsanforderungen von Unternehmen und Kunden	Kundenanforderungen an das Qualitätsmanagement	APO08.05, APO09.03, BAI01.07, BAI11.06
			Ergebnisse zur Servicequalität, einschließlich Kundenfeedback	APO08.05, APO09.05, BAI05.01, BAI07.07
			Akzeptanzkriterien	BAI02.01, BAI02.02
	Managementpraktik	Inputs		Outputs
APO11.03 Managen von Qualitätsstandards, -praktiken und -verfahren und integrieren von Qualitätsmanagement in Schlüsselprozesse und Lösungen	Von	Beschreibung	Beschreibung	Für
	BAI02.04	Genehmigte Qualitätsprüfungen	Qualitätsmanagementstandards	Alle APO, BAI, DSS, MEA
	Außerhalb von COBIT	• Bestehende Qualitätszertifizierungen • Bewährte Praktiken der Industrie	Grundursachen für Qualitätsmängel	APO08.02, APO09.04, BAI07.08, MEA02.04, MEA04.04
			Ergebnisse der Qualitätsüberwachung	APO08.05, APO09.04, BAI07.08
APO11.04 Durchführen von Qualitätsüberwachung, Kontrollen und Überprüfungen	BAI03.06	• Plan zur Qualitätssicherung • Ergebnisse der Qualitätsprüfung, Ausnahmen und Korrekturen	Prozessqualität von Servicezielen und Metriken	Alle APO, BAI, DSS, MEA
	DSS02.07	• Bericht über Störungstatus und Trends • Status der Antragserfüllung und Trendbericht	Ergebnisse von Qualitätsprüfungen und Audits	APO08.05, APO09.04, APO09.05, BAI07.08

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
APO11.05 Sicherstellen von kontinuierlicher Verbesserung			Benchmarkergebnisse für Qualitätsprüfung	Alle APO, BAI, DSS, MEA
			Beispiele für bewährte Verfahren, die geteilt werden sollten	Alle APO, BAI, DSS, MEA
			Kommunikation in Bezug auf kontinuierliche Verbesserung und bewährte Verfahren	Alle APO, BAI, DSS, MEA
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 8. Project quality management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Entwicklung einer ICT-Qualitätsstrategie	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.2. ICT Quality Strategy Development
Qualitätssicherung	Skills Framework for the Information Age V6, 2015	QUAS
Qualitätsmanagement	Skills Framework for the Information Age V6, 2015	QUMG
Qualitätsstandards	Skills Framework for the Information Age V6, 2015	QUST

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Qualitätsmanagementrichtlinie	Erfasst die Vision des Managements in Bezug auf die Qualitätsziele des Unternehmens, das akzeptable Qualitätsniveau und die Pflichten bestimmter Teams und Einheiten zur Gewährleistung der Qualität.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Fördern Sie eine Kultur der Qualität und kontinuierlichen Verbesserung. Erhalten Sie die Notwendigkeit und den Nutzen von Qualität und kontinuierlicher Verbesserung aufrecht und kommunizieren Sie diese regelmäßig.		

G. Komponente: Services, Infrastruktur und Anwendungen	
• QMS • Qualitätssicherungs-Dienstleistungen durch Dritte	

Domäne: Anpassen, Planen und Organisieren Managementziel: APO12 – Risiko ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Kontinuierliche Identifizierung, Bewertung und Reduzierung von I&T-bezogenen Risiken innerhalb der von der Geschäftsführung festgelegten Toleranzgrenzen.		
Zweck		
Integration des Managements von I&T-bezogenen Unternehmensrisiken in das allgemeine unternehmensweite Risikomanagement (ERM) und Abwägung von Kosten und Nutzen, die mit dem Management der I&T-bezogenen Unternehmensrisiken einhergehen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG02 Gesteuertes Geschäftsrisiko • EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services		• AG02 Gesteuertes I&T-Risiko • AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobewertung abgedeckt werden b. Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG02 a. Aktualisierungshäufigkeit des Risikoprofils b. Anteil der unternehmensweiten Risikobewertungen einschließlich I&T-bezogener Risiken c. Anzahl gravierender I&T-bezogener Störungen, die nicht im Rahmen einer Risikobewertung identifiziert wurden
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursachen b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
APO12.01 Erfassen von Daten Identifizieren und erfassen Sie relevante Daten, um eine effektive Identifizierung, Analyse und Meldung I&T-bezogener Risiken zu ermöglichen.	a. Anzahl der in Repositories erfassten Schadensfälle mit Schlüsselmerkmalen b. Anteil der in Repositories erfassten Prüfungen, Ereignisse und Trends c. Anteil der kritischen Systeme mit bekannten Problemen
Aktivitäten	Fähigkeitsstufe
1. Erarbeiten und pflegen Sie eine Methode für die Erfassung, Klassifizierung und Analyse von I&T-Risikodaten.	2
2. Zeichnen Sie relevante und signifikante risikobezogene I&T-Daten zur internen und externen Betriebsumgebung des Unternehmens auf.	
3. Übernehmen oder definieren Sie eine Risikosystematik mit konsistente Definitionen von Risikoszenarien mit Auswirkungen- und Eintrittswahrscheinlichkeitskategorien.	3
4. Zeichnen Sie Daten zu Risikoereignissen auf, die geschäftliche Auswirkungen gemäß den in der Risikosystematik definierten Auswirkungskategorien verursacht haben oder verursachen können. Erfassen Sie relevante Daten zu verwandten Problemen, Störungen, Problemen und Untersuchungen.	

A. Komponente: Prozess (Forts.)		
5. Untersuchen und analysieren Sie die historischen Daten zum I&T-Risiko und zu Verlusten aus extern verfügbaren Daten und Trends, von anderen Akteuren der Branche über branchenbezogene Ereignisprotokolle, aus Datenbanken sowie aus brancheninternen Abkommen für eine gemeinsame Offenlegung von Ereignissen.	4	
6. Strukturieren Sie für ähnliche Ereignisklassen die erfassten Daten und stellen Sie die maßgeblichen Faktoren heraus. Bestimmen Sie die gemeinsamen maßgeblichen Faktoren über mehrere Ereignisse hinweg.		
7. Bestimmen Sie die spezifischen Bedingungen, die bei Eintreten des Risikoereignisses vorlagen oder nicht vorlagen und ermitteln Sie, inwieweit sich diese Bedingungen auf die Ereignishäufigkeit und die Tragweite der Verluste auswirken.		
8. Führen Sie regelmäßig Ereignis- und Risikofaktoranalysen durch, um neue oder aufkommende Risikoaspekte zu identifizieren und ein Verständnis hinsichtlich der damit verbundenen internen und externen Risikofaktoren zu entwickeln.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
CMMI Data Management Maturity Model, 2014	Supporting Processes – Risk Management	
COSO Enterprise Risk Management, Juni 2017	8. Performance – Principle 10	
ISO/IEC 27005:2011(E)	8.2 Risk identification; 12. Information security risk monitoring and review	
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.1 Preparation (Task 7):	
Managementpraktik	Beispielmetrik	
AP012.02 Analysieren des Risikos Entwickeln Sie eine fundierte Sicht hinsichtlich des tatsächlichen I&T-Risikos zur Unterstützung von Risikoentscheidungen.	a. Anzahl der identifizierten I&T-Risikoszenarien b. Zeit seit der letzten Aktualisierung der I&T-Risikoszenarien	
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie einen angemessenen Umfang für Risikoanalysemaßnahmen unter Berücksichtigung aller Risikofaktoren und/oder der geschäftlichen Kritizität von Betriebsmitteln.	3	
2. Entwickeln und aktualisieren Sie regelmäßig die I&T-Risikoszenarien, I&T-bezogenen Schadensrisiken und Szenarien bezüglich des Reputationsrisikos, einschließlich zusammengesetzter Szenarien von kaskadierenden und/oder zufälligen Bedrohungsarten und -ereignissen. Entwickeln Sie Erwartungen für spezifische Kontrollaktivitäten und Ermittlungsfähigkeiten.		
3. Schätzen Sie die Häufigkeit (oder Wahrscheinlichkeit) und das Ausmaß von Verlusten oder Gewinnen im Zusammenhang mit I&T-Risikoszenarien ein. Berücksichtigen Sie alle relevanten Risikofaktoren und bewerten Sie bekannte betriebliche Kontrollen.		
4. Vergleichen Sie das aktuelle Risiko (I&T-bezogenes Schadensrisiko) mit der Risikobereitschaft und der akzeptablen Risikotoleranz. Identifizieren Sie inakzeptable oder erhöhte Risiken.		
5. Schlagen Sie Reaktionen auf Risiken vor, die die Risikobereitschaft und -toleranz übersteigen.		
6. Legen Sie allgemeine Anforderungen für Projekte oder Programme fest, die die ausgewählten Reaktionen auf Risiken umsetzen. Identifizieren Sie Anforderungen und Erwartungen für geeignete wichtige Kontrollen hinsichtlich der auf Minde- rung ausgelegten Reaktionen auf Risiken.		
7. Validieren Sie die Ergebnisse der Risikoanalyse und der Analyse der Geschäftsauswirkungen (BIA), bevor Sie sie zur Entscheidungsfindung heranziehen. Überprüfen Sie, ob die Analyse den Unternehmensanforderungen entspricht und stellen Sie sicher, dass die Schätzungen sachgemäß kalibriert und auf Richtigkeit überprüft wurden.	4	
8. Führen Sie eine Kosten-Nutzen-Analyse der Optionen für den Umgang mit dem potenziellen Risiko durch, z. B. Vermeiden, Reduzieren/Mindern, Übertragen/Teilen, Akzeptieren oder Nutzen/Ergreifen. Ermitteln Sie die optimale Risikobehandlung.	5	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
CMMI Data Management Maturity Model, 2014	Supporting Processes – Risk Management	
COSO Enterprise Risk Management, Juni 2017	8. Performance – Principle 11	
ISF, The Standard of Good Practice for Information Security 2016	IR2.1 Risk Assessment Scope; IR2.2 Business Impact Assessment	

A. Komponente: Prozess (Forts.)	
ISO/IEC 27001:2013/Cor.2:2015(E)	8.2 Information security risk assessment
ISO/IEC 27005:2011(E)	8.3 Risk analysis
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	ID.RA Risk Assessment
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.6 Authorization (Task 3)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.17 Risk assessment (RA-3)
Managementpraktik	Beispielmetrik
AP012.03 Pflegen eines Risikoprofils Führen Sie eine Bestandsliste bekannter Risiken und Risikoattribute, einschließlich der erwarteten Häufigkeit, der potenziellen Auswirkungen und der Behandlung. Dokumentieren Sie zugehörige Ressourcen, Befähigungen und aktuelle Kontrollaktivitäten in Bezug auf die jeweiligen Risiken.	a. Vollständigkeit der Attribute und Bewertungen im Risikoprofil b. Anteil der wichtigen Geschäftsprozesse, die im Risikoprofil enthalten sind
Aktivitäten	Fähigkeitsstufe
1. Erstellen Sie eine Bestandsliste der Geschäftsprozesse und dokumentieren Sie ihre Abhängigkeit von I&T-Service-Management-Prozessen und IT-Infrastrukturressourcen. Identifizieren Sie unterstützendes Personal, Anwendungen, Infrastruktur, Einrichtungen, kritische manuelle Aufzeichnungen, Anbieter, Lieferanten und Outsourcing-Dienstleister.	2
2. Ermitteln und vereinbaren Sie, welche I&T-Services und IT-Infrastrukturressourcen von wesentlicher Bedeutung für die Unterstützung der Geschäftsausführung sind. Analysieren Sie Abhängigkeiten und identifizieren Sie schwach ausgeprägte Verbindungen.	
3. Fassen Sie aktuelle Risikoszenarien nach Kategorie, Geschäftsbereich und Funktionsbereich zusammen.	
4. Erfassen Sie regelmäßig alle Risikoprofilinformationen und konsolidieren Sie diese zu einem aggregierten Risikoprofil.	3
5. Erfassen Sie Informationen zum Status des Risikoaktionsplans und nehmen Sie diese in das I&T-Risikoprofil des Unternehmens auf.	
6. Ziehen Sie alle verfügbaren Risikoprofildaten heran und definieren Sie Risikoindikatoren, die eine schnelle Identifizierung und Überwachung des aktuellen Risikos und der Risikotrends ermöglichen.	4
7. Erfassen Sie Informationen zu I&T-Risikoereignissen, die tatsächlich eingetreten sind, und nehmen Sie diese in das I&T-Risikoprofil des Unternehmens auf.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	RS.DT Define Organizational Risk Tolerance
COSO Enterprise Risk Management, Juni 2017	8. Performance – Principle 12
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.17 Risk assessment (RA-7)
Managementpraktik	Beispielmetrik
AP012.04 Artikulieren des Risikos Kommunizieren Sie allen betreffenden Anspruchsgruppen zeitnah Informationen zum aktuellen Zustand der I&T-bezogenen Risikopotenziale und Chancen, um den Anspruchsgruppen eine angemessene Reaktion zu ermöglichen.	a. Grad der Zufriedenheit der Anspruchsgruppen mit der bereitgestellten Risikoberichterstattung b. Vollständigkeit der Berichterstattung über das Risikoprofil (einschließlich Informationen, die den Anforderungen der Anspruchsgruppen entsprechen) c. Verwendung von Risikoberichten im Rahmen der Entscheidungsfindung des Managements

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Leiten Sie die Ergebnisse der Risikoanalyse an alle betroffenen Anspruchsgruppen weiter und wählen Sie dafür Formulierungen und Formate, die geeignet sind, Unternehmensentscheidungen zu unterstützen. Nehmen Sie, soweit machbar, Wahrscheinlichkeiten und Spannen von Verlusten bzw. Gewinnen sowie einen Vertrauensbereich auf, um dem Management ein Abwägen zwischen Risiko und Rendite zu ermöglichen.		3
2. Sorgen Sie dafür, dass Entscheidungsträger Worst-Case-Szenarien und wahrscheinlichste Szenarien, I&T-bezogene Verlustrisiken, wichtige Reputationsaspekte sowie rechtliche und behördliche Bedenken – oder jede andere Auswirkungskategorie – gemäß der Risikosystematik nachvollziehen können.		
3. Leiten Sie das aktuelle Risikoprofil an alle Anspruchsgruppen weiter. Machen Sie darin auch Angaben zur Effektivität des Risikomanagement-Prozesses und der Kontrollen sowie zu Lücken, Inkonsistenzen, Redundanzen, zum Abhilfestatus sowie zu den jeweiligen Auswirkungen auf das Risikoprofil.		
4. Überprüfen Sie regelmäßig Bereiche mit relativem Risiko und ausgewogener Risikokapazität und identifizieren Sie dort I&T-bezogene Möglichkeiten, ein größeres Risiko einzugehen, um mehr Wachstum und höhere Erträge zu generieren.		
5. Überprüfen Sie die Ergebnisse objektiver Beurteilungen Dritter sowie von interner Revision und Qualitätssicherungsüberprüfungen. Nehmen Sie diese in das Risikoprofil auf. Überprüfen Sie identifizierte Lücken und I&T-bezogene Verlustrisiken, um die Notwendigkeit einer zusätzlichen Risikoanalyse zu ermitteln.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	RS.CR Determine Critical Infrastructure Requirements	
COSO Enterprise Risk Management, Juni 2017	10. Information, Communication, and Reporting – Principle 19	
ISO/IEC 27005:2011(E)	11. Information security risk communication and consultation	
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	ID.RM Risk Management Strategy	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.15 Program management (PM-32)	
Managementpraktik		Beispielmetrik
AP012.05 Definieren eines Portfolios für Risikomanagement-Maßnahmen Managen Sie Chancen, das Risiko auf ein akzeptables Maß zu reduzieren in Form eines Risikomanagement-Portfolios.		a. Anzahl der erheblichen Störungen, die nicht identifiziert und in das Risikomanagement-Portfolio aufgenommen wurden b. Anteil der Projektvorschläge durch das Risikomanagement, die wegen mangelnder Berücksichtigung anderer verbundener Risiken abgelehnt wurden
Aktivitäten		Fähigkeitsstufe
1. Führen Sie eine Bestandsliste der implementierten Kontrollaktivitäten zur Minderung von Risiken, die es ermöglichen, Risiken in Einklang mit der Risikobereitschaft und Risikotoleranz einzugehen. Klassifizieren Sie die Kontrollaktivitäten und ordnen Sie sie spezifischen I&T-Risikoszenarien und Aggregationen von I&T-Risikoszenarien zu.		2
2. Bestimmen Sie, ob die einzelnen organisatorischen Einheiten das Risiko überwachen und die Verantwortung für Handlungen innerhalb der individuellen und innerhalb der im Portfolio vorhandenen Toleranzgrenzen übernehmen.		3
3. Definieren Sie einen ausgewogenen Umfang von Projektvorschlägen, die darauf ausgelegt sind, das Risiko zu reduzieren und/oder Projekte, die strategische Unternehmenschancen ermöglichen. Berücksichtigen Sie dabei Kosten und Nutzen sowie die Auswirkungen auf das Risikoprofil und auf Bestimmungen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Supporting Processes – Risk Management	
COSO Enterprise Risk Management, Juni 2017	8. Performance – Principle 14	
HITRUST CSF Version 9, September 2017	03.01 Risk Management Program	

A. Komponente: Prozess (Forts.)		
Managementpraktik	Beispielmetrik	
AP012.06 Behandeln des Risikos Reagieren Sie zeitnah und mit effektiven Mitteln auf eingetretene Risikoereignisse, um die Tragweite von Verlusten in Grenzen zu halten.	a. Anzahl der Maßnahmen, die das Restrisiko nicht reduzieren konnten b. Anteil der I&T-Risiko-Aktionspläne, die wie geplant ausgeführt wurden	
Aktivitäten	Fähigkeitsstufe	
1. Erstellen, pflegen und testen Sie Pläne, in denen die konkreten Schritte dokumentiert sind, die auszuführen sind, wenn ein Risikoereignis potenziell eine schwerwiegende Betriebs- oder Entwicklungsstörung mit gravierenden betrieblichen Auswirkungen verursacht. Stellen Sie sicher, dass in den Plänen unternehmensweite Eskalationspfade enthalten sind.	3	
2. Wenden Sie den jeweiligen Plan an, um die Auswirkungen bei Eintreten der Störung, auf die sich das Risiko bezieht, zu minimieren.		
3. Kategorisieren Sie Störungen und vergleichen Sie I&T-bezogene Verlustrisiken mit den für die Risikotoleranz festgelegten Grenzwerten. Kommunizieren Sie im Rahmen der Berichterstattung an die Entscheidungsträger die geschäftlichen Auswirkungen und aktualisieren Sie das Risikoprofil.	4	
4. Untersuchen Sie frühere negative Ereignisse/Verluste und verpasste Chancen und ermitteln Sie die Ursachen.		
5. Kommunizieren Sie die Ursache, zusätzliche Anforderungen für die Risikobewältigung sowie Prozessverbesserungen an die jeweiligen Entscheidungsträger. Stellen Sie sicher, dass die Ursache, die Anforderungen für die Risikobewältigung und die Prozessverbesserungen in die Risiko-Governance-Prozesse einbezogen werden.	5	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
COSO Enterprise Risk Management, Juni 2017	8. Performance – Principle 13	
ISF, The Standard of Good Practice for Information Security 2016	IR2.9 Risk Treatment	
ISO/IEC 27001:2013/Cor.2:2015(E)	6.1 Action to address risk and opportunities	
ISO/IEC 27005:2011(E)	9. Information security risk treatment	
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.6 Authorization (Task 4)	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.15 Program management (PM-9, PM-31)	

B. Komponente: Organisationsstrukturen																			
Wichtige Managementpraktik:										Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	Risikoausschuss des Unternehmens	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Project Management Office	Datenmanagement	Chefarchitekt
										Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter			
AP012.01 Erfassen von Daten										A	R	R	R		R	R	R	R	R
AP012.02 Analysieren des Risikos										A	R			R	R				
AP012.03 Pflegen eines Risikoprofils										A	R			R	R				
AP012.04 Artikulieren des Risikos										A	R			R	R				
AP012.05 Definieren eines Portfolios für Risikomanagement-Maßnahmen										A	R			R	R				
AP012.06 Behandeln des Risikos										R	A	R	R		R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)										Detaillierte Referenzen									
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017										3.1 Preparation (Task 1); Appendix A: Rollen und Zuständigkeiten									

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO12.01 Erfassen von Daten	Von	Beschreibung	Beschreibung	Für
	APO02.02	Lücken und Risiken im Zusammenhang mit den derzeitigen Fähigkeiten	Aufkommende Risiko- themen und -faktoren	APO01.01, APO02.02, EDM03.01
	APO02.05	Initiativen zur Risikobe- wertung	Daten zu Risikoereig- nissen und beitragenden Faktoren	Intern
	APO10.04	Identifiziertes Lieferan- ten-Lieferrisiko	Daten über die Betrieb- sumgebung in Bezug auf das Risiko	Intern
	DSS02.07	Bericht über Status und Trends von Störungen		
	EDM03.01	Bewertung der Risiko- management-Aktivitäten		
	EDM03.02	• Richtlinien zum Risiko- management • Zu überwachende wichtige Ziele für das Risikomanagement • Genehmigter Prozess zur Messung des Risi- komanagements		
APO12.02 Analysieren des Risikos	DSS04.02	Business-Impact-Ana- lysen (BIAs)	Ergebnisse der Risiko- analyse	APO01.01, APO02.02, EDM03.03, BAI01.08, BAI11.06
	DSS05.01	Auswertungen poten- zieller Bedrohungen	I&T-Risikoszenarien	Intern
	Außerhalb von COBIT	Ratschläge zu Bedro- hungen	Umfang der Risikoanaly- seaktivitäten	Intern
APO12.03 Pflegen eines Risikoprofils	APO10.04	Identifiziertes Lieferan- ten-Lieferrisiko	Aggregiertes Risiko- profil, einschließlich Status der Risikoma- nagementaktivitäten	APO02.02, EDM03.02
	DSS05.01	Auswertungen poten- zieller Bedrohungen	Dokumentierte Risikoszenarien nach Geschäftszweig und Funktion	Intern
	EDM03.01	• Anleitung zur Risikobe- reitschaft • Genehmigte Risikotole- ranzstufen		
APO12.04 Artikulieren des Risikos			Risikoanalyse und Risikoprofilberichte für Anspruchsgruppen	APO10.04, EDM03.03, EDM05.02, MEA04.05
			Ergebnisse von Risiko- bewertungen Dritter	APO10.04, EDM03.03, MEA02.01
			Chancen für die Akzep- tanz eines größeren Risikos	EDM03.03

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
APO12.05 Definieren eines Portfolios für Risikomanagement-Maßnahmen	Von	Beschreibung	Beschreibung	Für
			Projektvorschläge zur Risikominderung	AP002.02, AP013.02
APO12.06 Behandeln des Risikos	EDM03.03	Abhilfemaßnahmen bei Abweichungen im Risikomanagement	Kommunikation der Risikoauswirkungen	AP001.02, AP008.04, DSS04.02
			Risikobezogene Grundursachen	DSS02.03, DSS03.01, DSS03.02, DSS03.03, DSS03.05, DSS04.02, MEA02.04, MEA04.04, MEA04.06
			Pläne zum Umgang mit risikobehafteten Störungen	DSS02.05
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
COSO Enterprise Risk Management, Juni 2017		10. Information, Communication, and Reporting – Principle 20		
SF, The Standard of Good Practice for Information Security 2016		IR1.3 Information Risk Assessment – Supporting Material		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.1 Preparation (Task 7): Inputs and Outputs; 3.6 Authorization (Task 3, 4): Inputs und Outputs		
PMBOK Guide Sixth Edition, 2017		Part 1: 11. Project risk management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Management von Geschäftsrisiken	Skills Framework for the Information Age V6, 2015	BURM
Informationssicherung	Skills Framework for the Information Age V6, 2015	INAS
Risikomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.3. Risk Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Unternehmensrisiko	Definiert Governance und Management von Unternehmensrisiken auf strategischer, taktischer und operativer Ebene gemäß den Geschäftszielen. Überträgt die unternehmensweite Governance in Risiko-Governance-Grundsätze und -Richtlinien und erläutert Maßnahmen zum Risikomanagement.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.17 Risk assessment (RA-1)

E. Komponente: Richtlinien und Verfahren (Forts.)

Betrugsrisikorichtlinie	Informiert über den Schutz der Marke des Unternehmens, des Rufs und der Vermögenswerte im Falle von Verlust oder Schaden durch Betrug oder Fehlverhalten. Leitet Mitarbeiter bei der Meldung verdächtiger Aktivitäten und beim Umgang mit sensiblen Informationen und Beweisen an. Fördert eine Kultur der Betrugsbekämpfung und kultiviert ein Risikobewusstsein.	National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	
-------------------------	--	---	--

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Zur Förderung einer transparenten und partizipatorischen Risikokultur, sollte die Unternehmensleitung die Richtung vorgeben und wahrnehmbare und echte Unterstützung für die Einbeziehung von Risikopraktiken im gesamten Unternehmen demonstrieren. Das Management sollte eine offene Kommunikation und die Übernahme von Verantwortung für I&T-bezogene Geschäftsrisiken fördern. Zu den erwünschten Verhaltensweisen gehören die Anpassung der Richtlinien an die festgelegte Risikobereitschaft, die Berichterstattung über Risikotrends an die Unternehmensleitung und die entsprechenden Gremien, die Wertschätzung eines effektiven Risikomanagements und die proaktive Überwachung von Risiken und Fortschritten beim Risiko-Aktionsplan.	ISF, The Standard of Good Practice for Information Security 2016	IR1.2 Information Risk Assessment

G. Komponente: Services, Infrastruktur und Anwendungen

- Krisenmanagement-Services
- GRC-Tools (Governance, Risiko und Compliance)
- Risikoanalyse-Werkzeuge
- Risk Intelligence Services

Domäne: Anpassen, Planen und Organisieren Managementziel: APO13 – Sicherheit ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Definition, Betrieb und Überwachung eines Informationssicherheits-Managementsystems (ISMS).		
Zweck		
Begrenzung der Auswirkungen und des Auftretens von Informationssicherheitsstörungen auf die jeweilige Risikobereitschaft des Unternehmens.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG02 Gesteuertes Geschäftsrisiko • EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services		• AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobewertung abgedeckt werden b. Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursachen b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
APO13.01 Einrichten und Pflegen eines Informationssicherheits-Managementsystems (ISMS) Errichten und pflegen Sie ein Informationssicherheits-Management-system (ISMS), das einen standardisierten, formellen und kontinuierlichen Ansatz für das Informationssicherheitsmanagement bereitstellt, und das sichere Technologie- und Geschäftsprozesse ermöglicht, die an den Geschäftsanforderungen ausgerichtet sind.	a. Grad der Zufriedenheit der Anspruchsgruppen mit dem Sicherheitsplan im gesamten Unternehmen	
Aktivitäten	Fähigkeitsstufe	
1. Definieren Sie den Geltungsbereich und die Grenzen des Informationssicherheits-Managementsystems (ISMS) in Bezug auf die Eigenschaften des Unternehmens, die Organisation, den Standort, die Betriebsmittel und die Technologie. Machen Sie dabei Angaben zu etwaigen Abweichungen vom Geltungsbereich und fügen Sie Begründungen hinzu.	2	
2. Definieren Sie ein ISMS in Übereinstimmung mit der Unternehmenspolitik und dem Kontext, in dem das Unternehmen tätig ist.		
3. Passen Sie das ISMS an den allgemeinen Ansatz des Unternehmens für das Sicherheitsmanagement an.		
4. Holen Sie die Genehmigung des Managements für die Implementierung und Anwendung bzw. Änderung des ISMS ein.		
5. Erstellen und pflegen Sie ein Dokument, das den Geltungsbereich des ISMS beschreibt.		
6. Definieren und kommunizieren Sie Rollen und Zuständigkeiten für das Informationssicherheits-Management.		
7. Kommunizieren Sie den ISMS-Ansatz.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
HITRUST CSF Version 9, September 2017		0.01 Information Security Management program
ISO/IEC 20000-1:2011(E)		6.6 Information security management
ITIL V3, 2011		Service Design, 4.7 Information Security Management
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.3 Selection (Task 1); 3.4 Implementation (Task 1)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.17 Risk assessment (RA-2)
Managementpraktik		Beispielmetrik
AP013.02 Definieren und Managen eines Plans zur Behandlung von Informationssicherheitsrisiken Führen Sie einen Plan zur Behandlung von Informationssicherheitsrisiken, in dem beschrieben wird, wie das Informationssicherheitsrisiko zu managen und an Unternehmensstrategie und Unternehmensarchitektur auszurichten ist. Stellen Sie sicher, dass Empfehlungen für die Implementierung von Sicherheitsverbesserungen auf genehmigten Business Cases basieren und als fester Bestandteil der Service- und Lösungsentwicklung implementiert und anschließend als fester Bestandteil des Geschäftsbetriebs umgesetzt werden.		a. Anteil der erfolgreichen Simulationen von Sicherheitsrisikoszenarien b. Anzahl der Mitarbeiter, die eine Schulung zur Sensibilisierung bezüglich Informationssicherheit erfolgreich abgeschlossen haben
Aktivitäten		Fähigkeitsstufe
1. Formulieren und pflegen Sie einen Plan zur Behandlung von Informationssicherheitsrisiken, der an den strategischen Zielvorgaben und der Unternehmensarchitektur ausgerichtet ist. Stellen Sie sicher, dass im Plan die richtigen und optimalen Managementpraktiken und Sicherheitslösungen aufgezeigt werden, ebenso wie die zugehörigen Ressourcen, Zuständigkeiten und Prioritäten für die Behandlung des identifizierten Informationssicherheitsrisikos.		3
2. Führen Sie im Rahmen der Unternehmensarchitektur eine Bestandsliste der vorhandenen Lösungskomponenten zur Behandlung des sicherheitsbezogenen Risikos.		
3. Entwickeln Sie Vorschläge für die Implementierung des Plans zur Behandlung von Informationssicherheitsrisiken und stützen Sie diese auf geeignete Business Cases, die auch Überlegungen zur Finanzierung und zur Zuweisung von Rollen und Verantwortlichkeiten beinhalten.		
4. Stellen Sie Input für die Konzeption und Entwicklung von Managementpraktiken und Lösungen bereit, die aus dem Plan zur Behandlung von Informationssicherheitsrisiken ausgewählt wurden.		
5. Implementieren Sie Schulungs- und Sensibilisierungsprogramme zu den Themen Informationssicherheit und Datenschutz.		
6. Integrieren Sie die Planung, Konzeption, Implementierung und Überwachung von Informationssicherheitsverfahren und Datenschutz sowie sonstiger Kontrollen, die eine unmittelbare Vermeidung, eine Erkennung von Sicherheitsereignissen und eine Reaktion auf Sicherheitsvorfälle ermöglichen.		4
7. Definieren Sie, wie die Effektivität der ausgewählten Managementpraktiken gemessen werden soll. Legen Sie fest, wie diese Messungen anzuwenden sind, um die Effektivität der Generierung vergleichbarer und reproduzierbarer Ergebnisse zu beurteilen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
AP013.03 Überwachen und Überprüfen des Informationssicherheits-Managementsystems (ISMS) Halten Sie an der Notwendigkeit der kontinuierlichen Verbesserung der Informationssicherheit fest und kommunizieren Sie regelmäßig deren Vorteile. Sammeln und analysieren Sie Daten zum Informationssicherheits-Managementsystem (ISMS) und verbessern Sie dessen Effektivität. Beheben Sie nicht konforme Abweichungen, um deren wiederholtes Auftreten zu vermeiden.		a. Häufigkeit der geplanten Sicherheitsüberprüfungen b. Anzahl der Feststellungen bei regelmäßigen Sicherheitsüberprüfungen c. Grad der Zufriedenheit der Anspruchsgruppen mit dem Sicherheitsplan d. Anzahl sicherheitsrelevanter Störungen, die durch Nichteinhaltung des Sicherheitsplans verursacht wurden

Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie regelmäßig die Effektivität des ISMS. Prüfen Sie dabei auch die Einhaltung der ISMS-Richtlinie, die Erfüllung der Zielvorgaben und die Sicherheits- und Datenschutzpraktiken	4
2. Führen Sie in geplanten Abständen ISMS-Audits durch.	
3. Führen Sie regelmäßig eine Überprüfung des ISMS durch das Management durch, um sicherzustellen, dass der Geltungsbereich nach wie vor adäquat ist und mögliche Verbesserungen des ISMS-Prozesses identifiziert werden.	
4. Zeichnen Sie Maßnahmen und Ereignisse auf, die sich auf die Effektivität oder Leistung des ISMS auswirken könnten.	
5. Stellen Sie Input für die Pflege der Sicherheitspläne bereit, damit die Ergebnisse der Überwachungs- und Überprüfungsaktivitäten einfließen können.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.3 Selection (Task 3)

B. Komponente: Organisationsstrukturen													
Wichtige Managementpraktik:													
	Chief Information Officer	Chief Technology Officer	Risikoausschuss des Unternehmens	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Project Management Office	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager
AP013.01 Einrichten und Pflegen eines Informationssicherheits-Managementsystems (ISMS)	R		R	A						R		R	
AP013.02 Definieren und Managen eines Plans zur Behandlung von Informationssicherheitsrisiken	R		R	A						R		R	R
AP013.03 Überwachen und Überprüfen des Informationssicherheits-Managementsystems (ISMS)	R	R		A	R	R	R	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen												
ISF, The Standard of Good Practice for Information Security 2016	SG1.2 Security Direction												
ISO/IEC 27002:2013/Cor.2:2015(E)	6.1 Internal organization												

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
APO13.01 Einrichten und Pflegen eines Informationssicherheits-Managementsystems (ISMS)	Von	Beschreibung	Beschreibung	Für
	Außerhalb von COBIT	Sicherheitsansatz des Unternehmens	Erklärung zum ISMS-Umfang	APO01.05, DSS06.03
ISMS-Richtlinie			Intern	
APO13.02 Definieren und Managen eines Plans zur Behandlung von Informationssicherheitsrisiken	APO02.04	Lücken und erforderliche Änderungen zur Erreichung der Zielbefähigung	Plan zur Behandlung von Informationssicherheitsrisiken	Alle APO, BAI, DSS, MEA, EDM
	APO03.02	Grundlegende Domänenbeschreibungen und Architekturdefinition	Business Cases zur Informationssicherheit	APO05.02
	APO12.05	Projektvorschläge zur Risikominderung		
Managementpraktik	Inputs		Outputs	
APO13.03 Überwachen und Überprüfen des Informationssicherheits-Managementsystems (ISMS)	Von	Beschreibung	Beschreibung	Für
	DSS02.02	Klassifizierte und priorisierte Störungen und Serviceanfragen	Empfehlungen zur Verbesserung des Informationssicherheits-Managementsystems (ISMS)	Intern
Informationssicherheits-Management-system (ISMS)-Prüfberichte			MEA02.01	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.3 Selection (Tasks 1, 3): Inputs and Outputs; 3.4 Implementation (Task 1): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Informationssicherheit	Skills Framework for the Information Age V6, 2015	SCTY
Entwicklung einer Informationssicherheitsstrategie	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.1. Information Security Strategy Development

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zu Informationssicherheit und Datenschutz	Stellt Richtlinien zum Schutz von Unternehmensinformationen und der damit verbundenen Systeme und Infrastruktur bereit. Angesichts der Tatsache, dass die geschäftlichen Anforderungen in Bezug auf Sicherheit und Speicherung dynamischer sind als das I&T-Risikomanagement und der Datenschutz, sollte deren Governance getrennt von der des I&T-Risikos und Datenschutzes behandelt werden. Zur Steigerung der betrieblichen Effizienz, sollte die Leitlinie zur Informationssicherheit mit der für I&T-Risiko- und Datenschutz abgeglichen werden.	(1) ISO/IEC 27001:2013/Cor.2:2015(E); (2) ISO/IEC 27002:2013/Cor.2:2015(E); (3) National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017; (4) HITRUST CSF Version 9, September 2017; (5) ISF, The Standard of Good Practice for Information Security 2016	(1) 5.2 Policy; (2) 5. Information security policies; (3) 3.2 Awareness and training (AT-1); (4) 04.01 Information Security Policy; (5) SM1.1 Information Security Policy

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur des Bewusstseins für Sicherheit und Datenschutz, die das wünschenswerte Verhalten und die tatsächliche Umsetzung der Sicherheits- und Datenschutzrichtlinien in der täglichen Praxis positiv beeinflusst. Stellen Sie ausreichende Anleitungen zu den Themen Sicherheit und Datenschutz bereit, benennen Sie Sicherheits- und Datenschutz-Champions (einschließlich Führungskräften auf mittlerer Ebene, Führungskräften in der Personalabteilung und Fachleuten für Sicherheit und/oder Datenschutz) und kommunizieren Sie Sicherheits und Datenschutzprogramme, Innovationen und Herausforderungen und unterstützen Sie diese proaktiv.	(1) ISO/IEC 27001:2013/Cor.2:2015(E); (2) Creating a Culture of Security, ISACA, 2011	1) 7.3 Awareness; (2) Framework to achieve an intentional security aware culture (alle Kapitel)

G. Komponente: Services, Infrastruktur und Anwendungen
• Konfigurationsmanagement-Werkzeuge • Maßnahmen zur Sensibilisierung für Sicherheit und Datenschutz • Sicherheitsbewertungs-Dienstleistungen durch Dritte

Diese Seite wurde absichtlich freigelassen.

Domäne: Anpassen, Planen und Organisieren Managementziel: APO14 – Daten sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Durchsetzen und Aufrechterhalten eines effektiven Managements der Unternehmensdatenbestände über den gesamten Datenlebenszyklus hinweg, von der Erstellung über die Bereitstellung und Pflege bis hin zur Archivierung.		
Zweck		
Sicherstellung einer effektiven Nutzung der entscheidenden Datenbestände zur Erreichung der Unternehmensziele und -vorgaben.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen		AG10 Qualität der I&T-Managementinformationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, der Verständlichkeit und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG10 a. Grad der Zufriedenheit der Nutzer mit der Qualität, Pünktlichkeit und Verfügbarkeit von I&T-bezogenen Managementinformationen unter Berücksichtigung der verfügbaren Ressourcen b. Verhältnis und Ausmaß von falschen Geschäftsentscheidungen, bei denen fehlerhafte oder nicht verfügbare I&T-bezogene Informationen ein wichtiger Faktor waren c. Anteil der Informationen, die die Qualitätskriterien erfüllt haben
EG07 a. Grad der Zufriedenheit der Geschäftsleitung und obersten Führungskräfte mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
APO14.01 Definieren und Kommunizieren der Datenmanagementstrategie des Unternehmens sowie der Rollen und Verantwortlichkeiten Definieren Sie, wie die Datenbestände des Unternehmens im Einklang mit der Unternehmensstrategie und den Zielvorgaben gemanagt und verbessert werden können. Kommunizieren Sie die Datenmanagementstrategie an alle Anspruchsgruppen. Weisen Sie Rollen und Verantwortlichkeiten zu, um sicherzustellen, dass Unternehmensdaten als wichtige Ressourcen gehandhabt werden und die Datenmanagementstrategie effektiv und nachhaltig umgesetzt und weiterentwickelt wird.		a. Anzahl der Verstöße im Datenmanagement gemessen an der definierten Strategie b. Anteil der Rollen und Zuständigkeiten, die zur Unterstützung der Governance des Datenmanagements und der Interaktion zwischen den Funktionen Governance und Datenmanagement identifiziert wurden
Aktivitäten		Fähigkeitsstufe
1. Richten Sie eine Datenmanagementfunktion mit der Verantwortung für das Handhaben von Aktivitäten ein, die die Datenmanagementziele unterstützen.		2
2. Legen Sie Rollen und Zuständigkeiten zur Unterstützung von Datenmanagement sowie der Interaktion zwischen den Funktionen Governance und Datenmanagement fest.		
3. Stellen Sie sicher, dass die geschäftlichen und technologischen Bereiche gemeinsam die Datenmanagementstrategie der Organisation entwickeln. Stellen Sie sicher, dass die Ziele, Prioritäten und der Umfang des Datenmanagements die Unternehmensziele widerspiegeln, mit den Datenmanagementrichtlinien und -vorschriften konform gehen und von allen Anspruchsgruppen genehmigt werden.		3
4. Kommunizieren Sie die Ziele, Prioritäten und den Umfang des Datenmanagements und passen Sie diese bei Bedarf auf der Grundlage von Rückmeldungen an.		

A. Komponente: Prozess (Forts.)	
5. Verwenden Sie Metriken, um die Erreichung der Ziele für das Datenmanagement zu bewerten und zu überwachen.	4
6. Überwachen Sie den Ablaufplan für die Umsetzung der Datenmanagementstrategie. Aktualisieren Sie diesen bei Bedarf auf der Grundlage von Überprüfungen des Fortschritts.	
7. Nutzen Sie statistische und andere quantitative Techniken, um die Effektivität der strategischen Datenmanagementziele bei der Erreichung der Geschäftsziele zu bewerten. Nehmen Sie bei Bedarf Anpassungen auf der Grundlage von Metriken vor.	
8. Stellen Sie sicher, dass die Organisation innovative Geschäftsprozesse und aufkommende gesetzliche Anforderungen ermittelt, um sicherzustellen, dass das Datenmanagementprogramm mit den zukünftigen Geschäftsanforderungen kompatibel ist.	5
9. Leisten Sie Beiträge zu den bewährten Praktiken der Branche für die Entwicklung und Implementierung von Datenmanagementstrategien.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Data Management Strategy – Data Management Strategy; Data Governance – Governance Management
ITIL V3, 2011	Service Design, 5.2 Management of Data and Information
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 13: Data Protection
Managementpraktik	Beispielmetrik
AP014.02 Definieren und Pflegen eines einheitlichen Geschäftsglossars Erstellen, genehmigen, aktualisieren und fördern Sie konsistente Geschäftsbegriffe und Definitionen, um die gemeinsame Nutzung im gesamten Unternehmen voranzutreiben.	a. Grad der Akzeptanz und Häufigkeit der Verwendung von Geschäftsglossar-Begriffen in der gesamten Organisation b. Anzahl der Synonyme für definierte Geschäftsglossar-Terminologie, die bei neuen Entwicklungen verwendet wurden c. Granularitätsebene der definierten Geschäftsglossar-Begriffe
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie sicher, dass Standard-Geschäftsbegriffe einfach verfügbar sind und an die relevanten Anspruchsgruppen kommuniziert werden.	2
2. Stellen Sie sicher, dass jeder zum Geschäftsglossar hinzugefügte Begriff einen eindeutigen Namen und eine eindeutige Definition hat.	
3. Verwenden Sie, wenn zutreffend, im Geschäftsglossar branchenübliche Standardbegriffe und Definitionen.	
4. Erstellen, dokumentieren und befolgen Sie einen Prozess zur Definition, Verwaltung, Verwendung und Pflege des Geschäftsglossars. Neue Initiativen sollten beispielsweise Standardbegriffe im Rahmen des Definitionsprozesses der Datenanforderungen verwenden, um eine einheitliche Sprache zu gewährleisten. Das erleichtert die Vergleichbarkeit der Inhalte und den Datenaustausch innerhalb der Organisation.	3
5. Stellen Sie sicher, dass bei der Neuentwicklung, Datenintegration und Datenkonsolidierung Standardbegriffe im Rahmen des Definitionsprozesses der Datenanforderungen verwendet werden.	
6. Integrieren Sie das Geschäftsglossar in das Metadaten-Repository der Organisation und legen Sie entsprechende Zugriffsberechtigungen fest.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Data Governance – Business Glossary
ISF, The Standard of Good Practice for Information Security 2016	IM1.1 Information Classification and Handling
Managementpraktik	Beispielmetrik
AP014.03 Festlegen der Prozesse und der Infrastruktur für das Metadatenmanagement Richten Sie Prozesse und Infrastruktur für die Festlegung und Erweiterung von Metadaten über die Datenbestände des Unternehmens ein, fördern und unterstützen Sie die gemeinsame Datennutzung, gewährleisten Sie die konforme Nutzung von Daten, verbessern Sie die Reaktionsfähigkeit auf geschäftliche Änderungen und Reduzierung datenbezogener Risiken.	a. Anzahl der identifizierten Ungenauigkeiten in den Metadaten b. Anteil der Metadaten, die Kennzahlen und Metriken zur Bewertung der Genauigkeit und der Verwendung von Metadaten enthalten

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Richten Sie einen Metadaten-Managementprozess ein und wenden Sie diesen an.	2
2. Stellen Sie sicher, dass die Metadaten-Dokumentation die Abhängigkeiten zwischen den Daten erfasst.	
3. Erstellen Sie Metadatenkategorien, -eigenschaften und -standards und wenden Sie diese an.	
4. Entwickeln und verwenden Sie Metadaten zur Durchführung von Auswirkungenanalysen bei potenziellen Datenänderungen.	3
5. Erweitern Sie das Metadaten-Repository der Organisation um zusätzliche Kategorien und Klassifizierungen von Metadaten gemäß einem stufenweisen Implementierungsplan. Verknüpfen Sie das Repository mit Architekturebenen.	
6. Validieren Sie Metadaten und alle Änderungen an Metadaten anhand der bestehenden Architektur.	
7. Stellen Sie sicher, dass die Organisation ein integriertes Metamodell entwickelt hat, das auf allen Plattformen eingesetzt wird.	
8. Stellen Sie sicher, dass Metadatentypen und Datendefinitionen konsistente Import-, Abonnement- und Verbrauchspraktiken unterstützen.	4
9. Verwenden Sie Kennzahlen und Metriken zur Bewertung der Genauigkeit und Nutzung von Metadaten.	
10. Bewerten Sie geplante Datenänderungen hinsichtlich ihrer Auswirkungen auf das Metadaten-Repository. Verbessern Sie kontinuierlich die Prozesse zur Erfassung, Änderung und Verbesserung von Metadaten.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Data Governance – Metadata Management
ISO/IEC 27002:2013/Cor.2:2015(E)	8.2 Information classification
Managementpraktik	Beispielmetrik
AP014.04 Definieren einer Datenqualitätsstrategie Definieren Sie eine integrierte, unternehmensweite Strategie zur Erreichung und Aufrechterhaltung des Niveaus der Datenqualität (wie Komplexität, Integrität, Genauigkeit, Vollständigkeit, Gültigkeit, Nachvollziehbarkeit und Aktualität), das zur Unterstützung der Geschäftsziele und -zielvorgaben erforderlich ist.	a. Anzahl der identifizierten und in einem Ablaufplan aufgezeichneten Aktivitäten zur Verbesserung der Datenqualität b. Anteil der Anspruchsgruppen, die mit der Qualität der Daten zufrieden sind
Aktivitäten	Fähigkeitsstufe
1. Definieren Sie eine Datenqualitätsstrategie in Zusammenarbeit mit Anspruchsgruppen aus dem geschäftlichen und technischen Bereich, die von der Geschäftsleitung genehmigt und gemanagt wird. Die Strategie sollte den Übergang vom gegenwärtigen zum Zielzustand unterstützen. Sie sollte auch explizit auf die Geschäftsziele und die Datenmanagementstrategie der Organisation abgestimmt sein.	3
2. Stellen Sie sicher, dass die Datenqualitätsstrategie in der gesamten Organisation angewendet und von entsprechenden Richtlinien, Prozessen und Anleitungen flankiert wird.	
3. Verankern Sie die in der Datenqualitätsstrategie enthaltenen Richtlinien, Prozesse und Governance im gesamten Datenlebenszyklus. Sehen Sie auch entsprechende Prozesse in der Methodik des Systementwicklungslebenszyklus vor.	
4. Entwickeln, überwachen und pflegen Sie einen Ablaufplan für die Aktivitäten zur Verbesserung der Datenqualität in der gesamten Organisation.	
5. Überwachen Sie die Pläne zur Erfüllung der Ziele und Zielvorgaben der Datenqualitätsstrategie zur kontinuierlichen Bewertung des Fortschritts.	4
6. Erheben Sie systematisch Berichte der Anspruchsgruppen zu Problemen mit der Datenqualität. Beziehen Sie deren Erwartungen an die Verbesserung der Datenqualität in die Datenqualitätsstrategie ein. Messen und überwachen Sie diese.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	DP.DR Safeguard Data at Rest; DP.DT Safeguard Data in Transit; DP.IP Integrity and Data Leak Prevention
CMMI Data Management Maturity Model, 2014	Data Quality – Data Quality Strategy

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
AP014.05 Festlegen von Methoden, Prozessen und Werkzeugen für das Data Profiling Implementieren Sie standardisierte Methoden, Prozesse, Praktiken, Werkzeuge und Vorlagen für das Data Profiling, die über mehrere Datenrepositories und Datenspeicher hinweg angewendet werden können.		a. Anzahl der definierten und implementierten Datenvorlagen und deren Nutzungsgrad b. Anzahl der gemeinsam genutzten Datensätze mit einem definierten Datenprofil
Aktivitäten		Fähigkeitsstufe
1. Definieren und standardisieren Sie Methoden, Prozesse, Praktiken, Werkzeuge und Ergebnisvorlagen für das Data Profiling. Stellen Sie sicher, dass Profiling-Prozesse mehrfach verwendbar sind und über mehrere Datenspeicher und gemeinsam genutzte Datenrepositories hinweg genutzt werden können.		3
2. Setzen Sie das Datenmanagement zur Identifizierung von gemeinsam genutzten zentralen Datensätzen ein, die regelmäßig einem Data Profiling unterzogen und überwacht werden.		4
3. Bei der Nutzung von Data Profiling sollte die Konformität der Daten mit den bestätigten Metadaten und Standards bewertet werden.		
4. Vergleichen Sie während des Data Profiling die tatsächlichen Probleme mit den statistisch vorhergesagten Problemen, basierend auf den historischen Profiling-Ergebnissen.		
5. Stellen Sie sicher, dass die Ergebnisse zentral gespeichert, systematisch überwacht und anhand von Statistiken und Metriken analysiert werden. Lassen Sie die daraus resultierenden Erkenntnisse in die Verbesserung der Datenqualität einfließen.		5
6. Erstellen Sie automatisierte Profiling-Berichte in Echtzeit oder nahezu in Echtzeit für alle kritischen Datenfeeds und Repositories.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Data Quality – Data Profiling
National Institute of Standards and Technology Special Publication 800-53, Revision 5, August 2017		3.20 System and information integrity (SI-1)
Managementpraktik		Beispielmetrik
AP014.06 Sicherstellen eines Ansatzes zur Bewertung der Datenqualität Stellen Sie einen systematischen Ansatz zur Messung und Bewertung der Datenqualität in Bezug auf Prozesse, Techniken und Datenqualitätsregeln bereit.		a. Anzahl der identifizierten Probleme in den Ergebnissen der Datenqualitätsbewertung b. Anzahl der Ergebnisse der Datenqualitätsbeurteilung, die Empfehlungen für Abhilfemaßnahmen beinhalten
Aktivitäten		Fähigkeitsstufe
1. Führen Sie regelmäßig Bewertungen der Datenqualität, entsprechend einer genehmigten Häufigkeit auf Basis der Richtlinie zur Datenqualitätsbewertung, durch. Stellen Sie sicher, dass die wichtigsten Attribute für die Bewertung der Datenqualität nach Themenbereichen im Rahmen der Daten-Governance bestimmt werden.		4
2. Nehmen Sie Empfehlungen zur Behebung von Problemen mit einer Begründung in die Ergebnisse der Datenqualitätsbewertung mit auf.		
3. Bewerten Sie die Datenqualität unter Verwendung festgelegter Schwellenwerte und Ziele für jede ausgewählte Qualitätsdimension.		
4. Erstellen Sie systematisch Berichte zur Messung der Datenqualität auf der Grundlage der Kritikalität der Attribute und der Datenvolatilität.		
5. Überprüfen und verbessern Sie kontinuierlich die Prozesse zur Bewertung der Datenqualität und zur Erstellung von Berichten.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Data Quality – Data Quality Assessment

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
AP014.07 Definieren des Datenbereinigungsansatzes Definieren Sie Mechanismen, Regeln, Prozesse und Methoden zur Validierung und Korrektur von Daten gemäß vordefinierter Geschäftsregeln.		a. Anteil der korrekt bereinigten Daten b. Anteil der SLAs, die Datenqualitätskriterien enthalten und die Bereinigung der Daten in die Verantwortung der Datenanbieter legen
Aktivitäten		Fähigkeitsstufe
1. Erstellen und pflegen Sie eine Richtlinie zur Datenbereinigung.		2
2. Pflege Sie eine Datenänderungshistorie im Rahmen von Bereinigungsaktivitäten.		3
3. Legen Sie Methoden zur Datenkorrektur fest und definieren Sie diese Methoden in einem Plan. Zu den Methoden können der Vergleich mehrerer Repositories, die Verifizierung anhand einer gültigen Quelle, Logikprüfungen, referenzielle Integrität oder Bereichstoleranz gehören.		4
4. In die Service Level Agreements sollten Datenqualitätskriterien aufgenommen werden, um die Bereinigung der Daten in die Verantwortung der Datenanbieter legen zu können.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Data Quality – Data Cleansing
Managementpraktik		Beispielmetrik
AP014.08 Managen des Lebenszyklus von Datenbeständen Stellen Sie sicher, dass die Organisation ihre Datenflüsse im Rahmen von Geschäftsprozessen während des gesamten Datenlebenszyklus, von der Erstellung oder Erfassung bis zur Inaktivsetzung, versteht, abbildet, inventarisiert und kontrolliert.		a. Anzahl der Anforderungen von Datennutzern, die sich nicht einer Datenquelle zuordnen lassen b. Anzahl der geteilten Datenbestände c. Zeit seit der letzten Überprüfung der Einhaltung der Vorschriften bezüglich der Zuordnung von Geschäftsprozessen zu Daten
Aktivitäten		Fähigkeitsstufe
1. Bilden und gleichen Sie die Anforderungen von Datennutzern und -produzenten ab.		2
2. Definieren Sie die Zuordnung von Geschäftsprozessen zu Daten. Halten Sie sie aktuell und überprüfen Sie sie regelmäßig auf ihre Einhaltung.		3
3. Befolgen Sie einen definierten Prozess für Vereinbarungen zu Zusammenarbeit in Bezug auf gemeinsam genutzte Daten und die Datennutzung innerhalb von Geschäftsprozessen.		
4. Implementieren Sie Datenflüsse und bilden Sie den vollständigen Daten-zu-Prozessen-Lebenszyklus für gemeinsam genutzte Daten für jeden wichtigen Geschäftsprozess auf allen Ebenen der Organisation ab.		
5. Stellen Sie sicher, dass Änderungen an gemeinsam genutzten Datensätzen oder Zieldatensätzen für einen bestimmten Geschäftszweck von Daten-Governance-Strukturen unter Einbeziehung der relevanten Anspruchsgruppen gemanagt werden.		
6. Verwenden Sie Metriken, um die genehmigte wiederholte Verwendung von gemeinsam genutzten Daten zu erweitern und um Prozessredundanzen zu beseitigen.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Data Operations – Data Lifecycle Management
Managementpraktik		Beispielmetrik
AP014.09 Unterstützen der Datenarchivierung und -speicherung Stellen Sie sicher, dass die Datenverwaltung die organisatorischen und gesetzlichen Anforderungen an die Verfügbarkeit von historischen Daten erfüllt. Stellen Sie sicher, dass die gesetzlichen und behördlichen Anforderungen an die Datenarchivierung und -aufbewahrung erfüllt werden.		a. Anteil der erfolglosen Versuche, Daten zu archivieren b. Anteil der Datenverwaltungsaktivitäten, die die organisatorischen und behördlichen Anforderungen an die Verfügbarkeit historischer Daten sowie die gesetzlichen und behördlichen Anforderungen an die Datenarchivierung und -aufbewahrung erfüllen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie sicher, dass die Richtlinien das Management der Datenhistorie, einschließlich der Anforderungen an die Aufbewahrung, Vernichtung und den Prüfpfad, vorschreiben.	2
2. Stellen Sie sicher, dass eine definierte Methode besteht, die den Zugriff auf die historischen Daten gewährleistet, die zur Unterstützung der Geschäftsanforderungen erforderlich sind.	
3. Nutzen Sie Richtlinien und Prozessen zur Kontrolle des Zugriffs, der Übertragung und der Änderungen von historischen und archivierten Daten.	
4. Stellen Sie sicher, dass die Organisation über das vorgeschriebene Data-Warehouse-Repository verfügt, das den Zugriff auf historische Daten zur Erfüllung von Analyseerfordernissen zur Unterstützung von Geschäftsprozessen gewährleistet.	3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014	Platform and Architecture – Historical Data, Retention and Archiving
Managementpraktik	Beispielmetrik
AP014.10 Managen von Datensicherungs- und Wiederherstellungsmaßnahmen Managen Sie die Verfügbarkeit kritischer Daten, um die Betriebskontinuität zu gewährleisten.	a. Anteil der erfolglosen Versuche, Daten zu sichern b. Anteil der erfolgreichen Versuche, Sicherungsdaten wiederherzustellen
Aktivitäten	Fähigkeitsstufe
1. Definieren Sie einen Zeitplan, um die korrekte Sicherung aller kritischen Daten sicherzustellen.	2
2. Definieren Sie Anforderungen für die Speicherung von Sicherungsdaten vor Ort und außerhalb des Standorts unter Berücksichtigung des Volumens, der Kapazität und der Aufbewahrungszeit in Übereinstimmung mit den Geschäftsanforderungen.	
3. Erstellen Sie einen Testplan für Sicherungsdaten. Stellen Sie sicher, dass die Daten korrekt wiederhergestellt werden können, ohne dass das Geschäft erheblich beeinträchtigt wird.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 10: Data Recovery Capability

B. Komponente: Organisationsstrukturen							
Wichtige Managementpraktik:	Chief Risk Officer	Chief Information Officer	Chief Digital Officer	Risikoausschuss des Unternehmens	Chief Information Security Officer	Datenmanagement	Rechtsbeistand
AP014.01 Definieren und Kommunizieren der Datenmanagementstrategie des Unternehmens sowie der Rollen und Verantwortlichkeiten	R	A	R		R	R	
AP014.02 Definieren und Pflegen eines einheitlichen Geschäftsglossars	R	A	R		R	R	
AP014.03 Festlegen der Prozesse und der Infrastruktur für das Metadatenmanagement	R	A	R		R	R	
AP014.04 Definieren einer Datenqualitätsstrategie	R	A	R		R	R	
AP014.05 Festlegen von Methoden, Prozessen und Werkzeugen für das Data Profiling	R	A	R		R	R	
AP014.06 Sicherstellen eines Ansatzes zur Bewertung der Datenqualität	R	A	R		R	R	

B. Komponente: Organisationsstruktur (Forts.)									
AP014.07 Definieren des Datenbereinigungsansatzes	R	A	R		R	R			
AP014.08 Managen des Lebenszyklus von Datenbeständen	R	A	R	R	R	R	R		
AP014.09 Unterstützen der Datenarchivierung und -speicherung	R	A	R	R	R	R	R		
AP014.10 Managen von Datensicherungs- und Wiederherstellungsmaßnahmen	R	A	R		R	R	R		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)					Detaillierte Referenzen				
Keine entsprechenden weiteren Quellen für diese Komponente									

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
AP014.01 Definieren und Kommunizieren der Datenmanagementstrategie des Unternehmens sowie der Rollen und Verantwortlichkeiten	AP001.06	Richtlinien zur Datenklassifizierung	Strategie zum Datenmanagement	AP003.02, AP014.10
	AP007.03	Matrix der Fähigkeiten und Kompetenzen	Vereinbarte Rollen und Verantwortlichkeiten für Datenmanagement und Daten-Governance	Intern
	Außerhalb von COBIT	- Unternehmensstrategie - Richtlinien und Vorschriften zum Datenmanagement	Externe Veröffentlichungen und Präsentationen zu bewährten Praktiken auf Branchenkonzferenzen	Intern
			Implementierungsplan zur Datenmanagementstrategie	Intern
AP014.02 Definieren und Pflegen eines einheitlichen Geschäftsglossars			Geschäftsglossar	AP014.03, BAI02.01
AP014.03 Festlegen der Prozesse und der Infrastruktur für das Metadatenmanagement	AP003.02	Informationsarchitekturmodell	Metadaten-Dokumentation	AP003.02
	AP014.02	Geschäftsglossar		
AP014.04 Definieren einer Datenqualitätsstrategie	AP001.06	Verfahren zur Datenintegrität	Strategie zur Datenqualität	AP014.05, AP014.06, AP014.07
	AP001.07	Richtlinien zur Datensicherheit und -kontrolle	Berichte über Datenqualitätsprobleme	Intern
	AP011.01	Qualitätsmanagementpläne	Plan zur Verbesserung der Datenqualität	Intern
AP014.05 Festlegen von Methoden, Prozessen und Werkzeugen für das Data Profiling	AP014.04	Strategie zur Datenqualität	Definierte und standardisierte Methoden, Prozesse, Praktiken, Werkzeuge und Ergebnisvorlagen für das Data Profiling	Intern
AP014.06 Sicherstellen eines Ansatzes zur Bewertung der Datenqualität	AP011.01	Qualitätsmanagementpläne	Ergebnisse der Bewertung der Datenqualität	Intern
	AP014.04	Strategie zur Datenqualität		
AP014.07 Definieren des Datenbereinigungsansatzes	AP014.04	Strategie zur Datenqualität	Anforderungen an die Datenqualität	AP009.03

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)

APO14.08 Managen des Lebenszyklus von Datenbeständen	AP001.07	Richtlinien zur Datensicherheit und -kontrolle		
	DSS04.07	Datensicherung		
APO14.09 Unterstützen der Datenarchivierung und -speicherung	DSS06.05	Anforderungen an die Aufbewahrung	Datenarchiv	Intern
APO14.10 Managen von Datensicherungs- und Wiederherstellungsmaßnahmen	AP001.07	Richtlinien zur Datensicherheit und -kontrolle	Datensicherungs-Testplan	DSS04.07
	AP014.01	Strategie zum Datenmanagement	Datensicherungsplan	DSS04.07
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Datenanalyse	Skills Framework for the Information Age V6, 2015	DTAN
Datenmanagement	Skills Framework for the Information Age V6, 2015	DATM
Informationssicherung	Skills Framework for the Information Age V6, 2015	INAS
Informationsmanagement	Skills Framework for the Information Age V6, 2015	IRMG

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Bereinigung von Daten	Beschreibt die Selbstverpflichtung des Managements zur Datenbereinigung. Legt Häufigkeit, Richtlinien und Verantwortlichkeit fest und beschreibt verfügbare Methoden, Lösungen und Werkzeuge.	CMMI Data Management Maturity Model, 2014	Data Cleansing
Datenmanagementrichtlinie	Beschreibt die Verpflichtung der Organisation zum Managen von Datenbeständen über den gesamten Datenlebenszyklus hinweg, von der Erstellung bis zur Bereitstellung, Pflege und Archivierung.		
Richtlinie zur Bewertung der Datenqualität	Beschreibt den Bewertungsansatz der Organisation zur Sicherung der Datenqualität, um die Integrität der Daten zu gewährleisten, die für Entscheidungen mit Auswirkungen auf die Organisation verwendet werden. Legt Häufigkeit, Richtlinien und Verantwortlichkeit für die Bewertung der Datenqualität fest. Beschreibt verfügbare Methoden, Lösungen und Werkzeuge.	(1) CMMI Data Management Maturity Model, 2014; (2) National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	(1) Data Quality Assessment; (2) 3.20 System and information integrity (SI-1)

E. Komponente: Richtlinien und Verfahren (Forts.)			
Datenschutzrichtlinie	Beschreibt die Sammlung, Verwendung, Offenlegung und das Management von personenbezogenen Daten. Personenbezogene Daten können alle Daten sein, die zur Identifizierung einer Person verwendet werden können, wie z. B. Name, Adresse, Geburtsdatum, Familienstand, Kontaktinformationen, Ausweisausstellungs- und Ablaufdatum, Finanzdaten, Kreditinformationen, Krankengeschichte, Reiseziel und Absicht, Waren oder Dienstleistungen zu erwerben. Die Datenschutzerklärung definiert, wie ein Unternehmen personenbezogene Informationen sammelt, speichert und freigibt, wie und wann der Kunde über bestimmte gesammelte Informationen informiert wird und ob diese vertraulich behandelt, mit Partnern geteilt oder an andere Firmen oder Unternehmen verkauft werden. Die Erklärung schreibt die Einhaltung einschlägiger Rechtsvorschriften in Bezug auf den Datenschutz vor.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur der gemeinsamen Verantwortung für die Datenbestände der Organisation, erkennen Sie den potenziellen Wert der Datenbestände an und stellen Sie sicher, dass Rollen und Verantwortlichkeiten für die Governance und das Management der Datenbestände eindeutig sind.	CMMI Data Management Maturity Model, 2014	Data Governance
Schaffen Sie ein Verständnis hinsichtlich Datenintegrität, Genauigkeit, Vollständigkeit und Schutz, um ein Bewusstsein für Datenqualität zu etablieren. Setzen Sie die Datenqualität in Beziehung zu den Kernwerten des Unternehmens. Kommunizieren Sie fortwährend die Auswirkungen und Risiken von Datenverlusten. Stellen Sie sicher, dass den Mitarbeitern die tatsächlichen Kosten eines Versäumnisses der Etablierung einer Datenqualitätskultur bewusst sind.	CMMI Data Management Maturity Model, 2014	Data Quality

G. Komponente: Services, Infrastruktur und Anwendungen
• Werkzeuge zur Datenmodellierung • Daten-Repositories

Diese Seite wurde absichtlich freigelassen.

4.3 AUFBAUEN, BESCHAFFEN UND IMPLEMENTIEREN

- 01 Programme sind gemanagt
- 02 Anforderungsdefinition ist gemanagt
- 03 Lösungsidentifizierung und Lösungserstellung sind gemanagt
- 04 Verfügbarkeit und Kapazität sind gemanagt
- 05 Organisatorische Änderungen sind gemanagt
- 06 IT-Änderungen sind gemanagt
- 07 Umsetzung und Abnahme von IT-Änderungen sind gemanagt
- 08 Wissen ist gemanagt
- 09 Betriebsmittel sind gemanagt
- 10 Konfiguration ist gemanagt
- 11 Projekte sind gemanagt

Diese Seite wurde absichtlich freigelassen.

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI01 – Programme sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Koordiniertes und an der Unternehmensstrategie ausgerichtetes Management aller Programme des Investitionsportfolios, basierend auf einem Standard-Programm-Management-Ansatz. Initiierung, Planung, Kontrolle und Ausführung von Programmen und Überwachung des erwarteten Wertbeitrages des Programmes.		
Zweck		
Realisierung des gewünschten Geschäftswerts und Minderung des Risikos von unerwarteten Verzögerungen, Kosten und Wertverlusten, indem die Kommunikation zu und die Einbindung von Geschäfts- und Endbenutzern verbessert wird. Sicherstellen des Wertes und der Qualität von Programmsergebnissen und der Nachverfolgung von Projekten innerhalb der Programme sowie die Maximierung ihres Beitrags zum Investitionsportfolio.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio • AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
BAI01.01 Pflegen eines einheitlichen Ansatzes für das Programm-Management Pflegen Sie einen Standardansatz für das Programm-Management, der eine Überprüfung von Governance und Management sowie Aktivitäten zur Entscheidungsfindung und zum Management der Bereitstellung unterstützt. Der Fokus sollte dabei konsequent auf dem Geschäftswert und den Geschäftszielen (d. h. Anforderungen, Risiko, Kosten, Zeitplan und Qualitätsziele) liegen.	a. Anteil der erfolgreichen Programme, die auf dem definierten Standardansatz basieren b. Anteil der Anspruchsgruppen, die mit dem Programm-Management zufrieden sind

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie einen Standardansatz für das Programm-Management bereit, der an der spezifischen Situation des Unternehmens ausgerichtet ist und auf bewährten Verfahren auf der Grundlage eines definierten Prozesses und des Einsatzes geeigneter Technologie basiert und setzen Sie diesen um. Stellen Sie sicher, dass der Ansatz den gesamten Lebenszyklus und die zu berücksichtigenden Disziplinen abdeckt, einschließlich des Managements von Umfang, Ressourcen, Risiko, Kosten, Qualität, Zeit, Kommunikation, Einbeziehung der Anspruchsgruppen, Beschaffung, Änderungskontrolle, Integration und Nutzenrealisierung.	2
2. Richten Sie ein Programm- oder Projektmanagementbüro (PMO) ein, das die Anwendung des Standardansatzes für das Programm- und Projektmanagement in der gesamten Organisation sicherstellt. Das PMO unterstützt alle Programme und Projekte, indem es die erforderlichen Vorlagen für die Projektdokumentation erstellt und pflegt, Schulungen und bewährte Verfahren für Programm-/Projektmanager bereitstellt, Kennzahlen zur Verwendung bewährter Verfahren für das Projektmanagement ermittelt usw. In einigen Fällen kann das PMO auch der Geschäftsleitung und/oder den Anspruchsgruppen über den Programm-/Projektfortschritt berichten, bei der Priorisierung von Projekten helfen und sicherstellen, dass alle Projekte die allgemeinen Geschäftsziele des Unternehmens unterstützen.	3
3. Aktualisieren Sie den Ansatz für das Programm-Management basierend auf den aus seiner Anwendung gewonnenen Erkenntnissen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI01.02 Initiieren eines Programms Initiieren Sie ein Programm zur Überprüfung des erwarteten Nutzens, und holen Sie die Genehmigung zu dessen Fortsetzung ein. Dazu gehören die Vereinbarung der Trägerschaft (Sponsorship) für das Programm, die Bestätigung des Programm-Mandats in Form der Genehmigung des konzeptionellen Business Cases, die Benennung von Mitgliedern für den Programmausschuss, die Erstellung der Programmbeschreibung, die Überprüfung und Aktualisierung des Business Case, die Entwicklung eines Plans für die Nutzenrealisierung sowie die Einholung der Genehmigung zum Fortfahren seitens der Sponsoren.	a. Anteil der I&T-Initiativen/Projekte, die von Geschäftsverantwortlichen befürwortet werden b. Anteil der strategischen Initiativen mit zugewiesener Verantwortlichkeit c. Anteil der Programme, die ohne genehmigten Business Case durchgeführt wurden d. Anteil der Anspruchsgruppen, die den Bedarf des Unternehmens, den Umfang, das geplante Ergebnis und den Grad des Programmrisikos befürworten
Aktivitäten	Fähigkeitsstufe
1. Verständigen Sie sich auf die Programmträgerschaft. Benennen Sie Mitglieder für den Programmausschuss, die ein strategisches Interesse an dem Programm haben, zuständig für die Investitionsentscheidung und maßgeblich von dem Programm betroffen sind und deren Aufgaben es sein wird, die Umsetzung der Änderung zu ermöglichen.	2
2. Benennen Sie einen eigens für das Programm zuständigen Manager, der über die erforderlichen Kompetenzen und Fähigkeiten verfügt, das Programm effektiv und effizient zu managen.	
3. Bestätigen Sie das Programm-Mandat gemeinsam mit den Sponsoren und Anspruchsgruppen. Formulieren Sie die strategischen Zielvorgaben für das Programm, potenzielle Strategien für die Bereitstellung sowie Verbesserungen und Vorteile, die von dem Programm erwartet werden und legen Sie dar, wie sich das Programm in andere Initiativen einfügt.	3
4. Entwickeln Sie einen detaillierten Business Case für das Programm. Beziehen Sie alle wichtigen Anspruchsgruppen in die Entwicklung und Dokumentation eines umfassenden Verständnisses der erwarteten Unternehmensergebnisse ein. Erarbeiten Sie, wie diese Ergebnisse gemessen werden, welche Initiativen insgesamt erforderlich sind, welches Risiko damit verbunden ist und welche Auswirkungen sich für sämtliche Unternehmensaspekte ergeben. Identifizieren und beurteilen Sie alternative Handlungsoptionen zur Erreichung der gewünschten Unternehmensergebnisse.	
5. Entwickeln Sie einen Nutzenrealisierungsplan, der während des gesamten Programms gemanagt wird und sicherstellen soll, dass der geplante Nutzen jederzeit Verantwortlichen zugeordnet, erzielt, unterstützt und optimiert wird.	
6. Erarbeiten Sie einen vorläufigen (konzeptionellen) Business Case zu dem Programm, der wesentliche Informationen für die Entscheidungsfindung z. B. Zweck, Beitrag zu geschäftlichen Zielvorgaben, erwartete Wertbeiträge, Zeitrahmen usw. enthält und reichen Sie ihn zur Genehmigung ein.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
BAI01.03 Managen der Einbeziehung von Anspruchsgruppen Managen Sie die Einbeziehung von Anspruchsgruppen, um einen aktiven Austausch von genauen, konsistenten und zeitnahen Informationen für alle relevanten Anspruchsgruppen zu gewährleisten. Dazu gehört die Planung, Identifizierung und Einbeziehung der Anspruchsgruppen und das Managen ihrer Erwartungen.		a. Grad der Zufriedenheit der Anspruchsgruppen mit der Einbeziehung b. Anteil der effektiv einbezogenen Anspruchsgruppen
Aktivitäten		Fähigkeitsstufe
1. Planen Sie, wie Anspruchsgruppen innerhalb und außerhalb des Unternehmens für die Dauer des gesamten Projektlebenszyklus identifiziert, analysiert, einbezogen und gemanagt werden sollen.		3
2. Sorgen Sie für die Identifizierung, Einbeziehung und das Management der Anspruchsgruppen, indem Sie ein geeignetes Maß an Koordination, Kommunikation und Kontaktpflege etablieren und aufrecht erhalten und damit die Einbindung der Anspruchsgruppen in das Programm sicherstellen.		
3. Analysieren Sie die Interessen und Anforderungen der Anspruchsgruppen.		
4. Befolgen Sie einen definierten Prozess für Kooperationsvereinbarungen in Bezug auf gemeinsam genutzte Daten und die Datennutzung innerhalb von Geschäftsprozessen.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 10. Project communications management
Managementpraktik		Beispielmetrik
BAI01.04 Entwickeln und Pflegen des Programmplans Formulieren Sie ein Programm, um die Grundlagen zu schaffen. Sorgen Sie für eine erfolgreiche Umsetzung, indem Sie den Umfang der erforderlichen Arbeiten formulieren und Ergebnisse identifizieren, die zur Zieleerfüllung beitragen und einen Wertbeitrag liefern. Pflegen und aktualisieren Sie den Programmplan und den Business Case während des gesamten wirtschaftlichen Lebenszyklus des Programms. Stellen Sie sicher, dass diese jederzeit an den strategischen Zielvorgaben ausgerichtet sind und den aktuellen Status sowie die neuesten, bis dato gewonnenen Erkenntnisse abbilden.		a. Häufigkeit von Programmstatusüberprüfungen, in deren Rahmen nicht realisierte Vorteile identifiziert werden b. Anteil aktiver Programme, die ohne gültige und aktualisierte Planung des Programmwertbeitrags durchgeführt werden
Aktivitäten		Fähigkeitsstufe
1. Legen Sie Finanzierung, Kosten, Zeitplan und Abhängigkeiten zwischen mehreren Projekten fest.		2
2. Definieren und dokumentieren Sie den Programmplan und decken Sie darin sämtliche Projekte ab. Legen Sie dar, was für die Herbeiführung von Änderungen im Unternehmen erforderlich ist und machen Sie Angaben zu dem Zweck, der Mission, der Vision, den Werten, der Kultur sowie zu den Produkten und Services des Unternehmens, zu Geschäftsprozessen, zu Fähigkeiten der Mitarbeiter und ihrer Anzahl, zu Beziehungen zu Anspruchsgruppen, Kunden, Anbietern und sonstigen Parteien, zu technologischen Anforderungen sowie zur organisatorischen Umstrukturierung, die für die Erreichung der im Programm definierten, erwarteten Unternehmensergebnisse erforderlich ist.		3
3. Stellen Sie sicher, dass Programmpläne und Fortschrittsberichte effektiv projektübergreifend und programmweit kommuniziert werden. Stellen Sie sicher, dass alle an einzelnen Plänen vorgenommenen Änderungen in den anderen Programmplänen des Unternehmens berücksichtigt werden.		
4. Pflegen Sie den Programmplan, um sicherzustellen, dass er auf dem neuesten Stand ist und sich an den aktuellen strategischen Zielvorgaben, dem tatsächlichen Fortschritt und wesentlichen Änderungen der Ergebnisse, an den Vorteilen und Kosten sowie am Risiko orientiert. Sorgen Sie dafür, dass die Zielvorgaben im Rahmen des Geschäftsbetriebs ausreichende Berücksichtigung finden und setzen Sie Prioritäten für die zu erledigenden Arbeiten, um sicherzustellen, dass das Programm in seiner jeweiligen Konzeption die Unternehmensanforderungen erfüllt. Überprüfen Sie den Fortschritt einzelner Projekte, und nehmen Sie ggf. Anpassungen vor, um geplante Freigaben und Meilensteinen zu erreichen.		
5. Aktualisieren und pflegen Sie während des gesamten wirtschaftlichen Lebenszyklus des Programms den Business Case und ein Nutzenregister, um wichtige Vorteile zu identifizieren und zu definieren, die aus der Umsetzung des Programms resultieren.		
6. Erstellen Sie ein Programmbudget, das die Kosten über den gesamten wirtschaftlichen Lebenszyklus widerspiegelt sowie die damit verbundenen finanziellen und nicht finanziellen Vorteile.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI01.05 Starten und Ausführen des Programms Starten Sie das Programm und führen Sie es aus, um die Ressourcen zu beschaffen und zu lenken, die für die Erreichung der im Programmplan definierten Ziele und Nutzenvorteile erforderlich sind. Bereiten Sie, unter Berücksichtigung der jeweiligen Kriterien für die Stage-Gate- oder Release-Überprüfung, die Stage-Gate-, Iterations- oder Release-Überprüfung vor, um einen Bericht zum Fortschritt des Programms zu erstellen und Argumente für die Bereitstellung von Mitteln bis zur nächsten Stage-Gate- oder Release-Überprüfung zu identifizieren.		a. Anteil der erfolgten Anspruchsgruppenfreigaben für Stage-Gate-Überprüfungen aktiver Programme b. Anzahl der Ursachenanalysen für Planabweichungen und erforderliche Abhilfemaßnahmen
Aktivitäten		Fähigkeitsstufe
1. Sorgen Sie für die Planung und Beschaffung der Ressourcen und Beauftragung der Projekte, die für die Erreichung der Programmergebnisse erforderlich sind. Beziehen Sie sich dabei auf die Finanzierungsüberprüfung und Genehmigungen der einzelnen Stage-Gate-Überprüfungen.		3
2. Managen Sie jedes Programm bzw. Projekt so, dass der Fokus der Entscheidungsfindungs- und Bereitstellungsaktivitäten auf der Generierung von Wert liegt und dabei konsequent Vorteile für das Unternehmen erzielt und die festgelegten Ziele erreicht, das Risiko bewältigt und die Anforderungen der Anspruchsgruppen erfüllt werden.		
3. Vereinbaren Sie Phasen des Entwicklungsprozesses und richten Sie sie ein (Entwicklungskontrollpunkte). Erörtern Sie am Ende einer jeden Phase formell die genehmigten Kriterien mit den Anspruchsgruppen. Holen Sie nach erfolgreicher Durchführung der Funktions-, Leistungs- und Qualitätsüberprüfungen und vor Abschluss der Aktivitäten der jeweiligen Phase, die formelle Genehmigung und Freigabe aller Anspruchsgruppen sowie vom Sponsor/Geschäftsprozessverantwortlichen ein.		
4. Führen Sie während des gesamten Programms einen Prozess zur Nutzenrealisierung aus, um sicherzustellen, dass die geplanten Vorteile jederzeit Verantwortlichen zugeordnet sind und erzielt, unterstützt und optimiert werden können. Überwachen Sie bei jeder Stage-Gate- oder Iterations- und Release-Überprüfung die Bereitstellung von Mehrwert und vergleichen Sie diese mit den vorgesehenen Leistungszielen. Führen Sie bei Abweichungen vom Plan eine Ursachenanalyse durch und identifizieren und initiieren Sie ggf. geeignete Abhilfemaßnahmen.		4
5. Planen Sie Audits, Qualitätsprüfungen, Phasen-/Stage-Gate-Prüfungen und Überprüfungen des realisierten Nutzens ein.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI01.06 Überwachen, Kontrollieren und Berichten der Programmergebnisse Überwachen und kontrollieren Sie die Leistung während des gesamten Wirtschaftslebenszyklus der Investition, einschließlich der Lösungsbereitstellung auf Programmebene und dem Wert/Ergebnis auf Unternehmensebene und vergleichen Sie diese mit dem Plan. Berichten Sie dem Lenkungsausschuss des Programms und den Sponsoren über die Leistung.		a. Anteil des erwarteten Programmnutzens, der tatsächlich erzielt wurde b. Anteil der Programme, deren Leistung überwacht und bei denen bei Bedarf rechtzeitig Abhilfemaßnahmen ergriffen wurden
Aktivitäten		Fähigkeitsstufe
1. Aktualisieren Sie operative I&T-Portfolios, um Änderungen abzubilden, die sich aufgrund des Programms für die jeweiligen Portfolios für I&T-Services, -Betriebsmittel oder -Ressourcen ergeben.		3

A. Komponente: Prozess (Forts.)		
2. Überwachen und kontrollieren Sie die Leistung des Gesamtprogramms und der darin enthaltenen Projekte unter Berücksichtigung des jeweiligen Beitrags von Geschäft und IT zu den Projekten. Berichten Sie zeitnah, vollständig und genau. Der Bericht kann u. a. Bezug auf den Zeitplan, die Finanzierung, Funktionalität und Benutzerzufriedenheit, auf interne Kontrollen und auf die Übernahme von Verantwortlichkeiten nehmen.		4
3. Überwachen und kontrollieren Sie die Leistung unter Berücksichtigung der Unternehmens- und I&T-Strategien und -Ziele. Machen Sie gegenüber dem Management Angaben zu den implementierten unternehmensbezogenen Änderungen, zu realisiertem Nutzen im Vergleich zum Realisierungsplan sowie zur Angemessenheit des Realisierungsprozesses.		
4. Überwachen und kontrollieren Sie IT-Services, -Betriebsmittel und -Ressourcen, die infolge des Programms entstanden sind oder geändert wurden. Notieren Sie den Zeitpunkt von Implementierung und Inbetriebnahme. Erstellen Sie dem Management Bericht über Leistungsstufen, die nachhaltige Servicebereitstellung und den Wertbeitrag.		
5. Managen Sie die Programmleistung unter Berücksichtigung wichtiger Kriterien (z. B. Umfang, Zeitplan, Qualität, Nutzenrealisierung, Kosten, Risiko, Geschwindigkeit), identifizieren Sie Abweichungen vom Plan, und initiieren Sie ggf. zeitnah Abhilfemaßnahmen.		
6. Überwachen Sie die Leistung einzelner Projekte im Hinblick auf erwartete Befähigungen, Zeitplan, Nutzenrealisierung, Kosten, Risiko oder sonstige Metriken. Identifizieren Sie potenzielle Auswirkungen auf die Programmleistung und ergreifen Sie bei Bedarf rechtzeitig Abhilfemaßnahmen.		
7. Führen Sie, unter Berücksichtigung der jeweiligen Kriterien für die Stage-Gate-, Release- oder Iterationsüberprüfung, Überprüfungen durch, um Bericht zum Fortschritt des Programms zu erstatten, auf dessen Grundlage das Management Entscheidungen zur Fortsetzung bzw. zu Anpassungen treffen und die weitere Finanzierung bis zum nächsten Stage Gate, Release oder zur nächsten Iteration genehmigen kann.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI01.07 Managen der Programmqualität Erstellen Sie einen Qualitätsmanagementplan nebst Prozessen und Verfahren, der an den Qualitätsmanagementstandards (QMS) ausgerichtet ist, und setzen Sie diesen um. Beschreiben Sie den Ansatz zur Programmqualität und -implementierung. Der Plan sollte von allen betroffenen Parteien formell überprüft, verabschiedet und anschließend in den integrierten Programmplan aufgenommen werden.		a. Anteil der fehlerfrei erzeugten Programmpakete b. Anteil der Programmergebnisse, die beim jeweiligen Gate-Review genehmigt werden
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie die Prüfaufgaben und -verfahren, die erforderlich sind, um die Akkreditierung neuer oder geänderter Systeme während der Programmplanung zu unterstützen und nehmen Sie diese in die integrierten Pläne auf. Stellen Sie sicher, dass anhand dieser Aufgaben bestätigt werden kann, dass interne Kontrollen und Datenschutz-/Sicherheitslösungen die definierten Anforderungen erfüllen.		3
2. Identifizieren Sie, um die Qualitätssicherung der Programmergebnisse sicherzustellen, Verantwortung und Zuständigkeiten, Qualitätsüberprüfungsprozesse, Erfolgskriterien und Leistungsmetriken.		
3. Definieren Sie im Plan die Anforderungen für eine unabhängige Validierung und Verifizierung der Qualität der Pflichtergebnisse.		4
4. Führen Sie gemäß den Bestimmungen des Qualitätsmanagementplans und des QMS Qualitätssicherungs- und Kontrollaktivitäten durch.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI01.08 Managen des Programmrisikos Eliminieren oder minimieren Sie das spezifische Risiko in Verbindung mit Programmen anhand eines systematischen Prozesses zur Planung, Identifizierung, Analyse, Behandlung, Überwachung und Kontrolle derjenigen Bereiche oder Ereignisse, die ein Potenzial für unerwünschte Änderungen bergen. Definieren und erfassen Sie alle Risiken, die im Rahmen des Programmmanagements auftreten.		a. Anteil der Programme ohne sachgemäße Risikobewertung b. Anteil der Programme, die auf das Rahmenwerk für das Unternehmensrisikomanagement abgestimmt sind

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie einen am Rahmenwerk für das unternehmensweite Risikomanagement (ERM) orientierten, formellen Ansatz für das Risikomanagement. Stellen Sie sicher, dass der Ansatz die Identifizierung, Analyse, Behandlung, Minderung, Überwachung und Kontrolle des Risikos umfasst.		3
2. Weisen Sie entsprechend qualifizierten Mitarbeitern die Verantwortung für die Umsetzung des unternehmensweiten Risikomanagementprozesses innerhalb eines Programms zu und stellen Sie sicher, dass dies in die Praktiken der Lösungsentwicklung integriert wird. Ziehen Sie in Betracht, diese Rolle einem unabhängigen Team zuzuweisen, insbesondere wenn eine objektive Sichtweise erforderlich ist oder ein Programm als kritisch einzustufen ist.		
3. Führen Sie eine Risikobewertung durch, indem Sie das Risiko permanent während des gesamten Programms identifizieren und quantifizieren. Managen und kommunizieren Sie das Risiko angemessen im Rahmen der Programm-Governance-Struktur.		
4. Identifizieren Sie Verantwortliche für Maßnahmen, die auf die Vermeidung, Akzeptanz oder Minderung des Risikos ausgelegt sind.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI01.09 Schließen eines Programms Entfernen Sie das Programm aus dem aktiven Investitionsportfolio, wenn Einigkeit darüber besteht, dass der gewünschte Wert erreicht wurde, oder wenn feststeht, dass der Wert nicht im Rahmen der für das Programm festgelegten Wertkriterien erreicht werden kann.		a. Anteil der erfolgreich abgeschlossenen Programme, die den gewünschten Wert generiert haben b. Zeit zwischen Programmstart und der Erkennung der Erreichbarkeit des Wertes
Aktivitäten		Fähigkeitsstufe
1. Bringen Sie das Programm zu einem ordentlichen Abschluss. Dazu gehören die formelle Abnahme, die Auflösung der Organisations- und Unterstützungsfunktionen des Programms, die Validierung der Pflichtergebnisse sowie die Kommunikation der Programminaktivsetzung.		3
2. Überprüfen und dokumentieren Sie gewonnene Erkenntnisse. Entfernen Sie das Programm im Anschluss an die Stilllegung aus dem aktiven Investitionsportfolio. Überführen Sie alle resultierenden Fähigkeiten in ein operatives Betriebsmittelfolio, um sicherzustellen, dass weiterhin Wert geschaffen und erhalten wird.		4
3. Implementieren Sie geeignete Verantwortlichkeiten und Prozesse, die sicherstellen, dass das Unternehmen kontinuierlich den Wert optimiert, den es aus Services, Betriebsmitteln oder Ressourcen generiert. Möglicherweise sind zu einem späteren Zeitpunkt zusätzliche Investitionen erforderlich, um dies sicherzustellen.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018		RS.IM Improvements

		Chief Executive Officer	Chief Risk Officer	Chief Information Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Lenkungsausschuss für Projekte und Programme	Programm-Manager	Project Management Office	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb
Wichtige Managementpraktik:												
BAI01.01 Pflegen eines einheitlichen Ansatzes für das Programmmanagement		A	R	R			R					
BAI01.02 Initiieren eines Programms			R			R	A	R	R			
BAI01.03 Managen der Einbeziehung von Anspruchsgruppen						R	A	R	R			
BAI01.04 Entwickeln und Pflegen des Programmplans							A	R	R			
BAI01.05 Starten und Ausführen des Programms				R		R	A	R	R			
BAI01.06 Überwachen, Kontrollieren und Berichten der Programmergebnisse				R			A	R	R	R	R	R
BAI01.07 Managen der Programmqualität						R	A	R	R			
BAI01.08 Managen des Programmriskos			R			R	A	R	R		R	
BAI01.09 Schließen eines Programms				R		R	A	R	R		R	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen										
Keine entsprechenden weiteren Quellen für diese Komponente												

Managementpraktik	Inputs		Outputs	
BAI01.01 Pflegen eines einheitlichen Ansatzes für das Programmmanagement	Von	Beschreibung	Beschreibung	Für
	AP003.04	- Beschreibungen der Implementierungsphase - Anforderungen an die Governance der Architektur	Aktualisierte Programmmanagement-Ansätze	Intern
	AP005.04	Aktualisierte Portfolios von Programmen, Services und Betriebsmitteln		
	AP010.04	Identifiziertes Lieferanten-Lieferrisiko		
	EDM02.03	Anforderungen für Stagegate-Reviews		
	EDM02.04	Maßnahmen zur Verbesserung der Wertschöpfung		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
BAI01.02 Initiieren eines Programms	AP003.04	• Ressourcenanforderungen • Beschreibungen der Implementierungsphase	Programm-Mandat und Satzung	AP005.02
	AP005.02	Business Case des Programms	Business Case des Programmkonzepts	AP005.02
	AP007.03	Matrix der Fähigkeiten und Kompetenzen	Plan zur Realisierung des Programmnutzens	AP005.02, AP006.05
	BAI05.02	Gemeinsame Vision und Ziele		
BAI01.03 Managen der Einbeziehung von Anspruchsgruppen			Ergebnisse der Bewertungen der Effektivität der Einbindung der Anspruchsgruppen	Intern
			Plan zur Einbindung der Anspruchsgruppen	Intern
BAI01.04 Entwickeln und Pflegen des Programmplans	AP005.02	Ausgewählte Programme mit ROI-Meilensteinen	Programmbudget und Nutzenregister	AP005.05, AP006.05
	AP007.03	Matrix der Fähigkeiten und Kompetenzen	Ressourcenanforderungen und Rollen	AP007.05, AP007.06
	AP007.05	Bestandsaufnahme des für den Geschäftsbetrieb und für IT eingesetzten Personals	Programmplan	Intern
	BAI05.02	Implementierungsteam und Rollen		
	BAI05.03	Plan zur Kommunikation der Vision		
	BAI05.04	Identifizierte „Quick Wins“		
	BAI07.03	Genehmigter Abnahmetestplan		
	BAI07.05	Genehmigte Abnahme und Freigabe zur Produktion		
BAI01.05 Starten und Ausführen des Programms	BAI05.03	Kommunikation der Vision	Ergebnisse der Überwachung der Programmzielerreichung	AP002.04
			Ergebnisse der Überwachung der Nutzenrealisierung	AP005.05, AP006.05
			Plan der Programmprüfungen	MEA04.02

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
BAI01.06 Überwachen, Kontrollieren und Berichten der Programmergebnisse	Von	Beschreibung	Beschreibung	Für
	APO05.01	Renditeerwartungen	Stage-Gate-Review-Ergebnisse	APO02.04, APO05.03, EDM02.02
	APO05.02	Bewertung des Business Case	Ergebnisse der Programm-Leistungsbewertungen	MEA01.03
	APO05.03	Investitionsportfolio-Leistungsberichte		
	APO05.05	- Resultierender Nutzen und zugehörige Kommunikation - Korrekturmaßnahmen zur Verbesserung der Nutzenrealisierung		
	APO07.05	- Analysen des Ressourcenmangels - Erfassung der Ressourcennutzung		
	BAI05.04	Kommunikation der Vorteile		
	BAI06.03	Statusberichte zu Änderungsanträgen		
	BAI07.05	Bewertung der Abnahmeergebnisse		
	EDM02.04	Feedback zu Portfolio- und Programmleistung		
BAI01.07 Managen der Programmqualität	APO11.01	Qualitätsmanagementpläne	Qualitätsmanagementplan	BAI02.04, BAI03.06, BAI07.01
	APO11.02	Kundenanforderungen an das Qualitätsmanagement	Anforderungen an die unabhängige Verifizierung von Ergebnissen	BAI07.03
BAI01.08 Managen des Programmriskos	APO12.02	Ergebnisse der Risikoanalyse	Programm-Risikoregister	Intern
	BAI02.03	- Risikoregisteranforderungen - Maßnahmen zur Risikominderung	Ergebnisse der Bewertung des Programmriskos	Intern
	Außerhalb von COBIT	Rahmenwerk für das unternehmensweite Risikomanagement (ERM)	Programm-Risikomanagementplan	Intern
BAI01.09 Schließen eines Programms	BAI07.08	- Überprüfungsbericht nach der Implementierung - Plan für Abhilfemaßnahmen	Kommunikation über die Inaktivsetzung des Programms und laufende Verantwortlichkeiten	APO05.04, APO07.06
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 4. Project integration management: Inputs and Outputs; Part 1: 6. Project schedule management: Inputs and Outputs; Part 1: 10. Project communications management: Inputs and Outputs; Part 1: 11. Project risk management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Nutzenmanagement	Skills Framework for the Information Age V6, 2015	BENM
Entwicklung von Business Plänen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.3. Business Plan Development
Programm-Management	Skills Framework for the Information Age V6, 2015	PGMG
Projekt- und Portfoliomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.2. Project and Portfolio Management

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Programm-/Projektmanagementrichtlinie	Anleitung für das Risikomanagement im Zusammenhang mit Programmen und Projekten. Enthält detaillierte Angaben zur Managementposition und zu den Erwartungen hinsichtlich des Programm- und Projektmanagements. Behandelt Verantwortlichkeit, Ziele und Zielvorgaben in Bezug auf Leistung, Budget, Risikoanalyse, Berichterstattung und Eindämmung von unerwünschten Ereignissen während der Programm-/Projektumsetzung.	PMBOK Guide Sixth Edition, 2017	Part 1: 2.3.1 Processes, policies and procedures

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Stellen Sie sicher, dass die Organisation den Wert des unternehmensweiten Programm-Managements versteht und unterstützt. Etablieren Sie eine unternehmensweite Kultur, die eine konsequente Umsetzung des Programm-Managements unter Berücksichtigung der Organisationsstruktur und des Geschäftsumfelds fördert. Stellen Sie sicher, dass das Programmbüro einen umfassenden Überblick über alle Programme im Unternehmensportfolio hat.		

G. Komponente: Services, Infrastruktur und Anwendungen

Werkzeuge zum Programm-Management

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI02 – Anforderungsdefinition ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Identifizieren von Lösungen und analysieren der Anforderungen im Vorfeld der Übernahme oder Erstellung, um sicherzustellen, dass diese mit den strategischen Anforderungen des Unternehmens in Bezug auf Geschäftsprozesse, Anwendungen, Informationen/Daten, Infrastruktur und Services übereinstimmen. Koordination der Überprüfung von durchführbaren Optionen mit den betroffenen Anspruchsgruppen, einschließlich der relativen Kosten und Vorteile, der Risikoanalyse und der Genehmigung der Anforderungen und Lösungsvorschläge.		
Zweck		
Entwicklung optimaler Lösungen, die den Bedürfnissen des Unternehmens Rechnung tragen und gleichzeitig das Risiko minimieren.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen • AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
BAI02.01 Definieren und Pflegen der funktionalen geschäftlichen und technischen Anforderungen Identifizieren, priorisieren, spezifizieren und vereinbaren Sie, basierend auf dem Business Case, geschäftsbezogene Informationen, funktionale und technische Anforderungen sowie Kontrollanforderungen in Bezug auf den Umfang/das Verständnis aller Initiativen, die erforderlich sind, um die erwarteten Ergebnisse der vorgeschlagenen I&T-gestützten Geschäftslösung zu erreichen.	a. Anteil der Anforderungen, die wegen fehlerhafter Ausrichtung an den Bedürfnissen und Erwartungen des Unternehmens überarbeitet wurden b. Anteil der Anforderungen, die durch Ansätze wie Überprüfung durch Fachkollegen (Peer-Review), Modellvalidierung oder Umsetzung von Prototypen validiert wurden	
Aktivitäten	Fähigkeitsstufe	
1. Stellen Sie sicher, dass alle Anforderungen der Anspruchsgruppen, einschließlich relevanter Akzeptanzkriterien, in einer für alle Anspruchsgruppen verständlichen Weise berücksichtigt, erfasst, priorisiert und aufgezeichnet werden, wobei Sie sich bewusst machen sollten, dass die Anforderungen sich ändern können und mit der Umsetzung detaillierter werden.	2	
2. Formulieren Sie die Geschäftsanforderungen so, dass daraus hervorgeht, wie die Lücke zwischen den derzeitigen und den gewünschten Geschäftsbefähigungen geschlossen werden soll, und wie der Anwender (Mitarbeiter, Kunde usw.) mit der Lösung interagieren und sie nutzen wird.		
3. Spezifizieren und priorisieren Sie die Informationen sowie die funktionalen und technischen Anforderungen auf der Grundlage des User Experience Designs und der bestätigten Anforderungen der Anspruchsgruppen.		
4. Stellen Sie sicher, dass die Anforderungen den Unternehmensrichtlinien und -standards, der Unternehmensarchitektur, den strategischen und taktischen I&T-Plänen, den internen und ausgelagerten Geschäfts- und IT-Prozessen, den Sicherheitsanforderungen, den behördlichen Anforderungen, den Kompetenzen der Mitarbeiter, der Organisationsstruktur, dem Business Case und der unterstützenden Technologie entsprechen.	3	
5. Beziehen Sie Anforderungen an die Informationskontrolle in die Geschäftsprozesse, automatisierten Prozesse und I&T-Umgebungen mit ein, um Informationsrisiken zu bewältigen und Gesetze, Vorschriften und Handelsverträge einzuhalten.		
6. Überprüfen Sie die Akzeptanz wichtiger Aspekte der Anforderungen, z. B. Unternehmensregeln, Benutzererfahrung, Informationskontrollen, Geschäftskontinuität, rechtliche und behördliche Compliance, Prüffähigkeit, Ergonomie, Betriebs- und Nutzungsfähigkeit, Sicherheit der Vertraulichkeit und der unterstützenden Dokumentation.		
7. Verfolgen und kontrollieren Sie, vor dem Hintergrund der stetigen Weiterentwicklung des Lösungsverständnisses, den Umfang, die Anforderungen und die Änderungen im Lebenszyklus der Lösung.		
8. Definieren und implementieren Sie ein Verfahren für die Definition und Pflege von Anforderungen sowie ein Repository mit Anforderungen, die der Größe und Komplexität, den Zielvorgaben und dem Risiko der Initiative, die das Unternehmen umzusetzen beabsichtigt, angemessen sind.		
9. Validieren Sie sämtliche Anforderungen durch geeignete Ansätze, wie z. B. Überprüfung durch Fachkollegen (Peer Review), Modellvalidierung oder Umsetzung von Prototypen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016	SD2.1 Specifications of Requirements	
ISO/IEC 27002:2013/Cor.2:2015(E)	14.1 Security requirements of information systems	
ITIL V3, 2011	Service Design, 5.1 Requirements engineering	
PMBOK Guide Sixth Edition, 2017	Part 1: 5. Project scope management	
Managementpraktik	Beispielmetrik	
BAI02.02 Durchführen einer Machbarkeitsstudie und Formulieren alternativer Lösungen Führen Sie eine Machbarkeitsstudie möglicher alternativer Lösungen durch, beurteilen Sie deren Durchführbarkeit und wählen Sie die bevorzugte Option aus. Implementieren Sie die gewählte Option gegebenenfalls als Pilot, um mögliche Verbesserungen zu ermitteln.	a. Anteil der Zielvorgaben aus dem Business Case, die von der vorgeschlagenen Lösung erfüllt werden b. Anteil der Anforderungen, die durch die vorgeschlagene Lösung erfüllt werden	

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie die für die Zurverfügungstellung oder Entwicklung von Lösungen auf der Grundlage der Unternehmensarchitektur erforderlichen Maßnahmen. Berücksichtigen Sie Umfang und/oder zeitliche bzw. budgetäre Einschränkungen.	2
2. Prüfen Sie die alternativen Lösungen gemeinsam mit sämtlichen Anspruchsgruppen. Wählen Sie unter Berücksichtigung der Machbarkeitskriterien, Risiken und Kosten die am besten geeignete Lösung aus.	
3. Setzen Sie die bevorzugte Vorgehensweise in einen allgemeinen Beschaffungs-/Entwicklungsplan um und identifizieren Sie dabei die zu nutzenden Ressourcen sowie Iterationen (Stages), die eine Go/No-Go-Entscheidung erfordern.	3
4. Definieren und verwirklichen Sie eine Machbarkeitsstudie, ein Pilotkonzept oder eine Basislösung, die klar und prägnant die alternativen Lösungen beschreibt und misst, wie diese die geschäftlichen und funktionellen Anforderungen erfüllen würden. Bewerten Sie darin auch die technologische und wirtschaftliche Machbarkeit.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI02.03 Managen des Anforderungsrisikos Identifizieren, dokumentieren, priorisieren und mindern Sie das funktionale, das technische und das auf die Informationsverarbeitung bezogene Risiko, das mit den Unternehmensanforderungen, Annahmen und der vorgeschlagenen Lösung einhergeht.	a. Anteil des erkannten Anforderungsrisikos, das nicht durch eine angemessene Reaktion auf das Risiko abgedeckt wird b. Detaillierungsgrad des dokumentierten Anforderungsrisikos c. Vollständigkeit der geschätzten Wahrscheinlichkeit und der Auswirkungen der aufgelisteten Anforderungsrisiken und Risikobewertungen
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie das Risiko von Qualitäts-, Funktions- und technischen Anforderungen (z. B. aufgrund mangelnder Einbeziehung der Anwender, unrealistischer Erwartungen, des Hinzufügens unnötiger Funktionalität durch die Entwickler, unrealistischer Annahmen usw.).	3
2. Bestimmen Sie eine angemessene Reaktion auf das Anforderungsrisiko.	
3. Analysieren Sie das identifizierte Risiko durch Abschätzung der Wahrscheinlichkeit und der Auswirkungen auf Budget und Zeitplan. Bewertung Sie die budgetären Auswirkungen geeigneter Maßnahmen zur Reaktion auf Risiken.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI02.04 Einholen der Genehmigung für Anforderungen und Lösungen Koordinieren Sie die Rückmeldungen der betroffenen Anspruchsgruppen. Holen Sie an vorab festgelegten, wichtigen Punkten die Genehmigung und Freigabe des Geschäftssponsors oder Produktverantwortlichen für funktionale und technische Anforderungen, Machbarkeitsstudien, Risikoanalysen und empfohlene Lösungen ein.	a. Grad der Zufriedenheit der Anspruchsgruppen mit den Anforderungen b. Anzahl der während der Überprüfungen festgestellten Abweichungen der Lösung vom Konzept c. Anteil der Anspruchsgruppen, die die Lösung in Bezug auf den Business Case nicht genehmigen
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie sicher, dass der geschäftsseitige Sponsor oder Produktverantwortliche die endgültige Entscheidung in Bezug auf Lösungsauswahl, Beschaffungsansatz und Grobdesign auf der Grundlage des Business Cases trifft. Holen Sie von den betroffenen Anspruchsgruppen (z. B. Geschäftsprozessverantwortliche, Unternehmensarchitekten, Betriebsverantwortliche, Sicherheits- und Datenschutzverantwortliche) die erforderlichen Freigaben ein.	3
2. Führen Sie während des gesamten Projekts sowie am Ende wichtiger Projektphasen, Iterationen oder Releases Qualitätsüberprüfungen durch. Bewerten Sie die Ergebnisse anhand der ursprünglichen Abnahmekriterien. Holen Sie nach jeder erfolgreichen Qualitätsüberprüfung die Freigabe durch den geschäftsseitigen Sponsor und weitere Anspruchsgruppen ein	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen

Wichtige Managementpraktik:

BAI02.01 Definieren und Pflegen der funktionalen geschäftlichen und technischen Anforderungen			R	A	R	R	R	R	R	R		R	R
BAI02.02 Durchführen einer Machbarkeitsstudie und Formulieren alternativer Lösungen			R	A	R	R	R			R			
BAI02.03 Managen des Anforderungsrisikos	R	R	R	A	R	R	R			R	R	R	R
BAI02.04 Einholen der Genehmigung für Anforderungen und Lösungen			R	A	R	R	R					R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)			Detaillierte Referenzen										
Keine entsprechenden weiteren Quellen für diese Komponente													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
BAI02.01 Definieren und Pflegen der funktionalen geschäftlichen und technischen Anforderungen	APO01.07	- Richtlinien zur Datenklassifizierung - Richtlinien zur Datensicherheit und -kontrolle - Verfahren zur Datenintegrität	Repository für Anforderungsdefinitionen	BAI03.01, BAI03.02, BAI03.12, BAI04.01, BAI05.01
	APO03.01	Architekturprinzipien	Bestätigte Akzeptanzkriterien von Anspruchsgruppen	BAI03.01, BAI03.02, BAI03.12, BAI04.03, BAI05.01, BAI05.02
	APO03.02	- Grundlegende Domänenbeschreibungen und Architekturdefinition - Modell der Informationsarchitektur	Aufzeichnung von Anforderungsänderungsanträgen	BAI03.09
	APO03.05	Anleitung zur Lösungsentwicklung		
	APO10.02	Lieferanten-RFIs und RFPs		
	APO11.02	Akzeptanzkriterien		
	APO14.02	Geschäftsglossar		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
BAI02.02 Durchführen einer Machbarkeitsstudie und Formulieren alternativer Lösungen	APO03.05	Anleitung zur Lösungs-entwicklung	Akquisitions-/Entwick-lungsplan	APO10.02, BAI03.01
	APO10.01	Lieferantenkatalog	Bericht zur Durchführ-barkeitsstudie	BAI03.02, BAI03.03, BAI03.12
	APO10.02	• Lieferanten-RFIs und -RFPs • RFI- und RFP-Auswer-tungen • Entscheidungsergeb-nisse von Lieferanten-bewertungen		
	APO11.02	Akzeptanzkriterien		
BAI02.03 Managen des Anforderungsrisikos			Anforderungsrisikore-gister	BAI01.08, BAI03.02, BAI04.01, BAI05.01, BAI11.06
			Maßnahmen zur Risiko-minderung	BAI01.08, BAI03.02, BAI05.01
BAI02.04 Einholen der Genehmigung für Anforderungen und Lösungen	BAI01.07	Plan zum Qualitäts-mangement	Genehmigte Qualitäts-prüfungen	APO11.03
	BAI11.05	Projekt-Qualitätsma-nagementplan	Genehmigungen von Anforderungen und Lösungsvorschlägen durch den Sponsor	BAI03.02, BAI03.03, BAI03.04
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 5. Project management scope: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Anwendungsdesign	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	A. Plan – A.6. Application Design
Geschäftsanalyse	Skills Framework for the Information Age V6, 2015	BUAN
Verbesserung von Geschäftspro- zessen	Skills Framework for the Information Age V6, 2015	BPRE
Identifizierung der Bedürfnisse	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.11. Needs Identification
Anforderungsdefinition und -management	Skills Framework for the Information Age V6, 2015	REQM
Analyse der Benutzererfahrung	Skills Framework for the Information Age V6, 2015	UNAN

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Software-Entwicklung	Standardisiert die Softwareentwicklung der gesamten Organisation durch Auflistung aller zu befolgenden Protokolle und Standards.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur, die konsistente und robuste Prozesse zur Definition von Anforderungen gewährleistet. Stellen Sie sicher, dass die Prozesse die Entwicklungsanforderungen klar an den strategischen Anforderungen des Unternehmens ausrichten.		

G. Komponente: Services, Infrastruktur und Anwendungen

Werkzeuge zur Definition und Dokumentation von Anforderungen
--

Domäne: Aufbauen, Beschaffen und Implementieren		Schwerpunktbereich: COBIT-Kernmodell
Managementziel: BAI03 – Lösungsidentifizierung und Lösungserstellung sind gemanagt		
Beschreibung		
Bereitstellung und Pflege identifizierter Produkte und Services (Technologie, Geschäftsprozesse und Arbeitsabläufe) in Übereinstimmung mit den Unternehmensanforderungen für die Bereiche Design, Entwicklung, Beschaffung/Sourcing und Zusammenarbeit mit Lieferanten. Management der Konfiguration, Testvorbereitung, Testdurchführung, Anforderungsmanagement sowie Pflege von Geschäftsprozessen, Anwendungen, Informationen/Daten, Infrastruktur und Services.		
Zweck		
Sicherstellung einer agilen und skalierbaren Bereitstellung von digitalen Produkten und Services. Zeitgerechte und kostenoptimierte Entwicklung von Lösungen (Technologie, Geschäftsprozesse und Arbeitsabläufe), die geeignet sind, die strategischen und operativen Zielvorgaben des Unternehmens zu unterstützen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen • AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG09 Termingereute, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
BAI03.01 Grobkonzeption von Lösungen Entwickeln und dokumentieren Sie Grobkonzepte für die Lösung in Bezug auf Technologie, Geschäftsprozesse und Arbeitsabläufe. Wenden Sie dabei vereinbarte und geeignete, in Phasen unterteilte oder schnelle Agile Entwicklungstechniken an. Stellen Sie sicher, dass die Designs an der I&T-Strategie und an der Unternehmensarchitektur ausgerichtet sind. Führen Sie eine neuerliche Beurteilung und Aktualisierung der Designs durch, wenn während der ausführlichen Design- oder Erstellungsphasen oder im Laufe der Weiterentwicklung der Lösung bedeutende Probleme auftreten. Legen Sie einen nutzerzentrierten Ansatz zugrunde und stellen Sie sicher, dass sich die Anspruchsgruppen aktiv am Design beteiligen und die einzelnen Versionen genehmigen.		a. Anzahl der Mängel bei der Prüfung des Designs b. Grad der Beteiligung der Anspruchsgruppen am Design und an der Abnahme jeder Version
Aktivitäten		Fähigkeitsstufe
1. Erstellen Sie eine Spezifikation für das Grobdesign, die es ermöglicht, die vorgeschlagene Lösung in ein Grobdesign für Geschäftsprozesse, unterstützende Services, Workflows, Anwendungen, Infrastrukturen und Informationsbestände zu konvertieren, die geeignet sind, die Geschäftsanforderungen sowie die Anforderungen an die Unternehmensarchitektur zu erfüllen.		2
2. Beziehen Sie entsprechend qualifizierte und erfahrene User Experience Designer und IT-Spezialisten in den Designprozess ein, um sicherzustellen, dass auf Basis des Designs eine Lösung bereitgestellt wird, die die vorgeschlagenen I&T-Befähigungen optimal nutzt, um den Geschäftsprozess zu verbessern.		
3. Erstellen Sie ein Design, das den Designstandards der Organisation entspricht. Stellen Sie sicher, dass der Detaillierungsgrad der Lösung und die Entwicklungsmethode sachgerecht sind, und mit den Geschäfts-, Unternehmens- und I&T-Strategien, der Unternehmensarchitektur, dem Sicherheits-/Datenschutzplan sowie mit den anwendbaren Gesetzen, Bestimmungen und Verträgen vereinbar sind.		
4. Legen Sie das endgültige Grobdesign nach erfolgter Genehmigung seitens der Qualitätssicherung den Projektanspruchsgruppen und dem Sponsor bzw. Geschäftsprozessverantwortlichen vor, um es anhand vorab festgelegter Kriterien genehmigen zu lassen. Mit zunehmendem Erkenntnisgewinn wird sich das Design im Laufe des Projektes weiterentwickeln.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SD2.2 System Design
Managementpraktik		Beispielmetrik
BAI03.02 Konzipieren detaillierter Lösungskomponenten Entwickeln, dokumentieren und erarbeiten Sie schrittweise detaillierte Designs. Wenden Sie dabei vereinbarte und angemessene, in Phasen unterteilte oder schnelle agile Entwicklungstechniken an, die alle Komponenten berücksichtigen (Geschäftsprozesse und zugehörige automatisierte und manuelle Kontrollen, unterstützende I&T-Anwendungen, Infrastrukturservices und Technologieprodukte sowie Partner/Lieferanten). Stellen Sie sicher, dass das detaillierte Design interne und externe Service Level Agreements (SLAs) und Operational Level Agreements (OLAs) enthält.		a. Anzahl der Mängel bei der Prüfung des Designs b. Anzahl der prozessinternen Designänderungen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Erstellen Sie schrittweise das Design für die Geschäftsprozessaktivitäten und Arbeitsabläufe, die in Verbindung mit dem neuen Anwendungssystem durchzuführen sind, um die Unternehmenszielvorgaben zu erfüllen. Konzipieren Sie in diesem Zusammenhang auch die manuellen Kontrollaktivitäten.	2
2. Konzipieren Sie die Verarbeitungsschritte der Anwendung. Spezifizieren Sie Transaktionstypen und geschäftliche Verarbeitungsregeln, automatisierte Kontrollen, Datendefinitionen/Geschäftsobjekte, Anwendungsfälle, externe Schnittstellen, Design-Einschränkungen und sonstige Anforderungen (z. B. Lizenzierung, gesetzliche Bestimmungen, Standards und Internationalisierung/Lokalisierung).	
3. Klassifizieren Sie Dateninputs und -outputs gemäß den Unternehmensarchitekturstandards. Spezifizieren Sie das Design für die Erfassung von Quelldaten. Dokumentieren Sie die Dateninputs (unabhängig von der Quelle), die Validierung der Verarbeitungstransaktionen sowie die Validierungsmethoden. Entwickeln Sie das Design für die identifizierten Outputs und schließen Sie die Datenquellen dabei ein.	
4. Konzipieren Sie die System-/Lösungsschnittstelle, einschließlich einem eventuell vorhandenen, automatisierten Datenaustausch.	
5. Konzipieren Sie Speicherung, Speicherort, Abruf und Wiederherstellungsfähigkeit von Daten.	
6. Konzipieren Sie geeignete Redundanz, Wiederherstellung und Backup.	
7. Konzipieren Sie die Schnittstelle zwischen Benutzer und Systemanwendung so, dass sie einfach zu verwenden und selbsterklärend ist.	3
8. Bedenken Sie die Auswirkungen, die sich aus den Anforderungen der Lösung an die Infrastrukturleistung ergeben. Berücksichtigen Sie die Anzahl der Verarbeitungsgeräte, die Bandbreitenanforderungen und die zeitliche Sensitivität der Informationen.	
9. Prüfen Sie während des Lebenszyklus proaktiv, ob Schwächen im Design (z. B. Inkonsistenzen, Unklarheiten, potenzielle Lücken) vorhanden sind. Identifizieren Sie bei Bedarf Verbesserungen.	
10. Stellen Sie eine Möglichkeit zur Rückverfolgung von Transaktionen bereit und identifizieren Sie die Ursachen von Verarbeitungsfehlern.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016	SD2.2 System Design
Managementpraktik	Beispielmetrik
BAI03.03 Entwickeln von Lösungskomponenten Entwickeln Sie in einer separaten Umgebung schrittweise Lösungskomponenten, die den detaillierten Designs entsprechen und beachten Sie dabei Standards und Anforderungen für Entwicklung und Dokumentation, Qualitätssicherung (QA) und Freigabe. Stellen Sie sicher, dass allen Kontrollanforderungen in Verbindung mit Geschäftsprozessen, unterstützenden I&T-Anwendungen und Infrastrukturservices, Services und Technologieprodukten sowie Partner-/Lieferantenservices Rechnung getragen wird.	a. Anzahl der während der Überprüfungen festgestellten Abweichungen der Lösung vom Design b. Anzahl der detaillierten Designs für Geschäftsprozesse, unterstützende Services, Anwendungen und Infrastruktur sowie Informations-Repositories
Aktivitäten	Fähigkeitsstufe
1. Entwickeln Sie in einer separaten Umgebung das vorgeschlagene detaillierte Design für Geschäftsprozesse, unterstützende Services, Anwendungen, Infrastruktur und Informations-Repositories.	2
2. Soweit Drittanbieter in die Lösungsentwicklung eingebunden sind, stellen Sie sicher, dass Standards für Wartung, Support, Entwicklung und Lizenzierung berücksichtigt und deren Einhaltung vertraglich festgelegt werden.	
3. Verfolgen Sie Änderungsanträge und Design-, Leistungs- und Qualitätsüberprüfungen nach. Stellen Sie die aktive Beteiligung aller betroffenen Anspruchsgruppen sicher.	
4. Dokumentieren Sie alle Lösungskomponenten in Einklang mit definierten Standards. Führen Sie einen Versionsnachweis für alle entwickelten Komponenten und die zugehörige Dokumentation	

A. Komponente: Prozess (Forts.)		
5. Beurteilen Sie die Auswirkungen einer Lösungsanpassung und -konfiguration auf die Leistung und Effizienz erworbener Lösungen sowie auf die Interoperabilität mit vorhandenen Anwendungen, Betriebssystemen und anderen Infrastrukturen. Passen Sie Geschäftsprozesse ggf. an, um die Anwendungen adäquat nutzen zu können.		3
6. Stellen Sie sicher, dass die Verantwortlichkeiten bei der Nutzung von Hochsicherheits- oder Infrastrukturkomponenten mit begrenztem Zugriff klar definiert sind und von den Mitarbeitern, die diese Infrastrukturkomponenten entwickeln und integrieren, verstanden werden. Die Nutzung dieser Kompetenzen sollte überwacht und bewertet werden.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016	SD1.2 System Development Environments	
ISO/IEC 27002:2013/Cor.2:2015(E)	14.2 Security in development and support processes	
ITIL V3, 2011	Service Strategy, 5.5 IT service strategy and application development	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.18 System and services acquisition (SA-3)	
Managementpraktik	Beispielmetrik	
BAI03.04 Beschaffen von Lösungskomponenten Beschaffen Sie Lösungskomponenten auf der Grundlage des Beschaffungsplans und beachten Sie die Anforderungen und detaillierten Designs, die Architekturprinzipien und -standards sowie die allgemeinen Beschaffungs- und Vertragsverfahren, QA-Anforderungen und Genehmigungsstandards des Unternehmens. Stellen Sie sicher, dass alle gesetzlichen und vertraglichen Anforderungen identifiziert wurden und vom Lieferanten berücksichtigt werden.	a. Anteil der zertifizierten Zulieferer b. Anteil der Zulieferer, die sich an einem gemeinschaftlichen Design beteiligen	
Aktivitäten		Fähigkeitsstufe
1. Erstellen und pflegen Sie einen Plan für die Beschaffung von Lösungskomponenten. Berücksichtigen Sie dabei die Flexibilität für künftige Kapazitätserweiterungen, Übergangskosten, Risiken und Upgrades innerhalb des Projektlebenszyklus		3
2. Überprüfen und genehmigen Sie sämtliche Beschaffungspläne. Berücksichtigen Sie dabei Risiken, Kosten und Nutzen sowie die technische Konformität mit Unternehmensarchitekturstandards.		
3. Beurteilen und dokumentieren Sie, in welchem Umfang erworbene Lösungen die Anpassung von Geschäftsprozessen erfordern, um von der erworbenen Lösung bestmöglich zu profitieren.		
4. Holen Sie während der Beschaffungsprozesse die erforderlichen Genehmigungen an wichtigen Entscheidungspunkten ein.		
5. Erfassen Sie den Zugang aller erworbenen Infrastruktur- und Softwareprodukte im Betriebsmittelbestand.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016	SD2.3 Software Acquisition	
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	3.4 Buying Decisions	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.18 System and services acquisition (SA-4)	
Managementpraktik	Beispielmetrik	
BAI03.05 Erstellen von Lösungen Installieren und konfigurieren Sie Lösungen und integrieren Sie diese in Geschäftsprozessaktivitäten. Implementieren Sie während der Konfiguration und Integration von Hardware und Infrastruktursoftware Kontroll-, Sicherheits-, Datenschutz- und Prüffähigkeitsmaßnahmen, um Ressourcen zu schützen und die Verfügbarkeit und Integrität von Daten zu gewährleisten. Aktualisieren Sie den Produkt- oder Servicekatalog mit den neuen Lösungen.	a. Lücke zwischen dem geschätzten und dem endgültigen Entwicklungsaufwand b. Anzahl der gemeldeten Softwareprobleme c. Anzahl der bei Überprüfungen ermittelten Fehler	

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Integrieren und konfigurieren Sie Geschäfts- und IT-Lösungskomponenten und Informations-Repositories in Einklang mit detaillierten Spezifikationen und Qualitätsanforderungen. Berücksichtigen Sie bei der Konfiguration von Geschäftsprozessen die Rolle der Benutzer, der Anspruchsgruppen und des Prozessverantwortlichen.	2
2. Vervollständigen und aktualisieren Sie ggf. Geschäftsprozess- und Betriebshandbücher, um individuelle Anpassungen oder besondere Umstände, die für die Implementierung einzigartig sind, abzubilden.	
3. Berücksichtigen Sie bei der Integration und Konfiguration von Lösungskomponenten alle relevanten Anforderungen an die Informationskontrolle. Integrieren Sie ggf. auch Geschäftskontrollen in automatisierte Anwendungskontrollen, um sicherzustellen, dass die Verarbeitung genau, vollständig, zeitgerecht, genehmigt und prüffähig ist.	
4. Implementieren Sie während der Konfiguration und Integration von Hardware und Infrastruktursoftware geeignete Prüfpfade, um Ressourcen zu schützen und die Verfügbarkeit und Integrität sicherzustellen.	3
5. Bestimmen Sie, ab wann kumulative Anpassungen und Konfigurationen (einschließlich kleinerer Änderungen, die nicht formellen Designspezifikationen unterlagen) eine allgemeine neuerliche Beurteilung der Lösung und der damit verbundenen Funktionalität erfordern.	
6. Konfigurieren Sie erworbene Anwendungssoftware so, dass die geschäftlichen Anforderungen an die Funktionsweise erfüllt werden.	
7. Definieren Sie, basierend auf den geschäftlichen Anforderungen, Produkt- und Servicekataloge für relevante interne und externe Zielgruppen.	
8. Stellen Sie die Interoperabilität der Lösungskomponenten mit geeigneten, vorzugsweise automatisierten Tests sicher.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
HITRUST CSF Version 9, September 2017	10.05 Security in Development & Support Processes
ISF, The Standard of Good Practice for Information Security 2016	SD2.4 System Build
Managementpraktik	Beispielmesskriterien
BAI03.06 Durchführen der Qualitätssicherung Entwickeln Sie einen am QMS ausgerichteten QA-Plan, sehen Sie die benötigten Ressourcen vor, und setzen Sie den Plan um, mit dem Ziel, die in der Definition der Anforderungen und in den Qualitätsrichtlinien und -verfahren des Unternehmens festgelegte Qualität zu erreichen.	a. Anzahl der überarbeiteten Lösungsentwürfe aufgrund von Fehlaustrichtung bezüglich der Anforderungen b. Anzahl und Robustheit der durchgeführten dokumentierten Überwachungsaktivitäten
Aktivitäten	Fähigkeitsstufe
1. Definieren Sie einen QA-Plan und QA-Praktiken. Der Plan sollte u. a. eine Spezifikation der Qualitätskriterien sowie der Validierungs- und Verifizierungsprozesse enthalten, eine Definition des Verfahrens zur Überprüfung der Qualität, Angaben zur benötigten Qualifikation der Qualitätsprüfer sowie zu den für die Erreichung der Qualität erforderlichen Rollen und Zuständigkeiten.	3
2. Überwachen Sie regelmäßig die Lösungsqualität mit Blick auf die Erfüllung von Projektanforderungen und Unternehmensrichtlinien sowie die Einhaltung von Entwicklungsmethoden, Qualitätsmanagementverfahren und Abnahmekriterien.	4
3. Nutzen Sie ggf. Codeprüfungen, testgestützte Entwicklungsmethoden, automatisierte Tests, kontinuierliche Integration, Walkthroughs und Anwendungstests. Teilen Sie dem Software-Entwicklungsteam und dem IT-Management die Ergebnisse des Überwachungsprozesses und der Tests mit.	
4. Überwachen Sie alle Qualitätsausnahmen und verfolgen Sie alle korrekativen Maßnahmen. Führen Sie Aufzeichnungen zu allen Überprüfungen, Ergebnissen, Ausnahmen und Korrekturen. Wiederholen Sie ggf. Qualitätsprüfungen, je nachdem, wie viel Nacharbeit und korrektive Maßnahmen anstehen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016	SD1.3 Quality Assurance
Managementpraktik	Beispielmesskriterien
BAI03.07 Vorbereiten der Tests für die Lösung Erstellen Sie einen Testplan und richten Sie die erforderlichen Umgebungen zum Testen der individuellen und integrierten Lösungskomponenten ein. Berücksichtigen Sie dabei Geschäftsprozesse, unterstützende Services, Anwendungen und die Infrastruktur.	a. Anzahl der an der Erstellung des Testplans beteiligten Geschäftsanwender b. Anzahl und Robustheit der für das Testen erstellten Anwendungsfälle

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Erstellen Sie einen integrierten Testplan inklusive Praktiken, der mit der Unternehmensumgebung und den strategischen Technologieplänen vereinbar ist. Stellen Sie auf dieser Basis die Schaffung geeigneter Test- und Simulationsumgebungen sicher, damit anhand dieser Umgebungen überprüft werden kann, inwieweit die Lösung erfolgreich in der Live-Umgebung funktioniert und die beabsichtigten Ergebnisse liefert und ob die eingerichteten Kontrollen zielführend sind.		2
2. Erstellen Sie eine Testumgebung, die das gesamte Lösungsspektrum unterstützt. Stellen Sie sicher, dass diese im größtmöglichen Umfang reale Bedingungen abbildet. Dazu gehören z. B. Geschäftsprozesse und Verfahren, die verschiedenen Benutzer, Transaktionstypen und Bereitstellungsbedingungen.		
3. Erarbeiten Sie Testverfahren, die sich am Plan und an den Praktiken orientieren und die Bewertung des Lösungsbetriebs unter realen Bedingungen zulassen. Stellen Sie sicher, dass anhand der Testverfahren, und unter Berücksichtigung unternehmensweiter Standards für die Definition von Rollen, Zuständigkeiten und Testkriterien, die Eignung der Kontrollen bewertet wird, und dass die Testverfahren von den Projektanspruchsgruppen und vom Sponsor bzw. Geschäftsprozessverantwortlichen genehmigt sind.		3
4. Dokumentieren und speichern Sie die Testverfahren, Fälle, Kontrollen und Parameter für eine evtl. Wiederholung der Anwendungstests.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		AD.DE Safeguard Development Environment
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.10 Maintenance (MA-2, MA-3)
Managementpraktik		Beispielmetrik
BAI03.08 Ausführen der Tests für die Lösung Führen Sie während der Entwicklung in der jeweiligen Umgebung regelmäßig Tests durch (einschließlich Kontrolltests), die dem definierten Testplan und den Entwicklungspraktiken entsprechen. Beziehen Sie Geschäftsprozessverantwortliche und Endbenutzer in das Testteam ein. Identifizieren, protokollieren und priorisieren Sie Fehler und Probleme, die während der Tests festgestellt wurden.		a. Anzahl der beim Testen festgestellten Fehler b. Zeit und Aufwand zur Durchführung von Tests
Aktivitäten		Fähigkeitsstufe
1. Testen Sie Lösungen und deren Komponenten gemäß den Bestimmungen des Testplans. Sehen Sie Testpersonen außerhalb des Lösungsteams vor, bei denen es sich u. a. um repräsentative Geschäftsprozessverantwortliche und Endbenutzer handelt. Stellen Sie sicher, dass Tests nur innerhalb der Entwicklungs- und Testumgebung durchgeführt werden.		2
2. Verwenden Sie klar definierte Testanweisungen, wie im Testplan definiert. Sorgen Sie für ein ausgewogenes Verhältnis zwischen automatisierten skriptbasierten Tests und interaktiven Benutzertests.		
3. Führen Sie alle Tests in Einklang mit dem Testplan und -praktiken durch. Integrieren Sie Geschäftsprozesse und IT-Lösungskomponenten sowie nicht funktionale Anforderungen (z. B. Sicherheit, Datenschutz, Interoperabilität, Benutzerfreundlichkeit).		
4. Identifizieren, protokollieren und klassifizieren Sie (z. B. geringfügige, schwerwiegende und geschäftskritische) Fehler, die beim Testen festgestellt werden. Wiederholen Sie die Tests, bis alle schwerwiegenden Fehler behoben sind. Stellen Sie sicher, dass ein Prüfpfad der Testergebnisse gepflegt wird.		
5. Erfassen Sie Testergebnisse, und teilen Sie diese gemäß den Bestimmungen des Testplans den jeweiligen Anspruchsgruppen mit.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		
CMMI Cybermaturity Platform, 2018		AD.ST Secure Development Testing
ISF, The Standard of Good Practice for Information Security 2016		SD2.5 System Testing; SD2.6 Security Testing
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.18 System and services acquisition (SA-11)

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
BAI03.09 Managen von Anforderungsänderungen Verfolgen Sie den Status einzelner Anforderungen (einschließlich aller abgelehnten Anforderungen) innerhalb des Projektlebenszyklus. Managen Sie die Genehmigung von Anforderungsänderungen.		a. Anzahl der verfolgten genehmigten Änderungen, die neue Fehler verursachen b. Anteil der Anspruchsgruppen, die mit den Änderungsmanagementprozessen zufrieden sind
Aktivitäten		Fähigkeitsstufe
1. Beurteilen Sie die Auswirkungen aller Lösungsänderungsanträge auf die Lösungsentwicklung, den ursprünglichen Business Case und das Budget. Kategorisieren Sie sie entsprechend und setzen Sie Prioritäten.		3
2. Verfolgen Sie Anforderungsänderungen, so dass alle Anspruchsgruppen die Änderungen überwachen, überprüfen und genehmigen können. Stellen Sie sicher, dass die Ergebnisse des Änderungsprozesses von allen Anspruchsgruppen sowie vom Sponsor bzw. Geschäftsprozessverantwortlichen vollständig verstanden und akzeptiert werden.		
3. Übernehmen Sie die Änderungsanträge unter Wahrung der Integrität von Integration und Konfiguration der Lösungskomponenten. Beurteilen Sie die Auswirkungen wesentlicher Lösungsupgrades und klassifizieren Sie diese nach vereinbarten, objektiven Kriterien (z. B. Unternehmensanforderungen). Stützen Sie sich dabei auf das Ergebnis der Analyse des damit einhergehenden Risikos (z. B. Auswirkungen auf vorhandene Systeme und Prozesse oder auf die Sicherheit/Datenschutz), Kosten-Nutzen-Abwägungen und sonstige Anforderungen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SD2.9 Post-implementation Review
Managementpraktik		Beispielmetrik
BAI03.10 Pflegen der Lösungen Entwickeln Sie einen Plan für die Wartung von Lösungs- und Infrastrukturkomponenten, und setzen Sie diesen um. Planen Sie regelmäßige Überprüfungen ein, die einen Abgleich mit geschäftlichen Bedürfnissen und operativen Anforderungen vorsehen.		a. Anzahl der nicht abgearbeiteten Wartungsanfragen b. Bearbeitungsdauer der nicht, als auch der abgearbeiteten Wartungsanfragen
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie einen Plan für die Wartung von Lösungskomponenten und setzen Sie diesen um. Überprüfen Sie den Plan regelmäßig in Form eines Abgleichs mit geschäftlichen Bedürfnissen und operativen Anforderungen, z. B. Patch Management, Upgrade-Strategien, Risiken, Datenschutz, Beurteilung von Schwachstellen und Sicherheitsanforderungen.		2
2. Beurteilen Sie die Auswirkung einer vorgeschlagenen Wartungsaktivität auf das aktuelle Lösungsdesign, die Funktionalität und/oder Geschäftsprozesse. Berücksichtigen Sie das Risiko, die Auswirkungen für Benutzer und die Verfügbarkeit von Ressourcen. Stellen Sie sicher, dass den Geschäftsprozessverantwortlichen bewusst ist, welchen Effekt die Einstufung von Änderungen als Wartungsmaßnahme hat.		3
3. Sollten wesentliche Änderungen an vorhandenen Lösungen umfangreiche Änderungen am aktuellen Design und/oder an der Funktionalität und/oder an den Geschäftsprozessen nach sich ziehen, wenden Sie den Entwicklungsprozess für neue Systeme an. Nutzen Sie für Wartungsupdates den Änderungsmanagementprozess.		
4. Stellen Sie sicher, dass Muster und Umfang von Wartungsaktivitäten regelmäßig analysiert und auf abnormale Trends untersucht werden, die auf das Vorhandensein von zugrunde liegenden Qualitäts- oder Leistungsproblemen hinweisen. Prüfen Sie außerdem Kosten und Nutzen größerer Upgrades und inwieweit ein Austausch der Wartung vorzuziehen ist.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISO/IEC 27002:2013/Cor.2:2015(E)		14.3 Test data
Managementpraktik		Beispielmetrik
BAI03.11 Definieren von IT-Produkten und -Dienstleistungen und Pflegen des Dienstportfolios Definieren und vereinbaren Sie neue oder geänderte IT-Produkte oder -Dienstleistungen und Service Level. Dokumentieren Sie neue oder geänderte Produkt- und Dienstdefinitionen und Service Level, die im Produkt- und Dienstportfolio aktualisiert werden sollen.		a. Anteil der Anspruchsgruppen, die neue I&T-Dienste freigegeben haben b. Anteil der neuen oder geänderten Dienstdefinitionen und Service Level, die im Dienstportfolio dokumentiert sind c. Anteil der neuen oder geänderten Dienstdefinitionen und Service Level, die im Dienstportfolio aktualisiert wurden

A. Komponente: Prozess (Forts.)			
Aktivitäten			Fähigkeitsstufe
1. Schlagen Sie Definitionen für die neuen oder geänderten IT-Produkte und -Dienste vor, um deren Zweckdienlichkeit sicherzustellen. Dokumentieren Sie die vorgeschlagenen Definitionen in der Portfolioliste der zu entwickelnden Produkte und Dienste.			3
2. Schlagen Sie neue oder geänderte Service Level vor, um die Zweckdienlichkeit der IT-Produkte und -Dienste sicherzustellen (Servicezeiten, Benutzerzufriedenheit, Verfügbarkeit, Leistung, Kapazität, Sicherheit, Datenschutz, Kontinuität, Compliance und Benutzerfreundlichkeit). Dokumentieren Sie die vorgeschlagenen Optionen im Portfolio.			
3. Schaffen Sie eine Schnittstelle zu Business Relationship Management und Portfolio Management, um eine Einigung hinsichtlich der vorgeschlagenen Produkt- und Dienstdefinitionen und Service Level zu erzielen.			
4. Wird die Dienständerung von der vereinbarten Stelle genehmigt, erstellen Sie die neuen oder geänderten IT-Produkte und -Dienste bzw. Service Level. Leiten Sie anderenfalls die Änderung an das Portfoliomanagement weiter, um eine Investitionsüberprüfung zu veranlassen			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
Keine zugehörigen Leitfäden für diese Managementpraktik			
Managementpraktik		Beispielmessung	
BAI03.12 Entwerfen von Lösungen auf der Grundlage der definierten Entwicklungsmethodik Entwerfen, entwickeln und implementieren Sie Lösungen mit der geeigneten Entwicklungsmethodik (d. h. Wasserfall, agile oder bimodale I&T), in Übereinstimmung mit der Gesamtstrategie und den Anforderungen.		a. Anteil der Projekte zur Lösungsentwicklung, die speziell ausgewählte Methoden anwenden b. Anteil der Prozesse, die an die gewählte Strategie angepasst sind	
Aktivitäten			Fähigkeitsstufe
1. Analysieren und bewerten Sie die Auswirkungen der Wahl einer Entwicklungsmethodik (z. B. Wasserfall, agil, bimodal) auf die verfügbaren Ressourcen, die Anforderungen an die Architektur, die Konfigurationseinstellungen und die Systemstabilität.			3
2. Legen Sie eine geeignete Entwicklungsmethodik und einen geeigneten organisatorischen Ansatz fest, der es erlaubt, die vorgeschlagene Lösung effizient und effektiv bereitzustellen und in der Lage ist, die Geschäfts-, Architektur- und Systemanforderungen zu erfüllen. Passen Sie die Prozesse bei Bedarf an die gewählte Strategie an.			
3. Richten Sie die erforderlichen Projektteams gemäß der gewählten Entwicklungsmethodik ein. Sorgen Sie für eine ausreichende Schulung.			
4. Ziehen Sie bei Bedarf die Anwendung eines dualen Systems in Betracht, bei dem sich funktionsübergreifende Gruppen (digitale Fabriken) auf die Entwicklung eines Produkts oder Prozesses konzentrieren und dabei eine andere Technologie, Betriebs- oder Managementmethodik anwenden, als der Rest des Unternehmens. Die Einbettung dieser Gruppen in Geschäftseinheiten hat den Vorteil, die neue Kultur der agilen Entwicklung zu verbreiten und diesen Ansatz einer digitalen Fabrik zu etablieren.			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016		SD1.1 System Development Methodology	

B. Komponente: Organisationsstrukturen																					
Wichtige Managementpraktik:		Chief Information Officer	Chief Technology Officer	Chief Digital Officer	Geschäftsprozessverantwortlicher	Portfoliomanager	Lenkungsausschuss für Projekte und Programme			Programm-Manager	Projektmanager	Project Management Office	Relationship Manager	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter
	BAI03.01 Grobkonzeption von Lösungen		R		R		A	R	R	R	R			R					R		
	BAI03.02 Konzipieren detaillierter Lösungskomponenten		R		R		A	R	R	R				R							
	BAI03.03 Entwickeln von Lösungskomponenten		R		R		A	R	R	R				R							
	BAI03.04 Beschaffen von Lösungskomponenten		R		R		A							R	R	R					
	BAI03.05 Erstellen von Lösungen		R		R		A	R	R	R				R					R		
	BAI03.06 Durchführen der Qualitätssicherung		R		R		A	R	R	R				R							
	BAI03.07 Vorbereiten der Tests für die Lösung		R		R		A							R	R			R	R	R	R
	BAI03.08 Ausführen der Tests für die Lösung		R		R		A							R	R				R		R
	BAI03.09 Managen von Anforderungsänderungen		R		R		A	R	R	R			R	R					R		R
	BAI03.10 Pflegen der Lösungen	A	R		R			R	R	R				R					R		R
	BAI03.11 Definieren von IT-Produkten und -Dienstleistungen und Pflegen des Dienstportfolios	A																R	R		R
BAI03.12 Entwerfen von Lösungen auf der Grundlage der definierten Entwicklungsmethodik	A		R		R		R	R													
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen																			
Keine entsprechenden weiteren Quellen für diese Komponente																					

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
BAI03.01 Grobkonzeption von Lösungen	Von	Beschreibung	Beschreibung	Für
	APO03.01	Architekturprinzipien	Genehmigte erste Designspezifikation	BAI04.03, BAI05.01
	APO03.02	Grundlegende Domänenbeschreibungen und Architekturdefinition		
	APO04.03	Erforschung und Analyse von Innovationsmöglichkeiten		
	APO04.04	Auswertungen von Innovationsideen		
	BAI02.01	- Repository für Anforderungsdefinitionen - Bestätigte Akzeptanzkriterien von Anspruchsgruppen		
	BAI02.02	Akquisitions-/Entwicklungsplan		
BAI03.02 Konzipieren detaillierter Lösungskomponenten	APO03.01	Architekturprinzipien	Interne und externe SLAs	BAI04.02
	APO03.02	- Grundlegende Domänenbeschreibungen und Architekturdefinition - Modell der Informationsarchitektur	Genehmigte detaillierte Designspezifikation	BAI04.03, BAI05.01
	APO03.05	Anleitung zur Lösungsentwicklung		
	APO04.06	Bewertungen innovativer Ansätze		
	BAI02.01	- Repository für Anforderungsdefinitionen - Bestätigte Akzeptanzkriterien von Anspruchsgruppen		
	BAI02.02	Bericht zur Durchführbarkeitsstudie		
	BAI02.03	- Risikoregisteranforderungen - Maßnahmen zur Risikominderung		
	BAI02.04	Genehmigungen von Anforderungen und Lösungsvorschlägen durch den Sponsor		
BAI03.03 Entwickeln von Lösungskomponenten	BAI02.02	Bericht zur Durchführbarkeitsstudie	Dokumentierte Lösungskomponenten	BAI04.03, BAI05.05, BAI08.02, BAI08.03
	BAI02.04	Genehmigungen von Anforderungen und Lösungsvorschlägen durch den Sponsor		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
BAI03.04 Beschaffen von Lösungskomponenten	Von	Beschreibung	Beschreibung	Für
	BAI02.04	Genehmigungen von Anforderungen und Lösungsvorschlägen durch den Sponsor	Genehmigter Akquisitionplan Aktualisierung des Betriebsmittelinventars	AP010.03 BAI09.01
BAI03.05 Erstellen von Lösungen			Integrierte und konfigurierte Lösungskomponenten	BAI06.01
BAI03.06 Durchführen der Qualitätssicherung	AP011.01	Ergebnisse der QMS-Effektivitätsprüfungen	Qualitätsprüfungsergebnisse, Ausnahmen und Korrekturen	AP011.04
	BAI01.07	Plan zum Qualitätsmanagement	Plan zur Qualitätssicherung	AP011.04
	BAI11.05	Projekt-Qualitätsmanagementplan		
BAI03.07 Vorbereiten der Tests für die Lösung			Testverfahren	BAI07.03
			Testplan	BAI07.03
BAI03.08 Ausführen der Tests für die Lösung	AP004.05	Analyse der abgelehnten Initiativen	Kommunikation der Testergebnisse	BAI07.03
			Testergebnisprotokolle und Prüfpfade	BAI07.03
BAI03.09 Managen von Anforderungsänderungen	AP004.05	Ergebnisse und Empfehlungen von Proof-of-Concept-Initiativen	Erfassung aller genehmigten und umgesetzten Änderungsanträge	BAI06.03
	BAI02.01	Aufzeichnung von Anforderungsänderungsanträgen		
BAI03.10 Pflegen der Lösungen			Wartungsplan	AP008.05
			Aktualisierte Lösungskomponenten und zugehörige Dokumentation	BAI05.05

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)

BAI03.11 Definieren von IT-Produkten und -Dienst und Pflegen des Dienstportfolios	AP002.04	• Lücken und erforderliche Änderungen zur Erreichung der Zielbefähigung • Wert-Nutzen-Feststellung für die Zielumgebung	Aktualisiertes Serviceportfolio	AP005.04	
	AP006.02	Budgetzuweisungen	Servicedefinitionen	EDM02.01, DSS01.03	
	AP006.03	• I&T-Budget • Kommunikation des Budgets			
	AP008.05	Definition potenzieller Verbesserungsprojekte			
	BAI10.02	Grundkonfiguration			
	BAI10.03	Genehmigte Änderungen gegenüber der Referenz			
	BAI10.04	Statusberichte zur Konfiguration			
	EDM04.01	Leitprinzipien für die Zuweisung von Ressourcen und Fähigkeiten			
Managementpraktik		Inputs		Outputs	
BAI03.12 Entwerfen von Lösungen auf der Grundlage der definierten Entwicklungsmethodik	Von	Beschreibung	Beschreibung	Für	
	AP003.02	Grundlegende Domänenbeschreibungen und Architekturdefinition			
	AP003.05	Anleitung zur Lösungsentwicklung			
	AP007.03	Matrix der Fähigkeiten und Kompetenzen			
	BAI02.01	• Bestätigte Akzeptanzkriterien von Anspruchsgruppen • Repository für Anforderungsdefinitionen			
	BAI02.02	Bericht zur Durchführbarkeitsstudie			
	BAI10.02	Grundkonfiguration			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen			
Keine entsprechenden weiteren Quellen für diese Komponente					

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Anwendungsentwicklung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build–B.1. Application Development
Prüfung von Geschäftsprozessen	Skills Framework for the Information Age V6, 2015	BPTS
Integration von Komponenten	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build–B.2. Component Integration
Datenbank-Design	Skills Framework for the Information Age V6, 2015	DBDS
Erstellung der Dokumentation	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build–B.5. Documentation Production
Hardwaredesign	Skills Framework for the Information Age V6, 2015	HWDE
Portierung/Softwarekonfiguration	Skills Framework for the Information Age V6, 2015	PORT
Programmierung/Softwareentwicklung	Skills Framework for the Information Age V6, 2015	PROG
Freigabe und Bereitstellung	Skills Framework for the Information Age V6, 2015	RELM
Lösungsarchitektur	Skills Framework for the Information Age V6, 2015	ARCH
Lösungsbereitstellung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build–B.4. Solution Deployment
Systemdesign	Skills Framework for the Information Age V6, 2015	DESN
Management der Systementwicklung	Skills Framework for the Information Age V6, 2015	DLMG
Systemtechnik	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build–B.6. Systems Engineering
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Installation/Stilllegung von Systemen	Skills Framework for the Information Age V6, 2015	HSIN
Systemintegration	Skills Framework for the Information Age V6, 2015	SINT
Test	Skills Framework for the Information Age V6, 2015	TEST
Test	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	B. Build – B.3. Test
User Experience Design	Skills Framework for the Information Age V6, 2015	HCEV

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zu Wartung und Instandhaltung	Definiert die angemessene Pflege von Software- und Hardwarekomponenten, um eine längere Lebensdauer der Betriebsmittel zu gewährleisten, die Produktivität der Mitarbeiter zu steigern und eine akzeptable Benutzererfahrung zu gewährleisten.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.10 Maintenance (MA-1)
Richtlinie zur Softwareentwicklung	Standardisiert die Softwareentwicklung der gesamten Organisation durch Auflistung aller zu befolgenden Protokolle und Standards.		
Richtlinie für den Erwerb von Systemen und Services	Bietet Verfahren zur Bewertung, Überprüfung und Validierung von Anforderungen für den Erwerb von Systemen und Services.	National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.18 System and services acquisition (SA-1)

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Ermöglichen Sie eine agile und skalierbare Bereitstellung digitaler Dienste. Stellen Sie die Einbindung in ein Ökosystem von Partnern, mit denen die Organisation zusammenarbeiten kann, oder die Einrichtung einer bimodalen IT-Struktur mit digitalen Fabriken, agilen Führungskräften und Teams, kontinuierlichen Arbeitsabläufen und einer auf Verbesserungen ausgerichteten Denkweise sicher.		
Etablieren Sie eine offene, unvoreingenommene Kultur, die bei der Erforschung potenzieller neuer Lösungen (einschließlich der Frage, ob erstellt oder gekauft werden soll) Alternativen fair und objektiv bewertet.		

G. Komponente: Services, Infrastruktur und Anwendungen

- Services einer „digitalen Fabrik“, die eine Trennung der „schnellen IT“ (die digitalen Fabrik ist verantwortlich für die Entwicklung digitaler Anwendungen) von der „Kern-IT“ ermöglichen
- Services zur Bewertung und Auswahl von Lösungen
- Werkzeuge und Services zur Durchführung von Tests

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI04 – Verfügbarkeit und Kapazität sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Schaffung eines ausgeglichenen Verhältnisses zwischen dem aktuellen und künftigen Bedarf hinsichtlich Verfügbarkeit, Leistung und Kapazität unter Sicherstellung einer kostenoptimalen Servicebereitstellung. Bewertung der aktuellen Fähigkeiten, Vorhersage zukünftiger Anforderungen auf der Grundlage von Geschäftsanforderungen, Analyse der Geschäftsauswirkungen und Bewertung der Risiken bei der Planung und Umsetzung von Maßnahmen zur Erfüllung der identifizierten Anforderungen.		
Zweck		
Aufrechterhaltung der Serviceverfügbarkeit, effizientes Ressourcenmanagement und Optimierung der Systemleistung durch die Vorhersage zukünftiger Leistungs- und Kapazitätsanforderungen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
BAI04.01 Beurteilen der aktuellen Verfügbarkeit, Leistung und Kapazität und Erstellen einer Baseline Beurteilen Sie die Verfügbarkeit, Leistung und Kapazität von Services und Ressourcen, um sicherzustellen, dass eine kostenmäßig vertretbare Kapazität und Leistung verfügbar ist, um den geschäftlichen Bedarf zu unterstützen und den Service Level Agreements (SLAs) zu entsprechen. Erstellen Sie Baselines für Verfügbarkeit, Leistung und Kapazität, um später einen Vergleich herstellen zu können.	a. Anteil der tatsächlichen Kapazitätsauslastung b. Anteil der tatsächlichen Verfügbarkeit c. Anteil der tatsächlichen Leistung	
Aktivitäten	Fähigkeitsstufe	
1. Berücksichtigen Sie bei der Beurteilung der Verfügbarkeit, Leistung und Kapazität von Services und Ressourcen jeweils den aktuellen und den prognostizierten Status von Kundenanforderungen, Geschäftsprioritäten, Geschäftszielvorgaben, Budgetauswirkungen, Ressourcennutzung, Leistungsfähigkeit der IT und Branchentrends.	2	
2. Identifizieren und verfolgen Sie sämtliche Störungen, die auf eine inadäquate Leistung oder Kapazität zurückzuführen sind.	3	
3. Überwachen Sie die tatsächliche Leistung und Kapazitätsauslastung anhand von definierten Schwellenwerten und ziehen Sie ggf. automatisierte Software zur Unterstützung hinzu.	4	
4. Bewerten Sie regelmäßig die aktuellen Leistungsstufen aller Verarbeitungsebenen (geschäftliche Nachfrage, Servicekapazität und Ressourcenkapazität), indem Sie sie mit Trends und Service Level Agreements vergleichen. Berücksichtigen Sie dabei Veränderungen im Umfeld.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		DP.CP Capacity Planning
ISF, The Standard of Good Practice for Information Security 2016		SY2.2 Performance and Capacity Management
ISO/IEC 20000-1:2011(E)		6.5 Capacity management
ITIL V3, 2011		Service Design, 4.4 Availability Management; 4.5 Capacity Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.14 Planning (PL-10, PL-11)
Managementpraktik		Beispielmetrik
BAI04.02 Beurteilen der geschäftlichen Auswirkungen Identifizieren Sie die für das Unternehmen wichtigen Services. Ordnen Sie Services und Ressourcen einzelnen Geschäftsprozessen zu und ermitteln Sie die geschäftlichen Abhängigkeiten. Stellen Sie sicher, dass die Auswirkungen nicht verfügbarer Ressourcen die uneingeschränkte Zustimmung des Kunden finden und von ihm akzeptiert werden. Stellen Sie in Bezug auf kritische Geschäftsfunktionen sicher, dass die Verfügbarkeitsanforderungen gemäß den Service Level Agreements erfüllt werden können.		a. Anzahl der Szenarien, die zur Bewertung zukünftiger Verfügbarkeits-situationen erstellt wurden b. Anteil der Geschäftsprozessverantwortlichen, die die Analyseergebnisse freigegeben haben
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie diejenigen Lösungen oder Services, die für den Verfügbarkeits- und Kapazitätsmanagementprozess von kritischer Bedeutung sind.		2
2. Ordnen Sie die ausgewählten Lösungen oder Services den Anwendungen und Infrastrukturen (IT und Einrichtung) zu, von denen sie abhängig sind, um eine Fokussierung auf kritische Ressourcen im Rahmen der Verfügbarkeitsplanung zu ermöglichen.		3
3. Sammeln Sie Daten zu Verfügbarkeitsmustern, indem Sie Protokolle früherer Ausfälle und Aufzeichnungen zur Leistungsüberwachung heranziehen. Verwenden Sie Modellierungswerkzeuge, mit denen es möglich ist, Ausfälle auf der Grundlage früherer Auslastungstrends sowie Managementexpectationen an eine neue Umgebung oder Benutzerbedingungen vorherzusagen.		4
4. Erstellen Sie anhand der gesammelten Daten Szenarien, in denen Sie zukünftige Verfügbarkeits-situationen beschreiben, um verschiedene potenzielle Kapazitätsstufen zu illustrieren, die für die Erreichung der Verfügbarkeits- und Leistungszielvorgaben erforderlich sind.		
5. Bestimmen Sie anhand der Szenarien die Wahrscheinlichkeit für die Verfehlung der Verfügbarkeits- und Leistungszielvorgaben.		
6. Bestimmen Sie die Auswirkungen der Szenarien auf die geschäftsbezogenen Leistungskennzahlen (z. B. Umsatz, Gewinn, Kundendienst). Binden Sie Geschäftsbereichsleiter, Leiter funktionaler Einheiten (vor allem des Finanzbereichs) und regionale Leiter mit ein, um deren Bewertung der Auswirkungen nachzuvollziehen.		
7. Stellen Sie sicher, dass die Geschäftsprozessverantwortlichen die Ergebnisse dieser Analyse vollständig verstehen und ihnen zustimmen. Fordern Sie von den Geschäftsverantwortlichen eine Liste mit Szenarien nicht akzeptabler Risiken an, die eine Behandlung erfordern, um das Risiko auf ein akzeptables Niveau zu reduzieren.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)		6.3 Service continuity and availability management
Managementpraktik		Beispielmetrik
BAI04.03 Planen neuer oder geänderter Serviceanfragen Planen und priorisieren Sie Verfügbarkeits-, Leistungs- und Kapazitätsauswirkungen, die sich aus veränderten geschäftlichen Bedürfnissen und Serviceanforderungen ergeben.		a. Anzahl der ungeplanten Kapazitäts-, Leistungs- oder Verfügbarkeitsaktualisierungen b. Anteil der vom Management durchgeführten Vergleiche, um Abweichungen zwischen der tatsächlichen Nachfrage nach Ressourcen mit den Prognosen zu Angebot und Nachfrage durchzuführen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie Verfügbarkeits- und Kapazitätsauswirkungen, die sich aus veränderten geschäftlichen Bedürfnissen ergeben, sowie Verbesserungspotenziale. Wenden Sie Modellierungstechniken an, um die Verfügbarkeits-, Leistungs- und Kapazitätspläne zu validieren.	3
2. Überprüfen Sie Verfügbarkeits- und Kapazitätsauswirkungen, die sich aus Servicetrendanalysen ergeben.	4
3. Stellen Sie sicher, dass das Management Vergleiche zwischen dem tatsächlichen Ressourcenbedarf und der prognostizierten Bereitstellung und Nachfrage durchführt, um die derzeitigen Prognosetechniken bewerten und ggf. verbessern zu können.	
4. Priorisieren Sie erforderliche Verbesserungen und erstellen Sie kostenmäßig vertretbare Verfügbarkeits- und Kapazitätspläne.	5
5. Passen Sie die Leistungs- und Kapazitätspläne und SLAs an und beziehen Sie sich dabei auf realistische, neue, vorgeschlagene und/oder geplante Geschäftsprozesse und unterstützende Services, Anwendungen und Infrastrukturänderungen. Berücksichtigen Sie auch die Überprüfung der tatsächlichen Leistung und Kapazitätsauslastung, einschließlich der Arbeitslaststufen.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)	5. Design and transition of new changed services
Managementpraktik	Beispielmetrik
BAI04.04 Überwachen und Überprüfen von Verfügbarkeit und Kapazität Überwachen, messen, analysieren, melden und überprüfen Sie Verfügbarkeit, Leistung und Kapazität. Identifizieren Sie Abweichungen von den zuvor erstellten Baselines. Überprüfen Sie Trendanalyseberichte, und identifizieren Sie etwaig vorhandene, erhebliche Störungen und Varianzen. Leiten Sie, wo nötig, Maßnahmen ein und stellen Sie sicher, dass alle nicht beseitigten Störungen verfolgt werden.	a. Anzahl der Ereignisse, bei denen der geplante Kapazitätsgrenzwert überschritten wurde b. Anzahl der Transaktionsspitzen, bei denen die angestrebte Leistung übertroffen wurde
Aktivitäten	Fähigkeitsstufe
1. Stellen Sie Kapazitätsberichte für die Budgetierungsprozesse zur Verfügung.	2
2. Richten Sie einen Prozess zur Datenerfassung ein, um dem Management Überwachungs- und Berichtsinformationen zur Verfügbarkeit, Leistung und Kapazitätsauslastung aller I&T-bezogenen Ressourcen zur Verfügung zu stellen.	3
3. Sorgen Sie für eine regelmäßige Ergebnisberichterstattung in einem geeigneten Format, die vom IT- und Business-Management überprüft und anschließend der Unternehmensleitung vorgelegt wird.	4
4. Integrieren Sie Überwachungs- und Berichtsaktivitäten in die schrittweisen Kapazitätsmanagementaktivitäten (Überwachung, Analyse, Anpassung und Implementierung).	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI04.05 Untersuchen und Beheben von Verfügbarkeits-, Leistungs- und Kapazitätsschwierigkeiten Gehen Sie Abweichungen nach, indem Sie identifizierte Verfügbarkeits-, Leistungs- und Kapazitätsprobleme untersuchen und beheben.	a. Anzahl und Anteil der ungelösten Probleme hinsichtlich Verfügbarkeit, Leistung und Kapazität b. Anzahl der Verfügbarkeitsprobleme
Aktivitäten	Fähigkeitsstufe
1. Konsultieren Sie die Produkthandbücher des Anbieters, um ein angemessenes Leistungsniveau bei Verarbeitungsspitzen und hohen Arbeitslasten sicherzustellen.	3
2. Definieren Sie ein Eskalationsverfahren, um bei dringenden Kapazitäts- und Leistungsproblemen eine schnelle Lösung zu ermöglichen.	
3. Identifizieren Sie Leistungs- und Kapazitätslücken auf der Grundlage der Überwachung der aktuellen und prognostizierten Leistung. Ziehen Sie die bekannten Spezifikationen für Verfügbarkeit, Kontinuität und Wiederherstellung heran, um die Ressourcen zu klassifizieren und eine Priorisierung zu ermöglichen.	4

A. Komponente: Prozess (Forts.)

4. Definieren Sie korrektive Maßnahmen (z. B. Verschieben von Arbeitslasten, Priorisieren von Aufgaben oder Ergänzen von Ressourcen bei Feststellung von Leistungs- und Kapazitätsproblemen).	5
5. Integrieren Sie die erforderlichen korrektiven Maßnahmen in die jeweiligen Planungs- und Änderungsmanagementprozesse.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen

	Exekutivkomitee	Chief Information Officer	Chief Technology Officer	Geschäftsprozessverantwortlicher	Chefarchitekt	Leiter IT-Betrieb	Service Manager	Business Continuity Manager
Wichtige Managementpraktik:								
BAI04.01 Beurteilen der aktuellen Verfügbarkeit, Leistung und Kapazität und Erstellen einer Baseline		R	A	R		R	R	
BAI04.02 Beurteilen der geschäftlichen Auswirkungen	A			R		R	R	
BAI04.03 Planen neuer oder geänderter Serviceanfragen		R	A	R		R	R	
BAI04.04 Überwachen und Überprüfen von Verfügbarkeit und Kapazität	A			R		R	R	
BAI04.05 Untersuchen und Beheben von Verfügbarkeits-, Leistungs- und Kapazitätsschwierigkeiten		R	A	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen						
Keine entsprechenden weiteren Quellen für diese Komponente								

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
BAI04.01 Beurteilen der aktuellen Verfügbarkeit, Leistung und Kapazität und Erstellen einer Baseline	BAI02.01	Repository für Anforderungsdefinitionen	Auswertungen gegen SLAs	APO09.05
	BAI02.03	Anforderungsrisikoregister	Baselines für Verfügbarkeit, Leistung und Kapazität	Intern
BAI04.02 Beurteilen der geschäftlichen Auswirkungen	BAI03.02	Interne und externe Service Level Agreements (SLAs)	Bewertung der Auswirkungen von Verfügbarkeit, Leistung und Kapazität auf das Geschäft	Intern
			Verfügbarkeits-, Leistungs- und Kapazitätsszenarien	Intern

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
BAI04.03 Planen neuer oder geänderter Serviceanfragen	BAI02.01	Bestätigte Akzeptanzkriterien von Anspruchsgruppen	Leistungs- und Kapazitätspläne	AP002.02
	BAI03.01	Genehmigte Grobdesignspezifikation	Priorisierte Verbesserungen	AP002.02
	BAI03.02	Genehmigte detaillierte Designspezifikation		
	BAI03.03	Dokumentierte Lösungskomponenten		
BAI04.04 Überwachen und Überprüfen von Verfügbarkeit und Kapazität			Überprüfungsberichte zur Überwachung der Verfügbarkeit, Leistung und Kapazität	MEA01.03
BAI04.05 Untersuchen und Beheben von Verfügbarkeits-, Leistungs- und Kapazitätsschwierigkeiten			Abhilfemaßnahmen	AP002.02
			Notfall-Eskalationsverfahren	DSS02.02
			Leistungs- und Kapazitätslücken	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Verfügbarkeitsmanagement	Skills Framework for the Information Age V6, 2015	AVMT
Kapazitätsmanagement	Skills Framework for the Information Age V6, 2015	CPMG

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Verfügbarkeitsmanagement	Liefert Informationen für die Infrastrukturplanung hinsichtlich Verfügbarkeit, Skalierbarkeit, Zuverlässigkeit und potenzieller Ausfallsicherheit. Enthält Richtlinien zur Ermittlung von Bandbreite, Kapazität und Verfügbarkeit von Diensten (vor dem Entwurf und der Bereitstellung), zur Festlegung von Service Level Agreements (SLAs) und zur Implementierung einer kontinuierlichen Überwachung von Leitungen, Verkehr und Reaktionszeiten.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Für Unternehmen, die auf Informationen angewiesen sind, sind Verfügbarkeit und Kapazitätsmanagement entscheidend für einen erfolgreichen Betrieb. Etablieren Sie eine Kultur, in der die Verfügbarkeit und Kapazität von Produkten und Services (in Übereinstimmung mit den Geschäftsanforderungen) priorisiert und durch Prozesse und Verhaltensweisen unterstützt werden, und in der die erforderliche Verfügbarkeit und Kapazität nicht nur vor der Planung ermittelt, sondern auch bei der Bereitstellung berücksichtigt wird. Stellen Sie die Definition intelligenter SLAs, kontinuierliche Überwachung von Umlauf, Datenverkehr und Reaktionszeiten, regelmäßige Tests zu Business Continuity und Disaster Recovery der Infrastruktur sicher.		
G. Komponente: Services, Infrastruktur und Anwendungen		
• Werkzeuge zur Kapazitätsplanung • Services und Werkzeugen zur Beschaffung • Werkzeuge zur Überwachung der Service Level		

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI05 – Organisatorische Änderungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Maximierung der Wahrscheinlichkeit einer erfolgreichen und raschen Implementierung nachhaltiger, unternehmensweiter, organisatorischer Änderungen mit reduziertem Risiko. Abdeckung des vollständigen Änderungslebenszyklus und Berücksichtigung aller betroffenen Anspruchsgruppen aus dem geschäftlichen Bereich und der IT.		
Zweck		
Vorbereitung und Verpflichtung der Anspruchsgruppen auf geschäftsbezogene Änderungen und Reduzierung des Ausfallrisikos.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG05 Kundenorientierte Servicekultur • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die IT ermöglichten Anlage- und Dienstleistungsportfolio • AG08 Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie • AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case genannten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG05 a. Anzahl der Unterbrechungen bei Kundenservices b. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die Kundenservices den vereinbarten Standards entsprechen c. Anzahl von Kundenbeschwerden d. Trend der Umfrageergebnisse zur Kundenzufriedenheit		AG08 a. Dauer der Ausführung von Geschäftsservices oder -prozessen b. Anzahl von I&T-gestützten Geschäftsprogrammen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder zusätzliche Kosten verursachen c. Anzahl der Geschäftsprozessänderungen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder überarbeitet werden müssen d. Anzahl von Anwendungen oder kritischen Infrastrukturen, die isoliert arbeiten und nicht integriert sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
BAI05.01 Begründen des Wunsches nach Änderung Machen Sie sich mit dem Umfang und den Auswirkungen der in Erwägung gezogenen Änderung vertraut. Überprüfen Sie, inwieweit die Anspruchsgruppen bereit für die Änderung und gewillt sind, diese zu realisieren. Identifizieren Sie, welche Maßnahmen erforderlich sind, um die Anspruchsgruppen zu motivieren, die Änderung zu akzeptieren und sich für deren erfolgreiche Umsetzung einzusetzen.		a. Grad der Einbeziehung der obersten Führungsebene b. Grad des Wunsches nach Änderung seitens der Anspruchsgruppen
Aktivitäten		Fähigkeitsstufe
1. Beurteilen Sie den Umfang und die Auswirkungen der in Erwägung gezogenen Änderung, die davon betroffenen Anspruchsgruppen, die Art der Auswirkungen auf die einzelnen Anspruchsgruppen bzw. deren erforderliche Einbeziehung sowie die derzeitige Bereitschaft und Fähigkeit, die Änderung zu übernehmen.		2
2. Identifizieren, nutzen und kommunizieren Sie aktuelle Schwachstellen, negative Ereignisse, Risiken, Probleme mit der Kundenzufriedenheit und geschäftliche Probleme, aber auch sofortige Vorteile, zukünftige Chancen und Gewinne und Wettbewerbsvorteile und bilden Sie so die Grundlage für die Schaffung des Wunsches nach Änderung.		
3. Demonstrieren Sie anhand von wichtigen Mitteilungen des Exekutivkomitees oder des CEO deren Befürwortung der Änderung.		
4. Geben Sie die Richtung vor, indem Sie dafür sorgen, dass die Unterstützung des obersten Führungsstabs sichtbar ist und wirken Sie auf die Anspruchsgruppen ein, um sie zu motivieren und zu inspirieren, die Änderung zu befürworten.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PROSCI® 3-Phase Change Management Process		Phase 1. Preparing for change – Define your change management strategy
Managementpraktik		Beispielmetrik
BAI05.02 Aufstellen eines effektiven Implementierungsteams Stellen Sie ein effektives Implementierungsteam zusammen, indem Sie geeignete Teammitglieder auswählen, Vertrauen schaffen und gemeinsame Ziele und Maßnahmen zur Sicherung der Effektivität festlegen.		a. Anzahl der identifizierten Probleme aufgrund von Defiziten bei Fähigkeiten oder Kapazitäten im Implementierungsteam b. Beurteilung der Zufriedenheit mit dem Implementierungsteam seitens der Anspruchsgruppen
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie ein effektives Kernteam für die Implementierung auf, dem geeignete Mitglieder aus den Fachbereichen und der IT angehören und die in der Lage sind, die erforderliche Zeit zu investieren und Kenntnisse, Fähigkeiten, Erfahrung, Glaubwürdigkeit und Autorität einzubringen Überlegen Sie, inwieweit die Hinzuziehung Dritter (z. B. Berater) sinnvoll ist, um eine unabhängige Sichtweise zu erhalten oder etwaige Lücken in Bezug auf bestimmte Fähigkeiten zu füllen. Identifizieren Sie innerhalb der verschiedenen Unternehmensbereiche potenzielle Änderungsvermittler, mit denen das Kernteam zusammenarbeiten kann, um die Vision zu unterstützen und Änderungen in die Organisation zu tragen.		3
2. Schaffen Sie eine vertrauensvolle Atmosphäre innerhalb des Kernteams, indem Sie für sorgfältig geplante Veranstaltungen mit einer effektiven Kommunikation und gemeinsamen Aktivitäten sorgen.		
3. Entwickeln Sie eine gemeinsame Vision und gemeinsame Ziele, die die Zielvorgaben des Unternehmens unterstützen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PROSCI® 3-Phase Change Management Process		Phase 1. Preparing for change – Prepare your change management team
Managementpraktik		Beispielmetrik
BAI05.03 Kommunizieren der gewünschten Vision Kommunizieren Sie die gewünschte Vision für die Änderung und verwenden Sie dabei die Sprache derer, die von der Änderung betroffen sind. Die Mitteilung sollte durch den obersten Führungsstab erfolgen und die Begründung der Änderung und ihre Vorteile beinhalten, die Auswirkungen aufzeigen, die sich bei Nichtumsetzung der Änderung ergäben, die Vision und Roadmap umfassen sowie die erforderliche Beteiligung der verschiedenen Anspruchsgruppen darlegen.		a. Anzahl der Fragen zu Änderungen b. Rückmeldung der Anspruchsgruppen zum erlangten Grad an Verständnis der Änderung

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Entwickeln Sie einen Plan zur Kommunikation der Vision, mit dem Sie die wichtigsten Zielgruppen erreichen, und berücksichtigen Sie dabei deren Verhaltensmuster und Informationsbedürfnis sowie Kommunikationskanäle und Prinzipien.	3
2. Stellen Sie die Kommunikationsinhalte unter Berücksichtigung des Kommunikationsplans für die jeweiligen Unternehmensebenen bereit.	
3. Verstärken Sie die Kommunikation durch Foren und durch Wiederholung.	
4. Nehmen Sie alle Führungsebenen in die Verantwortung, was das Entstehen für die Vision anbelangt.	
5. Überprüfen Sie das Verständnis der gewünschten Vision und reagieren Sie auf etwaige Probleme, auf die seitens der Mitarbeiter hingewiesen wird.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI05.04 Befähigen von Rolleninhabern und Identifizieren kurzfristiger Erfolge Befähigen Sie die Inhaber von Implementierungsrollen, indem Sie für die Zuweisung von Verantwortlichkeiten sorgen. Bieten Sie Schulungen an und richten Sie die Organisationsstrukturen und HR-Prozesse entsprechend aus. Identifizieren und kommunizieren Sie kurzfristig realisierbare Erfolge, die wichtig für die Begünstigung von Änderungen sind.	a. Grad der Zufriedenheit der Rolleninhaber mit der Durchführung, Nutzung und Aufrechterhaltung der Änderung b. Anteil der geschulten Rolleninhaber c. Anteil der Rolleninhaber mit geeigneten zugewiesenen Befugnissen d. Feedback der Rolleninhaber zum Grad der Befähigung e. Selbsteinschätzung der relevanten Fähigkeiten durch die Rolleninhaber
Aktivitäten	Fähigkeitsstufe
1. Planen Sie den Schulungsbedarf, der gedeckt werden muss, damit die Mitarbeiter die erforderlichen Fähigkeiten und Verhaltensweisen entwickeln können.	2
2. Identifizieren, priorisieren und bieten Sie Möglichkeiten für kurzfristige Erfolge. Diese können sich beispielsweise auf derzeit bekannte Problembereiche oder externe Faktoren beziehen, die es dringend zu adressieren gilt.	
3. Nutzen Sie realisierte kurzfristige Erfolge, indem Sie die jeweiligen Vorteile gegenüber den Betroffenen kommunizieren und zeigen, dass die Vision auf dem richtigen Weg ist. Optimieren Sie die Vision, sichern Sie sich weiterhin die Unterstützung der Führungskräfte und sorgen Sie für Dynamik.	
4. Identifizieren Sie Organisationsstrukturen, die mit der Vision vereinbar sind und nehmen Sie ggf. Änderungen vor, um die Vereinbarkeit herzustellen.	3
5. Richten Sie HR-Prozesse und Messsysteme (z. B. Leistungsbewertung, Vergütungsentscheidungen, Beförderungsentscheidungen, Rekrutierung und Einstellung) so aus, dass sie die Vision optimal unterstützen .	
6. Identifizieren Sie Führungskräfte, die sich erforderlichen Änderungen gegenüber noch immer sperren, und wirken Sie auf sie ein.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI05.05 Ermöglichen von Betrieb und Nutzung Planen und implementieren Sie alle technischen, operativen und nutzungsbezogenen Aspekte so, dass all diejenigen, die in die zukünftige Umgebung einbezogen werden, ihren Zuständigkeiten nachkommen können.	a. Anteil der Benutzer, die über eine angemessene Handlungsfähigkeit verfügen b. Anteil der für den Betrieb und die Nutzung der Änderung entwickelten Pläne

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Entwickeln Sie einen Plan für den Betrieb und die Nutzung der Änderung. Der Plan sollte realisierte kurzfristige Erfolge kommunizieren und auf diesen aufbauen sowie verhaltensbezogene und kulturelle Aspekte des allgemeinen Übergangs berücksichtigen und die Identifizierung mit und Unterstützung der Änderung steigern. Stellen Sie sicher, dass der Plan eine ganzheitliche Sicht der Änderung bietet und Dokumentation (z. B. Verfahren), Mentoring, Schulung, Coaching, Wissenstransfer, verbesserte unmittelbare Unterstützung nach der Inbetriebnahme und kontinuierlichen Support umfasst.	3
2. Implementieren Sie den Betriebs- und Nutzungsplan. Definieren und verfolgen Sie Erfolgskennzahlen, einschließlich Geschäfts- und Wahrnehmungskennzahlen, die Hinweise darauf geben, wie Mitarbeiter über eine Änderung denken. Leiten Sie ggf. Abhilfemaßnahmen ein.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
PROSCI® 3-Phase Change Management Process	Phase 2. Managing change
Managementpraktik	Beispielmetrik
BAI05.06 Einbetten neuer Ansätze Betten Sie die neuen Ansätze ein, indem Sie implementierte Änderungen verfolgen, die Effektivität des Betriebs- und Nutzungsplans beurteilen und für eine dauerhafte Wahrnehmung durch regelmäßige Kommunikation sorgen. Ergreifen Sie gegebenenfalls korrektive Maßnahmen, die u. a. die Durchsetzung der Compliance beinhalten können.	a. Grad der Zufriedenheit der Benutzer mit der Einführung der Änderung b. Anteil der Compliance-Prüfungen, die Ursachen für eine geringe Akzeptanz identifiziert haben c. Anzahl der Compliance-Prüfungen, die durchgeführt wurden, um die Ursachen für die geringe Akzeptanz und empfohlene Korrekturmaßnahmen zu ermitteln
Aktivitäten	Fähigkeitsstufe
1. Übertragen Sie den Prozessverantwortlichen die Verantwortung für den Routinebetrieb.	2
2. Feiern Sie Erfolge und implementieren Sie Belohnungs- und Anerkennungsprogramme, um die Änderung zusätzlich zu verankern.	3
3. Sorgen Sie durch regelmäßige Kommunikation der Änderung und deren Übernahme für eine dauerhafte Wahrnehmung.	
4. Identifizieren Sie anhand von Leistungserfassungssystemen die Ursachen für eine geringe Akzeptanz. Leiten Sie ggf. korrektive Maßnahmen ein.	
5. Führen Sie Compliance-Prüfungen durch, um die Ursachen für eine geringe Akzeptanz zu identifizieren. Empfehlen Sie korrektive Maßnahmen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
PROSCI® 3-Phase Change Management Process	Phase 3. Reinforcing change
Managementpraktik	Beispielmetrik
BAI05.07 Aufrechterhalten von Änderungen Erhalten Sie Änderungen aufrecht, indem Sie für eine effektive Schulung neuer Mitarbeiter, regelmäßige Kommunikationskampagnen, ein dauerhaftes Engagement der oberen Führungsebene, die Überwachung der Akzeptanz und einen unternehmensweiten Wissens- und Erfahrungsaustausch sorgen.	a. Anzahl der durchgeführten Schulungen und Wissenstransfers b. Grad des Engagements der oberen Führungsebene zur Unterstützung der Änderung
Aktivitäten	Fähigkeitsstufe
1. Unterstützen und verstärken Sie Änderungen durch regelmäßige Mitteilungen, die das Engagement der oberen Führungsebene demonstriert.	2
2. Stellen Sie für neue Mitarbeiter Mentoring-, Schulungs-, Coaching- und Wissenstransfermaßnahmen bereit, um Änderungen nachhaltig zu stützen.	3
3. Überprüfen Sie regelmäßig Betrieb und Nutzung der Änderungen. Ermitteln Sie Verbesserungspotenziale.	4
4. Erfassen Sie Erkenntnisse, die in Verbindung mit der Änderungsimplementierung gewonnen wurden. Stellen Sie entsprechendes Wissen unternehmensweit zur Verfügung	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
PROSCI® 3-Phase Change Management Process	Phase 3. Reinforcing change

B. Komponente: Organisationsstrukturen													
Wichtige Managementpraktik:													
	Exekutivkomitee	Chief Executive Officer	Chief Operating Officer	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Programm-Manager	Projektmanager	Project Management Office	Leiter Personal	Leiter Entwicklung
												Leiter IT-Betrieb	Service Manager
												Information Security Manager	Business Continuity Manager
BAI05.01 Begründen des Wunsches nach Änderung	R	A		R	R	R	R	R	R	R		R	
BAI05.02 Aufstellen eines effektiven Implementierungsteams	A			R	R	R			R	R	R	R	
BAI05.03 Kommunizieren der gewünschten Vision	A			R	R	R	R		R	R			
BAI05.04 Befähigen von Rolleninhabern und Identifizieren kurzfristiger Erfolge	A			R	R	R			R	R		R	
BAI05.05 Ermöglichen von Betrieb und Nutzung	A		R	R	R	R		R			R	R	R
BAI05.06 Einbetten neuer Ansätze	A		R	R	R	R		R			R	R	R
BAI05.07 Aufrechterhalten von Änderungen	A		R	R	R	R		R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)													
Keine entsprechenden weiteren Quellen für diese Komponente													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
BAI05.01 Begründen des Wunsches nach Änderung	Von	Beschreibung	Beschreibung	Für
	AP011.02	Ergebnisse zur Servicequalität, einschließlich Kundenfeedback	Mitteilungen von Führungskräften, die für die Änderungen eintreten	Intern
	BAI02.01	• Repository für Anforderungsdefinitionen • Bestätigte Akzeptanzkriterien von Anspruchsgruppen	Kommunikation der Treiber der Änderungen	Intern
	BAI02.03	• Risikoregisteranforderungen • Maßnahmen zur Risikominderung		
	BAI03.01	Genehmigte Grobdesignspezifikation		
	BAI03.02	Genehmigte detaillierte Designspezifikation		
BAI05.02 Aufstellen eines effektiven Implementierungsteams	BAI02.01	Bestätigte Akzeptanzkriterien von Anspruchsgruppen	Gemeinsame Vision und Ziele	BAI01.02
			Implementierungsteam und Rollen	BAI01.04

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
BAI05.03 Kommunizieren der gewünschten Vision			Plan zur Kommunikation der Vision	BAI01.04
			Kommunikation der Vision	BAI01.05
BAI05.04 Befähigen von Rolleninhabern und Identifizieren kurzfristiger Erfolge	Außerhalb von COBIT	Organisationsstruktur des Unternehmens	Ausgerichtete HR-Leistungszielvorgaben	AP007.04
			Identifizierte kurzfristige Erfolge	BAI01.04
			Kommunikation der Vorteile	BAI01.06
BAI05.05 Ermöglichen von Betrieb und Nutzung	BAI03.03	Dokumentierte Lösungskomponenten	Betriebs- und Nutzungsplan	AP008.04, BAI08.03, DSS01.01, DSS01.02, DSS06.02
	BAI03.10	Aktualisierte Lösungskomponenten und zugehörige Dokumentation	Erfolgskennzahlen und Ergebnisse	AP008.05, BAI07.07, BAI07.08, MEA01.03
BAI05.06 Einbetten neuer Ansätze			Ergebnisse von HR-Leistungsprüfungen	AP007.04
			Kommunikation zur Bewusstseinsbildung	Intern
			Ergebnisse der Compliance-Überprüfung	MEA02.02, MEA03.03
BAI05.07 Aufrechterhalten von Änderungen			Pläne zum Wissenstransfer	BAI08.02, BAI08.03
			Mitteilungen über das Engagement des Managements	Intern
			Überprüfungen der betrieblichen Nutzung	MEA02.02
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Management von Geschäftsveränderungen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.7. Business Change Management
Planung und Management der Änderungsimplementierung	Skills Framework for the Information Age V6, 2015	CIPM
Organisationsdesign und Implementierung	Skills Framework for the Information Age V6, 2015	ORDI

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Management organisatorischer Veränderungen	Bietet einen Rahmen und skizziert Prinzipien für das Management organisatorischer Veränderungen. Geht mit der aktuellen Gesetzgebung konform und bietet bewährte Verfahren für das Personalmanagement und gewährleistet einen konsistenten Ansatz für das Management von Veränderungen in der gesamten Organisation.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Die Generierung von Wert aus durch I&T ermöglichten Investitionen erfordert mehr als nur die Bereitstellung von I&T-Lösungen und Services. Sie erfordert auch Änderungen der Geschäftsprozesse, der Fähigkeiten und Kompetenzen, der Kultur und des Verhaltens usw., die alle in den Business Case der Investition einbezogen werden müssen. Die Führungskräfte müssen durch Flexibilität, Offenheit und Vertrauen eine Kultur des kontinuierlichen Wandels schaffen und eine angemessene Unterstützung und Kommunikation für das Änderungsmanagement bieten.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Kommunikationsmittel und -kanäle • Werkzeuge für Befragungen

Diese Seite wurde absichtlich freigelassen.

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI06 – IT-Änderungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Managen sämtlicher Änderungen in einer kontrollierten Art und Weise, einschließlich Standardänderungen und dringender Wartungsmaßnahmen in Bezug auf Geschäftsprozesse, Anwendungen und Infrastruktur. Damit verbunden sind Änderungsstandards und -verfahren, die Beurteilung von Auswirkungen, Priorisierung und Genehmigung, dringende Änderungen, Nachverfolgung, Berichterstattung, Abschluss und Dokumentation.		
Zweck		
Ermöglichung einer schnellen und zuverlässigen Bereitstellung von Änderungen für den Geschäftsbetrieb. Minderung des Risikos einer negativen Auswirkung auf die Stabilität oder Integrität des veränderten Umfelds.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen		• AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
BAI06.01 Evaluieren, Priorisieren und Genehmigen von Änderungsanträgen Bewerten Sie alle Änderungsanträge und bestimmen Sie deren Auswirkung auf Geschäftsprozesse und I&T-Services und beurteilen Sie, inwieweit sich die Änderung negativ auf die betriebliche Umgebung auswirken könnte und inakzeptable Risiken birgt. Stellen Sie sicher, dass Änderungen protokolliert, priorisiert, kategorisiert, beurteilt, genehmigt, geplant und terminiert werden.	a. Umfang der Nacharbeit aufgrund fehlgeschlagener Änderungen b. Anteil der erfolglosen Änderungen aufgrund unzureichender Folgenabschätzungen	
Aktivitäten	Fähigkeitsstufe	
1. Setzen Sie formelle Änderungsanträge ein, um Geschäftsprozessverantwortlichen und IT-Vertretern die Möglichkeit zu geben, Änderungen in Bezug auf Geschäftsprozesse, Infrastrukturen, Systeme oder Anwendungen zu beantragen. Stellen Sie sicher, dass Änderungen dieser Art ausnahmslos aus dem Managementprozess für Änderungsanträge hervorgehen.	2	
2. Ordnen Sie die beantragten Änderungen einer bestimmten Kategorie zu (z. B. Geschäftsprozesse, Infrastruktur, Betriebssysteme, Netzwerke, Anwendungssysteme, erworbene/gebündelte Anwendungssoftware) und stellen Sie den Bezug zu den betroffenen Konfigurationselementen her.		
3. Priorisieren Sie die beantragten Änderungen basierend auf den geschäftlichen und technischen Anforderungen, den erforderlichen Ressourcen sowie den gesetzlichen, behördlichen und vertraglichen Gründen für die Beantragung der Änderung.		
4. Sorgen Sie dafür, dass jede Änderung formell von den jeweiligen Geschäftsprozessverantwortlichen, Service Managern und IT-Anspruchsgruppen genehmigt wird. Änderungen mit geringem Risiko, die relativ häufig vorkommen, sollten vorab als Standardänderungen genehmigt werden.		
5. Planen und terminieren Sie alle genehmigten Änderungen.		

A. Komponente: Prozess (Forts.)		
6. Planen und bewerten Sie alle Anträge in strukturierter Weise. Führen Sie außerdem eine Analyse der Auswirkungen auf Geschäftsprozesse, Infrastruktur, Systeme und Anwendungen, Geschäftskontinuitätspläne (BCPs) und Serviceanbieter durch, um sicherzustellen, dass alle von der Änderung betroffenen Komponenten identifiziert wurden. Beurteilen Sie die Wahrscheinlichkeit für eine Beeinträchtigung der Betriebsumgebung und das Risiko, das mit der Implementierung der Änderung einhergeht. Berücksichtigen Sie rechtliche und vertragliche Auswirkungen der beantragten Änderung sowie die Auswirkungen auf Sicherheit, Datenschutz und Compliance. Berücksichtigen Sie auch Abhängigkeiten zwischen den Änderungen. Beziehen Sie ggf. Geschäftsprozessverantwortliche in den Beurteilungsprozess ein.		3
7. Überlegen Sie, welche Auswirkungen sich durch beauftragte Serviceanbieter (z. B. für ausgelagerte Geschäftsverarbeitung, Infrastruktur, Anwendungsentwicklung und gemeinsam genutzte Services) für den Änderungsmanagementprozess ergeben könnten. Berücksichtigen Sie auch die Integration von Änderungsmanagementprozessen der Organisation in die Änderungsmanagementprozesse von Serviceanbietern sowie die Auswirkungen auf Vertragsbestimmungen und SLAs.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ISF, The Standard of Good Practice for Information Security 2016	SY2.4 Change Management	
ISO/IEC 20000-1:2011(E)	9.2 Change management	
ITIL V3, 2011	Service Transition, 4.2 Change Management	
PMBOK Guide Sixth Edition, 2017	Part 1: 4.6 Perform Integrated Change Control	
Managementpraktik	Beispielmetrik	
BAI06.02 Managen von Notfalländerungen Managen Sie Notfalländerungen mit einem hohen Maß an Sorgfalt, um weitere Störungen zu minimieren. Stellen Sie sicher, dass die Notfalländerung kontrolliert und sicher erfolgt. Stellen Sie sicher, dass Notfalländerungen im Anschluss an die Änderung angemessen beurteilt und genehmigt werden.	a. Anzahl der nach der Störung nicht genehmigten Notfalländerungen b. Anteil der Notfalländerungen an der Gesamtzahl der Änderungen	
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie die Merkmale einer Notfalländerung.		2
2. Stellen Sie sicher, dass ein dokumentiertes Verfahren besteht, mit dessen Hilfe Notfalländerungen angekündigt, beurteilt, vorläufig genehmigt und nachträglich autorisiert und aufgezeichnet werden können.		
3. Überprüfen Sie, ob alle Zugriffsvorkehrungen in Verbindung mit Notfalländerungen sachgemäß autorisiert und dokumentiert und nach der Änderung wieder aufgehoben wurden.		3
4. Überwachen Sie alle Notfalländerungen und führen Sie im Anschluss an die Implementierung eine Überprüfung mit den betroffenen Parteien durch. Im Rahmen der Überprüfung sollten korrektive Maßnahmen auf der Grundlage der jeweiligen Ursache in Erwägung gezogen und eingeleitet werden. Zu den Ursachen können beispielsweise Probleme mit Geschäftsprozessen, der Entwicklung und Wartung des Anwendungssystems, Entwicklungs- und Testumgebungen, Dokumentation und Handbüchern und der Datenintegrität gehören.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik	Beispielmetrik	
BAI06.03 Verfolgen und Berichten des Änderungsstatus Pflegen Sie ein Verlaufs- und Berichtssystem, um abgelehnte Änderungen zu dokumentieren und um den Status genehmigter, in Bearbeitung befindlicher und abgeschlossener Änderungen zu kommunizieren. Stellen Sie sicher, dass genehmigte Änderungen planmäßig implementiert werden.	a. Anzahl und Alter der aufgelaufenen Änderungsanträge b. Anteil der Änderungsanträge, deren Status den Anspruchsgruppen rechtzeitig mitgeteilt wurde	

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
BAI06.01 Evaluieren, Priorisieren und Genehmigen von Änderungsanträgen	Von	Beschreibung	Beschreibung	Für
	BAI03.05	Integrierte und konfigurierte Lösungskomponenten	(Zeit-)Planänderungen	BAI07.01
	DSS02.03	Genehmigte Serviceanfragen	Genehmigte Änderungsanträge	BAI07.01
	DSS03.03	Lösungsvorschläge für bekannte Fehler	Folgenabschätzungen	Intern
	DSS03.05	Identifizierte nachhaltige Lösungen		
	DSS04.08	Genehmigte Änderungen an den Plänen		
	DSS06.01	Ursachenanalysen und Empfehlungen		
BAI06.02 Managen von Notfalländerungen			Überprüfung von Notfalländerungen nach der Implementierung	Intern
BAI06.03 Verfolgen und Berichten des Änderungsstatus	BAI03.09	Erfassung aller genehmigten und umgesetzten Änderungsanträge	Statusberichte zu Änderungsanträgen	BAI01.06, BAI10.03
BAI06.04 Abschließen und Dokumentieren der Änderungen			Dokumentation der Änderungen	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Änderungsmanagement	Skills Framework for the Information Age V6, 2015	CHMG
Support von Änderungen	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	C. Run - C.2. Change Support

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum IT-Änderungsmanagement	Kommuniziert die Absicht des Managements, dass alle Änderungen an der Unternehmens-IT so gemanagt und umgesetzt werden, dass Risiken und Auswirkungen für die Anspruchsgruppen minimiert werden. Deckt bereichsinterne Betriebsmittel und den Standard-Änderungsmanagementprozess ab.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Führungskräfte müssen eine Kultur der kontinuierlichen Verbesserung von IT-Lösungen und -Services schaffen und erkennen, dass eine Verbesserung erfordert, dass sie die Auswirkungen des technologischen Wandels auf das Unternehmen, die inhärenten Risiken und Möglichkeiten zu deren Minderung genauso wie die Kosten verstehen. Die Führungskräfte müssen die Auswirkungen von Änderungen gegen den erwarteten Nutzen und den Beitrag zur I&T-Strategie und den Unternehmenszielvorgaben abwägen.		
G. Komponente: Services, Infrastruktur und Anwendungen		
• Konfigurationsmanagement-Werkzeuge • IT-Änderungsmanagement-Werkzeuge		

Diese Seite wurde absichtlich freigelassen.

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI07– Umsetzung und Abnahme von IT-Änderungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Formelle Abnahme und Inbetriebnahme neuer Lösungen Dazu gehören Implementierungsplanung, System- und Datenkonvertierung, Abnahmetests, Kommunikation, Release-Vorbereitung, Produktivsetzung neuer oder geänderter Geschäftsprozesse und I&T-Services, frühzeitiger Produktiv-Support und eine Überprüfung nach der Implementierung.		
Zweck		
Sichere Implementierung von Lösungen im Einklang mit vereinbarten Erwartungen und Ergebnissen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen		• AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden

A. Komponente: Prozess	
Managementpraktik	Beispielmesskriterien
BAI07.01 Erstellen eines Implementierungsplans Erstellen Sie einen Implementierungsplan, der folgende Aspekte abdeckt: System- und Datenkonvertierung, Abnahmetestkriterien, Kommunikation, Schulung, Release-Vorbereitung, Produktivsetzung, frühzeitiger Produktiv-Support, Fallback-/Back-Up-Plan und Überprüfung nach der Implementierung. Holen Sie die Genehmigung relevanter Parteien ein.	a. Anzahl und Kategorie der Anspruchsgruppen, die den Umsetzungsplan freigeben b. Anzahl der Implementierungspläne, die robust sind und alle erforderlichen Komponenten enthalten
Aktivitäten	Fähigkeitsstufe
1. Erstellen Sie einen Implementierungsplan, der folgende Aspekte beinhaltet: Allgemeine Implementierungsstrategie, Abfolge der Implementierungsschritte, Ressourcenanforderungen, Abhängigkeiten, Kriterien für die Abnahme der Produktivsetzung durch das Management, Anforderungen an die Installationsverifizierung, Übergangsstrategie für den Produktiv-Support und Aktualisierung der Geschäftskontinuitätspläne (BCPs).	2
2. Lassen Sie sich von den externen Lösungsanbietern ihre Beteiligung an den einzelnen Implementierungsschritten bestätigen.	
3. Identifizieren und dokumentieren Sie die Fallback- und Wiederherstellungsprozesse.	
4. Stellen Sie sicher, dass sämtliche Implementierungspläne von den technischen und geschäftlichen Anspruchsgruppen genehmigt und ggf. im Rahmen eines internen Audits geprüft werden.	3
5. Überprüfen Sie formell das technische und geschäftliche Risiko, das mit der Implementierung einhergeht. Stellen Sie sicher, dass das wesentliche Risiko im Planungsprozess berücksichtigt und behandelt wird.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ITIL V3, 2011	Service Transition, 4.1 Transition Planning and Support

A. Komponente: Prozess (Forts.)		
Managementpraktik	Beispielmetrik	
BAI07.02 Planen der Geschäftsprozess-, System- und Datenkonvertierung Bereiten Sie unter Rückgriff auf die Entwicklungsmethoden des Unternehmens die Migration der Geschäftsprozesse, der Daten der I&T-Services und der Infrastruktur vor. Sehen Sie Prüfpfade und einen Notfallplan für den Fall des Fehlschlagens der Migration vor.	a. Anteil der erfolgreich konvertiert wurde b. Anteil der notwendigen Anpassungen an den Verfahren (einschließlich überarbeiteter Rollen und Verantwortlichkeiten und Kontrollverfahren)	
Aktivitäten	Fähigkeitsstufe	
1. Definieren Sie einen Plan für die Migration der Geschäftsprozesse, Daten der I&T-Services und Infrastruktur. Berücksichtigen Sie bei der Entwicklung des Plans Aspekte, wie z. B. Hardware, Netzwerke, Betriebssysteme, Software, Transaktionsdaten, Stammdaten, Sicherungen und Archive, (interne und externe) Schnittstellen mit anderen Systemen, mögliche Compliance-Anforderungen, Geschäftsabläufe und die Systemdokumentation.	2	
2. Berücksichtigen Sie im Konvertierungsplan für die Geschäftsprozesse alle Anpassungen, die an Verfahren vorgenommen werden müssen, einschließlich der Überarbeitung von Rollen, Zuständigkeiten und Kontrollverfahren.		
3. Stellen Sie sicher, dass der Datenkonvertierungsplan keine Änderungen der Datenwerte erfordert, es sei denn, dies ist aus geschäftlichen Gründen unverzichtbar. Dokumentieren Sie vorgenommene Änderungen an Datenwerten und sichern Sie sich die Genehmigung seitens des Datenverantwortlichen für den Geschäftsprozess.		
4. Planen Sie die Aufbewahrung von Sicherungs- und Archivdaten unter Berücksichtigung der geschäftlichen, behördlichen bzw. Compliance-Anforderungen.		
5. Simulieren und testen Sie die Konvertierung, bevor Sie sie real durchführen.		
6. Koordinieren und überprüfen Sie die Vollständigkeit und Zeitplanung zum Konvertierungszeitpunkt, um einen nahtlosen, ununterbrochenen Übergang ohne Verlust von Transaktionsdaten sicherzustellen. Frieren Sie, soweit erforderlich und falls keine anderen Alternativen verfügbar sind, den Live-Betrieb ein.		
7. Planen Sie eine Sicherung aller Systeme und Daten unmittelbar vor der Konvertierung ein. Pflegen Sie Prüfpfade, damit die Konvertierung zurückverfolgt werden kann. Stellen Sie sicher, dass ein Notfallplan vorhanden ist, der das Rollback der Migration und eine Rückfalloption auf den vorherigen Verarbeitungszustand für den Fall des Fehlschlagens der Migration vorsieht.		
8. Berücksichtigen Sie im Datenkonvertierungsplan Methoden zur Erfassung, Konvertierung und Verifizierung der zu konvertierenden Daten sowie zur Identifizierung und Behebung von Fehlern, die während der Konvertierung auftreten. Sehen Sie außerdem einen Vergleich zwischen den ursprünglichen und den konvertierten Daten vor, um die Vollständigkeit und Integrität der Daten sicherzustellen.	3	
9. Berücksichtigen Sie im Migrationsplan für Geschäftsprozesse, Daten und Infrastruktur – soweit Risikomanagement-Anforderungen, geschäftliche, behördliche oder Compliance-Anforderungen bestehen – das Risiko in Verbindung mit Konvertierungsproblemen und sehen Sie eine Geschäftskontinuitätsplanung und Rückfalloption vor.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
ITIL V3, 2011	Service Transition, 4.1 Transition Planning and Support	
Managementpraktik	Beispielmetrik	
BAI07.03 Planen von Abnahmetests Erstellen Sie einen Testplan, der auf unternehmensweiten Standards für die Definition von Rollen, Zuständigkeiten und Testeinstiegs- und Testendekriterien basiert. Stellen Sie sicher, dass der Plan von den relevanten Parteien genehmigt wird.	a. Anteil der Anspruchsgruppen, die mit der Vollständigkeit des Testprozesses zufrieden sind b. Anzahl der dokumentierten Testpläne, die alle Testphasen und Testszenarien umfassen und den betrieblichen Anforderungen und der Umgebung entsprechen	

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Entwickeln und dokumentieren Sie einen Testplan, der am Qualitätsplan für Programme und Projekte und an den relevanten Standards der Organisation ausgerichtet ist. Kommunizieren Sie mit den jeweiligen Geschäftsprozessverantwortlichen und IT-Anspruchsgruppen und konsultieren Sie diese.		2
2. Stellen Sie sicher, dass im Testplan eine Einschätzung des projektbedingten Risikos abgebildet ist und alle funktionalen und technischen Anforderungen getestet wurden. Basierend auf der Bewertung des Risikos für einen Systemausfall oder das Auftreten von Fehlern bei der Implementierung, sollte der Plan geeignete Anforderungen für Leistungs-, Belastungs-, Eignungs-, Pilot- und Sicherheitstests sowie Datenschutz beinhalten.		
3. Stellen Sie sicher, dass im Testplan auf das potenzielle Erfordernis einer internen oder externen Akkreditierung der Testprozessergebnisse eingegangen wird (z. B. finanzielle oder behördliche Anforderungen).		
4. Stellen Sie sicher, dass im Testplan die für die Testausführung und Ergebnisbewertung benötigten Ressourcen angegeben sind. Zu den Ressourcen gehören beispielsweise die Einrichtung von Testumgebungen und die Arbeitszeit des Testpersonals, einschließlich dem potenziellen vorübergehenden Austausch von Testpersonal in der Produktions- oder Entwicklungs-umgebung. Stellen Sie sicher, dass die Anspruchsgruppen bezüglich der Ressourcenauswirkungen des Testplans konsultiert werden.		
5. Stellen Sie sicher, dass die im Testplan angegebenen Testphasen den betrieblichen und der betrieblichen Umgebung entsprechen. Beispiele für Tests sind: Modultest, Systemtest, Integrationstest, Benutzerabnahmetest, Leistungstest, Belastungstest, Datenkonvertierungstest, Sicherheitstest, Datenschutztest, Betriebsbereitschaftstest, Backup- und Wiederherstellungstest.		
6. Stellen Sie sicher, dass folgende Aspekte Bestandteil des Testplans sind: Testvorbereitung (einschließlich Standortvorbereitung), Schulungsanforderungen, Installation oder Aktualisierung einer definierten Testumgebung, Planen/Durchführen/Dokumentieren/Aufbewahren von Testfällen, Fehler- und Problembehandlung, Korrektur, Eskalation und formelle Freigabe.		
7. Stellen Sie sicher, dass alle Testpläne von den Anspruchsgruppen, einschließlich der Geschäftsprozessverantwortlichen und der IT, genehmigt werden. Die Anspruchsgruppen können Anwendungsentwicklungsmanager, Projektmanager und Endbenutzer von Geschäftsprozessen umfassen.		
8. Stellen Sie sicher, dass der Testplan klare Kriterien zur Messung des Erfolgs der einzelnen Testphasen festlegt. Konsultieren Sie die Geschäftsprozessverantwortlichen und IT-Anspruchsgruppen bei der Definition der Erfolgskriterien. Sorgen Sie dafür, dass der Plan Abhilfemaßnahmen vorsieht, wenn die Erfolgskriterien nicht erfüllt werden. Treten beispielsweise in einer Testphase schwerwiegende Fehler auf, sollte der Plan Anleitungen dahingehend enthalten, ob zur nächsten Testphase übergegangen, der Test gestoppt oder die Implementierung verschoben werden sollte.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI07.04 Einrichten einer Testumgebung Definieren und errichten Sie eine sichere Testumgebung, die für die geplante Umgebung repräsentativ ist hinsichtlich Geschäftsprozessen und IT-Betrieb in Bezug auf Leistung, Kapazität, Sicherheit, interne Kontrollen und operative Verfahren, Datenqualität, Datenschutzanforderungen und Arbeitslasten.		a. Grad der Vergleichbarkeit zwischen der Testumgebung und der zukünftigen Geschäfts- und Betriebsumgebung b. Umfang der bereinigten Testdaten (und/oder Datenbanken), die repräsentativ für die Produktionsumgebung sind
Aktivitäten		Fähigkeitsstufe
1. Erstellen Sie eine Datenbank mit Testdaten, die repräsentativ für die Produktionsumgebung sind. Bereinigen Sie die in der Testumgebung verwendeten Daten der Produktionsumgebung nach Maßgabe der geschäftlichen Erfordernisse und Standards der Organisation. Überprüfen Sie zum Beispiel, ob Compliance- oder behördliche Anforderungen die Verwendung bereinigter Daten vorschreiben.		2

A. Komponente: Prozess (Forts.)		
2. Schützen Sie sensible Testdaten und Testergebnisse vor Offenlegung, Zugriff, Speicherung, Aufbewahrung und Vernichtung. Berücksichtigen Sie die Auswirkungen der Interaktion von Systemen der Organisation mit den Systemen Dritter.		3
3. Richten Sie einen Prozess ein, der eine sachgemäße Aufbewahrung oder Vernichtung der Testergebnisse, Medien und sonstigen Dokumentationen ermöglicht und der eine adäquate Überprüfung und anschließende Analyse oder effiziente Wiederholung gemäß den Anforderungen des Testplans sicherstellt. Ziehen Sie die Notwendigkeit behördlicher Anforderungen oder von Compliance-Anforderungen in Erwägung.		
4. Stellen Sie sicher, dass die Testumgebung die zukünftige geschäftliche und betriebliche Landschaft repräsentativ abbildet. Dazu gehören auch Geschäftsprozessverfahren und Rollen, die voraussichtliche Auslastung, Betriebssysteme, benötigte Anwendungssoftware, Datenbankmanagementsysteme sowie die in der Produktionsumgebung vorhandene Netzwerk- und Computerinfrastruktur.		
5. Stellen Sie sicher, dass die Testumgebung sicher und eine Interaktion mit den Produktionssystemen ausgeschlossen ist.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI07.05 Durchführen von Abnahmetests Testen Sie Änderungen vor der Migration in die operative Live-Umgebung unabhängig voneinander gemäß den im Testplan definierten Bestimmungen.		a. Anzahl der identifizierten Lücken zwischen den Ergebnissen des Abnahmetests und den definierten Erfolgskriterien b. Anzahl erfolgreicher Abnahmetests
Aktivitäten		Fähigkeitsstufe
1. Überprüfen Sie das in Kategorien unterteilte Protokoll der im Testprozess vom Entwicklungsteam festgestellten Fehler. Stellen Sie sicher, dass alle Fehler behoben oder formell abgenommen wurden.		2
2. Bewerten Sie die Endabnahme anhand der Erfolgskriterien und interpretieren Sie die Ergebnisse der Endabnahmetests. Präsentieren Sie sie in einer Form, die für die Geschäftsprozessverantwortlichen und die IT-Abteilung verständlich ist, sodass eine sachkundige Überprüfung und Bewertung erfolgen kann.		3
3. Bestätigen Sie die Abnahme vor der Produktivsetzung in Form einer formellen Freigabe durch die Geschäftsprozessverantwortlichen, dritte Beteiligte (falls zutreffend) und IT-Anspruchsgruppen.		
4. Stellen Sie sicher, dass das Testen von Änderungen in Übereinstimmung mit dem Testplan durchgeführt wird. Sorgen Sie dafür, dass die Tests von Testpersonal konzipiert und durchgeführt werden, das vom Entwicklungsteam unabhängig ist. Überlegen Sie, inwieweit Geschäftsprozessverantwortliche und Endbenutzer in die Testgruppe involviert sind. Stellen Sie sicher, dass Tests nur innerhalb der Testumgebung durchgeführt werden.		
5. Stellen Sie sicher, dass die Tests und die erwarteten Ergebnisse den im Testplan definierten Erfolgskriterien entsprechen.		
6. Erwägen Sie die Verwendung klar definierter Testanweisungen (Skripts) für die Implementierung der Tests. Stellen Sie sicher, dass die unabhängige Testgruppe die einzelnen Testskripts beurteilt und genehmigt und damit bestätigt, dass das Skript die im Testplan festgelegten Erfolgskriterien adäquat abbildet. Ziehen Sie die Verwendung von Skripts in Erwägung, um zu prüfen, inwieweit das System die Sicherheits- und Datenschutzanforderungen erfüllt.		
7. Sorgen Sie für ein ausgewogenes Verhältnis zwischen automatisierten skriptbasierten Tests und interaktiven Benutzertests.		
8. Führen Sie Sicherheitstests nach Maßgabe des Testplans durch. Messen Sie das Ausmaß von Sicherheitsschwächen oder Lücken. Berücksichtigen Sie die Auswirkungen von Sicherheitsvorfällen seit der Erstellung des Testplans. Untersuchen Sie die Auswirkungen auf Zugangs- und Begrenzungskontrollen und berücksichtigen Sie Datenschutzanforderungen.		
9. Testen Sie System- und Anwendungsleistung gemäß den Bestimmungen des Testplans. Beziehen Sie verschiedene Leistungsmetriken ein (z. B. Endbenutzer-Reaktionszeit und Update-Performance des Datenbankmanagementsystems).		
10. Stellen Sie bei der Durchführung von Tests sicher, dass die Fallback- und Rollback-Elemente des Testplans berücksichtigt wurden.		
11. Identifizieren, protokollieren und klassifizieren Sie (z. B. in geringfügige, schwerwiegende und geschäftskritische) Fehler, die beim Testen festgestellt werden. Stellen Sie sicher, dass ein Prüfpfad der Testergebnisse verfügbar ist. Teilen Sie die Testergebnisse gemäß den Bestimmungen des Testplans den Anspruchsgruppen mit, um die Fehlerbehebung und weitere Qualitätsverbesserungen zu unterstützen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011		Service Transition, 4.5 Service Validation and Testing

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
BAI07.06 Produktivsetzen und Managen von Releases Übergeben Sie die abgenommene Lösung an Geschäfts- und Betriebs-einheiten. Führen Sie die Lösung ggf. für einen bestimmten Zeitraum als Pilotimplementierung oder parallel zur alten Lösung aus und vergleichen Sie Verhalten und Ergebnisse. Sollten schwerwiegende Probleme auftreten, kehren Sie mithilfe des Fallback-/Back-Up-Plans zurück zur ursprünglichen Umgebung. Managen Sie Releases von Lösungskomponenten.		a. Anzahl und Anteil der Releases, die nicht termingerecht bereitge-stellt werden können b. Grad der Zufriedenheit der Anspruchsgruppen mit der implemen-tierten Lösung
Aktivitäten		Fähigkeitsstufe
1. Bereiten Sie unter Berücksichtigung der Änderungsmanagementstandards der Organisation den Transfer von Geschäftsver-fahren und unterstützenden Services, Anwendungen und der Infrastruktur von der Testumgebung in die Produktionsumge-bung vor.		2
2. Bestimmen Sie in Einklang mit dem Implementierungsplan den Umfang der Pilotimplementierung bzw. Parallelausführung von altem und neuem System.		
3. Aktualisieren Sie ggf. umgehend die relevante Geschäftsprozess- und Systemdokumentation, die Konfigurationsinformati-onen und den Notfallplan.		
4. Stellen Sie sicher, dass alle Medienbibliotheken umgehend mit der Version der Lösungskomponente, die von der Test- in die Produktionsumgebung überführt wird, aktualisiert werden. Archivieren Sie die vorhandene Version und die zugehörige Dokumentation. Stellen Sie sicher, dass die Produktivsetzung von Systemen, Anwendungssoftware und Infrastruktur der Konfigurationskontrolle unterliegt.		
5. Soweit die Verteilung der Lösungskomponenten elektronisch erfolgt, kontrollieren Sie die automatisierte Verteilung, um sicherzustellen, dass die Benutzer benachrichtigt werden und die Verteilung nur an autorisierte und korrekt identifizierte Ziele erfolgt. Sehen Sie im Release-Prozess Backup-Verfahren vor, um bei Auftreten von Fehlfunktionen oder Fehlern die Verteilung der Änderungen überprüfen zu können.		
6. Führen Sie bei physischer Verteilung ein formelles Protokoll, aus dem hervorgeht, welche Elemente an wen verteilt wurden, wo sie implementiert wurden und wann die einzelnen Elemente aktualisiert wurden.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)		9.3 Release and deployment management
ITIL V3, 2011		Service Transition, 4.4 Release and Deployment Management
Managementpraktik		Beispielmetrik
BAI07.07 Bereitstellen eines frühzeitigen Produktiv-Supports Stellen Sie frühzeitig für einen vereinbarten Zeitraum Support-Leis-tungen für die Benutzer und den IT-Betrieb bereit, um Probleme zu beheben und die neue Lösung zu stabilisieren.		a. Anzahl der zusätzlichen I&T-Systemressourcen, die zur Unterstüt-zung bereitgestellt wurden b. Anzahl der zusätzlichen Mitarbeiter, die zur Unterstützung bereitge-stellt wurden
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie ggf. zusätzliche Ressourcen für Endbenutzer und Support-Mitarbeiter bereit, bis das Release eine ausreichende Stabilität erreicht hat.		3
2. Stellen Sie ggf. zusätzliche I&T-Systemressourcen bereit, bis das Release in einer stabilen Betriebsumgebung läuft.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
BAI07.08 Durchführen einer Nachbetrachtung nach erfolgter Implementierung Führen Sie im Anschluss an die Implementierung eine Nachbetrachtung durch, um Ergebnisse zu überprüfen, gewonnene Erkenntnisse zu identifizieren und einen Aktionsplan zu entwickeln. Bewerten Sie die tatsächliche Leistung und die tatsächlichen Ergebnisse des neuen oder geänderten Service und vergleichen Sie diese mit der erwarteten Leistung und den erwarteten Ergebnissen von Seiten der Benutzer oder Kunden.		a. Anzahl und Anteil der durchgeführten Ursachenanalysen b. Anzahl und Anteil der Releases, die nicht termingerecht für den Einsatz bereitgestellt wurden c. Anteil der Releases, die Ausfallzeiten verursachen
Aktivitäten		Fähigkeitsstufe
1. Etablieren Sie Verfahren, mit denen sichergestellt wird, dass bei den Überprüfungen nach der Implementierung folgende Ereignisse identifiziert, bewertet und gemeldet werden: Die Anforderungen des Unternehmens wurden erfüllt; die erwarteten Vorteile wurden realisiert; das System wird als nutzbar angesehen; die Erwartungen interner und externer Anspruchsgruppen werden erfüllt; es haben sich unerwartete Auswirkungen für das Unternehmen ergeben; das Hauptrisiko wurde gemindert; die Prozesse für das Änderungsmanagement, Installation und Akkreditierung wurden effektiv und effizient durchgeführt.		3
2. Konsultieren Sie Geschäftsprozessverantwortliche und das technische IT-Management, um geeignete Metriken für die Messung des Erfolgs und des Erfüllungs- bzw. Realisierungsumfangs von Anforderungen und Vorteilen auszuwählen.		4
3. Führen Sie die Überprüfung nach der Implementierung in Übereinstimmung mit dem Änderungsmanagementprozess der Organisation durch. Beteiligen Sie ggf. Geschäftsprozessverantwortliche und weitere betroffene Dritte.		
4. Berücksichtigen Sie Anforderungen, die sich außerhalb des Geschäfts- oder IT-Bereichs für die Überprüfung nach der Implementierung ergeben (z. B. Interne Revision, ERM, Compliance).		
5. Vereinbaren und implementieren Sie einen Aktionsplan, um die während der Überprüfung im Anschluss an die Implementierung identifizierten Probleme zu beheben. Beziehen Sie Geschäftsprozessverantwortliche und das technische IT-Management bei der Ausarbeitung des Aktionsplans ein.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011		Service Transition, 4.6 Change Evaluation

B. Komponente: Organisationsstrukturen									
Wichtige Managementpraktik:									
	Chief Information Officer	Geschäftsprozessverantwortlicher	Datenmanagement	Leiter Entwicklung	Leiter IT-Betrieb	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter
BAI07.01 Erstellen eines Implementierungsplans	A	R		R		R	R	R	
BAI07.02 Planen der Geschäftsprozess-, System- und Datenkonvertierung	A	R	R	R		R	R	R	
BAI07.03 Planen von Abnahmetests	A	R		R	R		R	R	R
BAI07.04 Einrichten einer Testumgebung	A	R		R	R		R	R	
BAI07.05 Durchführen von Abnahmetests	A	R		R	R		R	R	R
BAI07.06 Produktivsetzen und Managen von Releases	A	R		R	R	R		R	
BAI07.07 Bereitstellen eines frühzeitigen Produktiv-Supports	A	R		R	R	R			
BAI07.08 Durchführen einer Nachbetrachtung nach erfolgter Implementierung	A	R		R	R	R			

Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine entsprechenden weiteren Quellen für diese Komponente	

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
BAI07.01 Erstellen eines Implementierungsplans	Von	Beschreibung	Beschreibung	Für
	BAI01.07	- Plan zum Qualitätsmanagement - Fallback- und Wiederherstellungsprozesse bei der Implementierung		Intern
	BAI06.01	- Genehmigte Änderungsanträge - Änderungs- und Zeitplan	Genehmigter Implementierungsplan	Intern
	BAI11.05	Projekt-Qualitätsmanagementplan		
BAI07.02 Planen der Geschäftsprozess-, System- und Datenkonvertierung			Migrationsplan	DSS06.02
C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
BAI07.03 Planen von Abnahmetests	BAI01.07	Anforderungen an die unabhängige Verifizierung von Ergebnissen	Genehmigter Abnahmetestplan	BAI01.04, BAI11.04
	BAI03.07	- Testplan - Testverfahren		
	BAI03.08	- Testergebnisprotokolle und Prüfpfade - Kommunikation der Testergebnisse		
	BAI11.05	Anforderungen an die unabhängige Verifizierung von Projektergebnissen		
Managementpraktik	Inputs		Outputs	
BAI07.04 Einrichten einer Testumgebung	Von	Beschreibung	Beschreibung	Für
			Testdaten	Intern
BAI07.05 Durchführen von Abnahmetests			Genehmigte Abnahme und Freigabe zur Produktivsetzung	BAI01.04
			Bewertung der Abnahmeergebnisse	BAI01.06
			Aufzeichnung der Testergebnisse	Intern
BAI07.06 Produktivsetzen und Managen von Releases			Releaseplan	BAI10.01
			Releaseprotokoll	Intern

BAI07.07 Bereitstellen eines frühzeitigen Produktiv-Supports	APO11.02	Ergebnisse zur Servicequalität, einschließlich Kundenfeedback	Plan für zusätzlichen Support	APO08.04, APO08.05, DSS02.04
	BAI05.05	Erfolgskennzahlen und Ergebnisse		
BAI07.08 Durchführen einer Nachbetrachtung nach erfolgter Implementierung	APO11.03	• Ergebnisse der Überwachung der Lösungs- und Servicequalität • Grundursachen für Qualitätsmängel bei der Bereitstellung	Plan für Abhilfemaßnahmen	BAI01.09, BAI11.09
	APO11.04	Ergebnisse von Qualitätsprüfungen und Audits	Überprüfungsbericht nach der Implementierung	BAI01.09, BAI11.09
	BAI05.05	Erfolgskennzahlen und Ergebnisse		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Prüfung von Geschäftsprozessen	Skills Framework for the Information Age V6, 2015	BPTS
Freigabe und Bereitstellung	Skills Framework for the Information Age V6, 2015	RELM
Service-Akzeptanz	Skills Framework for the Information Age V6, 2015	SEAC
Test	Skills Framework for the Information Age V6, 2015	TEST
Bewertung der Benutzererfahrung	Skills Framework for the Information Age V6, 2015	USEV

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum IT-Änderungsmanagement	Kommuniziert die Absicht des Managements, dass alle Änderungen an der Unternehmens-IT so gemanagt und umgesetzt werden, dass Risiken und Auswirkungen für die Anspruchsgruppen minimiert werden. Deckt bereichsinterne Betriebsmittel und den Standard-Änderungsmanagementprozess ab.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur, die eine rechtzeitige Kommunikation von IT-Änderungsanträgen an betroffene Gruppen sicherstellt. Konsultieren Sie die betroffenen Gruppen bezüglich der Implementierung und des Testens von Änderungen.		

G. Komponente: Services, Infrastruktur und Anwendungen

• IT-Änderungsmanagement-Werkzeuge • Releasemanagement-Werkzeuge • Werkzeuge und Services für Tests

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI08 – Wissen ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Aufrechterhaltung der Verfügbarkeit von relevantem, aktuellem, validiertem und zuverlässigem Wissen und Managementinformationen zur Unterstützung aller Prozessaktivitäten und zur Erleichterung der Entscheidungsfindung im Zusammenhang mit der Governance und dem Management der unternehmensweiten I&T. Planung der Identifikation, Sammlung, Organisation, Aufrechterhaltung, Nutzung und Inaktivsetzung von Wissen.		
Zweck		
Bereitstellung von Wissen und Informationen, die zur Unterstützung aller Mitarbeiter bei Governance und Management der unternehmensweiten I&T erforderlich sind und Ermöglichung einer fundierten Entscheidungsfindung.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG10 Fähigkeiten, Motivation und Produktivität der Mitarbeiter • EG13 Produkt- und Geschäftsinnovation		• AG12 Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft • AG13 Wissen, Know-how und Initiativen für geschäftliche Innovationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG12 a. Anteil von I&T-erfahrenen Fachbereichsmitarbeitern (d. h. Personen, die über das erforderliche I&T-Wissen und -Verständnis verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten in ihrem Fachgebiet zu erkennen) b. Anteil der fachlich erfahrenen I&T-Mitarbeiter (d. h. Personen, die über das erforderliche Wissen und Verständnis der relevanten Geschäftsbereiche verfügen, um I&T-Themen zu lenken, vorzugeben, zu innovieren und I&T-Möglichkeiten für den Geschäftsbereich zu erkennen) c. Anzahl oder Anteil der Mitarbeiter mit Erfahrung im Technologiemanagement
EG10 a. Mitarbeiterproduktivität im Vergleich zu Benchmarks b. Grad der Zufriedenheit der Anspruchsgruppen mit den Fachkenntnissen und den Fähigkeiten der Mitarbeiter b. Anteil der Mitarbeiter, deren Fähigkeiten nicht ausreichen, um deren Rolle kompetent wahrzunehmen d. Anteil zufriedener Mitarbeiter		AG13 a. Grad des Bewusstseins von Führungskräften und des Verständnisses für Innovationsmöglichkeiten im Bereich I&T b. Anzahl der genehmigten Initiativen, die aus innovativen I&T-Ideen resultieren c. Anzahl der anerkannten/ausgezeichneten Innovations-Champions
EG13 a. Grad des Bewusstseins und Verständnisses für geschäftliche Innovationsmöglichkeiten b. Zufriedenheit der Anspruchsgruppen mit dem Grad der Produkt- und Innovationskompetenz und der Entwicklung von neuen Ideen c. Anzahl der genehmigten Produkt- und Serviceinitiativen, die aus innovativen Ideen resultieren		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
BAI08.01 Identifizieren und Klassifizieren von Informationsquellen für die Governance und das Management der I&T Identifizieren, validieren und klassifizieren Sie unterschiedliche interne und externe Informationsquellen, die für Governance und Management der I&T erforderlich sind, einschließlich Strategiedokumente, Störungsberichte und Konfigurationsinformationen, die vom Zeitpunkt der Entwicklung bis zum Betrieb vor der Produktivsetzung reichen.		a. Anteil der validierten Kategorisierungsinformationen b. Anteil der angemessenen Inhaltstypen, Werke sowie strukturierten und unstrukturierten Informationen
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie potenzielle Nutzer von Informationen, darunter auch Informationsinhaber, die möglicherweise Wissen beitragen und genehmigen müssen. Fragen Sie bei den identifizierten Nutzern die Wissensanforderungen und Informationsquellen ab.		2
2. Berücksichtigen Sie Inhaltstypen (Verfahren, Prozesse, Strukturen, Konzepte, Richtlinien, Regeln, Fakten, Klassifizierungen), Werke (Dokumente, Aufzeichnungen, Video und Sprache) sowie strukturierte und unstrukturierte Informationen (Expertenwissen, soziale Medien, E-Mail, Sprachnachrichten, RSS-Feeds).		
3. Klassifizieren Sie Informationsquellen nach einem Inhaltsklassifizierungsschema (z. B. Informationsarchitekturmodell). Ordnen Sie die Informationsquellen dem Klassifikationsschema zu.		3
4. Erfassen, sortieren und validieren Sie Informationsquellen anhand von Informationsvalidierungskriterien (z. B. Verständlichkeit, Relevanz, Bedeutung, Integrität, Genauigkeit, Konsistenz, Vertraulichkeit, Aktualität und Zuverlässigkeit).		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
BAI08.02 Strukturieren und Kontextualisieren von Informationen, um daraus Wissen abzuleiten Strukturieren Sie Informationen anhand von Klassifizierungskriterien. Identifizieren und erstellen Sie sinnvolle Beziehungen zwischen den Informationselementen und ermöglichen Sie die Nutzung von Informationen. Identifizieren Sie die Inhaber und nutzen und implementieren Sie auf Unternehmensebene definierte Informationsstufen für den Zugriff auf Managementinformationen und Wissensressourcen.		a. Anzahl der identifizierten Beziehungen zwischen den Informationsquellen (Tagging) b. Grad der Zufriedenheit der Anspruchsgruppen mit der Organisation und Kontextualisierung von Informationen um daraus Wissen abzuleiten
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie gemeinsame Attribute und gleichen Sie Informationsquellen ab, um Beziehungen zwischen einzelnen Informationssets herzustellen (Information Tagging).		3
2. Erstellen Sie unter Berücksichtigung der Anforderungen der Anspruchsgruppen und der Organisation Verweise auf miteinander verbundenen Datensets.		
3. Entwerfen und implementieren Sie ein Schema zum Managen von unstrukturiertem Wissen, das nicht über formelle Quellen verfügbar ist (z. B. Expertenwissen).		
4. Veröffentlichen Sie Wissen und sorgen Sie dafür, dass relevante Anspruchsgruppen darauf zugreifen können. Berücksichtigen Sie dabei Rollen und Zugangsmechanismen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
COSO Enterprise Risk Management, Juni 2017		10. Information, Communication, and Reporting – Principle 18
Managementpraktik		Beispielmetrik
BAI08.03 Nutzen und Weitergeben von Wissen Propagieren Sie verfügbare Wissensressourcen gegenüber relevanten Anspruchsgruppen und kommunizieren Sie, wie diese Ressourcen für verschiedene Zwecke genutzt werden können (z. B. Problemlösung, Lernen, strategische Planung und Entscheidungsfindung).		a. Anteil des tatsächlich genutzten verfügbaren Wissens b. Anteil der Nutzer, die mit dem zur Verfügung gestellten Wissen zufrieden sind

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Formulieren Sie die Managementexpectations und demonstrieren Sie eine angemessene Haltung hinsichtlich der Nützlichkeit von Wissen und der Notwendigkeit, Wissen im Zusammenhang mit Governance und Management von I&T im Unternehmen zu teilen.		2
2. Identifizieren Sie potenzielle Wissensnutzer auf Basis der Wissensklassifizierung.		
3. Transferieren Sie Wissen an Wissensnutzer und stützen Sie sich dabei auf GAP-Analysen und effektive Lerntechniken. Schaffen Sie eine Umgebung, Werkzeuge und Werke, die die gemeinsame Nutzung und den Transfer von Wissen unterstützen. Stellen Sie sicher, dass geeignete Zugangskontrollen entsprechend der definierten Wissensklassifikation eingerichtet sind.		3
4. Messen Sie die Nutzung von Werkzeugen und Elementen zur Wissensvermittlung und bewerten Sie die Auswirkungen auf Governance-Prozesse.		4
5. Verbessern Sie Informationen und Wissen zu Governance-Prozessen, für die Wissenslücken bestehen.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		PP.IS Apply Information Sharing; IR.ES Ensure Information sharing
ITIL V3, 2011		Service Transition, 4.7 Knowledge Management
PMBOK Guide Sixth Edition, 2017		Part 1: 4.4 Manage project knowledge
Managementpraktik		Beispielmetrik
BAI08.04 Bewerten und Aktualisieren oder Inaktivsetzen von Informationen Messen Sie die Nutzung und bewerten Sie die Aktualität und Relevanz von Informationen. Aktualisieren Sie oder ziehen Sie veraltete Informationen aus dem Verkehr.		a. Häufigkeit der Aktualisierung b. Grad der Zufriedenheit der Nutzer
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Steuerungsprozesse für die Inaktivsetzung von Wissen und ziehen Sie das Wissen dementsprechend aus dem Verkehr.		3
2. Bewerten Sie die Nützlichkeit, Relevanz und den Wert von Wissensselementen. Aktualisieren Sie veraltete Informationen, die für die Organisation immer noch relevant und wertvoll sind. Identifizieren Sie zugehörige Informationen, die für den Wissensbedarf des Unternehmens nicht mehr relevant sind und ziehen Sie sie gemäß den Richtlinien aus dem Verkehr oder archivieren Sie sie.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

B. Komponente: Organisationsstrukturen

Wichtige Managementpraktik:

	Chief Information Officer	Chief Technology Officer	Chief Digital Officer	Geschäftsprozessverantwortlicher	Portfoliomanager	Programm-Manager	Projektmanager	Datenmanagement	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter	Rechtsbeistand
BAI08.01 Identifizieren und Klassifizieren von Informationsquellen für die Governance und das Management der I&T	A			R				R		R	R		R				
BAI08.02 Strukturieren und Kontextualisieren von Informationen, um daraus Wissen abzuleiten	A							R		R	R	R					
BAI08.03 Nutzen und Weitergeben von Wissen	A	R	R	R	R	R	R	R				R					R
BAI08.04 Bewerten und Aktualisieren oder Inaktivsetzen von Informationen	A			R		R	R	R	R	R	R	R	R	R	R	R	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen) Detaillierte Referenzen																	
Keine entsprechenden weiteren Quellen für diese Komponente																	

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
BAI08.01 Identifizieren und Klassifizieren von Informationsquellen für die Governance und das Management der I&T	Von	Beschreibung	Beschreibung	Für
	Außerhalb von COBIT	Wissensanforderungen und -quellen	Klassifikation von Informationsquellen	Intern
BAI08.02 Strukturieren und Kontextualisieren von Informationen, um daraus Wissen abzuleiten	BAI03.03	Dokumentierte Lösungskomponenten	Veröffentlichte Wissens-Repositories	APO07.03
	BAI05.07	Pläne zum Wissenstransfer		
BAI08.03 Nutzen und Weitergeben von Wissen	BAI03.03	Dokumentierte Lösungskomponenten	Weitergabe von Wissen und Schulungspläne	APO07.03
	BAI05.05	Betriebs- und Nutzungsplan	Nutzer-Wissensdatenbank	Intern
	BAI05.07	Pläne zum Wissenstransfer		
BAI08.04 Bewerten und Aktualisieren oder Inaktivsetzen von Informationen			Regeln für die Wissensinaktivsetzung	Intern
			Ergebnisse der Wissensnutzungsbewertung	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Informations- und Wissensmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	D. Enable – D.10. Information and Knowledge Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Nutzung von Governance-Wissen	Anleitung für die Schaffung und Nutzung von Wissensressourcen im Zusammenhang mit der I&T-Governance. I&T-Wissensbestände sollten zur Bezugnahme leicht zugänglich sein.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Verankern Sie eine Kultur des Wissensaustauschs im Unternehmen. Vermitteln Sie proaktiv den Wert von Wissen, um die Schaffung, Nutzung, Wiederverwendung und den Austausch von Wissen zu begünstigen. Fördern Sie die gemeinsame Nutzung und den Transfer von Wissen, indem Sie Motivationsfaktoren identifizieren und nutzen.		

G. Komponente: Services, Infrastruktur und Anwendungen	
• Plattformen zur Zusammenarbeit • Wissens-Repository	

Diese Seite wurde absichtlich freigelassen.

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI09 – Betriebsmittel sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Managen der I&T-Betriebsmittel über ihren gesamten Lebenszyklus, um sicherzustellen, dass ihre Nutzung einen Wertbeitrag zu optimalen Kosten liefert, sie betriebsfähig (zweckdienlich) bleiben und sie buchhalterisch erfasst und physisch geschützt werden. Sicherstellung, dass die für die Unterstützung der Servicefähigkeit entscheidenden Betriebsmittel zuverlässig und verfügbar sind. Managen der Softwarelizenzen, um sicherzustellen, dass die optimale Anzahl von Softwarelizenzen im Verhältnis zur erforderlichen geschäftlichen Nutzung erworben, beibehalten und eingesetzt wird und die installierte Software den Lizenzvereinbarungen entspricht.		
Zweck		
Inventarisierung aller I&T-Betriebsmittel und Optimierung des Wertbeitrages, der durch die Nutzung entsteht.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen • EG09 Optimierung der Geschäftsprozesskosten		• AG04 Qualität der durch IT erzeugten Finanzinformationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG04 a. Zufriedenheit der wichtigsten Anspruchsgruppen hinsichtlich des Grades an Transparenz, Verständnis und Genauigkeit der I&T-Finanzinformationen b. Anteil der I&T-Services mit definierten und genehmigten Betriebskosten und erwartetem Nutzen
EG07 a. Grad der Zufriedenheit der Geschäftsleitung und obersten Führungskräfte mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		
EG09 a. Verhältnis von Kosten zu erreichten Service Levels b. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Kosten der Geschäftstätigkeit		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
BAI09.01 Identifizieren und Erfassen der aktuellen Betriebsmittel Führen Sie aktuelle, genaue Aufzeichnungen zu allen I&T-Betriebsmitteln, die zur Erbringung von Services erforderlich sind und die sich im Besitz oder unter der Kontrolle der Organisation befinden und von denen ein zukünftiger Nutzen zu erwarten ist (einschließlich Ressourcen mit wirtschaftlichem Wert, wie Hardware oder Software). Stellen Sie deren Ausrichtung am Konfigurationsmanagement und am Finanzmanagement sicher.	a. Anteil der Betriebsmittel, die im Bestandsverzeichnis genau erfasst sind b. Anteil der Betriebsmittel, die für den definierten Zweck geeignet sind c. Anteil der inventarisierten und aktuell gehaltenen Betriebsmittel

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie alle im Besitz befindlichen Betriebsmittel in einem Betriebsmittelregister, in dem auch der aktuelle Status erfasst wird. Betriebsmittel werden in der Bilanz ausgewiesen. Sie werden angeschafft oder erstellt, um den Wert eines Unternehmens zu steigern oder den Betrieb des Unternehmens (z. B. Hardware und Software) zu unterstützen. Identifizieren Sie alle im Besitz befindlichen Betriebsmittel und sorgen Sie dafür, dass eine Übereinstimmung mit Änderungsmanagement- und Konfigurationsmanagementprozessen sowie den Aufzeichnungen der Finanzbuchhaltung gewährleistet ist.		2
2. Identifizieren Sie gesetzliche, behördliche und vertragliche Anforderungen, die beim Managen der Betriebsmittel berücksichtigt werden müssen.		
3. Überprüfen Sie die Zweckdienlichkeit der Betriebsmittel, d. h. ob sie sich in einem brauchbaren Zustand befinden.		
4. Stellen Sie sicher, dass alle Betriebsmittel buchhalterisch erfasst sind.		3
5. Überprüfen Sie das tatsächliche Vorhandensein aller im Besitz befindlichen Betriebsmittel durch regelmäßige physische und logische Bestandsprüfungen und Abgleiche. Dies umfasst auch die Nutzung von Software zur maschinellen Erfassung.		4
6. Bestimmen Sie regelmäßig, ob die einzelnen Betriebsmittel weiterhin Wert generieren. Wenn ja, schätzen Sie die erwartete Nutzungsdauer in Verbindung mit der Erzielung eines Wertbeitrags.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	RI.AD Asset Discovery & Identification	
ISF, The Standard of Good Practice for Information Security 2016	BA1.1 Business Application Register	
ISO/IEC 27002:2013/Cor.2:2015(E)	8.1 Responsibility for assets	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.13 Physical and environmental protection (PE-9)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 1: Inventory of Authorized and Unauthorized Devices; CSC 2: Inventory of Authorized and Unauthorized Software	
Managementpraktik		Beispielmetrik
BAI09.02 Managen kritischer Betriebsmittel Identifizieren Sie Betriebsmittel, die kritisch für die Bereitstellung der Servicebefähigung sind. Maximieren Sie ihre Zuverlässigkeit und Verfügbarkeit im Rahmen der Unterstützung von geschäftlichen Erfordernissen.		a. Anzahl kritischer Betriebsmittel b. Durchschnittliche Ausfallzeit pro kritischem Betriebsmittel c. Anzahl der identifizierten Trends von Störungen
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie Betriebsmittel, die für die Bereitstellung der Servicebefähigung kritisch sind, indem Sie Anforderungen in Servicedefinitionen, SLAs und innerhalb des Konfigurationsmanagementsystems referenzieren.		2
2. Überprüfen Sie regelmäßig das Ausfallrisiko der einzelnen kritischen Betriebsmittel, bzw. ob ein Austausch erforderlich ist.		
3. Kommunizieren Sie die erwarteten Auswirkungen von Wartungsmaßnahmen (z. B. Leistungseinschränkungen) gegenüber den betroffenen Kunden und Benutzern.		
4. Berücksichtigen Sie geplante Ausfallzeiten im Gesamtproduktionszeitplan. Planen Sie Wartungsmaßnahmen so, dass negative Auswirkungen auf Geschäftsprozesse auf ein Minimum reduziert werden.		3
5. Sorgen Sie für eine dauerhafte Stabilität kritischer Betriebsmittel, indem Sie regelmäßige, vorbeugende Wartungsmaßnahmen umsetzen. Überwachen Sie die Leistung und stellen Sie ggf. alternative und/oder zusätzliche Betriebsmittel bereit, um die Ausfallwahrscheinlichkeit zu minimieren.		
6. Erstellen Sie einen Plan für vorbeugende Wartungsmaßnahmen für die gesamte Hardware und berücksichtigen Sie darin Kosten-Nutzen-Analysen, Herstellerempfehlungen, Ausfallrisiko, qualifiziertes Personal sowie sonstige relevante Faktoren.		
7. Schließen Sie Wartungsverträge ab, die den Zugang Dritter zu den I&T-Einrichtungen der Organisation für Aktivitäten vor Ort und ausgelagerte Aktivitäten (z. B. Outsourcing) beinhalten. Schließen Sie formelle Serviceverträge ab, die alle erforderlichen Sicherheits- und Datenschutzbedingungen enthalten bzw. auf diese Bezug nehmen. Dazu gehören auch Zugangsbe-rechtigungsverfahren zur Gewährleistung der Compliance mit den Sicherheitsrichtlinien und -standards der Organisation.		
8. Stellen Sie sicher, dass Services mit Remote-Zugriff und Benutzerprofile (oder sonstige für Wartungs- und Diagnosezwecke eingesetzte Mittel) nur dann aktiv sind, wenn sie benötigt werden.		

A. Komponente: Prozess (Forts.)		
9. Überwachen Sie die Leistung kritischer Betriebsmittel, indem Sie Störungstrends untersuchen. Leiten Sie ggf. Reparatur- oder Austauschmaßnahmen ein.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018		ID.AM Asset Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.13 Physical and environmental protection (PE-20)
Managementpraktik		Beispielmetrik
BAI09.03 Managen des Betriebsmittel-Lebenszyklus Managen Sie Betriebsmittel von der Beschaffung bis zu ihrer Entsorgung. Stellen Sie eine möglichst effektive und effiziente Nutzung der Betriebsmittel sowie deren buchhalterische Erfassung und physischen Schutz sicher, bis diese sachgemäß entsorgt wurden.		a. Anteil der von der Beschaffung bis zur Entsorgung gemanagten Betriebsmittel b. Auslastungsgrad pro Betriebsmittel c. Anteil der nach dem Standard-Implementierungslebenszyklus eingesetzten Betriebsmittel
Aktivitäten		Fähigkeitsstufe
1. Beschaffen Sie Betriebsmittel stets auf der Grundlage genehmigter Anträge und in Einklang mit den Beschaffungsrichtlinien und -verfahren des Unternehmens.		2
2. Sorgen Sie für eine kontrollierte Beschaffung, Warenannahme, Überprüfung, Erprobung und Erfassung der Betriebsmittel. Dies umfasst ggf. auch die physische Etikettierung.		
3. Genehmigen Sie Zahlungen und führen Sie Lieferantenprozesse gemäß den vereinbarten Vertragsbestimmungen durch.		
4. Stellen Sie Betriebsmittel unter Berücksichtigung des Standard-Implementierungslebenszyklus bereit, einschließlich Änderungsmanagement und Abnahmetests.		3
5. Teilen Sie die Betriebsmittel, ggf. unter Übernahme der Verantwortung und gegen Freizeichnung, den jeweiligen Benutzern zu.		
6. Sorgen Sie wann immer es möglich ist für eine Neuzuteilung der Betriebsmittel, wenn diese aufgrund von geänderten Benutzerrollen, Redundanz innerhalb eines Service oder aufgrund der Einstellung eines Service nicht mehr benötigt werden.		
7. Planen, genehmigen und implementieren Sie Aktivitäten in Verbindung mit der Außerbetriebnahme von Betriebsmitteln und bewahren Sie geeignete Aufzeichnungen auf, um weiterhin bestehenden Geschäfts- und behördlichen Anforderungen zu genügen.		
8. Entsorgen Sie Betriebsmittel auf sichere Art und Weise. Berücksichtigen Sie dabei u. a. die dauerhafte Löschung aufgezeichneter Daten von Datenträgern und mögliche Umweltschäden.		4
9. Entsorgen Sie Betriebsmittel verantwortungsbewusst, wenn sie aufgrund der Stilllegung aller damit verbundenen Services, veralteter Technologie oder fehlender Nutzer im Hinblick auf das Unternehmensumfeld keinen sinnvollen Zweck mehr erfüllen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		DP.ML Manage Asset Lifecycle
ISF, The Standard of Good Practice for Information Security 2016		IM2.1 Document Management; PA1.1 Hardware Life Cycle Management
ITIL V3, 2011		Service Transition, 4.3 Service Asset and Configuration Management
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018		PR.MA Maintenance

Managementpraktik	Beispielmetrik
BAI09.04 Optimieren des Wertes von Betriebsmitteln Überprüfen Sie regelmäßig den gesamten Betriebsmittelbestand, um Möglichkeiten für eine am geschäftlichen Bedarf ausgerichtete Wertoptimierung zu identifizieren.	a. Benchmark-Kosten b. Anzahl der nicht genutzten Betriebsmittel
A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie regelmäßig den gesamten Betriebsmittelbestand, um festzustellen, ob er nach wie vor den geschäftlichen Anforderungen entspricht.	3
2. Beurteilen Sie Wartungskosten und Angemessenheit und identifizieren Sie kostengünstigere Optionen. Erwägen Sie, falls erforderlich, den Austausch von Betriebsmitteln durch neue Alternativen.	4
3. Überprüfen Sie Garantien, prüfen Sie das Preis/Leistungsverhältnis und ziehen Sie Austauschstrategien in Erwägung, um die kostengünstigsten Optionen zu bestimmen.	5
4. Ziehen Sie Kapazitäts- und Auslastungsstatistiken heran, um zu selten oder zu wenig genutzte oder redundante Betriebsmittel zu identifizieren, deren Entsorgung oder Austausch unter dem Aspekt der Kostenreduzierung sinnvoll sein könnte.	
5. Überprüfen Sie die allgemeinen Rahmenbedingungen, um Möglichkeiten für eine Standardisierung, die Beschaffung von einer einzelnen Quelle und sonstige Strategien zu identifizieren, die eine Senkung der Beschaffungs-, Support- und Wartungskosten bewirken könnte.	
6. Überprüfen Sie den allgemeinen Zustand, um Möglichkeiten für die Nutzung aufkommender Technologien oder alternativer Sourcing-Strategien zu identifizieren, die zu einer Kostenreduzierung oder zur Verbesserung des Kosten/Nutzen-Verhältnisses beitragen könnten.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
BAI09.05 Managen von Lizenzen Stellen Sie beim Managen der Softwarelizenzen sicher, dass stets eine optimale Anzahl von Lizenzen für die Unterstützung der Geschäftsanforderungen vorhanden ist. Stellen Sie sicher, dass die Anzahl der im Besitz befindlichen Lizenzen ausreichend ist, um die Anzahl an installierter und genutzter Software abzudecken.	a. Anteil der verwendeten Lizenzen im Vergleich zu erworbenen Lizenzen b. Anteil der Lizenzen, für die Zahlungen erfolgen, die aber die nicht genutzt werden c. Anteil der Produkte und Lizenzen, die zur Erzielung eines Mehrwertes aufgerüstet werden sollten
Aktivitäten	Fähigkeitsstufe
1. Führen Sie ein Register, in dem die erworbenen Softwarelizenzen und die zugehörigen Lizenzvereinbarungen enthalten sind.	2
2. Führen Sie regelmäßig eine Prüfung durch, bei der alle Instanzen von installierter und lizenzierter Software ermittelt werden.	3
3. Vergleichen Sie die Anzahl der installierten Software-Instanzen mit der Anzahl der erworbenen Lizenzen. Stellen Sie sicher, dass die Methode zur Messung der Lizenzeinhaltung mit den Anforderungen der Lizenz- und Vertragsbedingungen konform geht.	4
4. Ist die Anzahl der Instanzen geringer als die der erworbenen Lizenzen, entscheiden Sie, ob die überzähligen Lizenzen beibehalten oder gekündigt werden sollten. Berücksichtigen Sie dabei das Einsparpotenzial durch den Wegfall von Wartungs-, Schulungs- und sonstigen Kosten.	
5. Ist die Anzahl der Instanzen höher als die Anzahl der erworbenen Lizenzen, überlegen Sie zunächst, ob Instanzen, die nicht mehr erforderlich oder gerechtfertigt sind, deinstalliert werden können. Erwerben Sie die dann ggf. noch erforderlichen, zusätzlichen Lizenzen, um nicht gegen die Lizenzvereinbarungen zu verstoßen.	
6. Überprüfen Sie regelmäßig, ob durch die Aktualisierung von Produkten und der zugehörigen Lizenzen nicht ein höherer Wert generiert werden könnte.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen																			
Wichtige Managementpraktik:										Chief Information Officer									
										Chief Technology Officer									
										Chefarchitekt									
										Leiter Entwicklung									
										Leiter IT-Betrieb									
										Leiter IT-Administration									
										Service Manager									
Information Security Manager																			
Datenschutzbeauftragter																			
BAI09.01 Identifizieren und Erfassen der aktuellen Betriebsmittel											A				R	R			
BAI09.02 Managen kritischer Betriebsmittel											A	R	R	R	R	R		R	R
BAI09.03 Managen des Betriebsmittel-Lebenszyklus											A				R	R	R		
BAI09.04 Optimieren des Wertes von Betriebsmitteln										A	R	R	R	R	R	R			
BAI09.05 Managen von Lizenzen										A	R		R	R	R				
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)										Detaillierte Referenzen									
Keine entsprechenden weiteren Quellen für diese Komponente																			

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
BAI09.01 Identifizieren und Erfassen der aktuellen Betriebsmittel	BAI03.04	Aktualisierung des Betriebsmittelinventars	Ergebnisse der Zweckmäßigkeitsüberprüfungen	APO02.02
	BAI10.02	Konfigurations-Repository	Betriebsmittelregister	AP006.01, BAI10.03
			Ergebnisse der physischen Bestandsprüfungen	BAI10.03, BAI10.04, DSS05.03
BAI09.02 Managen kritischer Betriebsmittel			Mitteilungen über geplante Wartungsausfallzeiten	AP008.04
			Wartungsverträge	Intern
BAI09.03 Managen des Betriebsmittel-Lebenszyklus			Genehmigte Betriebsmittelabgänge	BAI10.03
			Aktualisiertes Betriebsmittelverzeichnis	BAI10.03
			Genehmigte Anträge zur Beschaffung von Betriebsmitteln	Intern
BAI09.04 Optimieren des Wertes von Betriebsmitteln			Möglichkeiten zur Senkung der Betriebsmittelkosten oder zur Wertsteigerung	AP002.02
			Ergebnisse der Prüfungen zur Kostenoptimierung	AP002.02

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)

BAI09.05 Managen von Lizenzen			Maßnahmenplan zur Anpassung der Lizenzanzahl und -zuteilung	AP002.05
			Register der Software-Lizenzen	BAI10.02
			Ergebnisse der Prüfungen installierter Lizenzen	MEA03.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Betriebsmittelmanagement	Skills Framework for the Information Age V6, 2015	ASMG
Installation/Stilllegung von Systemen	Skills Framework for the Information Age V6, 2015	HSIN

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Management von Betriebsmitteln	Enthält Richtlinien für das Lebenszyklusmanagement von Betriebsmitteln, Maßnahmen zum Schutz von Betriebsmitteln, Systemklassifizierung und -eigentum, Dateneigentum und Datenklassifizierung.		
Richtlinie zum geistigen Eigentum	Befasst sich mit den Risiken im Zusammenhang mit der Nutzung, dem Besitz, dem Verkauf und der Verteilung der Ergebnisse von I&T-bezogenen kreativen Aktivitäten der Mitarbeiter (z. B. Softwareentwicklung). Erfordert von Beginn der Arbeit an angemessene Dokumentation, einen angemessenen Detaillierungsgrad usw.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur, die den relativen wirtschaftlichen und strategischen Wert jedes Betriebsmittels für das Unternehmen in einer offenen, nachvollziehbaren und transparenten Weise ermittelt, bewertet und darüber Bericht erstattet.		

G. Komponente: Services, Infrastruktur und Anwendungen

Werkzeuge zum Management von Betriebsmitteln
--

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI10 – Konfiguration ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Definition und Pflege der Beschreibungen und Beziehungen zwischen den wichtigsten Ressourcen und Fähigkeiten, die für die Bereitstellung von I&T-gestützten Services erforderlich sind. Dazu gehören das Sammeln von Konfigurationsinformationen, das Festlegen von Referenzwerten, die Verifikation und Überwachung von Konfigurationsinformationen und das Aktualisieren des Konfigurations-Repositories.		
Zweck		
Bereitstellung ausreichender Hintergrundinformationen zu Services, um ein effektives Managen des jeweiligen Services zu ermöglichen. Beurteilung der Auswirkungen von Änderungen und Abwicklung von Servicestörungen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG02 Gesteuertes Geschäftsrisiko • EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services		• AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobewertung abgedeckt werden b. Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten führen
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursachen b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services		

A. Komponente: Prozess		
Managementpraktik	Beispielmetriken	
BAI10.01 Erstellen und Pflegen eines Konfigurationsmodells Erstellen und pflegen Sie ein logisches Modell der Services, Betriebsmittel und der Infrastruktur und legen Sie fest, wie Konfigurationselemente (CIs: Configuration Items) und deren Beziehungen untereinander erfasst werden sollen. Nehmen Sie die CIs auf, die für ein effektives Managen von Services und die Bereitstellung einer einzigen, zuverlässigen Beschreibung der Betriebsmittel eines Service für erforderlich erachtet werden.	a. Anzahl der Anspruchsgruppen, die das Konfigurationsmodell freigeben haben b. Grad der Genauigkeit der Beziehungen von Konfigurationsobjekten	
Aktivitäten	Fähigkeitsstufe	
1. Definieren und vereinbaren Sie den Umfang und den Detaillierungsgrad des Modells für das Konfigurationsmanagement, (d. h., welche Konfigurationselemente für Services, Betriebsmittel und Infrastruktur enthalten sein sollen).	3	
2. Erstellen und pflegen Sie ein logisches Modell für das Konfigurationsmanagement, aus dem Informationen zu den CI-Typen, Attributen, Beziehungstypen, Beziehungsattributen und Statuscodes hervorgehen.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Supporting Processes – Configuration Management
ISF, The Standard of Good Practice for Information Security 2016		SY1 System Configuration
ISO/IEC 20000-1:2011(E)		9.1 Configuration management
ITIL V3, 2011		Service Transition, 4.3 Service Asset and Configuration Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.5 Configuration management (CM-6)
Managementpraktik		Beispielmetrik
BAI10.02 Erstellen und Pflegen eines Konfigurations-Repositories und einer Referenzkonfiguration Erstellen und pflegen Sie ein Konfigurationsmanagement-Repository, und legen Sie kontrollierte Referenzkonfigurationen an.		a. Anzahl der im Repository aufgelisteten Konfigurationselemente (CIs) b. Grad der Genauigkeit der Referenzkonfigurationen für einen Service, eine Anwendung oder eine Infrastruktur
Aktivitäten		Fähigkeitsstufe
1. Identifizieren und klassifizieren Sie Konfigurationselemente und befüllen Sie das Repository.		2
2. Erstellen, überprüfen und vereinbaren Sie formell Referenzkonfigurationen für einen Service, eine Anwendung oder eine Infrastruktur.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		IP.CB Apply Configuration Baselines
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.4 Implementation (Task 2)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.19 System and service acquisition (SA-10)
Managementpraktik		Beispielmetrik
BAI10.03 Pflegen und Kontrollieren von Konfigurationselementen Führen Sie ein aktuelles Repository mit Konfigurationselementen (CIs), in das Änderungen regelmäßig eingetragen werden.		a. Häufigkeit von Änderungen/Aktualisierungen des Repositories b. Grad der Genauigkeit und Vollständigkeit des Konfigurationselement-Repositories
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie regelmäßig sämtliche Änderungen, die an Konfigurationselementen vorgenommen wurden.		2
2. Vergleichen Sie vorgeschlagene Änderungen für Konfigurationselemente mit der Referenz, um die Vollständigkeit und Genauigkeit sicherzustellen.		
3. Aktualisieren Sie die Konfigurationsdetails für genehmigte Änderungen an Konfigurationselementen.		
4. Erstellen, überprüfen und vereinbaren Sie bei Bedarf formell Änderungen an der Referenzkonfiguration.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.5 Configuration management (CM-2)
Managementpraktik		Beispielmetrik
BAI10.04 Erstellen von Status- und Konfigurationsberichten Definieren und erstellen Sie Konfigurationsberichte zu Statusänderungen von Konfigurationselementen.		a. Anzahl der identifizierten nicht autorisierten Änderungen b. Grad der Genauigkeit von Statusänderungen von Konfigurationselementen gegenüber der Referenz
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie Statusänderungen von Konfigurationselementen und vergleichen Sie sie mit der Referenz.		2
2. Gleichen Sie alle Konfigurationsänderungen mit genehmigten Änderungsanträgen ab, um nicht genehmigte Änderungen zu identifizieren. Melden Sie nicht genehmigte Änderungen an das Änderungsmanagement.		3
3. Identifizieren Sie die Berichtsanforderungen aller Anspruchsgruppen und berücksichtigen Sie dabei Inhalt, Häufigkeit und Medien. Erstellen Sie Berichte entsprechend den ermittelten Anforderungen.		

A. Komponente: Prozess (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.5 Configuration management (CM-3)
Managementpraktik	Beispielmetrik
BAI10.05 Verifizieren und Überprüfen der Integrität des Konfigurations-Repositories. Überprüfen Sie das Konfigurations-Repository regelmäßig auf Vollständigkeit und Richtigkeit in Bezug auf das angestrebte Ziel.	a. Anzahl der Abweichungen zwischen dem Konfigurations-Repository und der Live-Konfiguration b. Anzahl der Diskrepanzen in Zusammenhang mit unvollständigen oder fehlenden Konfigurationsinformationen
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie regelmäßig die aktiven Konfigurationselemente anhand des Konfigurations-Repositories, indem Sie die physischen und logischen Konfigurationen vergleichen und ggf. geeignete Ermittlungswerkzeuge einsetzen.	4
2. Berichten Sie sämtliche Abweichungen und überprüfen Sie diese auf genehmigte Korrekturen oder Maßnahmen, um nicht genehmigte Betriebsmittel deaktivieren zu können.	
3. Überprüfen Sie regelmäßig, ob alle physischen Konfigurationselemente gemäß Definition im Repository auch tatsächlich vorhanden sind. Melden Sie Abweichungen dem Management.	
4. Legen Sie das Ziel für die Vollständigkeit fest, und überprüfen Sie es regelmäßig, damit das Konfigurations-Repository im Hinblick auf die jeweiligen Geschäftserfordernisse jederzeit vollständig ist.	
5. Gleichen Sie den Grad der Vollständigkeit und Genauigkeit regelmäßig mit dem Ziel ab und leiten Sie ggf. Abhilfemaßnahmen ein, um die Qualität der Daten im Repository zu verbessern.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.5 Configuration management (CM-4)

B. Komponente: Organisationsstrukturen									
Wichtige Managementpraktik:	Chief Information Officer	Chief Technology Officer	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	
	BAI10.01 Erstellen und Pflegen eines Konfigurationsmodells	A			R	R	R		
	BAI10.02 Erstellen und Pflegen eines Konfigurations-Repositories und einer Referenzkonfiguration	A		R	R	R	R	R	
	BAI10.03 Pflegen und Kontrollieren von Konfigurationselementen	A	R		R	R	R		
	BAI10.04 Erstellen von Status- und Konfigurationsberichten	A			R	R			
	BAI10.05 Verifizieren und Überprüfen der Integrität des Konfigurations-Repositories.	A	R	R	R		R		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen							
Keine entsprechenden weiteren Quellen für diese Komponente									

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
BAI10.01 Erstellen und Pflegen eines Konfigurationsmodells	Von	Beschreibung	Beschreibung	Für
	BAI07.06	Releaseplan	Logisches Konfigurationsmodell	Intern
			Umfang des Konfigurationsmanagementmodells	Intern
BAI10.02 Erstellen und Pflegen eines Konfigurations-Repositories und einer Referenzkonfiguration	BAI09.05	Register der Software-Lizenzen	Referenzkonfiguration	BAI03.11, BAI03.12
			Konfigurations-Repository	BAI09.01, DSS02.01
BAI10.03 Pflegen und Kontrollieren von Konfigurationselementen	BAI06.03	Statusberichte zu Änderungsanträgen	Genehmigte Änderungen gegenüber der Referenz	BAI03.11
	BAI09.01	• Betriebsmittelregister • Ergebnisse der physischen Bestandsprüfungen	Aktualisiertes CI-Repository	DSS02.01
	BAI09.03	• Aktualisiertes Betriebsmittelverzeichnis • Genehmigte Betriebsmittelabgänge		
BAI10.04 Erstellen von Status- und Konfigurationsberichten	BAI09.01	Ergebnisse der physischen Bestandsprüfungen	Statusberichte zur Konfiguration	BAI03.11, DSS02.01
BAI10.05 Verifizieren und Überprüfen der Integrität des Konfigurations-Repositories.			Ergebnisse der Überprüfung der Vollständigkeit des Repositories	Intern
			Ergebnisse der physischen Verifizierung von CIs	Intern
			Lizenzabweichungen	MEA03.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.4 Implementation (Task 2): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Konfigurationsmanagement	Skills Framework for the Information Age V6, 2015	CFMG

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Konfigurationsmanagement	Vermittelt Anleitungen zur Einrichtung und Nutzung eines umfassenden Konfigurations-Repositories, einschließlich aller Technologiekomponenten, der zugehörigen Konfigurationsdefinitionen und der Abhängigkeiten mit anderen Technologiekomponenten. Hilft sicherzustellen, dass System- und Software-Änderungen die Services möglichst wenig stören. Stellt sicher, dass Änderungen zwischen den beteiligten Gruppen koordiniert werden, damit es nicht zu Konflikten oder Doppelarbeit kommt.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine Kultur, die einen strukturierten, abteilungsübergreifenden Ansatz für das Konfigurationsmanagement unterstützt, bei dem die Benutzer den Wert eines strikten Konfigurationsmanagements (z. B. Vermeidung von Versionskonflikten oder Doppelarbeit) erkennen und die eingeführten Regeln und Verfahren anwenden.		

G. Komponente: Services, Infrastruktur und Anwendungen
Werkzeuge zum Konfigurationsmanagement und Repositories

Diese Seite wurde absichtlich freigelassen.

Domäne: Aufbauen, Beschaffen und Implementieren Managementziel: BAI11 – Projekte sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Managen aller Projekte, die innerhalb des Unternehmens eingeleitet werden, in Übereinstimmung mit der Unternehmensstrategie und in koordinierter Weise auf der Grundlage des Standard-Projektmanagementansatzes. Das umfasst das Initiieren, Planen, Kontrollieren und Ausführen von Projekten und die Durchführung einer Überprüfung im Anschluss an die Implementierung.		
Zweck		
Realisierung definierter Projektergebnisse und Minderung des Risikos von unerwarteten Verzögerungen, Kosten und Wertverlusten, indem die Kommunikation zu und die Einbindung von Geschäfts- und Endbenutzern verbessert wird. Sicherstellen des Wertes und der Qualität der Projektergebnisse und Maximierung ihres Beitrages zu den definierten Programmen und zum Investitionsportfolio.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG03 Realisierte Vorteile aus dem durch die I&T ermöglichten Investitions- und Serviceportfolio • AG06 Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen • AG09 Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG03 a. Anteil der durch die I&T ermöglichten Investitionen, für die die im Business Case geforderten Vorteile realisiert oder übertroffen wurden b. Anteil der I&T-Services, bei denen die erwarteten Vorteile (wie in den Service Level Agreements angegeben) realisiert wurden
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		AG06 a. Grad der Zufriedenheit von Führungskräften mit der Reaktionsfähigkeit der I&T auf neue Anforderungen b. Durchschnittliche Markteinführungszeit für neue I&T-bezogene Services und Anwendungen c. Durchschnittlicher Zeitbedarf für die Umsetzung strategischer I&T-Zielvorgaben in abgestimmte und genehmigte Initiativen d. Anzahl kritischer Geschäftsprozesse, die durch eine aktuelle Infrastruktur und Anwendungen unterstützt werden
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		AG09 a. Anzahl der im Zeit- und Budgetrahmen realisierten Programme/Projekte b. Anzahl der Programme, die aufgrund von Qualitätsmängeln erhebliche Nacharbeit erfordern c. Anteil der Anspruchsgruppen, die mit der Qualität des Programms/Projekts zufrieden sind

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
BAI11.01 Pflegen eines einheitlichen Ansatzes für das Projektmanagement Pflegen Sie einen einheitlichen Ansatz für das Projektmanagement, der eine Überprüfung von Governance und Management, Entscheidungsfindung und das Management der Bereitstellung ermöglicht. Diese Aktivitäten sollten konsequent auf den Geschäftswert und die Geschäftsziele (d. h. Anforderungen, Risiko, Kosten, Zeitplan und Qualitätsziele) ausgerichtet sein.		a. Anteil der erfolgreichen Projekte, die auf dem definierten Standardansatz basieren b. Anzahl der Aktualisierungen des Projektmanagement-Ansatzes, bewährter Praktiken, Werkzeuge und Vorlagen
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie einen einheitlichen Ansatz für das Projektmanagement bereit, der an der spezifischen Situation des Unternehmens ausgerichtet ist und auf bewährten Praktiken auf der Grundlage eines definierten Prozesses und des Einsatzes geeigneter Technologie basiert und setzen Sie diesen um. Stellen Sie sicher, dass der Ansatz den gesamten Lebenszyklus und die zu berücksichtigenden Disziplinen abdeckt, einschließlich des Managements von Umfang, Ressourcen, Risiko, Kosten, Qualität, Zeit, Kommunikation, Einbeziehung der Anspruchsgruppen, Beschaffung, Änderungskontrolle, Integration und Nutzenrealisierung.		2
2. Bieten Sie geeignete Projektmanagement-Schulungen an und erwägen Sie eine Zertifizierung der Projektmanager.		
3. Richten Sie ein Project Management Office (PMO) ein, das die Anwendung des einheitlichen Ansatzes für das Programm- und Projektmanagement in der gesamten Organisation sicherstellt. Das PMO unterstützt alle Projekte, indem es die erforderlichen Vorlagen für die Projektdokumentation erstellt und pflegt, Schulungen und bewährte Praktiken für Projektmanager bereitstellt, Kennzahlen zur Verwendung bewährter Praktiken für das Projektmanagement ermittelt usw. In einigen Fällen kann das PMO auch der Geschäftsleitung und/oder den Anspruchsgruppen über den Projektfortschritt berichten, bei der Priorisierung von Projekten helfen und sicherstellen, dass alle Projekte die allgemeinen Geschäftsziele des Unternehmens unterstützen.		3
4. Werten Sie die Erfahrungen aus, die im Rahmen der Anwendung des Projektmanagementansatzes gewonnen wurden. Aktualisieren Sie die bewährten Praktiken, Werkzeuge und Vorlagen entsprechend.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.15 Program management (PM-2)
Managementpraktik		Beispielmetrik
BAI11.02 Starten und Initiieren von Projekten Definieren und dokumentieren Sie Art und Umfang des Projekts, um ein gemeinsames Verständnis des Projektumfangs unter den Anspruchsgruppen zu erzielen. Die Definition sollte von den Projektspensoren formell genehmigt werden.		a. Anteil der Anspruchsgruppen, die den entsprechenden Bedarf des Unternehmens, den Umfang, das geplante Ergebnis und den Grad des Projektrisikos befürwortet b. Anteil der Projekte, bei denen die Anspruchsgruppen eine klare schriftliche Information erhalten haben, die Art, Umfang und Nutzen des Projekts definiert
Aktivitäten		Fähigkeitsstufe
1. Erstellen Sie für die Anspruchsgruppen zu jedem Projekt eine klare, schriftliche Darstellung, in der die Art, der Umfang und die Ergebnisse des Projekts definiert sind, um ein gemeinsames Verständnis des Projektumfangs zu gewährleisten.		2
2. Stellen Sie sicher, dass jedes Projekt über einen oder mehrere Sponsoren verfügt, die mit ausreichenden Befugnissen zur Ausführung des Projektes innerhalb des Gesamtprogramms ausgestattet sind.		
3. Stellen Sie sicher, dass sich wichtige Anspruchsgruppen und Sponsoren innerhalb des Unternehmens (Geschäft und IT) auf die Anforderungen an das Projekt verständigen und diese akzeptieren. Dies umfasst auch die Definition von Kriterien für den Projekterfolg (Abnahme) und wichtiger Leistungsindikatoren (KPIs).		
4. Benennen Sie einen Projektmanager. Stellen Sie sicher, dass der betreffende Mitarbeiter über das erforderliche Verständnis von Technologien und Geschäft sowie über die entsprechenden Kompetenzen und Fähigkeiten verfügt, um das Projekt effektiv und effizient leiten zu können.		
5. Stellen Sie sicher, dass in der Projektdefinition die Anforderungen für einen Projektkommunikationsplan beschrieben sind, in dem die interne und externe Projektkommunikation festgelegt ist.		
6. Aktualisieren Sie, mit der Zustimmung der Anspruchsgruppen, die Projektdefinition während der gesamten Projektdauer und bilden Sie geänderte Anforderungen darin ab.		
7. Implementieren Sie rechtzeitig und unter Einholung der erforderlichen Genehmigungen Mechanismen, wie z. B. regelmäßige Berichte oder Stage-Gate-, Release- oder Iterationsüberprüfungen, um die Umsetzung des Projektes nachzuverfolgen.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 4.1 Develop project charter; Part 1: 6. Project schedule management
Managementpraktik		Beispielmetrik
BAI11.03 Managen der Einbeziehung von Anspruchsgruppen Managen Sie die Einbeziehung von Anspruchsgruppen, um einen aktiven Austausch von genauen, konsistenten und aktuellen Informationen für alle relevanten Anspruchsgruppen zu gewährleisten. Dazu gehört die Planung, Identifizierung und Einbeziehung der Anspruchsgruppen und das Managen ihrer Erwartungen.		a. Grad der Zufriedenheit der Anspruchsgruppen mit der Einbeziehung b. Anteil der effektiv einbezogenen Anspruchsgruppen
Aktivitäten		Fähigkeitsstufe
1. Planen Sie, wie Anspruchsgruppen innerhalb und außerhalb des Unternehmens für die Dauer des gesamten Projektlebenszyklus identifiziert, analysiert, einbezogen und gemanagt werden sollen.		3
2. Sorgen Sie für die Identifizierung, Einbeziehung und das Management der Anspruchsgruppen, indem Sie ein geeignetes Maß an Koordination, Kommunikation und Kontaktpflege einrichten und aufrecht erhalten und damit die Einbindung der Anspruchsgruppen in das Projekt sicherstellen.		
3. Analysieren Sie die Interessen, Anforderungen und die Einbindung der Anspruchsgruppen. Leiten Sie ggf. Abhilfemaßnahmen ein.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 13. Project stakeholder management Part 1: 10. Project communications management
Managementpraktik		Beispielmetrik
BAI11.04 Entwickeln und Pflegen des Projektplans Erstellen und pflegen Sie einen formellen, genehmigten und integrierten Projektplan (der die Geschäfts- und IT-Ressourcen abdeckt), um die Projektausführung und -kontrolle während der gesamten Projektdauer zu steuern. Der Umfang der Projekte sollte klar definiert und an den Aufbau oder die Verbesserung der Unternehmensbefähigungen gebunden sein.		a. Anteil der aktiven Projekte, die ohne gültige und aktualisierte Planung des Programmwertbeitrags durchgeführt wurden b. Anteil der erreichten Meilensteine oder erledigten Aufgaben im Rahmen der Projektplanung
Aktivitäten		Fähigkeitsstufe
1. Entwickeln Sie einen Projektplan, der Informationen bereitstellt, die es dem Management ermöglichen, den Projektfortschritt nach und nach zu kontrollieren. Der Plan sollte Einzelheiten zu den Projektergebnissen und Abnahmekriterien enthalten, die erforderlichen internen und externen Ressourcen und Zuständigkeiten benennen sowie klare Arbeitsaufteilungsstrukturen und Arbeitspakete, Schätzungen zu den erforderlichen Ressourcen, Meilensteine/Releasepläne/Phasen und wichtige Abhängigkeiten, Budgets und Kosten enthalten sowie einen kritischen Pfad aufzeigen.		2
2. Pflegen Sie den Projektplan und alle davon abhängigen Pläne (z. B. Risikoplan, Qualitätsplan, Nutzenrealisierungsplan). Stellen Sie sicher, dass die Pläne aktuell sind und den tatsächlichen Fortschritt und die wichtigsten genehmigten Änderungen widerspiegeln.		
3. Stellen Sie sicher, dass die Kommunikation von Projektplänen und Fortschrittsberichten effektiv ist. Stellen Sie sicher, dass alle an einzelnen Plänen vorgenommenen Änderungen in den jeweils anderen Plänen berücksichtigt werden.		
4. Bestimmen Sie die Aktivitäten, Abhängigkeiten und erforderliche Zusammenarbeit und Kommunikation innerhalb des Projekts und zwischen mehreren Projekten eines Programms.		
5. Stellen Sie sicher, dass jeder Meilenstein mit einem wesentlichen Pflichtergebnis verbunden ist, für das eine Überprüfung und Freigabe erforderlich ist.		
6. Erstellen Sie eine Projektreferenz (z. B. Kosten, Zeitplan, Umfang, Qualität), die angemessen überprüft, genehmigt und in den integrierten Projektplan eingebettet wird.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 4.2 Develop project management plan

A. Komponente: Prozess (Forts.)			
Managementpraktik		Beispielmetrik	
BAI11.05 Managen der Projektqualität Erstellen Sie einen Qualitätsmanagementplan nebst Prozessen und Verfahren, der an den Qualitätsmanagementstandards (QMS) ausgerichtet ist und setzen Sie diesen um. Beschreiben Sie den Ansatz zur Sicherstellung der Projektqualität und -implementierung. Der Plan sollte von allen betroffenen Parteien formell überprüft, verabschiedet und in den integrierten Projektplan aufgenommen werden.		a. Anteil der fehlerfrei erzeugten Produkte b. Anzahl der abgebrochenen Projekte	
Aktivitäten			Fähigkeitsstufe
1. Identifizieren Sie Verantwortlichkeiten, Zuständigkeiten, Qualitätsüberprüfungsprozesse, Erfolgskriterien und Leistungsmetriken, um die Qualität der Projektergebnisse sicherzustellen.			2
2. Identifizieren Sie die Prüfaufgaben und -verfahren, die erforderlich sind, um die Akkreditierung neuer oder geänderter Systeme während der Projektplanung zu unterstützen. Nehmen Sie diese in die integrierten Pläne auf. Stellen Sie sicher, dass anhand dieser Aufgaben bestätigt werden kann, dass interne Kontrollen und Datenschutz-/Sicherheitslösungen die definierten Anforderungen erfüllen.			3
3. Definieren Sie im Plan die Anforderungen für eine unabhängige Validierung und Verifizierung der Qualität der Pflichtergebnisse.			
4. Führen Sie gemäß den Bestimmungen des Qualitätsmanagementplans und des QMS Qualitätssicherungs- und Kontrollaktivitäten durch.			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
PMBOK Guide Sixth Edition, 2017		Part 1: 8. Project quality management	
Managementpraktik		Beispielmetrik	
BAI11.06 Managen des Projektrisikos Eliminieren oder minimieren Sie das spezifische Risiko in Verbindung mit Projekten anhand eines systematischen Prozesses zur Planung, Identifizierung, Analyse, Behandlung, Überwachung und Kontrolle derjenigen Bereiche oder Ereignisse, die ein Potenzial für unerwünschte Änderungen bergen. Definieren und erfassen Sie alle Risiken, die im Rahmen des Projektmanagements auftreten.		a. Anzahl der identifizierten Verzögerungen und Probleme b. Anzahl der Projekte mit einem formellen Projekt-Risikomanagementansatz, der mit dem ERM-Rahmenwerk abgestimmt ist	
Aktivitäten			Fähigkeitsstufe
1. Richten Sie einem formellen Projekt-Risikomanagementansatz ein, der mit dem ERM-Rahmenwerk abgestimmt ist. Stellen Sie sicher, dass der Ansatz auch die Identifizierung, Analyse, Behandlung, Minderung, Überwachung und Kontrolle des Risikos umfasst.			2
2. Weisen Sie entsprechend qualifizierten Mitarbeitern die Verantwortung für die Umsetzung des unternehmensweiten Risikomanagementprozesses innerhalb eines Projektes zu und stellen Sie sicher, dass dies in die Praktiken der Lösungsentwicklung integriert wird. Ziehen Sie in Betracht, diese Rolle einem unabhängigen Team zuzuweisen, insbesondere wenn eine objektive Sichtweise erforderlich ist oder ein Projekt als kritisch einzustufen ist.			
3. Identifizieren Sie Verantwortliche für Maßnahmen, die auf die Vermeidung, Akzeptanz oder Minderung des Risikos ausgelegt sind.			
4. Führen Sie eine Risikobewertung durch, indem Sie das Risiko während des gesamten Projektes identifizieren und quantifizieren. Managen und kommunizieren Sie das Risiko angemessen innerhalb der Governance-Struktur des Projekts.			3
5. Führen Sie regelmäßig eine Neueinschätzung des Projektrisikos durch, u. a. bei Initiierung jeder wichtigen Projektphase sowie im Rahmen größerer Änderungsanforderungsbeurteilungen.			
6. Führen und überprüfen Sie ein Projektrisikoregister aller potenziellen Projektrisiken und ein Risikominderungsprotokoll aller im Projekt aufgetretenen Probleme und deren Lösung. Analysieren Sie das Protokoll regelmäßig in Bezug auf Trends und wiederkehrende Probleme, um sicherzustellen, dass die Grundursachen behoben werden.			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.15 Program management (PM-4)	
PMBOK Guide Sixth Edition, 2017		Part 1: 11. Project risk management	

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmetrik
BAI11.07 Überwachen und Steuern von Projekten Messen Sie die Projektleistung anhand wichtiger Projektleistungskriterien wie Zeitplan, Qualität, Kosten und Risiko. Identifizieren Sie alle Abweichungen von den erwarteten Zielvorgaben. Bewerten Sie die Auswirkungen von Abweichungen auf das Projekt und das gesamte Programm und berichten Sie die Ergebnisse an die wichtigsten Anspruchsgruppen.	a. Anteil der Aktivitäten, die auf den Umfang und die erwarteten Ergebnisse abgestimmt sind b. Anteil der bearbeiteten Planabweichungen c. Häufigkeit von Projektstatusüberprüfungen
Aktivitäten	Fähigkeitsstufe
1. Definieren Sie eine Reihe von Projektkriterien, wie z. B. Umfang, erwarteter geschäftlicher Nutzen, Zeitplan, Qualität, Kosten und Risikoniveau und wenden Sie diese an.	2
2. Informieren Sie wichtige Anspruchsgruppen über den Projektfortschritt, über Abweichungen von den eingerichteten zentralen Projektleistungskriterien (wie z. B. erwarteter Geschäftsnutzen) und über potenzielle positive und negative Auswirkungen auf das Projekt.	
3. Dokumentieren Sie alle notwendigen Änderungen und legen Sie sie den wichtigsten Anspruchsgruppen des Projekts vor der Umsetzung zur Genehmigung vor. Übermitteln Sie die überarbeiteten Kriterien an die Projektmanager, damit diese sie in künftigen Leistungsberichten verwenden können.	
4. Holen Sie für die in jeder Iterations-, Freigabe- oder Projektphase erstellten Ergebnisse die Zustimmung und Freigabe der benannten Manager und Anwender in den betroffenen Geschäfts- und IT-Funktionen ein.	
5. Stützen Sie den Genehmigungsprozess auf klar definierte Abnahmekriterien, die mit den Anspruchsgruppen vor dem Beginn der Arbeiten an einer Projektphase oder einer Iteration vereinbart wurden.	3
6. Bewerten Sie das Projekt an vereinbarten wichtigen Stage-Gates, Releases oder Iterationen. Treffen Sie formelle Go/No-Go-Entscheidungen auf der Grundlage vorgegebener wichtiger Erfolgskriterien.	
7. Richten Sie ein Änderungskontrollsystem für das Projekt ein und wenden Sie dieses an, sodass alle Änderungen, die gegenüber der Projektpreferenz (z. B. Umfang, erwarteter Geschäftsnutzen, Zeitplan, Qualität, Kosten, Risikoniveau) vorgenommen werden, in Übereinstimmung mit dem Governance-Rahmenwerk für Programme und Projekte überprüft, genehmigt und in den integrierten Projektplan eingebettet werden können.	
8. Messen Sie die Projektleistung anhand der wichtigsten Projektleistungskriterien. Analysieren Sie die Ursachen für Abweichungen von festgelegten wichtigen Projektleistungskriterien und beurteilen Sie die positiven und negativen Auswirkungen der Abweichungen auf das Projekt.	4
9. Überwachen Sie Änderungen innerhalb des Projekts und überprüfen Sie die vorhandenen wichtigen Projektleistungskriterien, um zu bestimmen, ob sie nach wie vor geeignet sind, den Fortschritt des Projekts zu messen.	
10. Empfehlen und überwachen Sie ggf. Abhilfemaßnahmen und berücksichtigen Sie dabei das Governance-Rahmenwerk für Projekte.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017	Part 1: 4.5 Monitor and control project work
Managementpraktik	Beispielmetrik
BAI11.08 Managen von Projektressourcen und Arbeitspaketen Managen Sie Projektarbeitspakete, indem formelle Anforderungen an die Genehmigung und Annahme von Arbeitspaketen gestellt und geeignete Geschäfts- und IT-Ressourcen zugewiesen und koordiniert werden.	a. Anzahl der Probleme bezüglich Ressourcen (z. B. Fähigkeiten, Kapazitäten) b. Anzahl der klar definierten Rollen, Verantwortlichkeiten und Vorrechte des Projektmanagers, der zugeteilten Mitarbeiter und anderer beteiligter Parteien

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie den Bedarf an Geschäfts- und IT-Ressourcen für das Projekt und ordnen Sie eindeutig Rollen und Zuständigkeiten zu. Vereinbaren Sie Eskalations- und Entscheidungsbefugnisse und stellen Sie sicher, dass diese verstanden werden.		2
2. Identifizieren Sie die erforderlichen Fähigkeiten und den Zeitbedarf für alle an den jeweiligen Projektphasen beteiligten Personen in Bezug auf die definierten Rollen. Besetzen Sie die Rollen auf der Grundlage der verfügbaren Informationen zu den Fähigkeiten (z. B. IT-Kompetenzmatrix).		
3. Setzen Sie erfahrene Projektmanager und Teamleiter ein, die über ausreichende Fähigkeiten verfügen, um mit der Größe, der Komplexität und dem Risiko des Projekts umgehen zu können.		
4. Berücksichtigen und definieren Sie klar die Rollen und Zuständigkeiten anderer involvierter Parteien, z. B. aus den Bereichen Finanzen, Recht, Beschaffung, HR, interne Prüfung und Compliance.		
5. Definieren Sie eindeutig und vereinbaren Sie die Zuständigkeit für die Beschaffung und Verwaltung externer Produkte und Services und managen Sie die Beziehungen mit den jeweiligen Anbietern.		
6. Identifizieren und autorisieren Sie die Umsetzung der Arbeiten gemäß den Festlegungen im Projektplan.		
7. Identifizieren Sie etwaige Lücken im Projektplan und geben Sie dem Projektmanager Rückmeldung, um geeignete Abhilfemaßnahmen zu ermöglichen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 4.3 Direct and manage project work
Managementpraktik		Beispielmessung
BAI11.09 Abschließen eines Projekts oder eines Abschnitts Fordern Sie am Ende jedes Projekts, Release oder jeder Iteration, die Projektbeteiligten auf, zu ermitteln, ob das Projekt, Release oder die Iteration die erforderlichen Ergebnisse in Bezug auf die Fähigkeiten geliefert und wie erwartet zum Programmnutzen beigetragen hat. Identifizieren und kommunizieren Sie alle ausstehenden Aktivitäten, die erforderlich sind, um die geplanten Ergebnisse des Projekts und/oder den Nutzen des Programms zu erzielen. Identifizieren und dokumentieren Sie die gewonnenen Erfahrungen für zukünftige Projekte, Releases, Iterationen und Programme.		a. Grad der Zufriedenheit der Anspruchsgruppen, der bei der Projektabschlussüberprüfung geäußert wurde b. Anteil der Ergebnisse mit unmittelbarer Abnahme
Aktivitäten		Fähigkeitsstufe
1. Lassen Sie die Projektergebnisse von den Anspruchsgruppen abnehmen und geben Sie die Verantwortung ab.		2
2. Definieren Sie wichtige Schritte für den Projektabschluss und führen Sie diese aus. Dazu gehören u. a. Überprüfungen nach der Implementierung, mit deren Hilfe beurteilt werden soll, inwieweit ein Projekt die gewünschten Ergebnisse geliefert hat.		3
3. Planen Sie die Überprüfungen nach der Implementierung, um festzustellen, inwieweit die Projekte die erwarteten Ergebnisse erbracht haben und führen Sie diese durch. Nutzen Sie die gewonnenen Erkenntnisse, um die Methodik des Projektmanagements und des Systementwicklungsprozesses zu verbessern.		
4. Ermitteln, bestimmen, kommunizieren und verfolgen Sie alle nicht abgeschlossenen Aktivitäten, die erforderlich sind, um sicherzustellen, dass das Projekt die erforderlichen Ergebnisse in Bezug auf die Fähigkeiten und die Ergebnisse, die erwartungsgemäß zum Nutzen für das entsprechende Programm beitragen, geliefert hat.		
5. Erfassen Sie fortlaufend und nach Abschluss des Projekts die von den Projektteilnehmern gesammelten Erfahrungen. Überprüfen Sie sie sowie die wesentlichen Aktivitäten, die Nutzenvorteile und Wert generiert haben. Analysieren Sie die Informationen und geben Sie Empfehlungen zur Verbesserung des aktuellen Projekts und der Projektmanagementmethodik für zukünftige Projekte ab.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
PMBOK Guide Sixth Edition, 2017		Part 1: 4.7 Close project or phase

B. Komponente: Organisationsstrukturen										
	Chief Executive Officer	Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Geschäftsprozessverantwortlicher	Lenkungsausschuss für Projekte und Programme	Programm-Manager	Projektmanager	Project Management Office	Leiter Entwicklung
Wichtige Managementpraktik:										
BAI11.01 Pflegen eines einheitlichen Ansatzes für das Projektmanagement	A		R				R	R		
BAI11.02 Starten und Initiieren von Projekten		R		R	R	A	R	R	R	
BAI11.03 Managen der Einbeziehung von Anspruchsgruppen			R			A	R			
BAI11.04 Entwickeln und Pflegen des Projektplans						A	R	R		
BAI11.05 Managen der Projektqualität		R	R			A	R			R
BAI11.06 Managen des Projektrisikos			R			A	R			R
BAI11.07 Überwachen und Steuern von Projekten					R	A	R	R	R	
BAI11.08 Managen von Projektressourcen und Arbeitspaketen					R	A	R		R	
BAI11.09 Abschließen eines Projekts oder eines Abschnitts						A	R	R		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen									
PMBOK Guide Sixth Edition, 2017	Part 1: 3. The role of the project manager									

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
BAI11.01 Pflegen eines einheitlichen Ansatzes für das Projektmanagement	APO03.04	- Anforderungen an die Architektur-Governance - Beschreibungen der Implementierungsphase	Aktualisierte Programm-Management-Ansätze	Intern
	APO10.04	Identifiziertes Lieferantenlieferisiko		
	EDM02.03	Anforderungen an Stage-Gate-Reviews		
	EDM02.04	Maßnahmen zur Verbesserung der Wertschöpfung		
BAI11.02 Starten und Initiieren von Projekten			Projektdefinitionen	Intern
			Information zum Projektumfang	Intern
BAI11.03 Managen der Einbeziehung von Anspruchsgruppen			Ergebnisse der Bewertungen der Effektivität der Einbindung der Anspruchsgruppen	Intern
			Plan zur Einbindung der Anspruchsgruppen	Intern
BAI11.04 Entwickeln und Pflegen des Projektplans	BAI07.03	Genehmigter Abnahmetestplan	Projektberichte und Mitteilungen	Intern
			Projektreferenz	Intern
			Projektpläne	Intern
BAI11.05 Managen der Projektqualität	APO11.01	Qualitätsmanagementpläne	Projekt-Qualitätsmanagementplan	BAI02.04, BAI03.06, BAI07.01
	APO11.02	Kundenanforderungen an das Qualitätsmanagement	Anforderungen an die unabhängige Verifizierung von Projektergebnissen	BAI07.03
BAI11.06 Managen des Projektrisikos	APO12.02	Ergebnisse der Risikoanalyse	Projektrisikoregister	Intern
	BAI02.03	- Risikoregisteranforderungen - Maßnahmen zur Risikominderung	Ergebnisse der Bewertung des Projektrisikos	Intern
	Außerhalb von COBIT	Rahmenwerk für das unternehmensweite Risikomanagement (ERM)	Projektrisikomanagementplan	Intern
BAI11.07 Überwachen und Steuern von Projekten			Vereinbarte Änderungen am Projekt	Intern
			Projektfortschrittsberichte	Intern
			Projektleistungskriterien	Intern

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
BAI11.08 Managen von Projektressourcen und Arbeitspaketen			Ressourcenanforderungen für Projekte	AP007.05, AP007.06
			Lücken in der Projektplanung	Intern
			Rollen und Zuständigkeiten für Projekte	Intern
Managementpraktik	Inputs		Outputs	
BAI11.09 Abschließen eines Projekts oder eines Abschnitts	Von	Beschreibung	Beschreibung	Für
	BAI07.08	- Überprüfungsbericht nach der Implementierung - Plan für Abhilfemaßnahmen	Überprüfungsergebnisse nach der Implementierung	AP002.04
			Bestätigungen der Projektabnahme der Anspruchsgruppen	Intern
			Gewonnene Erkenntnisse aus dem Projekt	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
PMBOK Guide Sixth Edition, 2017		Part 1: 4. Project integration management: Inputs and Outputs; Part 1: 6. Project schedule management: Inputs and Outputs; Part 1: 10. Project communications management: Inputs & Outputs; Part 1: 11. Project risk management: Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Portfolio-, Programm- und Projektunterstützung	Skills Framework for the Information Age V6, 2015	PROF
Projekt- und Portfoliomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.2. Project and Portfolio Management
Projektmanagement	Skills Framework for the Information Age V6, 2015	PRMG

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Programm-/Projektmanagementrichtlinie	Anleitung für das Risikomanagement im Zusammenhang mit Programmen und Projekten. Enthält detaillierte Angaben zur Position des Managements und zu den Erwartungen hinsichtlich des Programm- und Projektmanagements. Behandelt Verantwortlichkeit, Ziele und Zielvorgaben in Bezug auf Leistung, Budget, Risikoanalyse, Berichterstattung und Eindämmung von unerwünschten Ereignissen während der Programm-/Projektumsetzung.	PMBOK guide Sixth edition, 2017	Part 1: 2.3.1 Processes, policies and procedures

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Etablieren Sie eine unternehmensweite Projektmanagementkultur, die eine konsequente und optimale Umsetzung des Projektmanagements im gesamten Unternehmen unter Berücksichtigung der Organisationsstruktur und des Geschäftsumfelds unterstützt. Stellen Sie sicher, dass alle Initiativen in Projekte umgesetzt werden (oder in Änderungen, wenn diese nur einen geringen Umfang haben) und stellen Sie sicher, dass keine Ad-hoc-Aktionen außerhalb des Projektmanagements stattfinden.		

G. Komponente: Services, Infrastruktur und Anwendungen
Werkzeuge zum Projektmanagement

4.4 BEREITSTELLEN, BETREIBEN UND UNTERSTÜTZEN

- 01 Betrieb ist gemanagt
- 02 Serviceanfragen und Störungen sind gemanagt
- 03 Probleme sind gemanagt
- 04 Kontinuität ist gemanagt
- 05 Sicherheitsservices sind gemanagt
- 06 Geschäftsprozesskontrollen sind gemanagt

Diese Seite wurde absichtlich freigelassen.

Domäne: Bereitstellen, Betreiben und Unterstützen Managementziel: DSS01 – Betrieb ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Koordination und Ausführung der Aktivitäten und betrieblichen Verfahren, die zur Erbringung interner und ausgelagerter I&T-Services erforderlich sind. Einbeziehung der Ausführung von vordefinierten Standardverfahren und der erforderlichen Überwachungsaktivitäten.		
Zweck		
Bereitstellung von vereinbarten betrieblichen I&T-Produkten und Service-Ergebnissen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
DSS01.01 Durchführen der Verfahren des Betriebs Pflegen Sie betriebliche Verfahren und Aufgaben, und führen Sie diese zuverlässig und konsistent durch.	a. Anzahl der durch betriebliche Probleme verursachten Störungen b. Anzahl der ausgeführten nicht standardmäßigen betrieblichen Verfahren	
Aktivitäten	Fähigkeitsstufe	
1. Entwickeln und pflegen Sie betriebliche Verfahren und zugehörige Aktivitäten, um alle bereitgestellten Services zu unterstützen.	2	
2. Führen Sie einen Zeitplan für betriebliche Aktivitäten und führen Sie diese aus.		
3. Vergewissern Sie sich, dass alle zur Verarbeitung erforderlichen Daten vollständig, genau und rechtzeitig empfangen und verarbeitet werden. Liefern Sie die Ergebnisse so, dass Sie den Anforderungen des Unternehmens entsprechen. Sehen Sie Möglichkeiten zur erneuten Ausführung oder zur Aufbereitung vor. Stellen Sie sicher, dass die Benutzer die richtigen Ergebnisse auf sichere Weise und rechtzeitig erhalten.	3	
4. Managen Sie die Leistung und den Durchsatz der geplanten Aktivitäten.	4	
5. Überwachen Sie Störungen und Probleme im Zusammenhang mit operativen Verfahren und ergreifen Sie geeignete Maßnahmen, um die Zuverlässigkeit der ausgeführten betrieblichen Aufgaben zu verbessern.	5	

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		TP.SE Safeguard Operational Environment
HITRUST CSF Version 9, September 2017		09.01 Document Operating Procedures
ISO/IEC 27002:2013/Cor.2:2015(E)		12.1 Operational procedures and responsibilities
ITIL V3, 2011		Service Operation, 4.1 Event Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.13 Physical and environmental protection (PE-13, PE-14, PE-15)
Managementpraktik		Beispielmetrik
DSS01.02 Managen ausgelagerter I&T-Dienste Managen Sie den Betrieb ausgelagerter I&T-Dienste, um den Schutz der Unternehmensinformationen und die Zuverlässigkeit der Dienstbereitstellung aufrecht zu erhalten.		a. Anzahl spezifischer/intelligenter KPIs, die in Outsourcing-Verträgen enthalten sind b. Häufigkeit der Nichterfüllung der KPIs durch den Outsourcing-Partner
Aktivitäten		Fähigkeitsstufe
1. Stellen Sie sicher, dass die Anforderungen des Unternehmens an die Sicherheit von Informationsprozessen mit Hilfe von Verträgen und SLAs mit Dritten, die Dienste hosten oder bereitstellen, eingehalten werden.		3
2. Stellen Sie sicher, dass die Anforderungen des Unternehmens an das operative Geschäft und die IT-Verarbeitung sowie die Prioritäten für die Bereitstellung von Diensten anhand von Verträgen und SLAs mit Dritten, die Dienste hosten oder bereitstellen, eingehalten werden.		
3. Integrieren Sie kritische interne IT-Managementprozesse in die der Anbieter ausgelagerter Services. Dies sollte beispielsweise Leistungs- und Kapazitätsplanung, Änderungsmanagement, Konfigurationsmanagement, Management von Serviceanfragen und Störungen, Problemmanagement, Sicherheitsmanagement, Geschäftskontinuität, Überwachung der Prozessleistung und Berichterstattung umfassen.		
4. Planen Sie unabhängige Prüfungen der betrieblichen Umgebungen von Outsourcing-Partnern ein, um sicherzustellen, dass den vereinbarten Anforderungen adäquat entsprochen wird.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SC1.2 Outsourcing
ISO/IEC 20000-1:2011(E)		4.2 Governance of processes operated by other parties
Managementpraktik		Beispielmetrik
DSS01.03 Überwachen der I&T-Infrastruktur Überwachen Sie die I&T-Infrastruktur und damit verbundene Ereignisse. Speichern Sie ausreichende chronologische Informationen in Betriebsprotokollen, um zeitliche Abläufe im Rahmen des Betriebs und anderen Aktivitäten, die mit dem Betrieb verbunden sind oder ihn unterstützen, zu rekonstruieren und zu überprüfen.		a. Anteil der kritischen Vorfälle im Rahmen des Betriebs, die von automatischen Erkennungssystemen aufgedeckt werden b. Anteil der auf der Grundlage der Kritikalität der Services und der Abhängigkeiten zwischen Konfigurationselementen und den davon abhängigen Services überwachten Infrastrukturbetriebsmittel
Aktivitäten		Fähigkeitsstufe
1. Protokollieren Sie Ereignisse. Identifizieren Sie in diesem Zusammenhang den Umfang der aufzuzeichnenden Informationen, der sich aus der Berücksichtigung von Risiko und Leistung ergibt.		2
2. Ermitteln und pflegen Sie eine Liste der Infrastrukturbetriebsmittel, die – je nach Service-Kritikalität und je nach Beziehung zwischen Konfigurationselementen und den von ihnen abhängigen Services – überwacht werden müssen.		3
3. Definieren und implementieren Sie Regeln, die Schwellenwertverletzungen und Ereignisbedingungen identifizieren und aufzeichnen. Finden Sie ein Gleichgewicht zwischen der Erzeugung von irrelevanten Ereignissen und bedeutenden Ereignissen, damit die Ereignisprotokolle nicht mit unnötigen Informationen überladen werden.		
4. Generieren Sie Ereignisprotokolle, und bewahren Sie sie für eine angemessene Dauer auf, um künftige Asuwertungen zu unterstützen.		
5. Stellen Sie sicher, dass Störungs-Tickets zeitnah erstellt werden, wenn sich bei der Überwachung Abweichungen von definierten Schwellenwerten ergeben.		4
6. Richten Sie Verfahren für die Überwachung von Ereignisprotokollen ein. Führen Sie regelmäßige Überprüfungen durch.		

A. Komponente: Prozess (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.10 Maintenance (MA-2, MA-3)
Managementpraktik	Beispielmetrik
DSS01.04 Managen der Umgebung Erarbeiten Sie Maßnahmen zum Schutz vor Umweltfaktoren. Installieren Sie spezielle Geräte und Vorrichtungen zur Überwachung und Kontrolle der Umgebung.	a. Anzahl der Personen, die für die sachgemäße Reaktion nach Alarmen in der IT-Umgebung geschult sind b. Anzahl der definierten Risikoszenarien für Bedrohungen in der IT-Umgebung
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie natürliche und durch den Menschen verursachte Katastrophen, die sich potenziell in dem Bereich ereignen könnten, wo sich IT-Einrichtungen befinden. Bewerten Sie die potenziellen Auswirkungen auf die IT-Einrichtungen.	2
2. Ermitteln Sie, wie die I&T-Ausstattung, einschließlich mobiler und standortferner Geräte, vor Bedrohungen aus der Umgebung geschützt wird. Stellen Sie sicher, dass eine Richtlinie das Essen, Trinken und Rauchen in sensiblen Bereichen einschränkt oder ausschließt und das Lagern von Büromaterial oder anderen feuergefährlichen Materialien in Computerräumen verbietet.	
3. Halten Sie IT-Standorte und Serverräume jederzeit in einem sauberen und sicheren Zustand (vermeiden Sie Unordnung, Papier, Verpackungen, volle Papierkörbe, entflammbare Chemikalien oder Stoffe).	
4. Wählen Sie den Standort und die Konstruktionsweise für IT-Einrichtungen so, dass die Anfälligkeit für Bedrohungen aus der Umgebung (z. B. Diebstahl, Luft, Feuer, Rauch, Wasser, Vibrationen, Terror, Vandalismus, Chemikalien, Sprengstoffe) minimiert wird. Ziehen Sie spezielle Sicherheitszonen und/oder feuerfeste Räume in Betracht (z. B. die räumliche Trennung von Produktions- und Entwicklungsumgebungen/Servern).	3
5. Gleichen Sie vorhandene Maßnahmen und Notfallpläne mit den Versicherungsaufgaben ab, und berichten Sie die Ergebnisse. Verfolgen Sie jede Abweichung zeitnah.	
6. Reagieren Sie auf Alarme aus der Umgebung und andere Benachrichtigungen. Dokumentieren und testen Sie Verfahren, die eine Priorisierung der Alarme und den Kontakt mit örtlichen Notfallbehörden beinhalten sollten. Schulen Sie das Personal bezüglich dieser Verfahren.	
7. Überwachen und warten Sie regelmäßig die Geräte, die zur proaktiven Ermittlung von Umgebungsgefahren eingesetzt werden (z. B. Feuer-, Wasser-, Rauch- und Feuchtigkeitmelder).	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	2.1 System and system elements; 3.2 Categorization (Task 5, 6)
Managementpraktik	Beispielmetrik
DSS01.05 Managen von Einrichtungen Managen Sie Einrichtungen, einschließlich der Stromversorgungs- und Kommunikationsausrüstung, gemäß den gesetzlichen Vorgaben und Bestimmungen, technischen und geschäftlichen Anforderungen, Herstellerangaben sowie nach Maßgabe der Richtlinien für Gesundheit und Sicherheit.	a. Zeit seit dem letzten Test der unterbrechungsfreien Stromversorgung b. Anzahl der Personen, die zu Gesundheits- und Sicherheitsrichtlinien geschult wurden

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Untersuchen Sie die Anforderungen seitens der IT-Einrichtungen in Bezug auf den Schutz gegen Stromschwankungen und -ausfälle in Verbindung mit anderen Anforderungen der Geschäftskontinuitätsplanung. Beschaffen Sie geeignete Geräte für eine unterbrechungsfreie Stromversorgung (z. B. Batterien und Generatoren), um die Geschäftskontinuitätsplanung zu unterstützen.	2
2. Überprüfen Sie regelmäßig die Funktion der unterbrechungsfreien Stromversorgung. Stellen Sie sicher, dass Stromquellen zugeschaltet werden können, ohne dass sich dies merklich auf den Geschäftsbetrieb auswirkt.	
3. Stellen Sie sicher, dass die Räumlichkeiten, in denen die I&T-Systeme untergebracht sind, über mehr als eine Quelle für den Bezug wichtiger Versorgungsmedien verfügen (Strom, Telekommunikation, Wasser, Gas). Sorgen Sie für einen getrennten Zugang zu den einzelnen Versorgungseinrichtungen.	
4. Stellen Sie sicher, dass die externe Verkabelung des IT-Standorts unterirdisch verläuft oder über eine sonstige geeignete Schutzvorrichtung verfügt. Überprüfen Sie, ob die Verkabelung innerhalb des IT-Standorts in gesicherten Kabelkanälen verläuft, und stellen Sie sicher, dass Kabelschränke nur für autorisiertes Personal zugänglich sind. Schützen Sie das Kabelsystem angemessen vor Beschädigungen durch Feuer, Rauch, Wasser, Abfängen und Störfrequenzen.	
5. Stellen Sie sicher, dass die Kabel und Steckdosen (für Daten und Telefon) systematisch angeordnet sind. Die Verkabelung und der Kabelkanalverlauf sollten dokumentiert werden (z. B. Gebäudeplan und Schaltpläne).	
6. Schulen Sie das Personal regelmäßig hinsichtlich der einzuhaltenden Gesetze, Bestimmungen und Richtlinien für Gesundheit und Sicherheit. Bilden Sie das Personal im Rahmen von Brandschutz- und Rettungsübungen aus, um sicherzustellen, dass im Brandfall oder Notsituationen das entsprechende Wissen vorhanden ist und die richtigen Maßnahmen ergriffen werden.	
7. Stellen Sie sicher, dass die IT-Standorte und die IT-Ausrüstung gemäß den vom Hersteller empfohlenen Serviceintervallen und Spezifikationen gewartet werden. Wartungsarbeiten dürfen nur von autorisiertem Personal durchgeführt werden.	3
8. Analysieren Sie die Hochverfügbarkeitssysteme der Einrichtung auf Erfüllung der (externen und internen) Anforderungen hinsichtlich Redundanz und ausfallsicherer Verkabelung.	
9. Stellen Sie sicher, dass die IT-Standorte und -Einrichtungen jederzeit den relevanten Gesetzen, Bestimmungen und Richtlinien für Gesundheit und Sicherheit sowie den Herstellerangaben entsprechen.	
10. Erfassen, überwachen, managen und beheben Sie Störungen in den Einrichtungen nach Maßgabe des I&T-Störungsmanagementprozesses. Stellen Sie Berichte zu Störungen innerhalb der Einrichtung zur Verfügung, sofern deren Offenlegung gesetzlich oder behördlich vorgeschrieben ist.	4
11. Analysieren Sie bauliche Veränderungen am IT-Standort oder Grundstück, und schätzen Sie das Risiko durch Umgebungseinflüsse erneut ein (z. B. Brand- oder Wasserschäden). Leiten Sie die Ergebnisse dieser Analyse an das Geschäftskontinuitäts- und Gebäudemanagement weiter.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen						
Wichtige Managementpraktik:	Chief Operating Officer	Chief Information Officer	Chief Technology Officer	Leiter IT-Betrieb	Information Security Manager	Datenschutzbeauftragter
DSS01.01 Durchführen der Verfahren des Betriebs	R	A	R	R		
DSS01.02 Managen ausgelagerter I&T-Dienste		A	R	R	R	R
DSS01.03 Überwachen der I&T-Infrastruktur		R	A	R	R	
DSS01.04 Managen der Umgebung		R	A	R	R	
DSS01.05 Managen von Einrichtungen		R	A	R	R	

B. Komponente: Organisationsstrukturen (Forts.)	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine entsprechenden weiteren Quellen für diese Komponente	

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
DSS01.01 Durchführen der Verfahren des Betriebs	Von	Beschreibung	Beschreibung	Für
	BAI05.05	Betriebs- und Nutzungsplan	Sicherungsprotokoll	Intern
			Betriebsplan	Intern
DSS01.02 Managen ausgelagerter I&T-Dienste	AP009.03	• SLAs • OLAs	Unabhängige Prüfungspläne	MEA04.02
	BAI05.05	Betriebs- und Nutzungsplan		
DSS01.03 Überwachen der I&T-Infrastruktur	BAI03.11	Servicedefinitionen	Regeln für die Betriebsmittelüberwachung und Ereignisbedingungen	DSS02.01, DSS02.02
			Tickets von Störungen	DSS02.02
			Ereignisprotokolle	Intern
DSS01.04 Managen der Umgebung			Umweltpolitik	AP001.09
			Berichte zu Versicherungspolicen	MEA03.03
DSS01.05 Managen von Einrichtungen			Bewusstsein für Gesundheit und Sicherheit	Intern
			Berichte zur Beurteilung von Einrichtungen	MEA01.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.2 Categorization (Task 5, 6): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Datenbankverwaltung	Skills Framework for the Information Age V6, 2015	DBAD
Facility Management	Skills Framework for the Information Age V6, 2015	DCMA
IT-Infrastruktur	Skills Framework for the Information Age V6, 2015	ITOP
Methoden und Werkzeuge	Skills Framework for the Information Age V6, 2015	METL
Servicebereitstellung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	C. Run – C.3. Service Delivery
Speichermanagement	Skills Framework for the Information Age V6, 2015	STMG

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Service-Management-Richtlinie	Bietet innerhalb des Rahmens zur Leistungsmessung Richtungs- vorgaben und Leitlinien zur Gewährleistung eines effektiven Managements und einer effektiven Umsetzung aller I&T-Services zur Erfüllung der Geschäfts- und Kundenanforderungen. Deckt das Management von Risiken im Zusammenhang mit I&T-Services ab. (Das ITIL V3-Rahmenwerk bietet detaillierte Anleitungen zum Service-Management und zur Optimierung der mit Services verbundenen Risiken)	(1) ISO/IEC 20000-1:2011(E); (2) ITIL V3, 2011	(1) 4.1.2 Service management policy; (2) Service Strategy, 3. Service strategy principles

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur der Exzellenz in der gesamten Organisation. Ermutigen Sie die Mitarbeiter zu Höchstleistungen. Schaffen Sie ein Umfeld, in dem betriebliche Abläufe (mehr als) die erforderlichen Leistungen hervorbringen und gleichzeitig den Mitarbeitern die Möglichkeit gegeben wird, den Status quo in Frage zu stellen und neue Ideen auszuprobieren. Managen Sie operative Exzellenz durch Mitarbeiterengagement und kontinuierliche Verbesserung. Etablieren Sie einen kundenorientierten Ansatz (sowohl für interne als auch für externe Kunden).		

G. Komponente: Services, Infrastruktur und Anwendungen

- Cloud-Hosting-Dienste
- Werkzeuge zur Überwachung der Infrastruktur
- Werkzeuge zur Überwachung der Service Level

Domäne: Bereitstellen, Betreiben und Unterstützen Managementziel: DSS02 – Serviceanfragen und Störungen sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Sicherstellung einer zeitnahen und effektiven Bearbeitung von Benutzeranforderungen und Beseitigung aller Arten von Störungen. Dies umfasst die Wiederherstellung des Normalbetriebs, die Erfassung und Umsetzung von Benutzeranforderungen sowie die Erfassung, Untersuchung, Diagnose, Eskalation und Behebung von Störungen.		
Zweck		
Maximierung der Produktivität und Minimierung von Unterbrechungen durch schnelle Bearbeitung von Benutzeranfragen und Störungen. Beurteilung der Auswirkungen von Änderungen und Abwicklung von Servicestörungen. Bearbeitung von Benutzeranfragen und Wiederherstellen des Services bei Störungen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
DSS02.01 Definieren von Klassifizierungsschemen für Störungen und Serviceanfragen Definieren Sie Klassifizierungsschemen und -modelle für Störungen und Serviceanfragen.		a. Gesamtzahl der Serviceanfragen und Störungen pro definierter Prioritätsstufe b. Gesamtzahl der eskalierten Störungen
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Klassifizierungs- und Priorisierungsschemata für Störungen und Serviceanfragen sowie Kriterien für die Registrierung von Problemen. Verwenden Sie diese Informationen, um konsistente Ansätze für die Handhabung, die Information der Benutzer über Probleme und die Durchführung von Trendanalysen sicherzustellen.		3
2. Definieren Sie Störungsmodelle für bekannte Fehler, um eine effiziente und effektive Behebung zu ermöglichen.		
3. Definieren Sie Modelle für Serviceanfragen, die sich an der Art der Serviceanfragen orientieren, um Selbsthilfemaßnahmen und eine effiziente Abwicklung von Standardanfragen zu ermöglichen.		
4. Definieren Sie Regeln und Verfahren für die Störungseskalation, insbesondere für schwerwiegende Störungen und Sicherheitsvorfälle.		
5. Definieren Sie Wissensquellen für Störungen und Anfragen und beschreiben Sie deren Nutzung.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		IA.IP Implement Incident Investigation Processes
HITRUST CSF Version 9, September 2017		11.01 Reporting Information Security Incidents and Weaknesses
ISF, The Standard of Good Practice for Information Security 2016		TM2 Security Incident Management
ISO/IEC 20000-1:2011(E)		8.1 Incident and service request management
ISO/IEC 27002:2013/Cor.2:2015(E)		16. Information security incident management
Managementpraktik		Beispielmetrik
DSS02.02 Aufzeichnen, Klassifizieren und Priorisieren von Anforderungen und Störungen Identifizieren, erfassen und klassifizieren Sie Serviceanfragen und Störungen, und weisen Sie ihnen unter Berücksichtigung der Geschäftskritizität und vereinbarter Service Levels Prioritäten zu.		a. Anzahl der Typen und Kategorien, die für die Aufzeichnung von Serviceanfragen und Störungen definiert sind b. Anzahl der nicht kategorisierten Serviceanfragen und Störungen
Aktivitäten		Fähigkeitsstufe
1. Protokollieren Sie sämtliche Serviceanfragen und Störungen und erfassen Sie dabei alle relevanten Informationen, sodass sie effektiv bearbeitet und ein lückenloser Verlauf nachvollzogen werden kann.		2
2. Klassifizieren Sie Serviceanfragen und Störungen nach Typ und Kategorie, um die Durchführung von Trendanalysen zu ermöglichen.		
3. Priorisieren Sie Serviceanfragen und Störungen nach SLA-Servicedefinition, Geschäftsauswirkung und Dringlichkeit.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
DSS02.03 Überprüfen, Genehmigen und Erfüllen von Serviceanfragen Wählen Sie geeignete Anfrageverfahren aus und stellen Sie sicher, dass die Serviceanfragen den für sie festgelegten Kriterien entsprechen. Holen Sie ggf. die Genehmigung ein und bearbeiten Sie die Anfragen.		a. Durchschnittlich benötigte Zeit für die Bearbeitung jedes Typs von Serviceanfrage b. Anteil der Serviceanfragen, die definierte Anfragenkriterien erfüllen
Aktivitäten		Fähigkeitsstufe
1. Überprüfen Sie die Berechtigung für Serviceanfragen und stützen Sie sich dabei möglichst auf einen vordefinierten Prozessfluss und Standardänderungen.		2
2. Holen Sie ggf. die Genehmigung oder schriftliche Freigabe in finanzieller und funktionaler Hinsicht ein bzw. vorab erteilte Genehmigungen für bereits vereinbarte Standardänderungen.		
3. Erfüllen Sie die Anfragen, indem Sie das ausgewählte Anfragenverfahren anwenden. Verwenden Sie nach Möglichkeit automatisierte Selbsthilfe-Menüs und vordefinierte Anfragemodelle für häufig angeforderte Elemente.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011		Service Operation, 4.3 Request Fulfilment
Managementpraktik		Beispielmetrik
DSS02.04 Untersuchen, Diagnostizieren und Zuordnen von Störungen Identifizieren und erfassen Sie Störungssymptome, bestimmen Sie mögliche Ursachen und ordnen Sie die Störung zwecks Behebung zu.		a. Anzahl der identifizierten und aufgezeichneten Gründe für Störungen b. Anzahl der korrekt ermittelten Symptomursachen c. Anzahl der mehrfach im Referenzprotokoll auftauchenden Probleme
Aktivitäten		Fähigkeitsstufe
1. Identifizieren und beschreiben Sie relevante Symptome um die wahrscheinlichsten Ursachen der Störungen zu ermitteln. Ziehen Sie verfügbare Wissensressourcen heran (einschließlich bekannter Fehler und Probleme), um die möglichen Störungslösungen zu ermitteln (vorübergehende Workarounds und/oder dauerhafte Lösungen).		2
2. Falls noch kein ähnliches Problem oder bekannter Fehler existiert, und falls die Störung die vereinbarten Kriterien für die Problemregistrierung erfüllt, legen Sie ein neues Problem an.		
3. Weisen Sie Störungen entsprechenden Experten zu, sofern fundierte Fachkenntnisse erforderlich sind. Beziehen Sie ggf. die jeweilige Managementebene ein.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik	Beispielmetrik	
DSS02.05 Beheben von Störungen und anschließende Wiederherstellung Dokumentieren und testen Sie die identifizierten Lösungen oder Workarounds, und setzen Sie diese um. Führen Sie Wiederherstellungsmaßnahmen durch, um den I&T-gestützten Service wiederherzustellen.	a. Anteil der Störungen, die im Rahmen der vereinbarten SLAs gelöst wurden b. Grad der Zufriedenheit der Anspruchsgruppen mit der Lösung und der Beseitigung einer Störung	
Aktivitäten		Fähigkeitsstufe
1. Wählen Sie die am besten geeigneten Störungslösungen aus (vorübergehende Workarounds und/oder dauerhafte Lösungen) und setzen Sie diese um.		2
2. Dokumentieren Sie, ob für die Störungslösung Workarounds zur Anwendung kamen.		
3. Führen Sie ggf. Wiederherstellungsmaßnahmen durch.		
4. Dokumentieren Sie die Störungslösung und beurteilen Sie, ob die Lösung als künftige Wissensquelle infrage kommt.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ITIL V3, 2011	Service Operation, 4.2 Incident Management	
National Institute of Standards and Technology Framework for Improving Critical Infrastructure Cybersecurity v1.1, April 2018	RC.RP Recovery Planning	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.9 Incident response (IR-4, IR-5, IR-6)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 201	CSC 19: Incident Response and Management	
Managementpraktik	Beispielmetrik	
DSS02.06 Schließen von Serviceanfragen und Störungen Überprüfen Sie, ob die Störung und/oder Anfrage zufriedenstellend behoben bzw. bearbeitet wurde, und schließen Sie sie.	a. Grad der Zufriedenheit der Benutzer mit der Bearbeitung der Serviceanfrage b. Anteil der Störungen, die innerhalb einer vereinbarten/akzeptablen Zeitspanne gelöst wurden	
Aktivitäten		Fähigkeitsstufe
1. Fragen Sie bei den betroffenen Benutzern nach, ob die Serviceanfragen zufriedenstellend bearbeitet bzw. die Störung zufriedenstellend und innerhalb einer vereinbarten/akzeptablen Zeitspanne gelöst wurde.		2
2. Schließen Sie die Serviceanfragen und/oder Störungen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik	Beispielmetrik	
DSS02.07 Verfolgen des Status und Erstellen von Berichten Verfolgen und analysieren Sie regelmäßig Störungen und die Bearbeitung von Anfragen und erstellen Sie entsprechende Berichte. Analysieren Sie Trends, um Informationen für eine kontinuierliche Verbesserung bereitzustellen.	a. Durchschnittliche Zeit zwischen den Störungen eines aktiven I&T-gestützten Service b. Anzahl und Anteil der Störungen, die Unterbrechungen von geschäftskritischen Prozessen verursachen	
Aktivitäten		Fähigkeitsstufe
1. Überwachen und verfolgen Sie Störungseskalationen und Verfahren für die Handhabung von Störungen und Anfragen, um die Behebung bzw. den Abschluss voranzutreiben.		2
2. Identifizieren Sie Anspruchsgruppen für Informationen und deren Bedarf an Daten oder Berichten. Bestimmen Sie die Häufigkeit von Berichten und die zu verwendenden Medien.		3

A. Komponente: Prozess (Forts.)

3. Erstellen und verteilen Sie zeitnah Berichte oder stellen Sie einen kontrollierten Zugang zu entsprechenden Online-Daten bereit.	4
4. Analysieren Sie Vorfälle und Serviceanfragen nach Kategorie und Typ. Stellen Sie Trends fest und identifizieren Sie Muster von wiederkehrenden Problemen, SLA-Verstößen oder Ineffizienzen.	
5. Ziehen Sie diese Informationen als Input für die Planung kontinuierlicher Verbesserungen heran.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	MI.IM Ensure Incident Mitigation; IR.IR Incident Reporting
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.9 Incident response (IR-7, IR-8)

B. Komponente: Organisationsstrukturen

	Chief Technology Officer	Geschäftsprozessverantwortlicher	Leiter Entwicklung	Leiter IT-Betrieb	Service Manager	Information Security Manager
Wichtige Managementpraktik:						
DSS02.01 Definieren von Klassifizierungsschemen für Störungen und Serviceanfragen	A		R	R	R	
DSS02.02 Aufzeichnen, Klassifizieren und Priorisieren von Anforderungen und Störungen	A			R	R	
DSS02.03 Überprüfen, Genehmigen und Erfüllen von Serviceanfragen	A	R	R	R	R	
DSS02.04 Untersuchen, Diagnostizieren und Zuordnen von Störungen	A	R		R	R	
DSS02.05 Beheben von Störungen und anschließende Wiederherstellung	A		R	R	R	R
DSS02.06 Schließen von Serviceanfragen und Störungen	A			R	R	R
DSS02.07 Verfolgen des Status und Erstellen von Berichten	A			R	R	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen					
ISO/IEC 27002:2013/Cor.2:2015(E)	16.1.1 Responsibilities and procedures					

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
DSS02.01 Definieren von Klassifizierungsschemen für Störungen und Serviceanfragen	Von	Beschreibung	Beschreibung	Für
	APO09.03	Service Level Vereinbarungen (SLAs)	Kriterien für die Registrierung von Problemen	DSS03.01
	BAI10.02	Konfigurations-Repository	Regeln für die Eskalation von Störungen	Intern
	BAI10.03	Aktualisiertes Repository mit Konfigurations-elementen	Klassifikationsschemata und -modelle für Störungen und Serviceanfragen	Intern
	BAI10.04	Statusberichte zur Konfiguration		
	DSS01.03	Regeln für die Betriebsmittelüberwachung und Ereignisbedingungen		
	DSS03.01	Problemklassifizierungsschema		
DSS02.02 Aufzeichnen, Klassifizieren und Priorisieren von Anforderungen und Störungen	DSS04.03	Maßnahmen und Kommunikation bei Störungen		
	APO09.03	Service Level Vereinbarungen (SLAs)	Klassifizierte und priorisierte Störungen und Serviceanfragen	APO08.03, APO09.04, APO13.03, DSS03.05
	BAI04.05	Notfalleskalationsverfahren	Störungs- und Serviceanfragenprotokoll	Intern MEA04.07
	DSS01.03	- Regeln für die Betriebsmittelüberwachung und Ereignisbedingungen - Tickets für Störungen		
	DSS05.07	Tickets für sicherheitsrelevante Störungen		
Managementpraktik	Inputs		Outputs	
DSS02.03 Überprüfen, Genehmigen und Erfüllen von Serviceanfragen	Von	Beschreibung	Beschreibung	Für
	APO12.06	Risikobezogene Grundursachen	Genehmigte Serviceanfragen	BAI06.01
DSS02.04 Untersuchen, Diagnostizieren und Zuordnen von Störungen	BAI07.07	Plan für zusätzlichen Support	Erfüllte Serviceanfragen	Intern
			Problemprotokoll	DSS03.01
			Störungssymptome	Intern
DSS02.05 Beheben von Störungen und anschließende Wiederherstellung	APO12.06	Pläne zum Umgang mit risikobehafteten Störungen	Beseitigung von Störungen	DSS03.03, DSS03.04, DSS03.05, MEA04.07
	DSS03.03	Dokumentation von bekannten Fehlern		
	DSS03.04	Kommunikation des erlernten Wissens		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
DSS02.06 Schließen von Serviceanfragen und Störungen	DSS03.04	Geschlossene Problem- datensätze	Bestätigung der zufriedenstellenden Bearbeitung oder Lösung durch den Benutzer	AP008.03
			Geschlossene Serviceanfragen und Störungen	AP008.03, AP009.04, DSS03.04
DSS02.07 Verfolgen des Status und Erstellen von Berichten	AP009.03	OLAs (Operational Level Agreements) als Teil der SLAs	Bericht über Status und Trends von Störungen	AP008.03, AP009.04, AP011.04, AP012.01, MEA01.03
	DSS03.01	Problemstatusberichte	Anforderungserfüllungsstatus und Trendbericht	AP008.03, AP009.04, AP011.04, MEA01.03
	DSS03.02	Berichte zur Problemlösung		
	DSS03.05	Berichte zur Überwachung der Problemlösung		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Anwendungsunterstützung	Skills Framework for the Information Age V6, 2015	ASUP
Kundendienstunterstützung	Skills Framework for the Information Age V6, 2015	CSMG
Störungsmanagement	Skills Framework for the Information Age V6, 2015	USUP
Netzwerkunterstützung	Skills Framework for the Information Age V6, 2015	NTAS
Benutzerunterstützung	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	C. Run – C.1. User Support

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie für Serviceanfragen	Stellt Begründungen und Leitlinien für Service- und Störungsanfragen und deren Dokumentation bereit.	ITIL V3, 2011	Service Operation, 3. Service operation principles

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Befähigen Sie die Mitarbeiter, Störungen korrekt und zeitnah zu erkennen und geeignete Eskalationspfade zu implementieren. Ermutigen Sie zur Prävention. Reagieren Sie sofort auf Störungen und beseitigen Sie diese. Vermeiden Sie eine Heldenkultur.		

G. Komponente: Services, Infrastruktur und Anwendungen	
Werkzeuge zur Nachverfolgung von Störungen einschließlich eines entsprechenden Systems	

Domäne: Bereitstellen, Betreiben und Unterstützen Managementziel: DSS03 – Probleme sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Identifizierung und Klassifizierung von Problemen und deren Ursachen. Bereitstellung zeitnaher Lösungen, um eine Wiederholung der Störung zu verhindern. Bereitstellung von Empfehlungen für Verbesserungen.		
Zweck		
Steigerung der Verfügbarkeit, Verbesserung der Service Levels, Reduzierung von Kosten und Verbesserung der Benutzerfreundlichkeit und Benutzerzufriedenheit durch Reduzierung der Anzahl operativer Probleme und Identifikation der Ursachen im Rahmen der Problemlösung.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
DSS03.01 Identifizieren und Klassifizieren von Problemen Definieren und implementieren Sie Kriterien und Verfahren zur Identifizierung und Meldung von Problemen und sehen Sie die Klassifizierung, Kategorisierung und Priorisierung der Probleme vor.	a. Anteil der schwerwiegenden Störungen, bei denen Probleme protokolliert wurden b. Anteil der Störungen, die in Übereinstimmung mit den vereinbarten SLAs gelöst wurden c. Anteil der zutreffend identifizierten Probleme, einschließlich deren Klassifizierung, Kategorisierung und Priorisierung

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie Probleme durch die Korrelation von Störungsberichten, Fehlerprotokollen und anderen Ressourcen zur Problemidentifizierung.	2
2. Behandeln Sie Probleme strukturiert und unter Hinzuziehung aller relevanten Daten. Dazu gehören auch Informationen aus dem IT-Änderungsmanagement sowie Angaben zur IT-Konfiguration, zu IT-Betriebsmitteln und zu Störungen.	
3. Definieren Sie geeignete Support-Gruppen, die bei der Problemerkennung, Ursachenanalyse und Lösungsfindung helfen, um das Problemmanagement zu unterstützen. Bestimmen Sie Support-Gruppen auf der Grundlage vordefinierter Kategorien, wie z. B. Hardware, Netzwerk, Software, Anwendungen und Support-Software.	
4. Definieren Sie Prioritätsstufen unter Hinzuziehung von Vertretern aus dem geschäftlichen Bereich, um sicherzustellen, dass Problemidentifizierung und Ursachenanalyse rechtzeitig und nach Maßgabe der vereinbarten SLAs erfolgen. Richten Sie die Prioritätsstufen an den Geschäftsauswirkungen und an der Dringlichkeit aus.	
5. Leiten Sie den Status identifizierter Probleme an den Service Desk weiter, damit Kunden und IT-Management auf dem Laufenden gehalten werden können.	
6. Führen Sie einen zentralen Problemmanagement-Katalog, um festgestellte Probleme zu registrieren und zu melden. Verwenden Sie den Katalog, um Prüfpfade für Problemmanagementprozesse zu ermöglichen, aus denen auch der Status der einzelnen Probleme hervorgeht (z. B. Offen, Erneut geöffnet, In Bearbeitung oder Geschlossen).	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISO/IEC 20000-1:2011(E)	8.2 Problem management
Managementpraktik	Beispielmetrik
DSS03.02 Untersuchen und Diagnostizieren von Problemen Untersuchen und diagnostizieren Sie Probleme unter Hinzuziehung von Fachexperten, um deren Ursachen zu ermitteln und zu analysieren.	a. Anzahl der identifizierten Probleme, die als bekannte Fehler klassifiziert wurden b. Anteil der Probleme, deren gesamter Lebenszyklus untersucht und diagnostiziert wurde
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie Probleme, bei denen es sich möglicherweise um bekannte Fehler handelt, indem Sie die Störungsdaten mit der Datenbank der bekannten und vermuteten Fehler vergleichen (die beispielsweise von externen Anbietern kommuniziert werden). Klassifizieren Sie Probleme ggf. als bekannte Fehler.	3
2. Verknüpfen Sie die betroffenen Konfigurationselemente mit dem festgestellten/bekannten Fehler.	
3. Erstellen Sie Berichte, um den Fortschritt bei der Lösung von Problemen zu kommunizieren und die anhaltenden Auswirkungen nicht gelöster Probleme zu überwachen. Überwachen Sie den Status des Problembehandlungsprozesses während des gesamten Lebenszyklus und berücksichtigen Sie Inputs des Änderungs- und Konfigurationsmanagements.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	
Managementpraktik	Beispielmetrik
DSS03.03 Anlegen bekannter Fehler Legen Sie, sobald die Ursachen des Problems identifiziert wurden, einen Datensatz für ein bekanntes Problem an, dokumentieren Sie einen geeigneten Workaround und benennen Sie potenzielle Lösungen.	a. Anzahl der Probleme mit zufriedenstellender Lösung bei der die Ursachen bekämpft wurden b. Grad der Zufriedenheit der Anspruchsgruppen mit der Identifikation der Ursachen, der Erstellung von Aufzeichnungen über bekannte Fehler und geeigneten Workarounds sowie der Identifizierung potenzieller Lösungen
Aktivitäten	Fähigkeitsstufe
1. Legen Sie, sobald die Ursachen des Problems identifiziert wurden, einen Datensatz für ein bekanntes Problem an und entwickeln Sie einen geeigneten Workaround.	2
2. Identifizieren, bewerten, priorisieren und verarbeiten Sie (über das IT-Änderungsmanagement) Lösungen für bekannte Fehler. Stützen Sie sich dabei auf einen Kosten/Nutzen-Business Case, die Geschäftsauswirkungen und die Dringlichkeit.	3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
DSS03.04 Lösen und Schließen von Problemen Identifizieren und initiieren Sie nachhaltige Lösungen, die darauf ausgerichtet sind, die zugrundeliegende Ursache zu beseitigen. Reichen Sie, sofern erforderlich, einen Änderungsantrag für die Fehlerbehebung über den etablierten Änderungsmanagementprozess ein. Stellen Sie sicher, dass die betroffenen Mitarbeiter über die durchgeführten Maßnahmen und die entwickelten Pläne zur Vermeidung künftiger Störungen in Kenntnis gesetzt wurden.		a. Abnahme der Zahl der wiederkehrenden Störungen, die durch unge löste Probleme verursacht werden b. Anteil der für offene Probleme definierten Workarounds
Aktivitäten		Fähigkeitsstufe
1. Schließen Sie Problem Datensätze, sobald die Bestätigung der erfolgreichen Behebung des bekannten Fehlers vorliegt, oder sobald mit den Betroffenen eine alternative Handhabung des Problems vereinbart wurde.		2
2. Informieren Sie den Service Desk über den Zeitplan der Problemschließung (also beispielsweise bis wann bekannte Fehler behoben sind, den möglichen Workaround oder die Tatsache, dass das Problem weiterhin besteht, bis die Änderung implementiert ist), sowie über die Konsequenzen des verfolgten Ansatzes. Halten Sie die betroffenen Benutzer und Kunden je nach Erfordernis auf dem Laufenden.		
3. Fordern Sie während des Lösungsprozesses regelmäßig Berichte vom IT-Änderungsmanagement über den Fortschritt bei der Behebung von Problemen und Fehlern an.		3
4. Überwachen Sie die weiterhin vorhandenen Auswirkungen von Problemen und bekannten Fehlern auf Services.		4
5. Überprüfen und bestätigen Sie bei schwerwiegenden Problemen den Erfolg der Behebung.		
6. Stellen Sie sicher, dass die aus der Überprüfung gewonnenen Erkenntnisse dem Kunden im Rahmen eines Service Review Meetings kommuniziert werden.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
DSS03.05 Umsetzen eines proaktiven Problemmanagements Sammeln und analysieren Sie betriebliche Daten (insbesondere Datensätze zu Störungen und Änderungen), um aufkommende Trends zu identifizieren, die möglicherweise auf ein Problem hinweisen. Protokollieren Sie Problem Datensätze, um deren Beurteilung zu ermöglichen.		a. Anteil der protokollierten Probleme im Rahmen der proaktiven Problemmanagementaktivitäten b. Grad der Zufriedenheit der wichtigsten Anspruchsgruppen mit der Kommunikation von Problem Informationen im Zusammenhang mit IT-Änderungen und -Störungen
Aktivitäten		Fähigkeitsstufe
1. Erfassen Sie Problem Informationen im Zusammenhang mit I&T-Änderungen und -Störungen und kommunizieren Sie sie an die wichtigsten Anspruchsgruppen. Die Kommunikation kann in Form von Berichten und regelmäßigen Besprechungen mit Prozessverantwortlichen des Störungs-, Problem-, Änderungs- und Konfigurationsmanagements erfolgen, in denen aktuelle Probleme und potenzielle korrektive Maßnahmen erörtert werden.		3
2. Stellen Sie sicher, dass sich die Prozessverantwortlichen und Führungskräfte des Störungs-, Problem-, Änderungs- und Konfigurationsmanagements regelmäßig zusammenfinden, um bekannte Probleme und künftig geplante Änderungen zu besprechen.		
3. Identifizieren und initiieren Sie nachhaltige Lösungen, die darauf ausgerichtet sind, die zugrundeliegende Ursache zu beseitigen. Reichen Sie einen Änderungsantrag über den etablierten Änderungsmanagementprozess ein.		
4. Erfassen Sie Änderungsaufwendungen, die auf Aktivitäten des Problemmanagementprozesses zurückzuführen sind (z. B. Behebung von Problemen und bekannten Fehlern), in einem Bericht, um dem Unternehmen die Überwachung der Gesamtkosten bezogen auf Probleme zu ermöglichen.		4
5. Erstellen Sie Berichte, um die Problemlösung unter Berücksichtigung der Geschäftsanforderungen und SLAs überwachen zu können. Stellen Sie die angemessene Eskalation von Problemen sicher, z. B. eine Eskalation an eine höhere Managementebene gemäß vereinbarter Kriterien, Kontaktaufnahme mit externen Anbietern, oder Weiterleitung an den Änderungsberatungsausschuss (CAB), mit dem Ziel, die Priorität dringender Änderungsanträge (RFC) zu erhöhen, um einen vorübergehenden Workaround zu implementieren.		
6. Beobachten Sie Problemtrends, um die Ressourcennutzung zu optimieren und die Anzahl der Workarounds zu reduzieren.		

A. Komponente: Prozess (Forts.)

Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	MI.IC Ensure Incident Containment
ITIL V3, 2011	Service Operation, 4.4 Problem Management

B. Komponente: Organisationsstrukturen

	Exekutivkomitee	Chief Information Officer	Chief Technology Officer	Leiter Entwicklung	Leiter IT-Betrieb	Service Manager	Information Security Manager
Wichtige Managementpraktik:							
DSS03.01 Identifizieren und Klassifizieren von Problemen		R	A	R	R	R	
DSS03.02 Untersuchen und Diagnostizieren von Problemen			A		R	R	R
DSS03.03 Anlegen bekannter Fehler			A		R	R	R
DSS03.04 Lösen und Schließen von Problemen			A		R	R	
DSS03.05 Umsetzen eines proaktiven Problemmanagements	R		A		R	R	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen						
Keine entsprechenden weiteren Quellen für diese Komponente							

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
DSS03.01 Identifizieren und Klassifizieren von Problemen	AP012.06	Risikobehaftete Grundursachen	Problemklassifizierungsschema	DSS02.01
	DSS02.01	Kriterien für die Registrierung von Problemen	Problemstatusberichte	DSS02.07
	DSS02.04	Problemprotokoll	Problemregister	Intern
DSS03.02 Untersuchen und Diagnostizieren von Problemen	AP012.06	Risikobehaftete Grundursachen	Berichte zur Problemlösung	DSS02.07
			Grundursachen von Problemen	Intern DSS03.05
DSS03.03 Anlegen bekannter Fehler	AP012.06	Risikobehaftete Grundursachen	Lösungsvorschläge für bekannte Fehler	BAI06.01
	DSS02.05	Beseitigung von Störungen	Dokumentation von bekannten Fehlern	DSS02.05
DSS03.04 Lösen und Schließen von Problemen	DSS02.05	Beseitigung von Störungen	Kommunikation des erlernten Wissens	AP008.04, DSS02.05
	DSS02.06	Geschlossene Serviceanfragen und Störungen	Geschlossene Problem Datensätze	DSS02.06

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
DSS03.05 Umsetzen eines proaktiven Problemmanagements	AP012.06	Risikobehaftete Grundursachen	Identifizierte nachhaltige Lösungen	BAI06.01
	DSS02.02	• Klassifizierte und priorisierte Störungen und Serviceanfragen • Beseitigung von Störungen	Berichte zur Überwachung der Problemlösung	DSS02.07, MEA04.07
	DSS03.04	Grundursachen von Problemen		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Anwendungsunterstützung	Skills Framework for the Information Age V6, 2015	ASUP
Netzwerkunterstützung	Skills Framework for the Information Age V6, 2015	NTAS
Problemmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	C. Run – C.4. Problem Management
Problemmanagement	Skills Framework for the Information Age V6, 2015	PBMG

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zur Lösung von Problemen	Dokumentiert Begründungen und bietet Anleitungen für die Behandlung von Problemen, die sich durch Störungen ergeben, sowie für die Ermittlung validierter Abhilfemaßnahmen.	ITIL V3, 2011	Service Operation, 3. Service operation principles

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Unterstützen Sie eine Kultur des proaktiven Problemmanagements (Erkennung, Aktion und Prävention) mit klar definierten Rollen und Verantwortlichkeiten. Sorgen Sie für ein transparentes und offenes Umfeld für die Meldung von Problemen, indem Sie unabhängige Meldemechanismen bereitstellen und/oder Personen belohnen, die die Problemlösung fördern.		

G. Komponente: Services, Infrastruktur und Anwendungen
Systeme zur Verfolgung und Lösung von Problemen

Diese Seite wurde absichtlich freigelassen.

Domäne: Bereitstellen, Betreiben und Unterstützen Managementziel: DSS04 – Kontinuität ist gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Erstellen und pflegen Sie einen Plan, der die Geschäfts- und IT-Einheiten dabei unterstützt, auf Störungen zu reagieren und sich schnell auf Unterbrechungen einzustellen. Dies ermöglicht den kontinuierlichen Betrieb kritischer Geschäftsprozesse und notwendiger I&T-Services und hält die Verfügbarkeit von Ressourcen, Betriebsmitteln und Informationen auf einem für das Unternehmen akzeptablen Niveau.		
Zweck		
Schnelle Anpassung, Fortsetzung des Geschäftsbetriebs und Aufrechterhaltung der Verfügbarkeit von Ressourcen und Informationen auf einem für das Unternehmen akzeptablen Niveau im Falle einer erheblichen Unterbrechung (z. B. Bedrohungen, Chancen, Anforderungen).		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG02 Gesteuertes Geschäftsrisiko • EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen • AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobewertung abgedeckt werden b. Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursachen b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
DSS04.01 Definieren der Richtlinie, der Zielvorgaben und des Umfangs der Geschäftskontinuität Definieren Sie die Richtlinie und den Umfang der Geschäftskontinuität unter Berücksichtigung der Zielvorgaben des Unternehmens und der Anspruchsgruppen, um die Widerstandsfähigkeit des Unternehmens zu verbessern.	a. Anteil der Ziele und des Umfangs der Geschäftskontinuität, der aufgrund falsch identifizierter Prozesse und Aktivitäten überarbeitet wurde b. Anteil der wichtigsten Anspruchsgruppen, die sich daran beteiligen, die Geschäftskontinuitätsrichtlinie und deren Umfang zu definieren und zu vereinbaren	
Aktivitäten	Fähigkeitsstufe	
1. Identifizieren Sie interne und ausgelagerte Geschäftsprozesse und Serviceaktivitäten, die von kritischer Bedeutung für den Geschäftsbetrieb oder erforderlich für die Erfüllung gesetzlicher und/oder vertraglicher Pflichten sind.	2	
2. Ermitteln Sie wichtige Anspruchsgruppen, Rollen und Zuständigkeiten für die Definition und Vereinbarung von Kontinuitätsrichtlinie und -umfang.		
3. Definieren und dokumentieren Sie die vereinbarten Mindestzielvorgaben in Bezug auf die Richtlinie und den vereinbarten Umfang der Kontinuitätsstrategie.		
4. Identifizieren Sie wesentliche unterstützende Geschäftsprozesse und die zugehörigen I&T-Services.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
HITRUST CSF Version 9, September 2017	12.01 Information Security Aspects of Business Continuity Management	
ISF, The Standard of Good Practice for Information Security 2016	BC1.1 Business Continuity Strategy; BC1.2 Business Continuity Programme	
ISO/IEC 27002:2013/Cor.2:2015(E)	17. Information security aspects of business continuity management	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.6 Contingency planning (CP-1)	
Managementpraktik	Beispielmetrik	
DSS04.02 Pflegen einer Kontinuitätsstrategie Bewerten Sie die verschiedenen Optionen der Kontinuitätsstrategie und wählen Sie eine kosteneffektive und praktikable Strategie, die die Unternehmenskontinuität, die Wiederherstellung im Katastrophenfall und die Reaktion auf Störungen im Falle einer Notsituation oder einer anderen größeren Unterbrechung gewährleistet.	a. Gesamtausfallzeit infolge einer größeren Unterbrechung oder Störung b. Anteil der wichtigsten Anspruchsgruppen, die in Geschäftsauswirkungsanalysen einbezogen sind, um den Schaden, den eine Unterbrechung der kritischen Geschäftsfunktionen im Laufe der Zeit bewirkt, zu bewerten, sowie die Folgen, die eine Unterbrechung für sie haben würde	
Aktivitäten	Fähigkeitsstufe	
1. Identifizieren Sie potenzielle Szenarien, die zu Ereignissen führen könnten, die erhebliche Störungen zur Folge haben.	2	
2. Führen Sie eine Geschäftsauswirkungsanalyse durch, um den Schaden, den eine Unterbrechung der kritischen Geschäftsfunktionen im Laufe der Zeit bewirkt, zu bewerten, sowie die Folgen, die eine Unterbrechung für sie haben würde.		
3. Ermitteln Sie die mindestens erforderliche Zeit für die Wiederherstellung eines Geschäftsprozesses und der unterstützenden I&T. Stützen Sie sich dabei auf eine akzeptable Unterbrechungsdauer der Geschäftsabläufe und die maximal tolerierbare Ausfallzeit.		
4. Bestimmen Sie die Bedingungen und Verantwortlichen wichtiger Entscheidungen, die zur Aktivierung der Kontinuitätspläne führen.		
5. Beurteilen Sie die Wahrscheinlichkeit von Bedrohungen, die zu einer Unterbrechung der Geschäftsfunktionen führen könnten. Identifizieren Sie Maßnahmen, um der Wahrscheinlichkeit des Auftretens und den damit verbundenen Auswirkungen durch ein höheres Maß an Prävention und Stabilität entgegenzuwirken.	3	
6. Analysieren Sie die Kontinuitätsanforderungen, um mögliche strategische Geschäfts- und technische Optionen zu identifizieren.		
7. Ermitteln Sie die Ressourcenanforderungen und Kosten für die einzelnen strategischen und technischen Optionen, und geben Sie strategische Empfehlungen.		
8. Holen Sie die Genehmigung der Geschäftsleitung für die ausgewählten strategischen Optionen ein.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		BC1.3 Belastbare technische Umgebungen
ITIL V3, 2011		Service Design, 4.6 IT Continuity Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.6 Contingency planning (CP-2)
Managementpraktik		Beispielmetrik
DSS04.03 Entwickeln und Implementieren einer Geschäftskontinuitätsreaktion Entwickeln Sie basierend auf der Strategie einen Geschäftskontinuitätsplan (BCP) und einen Notfallwiederherstellungsplan (DRP). Dokumentieren Sie alle Verfahren, die dem Unternehmen im Falle einer Störung die Fortführung seiner kritischen Aktivitäten ermöglichen		a. Anzahl der kritischen Geschäftssysteme, die nicht in den Plänen enthalten sind b. Anteil der wichtigsten Anspruchsgruppen, die an der Entwicklung der Pläne beteiligt sind
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Maßnahmen zur Störungsbehandlung, die im Falle einer Unterbrechung einzuleiten sind, sowie die damit verbundene Kommunikation. Definieren Sie entsprechende Rollen und Zuständigkeiten, einschließlich der Verantwortlichkeit für die Richtlinie und die Implementierung.		2
2. Stellen Sie sicher, dass wichtige Lieferanten und Outsourcing-Partner effektive Kontinuitätspläne implementiert haben. Holen Sie ggf. einen bestätigten Nachweis dazu ein.		
3. Definieren Sie die Bedingungen und Wiederherstellungsverfahren, die eine Wiederaufnahme der Geschäftsprozesse ermöglichen würden. Dazu gehören auch die Aktualisierung und der Abgleich von Informationsdatenbanken zur Sicherstellung der Integrität der Informationen.		
4. Entwickeln und pflegen Sie operative BCPs und DRPs, in denen die anzuwendenden Verfahren für die Fortführung kritischer Geschäftsprozesse und/oder temporäre Verarbeitungsvorkehrungen enthalten sind. Fügen Sie Verweise zu den Plänen von Anbietern der ausgelagerten Services ein.		
5. Definieren und dokumentieren Sie die erforderlichen Ressourcen für die Unterstützung der Kontinuitäts- und Wiederherstellungsverfahren. Beziehen Sie dabei Mitarbeiter, Einrichtungen und die IT-Infrastruktur ein.		
6. Definieren und dokumentieren Sie die Anforderungen an die Informationssicherung, die im Zusammenhang mit den Plänen erfüllt sein müssen. Das umfasst sowohl Pläne in Papierform als auch Dateien. Erwägen Sie die Notwendigkeit von Sicherungsmaßnahmen und externer Lagerung.		
7. Ermitteln Sie, welche Fähigkeiten Mitarbeiter aufweisen müssen, die in die Umsetzung der Pläne und der Verfahren involviert sind.		3
8. Sorgen Sie für eine sichere Verteilung der Pläne und Begleitunterlagen an entsprechend befugte Parteien mit einem berechtigten Interesse. Stellen Sie sicher, dass die Pläne und unterstützenden Unterlagen in jeder Art von Katastrophenszenario zugänglich sind.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		BC1.4 Crisis Management; BC2.1 Business Continuity Planning
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.6 Contingency planning (CP-6, CP-9, CP-10)
Managementpraktik		Beispielmetrik
DSS04.04 Ausführen, Testen und Überprüfen des Geschäftskontinuitätsplans (BCP) und Katastrophenschutzplans (DRP) Testen Sie den Geschäftskontinuitätsplan regelmäßig, indem Sie die Planausführung an vorher festgelegten Ergebnisse messen, die Widerstandsfähigkeit des Unternehmens aufrechterhalten und die Entwicklung innovativer Lösungen ermöglichen.		a. Testhäufigkeit b. Anzahl der Übungen und Tests, die die Wiederherstellungsziele erreicht haben

A. Komponente: Prozess (Forts.)		
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie Zielvorgaben für das Ausführen und Testen der geschäftlichen, technischen, logistischen, administrativen, verfahrenstechnischen und betrieblichen Systeme laut Plan, um die Vollständigkeit des BCP und des DRP in Bezug auf das Geschäftsrisiko zu verifizieren.		2
2. Definieren und vereinbaren Sie gemeinsam mit den Anspruchsgruppen realistische Übungen, die geeignet sind, die Kontinuitätsverfahren zu validieren. Berücksichtigen Sie dabei Rollen und Zuständigkeiten sowie Vorkehrungen zur Datenverfügbarkeit, die die Geschäftsprozesse nur minimal unterbrechen.		
3. Weisen Sie Rollen und Zuständigkeiten für die Durchführung der Kontinuitätsplanübungen und -tests zu.		
4. Planen Sie Übungen und Testaktivitäten wie in den Kontinuitätsplänen definiert.		3
5. Führen Sie nach der Übung eine Besprechung und Analyse durch, um die erzielten Ergebnisse zu beurteilen.		4
6. Entwickeln Sie auf der Grundlage der Ergebnisüberprüfungen Empfehlungen zur Verbesserung der aktuellen Kontinuitätspläne.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	PP.RS Develop and Maintain Response Plans; PP.RP Develop and Maintain Recovery Plans	
ISF, The Standard of Good Practice for Information Security 2016	BC2.3 Business Continuity Testing	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 20: Penetration Tests and Red Team Exercises	
Managementpraktik		Beispielmetrik
DSS04.05 Überprüfen, Pflegen und Verbessern des Kontinuitätsplans Führen Sie in regelmäßigen Abständen ein Management Review der Kontinuitätsbefähigung durch, um die kontinuierliche Eignung, Angemessenheit und Effektivität des Kontinuitätsplans sicherzustellen. Managen Sie Änderungen am Plan nach Maßgabe des Änderungskontrollprozesses, um sicherzustellen, dass der Kontinuitätsplan auf dem neuesten Stand ist und jederzeit die aktuellen Geschäftsanforderungen berücksichtigt.		a. Anteil der vereinbarten Verbesserungen des Plans, die anschließend auch im Plan berücksichtigt wurden b. Anteil der Kontinuitätspläne und Bewertungen der Geschäftsauswirkungen, die tatsächlich aktuell sind
Aktivitäten		Fähigkeitsstufe
1. Überprüfen Sie die Kontinuitätspläne und die Kontinuitätsbefähigung regelmäßig und ziehen Sie einen Vergleich zu den Erwartungen und zu aktuellen operativen und strategischen Geschäftszielvorgaben.		3
2. Überprüfen Sie den Kontinuitätsplan regelmäßig, um die Auswirkungen neuer oder wesentlicher Änderungen in der Unternehmensorganisation, von Geschäftsprozessen, Outsourcing-Vereinbarungen, Technologien, Infrastruktur, Betriebssystemen und Anwendungssystemen zu beurteilen.		
3. Beurteilen Sie, inwieweit, unter Berücksichtigung der Art der Änderung, eine überarbeitete Beurteilung der Geschäftsauswirkungen erforderlich ist.		
4. Machen Sie Empfehlungen zu Änderungen an Richtlinien, Plänen, Verfahren, Infrastruktur sowie an Rollen und Zuständigkeiten. Holen Sie ggf. die Genehmigung des Managements ein, und setzen Sie diese anhand des IT-Änderungsmanagementprozessen um.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
DSS04.06 Durchführen von Schulungen zum Kontinuitätsplan Bieten Sie für alle betroffenen internen und externen Parteien regelmäßig Schulungen an, in denen die Verfahren sowie die Rollen und Zuständigkeiten der einzelnen Parteien im Falle einer Unterbrechung behandelt werden.		a. Anteil der internen und externen Anspruchsgruppen, die eine Schulung erhalten haben b. Anteil der relevanten internen und externen Parteien, deren Fähigkeiten und Kompetenzen auf dem neuesten Stand sind

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Fördern Sie Bewusstsein für den BCP und DRP und implementieren Sie Schulungen.	2
2. Definieren und pflegen Sie Schulungsanforderungen und Schulungspläne für Mitarbeiter, die mit der Kontinuitätsplanung, der Beurteilung von Auswirkungen und Risiken, medialer Kommunikation und der Behandlung von Störungen betraut sind. Stellen Sie sicher, dass in den Schulungsplänen die Häufigkeit der Schulungen und Mechanismen zur Bereitstellung der Schulungen berücksichtigt sind.	3
3. Sorgen Sie für die Ausweitung der Fähigkeiten durch praxisnahe Maßnahmen, wie z. B. die Teilnahme an Übungen und Tests.	
4. Überwachen Sie Fähigkeiten und Kompetenzen anhand der Übungs- und Testergebnisse.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.6 Contingency planning (CP-4)
Managementpraktik	Beispielmetrik
DSS04.07 Managen von Backup-Vorkehrungen Sorgen Sie für die dauerhafte Verfügbarkeit geschäftskritischer Informationen.	a. Anteil der Sicherungsmedien, die sicher übertragen und gespeichert sind b. Anteil der erfolgreichen und rechtzeitigen Wiederherstellungen aus Sicherungskopien oder alternativen Medien
Aktivitäten	Fähigkeitsstufe
1. Sichern Sie Systeme, Anwendungen, Daten und Dokumentationen nach einem festgelegten Zeitplan. Berücksichtigen Sie dabei die Häufigkeit (monatlich, wöchentlich, täglich usw.), die Art der Sicherung (z. B. Plattenspiegelung für Echtzeit-Backups bzw. DVD-ROM für die langfristige Aufbewahrung), die Art des Backups (z. B. vollständig vs. inkrementell) und den Medientyp. Berücksichtigen Sie auch automatisierte Online-Backups, Datenarten (z. B. Sprachdaten, optische Daten), die Erstellung von Protokollen, kritische Endbenutzerdaten (z. B. Kalkulationstabellen), physischen und logischen Speicherort von Datenquellen, Sicherheit und Zugriffsrechte sowie Verschlüsselung.	2
2. Definieren Sie Anforderungen für die Speicherung von Backup-Daten innerhalb und außerhalb des Standorts, die den geschäftlichen Anforderungen entsprechen. Berücksichtigen Sie den erforderlichen Zugang zu Datensicherungen.	
3. Testen und aktualisieren Sie regelmäßig archivierte und gesicherte Daten.	
4. Stellen Sie sicher, dass für Systeme, Anwendungen, Daten und Dokumentationen, die von Dritten gepflegt oder verarbeitet werden, adäquat Backups erstellt oder diese anderweitig gesichert werden. Überlegen Sie, ob die Rückgabe von Backups seitens Dritter erforderlich ist. Überlegen Sie, inwieweit Treuhand- oder Hinterlegungsvereinbarungen sinnvoll sein könnten.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	IP.BP Apply Backup Processes
HITRUST CSF Version 9, September 2017	09.05 Information Back-Up
ISF, The Standard of Good Practice for Information Security 2016	SY2.3 Backup
ISO/IEC 27002:2013/Cor.2:2015(E)	12.3 Backup
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.6 Contingency planning (CP-3)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 10: Data Recovery Capability
Managementpraktik	Beispielmetrik
DSS04.08 Durchführen einer Überprüfung nach der Wiederaufnahme Beurteilen Sie im Anschluss an die erfolgreiche Wiederaufnahme der Geschäftsprozesse und Services infolge einer Unterbrechung die Angemessenheit des Geschäftskontinuitätsplans (BCP) und des Katastrophenschutzplans (DRP).	a. Anteil der identifizierten und im Plan behandelten Problemstellungen b. Anteil der identifizierten und in den Schulungsmaterialien behandelten Problemstellungen

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Bewerten Sie die Einhaltung der dokumentierten BCP und DRP.	4
2. Bestimmen Sie die Effektivität der Pläne, der Kontinuitätsbefähigung, der Rollen und Zuständigkeiten, der Fähigkeiten und Kompetenzen, der Störungsfestigkeit, der technischen Infrastruktur sowie der Organisationsstrukturen und Beziehungen.	
3. Identifizieren Sie Schwächen oder fehlende Aspekte innerhalb des Plans und hinsichtlich der Befähigungen und machen Sie Empfehlungen für Verbesserungen. Holen Sie die Genehmigung des Managements für jede Änderung am Plan ein und setzen Sie diese anhand des unternehmensweiten Änderungskontrollprozesses um.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen													
	Exekutivkomitee	Chief Operating Officer	Chief Information Officer	Chief Technology Officer	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Datenmanagement	Chefarchitekt	Leiter Entwicklung	Leiter IT-Betrieb	Service Manager	Information Security Manager	Business Continuity Manager
Wichtige Managementpraktik:													
DSS04.01 Definieren der Richtlinie, der Zielvorgaben und des Umfangs der Geschäftskontinuität	R	A	R		R	R				R	R		R
DSS04.02 Pflegen einer Kontinuitätsstrategie	R	A	R			R		R		R		R	R
DSS04.03 Entwickeln und Implementieren einer Geschäftskontinuitätsreaktion			R	R		R				R		R	A
DSS04.04 Ausführen, Testen und Überprüfen des Geschäftskontinuitätsplans (BCP) und Katastrophenschutzplans (DRP)			R	R		R				R		R	A
DSS04.05 Überprüfen, Pflegen und Verbessern des Kontinuitätsplans		A	R	R	R	R				R			R
DSS04.06 Durchführen von Schulungen zum Kontinuitätsplan			R	R		R			R	R		R	A
DSS04.07 Managen von Backup-Vorkehrungen				A			R			R		R	R
DSS04.08 Durchführen einer Überprüfung nach der Wiederaufnahme			R	R	R	R				R			A
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen												
Keine entsprechenden weiteren Quellen für diese Komponente													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
DSS04.01 Definieren der Richtlinie, der Zielvorgaben und des Umfangs der Geschäftskontinuität	Von	Beschreibung	Beschreibung	Für
	APO09.03	Service Level Vereinbarungen (SLAs)	Richtlinien und Zielvorgaben für die Geschäftskontinuität	APO01.02
			Beurteilung der derzeitigen Kontinuitätsbefähigung und diesbezüglicher Lücken	Intern
			Szenarien für Störfälle	Intern
DSS04.02 Pflegen einer Kontinuitätsstrategie	APO12.06	• Kommunikation der Risikoauswirkungen • Risikobezogene Grundursachen	Genehmigte strategische Optionen	APO02.05
			Bewertung der Geschäftsauswirkungen	APO12.02
			Kontinuitätsanforderungen	Intern
DSS04.03 Entwickeln und Implementieren einer Geschäftskontinuitätsreaktion	APO09.03	OLAs (Operational Level Agreements) als Teil der SLAs	Maßnahmen und Kommunikation bei Störungen	DSS02.01
			BCP	Intern
DSS04.04 Ausführen, Testen und Überprüfen des Geschäftskontinuitätsplans (BCP) und Katastrophenschutzplans (DRP)			Testergebnisse und Empfehlungen	Intern
			Test-Übungen	Intern
			Test-Ziele	Intern
DSS04.05 Überprüfen, Pflegen und Verbessern des Kontinuitätsplans			Empfohlene Planänderungen	Intern
			Ergebnisse der Planüberprüfung	Intern
DSS04.06 Durchführen von Schulungen zum Kontinuitätsplan	HR	Liste des schulungsbedürftigen Personals	Überwachung der Ergebnisse von Fähigkeiten und Kompetenzen	APO07.03
			Schulungsanforderungen	APO07.03
DSS04.07 Managen von Backup-Vorkehrungen	APO14.10	• Backup-Plan • Backup-Testplan	Testergebnisse der Datensicherung	Intern
			Datensicherung	Intern APO14.08
DSS04.08 Durchführen einer Überprüfung nach der Wiederaufnahme			Genehmigte Änderungen an den Plänen	BAI06.01
			Überprüfungsbericht nach der Wiederaufnahme	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen

Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Kontinuitätsmanagement	Skills Framework for the Information Age V6, 2015	COPL

E. Komponente: Richtlinien und Verfahren

Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Geschäftskontinuitätsrichtlinie	Beschreibt das Engagement des Managements hinsichtlich der Bewertung der Geschäftsauswirkungen (BIA), des Geschäftskontinuitätsplans (einschließlich zuverlässiger Wiederherstellung), der Wiederherstellungsanforderungen für kritische Systeme, definierter Schwellenwerte und Auslöser für Notfälle, des Eskalationsplans, des Datenwiederherstellungsplans, Schulungen und Tests.		
Krisenmanagementrichtlinie	Legt die Anweisungen und die Abfolge der Krisenreaktion für wichtige Risikobereiche fest. Zusammen mit der I&T-Sicherheit, dem Netzwerkmanagement sowie der Datensicherheit und dem Datenschutz gehört das Krisenmanagement zu den Richtlinien auf operativer Ebene, die im Hinblick auf die Vollständigkeit des I&T-Risikomanagements Beachtung finden sollten.		

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Verankern Sie die Sicherstellung der Widerstandsfähigkeit von Unternehmen in der Unternehmenskultur. Informieren Sie die Mitarbeiter regelmäßig und häufig über Kernwerte, gewünschte Verhaltensweisen und strategische Ziele, um die Souveränität und das Image des Unternehmens in jeder Situation aufrechtzuerhalten. Testen Sie regelmäßig die Geschäftskontinuitätsverfahren und die Notfallwiederherstellung.		

G. Komponente: Services, Infrastruktur und Anwendungen

- Externe Hosting-Services
- Werkzeuge zur Überwachung von Störungen
- Services für ausgelagerte Speichermöglichkeiten

Domäne: Bereitstellen, Betreiben und Unterstützen Managementziel: DSS05 – Sicherheitsservices sind gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Schutz der Unternehmensinformationen, mit dem Ziel, das für das Unternehmen akzeptable Niveau des Informationssicherheitsrisikos gemäß der Sicherheitsrichtlinie aufrechtzuerhalten. Einrichtung und Pflege von Informationssicherheitsrollen und Zugangsrechten. Überwachung der Sicherheit.		
Zweck		
Minimierung der geschäftlichen Auswirkungen von betrieblichen Informationssicherheits-Schwachstellen und -Vorfällen.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG02 Gesteuertes Geschäftsrisiko • EG06 Kontinuität und Verfügbarkeit der geschäftlichen Services		• AG02 Gesteuertes I&T-Risiko • AG07 Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG02 a. Anteil der kritischen Geschäftsziele und Services, die von der Risikobewertung abgedeckt werden b. Anzahl der gravierenden Störungen, die in den Risikobewertungen nicht identifiziert wurden, gegenüber den gesamten Störungen c. Aktualisierungshäufigkeit des Risikoprofils		AG02 a. Aktualisierungshäufigkeit des Risikoprofils b. Anteil der unternehmensweiten Risikobewertungen einschließlich IT-bezogener Risiken c. Anzahl gravierender I&T-bezogener Störungen, die nicht im Rahmen einer Risikobewertung identifiziert wurden
EG06 a. Anzahl der Unterbrechungen des Kundenservice oder von Geschäftsprozessen, die erhebliche Störungen verursacht haben b. Geschäftsbezogene Kosten der aufgetretenen Störungen c. Anzahl der durch ungeplante Serviceunterbrechungen verlorenen Zeit im Bereich der Geschäftstätigkeit d. Anteil der Beschwerden in Abhängigkeit von den festgelegten Zielen zur Verfügbarkeit der Services		AG07 a. Anzahl von Verstößen gegen die Vertraulichkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben b. Anzahl von Störungen der Verfügbarkeit, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben c. Anzahl von Störungen der Integrität, die zu finanziellen Verlusten, Geschäftsunterbrechungen oder öffentlichen Unannehmlichkeiten geführt haben

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
DSS05.01 Einrichten eines Schutzes vor bösartiger Software Implementieren und pflegen Sie unternehmensweit vorbeugende, aufdeckende und korrektive Maßnahmen (insbesondere aktuelle Sicherheitspatches und Viruskontrollen), um Informationssysteme und Technologien vor bösartiger Software zu schützen (wie z. B. Ransomware, Malware, Viren, Würmer, Spyware, Spam).	a. Zahl der erfolgreichen Angriffe durch bösartige Software b. Anteil der Mitarbeiter, die bei Tests zu böswilligen Angriffen (z. B. Test von Phishing-E-Mails) durchgefallen	
Aktivitäten		Fähigkeitsstufe
1. Installieren und aktivieren Sie auf allen Verarbeitungseinrichtungen Tools zum Schutz vor bösartiger Software und sorgen Sie dafür, dass die Malware-Definitionsdateien (automatisch oder halbautomatisch) nach Erfordernis aktualisiert werden.		2
2. Filtern Sie den eingehenden Datenverkehr, wie E-Mails oder Downloads, um Schutz vor unerwünschten Daten zu gewährleisten (z. B. Spyware oder Phishing-Mails).		
3. Sensibilisieren Sie die Mitarbeiter für bösartige Software und setzen Sie Präventionsverfahren und Verantwortlichkeiten um. Führen Sie regelmäßige Schulungen durch, die sich mit dem Thema Malware im Rahmen der Nutzung von E-Mail und Internet befassen. Schulen Sie die Benutzer dahingehend, verdächtige E-Mails nicht zu öffnen, sondern zu melden und keine Shareware oder nicht genehmigte Software zu installieren.		3
4. Verteilen Sie sämtliche Schutzsoftware zentral (Versions- und Patchnummer), indem Sie auf ein zentralisiertes Konfigurations- und IT-Änderungsmanagement zurückgreifen.		
5. Überprüfen und bewerten Sie regelmäßig Informationen zu neuen potenziellen Bedrohungen (z. B. durch Überprüfen der Herstellerempfehlungen zur Sicherheit von Produkten und Services).		4

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		DP.DC Detect Malicious Code; RI.VT Vulnerability and Threat Identification
HITRUST CSF Version 9, September 2017		09.04 Protection Against Malicious & Mobile Code
SF, The Standard of Good Practice for Information Security 2016		TS1 Security Solutions
SO/IEC 27002:2013/Cor.2:2015(E)		12.2 Protection against malware
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016		CSC 4: Continuous Vulnerability Assessment and Remediation; CSC 8: Malware Defenses
Managementpraktik		Beispielmetrik
DSS05.02 Managen der Netzwerk- und Konnektivitätssicherheit Wenden Sie Sicherheitsmaßnahmen und entsprechende Managementverfahren an, um Informationen unabhängig von der verwendeten Konnektivitätsmethode zu schützen.		a. Anzahl von Firewall-Durchbrüchen b. Anzahl der aufgedeckten Schwachstellen c. Anteil der Zeit, in der Netzwerk und Systeme aufgrund von Sicherheitsvorfällen/Störungen nicht verfügbar waren
Aktivitäten		Fähigkeitsstufe
1. Gewähren Sie nur autorisierten Geräten Zugriff auf Konzerninformationen und das Unternehmensnetzwerk. Konfigurieren Sie die Geräte so, dass grundsätzlich ein Kennwort eingegeben werden muss.		2
2. Implementieren Sie Netzwerkfiltermechanismen wie Firewalls und Einbruchserkennungssoftware. Implementieren Sie geeignete Richtlinien zur Kontrolle des ein- und ausgehenden Datenverkehrs.		
3. Verwenden Sie für die Netzwerkkonnektivität bewährte Sicherheitsprotokolle.		
4. Konfigurieren Sie Netzwerkgeräte in einer sicheren Art und Weise.		
5. Verschlüsseln Sie zu übertragende Informationen entsprechend ihrer Klassifizierung.		3
6. Erstellen und pflegen Sie auf der Grundlage von Risikobeurteilungen und geschäftlichen Anforderungen eine Richtlinie für die Sicherheit der Konnektivität.		
7. Richten Sie zuverlässige Mechanismen ein, um die sichere Übertragung und den sicheren Empfang von Informationen zu unterstützen.		
8. Führen Sie regelmäßige Penetrationstests durch, um die Angemessenheit des Netzwerkschutzes zu prüfen.		4
9. Führen Sie regelmäßige Tests der Systemsicherheit durch, um die Angemessenheit des Systemschutzes zu prüfen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		AC.MI Manage Network Integrity & Segregation; CM.MN Monitor Networks; AC.CP Manage Communication Protections
HITRUST CSF Version 9, September 2017		01.04 Network Access Control
ISF, The Standard of Good Practice for Information Security 2016		PA2.3 Mobile Device Connectivity; NC1.1 Network Device Configuration
ISO/IEC 27002:2013/Cor.2:2015(E)		13.1 Network security management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.20 System and information integrity (SI-8)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016		CSC 9: Limitation and Control of Network Ports, Protocols, and Services; CSC 11: Secure Configurations for Network Devices such as Firewalls, Routers, and Switches
Managementpraktik		Beispielmetrik
DSS05.03 Managen der Endpunktsicherheit Stellen Sie sicher, dass Endpunkte (wie Laptops, Desktops, Server sowie sonstige mobile Geräte, Netzwerkgeräte oder Software) mindestens den Sicherheitsanforderungen genügen, die für die verarbeiteten, gespeicherten oder übertragenen Informationen definiert sind.		a. Anzahl von Störungen bei Endgeräten b. Anzahl nicht autorisierter Geräte, die im Netzwerk oder in der Endbenutzerumgebung erkannt wurden c. Anteil der Mitarbeiter, die eine Schulung zur Sensibilisierung in Bezug auf die Verwendung von Endgeräten erhalten haben

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Konfigurieren Sie Betriebssysteme in einer sicheren Art und Weise.	2
2. Implementieren Sie Mechanismen zum Sperren von Geräten.	
3. Regeln Sie Remote-Zugriff und -Kontrolle (z. B. mobile Endgeräte, Telearbeit).	
4. Sorgen Sie für eine sichere Netzwerkkonfiguration.	
5. Implementieren Sie auf Endpunktgeräten geeignete Filter für den Netzwerkdatenverkehr.	
6. Schützen Sie die Systemintegrität.	
7. Sorgen Sie für einen physischen Schutz der Endpunktgeräte.	
8. Entsorgen Sie Endpunktgeräte auf sichere Art und Weise.	
9. Handhaben Sie böswillige Zugriffe über E-Mail und Webbrowser. Blockieren Sie z. B. bestimmte Websites und deaktivieren Sie die Direktauswahl von Links für Smartphones.	
10. Verschlüsseln Sie zu speichernde Informationen entsprechend ihrer Klassifizierung.	3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	IP.MM Apply Mobile Device Management; TP.MP Apply Media Protection; DP.DP Detect Mobile Code and Browser Protection
ISF, The Standard of Good Practice for Information Security 2016	PM1.3 Remote Working; PA2.1 Mobile Device Configuration; PA2.4 Employee-owned Devices; PA2.5 Portable Storage Devices; NC1.6 Remote Maintenance
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.4 Assessment, authorization and monitoring (CA-8, CA-9); 3.19 System and communications protection (SC-10)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 3: Secure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers; CSC 7: Email and Web Browser Protections
Managementpraktik	Beispielmetrik
DSS05.04 Managen von Benutzeridentität und logischem Zugriff Stellen Sie sicher, dass alle Benutzer entsprechend den geschäftlichen Anforderungen Zugriffsrechte auf Informationen besitzen. Stimmen Sie sich mit Geschäftseinheiten ab, die eigene Zugriffsrechte innerhalb von Geschäftsprozessen verwalten.	a. Durchschnittliche Zeit zwischen Änderung und Aktualisierung von Benutzerkonten b. Anzahl der Benutzerkonten (gegenüber der Anzahl der autorisierten Benutzer/Mitarbeiter) c. Anzahl der Vorfälle/Störungen im Zusammenhang mit unbefugtem Zugriff auf Informationen
Aktivitäten	Fähigkeitsstufe
1. Stimmen Sie Benutzerzugriffsrechte auf die jeweilige Geschäftsfunktion, die Prozessanforderungen und die Sicherheitsrichtlinien ab. Richten Sie die Verwaltung von Identitäten und Zugriffsrechten an den jeweils definierten Rollen und Zuständigkeiten aus. Stützen Sie sich dabei auf die Prinzipien „Least-Privilege“, „Need-to-have“ und „Need-to-know“.	2
2. Managen Sie Änderungen an Zugriffsrechten (Erstellung, Modifizierung und Löschung) zeitnah und nur auf der Grundlage von genehmigten und dokumentierten Transaktionen, die von eigens dafür bestimmten Mitarbeitern des Managements autorisiert wurden.	3
3. Verteilen Sie kritische Funktionen, reduzieren Sie Benutzerkonten auf die minimal erforderliche Anzahl und managen Sie aktiv hoch privilegierte Benutzerkonten. Stellen Sie die Überwachung aller Aktivitäten dieser Konten sicher.	
4. Identifizieren Sie auf eindeutige Weise sämtliche Informationsverarbeitungsaktivitäten nach funktionalen Rollen. Stimmen Sie sich dabei mit den Geschäftseinheiten ab, um sicherzustellen, dass alle Rollen konsistent definiert sind. Dazu zählen auch die Rollen, die von den Geschäftseinheiten selbst innerhalb von Geschäftsprozessanwendungen definiert wurden.	
5. Verwalten Sie die Authentifizierung für den Zugang zu Informationsbetriebsmitteln basierend auf der Rolle der Person oder den Geschäftsregeln. Stimmen Sie sich mit Geschäftseinheiten ab, die die Authentifizierung innerhalb der für Geschäftsprozesse verwendeten Anwendungen verwalten, um sicherzustellen, dass Authentifizierungskontrollen sachgerecht gehandhabt werden.	
6. Stellen Sie sicher, dass alle Benutzer (interne, externe und temporäre Benutzer) sowie deren Aktivitäten auf IT-Systemen (Geschäftsanwendungen, IT-Infrastruktur, Systembetrieb, Entwicklung und Wartung) eindeutig identifizierbar sind.	

A. Komponente: Prozess (Forts.)		
7. Richten Sie einen Prüfpfad für den Zugriff auf Informationen je nach deren Sensibilität und den gesetzlichen Anforderungen ein.		4
8. Führen Sie regelmäßige Management Reviews aller Konten und der zugehörigen Berechtigungen durch.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
HITRUST CSF Version 9, September 2017		10.03 Cryptographic Controls
ISF, The Standard of Good Practice for Information Security 2016		PM1.1 Employment Life Cycle; SA1 Access Management
ISO/IEC 27002:2013/Cor.2:2015(E)		7.3 Termination and change of employment; 9. Access control
ITIL V3, 2011		Service Operation, 4.5 Access Management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.1 Access control (AC-11, AC-12); 3.11 Media protection (MP-2, MP-4, MP-7); 3.13 Physical and environmental protection (PE-2, PE-3, PE-6)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016		CSC 1: Inventory of Authorized and Unauthorized Devices; CSC 2: Inventory of Authorized and Unauthorized Software; CSC 5: Controlled Use of Administrative Privileges; CSC 16: Account Monitoring and Control
Managementpraktik		Beispielmetrik
DSS05.05 Managen des physischen Zugriffs auf I&T-Betriebsmittel Definieren und implementieren Sie Verfahren (einschließlich Notfallverfahren) zum Gewähren, Begrenzen und Widerrufen von Zutrittsrechten zu Grundstücken, Gebäuden und Bereichen in Abhängigkeit von den jeweiligen Geschäftserfordernissen. Der Zutritt zu Grundstücken, Gebäuden und Bereichen sollte begründet, genehmigt, protokolliert und überwacht werden. Dies sollte für alle Personen gelten, die das Gelände betreten, wie z. B. Mitarbeiter, Zeitarbeitskräfte, Kunden, Anbieter, Besucher oder sonstige Dritte.		a. Durchschnittliche Bewertung der physischen Sicherheit b. Anzahl der Störungen im Zusammenhang mit der physischen Sicherheit
Aktivitäten		Fähigkeitsstufe
1. Protokollieren und überwachen Sie alle Zugangspunkte zu IT-Standorten. Registrieren Sie alle Besucher des Standorts, einschließlich der Vertragspartner und Lieferanten.		2
2. Stellen Sie sicher, dass alle Mitarbeiter jederzeit einen genehmigten Ausweis sichtbar tragen.		
3. Sorgen Sie dafür, dass Besucher während ihres Aufenthalts am Standort nie ohne Begleitung sind.		
4. Verhindern und überwachen Sie den Zugang zu schützenswerten IT-Standorten, indem Sie geeignete Einfriedungen, wie Zäune oder Mauern, sowie Sicherheitseinrichtungen an den Innen- und Außentüren vorsehen.		
5. Managen Sie die Beantragung des Zutritts, um entsprechend autorisierten Personen Zugang zu den Computerräumlichkeiten zu ermöglichen.		3
6. Stellen Sie sicher, dass die Zutrittsprofile jederzeit aktuell sind. Koppeln Sie den Zutritt zu IT-Standorten (Serverräume, Gebäude, Bereiche oder Zonen) an die Funktion und Zuständigkeiten des jeweiligen Mitarbeiters.		
7. Führen Sie regelmäßig Schulungen durch, um das Bewusstsein für die physische Sicherheit zu schärfen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		AC.MA Manage Access; ID.DI Determine Impacts
HITRUST CSF Version 9, September 2017		01.01 Business Requirement for Access Control; 01.02 Authorized Access to Information Systems; 02.0 Human Resources Security
ISF, The Standard of Good Practice for Information Security 2016		NC1.2 Physical Network Management
ISO/IEC 27002:2013/Cor.2:2015(E)		11. Physical and environmental security
Managementpraktik		Beispielmetrik
DSS05.06 Managen von sensiblen Dokumenten und Ausgabegeräten Richten Sie geeignete physische Sicherheitsvorkehrungen, Praktiken im Rechnungswesen und Bestandsmanagement-Verfahren für sensible I&T-Betriebsmittel ein, z. B. Sonderformulare, begebare Instrumente, zweckgebundene Drucker oder Sicherheits-Token.		a. Anzahl der gestohlenen Ausgabegeräte b. Anteil der im Bestand identifizierten sensiblen Dokumente und Ausgabegeräte

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Legen Sie Verfahren zur Regelung des Empfangs, der Verwendung, der Entfernung und der Entsorgung von sensiblen Dokumenten und Ausgabegeräten innerhalb und außerhalb des Unternehmens fest.	2
2. Stellen Sie sicher, dass kryptographische Mechanismen zum Schutz sensibler elektronisch gespeicherter Informationen vorhanden sind.	
3. Weisen Sie Zugriffsrechte für sensible Dokumente und Ausgabegeräte auf der Basis des Minimalprinzips zu und wägen Sie dabei Risiko und Geschäftsanforderungen ab.	3
4. Erfassen Sie den Bestand der sensiblen Dokumente und Ausgabegeräte und gleichen Sie ihn regelmäßig ab.	
5. Richten Sie geeignete physische Schutzmaßnahmen für sensible Dokumente ein.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	CM.Ph Monitor Physical
HITRUST CSF Version 9, September 2017	01.06 Application & Information Access Control; 01.07 Mobile Computing & Teleworking; 08.0 Physical & Environmental Security; 10.03 Cryptographic Controls; 10.04 Security of System Files
ISF, The Standard of Good Practice for Information Security 2016	IR2.3 Business Impact Assessment - Confidentiality Requirements; IR2.4 Business Impact Assessment - Integrity Requirements; IR2.5 Business Impact Assessment - Availability Requirements; IM2.2 Sensitive Physical Information; PA2.2 Enterprise Mobility Man
ISO/IEC 27002:2013/Cor.2:2015(E)	10. Cryptography
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.1 Access control (AC-2, AC-3, AC-4, AC-5, AC-6, AC-13, AC-24); 3.7 Identification and authentication (IA-2, IA-10, IA-11)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 15: Wireless Access Control
Managementpraktik	Beispielmetrik
DSS05.07 Managen von Schwachstellen und überwachen der Infrastruktur zur Ermittlung sicherheitsrelevanter Ereignisse Setzen Sie Tools und Technologien (z. B. Einbruchserkennung) ein, managen Sie Schwachstellen und überwachen Sie die Infrastruktur, um sie vor unberechtigtem Zugriff zu schützen. Stellen Sie sicher, dass Sicherheitstools, Technologien und Erkennungssysteme mit der allgemeinen Überwachung und dem Störungsmanagement verknüpft sind.	a. Anzahl der durchgeführten Schwachstellen-Tests der Geräte an Netzwerkknoten (Perimeter) b. Anzahl der während der Tests aufgedeckten Schwachstellen c. Zeitaufwand für die Behebung von Schwachstellen d. Anteil der Tickets, die rechtzeitig erstellt werden, wenn die Überwachungssysteme potenzielle Sicherheitsvorfälle/Störungen identifizieren
Aktivitäten	Fähigkeitsstufe
1. Nutzen Sie kontinuierlich ein Portfolio von unterstützten Technologien, Services und Betriebsmitteln (z. B. Schwachstellen-Scanner, Fuzzer und Sniffer, Protokollanalysatoren) zur Identifikation von Schwachstellen in der Informationssicherheit.	2
2. Definieren und kommunizieren Sie Risikoszenarien, damit sie leicht erkannt und die Wahrscheinlichkeit und die Auswirkungen verstanden werden.	
3. Überprüfen Sie die Ereignisprotokolle regelmäßig auf potenzielle Störungen.	
4. Stellen Sie sicher, dass sicherheitsrelevante Ereignisprotokolle rechtzeitig erstellt werden, wenn bei der Überwachung potenzielle Störungen erkannt werden.	
5. Protokollieren Sie sicherheitsrelevante Ereignisse und bewahren Sie die Aufzeichnungen für einen angemessenen Zeitraum auf.	3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016	IR2.6 Threat Profiling
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.7 Identification and authentication (IA-3); 3.11 Media protection (MP-1); 3.13 Physical and environmental protection (PE-5); 3.19 System and communications protection (SC-15)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	Maintenance, Monitoring, and Analysis of Audit Logs

B. Komponente: Organisationsstrukturen

	Chief Information Officer	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Leiter Personal	Leiter Entwicklung	Leiter IT-Betrieb	Information Security Manager	Datenschutzbeauftragter
Wichtige Managementpraktik:								
DSS05.01 Einrichten eines Schutzes vor bösartiger Software		A	R	R	R	R	R	
DSS05.02 Managen der Netzwerk- und Konnektivitätssicherheit		A			R	R	R	
DSS05.03 Managen der Endpunktsicherheit		A			R	R	R	
DSS05.04 Managen von Benutzeridentität und logischem Zugriff		A	R			R	R	R
DSS05.05 Managen des physischen Zugriffs auf I&T-Betriebsmittel		A				R	R	R
DSS05.06 Managen von sensiblen Dokumenten und Ausgabegeräten	A					R		R
DSS05.07 Managen von Schwachstellen und überwachen der Infrastruktur zur Ermittlung sicherheitsrelevanter Ereignisse		A				R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen							
Keine entsprechenden weiteren Quellen für diese Komponente								

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
DSS05.01 Einrichten eines Schutzes vor bösartiger Software			Richtlinie zum Schutz vor bösartiger Software	AP001.02
			Auswertungen potenzieller Bedrohungen	AP012.02, AP012.03
DSS05.02 Managen der Netzwerk- und Konnektivitätssicherheit	AP001.07	Richtlinien zur Datenklassifizierung	Sicherheitsrichtlinie für Konnektivität	AP001.02
	AP009.03	Service Level Vereinbarungen (SLAs)	Ergebnisse der Penetrationstests	MEA04.07
DSS05.03 Managen der Endpunktsicherheit	AP003.02	Informationsarchitekturmodell	Sicherheitsrichtlinien für Endpunktgeräte	AP001.02
	AP009.03	• SLAs • OLAs		
	BAI09.01	Ergebnisse der physischen Bestandsprüfungen		
	DSS06.06	Berichte über Verstöße		
DSS05.04 Managen von Benutzeridentität und logischem Zugriff	AP001.05	Definition von I&T-bezogenen Rollen und Zuständigkeiten	Ergebnisse der Überprüfung von Benutzerkonten und -rechten	Intern
	AP003.02	Informationsarchitekturmodell	Genehmigte Benutzerzugriffsrechte	Intern

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
Managementpraktik	Inputs		Outputs	
DSS05.05 Managen des physischen Zugriffs auf I&T-Betriebsmittel	Von	Beschreibung	Beschreibung	Für
			Zugriffsprotokolle	DSS06.03, MEA04.07
			Genehmigte Zugriffsanfragen	Intern
DSS05.06 Managen von sensiblen Dokumenten und Ausgabegeräten	APO03.02	Informationsarchitekturmodell	Zugriffsrechte	Intern
			Inventar von sensiblen Dokumenten und Geräten	Intern
DSS05.07 Managen von Schwachstellen und überwachen der Infrastruktur zur Ermittlung sicherheitsrelevanter Ereignisse			Tickets zu sicherheitsrelevanten Störungen	DSS02.02
			Merkmale von Sicherheitsvorfällen	Intern
			Protokolle zu Sicherheitsvorfällen	Intern
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Informationssicherheit	Skills Framework for the Information Age V6, 2015	SCTY
Management der Informationssicherheit	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.8. Informationssicherheitsmanagement
Penetrationstest	Skills Framework for the Information Age V6, 2015	PENT
Sicherheitsverwaltung	Skills Framework for the Information Age V6, 2015	SCAD

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Informationssicherheitsrichtlinie	Macht Vorgaben zum Schutz von Unternehmensinformationen und der damit verbundenen Systeme und Infrastruktur.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur des Bewusstseins hinsichtlich der Verantwortung der Benutzer für die fortwährende Beachtung von Sicherheits- und Datenschutzpraktiken.	1) HITRUST CSF version 9, September 2017; (2) ISF, The Standard of Good Practice for Information Security 2016	(1) 01.03 User Responsibilities; (2) PM2.1 Security Awareness Program

G. Komponente: Services, Infrastruktur und Anwendungen

- Verzeichnisdienste
- Systeme zur Filterung von E-Mails
- Zentrales Zugriffsrechte-managementsystem (IAM)
- Services zum Sicherheitsbewusstsein
- Werkzeuge zu SIEM (Security information and event management)
- Services der Sicherheitsbetriebszentrale (SOC)
- Sicherheitsbewertungen durch Dritte
- Filtersysteme für URLs

Domäne: Bereitstellen, Betreiben und Unterstützen		Schwerpunktbereich: COBIT-Kernmodell
Managementziel: DSS06 – Geschäftsprozesskontrollen sind gemanagt		
Beschreibung		
Definition und Pflege von angemessenen Geschäftsprozesskontrollen, um sicherzustellen, dass Informationen, die mit internen oder ausgelagerten Geschäftsprozessen verknüpft sind und von diesen verarbeitet werden, alle relevanten Anforderungen an die Informationskontrolle erfüllen. Identifikation aller relevanten Anforderungen an die Informationskontrolle. Management und Anwendung adäquater Eingabe-, Durchsatz- und Ausgabekontrollen (Anwendungskontrollen), um sicherzustellen, dass die Informationen und die Informationsverarbeitung diesen Anforderungen gerecht werden.		
Zweck		
Aufrechterhaltung der Informationsintegrität und der Sicherheit von Informationsbeständen, die im Rahmen von unternehmensinternen oder ausgelagerten Geschäftsprozessen verarbeitet werden.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG05 Kundenorientierte Servicekultur • EG08 Optimierung der internen Geschäftsprozessfunktionalität • EG12 Gesteuerte Programme zur digitalen Transformation		• AG08 Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG08 a. Dauer der Ausführung von Geschäftsservices oder -prozessen b. Anzahl von I&T-gestützten Geschäftsprogrammen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder zusätzliche Kosten verursachten c. Anzahl der Geschäftsprozessänderungen, die aufgrund von Problemen bei der Technologieintegration verzögert wurden oder überarbeitet werden müssen d. Anzahl von Anwendungen oder kritischen Infrastrukturen, die isoliert arbeiten und nicht integriert sind
EG05 a. Anzahl der Unterbrechungen bei Kundenservices b. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die Kundenservices den vereinbarten Standards entsprechen c. Anzahl von Kundenbeschwerden d. Trend der Umfrageergebnisse zur Kundenzufriedenheit		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		
EG12 a. Anzahl der Programme, die pünktlich und innerhalb des Budgets abgewickelt wurden b. Anteil der Anspruchsgruppen, die mit der Programmdurchführung zufrieden sind c. Anteil der Programme zur Unternehmenstransformation, die eingestellt wurden d. Anteil der Programme zur Unternehmenstransformation mit regelmäßigen Statusberichten		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
DSS06.01 Ausrichten der in die Geschäftsprozesse eingebetteten Kontrollaktivitäten an den Zielvorgaben des Unternehmens Beurteilen und überwachen Sie kontinuierlich die Ausführung der Geschäftsprozessaktivitäten und der zugehörigen Kontrollen (unter Berücksichtigung des Unternehmensrisikos), um sicherzustellen, dass die Verarbeitungskontrollen an den Geschäftserfordernissen ausgerichtet sind.		a. Anteil der Bestandsaufnahme kritischer Prozesse und wichtiger Kontrollen, der abgeschlossen wurde b. Anteil der Verarbeitungskontrollen, die auf die Geschäftsanforderungen abgestimmt wurden
Aktivitäten		Fähigkeitsstufe
1. Identifizieren und dokumentieren Sie die erforderlichen Kontrollaktivitäten für wichtige Geschäftsprozesse, um die Kontrollanforderungen für strategische und operative sowie für Berichts- und Compliance-Zielvorgaben zu erfüllen.		2
2. Priorisieren Sie die Kontrollaktivitäten basierend auf dem inhärenten Geschäftsrisiko. Identifizieren Sie wichtige Kontrollen.		
3. Stellen Sie sicher, dass es Verantwortliche für wichtige Kontrollaktivitäten gibt.		
4. Implementieren Sie automatisierte Kontrollen.		3
5. Überwachen Sie Kontrollaktivitäten kontinuierlich und umfassend, um Verbesserungspotenziale zu ermitteln.		4
6. Verbessern Sie kontinuierlich die Gestaltung und die Umsetzung von Geschäftsprozesskontrollen.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.1 Preparation (Task 10, 11)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016		CSC 14: Controlled Access Based on the Need to Know
Managementpraktik		Beispielmetrik
DSS06.02 Kontrollieren der Informationsverarbeitung Sorgen Sie dafür, dass Geschäftsprozessaktivitäten und die zugehörigen Kontrollen unter Berücksichtigung des Unternehmensrisikos ausgeführt werden. Stellen Sie sicher, dass die Informationsverarbeitung valide, vollständig, genau, zeitgerecht und sicher ist (d. h. sie spiegelt die rechtmäßige und autorisierte Geschäftsnutzung wider).		a. Anzahl der Störungen und Prüfungsberichtfeststellungen, die auf ein Versagen von wichtigen Kontrollen hinweisen b. Anteil der Abdeckung der wichtigen Kontrollen innerhalb der Testpläne
Aktivitäten		Fähigkeitsstufe
1. Authentifizieren Sie Veranlasser von Transaktionen, und prüfen Sie, ob diese Person über die Berechtigung zur Veranlassung der Transaktion verfügt.		2
2. Sehen Sie ggf. eine angemessene Funktionstrennung vor, was die Veranlassung und die Genehmigung von Transaktionen anbelangt.		

A. Komponente: Prozess (Forts.)			
3. Stellen Sie sicher, dass die Transaktionen genau, vollständig und gültig sind. Die Kontrollen können folgende Aspekte umfassen: Abfolge, Limits, Bereich, Gültigkeit, Angemessenheit, Tabellenabfragen, Existenz, Schlüsselverifizierung, Prüfziffer, Vollständigkeit, Überprüfung von Duplikaten und logischen Beziehungen sowie Bearbeitungszeit. Validierungskriterien und -parameter sollten in regelmäßigen Abständen überprüft und bestätigt werden. Validieren Sie die Eingabedaten, und bearbeiten Sie sie, oder senden Sie diese ggf. zur Korrektur zurück, wobei die Rücksendung möglichst nah an den Entstehungsort erfolgen sollte		3	
4. Korrigieren Sie falsch eingegebene Daten und reichen Sie diese erneut ein, ohne dabei die Autorisierungsstufen der ursprünglichen Transaktion zu umgehen. Bewahren Sie gegebenenfalls für die Rekonstruktion die ursprünglichen Quelldokumente für einen angemessenen Zeitraum auf.			
5. Sorgen Sie während des gesamten Verarbeitungszyklus kontinuierlich für Datenintegrität und -validität. Stellen Sie sicher, dass durch die Ermittlung fehlerhafter Transaktionen die Verarbeitung gültiger Transaktionen nicht unterbrochen wird.			
6. Beachten Sie bei der Handhabung von Output die jeweiligen Genehmigungen, liefern Sie Output an den vorgesehenen Empfänger und schützen Sie die Informationen während der Übertragung. Überprüfen Sie die Richtigkeit und Vollständigkeit des Outputs.			
7. Stellen Sie die Datenintegrität bei unerwarteten Verarbeitungsunterbrechungen sicher. Überprüfen Sie die Datenintegrität im Anschluss an Verarbeitungsfehler.			
8. Überprüfen Sie vor der Weiterleitung von Transaktionsdaten zwischen internen Anwendungen und geschäftlichen/betrieblichen Funktionen (innerhalb und außerhalb des Unternehmens) die sachgerechte Adressierung, die Authentizität des Absenders sowie die Integrität des Inhalts. Sorgen Sie für Authentizität und Integrität während der Übertragung oder während des Transports.			
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)			Detaillierte Referenzen
HITRUST CSF Version 9, September 2017			13.01 Openness and Transparency; 13.02 Individual Choice and Participation
ISF, The Standard of Good Practice for Information Security 2016		BA1.4 Information Validation	
Managementpraktik		Beispielmetrik	
DSS06.03 Verwalten von Rollen, Zuständigkeiten, Zugriffsrechten und Genehmigungsebenen Verwalten Sie die geschäftsbezogenen Rollen, Zuständigkeiten, Genehmigungsebenen und Aufgabentrennung, die für die Unterstützung der Geschäftsprozesszielvorgaben erforderlich sind. Autorisieren Sie den Zugang zu Informationsbeständen in Verbindung mit geschäftlichen Informationsprozessen, einschließlich derer, die im Rahmen des Geschäftsbetriebs, von der IT oder Dritten verwaltet werden. Dadurch wird sichergestellt, dass dem Unternehmen jederzeit bekannt ist, wo sich die Daten befinden und wer diese in seinem Namen verarbeitet.		a. Anzahl der Störungen und Prüfungsfeststellungen aufgrund von Verstößen gegen den Zugriffsrechte oder die Trennung von Aufgaben b. Anteil der Geschäftsprozessrollen mit zugewiesenen Zugriffsrechten und Genehmigungsebenen c. Anteil der Geschäftsprozessrollen mit klarer Aufgabentrennung	
Aktivitäten		Fähigkeitsstufe	
1. Ordnen Sie Rollen und Zuständigkeiten basierend auf genehmigten Stellenbeschreibungen und Geschäftsprozessaktivitäten zu.		2	
2. Ordnen Sie Genehmigungsebenen für die Freigabe von Transaktionen, Transaktionsgrenzen und sonstigen Entscheidungen in Verbindung mit dem Geschäftsprozess basierend auf genehmigten beruflichen Rollen zu.			
3. Ordnen Sie Rollen für sensible Aktivitäten so zu, dass eine klare Aufgabentrennung gegeben ist.			
4. Weisen Sie Zugriffsrechte und Berechtigungen basierend auf vordefinierten beruflichen Rollen und nur für die Bereiche zu, die für die Ausübung der beruflichen Tätigkeiten unbedingt erforderlich sind. Entziehen oder ändern Sie die Zugriffsrechte sofort, wenn sich die Rolle ändert, oder wenn der betreffende Mitarbeiter nicht mehr mit dem Geschäftsprozess betraut ist. Stellen Sie durch regelmäßige Überprüfungen sicher, dass die Zugriffsrechte dem derzeitigen Bedrohungsniveau, Risiken, Technologien und Geschäftserfordernissen Rechnung trägt.		3	
5. Bieten Sie regelmäßig Trainings zur Förderung des Bewusstseins in Bezug auf Rollen und Zuständigkeiten an, um den Mitarbeitern ihre Zuständigkeiten, die Bedeutung von Kontrollen sowie die Sicherheit, Integrität, Vertraulichkeit, und den Schutz von Unternehmensinformationen in jeglicher Form zu vermitteln.			
6. Stellen Sie sicher, dass Administrationsrechte ausreichend und wirksam gesichert, nachverfolgt und kontrolliert werden, um Missbrauch zu verhindern.			

A. Komponente: Prozess (Forts.)		
7. Überprüfen Sie regelmäßig die Definitionen für die Zugriffssteuerung sowie Protokolle und Ausnahmeberichte Stellen Sie sicher, dass alle Zugangsberechtigungen gültig und an den derzeitigen Mitarbeitern und den ihnen zugeordneten Rollen ausgerichtet sind.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
HITRUST CSF Version 9, September 2017		13.04 Collection, Use and Disclosure
ISO/IEC 27002:2013/Cor.2:2015(E)		7. Human resource security
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016		CSC 5: Controlled Use of Administrative Privileges
Managementpraktik		Beispielmetrik
DSS06.04 Managen von Fehlern und Ausnahmen Managen Sie Fehler und Ausnahmen in Verbindung mit Geschäftsprozessen und erleichtern Sie deren Behebung, indem Sie definierte Korrekturmaßnahmen durchführen und bei Bedarf eskalieren. Diese Behandlung von Ausnahmen und Fehlern bietet Gewähr für die Richtigkeit und Integrität des geschäftlichen Informationsprozesses.		a. Häufigkeit von Ineffizienzen bei der Verarbeitung aufgrund unvollständiger Dateneingabe b. Anzahl der rechtzeitig entdeckten Fehler c. Anzahl der Datenverarbeitungsfehler, die effizient behoben wurden
Aktivitäten		Fähigkeitsstufe
1. Überprüfen Sie Fehler, Ausnahmen und Abweichungen.		2
2. Verfolgen, korrigieren, genehmigen und reichen Sie Urbelege und Transaktionen erneut ein.		
3. Weisen Sie die Durchführung von Abhilfemaßnahmen nach.		
4. Definieren und pflegen Sie Verfahren zur Zuweisung von Verantwortlichkeiten für Fehler und Ausnahmen, zur Korrektur von Fehlern, zur Übersteuerung von Fehlern und zur Handhabung von aus dem Gleichgewicht geratenen Zuständen.		3
5. Erfassen Sie relevante Fehler in Verbindung mit dem geschäftlichen Informationsprozess zeitnah in einem Bericht, und führen Sie eine Ursachen- und Trendanalyse durch.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
DSS06.05 Sicherstellen der Nachvollziehbarkeit und Verantwortlichkeiten von Informationsereignissen Stellen Sie sicher, dass Geschäftsinformationen bis zum ursprünglichen Geschäftsereignis und zu den verantwortlichen Parteien zurückverfolgt werden können. Diese Nachvollziehbarkeit bietet die Gewissheit, dass Geschäftsinformationen zuverlässig sind und in Übereinstimmung mit den definierten Zielvorgaben verarbeitet wurden.		a. Anzahl der Störungen, bei denen die Transaktionshistorie nicht wiederhergestellt werden kann b. Grad der Vollständigkeit von nachvollziehbaren Transaktionsprotokollen
Aktivitäten		Fähigkeitsstufe
1. Erfassen Sie Urbelege, ergänzende Nachweise und Transaktionsaufzeichnungen.		2
2. Definieren Sie unter Berücksichtigung der Geschäftsanforderungen Aufbewahrungsanforderungen, die geeignet sind, operative Erfordernisse sowie Vorschriften in Bezug auf Finanzberichterstattung und Compliance zu erfüllen.		3
3. Entsorgen Sie Urbelege, ergänzende Nachweise und Transaktionsaufzeichnungen nach Maßgabe der Aufbewahrungsrichtlinie.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmetrik
DSS06.06 Sichern von Informationsbeständen Schützen Sie die im Geschäftsbetrieb zugänglichen Informationsbestände anhand von bewährten Methoden. Dies betrifft sowohl Informationen in elektronischer Form (z. B. mobile Endgeräte, Benutzeranwendungen und Speichermedien oder andere Methoden, die neue Möglichkeiten in beliebiger Form schaffen), als auch Informationen in physischer Form (wie z. B. Quellbelege oder Ausgabeberichte) sowie Informationen während der Übertragung. Der Vorteil für das Unternehmen besteht in der Bereitstellung eines durchgängigen Schutzes von Informationen.	a. Fälle von sensiblen Transaktionsdaten, die in falsche Hände gelangt sind b. Häufigkeit der kompromittierten Integrität kritischer Daten
Aktivitäten	Fähigkeitsstufe
1. Schränken Sie die Verwendung und Verteilung von Informationen sowie den physischen Zugang zu Informationen je nach Klassifizierung der Informationen ein.	2
2. Fördern Sie das Bewusstsein für die Nutzung und bieten Sie entsprechende Schulungen an.	
3. Wenden Sie Datenklassifizierungs- sowie akzeptable Nutzungs- und Sicherheitsrichtlinien und -verfahren an, um die Informationsbestände, die sich im Kontrollbereich des Unternehmens befinden, zu schützen.	3
4. Identifizieren und implementieren Sie Prozesse, Tools und Techniken, die geeignet sind, die Compliance angemessen zu überprüfen.	
5. Melden Sie den Unternehmensvertretern und sonstigen Anspruchsgruppen Verstöße und Abweichungen.	4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018	AC.MP Manage Access Permissions
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 18: Application Software Security

B. Komponente: Organisationsstrukturen									
	Exekutivkomitee	Chief Information Officer	I&T Governance Board	Chief Information Security Officer	Geschäftsprozessverantwortlicher	Datenmanagement	Service Manager	Information Security Manager	Rechtsbeistand
Wichtige Managementpraktik:									
DSS06.01 Ausrichten der in die Geschäftsprozesse eingebetteten Kontrollaktivitäten an den Zielvorgaben des Unternehmens	R		A		R				
DSS06.02 Kontrollieren der Informationsverarbeitung		R	A	R	R	R			R
DSS06.03 Verwalten von Rollen, Zuständigkeiten, Zugriffsrechten und Genehmigungsebenen		R	A	R	R			R	
DSS06.04 Managen von Fehlern und Ausnahmen		R		R	A		R		
DSS06.05 Sicherstellen der Nachvollziehbarkeit und Verantwortlichkeiten von Informationsereignissen		R		R	A				
DSS06.06 Sichern von Informationsbeständen		R		R	A				
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen								
Keine entsprechenden weiteren Quellen für diese Komponente									

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
DSS06.01 Ausrichten der in die Geschäftsprozesse eingebetteten Kontrollaktivitäten an den Zielvorgaben des Unternehmens	Von	Beschreibung	Beschreibung	Für
	APO01.07	• Richtlinien zur Datenklassifizierung • Verfahren zur Datenintegrität	Ursachenanalysen und Empfehlungen	BAI06.01, MEA02.04, MEA04.04, MEA04.06, MEA04.07
			Ergebnisse der Überprüfungen der Verarbeitungseffektivität	MEA02.04
DSS06.02 Kontrollieren der Informationsverarbeitung	BAI05.05	Betriebs- und Nutzungsplan	Verarbeitungskontrollberichte	Intern
	BAI07.02	Migrationsplan		
DSS06.03 Verwalten von Rollen, Zuständigkeiten, Zugriffsrechten und Genehmigungsebenen	APO11.01	Rollen, Verantwortlichkeiten und Entscheidungsbefugnisse im Qualitätsmanagementsystem (QMS)	Zugewiesene Kompetenzstufen	APO01.05
	APO13.01	• Informationssicherheits-Managementsystem • Erklärung zum ISMS-Umfang	Zugewiesene Rollen und Zuständigkeiten	APO01.05
	DSS05.05	Zugriffsprotokolle	Zugewiesene Zugriffsrechte	APO07.04
	EDM04.02	Zugewiesene Zuständigkeiten für das Ressourcenmanagement		
Managementpraktik	Inputs		Outputs	
DSS06.04 Managen von Fehlern und Ausnahmen	Von	Beschreibung	Beschreibung	Für
			Fehlerberichte und Ursachenanalyse	Intern
			Nachweis der Fehlerkorrektur und -behebung	MEA02.04
DSS06.05 Sicherstellen der Nachvollziehbarkeit und Verantwortlichkeiten von Informationsereignissen			Aufzeichnung von Transaktionen	Intern
			Anforderungen an die Aufbewahrung	Intern APO14.09
DSS06.06 Sichern von Informationsbeständen			Berichte über Verstöße	DSS05.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.1 Preparation (Task 10, 11): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Informationssicherheit	Skills Framework for the Information Age V6, 2015	SCTY
Sicherheitsverwaltung	Skills Framework for the Information Age V6, 2015	SCAD

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Anleitung zu Unternehmenskontrollen	Definiert Geschäftsprozesskontrollen, um die angemessene Kontrolle zu gewährleisten und das Risiko von Betrug und Fehlern zu reduzieren. Zeigt manuelle Kontrollen zum Schutz von Dokumenten (z. B. Quell-, Eingabe-, Verarbeitungs- und Ausgabedokumente) auf und benennt Überwachungskontrollen, um den Dokumentenfluss zu überprüfen und eine korrekte Verarbeitung sicherzustellen. Umfasst allgemeine I&T-Kontrollen (z. B. physische Sicherheit, Zugriff und Authentifizierung sowie Änderungsmanagement) und Anwendungskontrollen (z. B. Bearbeitungsprüfung, Systemkonfigurations- und Sicherheitseinstellungen).		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Unternehmenskultur, die den Bedarf für solide Kontrollen im Rahmen der Geschäftsprozesse als wichtig erachtet und diese für Anwendungen vorsieht, die sich in der Entwicklung befinden, oder sie für Anwendungen einfordert, die angeschafft oder als Service in Anspruch genommen werden. Ermutigen Sie alle Mitarbeiter zu einem Kontrollbewusstsein, um sicherzustellen, dass alle Betriebsmittel der Organisation (z. B. Papierunterlagen und Einrichtungen) geschützt sind.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Automatisierte Anwendungskontrollen • Werkzeuge zur Überprüfung von Ereignisprotokollen

Diese Seite wurde absichtlich freigelassen.

4.5 ÜBERWACHEN, EVALUIEREN UND BEURTEILEN

- 01 Überwachung von Leistung und Konformität wird gemanagt
- 02 Internes Kontrollsystem wird gemanagt
- 03 Compliance mit externen Anforderungen wird gemanagt
- 04 Assurance wird gemanagt

Diese Seite wurde absichtlich freigelassen.

Domäne: Überwachen, Evaluieren und Beurteilen		Schwerpunktbereich: COBIT-Kernmodell
Managementziel: MEA01 – Überwachung von Leistung und Konformität wird gemanagt		
Beschreibung		
Erfassung, Validierung und Evaluierung von geschäftlichen Zielen, IT-bezogenen Zielen und Metriken. Überwachung, inwieweit Prozesse und Praktiken in Einklang mit den vereinbarten Leistungs- und Konformitätszielen und -metriken durchgeführt werden. Bereitstellung einer systematischen und zeitnahen Berichterstattung.		
Zweck		
Gewährleistung von Transparenz in Bezug auf Leistung und Konformität sowie Förderung der Zielerreichung.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG01 Portfolio wettbewerbsfähiger Produkte und Dienstleistungen • EG04 Qualität von Finanzinformationen • EG07 Qualität der Managementinformationen • EG08 Optimierung der internen Geschäftsprozessfunktionalität		• AG05 Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen • AG10 Qualität der I&T-Managementinformationen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG01 a. Anteil der Produkte und Dienstleistungen, die die Ziele bezüglich Umsatz und/oder Marktanteil erreicht oder übertroffen haben b. Anteil der Produkte und Dienstleistungen, die die Kundenzufriedenheitsziele erreicht oder übertroffen haben c. Anteil der Produkte und Dienstleistungen, die Wettbewerbsvorteile bieten d. Markteinführungszeit für neue Produkte und Dienstleistungen		AG05 a. Anteil der geschäftlichen Anspruchsgruppen, die zufrieden damit sind, dass die I&T-Servicebereitstellung den vereinbarten Service Levels entspricht b. Anzahl von Geschäftsunterbrechungen aufgrund von I&T-Service-Störungen c. Anteil der Nutzer, die mit der Qualität der I&T-Servicebereitstellung zufrieden sind
EG04 a. Abfrage der Zufriedenheit bei den wichtigsten Anspruchsgruppen bezüglich der Transparenz, des Verständnisses und der Genauigkeit der Finanzinformationen des Unternehmens b. Kosten der Nichteinhaltung finanzbezogener Vorschriften		AG10 a. Grad der Zufriedenheit der Nutzer mit der Qualität, Pünktlichkeit und Verfügbarkeit von I&T-bezogenen Managementinformationen unter Berücksichtigung der verfügbaren Ressourcen b. Verhältnis und Ausmaß von falschen Geschäftsentscheidungen, bei denen fehlerhafte oder nicht verfügbare I&T-bezogene Informationen ein wesentlicher Faktor waren c. Anteil der Informationen, die die Qualitätskriterien erfüllt haben
EG07 a. Grad der Zufriedenheit der Geschäftsleitung und obersten Führungskräfte mit den Informationen zur Entscheidungsfindung b. Anzahl der Störungen, die durch falsche Geschäftsentscheidungen auf der Grundlage fehlerhafter Informationen verursacht wurden c. Zeitbedarf zur Bereitstellung von Informationen zur Unterstützung effektiver Geschäftsentscheidungen d. Aktualität der Managementinformationen		
EG08 a. Zufriedenheitsgrad der Geschäftsleitung und obersten Führungskräfte mit den Geschäftsprozessfähigkeiten b. Zufriedenheitsgrad der Kunden mit der Servicebereitstellung c. Zufriedenheitsgrad der Lieferanten mit der Leistungsfähigkeit der Lieferkette		

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
MEA01.01 Einrichten eines Überwachungsansatzes Erarbeiten und pflegen Sie gemeinsam mit den Anspruchsgruppen einen Überwachungsansatz, in dem die Zielvorgaben, der Umfang und die Methode für die Messung der Bereitstellung von Geschäftslösungen und Services sowie der Beitrag zu den Unternehmenszielvorgaben definiert sind. Integrieren Sie diesen Ansatz in das unternehmensweite Leistungssteuerungssystem.		a. Anteil der Prozesse mit definierten Zielen und Metriken b. Grad der Integration des Überwachungsansatzes in das Leistungssteuerungssystem des Unternehmens
Aktivitäten		Fähigkeitsstufe
1. Identifizieren Sie die Anspruchsgruppen (z. B. Management, Prozessverantwortliche und Benutzer).		2
2. Beziehen Sie die Anspruchsgruppen ein und kommunizieren Sie die Anforderungen und Zielvorgaben des Unternehmens für die Überwachung, Konsolidierung und Berichterstattung und verwenden Sie dabei allgemeine Definitionen (z. B. Geschäftsglossar, Metadaten und Taxonomie), Referenzwerte und Benchmarks.		
3. Richten Sie den Überwachungs- und Evaluierungsansatz am Unternehmensansatz sowie an den zu verwendenden Tools für die Datenerfassung und die Unternehmensberichterstattung aus (z. B. Business-Intelligence-Anwendungen) und pflegen Sie ihn kontinuierlich.		
4. Einigen Sie sich auf die Arten von Zielen und Metriken (z. B. Konformität, Leistung, Wert, Risiko), die Taxonomie (Klassifizierung und Beziehung zwischen den Zielen und Metriken) und die Datenspeicherung (Aufbewahrung von Nachweisen).		
5. Fordern Sie Ressourcen für die Überwachung an und priorisieren Sie diese und weisen Sie sie unter Berücksichtigung von Angemessenheit, Effizienz, Effektivität und Vertraulichkeit zu.		
6. Validieren Sie den verwendeten Ansatz regelmäßig und identifizieren Sie neue oder geänderte Anspruchsgruppen, Anforderungen und Ressourcen.		3
7. Vereinbaren Sie einen Lebenszyklusmanagement- sowie einen Änderungskontrollprozess für die Überwachung und Berichterstellung. Berücksichtigen Sie Verbesserungspotentiale für Berichterstellung, Metriken, Ansatz, Referenzwert- und Benchmark-Erstellung.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Supporting Processes – Measurement and Analysis
SF, The Standard of Good Practice for Information Security 2016		SI2 Security Performance
ISO/IEC 27001:2013/Cor.2:2015(E)		9.1 Monitoring, measurement, analysis and evaluation
ISO/IEC 27004:2016(E)		6. Characteristics; 7. Types of measures; 8. Prozesse
ISO/IEC 38500:2015(E)		5.5 Principle 4: Performance; 5.6 Principle 5: Conformance
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.1 Preparation (Task 13); 3.3 Selection (Task 2); 3.7 Monitoring (Task 1)
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.4 Assessment, authorization and monitoring (CA-2, CA-7); 3.20 System and information integrity (SI-4)
Managementpraktik		Beispielmetrik
MEA01.02 Festlegen von Leistungs- und Konformitätszielen Definieren, überprüfen Sie regelmäßig, aktualisieren und genehmigen Sie gemeinsam mit den Anspruchsgruppen Leistungs- und Konformitätsziele im Rahmen des Leistungserfassungssystems.		a. Anteil der Ziele und Metriken, die von den Anspruchsgruppen genehmigt wurden b. Anteil der Prozesse, bei denen die Effektivität der Ziele und Metriken überprüft und verbessert wurden
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie die Ziele und Metriken. Überprüfen Sie diese regelmäßig zusammen mit den Anspruchsgruppen, um alle wichtigen fehlenden Aspekte zu ermitteln und die Angemessenheit der Ziele und Toleranzen zu definieren.		2
2. Bewerten Sie, ob die Ziele und Metriken adäquat, d.h. spezifisch, messbar, erreichbar, relevant und zeitgebunden (SMART) sind.		
3. Kommunizieren Sie vorgeschlagene Änderungen der Leistungs- und Konformitätsziele und -toleranzen (in Bezug auf Metriken) an wichtige Anspruchsgruppen für die Sorgfaltspflicht (z. B. Recht, Audit, HR, Ethik, Compliance, Finanzen).		
4. Informieren Sie die Anwender dieser Informationen über geänderte Ziele und Toleranzen.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Supporting Processes – Process Management
National Institute of Standards and Technology Special Publication 800-53, Revision V5 (Entwurf), August 2017		3.4 Assessment, authorization and monitoring (CA-5)
Managementpraktik		Beispielmetrik
MEA01.03 Erfassen und Verarbeiten von Leistungs- und Konformitätsdaten Erfassen und verarbeiten Sie aktuelle und genaue Daten im Einklang mit den Unternehmensansätzen.		a. Anteil der überwachten kritischen Prozesse b. Teil der Kontrollumgebung, der überwacht, bewertet und verbessert wird, um die Unternehmenszielvorgaben zu erreichen
Aktivitäten		Fähigkeitsstufe
1. Erfassen Sie (möglichst automatisiert) Daten von definierten Prozessen.		2
2. Bewerten Sie die Effizienz (Aufwand im Verhältnis zum Erkenntnisgewinn) und Angemessenheit (Nutzen und Bedeutung) und validieren Sie die Integrität (Richtigkeit und Vollständigkeit) der gesammelten Daten.		
3. Fassen Sie die Daten zusammen, um die Erstellung vereinbarter Metriken zu unterstützen.		
4. Bringen Sie die aggregierten Daten in Einklang mit dem Berichterstellungsansatz und den Zielvorgaben des Unternehmens.		3
5. Verwenden Sie geeignete Werkzeuge und Systeme für die Verarbeitung und Analyse von Daten.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.20 System and information integrity (SI-2)
Managementpraktik		Beispielmetrik
MEA01.04 Analysieren und Berichten der Leistung Überprüfen Sie die Leistung regelmäßig auf Erfüllung der Sollwerte und geben Sie einen Bericht dazu ab. Verwenden Sie dazu eine Methode, die einen knappen, aber umfassenden Überblick der I&T-Leistung bietet, und die sich in das Überwachungssystem des Unternehmens integrieren lässt.		a. Anteil der Ziele und Metriken, die auf das Unternehmensüberwachungssystem abgestimmt wurden b. Anteil der Leistungsberichte, die wie geplant geliefert wurden c. Anteil der Prozesse mit gesichertem Output, die die Zielvorgaben innerhalb der Toleranzen erfüllen
Aktivitäten		Fähigkeitsstufe
1. Gestalten Sie Prozessleistungsberichte, die knapp, gut verständlich und individuell an die verschiedenen Managementanforderungen und Zielgruppen angepasst sind. Fördern Sie eine effektive und zeitgerechte Entscheidungsfindung (z. B. durch Scorecards und Ampelberichte). Stellen Sie sicher, dass Ursache und Wirkung in Bezug auf Ziele und Metriken in einer verständlichen Art und Weise kommuniziert werden.		3
2. Verteilen Sie die Berichte an die relevanten Anspruchsgruppen.		
3. Analysieren Sie die Ursachen von Sollwertabweichungen, leiten Sie Abhilfemaßnahmen ein, weisen Sie entsprechende Zuständigkeiten zu, und überprüfen Sie deren Erfolg. Überprüfen Sie zu geeigneten Zeitpunkten sämtliche Abweichungen, und ermitteln Sie ggf. deren Ursachen. Dokumentieren Sie die Störungen, um bei neuerlichem Auftreten des Problems Hilfestellung bieten zu können. Dokumentieren Sie die Ergebnisse.		4
4. Integrieren Sie, wo möglich, Leistung und Einhaltung der Vorgaben (Compliance) in die Leistungsziele der einzelnen Mitarbeiter und verknüpfen die Erreichung der Leistungsziele mit dem Vergütungssystem der Organisation.		
5. Vergleichen Sie die Leistungswerte mit internen Zielen und Benchmarks und möglichst auch mit externen Benchmarks (der Industrie und wichtiger Wettbewerber).		
6. Analysieren Sie Trends, die sich im Hinblick auf Leistung und Compliance abzeichnen und ergreifen Sie geeignete Maßnahmen.		
7. Empfehlen Sie ggf. Änderungen für einzelne Ziele und Metriken.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Supporting Processes – Measurement and Analysis
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017		3.3 Audit and accountability (AU-6)

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmesskriterien
MEA01.05 Sicherstellen der Implementierung korrekativer Maßnahmen Unterstützen Sie Anspruchsgruppen bei der Identifizierung, Einleitung und Nachverfolgung korrekativer Maßnahmen zur Behebung von Unregelmäßigkeiten.	a. Anzahl der wiederkehrenden Unregelmäßigkeiten b. Anzahl der implementierten korrekativen Maßnahmen
Aktivitäten	Fähigkeitsstufe
1. Überprüfen Sie Reaktionen, Optionen und Empfehlungen des Managements zur Behebung von Problemen und gravierenden Abweichungen.	2
2. Stellen Sie sicher, dass die Zuständigkeit für die korrektive Maßnahme jederzeit sichergestellt ist.	
3. Verfolgen Sie die Ergebnisse der eingeleiteten Maßnahmen.	
4. Melden Sie den Anspruchsgruppen die Ergebnisse.	
Zugehörige Leitlinien (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
ITIL V3, 2011	Continual Service Improvement, 4.1 The 7-Step Improvement Process
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018	3.7 Monitoring (Task 3):
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.3 Audit and accountability (AU-5)

B. Komponente: Organisationsstrukturen											

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
MEA01.01 Einrichten eines Überwachungsansatzes	Von	Beschreibung	Beschreibung	Für
	EDM05.01	- Bewertung der Anforderungen an die Unternehmensberichterstattung - Grundsätze der Berichterstattung und Kommunikation	Genehmigte Überwachungsziele und Metriken	Intern
	EDM05.02	Regeln für die Validierung und Genehmigung von Pflichtberichten	Anforderungen an die Überwachung	Intern
	EDM05.03	Bewertung der Effektivität der Berichterstattung		
MEA01.02 Festlegen von Leistungs- und Konformitätszielen	APO01.11	Leistungsziele und Metriken zur Nachverfolgung von Prozessverbesserungen	Überwachungsziele	Alle APO, BAI, DSS, MEA
Managementpraktik	Inputs		Outputs	
MEA01.03 Erfassen und Verarbeiten von Leistungs- und Konformitätsdaten	Von	Beschreibung	Beschreibung	Für
	APO01.11	Bewertungen der Prozessfähigkeit	Verarbeitete Überwachungsdaten	Intern
	APO05.03	Investitionsportfolio-Leistungsberichte		
	APO09.04	Service-Level-Leistungsberichte		
	AP010.05	Ergebnisse der Überprüfung der Compliance der Lieferanten		
	BAI01.06	Ergebnisse der Programmleistungsbeurteilungen		
	BAI04.04	Verfügbarkeits-, Leistungs- und Kapazitätsüberwachungsberichte		
	BAI05.05	Erfolgskennzahlen und Ergebnisse		
	DSS01.05	Berichte zur Beurteilung von Einrichtungen		
	DSS02.07	- Bericht über Störungstatus und Trends - Bericht über den Status der Erfüllung von Anforderungen und Trends		
MEA01.04 Analysieren und Berichten der Leistung			Leistungsberichte	Alle APO, BAI, DSS, MEA, EDM01.03

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
MEA01.05 Sicherstellen der Implementierung korrektiver Maßnahmen	APO01.09	Abhilfemaßnahmen bei Nichteinhaltung (Non-Compliance)	Korrektive Maßnahmen und Zuweisungen	Alle APO, BAI, DSS, MEA
	EDM05.02	Richtlinien zur Eskalation	Status und Ergebnisse von Aktivitäten	EDM01.03
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.1 Preparation (Task 13): Inputs and Outputs; 3.3 Selection (Task 2): Inputs and Outputs; 3.7 Monitoring (Task 1, Task 3): Inputs and Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Überprüfung der Konformität	Skills Framework for the Information Age V6, 2015	CORE
ICT-Qualitätsmanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.6. ICT Quality Management
Qualitätssicherung	Skills Framework for the Information Age V6, 2015	QUAS

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zu Selbsteinschätzungen	Bietet Informationen zu den Verantwortlichkeiten des Managements bei der Beurteilung des Betriebs als Teil des Programms zur kontinuierlichen Verbesserung. Wird häufig verwendet, um Führungskräften oder der Geschäftsleitung intern über aktuelle Fähigkeiten, Fortschritte und Verbesserungen in Bezug auf Geschäftsanforderungen zu berichten. Beurteilungen können während oder nach einem Prozessverbesserungsprogramm vorgenommen werden (d. h. zur Bewertung des Fortschritts nach Abschluss einer Verbesserung).		
Whistleblowing-Richtlinie	Ermutigt die Mitarbeiter dazu, Bedenken und Fragen vertrauensvoll vorzubringen. Stellt sicher, dass die Mitarbeiter eine Rückmeldung erhalten und in der Lage sind, Bedenken zu eskalieren, wenn sie mit der Rückmeldung nicht zufrieden sind. Gewährleistet, dass die Mitarbeiter geschützt sind, wenn sie Probleme ansprechen, und dass sie keine Repressalien befürchten müssen.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Fördern Sie eine Kultur der kontinuierlichen Verbesserung der Geschäfts- und I&T-Prozesse, um die Ziele der Organisation zu erreichen und die Leistung zu optimieren		

G. Komponente: Services, Infrastruktur und Anwendungen		
• System zur Leistungsmessung (z. B. Balanced Scorecard, Werkzeuge zum Management der Fähigkeiten) • Werkzeuge zur Selbsteinschätzung		

Diese Seite wurde absichtlich freigelassen.

Domäne: Überwachen, Evaluieren und Beurteilen Managementziel: MEA02 – Internes Kontrollsystem wird gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Kontinuierliche Überwachung und Evaluierung des Kontrollumfeldes, u. a. durch Selbsteinschätzungen und Eigenwahrnehmung. Befähigung des Managements, Kontrollschwächen und Ineffizienzen zu identifizieren und Verbesserungsmaßnahmen einzuleiten. Planung, Organisation und Pflege von Standards für die Beurteilung interner Kontrollen und zur Steigerung der Effektivität von Prozesskontrollen.		
Zweck		
Sicherstellung von Transparenz für wichtige Anspruchsgruppen in Bezug auf die Angemessenheit des internen Kontrollsystems und somit die Schaffung von Vertrauen in Abläufe, von Zuversicht hinsichtlich der Erreichung der Unternehmenszielvorgaben sowie Förderung eines adäquaten Verständnisses des Restrisikos.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG03 Compliance mit externen Gesetzen und Bestimmungen • EG11 Compliance mit internen Richtlinien		• AG11 I&T-Compliance mit internen Richtlinien
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG03 a. Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern b. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursachten c. Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Compliance-Verstößen d. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern		AG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von I&T-bezogenen Richtlinien. b. Anzahl der Ausnahmen hinsichtlich interner Richtlinien c. Häufigkeit der Überprüfung und Aktualisierung der Richtlinien
EG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von Richtlinien b. Anteil der Anspruchsgruppen, die die Richtlinien verstehen c. Anteil der Richtlinien, die durch effektive Standards und Arbeitspraktiken unterstützt werden		

A. Komponente: Prozess	
Managementpraktik	Beispielmetrik
MEA02.01 Überwachen interner Kontrollen Sorgen Sie für eine regelmäßige Überwachung, Benchmark-Erstellung und Verbesserung der I&T-Kontrollumgebung und des I&T-Kontrollrahmenwerks, um die Erreichung der Zielvorgaben der Organisation sicherzustellen.	a. Anzahl von schwerwiegenden internen Kontrollverstößen b. Teil der Kontrollumgebung und des Kontrollrahmens, der kontinuierlich überwacht, bewertet und verbessert wird, um die Unternehmensziele zu erreichen.

A. Komponente: Prozess (Forts.)	
Aktivitäten	Fähigkeitsstufe
1. Identifizieren Sie die Grenzen des internen Kontrollsystems. Ermitteln Sie beispielsweise, inwieweit interne Kontrollen der Organisation ausgelagerte und/oder Offshore-Entwicklungs- oder Produktionsaktivitäten berücksichtigen.	3
2. Beurteilen Sie den Status der internen Kontrollen externer Serviceanbieter. Stellen Sie sicher, dass die Serviceanbieter den gesetzlichen, behördlichen und vertraglichen Anforderungen und Pflichten nachkommen.	
3. Führen Sie Aktivitäten zur Überwachung und Bewertung interner Kontrollen durch, die auf Governance-Standards der Organisation sowie auf Rahmenwerken und Praktiken basieren, die innerhalb der Branche akzeptiert sind Überwachen und bewerten Sie auch die Effizienz und Effektivität der Aufsichtstätigkeit des Managements.	
4. Stellen Sie sicher, dass Kontrollausnahmen unmittelbar gemeldet, nachverfolgt und analysiert werden. Sorgen Sie dafür, dass Prioritäten für geeignete korrektive Maßnahmen festgelegt und die Maßnahmen in Einklang mit dem Risikomanagement-Profil implementiert werden (unterscheiden Sie bei der Klassifizierung von Ausnahmen beispielsweise zwischen wesentlichen Risiken und unwesentlichen Risiken).	
5. Ziehen Sie unabhängige Bewertungen des internen Kontrollsystems in Erwägung (z. B. durch interne Audits oder Fachkollegen).	
6. Pflegen Sie das interne Kontrollsystem und berücksichtigen Sie dabei fortwährende Änderungen in Bezug auf das geschäftliche und das I&T-Risiko, die Kontrollumgebung der Organisation und relevante Geschäfts- und I&T-Prozesse. Nehmen Sie bei etwaigen Lücken eine Bewertung vor und empfehlen Sie Änderungen.	4
7. Bewerten Sie regelmäßig die Leistung des Kontrollrahmenwerks, indem Sie einen Benchmark-Vergleich mit innerhalb der Branche akzeptierten Standards und bewährten Verfahren durchführen. Ziehen Sie die formelle Übernahme eines Ansatzes für die kontinuierliche Verbesserung der Überwachung interner Kontrollen in Erwägung.	5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
HITRUST CSF Version 9, September 2017	09.10 Monitoring
ISO/IEC 38502:2017(E)	5.5 Governance and internal control
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Entwurf), August 2017	3.3 Audit and accountability (AU-2)
Managementpraktik	Beispielmetrik
MEA02.02 Überprüfen der Effektivität von Geschäftsprozesskontrollen Überprüfen Sie die Kontrollen, u. a. anhand einer Überprüfung der Überwachungs- und Testnachweise, um sicherzustellen, dass die Kontrollen innerhalb eines Geschäftsprozesses effektiv funktionieren. Führen Sie außerdem Aktivitäten durch, um die effektive Funktion der Kontrollen durch geeignete Mechanismen dauerhaft zu belegen. Dazu zählen beispielsweise das regelmäßige Testen, die kontinuierliche Überwachung, unabhängige Beurteilungen, Steuer- und Kontrollzentren sowie Netzwerkbetriebszentren. Diese Nachweise liefern dem Unternehmen die Bestätigung, dass die Kontrollen die Anforderungen im Zusammenhang mit geschäftlichen, behördlichen und sozialen Verantwortlichkeiten erfüllen.	a. Anzahl der anhand von externen Qualifizierungs- und Zertifizierungsberichten festgestellten Schwachstellen b. Anzahl der Kontrollen, die überwacht und getestet werden, um sicherzustellen, dass die Kontrollen innerhalb von Geschäftsprozessen effektiv funktionieren
Aktivitäten	Fähigkeitsstufe
1. Ermitteln Sie das Risiko in Bezug auf Zielvorgaben der Organisation, und legen Sie Prioritäten fest.	3
2. Identifizieren Sie wichtige Kontrollen und entwickeln Sie eine geeignete Strategie für die Validierung von Kontrollen.	
3. Identifizieren Sie Informationen, die Hinweise darauf geben, inwieweit die interne Kontrollumgebung effektiv funktioniert.	
4. Weisen Sie die Effektivität der Kontrollen kontinuierlich nach.	4
5. Entwickeln und implementieren Sie kosteneffektive Verfahren zur Gewinnung dieser Informationen in Übereinstimmung mit den geltenden Kriterien für die Informationsqualität.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
MEA02.03 Durchführen von Selbsteinschätzungen zu Kontrollen Motivieren Sie Management und Prozessverantwortliche, die Kontrollen proaktiv zu verbessern und zwar durch ein kontinuierliches Programm zur Selbsteinschätzung, das die Vollständigkeit und Wirksamkeit der Kontrolle des Managements hinsichtlich Prozessen, Richtlinien und Verträgen bewertet.		a. Anzahl der durchgeführten Selbsteinschätzungen b. Anzahl der identifizierten Lücken in Selbsteinschätzungen im Vergleich zu Branchenstandards oder bewährten Verfahren
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie einen abgestimmten, konsistenten Ansatz für die Durchführung von Selbsteinschätzungen zu Kontrollen und die Koordination mit interner Revision und externen Prüfern.		3
2. Pflegen Sie Pläne für die Durchführung von Selbsteinschätzungen, legen Sie deren Umfang fest, und identifizieren Sie geeignete Bewertungskriterien. Planen Sie die Kommunikation der Ergebnisse des Selbsteinschätzungsprozesses an Geschäftsbereiche, IT, Management und Geschäftsleitung. Berücksichtigen Sie bei der Konzeption der Selbsteinschätzungen Standards für die interne Revision.		
3. Legen Sie die Häufigkeit regelmäßiger Selbsteinschätzungen fest und berücksichtigen Sie dabei die allgemeine Effektivität und Effizienz der kontinuierlichen Überwachung.		
4. Weisen Sie die Zuständigkeit für Selbsteinschätzungen Mitarbeitern zu, die über die notwendige Objektivität und Kompetenz verfügen.		
5. Achten Sie darauf, dass die Prüfungen unabhängig durchgeführt werden, um die Objektivität der Selbsteinschätzungen sicherzustellen und ermöglichen Sie einen Informationsaustausch zu bewährten Verfahren für interne Kontrollen mit anderen Unternehmen.		
6. Vergleichen Sie die Ergebnisse der Selbsteinschätzungen mit Branchenstandards und bewährten Verfahren.		4
7. Fassen Sie die Ergebnisse der Selbsteinschätzungen und Benchmarks in einem Bericht zusammen, um ggf. Abhilfemaßnahmen einzuleiten.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISO/IEC 27001:2013/Cor.2:2015(E)		9.3 Management review
National Institute of Standards and Technology Special Publication 800-37, Revision 2 (Entwurf), Mai 2018		3.7 Monitoring (Task 2):
Managementpraktik		Beispielmetrik
MEA02.04 Identifizieren und Melden von Kontrollschwächen Identifizieren Sie Kontrollschwächen und analysieren und identifizieren Sie deren Ursachen. Eskalieren Sie Kontrollschwächen und melden Sie diese den Anspruchsgruppen.		a. Zeit zwischen dem Auftreten interner Kontrollschwächen und Berichterstattung b. Zeit zwischen der Identifizierung von Ausnahmen und der Umsetzung von vereinbarten Maßnahmen c. Anteil der umgesetzten Abhilfemaßnahmen, die aus der Beurteilung von Kontrollen resultieren
Aktivitäten		Fähigkeitsstufe
1. Kommunizieren Sie Verfahren für die Eskalation von Kontrollausnahmen, die Durchführung von Ursachenanalysen und die Berichterstattung an Prozessverantwortliche und I&T-Anspruchsgruppen.		3
2. Legen Sie unter Berücksichtigung des damit verbundenen Unternehmensrisikos Schwellenwerte für die Eskalation von Kontrollausnahmen und Unterbrechungen fest.		
3. Identifizieren, melden und protokollieren Sie Kontrollausnahmen. Weisen Sie die Zuständigkeit für deren Lösung und die Berichterstattung über den Status zu.		
4. Entscheiden Sie, welche Kontrollausnahmen an den für die Funktion zuständigen Mitarbeiter kommuniziert und welche Ausnahmen eskaliert werden sollen. Informieren Sie betroffene Prozessverantwortliche und Anspruchsgruppen.		
5. Verfolgen Sie sämtliche Ausnahmen, um sicherzustellen, dass vereinbarte Maßnahmen umgesetzt wurden.		4
6. Identifizieren, initiieren, verfolgen und implementieren Sie Abhilfemaßnahmen, die sich aus der Beurteilung von Kontrollen und aus Berichten ergeben.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

B. Komponente: Organisationsstrukturen

		Chief Financial Officer	Chief Risk Officer	Chief Information Officer	Chief Technology Officer	I&T Governance Board	Geschäftsprozessverantwortlicher	Project Management Office	Leiter Entwicklung	Leiter IT-Betrieb	Leiter IT-Administration	Service Manager	Information Security Manager	Business Continuity Manager	Datenschutzbeauftragter
Wichtige Managementpraktik:															
MEA02.01 Überwachen interner Kontrollen		R	A	R		R	R	R	R	R	R	R	R	R	R
MEA02.02 Überprüfen der Effektivität von Geschäftsprozesskontrollen		R		A	R	R									
MEA02.03 Durchführen von Selbsteinschätzungen zu Kontrollen			R	A	R		R	R	R	R	R	R	R	R	R
MEA02.04 Identifizieren und Melden von Kontrollschwächen				A	R		R	R	R	R	R	R	R	R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen													
Keine entsprechenden weiteren Quellen für diese Komponente															

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)

Managementpraktik	Inputs		Outputs	
	Von	Beschreibung	Beschreibung	Für
MEA02.01 Überwachen interner Kontrollen	AP012.04	Ergebnisse von Risikobewertungen Dritter	Ergebnisse aus Benchmarks und anderen Bewertungen	Alle APO, BAI, DSS, MEA; EDM01.03
	AP013.03	Informationssicherheits-Managementsystem-(ISMS) Prüfberichte	Ergebnisse aus der Überwachung und Überprüfung interner Kontrollen	Alle APO, BAI, DSS, MEA; EDM01.03
	Außerhalb von COBIT	Industriestandards und bewährte Verfahren		
MEA02.02 Überprüfen der Effektivität von Geschäftsprozesskontrollen	BAI05.06	Ergebnisse der Compliance-Überprüfung	Nachweis der Kontroll-effektivität	Intern
	BAI05.07	Überprüfungen der betrieblichen Nutzung		
MEA02.03 Durchführen von Selbsteinschätzungen zu Kontrollen			Pläne und Kriterien zur Selbsteinschätzung	Alle APO, BAI, DSS, MEA
			Ergebnisse aus der Überprüfung von Selbsteinschätzungen	Alle APO, BAI, DSS, MEA; EDM01.03
			Ergebnisse der Selbsteinschätzungen	Intern

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
MEA02.04 Identifizieren und Melden von Kontrollschwächen	AP011.03	Grundursachen für Qualitätsmängel	Abhilfemaßnahmen	Alle APO, BAI, DSS, MEA
	AP012.06	Risikobezogene Grundursachen	Kontrollschwächen	Alle APO, BAI, DSS, MEA
	DSS06.01	• Ergebnisse der Überprüfungen der Bearbeitungseffektivität • Ursachenanalysen und Empfehlungen		
	DSS06.04	Nachweis der Fehlerkorrektur und -behebung		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
National Institute of Standards and Technology Special Publication 800-37, Revision 2, September 2017		3.7 Monitoring (Task 2): Inputs und Outputs		

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Risikomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.3. Risk Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Richtlinie zum Internen Kontrollsystem	Vermittelt die internen Kontrollziele des Managements. Legt Standards für die Gestaltung und den Betrieb des unternehmensinternen Kontrollsystems fest, um die Gefährdung durch Risiken aller Art zu verringern. Bietet Anleitungen für die kontinuierliche Überwachung und Bewertung des Kontrollumfelds, einschließlich der Eigenwahrnehmung und Selbsteinschätzung.		
Leitlinie zur Selbsteinschätzung der internen Kontrollen	Empfiehlt eine kontinuierliche Überwachung der internen Kontrollen, um Mängel und Lücken in der Wirksamkeit zu identifizieren, ihre Ursachen zu ermitteln und Aktionspläne und Meilensteine zur Mängelbehebung für die Berichterstattung an die Anspruchsgruppen zu initiieren.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Fördern Sie ein Bewusstsein für eine wirksame Kontrollumgebung und eine proaktive risiko- und selbstbewusste Kultur, einschließlich der Verpflichtung zur Selbsteinschätzung und zu unabhängigen Prüfungen.		

G. Komponente: Services, Infrastruktur und Anwendungen

- COBIT und zugehörige Produkte/Werkzeuge
- Serviceangebote der Bewertung des internen Kontrollsystems durch Dritte

Domäne: Überwachen, Evaluieren und Beurteilen Managementziel: MEA03 – Compliance mit externen Anforderungen wird gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Bewertung, inwieweit I&T-Prozesse und I&T-gestützte Geschäftsprozesse mit Gesetzen, Vorschriften und vertraglichen Anforderungen konform gehen. Sicherstellung, dass die Anforderungen identifiziert und eingehalten wurden und dass die Einbindung der IT-Compliance in die allgemeine Unternehmens-Compliance erfolgt ist.		
Zweck		
Sicherstellung, dass die Organisation alle relevanten externen Anforderungen erfüllt.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG03 Compliance mit externen Gesetzen und Bestimmungen		• AG01 I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG03 a. Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern b. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursachten c. Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Compliance-Verstößen d. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern		AG01 a. Kosten der Nichteinhaltung von IT-Vorschriften, einschließlich Vergleichen und Bußgeldern, sowie die Auswirkungen von Reputationsverlusten b. Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von IT-Vorschriften, die der Geschäftsleitung gemeldet wurden oder zu öffentlichen Kommentaren oder Unannehmlichkeiten führten c. Anzahl der Probleme im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit IT-Dienstleistern

A. Komponente: Prozess		
Managementpraktik		Beispielmetrik
MEA03.01 Identifizieren externer Compliance-Anforderungen Überwachen Sie kontinuierlich Änderungen der lokalen und internationalen Gesetze, Bestimmungen und sonstigen externen Anforderungen, die aus I&T-Sicht eingehalten werden müssen.		a. Häufigkeit der Überprüfung der Einhaltung von Compliance-Anforderungen b. Grad der Zufriedenheit der wichtigsten Anspruchsgruppen mit der Einhaltung von Compliance-Anforderungen
Aktivitäten		Fähigkeitsstufe
1. Weisen Sie die Zuständigkeit für die Identifizierung und Überwachung von Änderungen der gesetzlichen, behördlichen und sonstigen externen vertraglichen Anforderungen zu, die relevant für die Nutzung von IT-Ressourcen und die Verarbeitung von Informationen innerhalb der geschäftlichen und IT-bezogenen Abläufe des Unternehmens sind.		2
2. Identifizieren und beurteilen Sie sämtliche potenziellen Compliance-Anforderungen und deren Auswirkungen auf I&T-Aktivitäten, z. B. in den Bereichen Datenfluss, Datenschutz, interne Kontrollen, Finanzberichtswesen, branchenspezifische Bestimmungen, geistiges Eigentum, Gesundheit und Sicherheit.		
3. Beurteilen Sie die Auswirkungen I&T-bezogener gesetzlicher und behördlicher Anforderungen auf Verträge mit Dritten in Bezug auf IT-Abläufe, Serviceanbieter und Handelspartner.		
4. Definieren Sie die Folgen der Nichteinhaltung (Non-Compliance).		
5. Holen Sie sich ggf. unabhängigen Rat zu den anwendbaren Gesetzen, Bestimmungen und Standards ein.		3
6. Führen Sie ein aktuelles Protokoll, in dem alle relevanten gesetzlichen, behördlichen und vertraglichen Anforderungen, ihre Auswirkungen sowie die erforderlichen Maßnahmen enthalten sind.		
7. Führen Sie ein abgestimmtes und integriertes umfassendes Register, in dem alle für das Unternehmen maßgeblichen, externen Compliance-Anforderungen enthalten sind.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		BC.RR Determine Legal/Regulatory Requirements
HITRUST CSF Version 9, September 2017		06.01 Compliance with Legal Requirements
ISF, The Standard of Good Practice for Information Security 2016		SM2.3 Legal and Regulatory Compliance

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
MEA03.02 Optimieren der Reaktion auf externe Anforderungen Sorgen Sie für die Überprüfung und Anpassung von Richtlinien, Prinzipien, Standards, Verfahren und Methoden, um sicherzustellen, dass den gesetzlichen, behördlichen und vertraglichen Anforderungen Rechnung getragen wird und diese kommuniziert werden. Überlegen Sie, welche Industriestandards sowie Regeln und Leitlinien zu bewährten Verfahren übernommen und ggf. angepasst werden könnten.		a. Durchschnittliche Zeitspanne zwischen der Identifizierung von Compliance-Problemen und deren Lösung b. Grad der Zufriedenheit der relevanten Mitarbeiter mit der Kommunikation neuer und geänderter Compliance-Anforderungen
Aktivitäten		Fähigkeitsstufe
1. Sorgen Sie für die regelmäßige Überprüfung und Anpassung von Richtlinien, Prinzipien, Standards, Verfahren und Methoden, um deren Effektivität für die Gewährleistung der erforderlichen Compliance und die Bewältigung des Unternehmensrisikos sicherzustellen. Setzen Sie je nach Bedarf interne und externe Experten ein.		3
2. Kommunizieren Sie neue und geänderte Anforderungen an alle relevanten Mitarbeiter.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
King IV Report on Corporate Governance for South Africa, 2016		Part 5.4: Governance functional areas – Principle 13
Managementpraktik		Beispielmetrik
MEA03.03 Überprüfen der externen Compliance Überprüfen Sie die Compliance von Richtlinien, Prinzipien, Standards, Verfahren und Methodologien mit gesetzlichen, behördlichen und vertraglichen Anforderungen.		a. Anzahl der festgestellten kritischen Verstöße pro Jahr b. Anteil der Prozessverantwortlichen, die die Compliance-Konformität bestätigen
Aktivitäten		Fähigkeitsstufe
1. Bewerten Sie regelmäßig die Richtlinien der Organisation, Standards, Verfahren und Methoden aller Unternehmensfunktionen, um deren Compliance mit relevanten gesetzlichen und behördlichen Anforderungen hinsichtlich der Verarbeitung von Informationen sicherzustellen.		3
2. Bearbeiten Sie Compliance-Lücken bei Richtlinien, Standards und Verfahren zeitnah.		
3. Bewerten Sie regelmäßig Geschäfts- und IT-Prozesse und -Aktivitäten, um sicherzustellen, dass sie mit den anwendbaren gesetzlichen, behördlichen und vertraglichen Anforderungen vereinbar sind.		
4. Überprüfen Sie regelmäßig das Vorhandensein von Mustern beim Auftreten von Compliance-Verfehlungen und bewerten Sie die daraus gezogenen Erkenntnisse.		4
5. Überarbeiten Sie (auf der Grundlage von Überprüfungen und der daraus gezogenen Erkenntnisse) Richtlinien, Standards, Verfahren, Methoden sowie die damit verbundenen Prozesse und Aktivitäten.		5
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
MEA03.04 Erhalten von Compliance-Bestätigungen Stellen Sie die Compliance mit bzw. Einhaltung von Richtlinien, Prinzipien, Standards, Verfahren und Methoden sicher und dokumentieren Sie dies in einem Bericht. Stellen Sie sicher, dass korrektive Maßnahmen zur Beseitigung von Compliance-Lücken zeitnah durchgeführt werden.		a. Anzahl der erhaltenen Compliance-Berichte b. Grad der Einhaltung der Vorschriften (Compliance) durch die Service-Anbieter auf der Grundlage unabhängiger Überprüfungen c. Zeit zwischen der Identifizierung einer Lücke in der (Compliance-) Umsetzung und den Korrekturmaßnahmen d. Anzahl der Berichte zu Korrekturmaßnahmen, auf deren Basis Lücken bezüglich der Einhaltung der Vorschriften (Compliance) rechtzeitig geschlossen werden

B. Komponente: Organisationsstrukturen																																	
Wichtige Managementpraktik:												Chief Executive Officer																					
												Chief Financial Officer																					
												Chief Operating Officer																					
												Chief Information Officer																					
												I&T Governance Board																					
												Geschäftsprozessverantwortlicher																					
												Project Management Office																					
												Leiter Entwicklung																					
												Leiter IT-Betrieb																					
												Leiter IT-Administration																					
												Service Manager																					
												Information Security Manager																					
												Business Continuity Manager																					
												Datenschutzbeauftragter																					
												Rechtsbeistand																					
												Compliance																					
												Audit																					
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)												Detaillierte Referenzen																					
Keine entsprechenden weiteren Quellen für diese Komponente																																	

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
MEA03.01 Identifizieren externer Compliance-Anforderungen	Von	Beschreibung	Beschreibung	Für
	Außerhalb von COBIT	Rechtliche und behördliche Compliance-Anforderungen	Protokoll der erforderlichen Compliance-Maßnahmen	Register der internen Compliance-Anforderungen
				Intern
MEA03.02 Optimieren der Reaktion auf externe Anforderungen			Kommunikation zu geänderten Compliance-Anforderungen	Alle APO-Prozesse, Alle BAI-Prozesse, Alle DSS-Prozesse, Alle MEA; EDM01.01
			Aktualisierte Richtlinien, Grundsätze, Verfahren und Standards	AP001.09, AP001.11
MEA03.03 Überprüfen der externen Compliance	BAI05.06	Ergebnisse der Compliance-Überprüfung	Compliance-Bestätigungen	EDM01.03
	BAI09.05	Ergebnisse der Prüfungen installierter Lizenzen	Identifizierte Compliance-Lücken	MEA04.08
	BAI10.05	Lizenz-Abweichungen		
	DSS01.04	Berichte über Versicherungspolicen		
MEA03.04 Erhalten von Compliance-Bestätigungen	EDM05.02	Regeln für die Validierung und Genehmigung von Pflichtberichten	Berichte zur Compliance-Prüfung	EDM01.03
	EDM05.03	Bewertung der Effektivität der Berichterstattung	Berichte über Compliance-Verstöße und deren Ursachen	EDM01.03, MEA04.04
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Informationssicherheit	Skills Framework for the Information Age V6, 2015	SCTY

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Compliance-Richtlinie	Zeigt behördliche, vertragliche und interne Compliance-Anforderungen auf. Erläutert den Prozess zur Beurteilung der Compliance mit behördlichen, vertraglichen und internen Anforderungen. Führt Rollen und Zuständigkeiten für verschiedene Aktivitäten im Prozess auf und gibt Hinweise zu Metriken zur Messung der Compliance. Einholung von Compliance-Berichten und Bestätigung der Compliance oder von Korrekturmaßnahmen zur rechtzeitigen Behebung von Compliance-Lücken.		

F. Komponente: Kultur, Ethik und Verhalten		
Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Förderung einer Kultur, in der das Thema Compliance und eine Null-Toleranz-Politik gegenüber der Nichteinhaltung gesetzlicher und behördlicher Anforderungen verankert ist.		

G. Komponente: Services, Infrastruktur und Anwendungen
• Serviceangebote zur Überwachung behördlicher Anforderungen • Serviceangebote der Compliance-Bewertung durch Dritte

Diese Seite wurde absichtlich freigelassen.

Domäne: Überwachen, Evaluieren und Beurteilen Managementziel: MEA04 – Assurance wird gemanagt		Schwerpunktbereich: COBIT-Kernmodell
Beschreibung		
Planung, Festlegung des Umfangs und Ausführung von Assurance-Initiativen zur Einhaltung von internen Anforderungen, Gesetzen, Vorschriften und strategischen Zielvorgaben. Befähigung des Managements, durch unabhängige Prüfungen und Maßnahmen eine angemessene und nachhaltige Assurance im Unternehmen zu gewährleisten.		
Zweck		
Befähigung des Unternehmens, effiziente und effektive Assurance-Initiativen zu konzipieren, indem Anleitungen zur Planung, zur Festlegung des Umfangs, zur Durchführung und zur Weiterverfolgung von Assurance-Prüfungen bereitgestellt werden. Dies erfolgt unter Verwendung einer Roadmap, die auf bewährten Assurance-Ansätzen basiert.		
Das Managementziel unterstützt die Erreichung verschiedener primärer Unternehmens- und IT-bezogener Ziele:		
Unternehmensziele	➔	IT-bezogene Ziele
• EG03 Compliance mit externen Gesetzen und Bestimmungen • EG11 Compliance mit internen Richtlinien		• AG11 I&T-Compliance mit internen Richtlinien
Beispielmetriken für Unternehmensziele		Beispielmetriken für IT-bezogene Ziele
EG03 a. Kosten der Nichteinhaltung von Vorschriften, einschließlich Vergleichen und Bußgeldern b. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von Vorschriften, die öffentliche Kommentare oder negative Publicity verursachten c. Anzahl der von den Aufsichtsbehörden festgestellten Fälle von Compliance-Verstößen d. Anzahl von Problemen im Zusammenhang mit der Nichteinhaltung von vertraglichen Vereinbarungen mit Geschäftspartnern		AG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von I&T-bezogenen Richtlinien b. Anzahl der Ausnahmen bezüglich interner Richtlinien c. Häufigkeit der Überprüfung und Aktualisierung der Richtlinien
EG11 a. Anzahl der Störungen im Zusammenhang mit der Nichteinhaltung von Richtlinien b. Anteil der Anspruchsgruppen, die die Richtlinien verstehen c. Anteil der Richtlinien, die durch effektive Standards und Arbeitspraktiken unterstützt werden		

A. Komponente: Prozess		
Managementpraktik	Beispielmetrik	
MEA04.01 Sicherstellen der Unabhängigkeit und Qualifikation der Prüfer Stellen Sie sicher, dass die für die Prüfung zuständigen Institutionen unabhängig von der betreffenden Funktion, Gruppe oder Organisation sind. Die mit der Prüfung beauftragten Institutionen sollten eine angemessene Haltung und ein entsprechendes Auftreten erkennen lassen, sollten ausreichend qualifiziert sein, d. h. die erforderlichen Fähigkeiten und Kenntnisse für die Durchführung der Prüfung mitbringen und sie sollten ethische Richtlinien und fachliche Standards befolgen.	a. Anteil der Prozesse, die einer unabhängigen Überprüfung unterliegen b. Anteil der Qualifikationen und Kompetenzen, die von den Serviceanbietern erfüllt werden	
Aktivitäten	Fähigkeitsstufe	
1. Sorgen Sie für die Einhaltung der einschlägigen ethischen Richtlinien und Standards (z. B. Code of Professional Ethics der ISACA) sowie der branchenspezifischen und regionalen Prüfstandards (z. B. der Standards für IT-Audits und Prüfung der ISACA, oder dem internationalen Rahmenwerk für Prüfaufgaben des International Auditing and Assurance Standards Board (IAASB), dem IAASB Assurance Framework).	2	
2. Stellen Sie sicher, dass die externen Prüfer unabhängig sind.		
3. Stellen Sie sicher, dass die externen Prüfer kompetent und qualifiziert sind.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen	
HITRUST CSF Version 9, September 2017	06.03 Information System Audit Considerations	

A. Komponente: Prozess (Forts.)		
Managementpraktik		Beispielmetrik
MEA04.02 Entwickeln von risikoorientierten Planungen von Assurance-Initiativen Bestimmen Sie Prüfungsziele auf der Grundlage von Beurteilungen des internen und externen Umfelds und Kontexts, des Risikos, die Unternehmensziele nicht zu erreichen und der damit verbundenen Möglichkeiten, die betreffenden Ziele zu erreichen.		a. Anteil der Assurance-Initiativen, die den genehmigten Standards für Assurance-Programme und -Pläne folgen b. Anteil der Prüfungsplaninitiativen auf der Grundlage einer Risikobewertung
Aktivitäten		Fähigkeitsstufe
1. Verschaffen Sie sich ein Verständnis der Unternehmensstrategie und der Prioritäten.		2
2. Verschaffen Sie sich ein Verständnis des internen Kontexts des Unternehmens. Dieses Verständnis wird dem Prüfer helfen, die Unternehmensziele und die relative Bedeutung der Unternehmens- und IT-bezogenen Ziele sowie die wichtigsten Bedrohungen dieser Ziele besser beurteilen zu können. Dies wiederum ist hilfreich, um einen angemesseneren und sachdienlicheren Umfang für die Prüfungsaufträge festzulegen.		
3. Verschaffen Sie sich ein Verständnis des externen Kontexts des Unternehmens. Dieses Verständnis wird dem Prüfer helfen, die Unternehmensziele und die relative Bedeutung der Unternehmens- und IT-bezogenen Ziele sowie die wichtigsten Bedrohungen dieser Ziele besser verstehen zu können. Dies wiederum ist hilfreich, um einen angemesseneren und sachdienlicheren Umfang für die Prüfungsaufträge festzulegen.		
4. Entwickeln Sie einen Gesamtjahresplan für Assurance-Initiativen, der die konsolidierten Prüfungsziele enthält.		3
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
King IV Report on Corporate Governance for South Africa, 2016		Part 5.4: Governance functional areas – Principle 15
Managementpraktik		Beispielmetrik
MEA04.03 Festlegen der Ziele der Assurance-Initiative Definieren Sie die Ziele der Assurance-Initiative und stimmen Sie diese mit allen Anspruchsgruppen ab.		a. Anteil der mittels der Assurance-Initiative erreichten Ziele b. Grad der Zufriedenheit der Anspruchsgruppen mit den Zielen der Assurance-Initiative
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie das Prüfungsziel der Assurance-Initiative durch die Identifizierung der Anspruchsgruppen der Assurance-Initiative und ihrer Interessen.		2
2. Einigen Sie sich auf die vordergründigen Ziele und die organisatorischen Grenzen der Prüfungsaufträge.		
3. Nutzen Sie die COBIT-Zielkaskade und ihre verschiedenen Ebenen, um das Prüfungsziel zu definieren.		3
4. Stellen Sie sicher, dass die Ziele der Prüfungsaufträge alle drei Komponenten des Wertziels berücksichtigen: die Erbringung von Nutzenvorteilen, die die strategischen Ziele unterstützen, die Optimierung des Risikos, dass die strategischen Ziele nicht erreicht werden und die Optimierung der zur Erreichung der strategischen Ziele erforderlichen Ressourcen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Data Management Maturity Model, 2014		Supporting Processes – Process Quality Assurance
Managementpraktik		Beispielmetrik
MEA04.04 Festlegen des Umfangs von Assurance-Initiativen Definieren und vereinbaren Sie mit allen Anspruchsgruppen den Umfang der Assurance-Initiative, basierend auf den Prüfungszielen.		a. Anzahl der geplanten Aktivitäten, basierend auf dem Umfang, der die zu erhebenden Informationen und die zu befragenden Anspruchsgruppen berücksichtigt b. Grad der Zufriedenheit der Anspruchsgruppen mit dem Umfang der Assurance-Initiative, basierend auf den Prüfungszielen
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie alle Governance-Komponenten, die im Umfang der Prüfung enthalten sein sollen, d.h. Prinzipien, Richtlinien und Rahmenwerke, Prozesse, Organisationsstrukturen, Kultur, Ethik und Verhalten, Informationen, Services, Infrastruktur und Anwendungen, Menschen, Fähigkeiten und Kompetenzen		2

A. Komponente: Prozess (Forts.)		
2. Definieren Sie auf der Grundlage der Definition des Umfangs einen verbindlichen Plan und berücksichtigen Sie dabei die zu sammelnden Informationen und die zu befragenden Anspruchsgruppen.		3
3. Bestätigen und verfeinern Sie den Umfang auf der Grundlage des Verständnisses der Unternehmensarchitektur.		
4. Verfeinern Sie den Umfang des Prüfungsauftrags auf der Grundlage der verfügbaren Ressourcen.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
CMMI Cybermaturity Platform, 2018		TP.LA Apply Logging and Audit Processes
Managementpraktik		Beispielmetrik
MEA04.05 Definieren des Arbeitsprogramms für die Assurance-Initiative Definieren Sie ein detailliertes Arbeitsprogramm für die Assurance-Initiative und planen Sie den Umfang unter Berücksichtigung der Managementziele und Governance-Komponenten.		a. Anteil der als schwach erkannten Managementkontrollen ohne definierte Praktiken zur Reduzierung des Restrisikos b. Anzahl der überprüften Kontrollen c. Grad der Zufriedenheit der Anspruchsgruppen mit dem Arbeitsprogramm der Assurance-Initiative
Aktivitäten		Fähigkeitsstufe
1. Definieren Sie detaillierte Schritte zur Sammlung und Auswertung von Informationen aus Managementkontrollen im Rahmen des definierten Umfangs. Legen Sie den Schwerpunkt auf die Beurteilung der Definition und Anwendung bewährter Praktiken im Zusammenhang mit der Gestaltung von Kontrollen und der Erreichung von Kontrollzielen im Zusammenhang mit der Effektivität von Kontrollen.		2
2. Machen Sie sich mit dem Kontext der eingesetzten Managementziele und unterstützenden Managementkontrollen vertraut. Verschaffen Sie sich ein Verständnis darüber, wie diese Managementkontrollen zur Erreichung der IT-bezogenen Ziele und Unternehmensziele beitragen.		
3. Machen Sie sich mit allen Anspruchsgruppen und deren Interessen vertraut.		
4. Einigen Sie sich auf bewährte Praktiken für die Managementkontrollen.		3
5. Sollte eine Managementkontrolle (zu) schwach sein, definieren Sie Praktiken, um Restrisiken zu identifizieren (zur Vorbereitung der Berichterstattung).		
6. Verschaffen Sie sich ein Verständnis des Lebenszyklusstadiums der Managementkontrollen und einigen Sie sich auf die erwarteten Werte.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		
Managementpraktik		Beispielmetrik
MEA04.06 Umsetzen der Assurance-Initiative mit Fokus auf der Effektivität des Designs Führen Sie die geplante Assurance-Initiative durch. Validieren und bestätigen Sie die Konzeption der vorhandenen internen Kontrollen. Berücksichtigen Sie, insbesondere bei internen Prüfungsaufträgen, ein kosteneffektives Design der Governance-Komponente.		a. Anteil der Assurance-Initiativen, die ein kosteneffektives Design aufweisen b. Grad der Zufriedenheit der Anspruchsgruppen mit dem Design der Assurance-Initiative
Aktivitäten		Fähigkeitsstufe
1. Arbeiten Sie das Verständnis des IT-Prüfthemas weiter aus.		2
2. Arbeiten Sie den Umfang des IT-Prüfthemas weiter aus.		
3. Beobachten und überprüfen Sie den Managementkontrollansatz. Validieren Sie den Ansatz zusammen mit dem Kontrollverantwortlichen hinsichtlich Vollständigkeit, Relevanz, Pünktlichkeit und Messbarkeit.		3
4. Fragen Sie den Kontrollverantwortlichen, ob die Zuständigkeiten für die Governance-Komponente und die Gesamtverantwortung zugewiesen wurden. Bestätigen Sie die entsprechende Antwort. Prüfen Sie, ob Verantwortlichkeiten und Zuständigkeiten verstanden und akzeptiert werden. Vergewissern Sie sich, dass die erforderlichen Fähigkeiten und die erforderlichen Ressourcen verfügbar sind.		
5. Wägen Sie erneut zwischen Prävention und Erkennung und den Arten der Korrektur von Managementkontrollaktivitäten ab.		
6. Berücksichtigen Sie den Aufwand für die Aufrechterhaltung der Managementkontrollen und die damit verbundenen Kosten und die Effektivität.		

A. Komponente: Prozess (Forts.)		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SI1 Security Audit
ISO/IEC 27001:2013/Cor.2:2015(E)		9.2 Internal audit
Managementpraktik		Beispielmetrik
MEA04.07 Umsetzen der Assurance-Initiative mit Fokus auf der operativen Effektivität Führen Sie die geplante Assurance-Initiative durch. Prüfen Sie, ob die bestehenden internen Kontrollen angemessen und ausreichend sind. Prüfen Sie das Ergebnis der wichtigsten Managementziele im Rahmen des festgelegten Umfangs der Assurance-Initiative.		a. Anteil der Assurance-Initiativen, die das Ergebnis der wichtigsten Managementziele innerhalb des festgelegten Umfangs testen b. Grad der Zufriedenheit der Anspruchsgruppen mit der Durchführung der Assurance-Initiative
Aktivitäten		Fähigkeitsstufe
1. Beurteilen Sie, ob die erwarteten Ergebnisse für jede der Managementkontrollen des festgelegten Umfangs erreicht werden. Mit anderen Worten, beurteilen Sie die Effektivität der Managementkontrolle (Kontrolleffektivität).		3
2. Stellen Sie sicher, dass der Prüfer das Ergebnis oder die Effektivität der Managementkontrolle prüft, indem er nach direkten und indirekten Nachweisen für die Auswirkungen auf die Ziele der Managementkontrollen sucht. Dies impliziert die direkte und indirekte Konkretisierung eines messbaren Beitrags der Managementziele zu den IT-bezogenen Zielen und damit die Feststellung direkter und indirekter Nachweise für die tatsächliche Erreichung der erwarteten Ergebnisse.		
3. Stellen Sie fest, ob der Prüfer direkte oder indirekte Nachweise für ausgewählte Elemente/Zeiträume erhält, indem er eine Auswahl von Prüftechniken anwendet, um sicherzustellen, dass die untersuchte Managementkontrolle effektiv funktioniert. Stellen Sie sicher, dass der Prüfer auch eine begrenzte Überprüfung der Angemessenheit der Ergebnisse der Managementkontrolle durchführt und den Umfang der substanziellen Tests und der zusätzlichen Arbeit bestimmt, die erforderlich sind, um die Angemessenheit der Leistung der Managementkontrolle zu gewährleisten.		
4. Untersuchen Sie, ob eine Managementkontrolle effizienter gestaltet werden kann und ob sie durch die Optimierung der Schritte oder die Suche nach Synergien mit anderen Managementkontrollen effektiver gestaltet werden kann.		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
ISF, The Standard of Good Practice for Information Security 2016		SI1 Security Audit
SO/IEC 27001:2013/Cor.2:2015(E)		9.2 Internal audit
Managementpraktik		Beispielmetrik
MEA04.08 Bericht und Weiterverfolgung der Assurance-Initiative Geben Sie eine positive Stellungnahme ab, wo angebracht, sowie Empfehlungen für Verbesserungen in Bezug auf die festgestellten betrieblichen Leistungen, die Einhaltung externer Vorschriften (Compliance) und die internen Kontrollschwächen.		a. Akzeptanz des Prüfberichts durch die Anspruchsgruppen b. Akzeptanz der Anspruchsgruppen von Verbesserungsempfehlungen in Bezug auf identifizierte betriebliche Leistung, externe Compliance und interne Kontrollschwächen
Aktivitäten		Fähigkeitsstufe
1. Dokumentieren Sie die Auswirkungen von Kontrollschwächen.		2
2. Kommunizieren Sie mit dem Management während der Durchführung der Initiative, damit ein klares Verständnis der durchgeführten Arbeiten sowie Übereinstimmung und Akzeptanz der vorläufigen Ergebnisse und Empfehlungen gegeben ist.		
3. Legen Sie dem Management einen Bericht (in Übereinstimmung mit den Auftragsbedingungen, dem Umfang und den vereinbarten Berichterstattungsstandards) vor, der die Ergebnisse der Initiative stützt und eine klare Konzentration auf wichtige Fragen und Maßnahmen ermöglicht.		3
4. Beaufsichtigen Sie die Prüftätigkeiten und stellen Sie sicher, dass die Arbeitsauftrag vollständig geleistet wurde, den Zielvorgaben entspricht und von angemessener Qualität ist. Überarbeiten Sie den Ansatz oder einzelne Schritte, wenn Qualitätsprobleme auftreten.		4
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik		

A. Komponente: Prozess (Forts.)	
Managementpraktik	Beispielmetrik
MEA04.09 Weiterverfolgung von Empfehlungen und Maßnahmen Vereinbaren Sie, verfolgen Sie und setzen Sie die identifizierten Verbesserungsempfehlungen um.	a. Anzahl der wiederholt auftretenden Schwächen b. Anzahl der identifizierten Schwächen, die behoben wurden
Aktivitäten	Fähigkeitsstufe
1. Vereinbaren und implementieren Sie intern innerhalb der Organisation die notwendigen Maßnahmen, die zur Behebung der festgestellten Schwächen und Lücken ergriffen werden müssen.	2
2. Verfolgen Sie die Maßnahmen innerhalb der Organisation weiter, um festzustellen, ob Korrekturmaßnahmen ergriffen und interne Kontrollschwächen behoben wurden.	
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Keine zugehörigen Leitfäden für diese Managementpraktik	

B. Komponente: Organisationsstrukturen													
	Chief Operating Officer	Chief Risk Officer	Chief Information Officer	Chief Technology Officer	Risikoausschuss des Unternehmens	Geschäftsprozessverantwortlicher	Datenmanagement	Leiter IT-Betrieb	Service Manager	Information Security Manager	Business Continuity Manager	Rechtsbeistand	Audit
Wichtige Managementpraktik:													
MEA04.01 Sicherstellen der Unabhängigkeit und Qualifikation der Prüfer			R	R	R	R						R	A
MEA04.02 Entwickeln von risikoorientierten Planungen von Assurance-Initiativen	R	R	R	R		R						R	A
MEA04.03 Festlegen der Ziele der Assurance-Initiative	R	R	R	R		R						R	A
MEA04.04 Festlegen des Umfangs von Assurance-Initiativen	R	R	R	R		R						R	A
MEA04.05 Definieren des Arbeitsprogramms für die Assurance-Initiative	R		R	R		R						R	A
MEA04.06 Umsetzen der Assurance-Initiative mit Fokus auf der Effektivität des Designs	R		R	R		R	R	R	R	R	R	R	A
MEA04.07 Umsetzen der Assurance-Initiative mit Fokus auf der operativen Effektivität	R		R	R		R	R	R	R	R	R	R	A
MEA04.08 Bericht und Weiterverfolgung der Assurance-Initiative	R		R	R		R						R	A
MEA04.09 Weiterverfolgung von Empfehlungen und Maßnahmen	R	R	A	R		R	R					R	R
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen												
Keine entsprechenden weiteren Quellen für diese Komponente													

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6)				
Managementpraktik	Inputs		Outputs	
MEA04.01 Sicherstellen der Unabhängigkeit und Qualifikation der Prüfer	Von	Beschreibung	Beschreibung	Für
			Ergebnisse der Prüfer	Intern
MEA04.02 Entwickeln von risikoorientierten Planungen von Assurance-Initiativen	BAI01.05	Planung der Programmprüfungen	Prüfungspläne	Alle APO, BAI, DSS, MEA, EDM01.03
	DSS01.02	Unabhängige Prüfungspläne	Beurteilungskriterien	Intern
			Generelle Beurteilungen	Intern
MEA04.03 Festlegen der Ziele der Assurance-Initiative	MEA04.02	Prüfungspläne	Prüfungsziele und erwarteter Nutzen	Intern
MEA04.04 Festlegen des Umfangs von Assurance-Initiativen	APO11.03	Grundursachen für Qualitätsmängel	Praktiken für Prüfungen	Intern
	APO12.06	Risikobezogene Grundursachen	Einsatzplan	Intern
	DSS06.01	Ursachenanalysen und Empfehlungen		
	MEA03.04	Berichte über Compliance-Verstöße und deren Ursachen	Umfang der Prüfungen	Intern
Managementpraktik	Inputs		Outputs	
MEA04.05 Definieren des Arbeitsprogramms für die Assurance-Initiative	Von	Beschreibung	Beschreibung	Für
	APO12.04	Risikoanalyse und Risikoprofilberichte für Anspruchsgruppen	Geänderter Umfang	Intern
			Detailliertes Arbeitsprogramm für die Assurance	MEA04.06
MEA04.06 Umsetzen der Assurance-Initiative mit Fokus auf der Effektivität des Designs	APO12.06	Risikobezogene Grundursachen	Dokumentiertes Design interner Kontrollen	MEA04.07
	DSS06.01	Ursachenanalysen und Empfehlungen		
	MEA04.05	Detailliertes Arbeitsprogramm für die Assurance		
MEA04.07 Umsetzen der Assurance-Initiative mit Fokus auf der operativen Effektivität	DSS02.02	Störungs- und Serviceanfragenprotokoll	Tests der Effektivität von Kontrollen	MEA04.08, MEA04.09
	DSS02.05	Beseitigung von Störungen		
	DSS03.05	Berichte zur Überwachung der Problemlösung		
	DSS05.02	Ergebnisse der Penetrationstests		
	DSS05.05	Zugriffsprotokolle		
	DSS06.01	Ursachenanalysen und Empfehlungen		
	MEA04.06	Dokumentiertes Design interner Kontrollen		

C. Komponente: Informationsflüsse und -elemente (siehe auch Abschnitt 3.6) (Forts.)				
MEA04.08 Bericht und Weiterverfolgung der Assurance-Initiative	MEA03.03	Identifizierte Compliance-Lücken	Bericht über die Prüfungen	Alle APO, BAI, DSS, MEA, EDM05.03
	MEA04.07	Tests der Effektivität von Kontrollen	Ergebnisse der Prüfungen	Alle APO, BAI, Alle DSS, MEA, EDM05.03, MEA04.09
MEA04.09 Weiterverfolgung von Empfehlungen und Maßnahmen	MEA04.07	Tests der Effektivität von Kontrollen	Abhilfemaßnahmen	Alle APO, BAI, DSS, MEA
	MEA04.08	Ergebnisse der Prüfungen		
Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)		Detaillierte Referenzen		
Keine entsprechenden weiteren Quellen für diese Komponente				

D. Komponente: Mitarbeiter, Fähigkeiten und Kompetenzen		
Fähigkeit	Zugehörige Leitfäden (Standards, Rahmenwerke, Compliance-Anforderungen)	Detaillierte Referenzen
Eine Reihe von Kernprinzipien, die vom Institute of Internal Auditors® aufgestellt wurden, unterstützen die Effektivität und Effizienz der (internen) Revision. Zu diesen Prinzipien gehören u. a. die Bedeutung von Unabhängigkeit, effektiven Kommunikationsfähigkeiten, Proaktivität usw.	Core Principles for the Professional Practice of Internal Auditing, The Institute of Internal Auditors	Vgl. IIA Website – Standards & Guidance – Core Principles
Risikomanagement	e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework, 2016	E. Manage – E.3. Risk Management

E. Komponente: Richtlinien und Verfahren			
Relevante Richtlinie	Beschreibung der Richtlinie	Zugehörige Leitfäden	Detaillierte Referenzen
Leitfaden für Assurance	Bietet Anleitungen zur Durchführung von Assurance-Initiativen. Unterstützt bei der effizienten und effektiven Entwicklung von I&T-Assurance-Initiativen, einschließlich Planung, Festlegung des Umfangs und Durchführung auf der Grundlage bewährter Prüfansätze. Zeigt die Schritte zum Prüfen des Kontrolldesigns, des Ergebnisses der operativen Effektivität der Kontrolle und zur Dokumentation von Kontrollschwächen und deren Auswirkungen auf.		

Charta für die Interne Revision	Gewährleistet die Unabhängigkeit bei der Durchführung von Revisionsprüfungen und dem Berichten der Ergebnisse und Empfehlungen direkt an die oberste Führungsebene. Die interne Revision sollte eine separate Einheit sein, die entweder dem CEO oder dem COO untersteht. In Bezug auf I&T sollte in der Charta festgelegt werden, dass die interne Revision für die Überprüfung sowohl der allgemeinen als auch der Anwendungskontrollen verantwortlich ist, um festzustellen, ob die Kontrollen in Übereinstimmung mit den Anweisungen des Managements, den festgelegten Standards und Verfahren und den bekannten rechtlichen Anforderungen konzipiert wurden und ob die Kontrollen effektiv funktionieren, um Zuverlässigkeit und Sicherheit der verarbeiteten Daten (d. h. Vertraulichkeit, Integrität und Verfügbarkeit) zu gewährleisten. In der Charta sollte auch deutlich werden, dass die interne Revision für die Überprüfung des Entwurfs, der Entwicklung und der Umsetzung neuer Systeme oder größerer Änderungen bestehender Systeme verantwortlich ist.		
---------------------------------	---	--	--

F. Komponente: Kultur, Ethik und Verhalten

Wichtige Elemente der Kultur	Zugehörige Leitfäden	Detaillierte Referenzen
Schaffen Sie eine Kultur, die die Erkenntnisse und Empfehlungen der internen Revision und der Assurance-Initiative auf der Grundlage der Ursachenanalyse wertschätzt. Die Führungskräfte müssen dazu sicherstellen, dass die interne Revision und Assurance in strategische Initiativen einbezogen werden und die Notwendigkeit (und den Wert) von Prüf- und Assurance-Berichten anerkennen.		
Gewährleistung einer ethischen Kultur der internen Revision durch einen geeigneten Ethikkodex.	Code of Ethics, The Institute of Internal Auditors	Vgl. IIA Website – Standards & Guidance – Code of Ethics

G. Komponente: Services, Infrastruktur und Anwendungen

- Werkzeuge zur Unterstützung von Prüfungen
- Werkzeuge zur Überprüfung von Ereignisprotokollen
- Dienstleistungsangebote der Bereitstellung von Assurance durch Dritte

Anhänge

A.1 Anhang A: Zielkaskade – Zuordnungstabellen

Die Zuordnungstabellen in Anhang A stellen Informationen zur Zielkaskade bereit. Die erste Tabelle ordnet die Unternehmensziele den IT-bezogenen Zielen zu und die zweite Tabelle die Governance- und Managementziele den IT-bezogenen Zielen zu. Das „P“ in der Tabelle steht für primär und das „S“ für sekundär.

A.1.1 Zuordnungstabelle: Unternehmensziele – IT-bezogene Ziele

Abbildung A.1: Zuordnung von Unternehmenszielen zu IT-bezogenen Zielen														
		EG01	EG02	EG03	EG04	EG05	EG06	EG07	EG08	EG09	EG10	EG11	EG12	EG13
		Portfolio wettbewerbsfähiger Produkte und Services	Gesteuertes Geschäftsrisiko	Compliance mit externen Gesetzen und Bestimmungen	Qualität von Finanzinformationen	Kundenorientierte Servicekultur	Kontinuität und Verfügbarkeit der geschäftlichen Services	Qualität der Managementinformationen	Optimierung der internen Geschäftsfunktionalität	Optimierung der Geschäftsprozesskosten	Fähigkeiten, Motivation und Produktivität des Personals	Compliance mit internen Richtlinien	Gesteuerte Programme zur digitalen Transformation	Produkt- und Geschäftsinnovation
AG01	I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen		S	P								S		
AG02	Gesteuertes I&T-Risiko		P				S							
AG03	Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio	S				S			S	S			P	
AG04	Qualität der durch IT erzeugten Finanzinformationen				P			P		P				
AG05	Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen	P				S	S		S				S	
AG06	Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen	P				S			S				S	S
AG07	Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz		P				P							
AG08	Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie	P				P			S		S		P	S
AG09	Termingetreue, budgetgerechte, bedarfs- und qualitätsgerechte Bereitstellung von Programmen	P				S			S	S			P	S
AG10	Qualität der I&T-Managementinformationen				P			P		S				
AG11	I&T-Compliance mit internen Richtlinien		S	P								P		
AG12	Kompetente und motivierte Mitarbeiter mit gegenseitigem Verständnis für Technologie und Geschäft					S					P			
AG13	Wissen, Know-how und Initiativen für geschäftliche Innovationen	P		S									S	P

A.1.2 Zuordnungstabelle: Governance- und Managementziele – IT-bezogene Ziele

Abbildung A.2: Zuordnung von Governance- und Managementzielen zu IT-bezogenen Zielen														
		AG01	AG02	AG03	AG04	AG05	AG06	AG07	AG08	AG09	AG10	AG11	AG12	AG13
		I&T-Compliance und Unterstützung für die Unternehmens-Compliance mit externen Gesetzen und Bestimmungen	Gesteuertes I&T-Risiko	Realisierte Vorteile aus dem durch die I&T ermöglichten Anlage- und Dienstleistungsportfolio	Qualität der durch IT erzeugten Finanzinformationen	Lieferung von I&T-Services in Übereinstimmung mit den Geschäftsanforderungen	Agilität, um Geschäftsanforderungen in operative Lösungen umzusetzen	Sicherheit von Informationen, Verarbeitungsinfrastrukturen und Anwendungen sowie Datenschutz	Ermöglichung und Unterstützung von Geschäftsprozessen durch Integration von Anwendungen und Technologie	Termin-getreue, budget-gerechte, bedarfs- und qualitäts-gerechte Bereitstel-lung von Programmen	Qualität der I&T-Managementinfor-mationen	I&T-Com-pliance mit internen Richtlinien	Kompe-tenente und motivierte Mitarbeiter mit gegen-seitigem Verständnis für Techno-logie und Geschäft	Wissen, Know-how und Initi-ativen für geschäft-liche Inno-vationen
EDM01	Einrichtung und Pflege des Governance-Rahmenwerks ist sichergestellt	P	S	P					S			S		
EDM02	Bereitstellung von Mehrwert ist sichergestellt			P		S	S		S					S
EDM03	Risiko-Optimierung ist sichergestellt	S	P					P				S		
EDM04	Ressourcen-Optimierung ist sichergestellt			S		S	S		S	P			S	
EDM05	Einbindung der Anspruchsgruppen ist sichergestellt				S						P	S		
AP001	I&T-Management-Rahmenwerk ist gemanagt	S	S	P		S		S	S	S	S	P		
AP002	Strategie ist gemanagt			S		S	S		P				S	S
AP003	Unternehmensarchitektur ist gemanagt			S		S	P	S	P					
AP004	Innovation ist gemanagt			S			P		S				S	P
AP005	Portfolio ist gemanagt			P		P	S		S	S				
AP006	Budget und Kosten sind gemanagt			S	P					P	S			
AP007	Personal ist gemanagt			S		S				S			P	P
AP008	Beziehungen sind gemanagt			S		P	P		S	S			P	P
AP009	Servicevereinbarungen sind gemanagt					P			S					
AP010	Lieferanten sind gemanagt					P	S			S				
AP011	Qualität ist gemanagt			S	S	S				P	P			
AP012	Risiko ist gemanagt		P					P						
AP013	Sicherheit ist gemanagt	S	S					P						
AP014	Daten sind gemanagt	S	S		S			S			P			
BAI01	Programme sind gemanagt			P			S		S	P				
BAI02	Anforderungsdefinition ist gemanagt			S		P	P		S	P			S	
BAI03	Lösungsidentifizierung und Lösungserstellung sind gemanagt			S		P	P		S	P				
BAI04	Verfügbarkeit und Kapazität sind gemanagt					P		S		S				
BAI05	Organisatorische Änderungen sind gemanagt			P		S	S		P	P			S	
BAI06	IT-Änderungen sind gemanagt		S			S	P		S					
BAI07	Umsetzung und Abnahme von IT-Änderungen sind gemanagt		S				P			S				
BAI08	Wissen ist gemanagt			S			S		S	S			P	P
BAI09	Betriebsmittel sind gemanagt				P						S			
BAI10	Konfiguration ist gemanagt					S		P						
BAI11	Projekte sind gemanagt			P		S	P			P				
DSS01	Betrieb ist gemanagt					P			S					
DSS02	Serviceanfragen und Störungen sind gemanagt		S			P		S						
DSS03	Probleme sind gemanagt		S			P		S						
DSS04	Kontinuität ist gemanagt		S			P		P						
DSS05	Sicherheitsservices sind gemanagt	S	P			S		P				S		
DSS06	Geschäftsprozesskontrollen sind gemanagt		S			S		S	P			S		

Abbildung A.2: Zuordnung von Governance- und Managementzielen zu IT-bezogenen Zielen (Forts.)

MEA01	Überwachung von Leistung und Konformität wird gemanagt	S		S		P				S	P	S		
MEA02	Internes Kontrollsystem wird gemanagt	S	S		S	S		S		S	S	P		
MEA03	Compliance mit externen Anforderungen wird gemanagt	P										S		
MEA04	Assurance wird gemanagt	S	S		S	S		S			S	P		

A.2 Anhang B: Organisationsstrukturen – Übersicht und Beschreibungen

Die in Kapitel 4 detailliert beschriebenen Komponenten der Organisationsstrukturen beziehen sich auf die in **Abbildung A.3** dargestellten Rollen und Strukturen (siehe auch Abschnitt 3.5, der einen Überblick über die Komponente Organisationsstrukturen bietet).

Die verwendete Nomenklatur bezüglich der Rolle oder Struktur wird vermutlich von Unternehmen zu Unternehmen unterschiedlich sein. Ein Unternehmen kann geeignete Rollen und Strukturen, die seinem jeweiligen Geschäftskontext, seiner Organisation und seinem Betriebsumfeld entsprechen, auf der Grundlage der nachstehenden Beschreibungen bestimmen und dementsprechend Verantwortlichkeiten und Zuständigkeiten zuweisen.

Abbildung A.3: COBIT Rollen und Organisationsstrukturen

Rolle/Struktur	Beschreibung
Geschäftsleitung	Gruppe der obersten Führungskräfte mit und ohne geschäftsführende Funktion, die für die Governance und Gesamtsteuerung der Unternehmensressourcen verantwortlich sind
Exekutivkomitee	Gruppe hochrangiger Führungskräfte, die von der Geschäftsleitung ernannt werden, um sicherzustellen, dass die Geschäftsleitung an wichtigen Entscheidungen beteiligt ist und über diese fortlaufend informiert wird (Das Exekutivkomitee ist verantwortlich für das Managen der Portfolios von durch I&T ermöglichten Investitionen, I&T-Services und I&T-Betriebsmitteln, für die Sicherstellung der Wertschöpfung und für das Risikomanagement. Das Komitee wird üblicherweise von einem Mitglied der Geschäftsleitung geleitet)
Chief Executive Officer	Führungskraft mit dem höchsten Rang, die mit der Gesamtleitung des Unternehmens beauftragt ist
Chief Financial Officer	Führungskraft mit dem höchsten Rang, die für alle Aspekte des Finanzmanagements verantwortlich ist, einschließlich dem Management finanzieller Risiken und Kontrollen sowie eines zuverlässigen und genauen Rechnungswesens
Chief Operating Officer	Führungskraft mit dem höchsten Rang, die für die betrieblichen Aufgabenbereiche des Unternehmens verantwortlich ist
Chief Risk Officer	Führungskraft mit dem höchsten Rang, die für alle Aspekte des Risikomanagements im gesamten Unternehmen verantwortlich ist (Es kann auch ein I&T-Risk Officer vorhanden sein, um I&T-bezogene Risiken zu überwachen)
Chief Information Officer	Führungskraft mit dem höchsten Rang, die für die Abstimmung von IT- und Geschäftsstrategien verantwortlich ist sowie für die Planung, Beschaffung und das Management der Bereitstellung von I&T-Services und -Lösungen.
Chief Technology Officer	Führungskraft mit dem höchsten Rang, die mit technischen Aspekten der I&T beauftragt ist, einschließlich dem Management und der Überwachung von Entscheidungen im Zusammenhang mit I&T-Services, -Lösungen und -Infrastrukturen (Diese Rolle kann auch vom CIO übernommen werden)
Chief Digital Officer	Führungskraft mit dem höchsten Rang, die damit beauftragt ist, die digitalen Initiativen des Unternehmens oder der Geschäftseinheit in die Praxis umzusetzen (Diese Rolle kann auch vom CIO oder einem anderen Mitglied des Exekutivkomitees übernommen werden)
I&T Governance Board	Anspruchsgruppen und Experten, die für die Leitung I&T-bezogener Angelegenheiten und Entscheidungen verantwortlich sind, einschließlich des Managements von durch I&T ermöglichten Investitionen, der Wertschöpfung und der Überwachung von Risiken
Architekturausschuss	Anspruchsgruppen und Experten, die für die Leitung von Angelegenheiten und Entscheidungen im Zusammenhang mit der Unternehmensarchitektur und für die Festlegung von Architekturrichtlinien und -standards verantwortlich sind

Abbildung A.3: COBIT Rollen und Organisationsstrukturen (Forts.)

Rolle/Struktur	Beschreibung
Risikoausschuss des Unternehmens	Gruppe von Führungskräften, die für die Zusammenarbeit auf Unternehmensebene und die Erlangung von Konsens verantwortlich sind, die zur Unterstützung von Aktivitäten und Entscheidungen im Zusammenhang mit dem Management von Unternehmensrisiken erforderlich sind (Es kann auch ein I&T-Risikoausschuss eingerichtet werden, der sich eingehender mit I&T-Risiken befasst und den Risikoausschuss des Unternehmens berät)
Chief Information Security Officer	Führungskraft mit dem höchsten Rang, die für alle Aspekte des Sicherheitsmanagements im gesamten Unternehmen verantwortlich ist
Geschäftsprozess-verantwortlicher	Mitarbeiter, der für die Durchführung von Prozessen und/oder die Realisierung von Prozesszielen, die Förderung von Prozessverbesserungen und die Genehmigung von Prozessänderungen verantwortlich ist
Portfoliomanager	Mitarbeiter, der für die Leitung des Portfoliomanagements, die Gewährleistung der Auswahl der richtigen Programme und Projekte, das Management und die Überwachung von Programmen und Projekten im Hinblick auf eine optimale Werterzielung und die effektive und effiziente Umsetzung langfristiger strategischer Ziele verantwortlich ist.
Lenkungsausschuss für Projekte und Programme	Anspruchsgruppen und Experten, die für die Leitung von Programmen und Projekten verantwortlich sind, einschließlich Management und Überwachung von Plänen, Zuweisung von Ressourcen, Erbringung von Nutzenbeiträgen und Wert sowie Management von Programm- und Projektrisiken
Programm-Manager	Mitarbeiter, der für die Leitung eines bestimmten Programms verantwortlich ist, einschließlich der Formulierung und Nachverfolgung der Ziele und Zielvorgaben des Programms sowie für das Management von Risiken und Auswirkungen auf das Geschäft
Projektmanager	Mitarbeiter, der für die Leitung eines bestimmten Projekts verantwortlich ist, einschließlich der Koordination und Delegation von Zeit, Budget, Ressourcen und Aufgaben im gesamten Projektteam
Project Management Office	Funktion, die für die Unterstützung von Programm- und Projektmanagern und für das Sammeln, Beurteilen und Berichten von Informationen über die Durchführung von Programmen und den entsprechenden Projekten verantwortlich ist
Datenmanagement	Funktion, die für die Betreuung von Unternehmensdatenbeständen über den gesamten Datenlebenszyklus und das Managen der Datenstrategie, Infrastruktur und Repositories verantwortlich ist
Leiter Personal	Führungskraft mit dem höchsten Rang, die für die Planung und Richtlinien in Bezug auf die Personalressourcen im Unternehmen verantwortlich ist
Relationship Manager	Führungskraft, die für die Überwachung und Verwaltung der internen Schnittstellen und Kommunikation zwischen Geschäft und I&T-Funktionen verantwortlich ist
Chefarchitekt	Führungskraft, die für den Prozess in Verbindung mit der Unternehmensarchitektur verantwortlich ist
Leiter Entwicklung	Führungskraft, die für die I&T-bezogenen Lösungsentwicklungsprozesse verantwortlich ist
Leiter IT-Betrieb	Führungskraft, die für die IT-Betriebsumgebung und Infrastruktur verantwortlich ist
Leiter IT-Administration	Führungskraft, die für I&T-bezogene Aufzeichnungen verantwortlich ist und für die Unterstützung I&T-bezogener Verwaltungsangelegenheiten zuständig ist
Service Manager	Mitarbeiter, der die Entwicklung, Implementierung, Evaluierung und laufende Wartung von neuen und bestehenden Produkten und Services für einen bestimmten Kunden (Benutzer) oder eine bestimmte Kundengruppe (Benutzer) managt.
Information Security Manager	Mitarbeiter, der die Informationssicherheit des Unternehmens managt, gestaltet, beaufsichtigt und/oder bewertet
Business Continuity Manager	Mitarbeiter, der die Geschäftskontinuität des Unternehmens managt, gestaltet, beaufsichtigt und/oder beurteilt, um sicherzustellen, dass die kritischen Unternehmensfunktionen auch nach Störfällen weitergeführt werden
Datenschutzbeauftragter	Mitarbeiter, der für die Überwachung der Risiken und der Geschäftsauswirkungen in Bezug auf Datenschutzgesetze zuständig ist und die Implementierung von Richtlinien und Aktivitäten steuert und koordiniert, mit denen die Einhaltung der Datenschutzrichtlinien sichergestellt wird
Rechtsbeistand	Funktion, die für die Beratung in rechtlichen und behördlichen Angelegenheiten zuständig ist
Compliance	Funktion, die für alle Richtlinien zur externen Compliance zuständig ist
Audit	Funktion, die für die Durchführung interner Prüfungen zuständig ist

A.3 Anhang C: Detaillierte Liste der Referenzen

Die folgenden Standards und Anleitungen enthalten weitere Informationen zu den Referenzen der 40 wichtigen COBIT® 2019-Governance- und Managementziele.

- CIS® Center for Internet Security®, *The CIS Critical Security Controls for Effective Cyber Defense*, Version 6.1, August 2016
- CMMI® Cybermaturity Platform, 2018
- CMMI® Data Management Maturity (DMM)SM model, 2014
- Committee of Sponsoring Organizations (COSO) Enterprise Risk Management (ERM) Framework, Juni 2017
- European Committee for Standardization (CEN), *e-Competence Framework (e-CF) – A common European Framework for ICT Professionals in all industry sectors – Part 1: Framework*, EN 16234-1:2016
- HITRUST® Common Security Framework, Version 9, September 2017
- Information Security Forum (ISF), *The Standard of Good Practice for Information Security 2016*
- International Organization for Standardization / International Electrotechnical Commission (ISO/IEC) standards
 - ISO/IEC 20000-1:2011(E)
 - ISO/IEC 27001:2013/Cor.2:2015(E)
 - ISO/IEC 27002:2013/Cor.2:2015(E)
 - ISO/IEC 27004:2016(E)
 - ISO/IEC 27005:2011(E)
 - ISO/IEC 38500:2015(E)
 - ISO/IEC 38502:2017(E)
- Information Technology Infrastructure Library (ITIL®) v3, 2011
- Institute of Internal Auditors® (IIA®), “Core Principles for the Professional Practice of Internal Auditing”
- *King IV Report on Corporate Governance*TM, 2016
- US National Institute of Standards and Technology (NIST) standards
 - *Framework for Improving Critical Infrastructure Cybersecurity* V1.1, April 2018
 - Special Publication 800-37, Revision 2 (Entwurf), Mai 2018
 - Special Publication 800-53, Revision 5 (Entwurf), August 2017
- *A Guide to the Project Management Body of Knowledge: PMBOK® Guide Sixth Edition*, 2017
- PROSCI® 3-Phase Change Management Process
- Scaled Agile Framework for Lean Enterprises (SAFe®)
- Skills Framework for the Information Age (SFIA®) V6, 2015
- The Open Group IT4IT® Reference Architecture, Version 2.0
- The Open Group Standard TOGAF® Version 9.2, 2018

Diese Seite wurde absichtlich freigelassen.